# RTSec.Kryptonian

# Formal Engineering Specification

## Revision 0.2 / 13 October 2026

Production publication of the Draft specification

Enterprise healthcare IT cybersecurity infrastructure: EST enrollment, institutional CA integration and credential lifecycle management.

Application baseline: 682f996c8447afec13bc1fce5b7f59e6a06efa25

Markdown is the authoritative editable source. Publication does not imply stakeholder approval, implementation completeness, standards conformity or production readiness.

# Contents

Kryptonian Formal Engineering Specification - Package Index 3
Kryptonian Formal Engineering Specification - Conventions and Controls 8
Kryptonian Product Definition 15
Kryptonian Stakeholder and User Requirements 31
Kryptonian Software Requirements Specification 46
Kryptonian Formal Engineering Specification - Software Design 120
Kryptonian Formal Engineering Specification - Interface Control Document 166
Kryptonian Formal Engineering Specification - Cybersecurity Architecture and Threat Model 192
Kryptonian Formal Engineering Specification - Operational Risk and Reliability Assessment 218
Kryptonian Verification and Validation Specification 241
Kryptonian Requirements Traceability Matrix 281
Kryptonian Formal Engineering Specification - Engineering Gap Analysis 341
Kryptonian Formal Engineering Specification - Security and Standards Conformance Assessment 365
Kryptonian Engineering Handoff Specification 379
Kryptonian Formal Engineering Specification - Independent Review Findings 401
Kryptonian Code and Document Reconciliation 411
Kryptonian Formal Engineering Specification - Final Summary 416

# Kryptonian Formal Engineering Specification - Package Index

| Field | Value |
|---|---|
| Document ID | KSPEC-014 |
| Title | Formal Specification Package Index and Review Sequence |
| Version | 0.2 (Draft) |
| Status | Draft - pending review |
| Created | 2026-10-13 |
| Baseline commit | `682f996c8447afec13bc1fce5b7f59e6a06efa25` (branch `feat/windows-sandbox-installer`) |
| Repository | https://github.com/AAPM-RT-SEC/RTSec.Kryptonian |
| Revision history | 0.1 initial draft; 0.2 code/document reconciliation, 2026-10-13 (KSPEC-016) |
| Source references | KSPEC-000 evidence map; KSPEC-016 reconciliation evidence |
| Author | Unassigned - no approval recorded |
| Reviewer | Unassigned - no approval recorded |
| Approver | Unassigned - no approval recorded |

## 1. Purpose of this package

This directory contains the formal engineering specification for **RTSec.Kryptonian**, a healthcare IT cybersecurity infrastructure system: an EST (RFC 7030) certificate enrollment, identity provisioning, and credential lifecycle management gateway that connects network devices - including medical devices - to institution-managed certificate authorities.

The package was produced by reverse-engineering the repository at the baseline commit above and transforming the observed prototype into an implementation-independent, verifiable specification. It is intended to be handed to an independent engineering team for implementation, testing, maintenance, and future development.

**Classification (binding):** Kryptonian is enterprise IT/security infrastructure. It performs no clinical functions and is not a regulated medical device. Device identity, certificate enrollment authorization, network trust, application-level authorization, and clinical capability remain distinct throughout; no clinical capability may be derived from Kryptonian state.

## 2. Document hierarchy

### KSPEC-000

**File:** `00-SPEC-CONVENTIONS.md`
**Role:** Conventions, terminology, provenance and identifier controls
**Primary audience:** All readers; read first

### KSPEC-001

**File:** `01-PRODUCT-DEFINITION.md`
**Role:** Purpose, stakeholders, boundaries, use cases, scope

**Primary audience:** Everyone

### KSPEC-002

**File:** `02-USER-REQUIREMENTS.md`
**Role:** Stakeholder and user requirements (UR-001 - UR-038)
**Primary audience:** Product owner, stakeholders

### KSPEC-003

**File:** `03-SOFTWARE-REQUIREMENTS.md`
**Role:** **Normative software requirements specification** (154 SR-* requirements + canonical register)
**Primary audience:** Engineering, QA

### KSPEC-004

**File:** `04-SOFTWARE-DESIGN.md`
**Role:** Architecture and design (AS-IS and TO-BE, state machines, data model)
**Primary audience:** Engineering

### KSPEC-005

**File:** `05-INTERFACE-CONTROL.md`
**Role:** EST and admin API interface contracts, CA connector contract
**Primary audience:** Engineering, integrators

### KSPEC-006

**File:** `06-CYBERSECURITY.md`
**Role:** STRIDE threat model, controls, residual risk (THR-001 - THR-018)
**Primary audience:** Security, engineering

### KSPEC-007

**File:** `07-OPERATIONAL-RISK.md`
**Role:** FMEA operational risk assessment and recovery design (ORK-001 - ORK-016)
**Primary audience:** Operations, engineering

### KSPEC-008

**File:** `08-VERIFICATION-VALIDATION.md`
**Role:** V&V strategy and test specification (VT-001 - VT-060)
**Primary audience:** QA, engineering

### KSPEC-009

**File:** `09-TRACEABILITY.md`
**Role:** Bidirectional traceability UR → SR → architecture → evidence → VT
**Primary audience:** QA, review board

### KSPEC-010

**File:** `10-GAP-ANALYSIS.md`
**Role:** 40 findings (GAP-001 - GAP-040) between baseline and target
**Primary audience:** Engineering, product owner

### KSPEC-011

**File:** `11-STANDARDS-CONFORMANCE.md`
**Role:** Standards readiness analysis; no conformity claims
**Primary audience:** Security, standards liaison

### KSPEC-012

**File:** `12-ENGINEERING-HANDOFF.md`
**Role:** Implementation-independent handoff, roadmap, definition of done
**Primary audience:** Incoming engineering team

### KSPEC-015

**File:** `FINAL-SUMMARY.md`
**Role:** Package synthesis and approval limits
**Primary audience:** All readers

### KSPEC-016

**File:** `13-CODE-DOCUMENT-RECONCILIATION.md`
**Role:** Current source audit, corrections and evidence limits
**Primary audience:** Engineering, reviewers

### KSPEC-013

**File:** `REVIEW-FINDINGS.md`
**Role:** Independent review findings (RF-001 - RF-024; original review and current reconciliation) and resolution log
**Primary audience:** Review board

## 3. Review sequence

Read in this order:

1. **KSPEC-000** - conventions (mandatory baseline for identifiers and provenance).
2. **KSPEC-001** → **KSPEC-002** → **KSPEC-003** - what the product is, who needs it, and the normative requirements.
3. **KSPEC-004**, **KSPEC-005**, **KSPEC-006**, **KSPEC-007** - how it is designed, what interfaces exist, what the security model is, and what can fail.
4. **KSPEC-008** and **KSPEC-009** - how conformance is verified and traced.
5. **KSPEC-010**, **KSPEC-011** - what is missing and how the implementation compares with applicable standards.
6. **KSPEC-012** - the handoff synthesis for the incoming team.
7. **KSPEC-013** - independent review status and open findings.

## 4. Review and approval workflow

1. Every document carries a doc-control header (KSPEC-000 §2) with approval placeholders (Author / Reviewer / Approver). All documents are **Draft**; approval is never inferred from implementation.

2. Requirements carry Approval = Draft or Review Required. Approval transitions are a stakeholder decision recorded in the document revision histories.

3. Unresolved thresholds and design decisions are recorded as **TBD** and collected in the decisions register of KSPEC-012 §10 (DEC-001 - DEC-020); they must never be resolved by guessing values.

4. Independent review findings (KSPEC-013) must be dispositioned before any document is promoted to Approved.

## 5. Identifier discipline

Requirement, test, threat, risk, gap, and finding identifiers are allocated per KSPEC-000 §7 and are stable and never reused. The canonical register of all SR-* requirements is KSPEC-003 (Requirements Register section); traceability binding is KSPEC-009. Prefix-level SR references remaining in KSPEC-004, KSPEC-005, KSPEC-007, and KSPEC-012 (a parallel-authoring artifact, finding RF-001) are resolved by the KSPEC-009 §7 binding tables and do not allocate new identifiers.

## 6. Evidence discipline

• Baseline: commit `682f996c8447afec13bc1fce5b7f59e6a06efa25`.

• Provenance classes (VERIFIED / CODE-OBSERVED / DOCUMENTED / INFERRED / PROPOSED / UNKNOWN) are used per KSPEC-000 §5; executed-evidence records live under `artifacts/developer/verify-*/` and `docs/IMPLEMENTATION-TRACKER.md`.

• No document asserts standards conformity, third-party certification, approvals, or medical-device regulatory status. The prototype is reference material only; where it conflicts with this specification, the specification governs.

## 7. Revision history

| Version | Date | Change |
|---|---|---|
| 0.1 | 2026-10-13 | Initial package: documents KSPEC-000 - KSPEC-013 created; independent review (KSPEC-013) performed; RF-002, RF-003, RF-004, RF-005, RF-006, RF-007 corrections applied (see KSPEC-013 resolution log). |
| 0.2 | 2026-10-13 | Reconciled source behavior and evidence; corrected requirement statuses and traceability; added KSPEC-016, GAP-038-040 and VT-059-060; added reproducible PDF publication and fresh regression records. |

## 8. Editable source and production PDF

The `.md` files are the authoritative specification source. The publication is `Kryptonian-Formal-Specification.pdf` in this directory. It contains the complete 17-document package, rendered Mermaid diagrams, document bookmarks, a contents page, page numbers and explicit Draft review status. Diagram sheets use larger page sizes to retain legible labels. Wide Markdown tables publish as labeled records so their text stays readable and no columns are silently dropped.

Install the pinned build dependencies once from the repository root:

```
python -m pip install -r docs/formal-specification/tools/requirements.txt
npm ci --prefix docs/formal-specification/tools
```

Validate and rebuild after editing the Markdown:

```
python docs/formal-specification/tools/validate_specs.py
python docs/formal-specification/tools/build_pdf.py
```

`validation/verification.json` reports mechanical checks and available fresh test evidence. `validation/publication-manifest.json` records ordered source hashes, dependency versions, output hash, page count and diagram count. Generated diagram images, page previews, logs and test results are ignored; Markdown, build tools, dependency lockfiles, manifests and the final PDF are retained.

Reproduce application checks separately:

```
dotnet test RTSec.Kryptonian.sln --logger trx --results-directory docs/formal-
specification/validation/test-results
```

A link to a VT means a specified verification obligation, not that its full procedure has passed. Source inspection, existing test definitions, historical live evidence, and freshly executed tests retain distinct provenance. See KSPEC-016 first for the current reconciliation findings. This PDF is production-quality documentation of a Draft specification; it does not assert production readiness of the application.

# Kryptonian Formal Engineering Specification - Conventions and Controls

| Field | Value |
|---|---|
| Document ID | KSPEC-000 |
| Title | Specification Conventions and Document Controls |
| Version | 0.2 (Draft) |
| Status | Draft - pending review |
| Created | 2026-10-13 |
| Baseline commit | `682f996c8447afec13bc1fce5b7f59e6a06efa25` (branch `feat/windows-sandbox-installer`, "Release Windows gateway and portable enrollment demo 0.1.4") |
| Repository | https://github.com/AAPM-RT-SEC/RTSec.Kryptonian |
| Revision history | 0.1 initial draft; 0.2 code/document reconciliation, 2026-10-13 (KSPEC-016) |
| Source references | KSPEC-000 evidence map; KSPEC-016 reconciliation evidence |
| Author | Unassigned - no approval recorded |
| Reviewer | Unassigned - no approval recorded |
| Approver | Unassigned - no approval recorded |

This document defines the shared conventions, terminology, provenance classes, and document-control rules that apply to every document in `docs/formal-specification/`. It is the controlling reference for identifier allocation and evidence classification.

# 1. Document hierarchy and identifiers

| Document ID | File | Role |
|---|---|---|
| KSPEC-000 | `00-SPEC-CONVENTIONS.md` | Conventions and controls (this document) |
| KSPEC-001 | `01-PRODUCT-DEFINITION.md` | Product definition, scope, stakeholders, use cases |
| KSPEC-002 | `02-USER-REQUIREMENTS.md` | Stakeholder and user requirements (UR-nnn) |
| KSPEC-003 | `03-SOFTWARE-REQUIREMENTS.md` | Normative software requirements specification (SR-*) |
| KSPEC-004 | `04-SOFTWARE-DESIGN.md` | Architecture and design (AS-IS and TO-BE) |
| KSPEC-005 | `05-INTERFACE-CONTROL.md` | Interface control specification (ICD-nnn items) |
| KSPEC-006 | `06-CYBERSECURITY.md` | Cybersecurity architecture and threat model (THR-nnn) |
| KSPEC-007 | `07-OPERATIONAL-RISK.md` | Operational risk and reliability assessment (ORK-nnn) |
| KSPEC-008 | `08-VERIFICATION-VALIDATION.md` | Verification and validation specification (VT-nnn) |
| KSPEC-009 | `09-TRACEABILITY.md` | Requirements traceability matrix |
| KSPEC-010 | `10-GAP-ANALYSIS.md` | Engineering gap analysis (GAP-nnn) |
| KSPEC-011 | `11-STANDARDS-CONFORMANCE.md` | Security and standards conformance assessment |
| KSPEC-012 | `12-ENGINEERING-HANDOFF.md` | Engineering handoff specification |
| KSPEC-013 | `REVIEW-FINDINGS.md` | Independent review findings (RF-nnn) |
| KSPEC-014 | `README.md` | Package index and review sequence |
| KSPEC-015 | `FINAL-SUMMARY.md` | Package summary |
| KSPEC-016 | `13-CODE-DOCUMENT-RECONCILIATION.md` | Current source/document reconciliation |

Review sequence: 000 → 001 → 002 → 003 → (004, 005, 006, 007) → (008, 009, 010, 011) → 012 → 013 → 014.

# 2. Document control header (mandatory)

Every generated document shall begin with a table containing: document title, unique document identifier (per §1), version, review status (Draft / In Review / Approved), creation date, baseline repository commit SHA, revision history, source references, and approval placeholders (Author / Reviewer / Approver with name-date-signature rows).

# 3. Product classification (binding for all documents)

Kryptonian is **enterprise healthcare IT cybersecurity infrastructure**: a certificate enrollment, identity provisioning, and credential lifecycle management gateway. It is **not** a regulated medical device and performs **no clinical functions**. All documents shall:

- Exclude medical-device regulatory classification, FDA pathways, IEC 62304 lifecycle classification, ISO 14971 medical-device hazard analysis, and similar content.
- Preserve the distinction between **device identity** (X.509 credential holders), **certificate enrollment authorization** (approval to obtain a credential), **network trust** (TLS/mTLS peer authentication), **application-level authorization** (what a

device may do at the application layer), and **clinical capability** (explicitly out of scope - never derived from Kryptonian state).

• Describe the device simulators (`Kryptonian.MedicalDevice`, `Kryptonian.DICOMTls`) as demonstration/reference clients, not as product deliverables for production.

## 4. AS-IS / TO-BE / PROPOSED classification

Every behavior description, architecture element, requirement, and interface shall be classified:

• **AS-IS** - behavior present in the baseline commit (implementation source of evidence).

• **TO-BE** - intended, formally specified behavior of the target system (normative).

• **PROPOSED** - enhancement or design alternative requiring stakeholder approval (never presented as normative without approval).

Defects, shortcuts, weak controls, or limitations observed in the prototype are recorded as findings and gaps - they are **never reproduced as intended requirements**.

## 5. Evidence provenance classes

All technical assertions shall carry one of these classes:

| Class | Meaning |
|---|---|
| VERIFIED | Confirmed through source inspection **and** executed tests (including recorded evidence under `artifacts/developer/verify-*/`). |
| CODE-OBSERVED | Established by source inspection only. |
| DOCUMENTED | Supported only by existing repository documentation; not confirmed in code. |
| INFERRED | Plausible conclusion from indirect evidence; not verified. |
| PROPOSED | Recommended behavior requiring stakeholder approval; not implemented. |
| UNKNOWN | Insufficient evidence; recorded as an open question or TBD. |

Prohibitions: no fabricated test results, approvals, standards conformity claims, or stakeholder decisions. Documented-only claims are never upgraded to VERIFIED.

## 6. Requirement status classes

| Status | Meaning |
|---|---|
| Existing | Fully implemented at baseline with positive evidence. |
| Partial | Implemented incompletely or with known deviations. |
| Missing | Not implemented at baseline; required in TO-BE. |
| Proposed | Recommended addition requiring approval. |

## 7. Requirement identifier scheme

Identifiers are stable and never reused. Format: `<PREFIX>-<AREA>.<n>` where AREA is a short mnemonic (e.g., `SR-F-REG.001`). Standalone prefixes use simple `-nnn` numbering.

| Prefix | Domain | Owner document |
|---|---|---|
| UR | Stakeholder/user requirements | KSPEC-002 |
| SR-F | Functional requirements (REG device registration, EST EST protocol, CLM certificate lifecycle, CAI CA integration, ADM administration, INT interoperability) | KSPEC-003 |
| SR-S | Security requirements | KSPEC-003 |
| SR-A | Authentication requirements | KSPEC-003 |
| SR-Z | Authorization requirements | KSPEC-003 |
| SR-C | Certificate lifecycle requirements | KSPEC-003 |
| SR-D | Data management requirements | KSPEC-003 |
| SR-P | Performance requirements | KSPEC-003 |
| SR-R | Reliability requirements | KSPEC-003 |
| SR-V | Availability requirements | KSPEC-003 |
| SR-U | Audit requirements | KSPEC-003 |
| SR-B | Deployment requirements | KSPEC-003 |
| SR-O | Operational maintenance requirements | KSPEC-003 |
| SR-X | Failure and recovery requirements | KSPEC-003 |
| THR | Threats (threat model entries) | KSPEC-006 |
| ORK | Operational risks | KSPEC-007 |
| VT | Verification tests | KSPEC-008 |
| GAP | Findings (gap analysis) | KSPEC-010 |
| RF | Independent review findings | KSPEC-013 |

The canonical register of all normative requirements (ID, statement, priority, status, verification method) is maintained in `03-SOFTWARE-REQUIREMENTS.md` (Requirements Register) and summarized in `09-TRACEABILITY.md`. Other documents reference requirements by ID only and shall not redefine them.

# 8. Requirement record format (KSPEC-003)

Every normative requirement is presented with the fields: ID, Requirement (single verifiable obligation using "shall"), Rationale, Source, Priority (Critical/High/Medium/Low), Status (Existing/Partial/Missing/Proposed), Verification (Test/Inspection/Analysis/Demonstration), Evidence (repository path, commit, doc reference), Approval (Draft/Review Required/Approved).

Approval state is **never** inferred from implementation. At baseline, all requirements are `Draft` or `Review Required`. Unconfirmed thresholds use `TBD` with a separate recommendation and rationale.

# 9. Terminology (binding)

| Term | Definition |
|---|---|
| Gateway | The Kryptonian server application (API + admin portal). |
| Device | A networked client (often a medical device or its local agent) that enrolls via EST. |
| Activation code | One-time, short-lived credential issued at registration; consumed by the device to bootstrap EST authentication. |
| EST profile | Named policy bundle binding devices to a CA backend, subject-DN rules, key usage, validity, and trust policy. |
| CA backend | An institution-managed certificate authority reachable through a connector (Self-Signed, ACME, ADCS, EJBCA). |
| Connector | Implementation of the internal CA abstraction for one backend type. |
| Trust policy | Persisted profile data defining which issuers/anchors the gateway and clients accept. |
| Enrollment event | Persisted record of an enrollment/renewal/revocation attempt and outcome. |
| CRL | Certificate revocation list, issuer-scoped, published by the gateway or by the CA. |
| Renewal window | Pre-expiry period during which re-enrollment without re-approval is authorized. |
| Admin portal | React/TypeScript dashboard served by the API; a separate optional Blazor Server portal also exists. |
| DIMSE-TLS proxy | Demonstration component terminating mTLS for DICOM associations (AS-IS demonstration only). |

# 10. Evidence source map

| Evidence area | Primary repository sources |
|---|---|
| Product intent, positioning | README.md, Mvp.md, docs/HACKATHON-DELIVERABLE.md, docs/background.md, docs/ORNET-ALIGNMENT-2026-09-09.md, docs/CHANGES-AND-ORNET-ALIGNMENT.md |
| Architecture | docs/ARCHITECTURE.md, docs/flow.md, src/RTSec.Kryptonian.{Api,Application,Domain,Infrastructure,Web} |
| Interfaces / contracts | OpenAPI.Admin.yaml, OpenAPI.Client.yaml, OpenAPI.ESTProfiles.yaml, OpenAPI.Schema.yaml, OpenAPI.StatusObserve.yaml, docs/API-GUIDE.md, src/RTSec.Kryptonian.Api/Controllers/ |
| Device registration & lifecycle | src/RTSec.Kryptonian.Application/Services/, DevicesController.cs, docs/device-enrollment.md, docs/sequence-diagrams/*.mmd |
| EST protocol behavior | EstController.cs, EstProfilesController.cs, CrlController.cs, docs/device-enrollment.md |
| CA integration | src/RTSec.Kryptonian.Infrastructure/Harness/* (ADCS, EJBCA, Self-Signed connectors, SCEP client), src/RTSec.Kryptonian.Infrastructure/Acme/*, CaBackendsController.cs, docs/ca-backend-configuration.md, docs/adcs-real-backend-demo.md |
| Identity, users, RBAC | AuthController.cs, UsersController.cs, ApiKeyAuthenticationHandler.cs, docs/user-management.md, docs/admin-setup.md |
| Certificate lifecycle | CertificatesController.cs, CertificateExpiryWatcher.cs, CrlController.cs, enrollment events, docs/sequence-diagrams/07-* |
| Notifications | NotificationSettingsController.cs, src/RTSec.Kryptonian.Infrastructure/Notifications/*, docs/email-notifications.md |
| Device-side EST client | src/Kryptonian.MedicalDevice/Enrollment/*, docs/medical-device-demo.md, docs/README-enrollment-demo.md |
| DICOM TLS demonstration | src/Kryptonian.DICOMTls/*, docs/sequence-diagrams/08-*, tests/RTSec.Kryptonian.DimseTlsProxy.Tests/ |
| Deployment | docs/DEPLOYMENT.md, docker-compose*.yml, deploy/, installer/, docs/windows-installation.md, docs/windows-sandbox.md |
| Executed-test evidence | artifacts/developer/verify-*/evidence.json, tests/ (8 test projects), .github/workflows/ |
| Known limits & boundaries | docs/IMPLEMENTATION-TRACKER.md (deliberate boundaries section), README.md disclaimer |

# 11. Verification method abbreviations

T = Test, I = Inspection, A = Analysis, D = Demonstration (ISO/IEC/IEEE 29148 usage).

# 12. Diagrams

Architecture, sequence, and state-machine diagrams use Mermaid fenced blocks unless PlantUML is required for state-machine complexity; Mermaid is the default.

# 13. Restrictions inherited from the assignment

- No application source code modifications; documentation artifacts only.
- No refactoring, defect fixing, or feature implementation.

- No fabricated evidence, approvals, or conformity claims.
- Prototype behavior never becomes normative without explicit review and approval.

## 14. Publication controls

Markdown is authoritative editable source. Production PDFs preserve Draft status and are generated using `tools/build_pdf.py`. The source-hash publication manifest identifies the exact Markdown revision independently of the application baseline SHA. Use KSPEC-016 and the current disposition section in KSPEC-013 for current review status; original review passages are historical evidence.

# Kryptonian Product Definition

| Field | Value |
|---|---|
| Document title | Kryptonian Product Definition and Scope |
| Document ID | KSPEC-001 |
| Version | 0.2 (Draft) |
| Review status | Draft - pending review |
| Created | 2026-10-13 |
| Baseline repository commit | `682f996c8447afec13bc1fce5b7f59e6a06efa25` (branch `feat/windows-sandbox-installer`, "Release Windows gateway and portable enrollment demo 0.1.4") |
| Repository | https://github.com/AAPM-RT-SEC/RTSec.Kryptonian |
| Revision history | 0.1 - 2026-10-13 - Initial draft generated from baseline documentation and evidence map (Author: requirements engineering team). |
| Source references | KSPEC-000 (conventions); README.md; Mvp.md; docs/IMPLEMENTATION-TRACKER.md; docs/HACKATHON-DELIVERABLE.md; docs/background.md; docs/ORNET-ALIGNMENT-2026-09-09.md; docs/CHANGES-AND-ORNET-ALIGNMENT.md; docs/flow.md; docs/ARCHITECTURE.md; docs/device-enrollment.md; docs/user-management.md; docs/ca-backend-configuration.md; docs/medical-device-demo.md; docs/DEPLOYMENT.md |
| Author | Name: TBD - Date: TBD - Signature: TBD |
| Reviewer | Name: TBD - Date: TBD - Signature: TBD |
| Approver | Name: TBD - Date: TBD - Signature: TBD |
| Reconciliation revision | 0.2 - 2026-10-13 - source/document audit and publication controls (KSPEC-016) |

This document defines the product purpose, stakeholders, intended users, operating environment, system boundaries, assumptions, dependencies, exclusions, primary use cases, operational scenarios, and scope classification (AS-IS / TO-BE / PROPOSED) for the RTSec.Kryptonian Certificate Enrollment Gateway. It follows the conventions of KSPEC-000 and classifies every technical assertion with a provenance class (VERIFIED / CODE-OBSERVED / DOCUMENTED / INFERRED / PROPOSED / UNKNOWN).

## 1. Introduction

### 1.1 Purpose of this document

This document establishes a shared, evidence-classified understanding of what the Kryptonian gateway *is*, who it serves, where it runs, what lies inside and outside its boundary, and which behaviors exist today (AS-IS) versus are intended (TO-BE) or merely proposed (PROPOSED). It is the upstream source from which stakeholder and user requirements (KSPEC-002, UR-nnn) and software requirements (KSPEC-003, SR-*) are derived.

### 1.2 Intended audience

Reviewers of the formal specification package, AAPM RT-SEC working-group members, hospital stakeholders evaluating the gateway, and engineers performing gap analysis (KSPEC-010) and traceability (KSPEC-009).

# 2. Product purpose

**Provenance: DOCUMENTED** (README.md; Mvp.md; docs/background.md)

Kryptonian is an **enterprise healthcare IT cybersecurity infrastructure** component: a certificate enrollment, identity provisioning, and credential lifecycle management gateway for networked medical devices. It sits between device-side EST clients (RFC 7030, Enrollment over Secure Transport) and one or more hospital-authorized certificate authority (CA) backends.

The problem it addresses: hospitals operate heterogeneous CA infrastructures (Microsoft ADCS, EJBCA, ACME services, private self-signed CAs), while device manufacturers cannot control which CA a given hospital uses. Without an intermediary, each vendor must implement custom, often incomplete certificate-handling logic per hospital, producing manual certificate installs, expired-certificate outages, incompatible TLS settings, and inconsistent trust models (Mvp.md; docs/background.md).

Kryptonian provides:

- **Device enrollment** - devices register against an administrator-issued, one-time activation code, are bound to an approved identity, and receive certificates through EST (README.md; docs/device-enrollment.md).
- **Automatic certificate renewal** - approved devices renew credentials without administrator intervention unless their privileges are revoked (README.md).
- **Renewal monitoring** - administrators receive notifications when certificates are not renewed as expected, signaling potential device problems (README.md).
- **Multi-CA abstraction** - a single EST interface for devices regardless of which CA backend the institution uses (README.md; docs/flow.md).
- **Centralized inventory and audit** - device records, certificate metadata, and enrollment events recorded for every enrollment decision (docs/flow.md).
- **Trust lifecycle** - administrative trust removal and revocation so that devices can no longer obtain fresh credentials, with demonstrated revocation checking by peers (docs/flow.md; IMPLEMENTATION-TRACKER.md).

The project is a **reference implementation and test environment** contributed by the AAPM RT-SEC working group. It is positioned to contribute operational DICOM lifecycle evidence to the OR.NET / IEEE 11073 SDC enrollment work - **not** to define a competing enrollment protocol (README.md; docs/ORNET-ALIGNMENT-2026-09-09.md). It is a proof-of-concept research prototype, not intended for clinical deployment, and not an adopted OR.NET enrollment profile, SDC conformity implementation, or DICOM TLS certification (README.md disclaimer).

## 2.1 Binding product classification

Per KSPEC-000 §3, which is binding on this document:

- Kryptonian is **not a regulated medical device** and performs **no clinical functions**. It is excluded from medical-device regulatory classification discussions, FDA pathways, IEC 62304 lifecycle classification, and ISO 14971 medical-device hazard analysis.
- The following distinctions are preserved throughout the specification:
  - **Device identity** - the X.509 credential a device holds.
  - **Certificate enrollment authorization** - approval to obtain a credential.
  - **Network trust** - TLS/mTLS peer authentication.
  - **Application-level authorization** - what a device may do at the application layer.
  - **Clinical capability** - explicitly out of scope; never derived from Kryptonian state.
- The device simulators (`Kryptonian.MedicalDevice`, `Kryptonian.DICOMTls`) are demonstration/reference clients, not production product deliverables.

"Certificate renewal" throughout this specification means renewal of cryptographic credentials. It does **not** recertify a device's clinical safety, regulatory status, or SDC conformity (docs/CHANGES-AND-ORNET-ALIGNMENT.md).

## 3. Stakeholders

| Stakeholder | Interest in the gateway | Provenance |
|---|---|---|
| Hospital IT administrators | Operate the gateway: register devices, issue activation codes, manage the device inventory, configure CA backends and EST profiles, monitor the dashboard. | DOCUMENTED (docs/user-management.md; docs/ca-backend-configuration.md; README.md) |
| Hospital cybersecurity personnel | Audit enrollment events, enforce trust policy, remove trust and revoke credentials, configure notifications, ensure secrets and deployment hardening. | DOCUMENTED (docs/flow.md; docs/email-notifications.md) |
| Device manufacturers | Implement one standard device-side enrollment workflow (EST) that works across heterogeneous hospital CA choices. | DOCUMENTED (docs/background.md; Mvp.md) |
| Device software developers | Implement and maintain the device-side EST client (bootstrap activation, `simpleenroll`, `simplereenroll`, key generation and protection, credential installation and renewal). | DOCUMENTED (docs/medical-device-demo.md; src/Kryptonian.MedicalDevice) |
| Clinical engineering (biomedical/HTM staff) | Keep imaging and therapy devices operational; avoid expired-certificate outages; need certificate expiry visibility without confusing it with clinical service status. | INFERRED (derived from README.md renewal-monitoring motivation and Mvp.md outage-reduction goals) |
| Healthcare system integrators | Integrate the gateway into hospital estates and automation via the REST admin API, API keys, and containerized or Windows deployment. | DOCUMENTED (docs/DEPLOYMENT.md; docs/API-GUIDE.md) |
| Enterprise PKI administrators | Connect institution-managed CAs through connectors; control certificate policy (subject-DN rules, key usage, validity) via EST profiles; manage issuer trust and revocation publication. | DOCUMENTED (docs/ca-backend-configuration.md; KSPEC-000 §9 terminology) |
| AAPM RT-SEC / OR.NET research community | Use the gateway as a reference implementation and test environment; contribute operational DICOM lifecycle evidence to the OR.NET/IEEE 11073 SDC enrollment effort under shared requirements and test cases. | DOCUMENTED (README.md; docs/ORNET-ALIGNMENT-2026-09-09.md; docs/CHANGES-AND-ORNET-ALIGNMENT.md) |

Patients and clinical operations benefit indirectly (fewer insecure transfers, expired-certificate outages, and manual installation mistakes - docs/background.md) but are not direct users of the gateway.

# 4. Intended users

| User class | Roles used in the gateway (AS-IS) | Typical activities |
|---|---|---|
| Gateway administrators (SystemAdmin) | Full access: user management, CA backends, EST profiles, gateway and notification settings. | First-run admin setup; user administration; backend/profile configuration. |
| Device administrators (DeviceAdmin) | Register/approve/remove devices; generate API keys for scripted device management. | Device registration; activation-code handover; device removal; API-key issuance. |
| Standard (read-only) users | View dashboards, devices, certificates, EST profiles, CA backends, event log. | Monitoring and audit review. |
| Scripted/automation clients | `X-API-Key` authenticated REST clients carrying the owner's role. | CI pipelines, integration automation. |
| Devices (non-human) | EST clients authenticating with activation code (first enrollment) or device certificate (renewal). | Enrollment, renewal, CRL retrieval. |

**Provenance: DOCUMENTED** (docs/user-management.md). RBAC elaboration: KSPEC-002 (UR-032) and KSPEC-003 (SR-Z area).

# 5. Operating environment

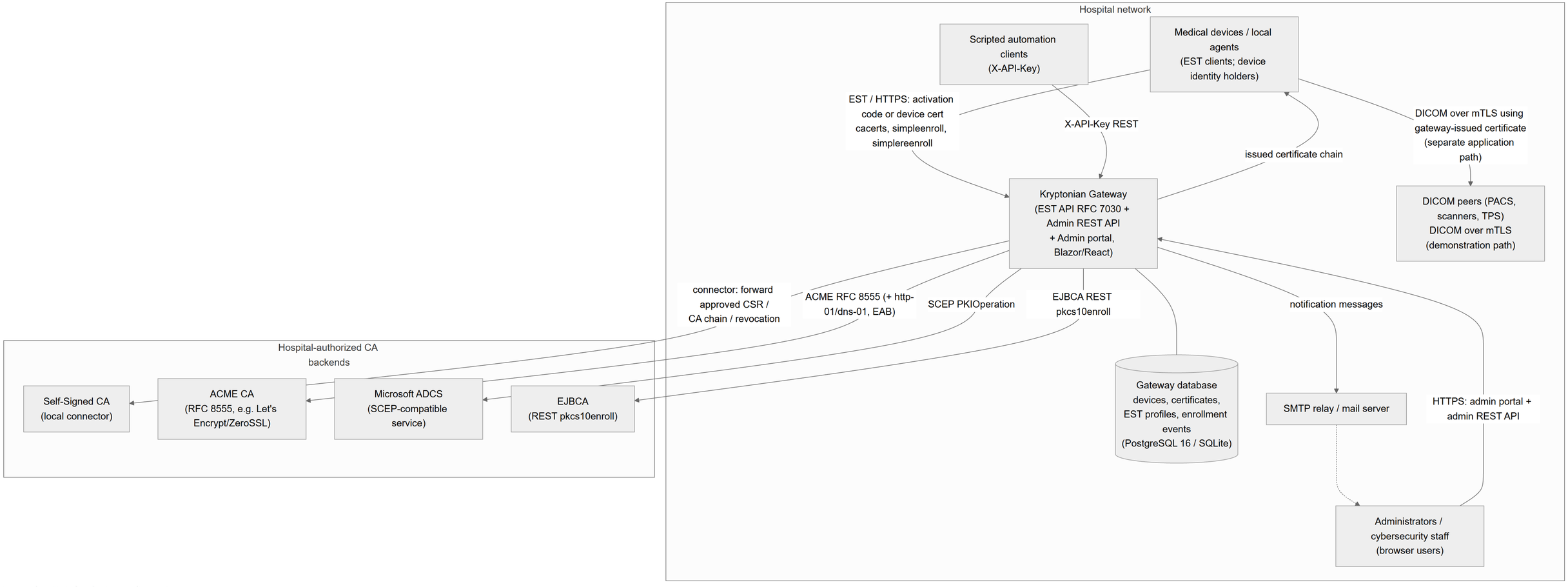
**Provenance: DOCUMENTED** unless noted.

- **Deployment targets**: Docker / Docker Compose (Docker 24.0+, Compose 2.20+) and Kubernetes manifests (docs/DEPLOYMENT.md); a Windows gateway package with installer and Windows sandbox distribution (docs/medical-device-demo.md; docs/windows-installation.md).
- **Runtime**: .NET 8, ASP.NET Core. The API serves the React/TypeScript dashboard from its built static files. `RTSec.Kryptonian.Web` is a separate optional Blazor Server/MudBlazor portal; React is not embedded in that process (CODE-OBSERVED: both `Program.cs` files).
- **Persistence**: PostgreSQL 16 in the production topology; SQLite exercised in the developer/Windows preview environment; PostgreSQL schema upgrades implemented but only SQLite persistence exercised at baseline (docs/DEPLOYMENT.md; IMPLEMENTATION-TRACKER.md - see TBD-006 in §14).
- **Network position**: hospital network segment reachable by devices for EST (`/.well-known/est/{profile}/...` over HTTPS) and by administrators for the portal and admin REST API; gateway reaches CA backends over HTTPS/REST (ADCS via an SCEP-compatible service, EJBCA REST, ACME directory) (docs/ARCHITECTURE.md; docs/ca-backend-configuration.md).
- **TLS**: TLS 1.2+; device-facing EST over HTTPS; mTLS demonstrated end-to-end for DICOM via gateway-issued certificates (docs/ARCHITECTURE.md; IMPLEMENTATION-TRACKER.md).
- **Email (SMTP)**: outbound SMTP used for notification delivery (MailKit; docs/email-notifications.md).
- **Demonstration environment**: the AAPM RT-SEC hackathon CA Harness (hosted selfsigned/ADCS/EJBCA/ACME backends, DIMSE TLS proxy, Orthanc DICOM endpoints) and a local fo-dicom TLS store SCP in the DICOM mTLS demo (docs/HACKATHON-DELIVERABLE.md; README.md §DICOM TLS demo).
- **Device-side**: the reference device client is a Windows x64 self-contained WPF application (`Kryptonian.MedicalDevice`); automatic renewal runs only while the application is open (docs/medical-device-demo.md; IMPLEMENTATION-TRACKER.md).

# 6. System boundaries

## 6.1 Context diagram

## Diagram KSPEC-001-1




Rendered from 01-PRODUCT-DEFINITION.md. Diagram sheets use larger page sizes to preserve readable labels.

**Provenance: DOCUMENTED** for all elements and edges above, from the sources cited in §5 plus docs/flow.md, docs/user-management.md, docs/email-notifications.md.

### 6.2 Boundary statements

| Boundary element | Inside the gateway boundary | Outside the gateway boundary |
|---|---|---|
| Trust policy | Device trust registry, activation, approval, profile selection, renewal-window decisions (docs/flow.md). | CA-internal issuance policy configured at the CA itself. |
| Certificate issuance | CSR validation and forwarding of **approved** requests only; certificate metadata storage. | Actual signing, which is performed by the CA backend. |
| Credential use | Issuance and lifecycle; demonstration of mTLS acceptance via the DIMSE-TLS proxy (AS-IS demonstration only). | Production DICOM/SDC application protocols and their authorization. |
| Device software | Reference simulators shipped as demonstration clients. | Real vendor device firmware and clinical applications. |

## 7. Assumptions

| ID | Assumption | Provenance |
|---|---|---|
| ASM-001 | Devices (or their local agents) generate and protect their own private keys; the gateway does not take custody of device private keys in the intended design. | DOCUMENTED (docs/flow.md responsibility split; docs/ORNET-ALIGNMENT-2026-09-09.md target architecture) |
| ASM-002 | The institution operates and authorizes at least one CA backend and supplies its connector configuration. | DOCUMENTED (docs/ca-backend-configuration.md) |
| ASM-003 | Administrators deliver activation codes to devices through a trusted provisioning channel outside the gateway. | DOCUMENTED (docs/device-enrollment.md) |
| ASM-004 | Devices can reach the gateway's HTTPS EST endpoint over the hospital network, and the gateway can reach the active CA backend. | INFERRED (deployment topology; not separately evidenced) |
| ASM-005 | Reliable time sources are available for certificate validity and renewal-window logic. | PROPOSED (docs/ORNET-ALIGNMENT-2026-09-09.md lists reliable time among availability evidence needs; not evidenced as implemented) |
| ASM-006 | The gateway is deployed inside a segmented network; CA backend connectors are reachable from a more restricted network zone than devices. | PROPOSED (Mvp.md §8 recommends segmentation; deployment realization UNKNOWN at baseline) |
| ASM-007 | The gateway is a research prototype not deployed in clinical production; independent security assessment precedes any such deployment. | DOCUMENTED (README.md disclaimer) |

# 8. Dependencies

### DEP-001

**Dependency:** .NET 8 runtime / ASP.NET Core hosting
**Nature:** Runtime
**Provenance:** DOCUMENTED (docs/ARCHITECTURE.md)

### DEP-002

**Dependency:** PostgreSQL 16 (production) or SQLite (developer/preview)
**Nature:** Persistence
**Provenance:** DOCUMENTED (docs/DEPLOYMENT.md; IMPLEMENTATION-TRACKER.md)

### DEP-003

**Dependency:** Entity Framework Core 8, BouncyCastle, Certes, Serilog, AspNetCoreRateLimit, MailKit (+ BouncyCastle transitive)
**Nature:** Libraries
**Provenance:** DOCUMENTED (docs/ARCHITECTURE.md; IMPLEMENTATION-TRACKER.md)

### DEP-004

**Dependency:** A reachable, institution-authorized CA backend of one of the supported types
**Nature:** External system
**Provenance:** DOCUMENTED (docs/ca-backend-configuration.md)

### DEP-005

**Dependency:** SMTP service for email notifications
**Nature:** External system
**Provenance:** DOCUMENTED (docs/email-notifications.md)

### DEP-006

**Dependency:** TLS server certificate (and public issuing CA certificate) for the EST/HTTPS listener; for the Windows sandbox this is distributed as a public CA file
**Nature:** Configuration
**Provenance:** DOCUMENTED (docs/medical-device-demo.md)

### DEP-007

**Dependency:** Docker 24.0+ / Compose 2.20+ (container deployment) or Windows host (installer/sandbox)
**Nature:** Platform
**Provenance:** DOCUMENTED (docs/DEPLOYMENT.md; docs/medical-device-demo.md)

### DEP-008

**Dependency:** Remaining high-severity transitive dependency advisories (SQLitePCLRaw.lib.e_sqlite3 2.1.6, System.Security.Cryptography.Xml 8.0.2) identified as deployment blockers
**Nature:** Known constraint
**Provenance:** DOCUMENTED (IMPLEMENTATION-TRACKER.md)

# 9. Exclusions (out of scope)

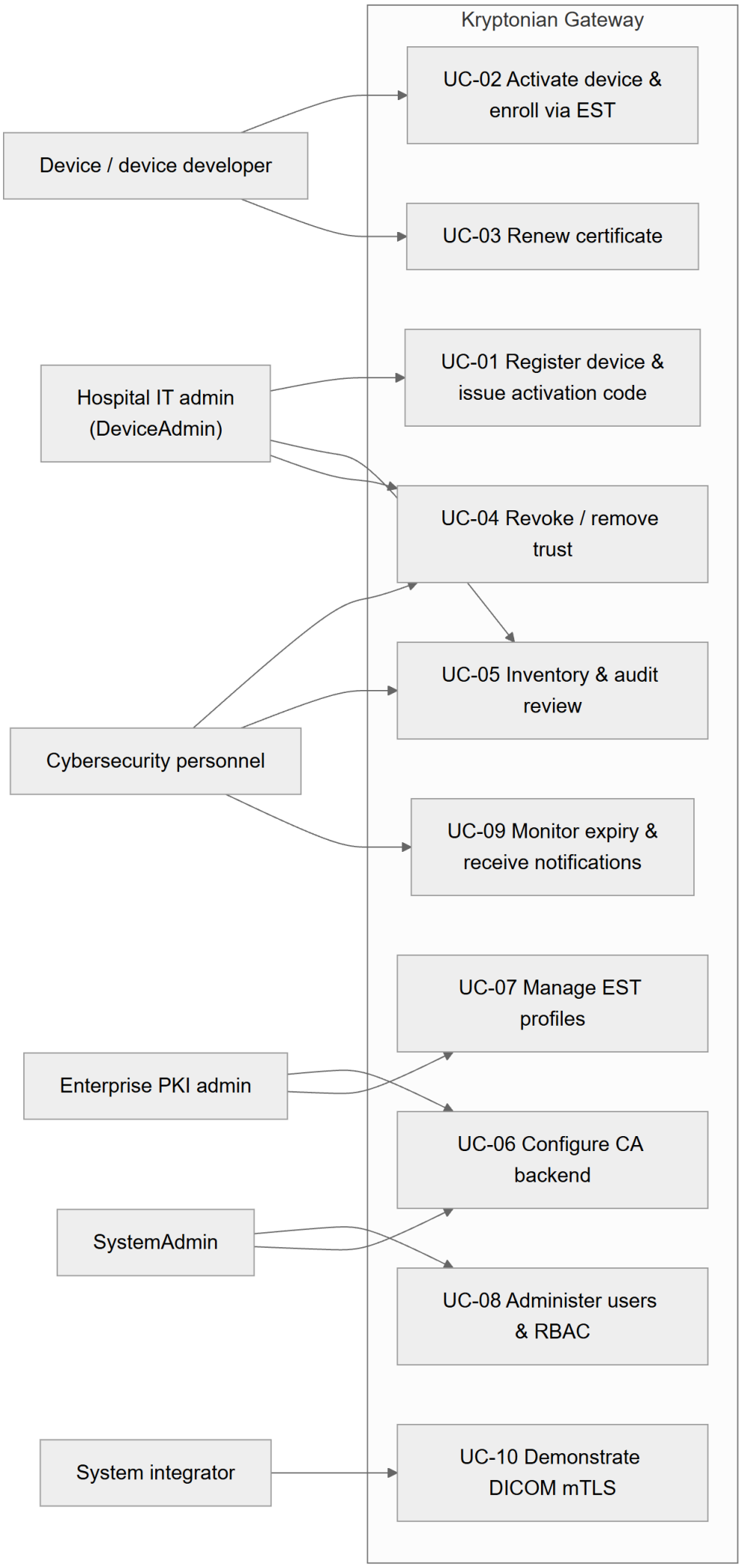
The following are explicitly **out of scope** for the product definition and for the requirements derived from it:

| ID | Exclusion | Basis |
|---|---|---|
| EXC-001 | Clinical authorization: determining or expressing what a device is clinically permitted to do. Clinical capability is never derived from Kryptonian state. | KSPEC-000 §3 (binding) |
| EXC-002 | SDC role assignment: issuing certificates containing SDC OIDs is not an SDC role or interoperability demonstration; no SDC participant exchange exists at baseline. | DOCUMENTED (IMPLEMENTATION-TRACKER.md deliberate boundaries) |
| EXC-003 | Key escrow and server-side key generation in production design: device private keys are never exported by design; any server-side key generation would require HSM-grade treatment and is not an MVP function. | DOCUMENTED (Mvp.md §1, §8) |
| EXC-004 | Defining a competing enrollment protocol or a new medical-device interoperability requirement from prototype-specific headers (e.g., legacy activation headers must not become mandatory). | DOCUMENTED (README.md; IMPLEMENTATION-TRACKER.md) |
| EXC-005 | Standards conformity claims: no EST, SDC, SDPi, ATNA, DICOM TLS/B.12/B.13 conformance, FDA/IEC 62304/ISO 14971 classification, or OR.NET adoption claims. | DOCUMENTED (README.md disclaimer; ORNET-ALIGNMENT review limits) |
| EXC-006 | Long-lived OS-service device operation, hardware-backed key storage, and old-certificate retirement policy: flagged as deployment policy decisions, not baseline features. | DOCUMENTED (IMPLEMENTATION-TRACKER.md) |
| EXC-007 | Instant mid-association revocation of established TLS/DICOM connections: proxy connections have bounded lifetimes; revocation affects new connections and credential acquisition. | DOCUMENTED (IMPLEMENTATION-TRACKER.md; ORNET-ALIGNMENT availability note) |
| EXC-008 | ATNA/DICOM audit-format conformance and audit export protection: mapping lifecycle events to audit standards is a separate conformance task. | DOCUMENTED (docs/ORNET-ALIGNMENT-2026-09-09.md) |

# 10. Primary use cases

## 10.1 Use-case overview

## Diagram KSPEC-001-2




Rendered from 01-PRODUCT-DEFINITION.md. Diagram sheets use larger page sizes to preserve readable labels.

## 10.2 Use-case descriptions

### UC-01

**Use case:** Register device and issue activation code

**Primary actor:** Hospital IT admin

**Summary (AS-IS unless noted):** Admin creates a pending device alias in the Devices portal; gateway generates a one-time, time-limited, hashed activation code. Admin hands the code to the device operator through the hospital provisioning process.

**Provenance:** DOCUMENTED (docs/device-enrollment.md)

### UC-02

**Use case:** Activate device and enroll via EST

**Primary actor:** Device

**Summary (AS-IS unless noted):** Device generates key pair + CSR, presents activation code with device metadata (CN from CSR, manufacturer, model, serial); gateway validates the code (exists, unexpired, unused, belongs to pending registration), binds identity, forwards CSR to the active CA backend, returns the first certificate, marks device active, consumes the code.

**Provenance:** DOCUMENTED (docs/device-enrollment.md)

### UC-03

**Use case:** Renew certificate

**Primary actor:** Device

**Summary (AS-IS unless noted):** Active device re-authenticates with its existing device certificate (not the activation code) and uses EST `simplereenroll` in the renewal window; gateway re-approves automatically and returns a fresh certificate.

**Provenance:** DOCUMENTED (docs/device-enrollment.md; README.md)

### UC-04

**Use case:** Revoke and remove trust

**Primary actor:** Cybersecurity personnel / DeviceAdmin

**Summary (AS-IS unless noted):** Admin marks device untrusted/removed; gateway rejects subsequent enrollment and renewal, records a blocked enrollment event; issuer-scoped signed CRLs support revocation; demonstrated online revocation checking independent of registry lookup.

**Provenance:** DOCUMENTED (docs/flow.md trust removal); VERIFIED for revocation behavior (IMPLEMENTATION-TRACKER.md: revocation followed by X509Chain reporting Revoked)

### UC-05

**Use case:** Inventory and audit review

**Primary actor:** IT admin / cybersecurity / read-only users

**Summary (AS-IS unless noted):** Portal lists devices with status (pending/active/untrusted/retired), certificates with issuer/validity/status, and enrollment events (who/what, source IP, CSR subject, result, reason).

**Provenance:** DOCUMENTED (docs/flow.md gateway database model)

### UC-06

**Use case:** Configure CA backend

**Primary actor:** PKI admin / SystemAdmin

**Summary (AS-IS unless noted):** Admin adds a backend of type selfsigned, acme, adcs, or ejbca with guided or JSON config, tests it, and activates it; exactly one backend is active and receives future enrollments; the device never sends a backend id.

**Provenance:** DOCUMENTED (docs/ca-backend-configuration.md)

### UC-07

**Use case:** Manage EST profiles

**Primary actor:** PKI admin / SystemAdmin

**Summary (AS-IS unless noted):** Admin creates/enables named EST profiles binding devices to a CA backend, subject-DN rules, key usage, validity, and trust policy; profiles are reachable at `/.well-known/est/{profile}/...`; unknown profile labels are rejected.

**Provenance:** DOCUMENTED (KSPEC-000 §9; docs/ca-backend-configuration.md); VERIFIED for profile issuer routing (IMPLEMENTATION-TRACKER.md, PR 37)

### UC-08

**Use case:** Administer users and RBAC

**Primary actor:** SystemAdmin

**Summary (AS-IS unless noted):** First-run wizard or env-seeded initial SystemAdmin; create/edit/deactivate/delete users; three roles (Standard, DeviceAdmin, SystemAdmin); API keys carry the generating owner's role; last active SystemAdmin cannot be deleted.

**Provenance:** DOCUMENTED (docs/user-management.md)

### UC-09

**Use case:** Monitor expiry and receive notifications

**Primary actor:** Cybersecurity personnel / clinical engineering

**Summary (AS-IS unless noted):** Gateway watches certificate expiry (CertificateExpiryWatcher) and sends email notifications when certificates are not renewed as expected or approach expiry; notification settings configurable in the portal.

**Provenance:** DOCUMENTED (README.md; evidence map; docs/email-notifications.md)

### UC-10

**Use case:** Demonstrate DICOM mTLS

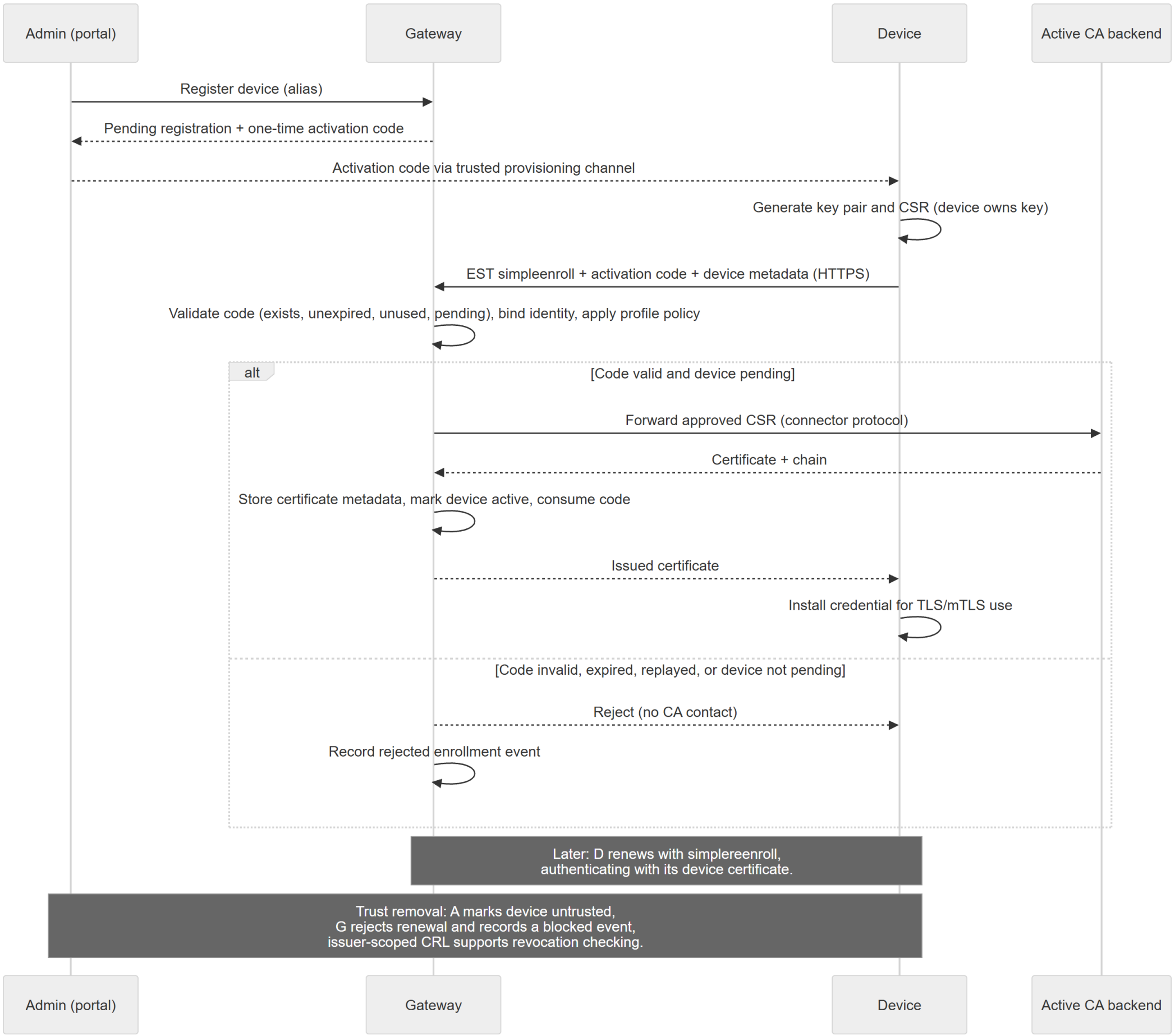
**Primary actor:** System integrator / researchers (demonstration)

**Summary (AS-IS unless noted):** Two demo devices enroll via EST, then establish a mutually authenticated TLS DICOM C-STORE association using gateway-issued certificates with issuer, TLS-purpose, and online revocation checks; temporary demo devices are archived/deleted afterward. Demonstration only; the DIMSE-TLS proxy is an AS-IS demonstration component.

**Provenance:** VERIFIED (IMPLEMENTATION-TRACKER.md: two actual mTLS C-STORE transfers with SOP Instance UID readback, recorded under artifacts/developer/verify-*/)

### 10.3 Core enrollment flow (supporting diagram)

## Diagram KSPEC-001-3




Rendered from 01-PRODUCT-DEFINITION.md. Diagram sheets use larger page sizes to preserve readable labels.

**Provenance: DOCUMENTED** (docs/device-enrollment.md; docs/flow.md; IMPLEMENTATION-TRACKER.md for replay-rejection and renewal-by-certificate behavior, classified VERIFIED per executed evidence).

# 11. Operational scenarios

### SCN-01

**Scenario:** First device onboarding in a hospital

**Flow summary:** Admin registers alias → activation code handed over → device enrolls over EST → certificate issued via hospital CA → device appears active in inventory.

**Provenance:** DOCUMENTED (docs/device-enrollment.md; docs/ca-backend-configuration.md common setup sequence)

### SCN-02

**Scenario:** Unactivated device attempts enrollment

**Flow summary:** Unknown/pending device presents a CSR; gateway rejects it before any CA contact and records a rejected enrollment event visible in the audit view.

**Provenance:** DOCUMENTED (docs/flow.md walkthrough)

### SCN-03

**Scenario:** Routine automatic renewal

**Flow summary:** Approved device renews on schedule via `simplereenroll` with certificate authentication; no administrator action; `renewed` enrollment event recorded.

**Provenance:** DOCUMENTED (README.md; docs/device-enrollment.md)

### SCN-04

**Scenario:** Silent renewal failure

**Flow summary:** Device stops renewing (e.g., powered off or failing); expiry watcher flags it; administrators receive notification emails indicating a potential device problem.

**Provenance:** DOCUMENTED (README.md renewal monitoring); expiry-watcher mechanism DOCUMENTED via evidence map; notification-delivery behavior at baseline: UNKNOWN (no executed evidence reviewed) - see TBD-002

### SCN-05

**Scenario:** Device decommissioning / compromise

**Flow summary:** Admin marks the device untrusted/removed; gateway blocks renewal and records `blocked`; issuer-scoped CRL is published; peers performing online revocation checking reject the credential on new associations; existing associations are not instantly terminated (bounded proxy lifetimes).

**Provenance:** DOCUMENTED (docs/flow.md trust removal; IMPLEMENTATION-TRACKER.md; ORNET-ALIGNMENT availability note)

### SCN-06

**Scenario:** CA backend migration

**Flow summary:** PKI admin adds a new backend, tests it, activates it; future enrollments route to the new backend; existing device records and issued certificates remain available.

**Provenance:** DOCUMENTED (docs/ca-backend-configuration.md)

### SCN-07

**Scenario:** Certificate-gated DICOM transfer (demonstration)

**Flow summary:** Demo devices enroll, then perform mTLS DICOM C-STORE; receiver enforces issuer, TLS purpose, and online revocation; received SOP Instance UIDs verified by readback.

**Provenance:** VERIFIED (IMPLEMENTATION-TRACKER.md executed evidence)

### SCN-08

**Scenario:** Developer lifecycle verification

**Flow summary:** Reproducible HTTPS/EST/DICOM proof: independent curl HTTP-Basic EST over real HTTPS, replay rejection, spoofed-forwarding rejection, restart persistence on SQLite, five loopback proxy tests including unknown/expired/revoked rejection.

**Provenance:** VERIFIED (IMPLEMENTATION-TRACKER.md; artifacts/developer/verify-*/evidence.json)

### SCN-09

**Scenario:** Hospital outage during renewal window

**Flow summary:** Scenario required by OR.NET-alignment analysis (early renewal, retry/backoff, atomic installation, behavior when the enrollment service is unavailable); not yet a specified baseline behavior.

**Provenance:** PROPOSED (docs/ORNET-ALIGNMENT-2026-09-09.md §availability)

### SCN-10

**Scenario:** Credential rotation of the EST listener / proxy PFX

**Flow summary:** Externally rotated PFX is replaced atomically; fresh handshakes observe the new credential; expired replacement fails closed.

**Provenance:** VERIFIED for demonstration loopback tests (IMPLEMENTATION-TRACKER.md); automation of the rotation itself: PROPOSED (not automated at baseline)

## 12. Current-versus-intended scope (AS-IS / TO-BE / PROPOSED)

### Enrollment protocol

**AS-IS (at baseline commit):** EST `/cacerts`, `/simpleenroll`, `/simplereenroll` over HTTPS; activation-code bootstrap with legacy compatibility headers; independent curl HTTP-Basic EST demonstrated

**TO-BE (intended, formally specified target):** Standards-based RFC 7030 enrollment and renewal usable by independent clients without gateway-private headers; private headers documented as compatibility-only

**PROPOSED (requires stakeholder approval):** Retire/flag legacy activation headers as non-normative; agree EST profile conventions jointly with OR.NET

### CA backends

**AS-IS (at baseline commit):** Self-Signed, ACME, ADCS (SCEP-compatible), EJBCA connectors implemented; single active backend; enum-only types (cfssl, Vault, Smallstep, OpenXPKI) unimplemented

**TO-BE (intended, formally specified target):** Multi-CA abstraction with tested/activated backends and profile-level routing

**PROPOSED (requires stakeholder approval):** Additional connector types beyond the four implemented

### Device lifecycle

**AS-IS (at baseline commit):** Registration → activation-code enrollment → certificate-authenticated renewal → removal blocking

**TO-BE (intended, formally specified target):** Full credential lifecycle with renewal-window automation and monitoring

**PROPOSED (requires stakeholder approval):** Long-lived OS-service renewal; hardware-backed key storage; old-certificate retirement policy

### Revocation

**AS-IS (at baseline commit):** Issuer-scoped signed CRLs; transactional revocation; online revocation checking demonstrated for device/DICOM peers; unsupported remote-CA revocation fails closed

**TO-BE (intended, formally specified target):** Trust removal plus revocation publication and peer checking with explicit stale-revocation-data handling

**PROPOSED (requires stakeholder approval):** Automated CA-side revocation interoperability validation for real ADCS/EJBCA deployments

### Audit

**AS-IS (at baseline commit):** Enrollment events persisted; event log in portal

**TO-BE (intended, formally specified target):** Complete lifecycle audit supporting incident investigation; mapping to ATNA/DICOM audit formats as a separate conformance task

**PROPOSED (requires stakeholder approval):** Standard-format audit export over protected transport

### Notifications

**AS-IS (at baseline commit):** Email notification settings and infrastructure present

**TO-BE (intended, formally specified target):** Renewal-failure and expiry alerting with configurable rules

**PROPOSED (requires stakeholder approval):** Metrics/alerting integration; additional delivery channels

### RBAC

**AS-IS (at baseline commit):** Standard / DeviceAdmin / SystemAdmin; API keys carrying owner role

**TO-BE (intended, formally specified target):** Documented RBAC as security requirement basis

**PROPOSED (requires stakeholder approval):** Federated identity/SSO integration

### Deployment

**AS-IS (at baseline commit):** Docker Compose, Kubernetes manifests, Windows installer/sandbox package; PostgreSQL upgrades implemented, SQLite exercised

**TO-BE (intended, formally specified target):** Hardened production deployment guidance including secrets management

**PROPOSED (requires stakeholder approval):** Secret-store integration (vault) for connector credentials

### DICOM integration

**AS-IS (at baseline commit):** DIMSE-TLS proxy and DICOM mTLS demo (demonstration components)

**TO-BE (intended, formally specified target):** Gateway-issued credentials usable for DICOM TLS in demonstration/reference contexts

**PROPOSED (requires stakeholder approval):** Production DICOM TLS profile alignment and certification (out of scope to claim)

### OR.NET alignment

**AS-IS (at baseline commit):** Positioning as RT-SEC reference implementation; no joint tests performed

**TO-BE (intended, formally specified target):** Shared requirements/test-vector agreement as research goal; no competing protocol

**PROPOSED (requires stakeholder approval):** Joint SDC-partner demonstration; shared EST profile white-paper alignment

**Provenance:** AS-IS column DOCUMENTED/VERIFIED per the cited tracker and docs; TO-BE column is the formally specified intent (KSPEC-002/003) and is not evidence of implementation; PROPOSED column items are recommendations from docs/ORNET-ALIGNMENT-2026-09-09.md, IMPLEMENTATION-TRACKER.md, and Mvp.md and are never presented as normative without approval (KSPEC-000 §4).

## 13. Traceability

Stakeholder requirements derived from this product definition are specified in KSPEC-002 (UR-nnn). Each UR record carries a traceability note naming the product-definition element (UC-*, SCN-*, ASM-*, EXC-*) it elaborates. Software requirements (SR-*) are defined only in KSPEC-003 per KSPEC-000 §7; this document does not allocate SR identifiers.

## 14. Open questions and TBD items

| ID | Open question | Provenance |
|---|---|---|
| TBD-001 | Exact production certificate-lifetime policy (to be chosen from outage tolerance and revocation objectives, not an arbitrary short-lived demo value). | UNKNOWN (ORNET-ALIGNMENT recommends the decision method; no decision recorded) |
| TBD-002 | Notification delivery behavior and rule expressiveness at baseline (what triggers exist beyond expiry watching; delivery reliability). | UNKNOWN (mechanism documented; no executed evidence reviewed) |
| TBD-003 | Which clinical settings and bootstrap options the forthcoming OR.NET white paper covers (offline sites, legacy devices). | UNKNOWN (correspondence-reported intentions only) |
| TBD-004 | Where shared OR.NET/RT-SEC requirements and test vectors will live, and the reported adoption status of each. | UNKNOWN (open question in ORNET-ALIGNMENT joint discussion) |
| TBD-005 | Production secrets-management approach for connector credentials (environment variables at baseline; store integration unimplemented). | PROPOSED (Mvp.md §8) with UNKNOWN deployment realization |
| TBD-006 | PostgreSQL deployment behavior in practice (schema upgrades implemented but only SQLite exercised). | UNKNOWN (IMPLEMENTATION-TRACKER.md) |

## 15. References


- KSPEC-000, *Specification Conventions and Document Controls* (this package).
- Repository sources as listed in the header table and in KSPEC-000 §10 (evidence source map).
- RFC 7030 (EST); RFC 8555 (ACME); DICOM PS3.15 security/ATNA references; IEEE 11073 SDC - referenced as context only, with no conformity claims (KSPEC-000 §3; EXC-005).

# Kryptonian Stakeholder and User Requirements

| Field | Value |
|---|---|
| Document title | Stakeholder and User Requirements (UR-nnn) |
| Document ID | KSPEC-002 |
| Version | 0.2 (Draft) |
| Review status | Draft - pending review |
| Created | 2026-10-13 |
| Baseline repository commit | `682f996c8447afec13bc1fce5b7f59e6a06efa25` (branch `feat/windows-sandbox-installer`, "Release Windows gateway and portable enrollment demo 0.1.4") |
| Repository | https://github.com/AAPM-RT-SEC/RTSec.Kryptonian |
| Revision history | 0.1 - 2026-10-13 - Initial draft: 38 user requirements derived from KSPEC-001 product definition (Author: requirements engineering team). |
| Source references | KSPEC-000 (conventions); KSPEC-001 (product definition); README.md; Mvp.md; docs/IMPLEMENTATION-TRACKER.md; docs/background.md; docs/ORNET-ALIGNMENT-2026-09-09.md; docs/CHANGES-AND-ORNET-ALIGNMENT.md; docs/flow.md; docs/ARCHITECTURE.md; docs/device-enrollment.md; docs/user-management.md; docs/ca-backend-configuration.md; docs/medical-device-demo.md; docs/DEPLOYMENT.md |
| Author | Name: TBD - Date: TBD - Signature: TBD |
| Reviewer | Name: TBD - Date: TBD - Signature: TBD |
| Approver | Name: TBD - Date: TBD - Signature: TBD |
| Reconciliation revision | 0.2 - 2026-10-13 - source/document audit and publication controls (KSPEC-016) |

This document defines the stakeholder and user requirements (UR-nnn) for the RTSec.Kryptonian Certificate Enrollment Gateway. Each UR is grouped by stakeholder and carries: ID, statement, rationale, source, priority, status, verification method, and provenance class per KSPEC-000 §5-§6 and §11. These URs are stakeholder-level requirements; they are elaborated into normative software requirements (SR-*) only in KSPEC-003 (KSPEC-000 §7). UR identifiers are stable and never reused.

Verification method abbreviations (KSPEC-000 §11): T = Test, I = Inspection, A = Analysis, D = Demonstration.

**No UR in this document constitutes a standards-conformity claim** (EST, SDC, SDPi, ATNA, DICOM TLS) or a regulatory classification; the gateway is healthcare IT cybersecurity infrastructure, not a medical device (KSPEC-000 §3; KSPEC-001 EXC-005).

## 1. Requirement conventions

- **Statement form**: each UR is a single verifiable obligation using "shall".
- **Status classes** (KSPEC-000 §6): Existing (implemented at baseline with positive evidence), Partial (incompletely implemented or with known deviations), Missing (required in TO-BE, not implemented at baseline), Proposed (recommended addition requiring approval).
- **Provenance classes** (KSPEC-000 §5): VERIFIED, CODE-OBSERVED, DOCUMENTED, INFERRED, PROPOSED, UNKNOWN. Documented-only claims are never upgraded to VERIFIED.

• **Traceability note**: names the KSPEC-001 element (UC-, *SCN-*, ASM-, *EXC-*, §section) the UR elaborates and the expected SR elaboration area in KSPEC-003. SR identifiers are not allocated here.

• **Priorities**: Critical / High / Medium / Low.

## 2. Stakeholder-to-requirement map

| Stakeholder | UR range | Theme |
|---|---|---|
| Hospital IT administrators | UR-001 - UR-007 | Onboarding simplicity, inventory, backend configuration, administration |
| Hospital cybersecurity personnel | UR-008 - UR-015 | Policy enforcement, trust removal, revocation, audit, notifications, secrets, RBAC |
| Device manufacturers | UR-016 - UR-019 | Standards-based single-protocol enrollment across hospital CA choices |
| Device software developers | UR-020 - UR-023 | Enrollment client behavior, identity binding, renewal, error semantics |
| Clinical engineering | UR-024 - UR-026 | Expiry visibility, renewal automation, credential/clinical separation |
| Healthcare system integrators | UR-027 - UR-029 | API automation, deployment options, health monitoring |
| Enterprise PKI administrators | UR-030 - UR-033 | CA connectors, certificate policy profiles, trust policy, issuance policy enforcement |
| AAPM RT-SEC / OR.NET research community | UR-034 - UR-036 | Research alignment, no competing protocol, interoperability testing as research goal |
| Cross-cutting (all stakeholders) | UR-037 - UR-038 | Data portability and maintainability |

## 3. Requirements - Hospital IT administrators

### UR-001

**Requirement:** The gateway shall allow an administrator to register a device by entering only an administrative alias and to obtain a one-time activation code for that device, without manually entering the device certificate identity.

**Rationale:** Minimizes onboarding effort and transcription errors; device identity is supplied authoritatively by the device itself.

**Source:** docs/device-enrollment.md; README.md (Device Registration Center)

**Priority:** High

**Status:** Existing

**Verification:** D

**Provenance:** DOCUMENTED

**Traceability note:** Elaborates KSPEC-001 UC-01, SCN-01; SR-F-REG area in KSPEC-003.

### UR-002

**Requirement:** The gateway shall generate activation codes that are one-time, time-limited, stored hashed, consumed on validated bootstrap acceptance before CA issuance, and rejected on replay.

**Rationale:** The activation code is a bootstrap secret; reuse would allow identity impersonation.

**Source:** docs/device-enrollment.md (validation rules); IMPLEMENTATION-TRACKER.md (one-time activation replay rejected)

**Priority:** Critical
**Status:** Existing
**Verification:** T
**Provenance:** VERIFIED (replay rejection per executed evidence)
**Traceability note:** Elaborates UC-01/UC-02, SCN-02; SR-A / SR-S area.

### UR-003

**Requirement:** The gateway shall maintain a centralized device inventory showing each device's status (pending, active, untrusted, retired), assigned profile, identity metadata, and certificate state.
**Rationale:** Administrators need one operating surface for the device estate and trust state.
**Source:** docs/flow.md (device database model); README.md
**Priority:** High
**Status:** Existing
**Verification:** D
**Provenance:** DOCUMENTED
**Traceability note:** Elaborates UC-05; SR-D / SR-F-REG area.

### UR-004

**Requirement:** The gateway shall allow an administrator to configure multiple CA backends through the admin portal using guided fields or an advanced JSON configuration.
**Rationale:** Hospitals use different CA technologies; configuration must not require code changes.
**Source:** docs/ca-backend-configuration.md
**Priority:** High
**Status:** Existing
**Verification:** D
**Provenance:** DOCUMENTED
**Traceability note:** Elaborates UC-06; SR-F-CAI area.

### UR-005

**Requirement:** The gateway shall support testing a configured CA backend before activation and shall route each enrollment to the enabled CA backend bound to its resolved EST profile without the device sending a backend identifier.
**Rationale:** Prevents misconfigured backends from receiving live enrollments; preserves the device-side single-protocol abstraction.
**Source:** docs/ca-backend-configuration.md (activating/testing sections)
**Priority:** High
**Status:** Existing
**Verification:** T
**Provenance:** DOCUMENTED
**Traceability note:** Elaborates UC-06, SCN-06; SR-F-CAI area.

### UR-006

**Requirement:** The gateway shall provide a dashboard summarizing CA backend state, registered device counts, enrollment outcomes, and backend evidence.
**Rationale:** Administrators need rapid assessment of gateway health without drilling through pages.
**Source:** README.md (Gateway dashboard)
**Priority:** Medium
**Status:** Existing
**Verification:** D
**Provenance:** DOCUMENTED
**Traceability note:** Elaborates UC-05; SR-F-ADM area.

### UR-007

**Requirement:** The gateway shall support first-time administrator setup through an initial-account wizard or environment-seeded initial administrator, and shall prevent deletion of the last active SystemAdmin.

**Rationale:** Prevents lockout on first deployment and after administrative mistakes.

**Source:** docs/user-management.md (First-Time Setup; Delete a user)

**Priority:** High

**Status:** Existing

**Verification:** T

**Provenance:** DOCUMENTED

**Traceability note:** Elaborates UC-08; SR-Z / SR-B area.

## 4. Requirements - Hospital cybersecurity personnel

### UR-008

**Requirement:** The gateway shall evaluate device trust policy itself and shall reject certificate requests from unknown, unactivated, untrusted, or retired devices before any contact with the CA backend.

**Rationale:** The gateway, not the CA, owns the medical-device trust decision; prevents unauthorized devices from obtaining credentials.

**Source:** docs/flow.md (Trust Policy Role; walkthrough)

**Priority:** Critical

**Status:** Existing

**Verification:** T

**Provenance:** DOCUMENTED

**Traceability note:** Elaborates UC-02/UC-04, SCN-02; SR-Z area.

### UR-009

**Requirement:** The gateway shall, upon administrative trust removal, deny subsequent enrollment and renewal attempts for the device and record a blocked enrollment event with a reason.

**Rationale:** Decommissioned or compromised devices must not acquire fresh credentials.

**Source:** docs/flow.md (Trust Removal Flow); docs/HACKATHON-DELIVERABLE.md (device removal UI)

**Priority:** Critical

**Status:** Existing

**Verification:** T

**Provenance:** DOCUMENTED

**Traceability note:** Elaborates UC-04, SCN-05; SR-F-CLM / SR-C area.

### UR-010

**Requirement:** The gateway shall support certificate revocation with issuer-scoped signed CRL publication, and shall fail closed when revocation is not supported by the configured remote CA backend rather than falsely reporting success.

**Rationale:** Revocation must remain trustworthy; silent success on unsupported backends would mislead operators.

**Source:** IMPLEMENTATION-TRACKER.md (PR 46; local-CA CRL demonstrated; unsupported remote revocation fails closed)

**Priority:** Critical

**Status:** Partial

**Verification:** T

**Provenance:** VERIFIED (local-CA revocation; remote ADCS/EJBCA revocation interoperability unverified)

**Traceability note:** Elaborates UC-04, SCN-05; SR-F-CLM / SR-C area; remote-backend revocation is a gap-analysis candidate (KSPEC-010).

### UR-011

**Requirement:** The gateway shall record an audit record for every enrollment, renewal, and revocation decision, including requester identity, source address, CSR subject, outcome, and reason.
**Rationale:** Security teams must be able to reconstruct who enrolled what, from where, through which backend.
**Source:** docs/flow.md (Enrollment Events); Mvp.md §8 ("audit everything")
**Priority:** High
**Status:** Partial
**Verification:** I
**Provenance:** DOCUMENTED
**Traceability note:** Elaborates UC-05, SCN-02; SR-U area.

### UR-012

**Requirement:** The gateway shall notify configured administrators by email when device certificates are not renewed as expected or approach expiry.
**Rationale:** Non-renewal is an early signal of device problems; expiry otherwise leads to outages.
**Source:** README.md (Renewal monitoring); docs/email-notifications.md
**Priority:** High
**Status:** Partial
**Verification:** D
**Provenance:** DOCUMENTED (delivery behavior at baseline UNKNOWN - TBD-002 in KSPEC-001)
**Traceability note:** Elaborates UC-09, SCN-04; SR-F-CLM / SR-C / SR-O area.

### UR-013

**Requirement:** Connector credentials (CA service-account secrets, ACME account keys, CA key passwords) shall be supplied through a secure secrets mechanism rather than plain configuration files.
**Rationale:** Leakage of CA-issuing credentials compromises the institution's PKI.
**Source:** Mvp.md §8; TBD-005 in KSPEC-001
**Priority:** High
**Status:** Missing
**Verification:** I
**Provenance:** PROPOSED (baseline uses environment variables/plain config; store integration not implemented)
**Traceability note:** Elaborates ASM-006/TBD-005; SR-B / SR-S area.

### UR-014

**Requirement:** The gateway shall rate-limit EST endpoints to resist enrollment flooding.
**Rationale:** The device-facing endpoints are exposed to the hospital network and must tolerate abusive traffic.
**Source:** docs/ARCHITECTURE.md (rate limiting via AspNetCoreRateLimit)
**Priority:** Medium
**Status:** Existing
**Verification:** T
**Provenance:** CODE-OBSERVED (configuration documented; effectiveness not separately evidenced)
**Traceability note:** Elaborates KSPEC-001 §5; SR-S area.

### UR-015

**Requirement:** The gateway shall enforce role-based access control with at least three roles (read-only, device administration, full system administration) and shall restrict device modification and system configuration to the appropriate roles.
**Rationale:** Least privilege separates operational duties (device ops vs. system configuration) and read-only audit use.
**Source:** docs/user-management.md (Roles)

**Priority:** Critical
**Status:** Existing
**Verification:** T
**Provenance:** DOCUMENTED
**Traceability note:** Elaborates UC-08, KSPEC-001 §4; SR-Z area.

# 5. Requirements - Device manufacturers

## UR-016

**Requirement:** The gateway shall expose a single standards-based device enrollment protocol, EST (RFC 7030), that any conforming device client can use for enrollment and renewal regardless of which hospital CA backend is configured.
**Rationale:** Manufacturers cannot implement custom logic per hospital CA; one open protocol is the core interoperability proposition.
**Source:** README.md; Mvp.md; docs/background.md (desired pattern); RFC 7030
**Priority:** Critical
**Status:** Existing
**Verification:** D
**Provenance:** DOCUMENTED
**Traceability note:** Elaborates UC-02/UC-03, KSPEC-001 §2; SR-F-EST area.

## UR-017

**Requirement:** The gateway shall distribute CA certificates/trust anchors to devices via the EST `cacerts` operation for the selected profile.
**Rationale:** Devices must authenticate the enrollment service and validate issued chains without out-of-band CA distribution where possible.
**Source:** docs/ARCHITECTURE.md (EST endpoints); docs/medical-device-demo.md (trusted gateway CA selection)
**Priority:** High
**Status:** Existing
**Verification:** T
**Provenance:** DOCUMENTED
**Traceability note:** Elaborates UC-02; SR-F-EST / SR-F-INT area.

## UR-018

**Requirement:** The gateway shall map device enrollment requests to the hospital-selected CA backend and its native protocol, so that device-side code requires no CA-specific integration.
**Rationale:** Preserves the manufacturer's single implementation while hospitals keep CA choice; the gateway is the adaptation layer.
**Source:** docs/flow.md (Responsibility Split); docs/background.md
**Priority:** Critical
**Status:** Existing
**Verification:** A
**Provenance:** DOCUMENTED
**Traceability note:** Elaborates UC-06, SCN-06; SR-F-CAI area.

## UR-019

**Requirement:** The gateway's EST path shall be usable by independent clients using standard authentication only; any gateway-specific compatibility headers shall remain optional, documented as legacy compatibility, and shall not become an interoperability requirement.
**Rationale:** A proprietary-header requirement would recreate the vendor lock-in the gateway exists to remove.
**Source:** IMPLEMENTATION-TRACKER.md (independent curl HTTP-Basic EST demonstrated; legacy headers "must not become a new interoperability requirement")
**Priority:** High
**Status:** Partial

**Verification:** T
**Provenance:** VERIFIED (independent curl EST over real HTTPS)
**Traceability note:** Elaborates KSPEC-001 §12 enrollment-protocol row, EXC-004; SR-F-INT / SR-F-EST area.

# 6. Requirements - Device software developers

## UR-020

**Requirement:** The gateway shall bind the enrolled device identity to the pending registration by validating that the CSR subject CN is present, unique among registered devices, and accompanied by device metadata including a serial number.
**Rationale:** Prevents duplicate or ambiguous device identities and binds certificates to the intended registry entry.
**Source:** docs/device-enrollment.md (validation rules); IMPLEMENTATION-TRACKER.md (PR 38 authenticated enrollment identity binding)
**Priority:** High
**Status:** Existing
**Verification:** T
**Provenance:** DOCUMENTED (PR 38 behavior VERIFIED per tracker)
**Traceability note:** Elaborates UC-02; SR-F-REG area.

## UR-021

**Requirement:** The gateway shall allow an active, non-revoked device to renew its certificate by authenticating with its existing device certificate via EST `simplereenroll`, without re-presenting the activation code or requiring administrator approval, preserving the approved identity.
**Rationale:** Renewal must be automatic and unattended; re-approval would defeat the automation goal.
**Source:** docs/device-enrollment.md (Renewal And Future Signing); IMPLEMENTATION-TRACKER.md (PR 44; renewal uses native TLS client certificate, generates new key, preserves approved identity)
**Priority:** Critical
**Status:** Existing
**Verification:** T
**Provenance:** VERIFIED (renewal behavior per executed evidence)
**Traceability note:** Elaborates UC-03, SCN-03; SR-F-CLM / SR-C area.

## UR-022

**Requirement:** The gateway shall serve EST operations under named, profile-scoped paths (`/.well-known/est/{profile}/...`) and shall reject requests for unknown or disabled profile labels.
**Rationale:** Profile-scoped paths allow per-policy enrollment; unknown labels must not silently fall through to a default policy.
**Source:** docs/medical-device-demo.md (EST profile URL usage); IMPLEMENTATION-TRACKER.md (PR 37 unknown-label rejection)
**Priority:** Medium
**Status:** Existing
**Verification:** T
**Provenance:** VERIFIED (profile issuer routing/unknown-label rejection per tracker)
**Traceability note:** Elaborates UC-07; SR-F-EST area.

## UR-023

**Requirement:** The gateway shall return distinguishable error outcomes for failed device operations (e.g., invalid/expired/used activation code, unknown or disabled profile, unauthorized renewal) that client developers can diagnose.
**Rationale:** Developers need actionable failures; undifferentiated errors raise support burden and mask security events.
**Source:** docs/medical-device-demo.md (connection troubleshooting: 404/401/403 semantics)
**Priority:** Low
**Status:** Existing

**Verification:** I

**Provenance:** DOCUMENTED

**Traceability note:** Elaborates SCN-01/SCN-02; SR-F-EST / SR-X area.

# 7. Requirements - Clinical engineering

### UR-024

**Requirement:** The gateway shall provide visibility of device certificate validity periods and expiry so that staff can identify devices at risk of losing network trust.

**Rationale:** Expired credentials cause transport failures that present as device "network problems"; early visibility enables planned maintenance.

**Source:** README.md (certificate expiry tracking in Devices page); docs/flow.md (certificates table)

**Priority:** High

**Status:** Existing

**Verification:** D

**Provenance:** DOCUMENTED

**Traceability note:** Elaborates UC-05/UC-09; SR-F-ADM / SR-D area.

### UR-025

**Requirement:** The gateway shall enable automatic renewal for approved devices so that credentials remain valid without manual certificate installation on the device.

**Rationale:** Manual installs are error-prone and scale poorly; automation removes a primary cause of expired-certificate outages.

**Source:** README.md (automatic renewal); Mvp.md

**Priority:** High

**Status:** Existing

**Verification:** D

**Provenance:** DOCUMENTED

**Traceability note:** Elaborates UC-03, SCN-03; SR-F-CLM / SR-C area.

### UR-026

**Requirement:** The gateway's device and certificate status shall not be presented as, and shall not be derivable as, a statement of a device's clinical service status, clinical capability, or regulatory status.

**Rationale:** Prevents staff from misreading an operational TLS identity as clinical clearance; preserves the identity/capability boundary.

**Source:** KSPEC-000 §3 (binding); docs/CHANGES-AND-ORNET-ALIGNMENT.md (renewal ≠ recertification)

**Priority:** Critical

**Status:** Existing

**Verification:** I

**Provenance:** DOCUMENTED

**Traceability note:** Elaborates KSPEC-001 §2.1, EXC-001; SR-Z / SR-F-ADM area.

# 8. Requirements - Healthcare system integrators

### UR-027

**Requirement:** The gateway shall expose an authenticated administrative REST API, including API-key authentication carrying the generating user's role, for scripted device and configuration management.

**Rationale:** Hospitals automate estate management; browser-only administration does not integrate with runbooks, CI, or configuration tooling.

**Source:** docs/user-management.md (API Keys); docs/API-GUIDE.md

**Priority:** High
**Status:** Existing
**Verification:** T
**Provenance:** DOCUMENTED
**Traceability note:** Elaborates KSPEC-001 §4 (scripted clients); SR-A / SR-Z area.

### UR-028

**Requirement:** The gateway shall be deployable as containers (Docker Compose, Kubernetes manifests) and as a Windows package, with production deployment guidance.
**Rationale:** Hospitals have heterogeneous infrastructure; deployment flexibility determines adoptability.
**Source:** docs/DEPLOYMENT.md; docs/medical-device-demo.md (Windows package)
**Priority:** Medium
**Status:** Existing
**Verification:** I
**Provenance:** DOCUMENTED (Windows installer path and PostgreSQL in practice: UNKNOWN - TBD-006 in KSPEC-001)
**Traceability note:** Elaborates §5; SR-B area.

### UR-029

**Requirement:** The gateway shall expose a health-check endpoint reporting the health of its components (e.g., database, CA connectors).
**Rationale:** Integrators and monitoring systems need a liveness/readiness probe for orchestration.
**Source:** docs/DEPLOYMENT.md (health checks); docs/ARCHITECTURE.md
**Priority:** Medium
**Status:** Existing
**Verification:** T
**Provenance:** DOCUMENTED
**Traceability note:** Elaborates SCN-09 context; SR-V area.

## 9. Requirements - Enterprise PKI administrators

### UR-030

**Requirement:** The gateway shall connect to institution-managed CA backends through pluggable connectors for Self-Signed, ACME (RFC 8555), ADCS (SCEP-compatible service), and EJBCA (REST) types.
**Rationale:** These represent the realistic hospital CA landscape the abstraction must cover.
**Source:** docs/ca-backend-configuration.md (supported backends); docs/HACKATHON-DELIVERABLE.md
**Priority:** High
**Status:** Existing
**Verification:** T
**Provenance:** DOCUMENTED (ADCS/EJBCA hospital interop unverified - see UR-010 note)
**Traceability note:** Elaborates UC-06; SR-F-CAI area.

### UR-031

**Requirement:** The gateway shall support named EST profiles as policy bundles binding devices to a CA backend with subject-DN rules, key usage, validity, and trust policy.
**Rationale:** Certificate policy must be administratively controlled by the institution, not hard-coded.
**Source:** KSPEC-000 §9 (EST profile terminology); docs/ca-backend-configuration.md (common setup sequence)
**Priority:** Critical
**Status:** Existing
**Verification:** I

**Provenance:** DOCUMENTED

**Traceability note:** Elaborates UC-07; SR-F-CAI / SR-F-CLM / SR-C area.

### UR-032

**Requirement:** The gateway shall persist EST profile trust policy across restarts and shall apply trust-list changes additively, preserving omitted trust lists on partial updates.

**Rationale:** Loss or silent narrowing of trust policy on restart or update would break enrolled devices unpredictably.

**Source:** IMPLEMENTATION-TRACKER.md (PR 41 durable trust policy; PR 47 partial updates preserve omitted trust lists)

**Priority:** High

**Status:** Existing

**Verification:** T

**Provenance:** VERIFIED (restart persistence on populated SQLite per tracker)

**Traceability note:** Elaborates UC-07, SCN-08; SR-D / SR-F-CLM / SR-C area.

### UR-033

**Requirement:** The gateway shall enforce issuance policy on both the submitted CSR and the returned certificate (rejecting, e.g., unauthorized subject/SAN/EKU content) before delivering credentials to the device.

**Rationale:** A malicious or faulty client must not obtain credentials whose identity or purpose exceeds its approved policy.

**Source:** IMPLEMENTATION-TRACKER.md (PR 43 CSR and returned-certificate policy enforcement; ORNET-ALIGNMENT test matrix: unauthorized SAN/EKU)

**Priority:** Critical

**Status:** Existing

**Verification:** T

**Provenance:** VERIFIED (per tracker PR 43)

**Traceability note:** Elaborates UC-02/UC-07; SR-S / SR-F-CLM / SR-C area.

## 10. Requirements - AAPM RT-SEC / OR.NET research community

### UR-034

**Requirement:** The project shall position the gateway as an RT-SEC reference implementation and test environment contributing operational DICOM credential-lifecycle evidence (enroll, renew, use for DICOM TLS, rotate, deny after trust withdrawal) to the OR.NET / IEEE 11073 SDC enrollment effort, without defining a competing enrollment protocol.

**Rationale:** Avoids fragmenting the medical-device enrollment landscape; contributes implementation evidence where OR.NET is developing its own EST-based direction.

**Source:** README.md; docs/ORNET-ALIGNMENT-2026-09-09.md; docs/CHANGES-AND-ORNET-ALIGNMENT.md (§recommended decisions 1-2)

**Priority:** High

**Status:** Existing

**Verification:** I

**Provenance:** DOCUMENTED

**Traceability note:** Elaborates KSPEC-001 §2, EXC-004; SR-F-INT area (research positioning).

### UR-035

**Requirement:** All project communications and specification documents shall state explicitly that no OR.NET adoption, SDC conformity, DICOM TLS certification, or standards-conformance status is claimed, and that interoperability with OR.NET/IEEE 11073 SDC work is a research goal only.

**Rationale:** Prevents overstating maturity; alignment is with correspondence-reported working-group intentions, not adopted specifications.

**Source:** README.md disclaimer; docs/ORNET-ALIGNMENT-2026-09-09.md (review limits); IMPLEMENTATION-TRACKER.md (deliberate boundaries)

**Priority:** High

**Status:** Existing

**Verification:** I

**Provenance:** DOCUMENTED

**Traceability note:** Elaborates EXC-002/EXC-005; governing rule for KSPEC-011.

### UR-036

**Requirement:** The project shall maintain an interoperability testing approach in which independent client/server pairs exercise the real network boundary (enrollment authentication, issuer trust, certificate identity/purposes, renewal, revocation timing, failure behavior), with test cases agreed jointly with OR.NET where possible.

**Rationale:** Controller-mocked tests missed real defects at baseline; joint test vectors are the agreed path to credible interoperability evidence.

**Source:** IMPLEMENTATION-TRACKER.md ("live checks exposed two bugs that mocked tests missed"); docs/ORNET-ALIGNMENT-2026-09-09.md (§proposed slices; recommended decision 3)

**Priority:** Medium

**Status:** Partial

**Verification:** T

**Provenance:** VERIFIED (developer verifier evidence exists for the gateway boundary); the joint OR.NET-agreed test vectors remain PROPOSED

**Traceability note:** Elaborates SCN-08/SCN-09; SR-F-INT / SR-V area; KSPEC-008 verification-spec input.

## 11. Requirements - Cross-cutting (all stakeholders)

### UR-037

**Requirement:** The gateway shall persist all configured state (devices, certificates, profiles, backends, trust policy) durably so that a gateway restart preserves the configuration and records, with support for both SQLite and PostgreSQL persistence.

**Rationale:** Configuration loss across restarts would silently revoke operational trust state; hospitals need an embeddable option (SQLite) and a server-grade option (PostgreSQL).

**Source:** IMPLEMENTATION-TRACKER.md (gateway restart on populated SQLite preserved profile, issuer and devices); docs/DEPLOYMENT.md (PostgreSQL)

**Priority:** High

**Status:** Partial

**Verification:** T

**Provenance:** VERIFIED (SQLite restart persistence per tracker); PostgreSQL exercised: UNKNOWN

**Traceability note:** Elaborates §5, TBD-006; SR-D / SR-B area.

### UR-038

**Requirement:** The gateway's software design shall keep CA backend integration behind a common internal connector abstraction so that new backend types can be added without changing device-facing behavior or business logic.

**Rationale:** Sustains the multi-CA roadmap and the single-protocol device contract as backends evolve.

**Source:** docs/ARCHITECTURE.md (Extension Points; factory pattern for CA connectors); Mvp.md §6.2 (connector interface)

**Priority:** Medium

**Status:** Existing

**Verification:** A

**Provenance:** CODE-OBSERVED (design documented; addition of a new connector not exercised at baseline)

**Traceability note:** Elaborates UC-06; SR-O / maintainability in KSPEC-003.

# 12. Requirements coverage summary

| Coverage theme (task input) | Covering URs |
|---|---|
| Onboarding simplicity | UR-001, UR-002, UR-007, UR-020, UR-023 |
| Standards-based enrollment (RFC 7030) | UR-016, UR-017, UR-019, UR-022 |
| Multi-CA support | UR-004, UR-005, UR-018, UR-030, UR-038 |
| Centralized inventory and audit | UR-003, UR-006, UR-011, UR-024 |
| Renewal automation with monitoring alerts | UR-012, UR-021, UR-025 |
| Revocation and trust removal | UR-008, UR-009, UR-010 |
| RBAC | UR-015, UR-027 |
| Notification rules | UR-012 |
| Secure deployment | UR-013, UR-014, UR-028, UR-037 |
| Interoperability with DICOM TLS / OR.NET-SDC alignment (research goals, no conformity claims) | UR-034, UR-035, UR-036, UR-026 |
| Maintainability | UR-038, UR-022, UR-023 |

Total: **38 user requirements (UR-001 - UR-038)**.

| Priority | Count |
|---|---|
| Critical | UR-002, UR-008, UR-009, UR-010, UR-015, UR-016, UR-018, UR-021, UR-026, UR-031, UR-033 (11) |
| High | UR-001, UR-003, UR-004, UR-005, UR-007, UR-011, UR-012, UR-013, UR-017, UR-019, UR-020, UR-024, UR-025, UR-027, UR-030, UR-032, UR-034, UR-035, UR-037 (19) |
| Medium | UR-006, UR-014, UR-022, UR-028, UR-029, UR-036, UR-038 (7) |
| Low | UR-023 (1) |
| **Total** | **38** |

| Status | Count |
|---|---|
| Existing | 31 |
| Partial | 6 (UR-010, UR-011, UR-012, UR-019, UR-036, UR-037) |
| Missing | 1 (UR-013) |
| Proposed (as requirement origin) | covered by UR-013 provenance; no standalone Proposed-status URs at stakeholder level |

## 13. Open questions carried forward (TBD / UNKNOWN)

| ID | Open question | Related URs |
|---|---|---|
| TBD-001 | Production certificate-lifetime policy (outage tolerance vs. revocation objectives). | UR-021, UR-025, UR-031 |
| TBD-002 | Notification trigger set and delivery reliability at baseline. | UR-012 |
| TBD-003 | Clinical settings/bootstrap options in the forthcoming OR.NET white paper. | UR-034, UR-036 |
| TBD-004 | Location and adoption status of shared OR.NET/RT-SEC requirements and test vectors. | UR-035, UR-036 |
| TBD-005 | Production secrets-management mechanism for connector credentials. | UR-013 |
| TBD-006 | PostgreSQL persistence behavior in practice. | UR-028, UR-037 |

## 14. Traceability

• **Upstream**: every UR cites the KSPEC-001 element it elaborates in its traceability note (UC-01 - UC-10, SCN-01 - SCN-10, ASM-001 - ASM-007, EXC-001 - EXC-008, and §2/§4/§5/§12).

• **Downstream**: URs are to be elaborated into SR-* requirements in KSPEC-003 (SR-F-REG, SR-F-EST, SR-F-CLM, SR-F-CAI, SR-F-ADM, SR-Z, SR-A, SR-S, SR-D, SR-U, SR-B, SR-O, SR-V, SR-X areas per KSPEC-000 §7). KSPEC-003 shall maintain the canonical requirements register including UR→SR mapping; this document does not redefine requirements there.

## 15. Status detail and evidence basis

This section records, for each status classification used above, what the evidence basis is at the baseline commit. It is provided so reviewers can re-derive each status and so that later documents (KSPEC-003, KSPEC-010) do not silently upgrade Documented-only claims to Verified.

| UR(s) | Status | Evidence basis |
|---|---|---|
| UR-002, UR-019, UR-021, UR-022, UR-032, UR-033, UR-036 (partial) | Existing / Partial | Executed evidence recorded in docs/IMPLEMENTATION-TRACKER.md and `artifacts/developer/verify-*/evidence.json`: replay rejection, independent HTTP-Basic EST over real HTTPS, certificate-authenticated renewal with new key and preserved identity, profile routing/unknown-label rejection, trust-policy restart persistence, CSR/returned-certificate policy enforcement, and loopback proxy tests. These are Verified per KSPEC-000 §5. |
| **UR(s)** | **Status** | **Evidence basis** |
| UR-010 | Partial | Local-CA issuer-scoped signed CRLs and transactional revocation demonstrated with online revocation checking; |

| UR(s) | Status | Evidence basis |
|---|---|---|
| | | remote ADCS/EJBCA revocation interoperability explicitly unverified and unsupported remote revocation fails closed. The Verified portion is local-CA only. |
| UR-012 | Partial | Renewal monitoring is a stated product capability (README.md) with notification infrastructure and settings documented; delivery behavior was not exercised in the reviewed evidence. |
| UR-013 | Missing | Secure secrets storage for connector credentials is recommended in Mvp.md §8 and flagged as TBD-005; baseline uses environment variables and configuration files. |
| UR-001, UR-003 - UR-007, UR-008, UR-009, UR-014 - UR-018, UR-020, UR-023 - UR-031, UR-034, UR-035, UR-038 | Existing | Behavior described in repository documentation (Device Registration Center, Roles, CA backend configuration, flow document, architecture, deployment) consistent with the evidence source map (KSPEC-000 §10). Classified DOCUMENTED or CODE-OBSERVED as noted per row; none upgraded to VERIFIED without executed evidence. |
| UR-011 | Partial | Selected lifecycle events are persisted, but early failures and revocation paths do not provide complete durable per-attempt audit coverage (CODE-OBSERVED; GAP-038, VT-059). |
| UR-037 | Partial | SQLite restart persistence Verified via tracker; PostgreSQL schema upgrades exist but persistence was not exercised (UNKNOWN). |

## 16. Constraints on elaboration (guidance for KSPEC-003)

The following constraints bind the elaboration of these URs into software requirements:

1. **No clinical capability derivation.** No SR may derive clinical capability, clinical authorization, or SDC role assignment from gateway state (KSPEC-000 §3; EXC-001, EXC-002; UR-026).

2. **No conformity smuggling.** SRs elaborating UR-016/UR-017/UR-019 shall phrase EST behavior as implementation behavior, not as RFC 7030 conformance claims; conformance assessment belongs to KSPEC-011 and may only reference the assessed evidence.

3. **Legacy headers non-normative.** Compatibility activation headers observed in the sample device client shall not be reproduced as mandatory interface requirements (EXC-004; UR-019).

4. **Revocation realism.** SRs elaborating UR-010/UR-009 shall preserve the fail-closed behavior for unsupported remote revocation and shall not promise instant mid-association termination (EXC-007).

5. **Unconfirmed thresholds.** Where a UR leaves a threshold or policy value unspecified (certificate lifetimes, notification triggers, rate-limit values), the SR shall use `TBD` with a separate recommendation and rationale, never an invented value presented as agreed (KSPEC-000 §8).

6. **Approval state.** All elaborated SRs inherit Draft / Review Required approval state; approval is never inferred from implementation status (KSPEC-000 §8).

# 17. Inter-requirement dependencies

| Dependency | Reason |
|---|---|
| UR-001 → UR-002, UR-020 | Registration and activation-code generation are meaningful only with the code-validation and identity-binding rules. |
| UR-008 → UR-009, UR-010 | Trust-policy evaluation is the gate that trust removal and revocation tighten. |
| UR-016 → UR-017, UR-019, UR-022 | The single-protocol contract depends on `cacerts` distribution, independent-client usability, and profile-scoped paths. |
| UR-004/UR-005 → UR-018 | Backend configuration and activation are the mechanism behind CA-agnostic device enrollment. |
| UR-031 → UR-032, UR-033 | Profile policy bundles are only trustworthy if durable and enforced on CSR and returned certificates. |
| UR-021 → UR-012, UR-024, UR-025 | Renewal automation is what makes expiry visibility and non-renewal alerting the correct compensating controls. |
| UR-015 → UR-027 | REST automation inherits the same RBAC model as the portal. |
| UR-030 → UR-038 | The connector abstraction is the maintainability precondition for the supported backend set. |

# Kryptonian Software Requirements Specification

| Field | Value |
|---|---|
| Document title | Software Requirements Specification (SR-*) |
| Document ID | KSPEC-003 |
| Version | 0.2 (Draft) |
| Review status | Draft - pending review |
| Created | 2026-10-13 |
| Baseline repository commit | `682f996c8447afec13bc1fce5b7f59e6a06efa25` (branch `feat/windows-sandbox-installer`, "Release Windows gateway and portable enrollment demo 0.1.4") |
| Repository | https://github.com/AAPM-RT-SEC/RTSec.Kryptonian |
| Revision history | 0.1 - 2026-10-13 - Initial draft: 154 software requirements elaborated from KSPEC-002 UR-001 - UR-038 and source inspection of the baseline commit (Author: requirements engineering team). |
| Source references | KSPEC-000 (conventions); KSPEC-001 (product definition); KSPEC-002 (user requirements UR-001 - UR-038); docs/ARCHITECTURE.md; docs/API-GUIDE.md; docs/device-enrollment.md; docs/ca-backend-configuration.md; docs/user-management.md; docs/email-notifications.md; docs/admin-setup.md; docs/DEPLOYMENT.md; docs/IMPLEMENTATION-TRACKER.md; docs/formal-specification/04-SOFTWARE-DESIGN.md; docs/formal-specification/05-INTERFACE-CONTROL.md; docs/formal-specification/07-OPERATIONAL-RISK.md; src/RTSec.Kryptonian.{Api,Application,Domain,Infrastructure}; OpenAPI.*.yaml; artifacts/developer/verify-*/evidence.json |
| Author | Name: TBD - Date: TBD - Signature: TBD |
| Reviewer | Name: TBD - Date: TBD - Signature: TBD |
| Approver | Name: TBD - Date: TBD - Signature: TBD |
| Reconciliation revision | 0.2 - 2026-10-13 - source/document audit and publication controls (KSPEC-016) |

This document is the **principal normative specification** of the RTSec.Kryptonian Certificate Enrollment Gateway. It elaborates the stakeholder requirements of KSPEC-002 into software requirements (SR-*) using the requirement record format of KSPEC-000 §8 and the identifier scheme of KSPEC-000 §7. This document maintains the **canonical Requirements Register** (Section 21) of all normative SR IDs; every other package document references requirements by ID only and shall not redefine them (KSPEC-000 §7).

**Product classification (binding, KSPEC-000 §3).** Kryptonian is enterprise healthcare IT cybersecurity infrastructure: an EST (RFC 7030) certificate enrollment, identity provisioning, and credential lifecycle gateway. It is **not a regulated medical device**, performs no clinical functions, and no requirement in this document may be read as claiming FDA classification, IEC 62304 lifecycle classification, ISO 14971 hazard coverage, SDC conformity, DICOM TLS certification, or any other standards-conformance status. Device identity, enrollment authorization, network trust, and application-layer authorization are distinguished throughout; no gateway state derives clinical capability.

## 1. Requirement conventions

Each requirement is presented with the full field set of KSPEC-000 §8:

| Field | Meaning |
|---|---|
| ID | Stable identifier `<PREFIX>-<AREA>.<nnn>` (never reused, KSPEC-000 §7). |
| Requirement | A single verifiable obligation using "shall". |
| Rationale | Why the obligation exists. |
| Source | Upstream UR (KSPEC-002) and/or KSPEC-001 element and/or finding driving the requirement. |
| Classification | AS-IS, TO-BE, or PROPOSED behavior classification (KSPEC-000 §4). |
| Priority | Critical / High / Medium / Low. |
| Status | Existing / Partial / Missing / Proposed (KSPEC-000 §6). |
| Verification | T = Test, I = Inspection, A = Analysis, D = Demonstration (KSPEC-000 §11). |
| Evidence | Concrete repository paths, documents, or executed-evidence locations, each annotated with its provenance class (KSPEC-000 §5). |
| Approval | Draft or Review Required. Approval is never inferred from implementation (KSPEC-000 §8). |

Rules applied throughout:

1. **Single obligation.** Each requirement states exactly one verifiable obligation. Compound behaviors are split.

2. **Implementation independence.** Requirements state observable system behavior, not algorithms or class names, except where a configuration key or protocol literal is itself the contract.

3. **Weak controls are not reproduced.** Prototype defects and weak controls observed at baseline (hard-coded JWT secret fallback, endpoints with authentication but no role policy, empty/stale OpenAPI contract files, hard-coded demo CRL lifetime, DNS-01 challenge stub, forwarder trust by source IP only) are specified as correct TO-BE requirements with Status **Missing** or **Proposed**, never as intended AS-IS behavior (KSPEC-000 §4).

4. **Unconfirmed thresholds use** `TBD` with a separate recommendation and rationale (KSPEC-002 §16.5). No threshold value is presented as agreed without evidence.

5. **Legacy activation headers are non-normative** (KSPEC-002 §16.3): the `X-Activation-Code`/`X-Device-*` compatibility headers are specified as compatibility behavior only and never as an interoperability requirement.

6. **Revocation realism** (KSPEC-002 §16.4): fail-closed behavior for unsupported remote revocation is preserved; no promise of instant mid-association termination.

7. **Honest status.** Status reflects the baseline commit only, with evidence classes; documented-only claims are never upgraded to VERIFIED.

## 2. Identifier areas used in this document

| Prefix | Area | Section |
|---|---|---|
| SR-F-REG | Functional - device registration and identity management | §3 |
| SR-F-EST | Functional - EST protocol behavior | §4 |
| SR-F-CLM | Functional - certificate lifecycle management flows | §5 |
| SR-F-CAI | Functional - CA backend integration | §6 |
| SR-F-ADM | Functional - administration and portal | §7 |
| SR-F-INT | Functional - interoperability and contract artifacts | §8 |
| SR-S | Security | §9 |
| SR-A | Authentication | §10 |
| SR-Z | Authorization | §11 |
| SR-C | Certificate lifecycle policy | §12 |
| SR-D | Data management | §13 |
| SR-P | Performance | §14 |
| SR-R | Reliability | §15 |
| SR-V | Availability | §16 |
| SR-U | Audit | §17 |
| SR-B | Deployment | §18 |
| SR-O | Operational maintenance | §19 |
| SR-X | Failure and recovery | §20 |
| - | Requirements Register (canonical ID list) | §21 |

## 3. Functional requirements - device registration and identity management (SR-F-REG)

### SR-F-REG.001 - Administrator device registration with one-time activation code

• **ID:** SR-F-REG.001

• **Requirement:** The gateway shall allow an administrator to register a device by entering only an administrative alias and shall issue a one-time activation code for that device without requiring manual entry of the device certificate identity.

• **Rationale:** Minimizes onboarding effort and transcription errors; device identity is supplied authoritatively by the device itself during activation.

• **Source:** KSPEC-002 UR-001 (UC-01, SCN-01).

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** High

• **Status:** Existing

• **Verification:** D

• **Evidence:** `src/RTSec.Kryptonian.Api/Controllers/DevicesController.cs` (Create, activation-code issuance) CODE-OBSERVED; `src/RTSec.Kryptonian.Application/Services/DeviceService.cs` CODE-OBSERVED; docs/device-enrollment.md DOCUMENTED.

• **Approval:** Review Required

## SR-F-REG.002 - Activation code secrecy, one-time use, and replay rejection

• **ID:** SR-F-REG.002

• **Requirement:** The gateway shall generate activation codes that are one-time and time-limited, shall store them only as one-way hashes, shall consume the code atomically when accepting validated bootstrap credentials, before CA issuance, and shall reject any replay of a consumed, expired, or invalid activation code.

• **Rationale:** The activation code is a bootstrap secret; replay would permit device-identity impersonation.

• **Source:** KSPEC-002 UR-002 (UC-01/UC-02, SCN-02).

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** Critical

• **Status:** Existing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Api/Controllers/EstController.cs` (bootstrap credential validation) CODE-OBSERVED; `src/RTSec.Kryptonian.Application/Services/DeviceService.cs` CODE-OBSERVED; replay rejection VERIFIED per docs/IMPLEMENTATION-TRACKER.md and `artifacts/developer/verify-*/evidence.json`.

• **AS-IS limitation:** Consumption is persisted before backend resolution, issuance-policy validation and CA issuance; a later failure, pending response or process crash can leave the device Pending with a consumed code. Administrator code regeneration is the recovery path; consumption and issuance are not a single transaction (CODE-OBSERVED: `EnrollmentOrchestrator.EnrollAsync`, `TryConsumeActivationCodeAsync`). VT-060 specifies failure/restart verification.

• **Approval:** Review Required

## SR-F-REG.003 - Centralized device inventory

• **ID:** SR-F-REG.003

• **Requirement:** The gateway shall provide an administrator-accessible device inventory that reports, for every registered device, its registration status, assigned EST profile, identity metadata, and certificate state.

• **Rationale:** Administrators need one operating surface for the device estate and its trust state.

• **Source:** KSPEC-002 UR-003 (UC-05).

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** High

• **Status:** Existing

• **Verification:** D

• **Evidence:** `src/RTSec.Kryptonian.Api/Controllers/DevicesController.cs` (List, Get, Events, AllCertificates) CODE-OBSERVED; `src/RTSec.Kryptonian.Application/DTOs/DeviceDto.cs` CODE-OBSERVED; README.md (Device Registration Center) DOCUMENTED.

• **Approval:** Review Required

## SR-F-REG.004 - Device record status lifecycle

• **ID:** SR-F-REG.004

• **Requirement:** The gateway shall record device registration status transitions (including pending, active, and removed states) together with their timestamps, and shall expose those transitions in the device event history.

• **Rationale:** Lifecycle transitions are the basis of trust decisions and audit reconstruction.

• **Source:** KSPEC-002 UR-003; docs/flow.md (device database model).

• **Classification:** TO-BE (elaborates AS-IS behavior; the AS-IS status enum covers pending/active/removed while trust state is carried as separate device trust data - see SR-Z.003).

• **Priority:** High

• **Status:** Existing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Domain/Enums/DeviceStatus.cs` CODE-OBSERVED; `src/RTSec.Kryptonian.Api/Controllers/DevicesController.cs` (Events) CODE-OBSERVED.

• **Approval:** Review Required

## SR-F-REG.005 - Enrollment identity binding to the pending registration

• **ID:** SR-F-REG.005

• **Requirement:** The gateway shall bind the enrolled device identity to its pending registration by requiring that the CSR subject common name is present, unique among registered devices, and accompanied by device metadata including a serial number, and shall reject requests that fail this binding.

• **Rationale:** Prevents duplicate or ambiguous device identities and binds issued certificates to the intended registry entry.

• **Source:** KSPEC-002 UR-020 (UC-02).

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** High

• **Status:** Existing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Application/Services/EnrollmentOrchestrator.cs` and `src/RTSec.Kryptonian.Application/Services/EnrollmentCertificatePolicy.cs` CODE-OBSERVED; PR 38 identity binding VERIFIED per docs/IMPLEMENTATION-TRACKER.md.

• **Approval:** Review Required

## SR-F-REG.006 - Self-service approval requests create only pending records

• **ID:** SR-F-REG.006

• **Requirement:** The gateway shall accept self-service device approval requests through a dedicated endpoint that, without an authenticated caller, creates only a pending device record requiring administrator approval, and shall never grant enrollment capability on the basis of such a request alone.

• **Rationale:** Self-service request intake is useful for estate discovery, but trust must remain an administrator decision.

• **Source:** KSPEC-002 UR-001; KSPEC-005 open item (authorization model of `POST /api/device-requests`).

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** High

• **Status:** Existing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Api/Controllers/DevicesController.cs` (RequestApproval, `[AllowAnonymous]`, 202 response) CODE-OBSERVED.

• **Approval:** Review Required

## SR-F-REG.007 - Abuse controls on the anonymous approval-request endpoint

• **ID:** SR-F-REG.007

• **Requirement:** The gateway shall apply abuse controls (rate limiting and/or submission throttling) to the anonymous self-service approval-request endpoint so that unauthenticated callers cannot flood the device registry with pending records; the production threshold is `TBD` (recommendation: extend the existing EST rate-limit configuration to this endpoint).

• **Rationale:** An unauthenticated write path without abuse controls permits registry flooding and operator alert fatigue.

• **Source:** KSPEC-005 open item 6 (anonymous endpoint by design - confirm authorization model); KSPEC-007 ORK finding (flooding exposure).

• **Classification:** TO-BE (hardening of an AS-IS weak control).

• **Priority:** Medium

• **Status:** Missing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Api/Controllers/DevicesController.cs` (RequestApproval with no rate-limit attribute) CODE-OBSERVED; `src/RTSec.Kryptonian.Api/appsettings.json` (IpRateLimiting scoped to EST paths) CODE-OBSERVED.

• **Approval:** Review Required

## SR-F-REG.008 - Trust removal blocks further enrollment

• **ID:** SR-F-REG.008

• **Requirement:** The gateway shall, upon administrative trust removal, deny subsequent enrollment and renewal attempts for that device and shall record a blocked enrollment event including a reason.

• **Rationale:** Decommissioned or compromised devices must not acquire fresh credentials.

• **Source:** KSPEC-002 UR-009 (UC-04, SCN-05).

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** Critical

• **Status:** Existing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Application/Services/EnrollmentOrchestrator.cs` (trust-policy gate) CODE-OBSERVED; docs/flow.md (Trust Removal Flow) DOCUMENTED.

• **Approval:** Review Required

### SR-F-REG.009 - Device identity metadata preservation

• **ID:** SR-F-REG.009

• **Requirement:** The gateway shall persist the device identity metadata presented during activation (including common name, manufacturer, model, and serial number) and shall display it in the device inventory.

• **Rationale:** Identity metadata is what ties a certificate back to a physical device for inventory and incident response.

• **Source:** KSPEC-002 UR-003, UR-020; README.md (activation workflow).

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** High

• **Status:** Existing

• **Verification:** D

• **Evidence:** `src/RTSec.Kryptonian.Application/DTOs/DeviceDto.cs` CODE-OBSERVED; README.md (activation code workflow) DOCUMENTED.

• **Approval:** Review Required

### SR-F-REG.010 - History preservation on device removal

• **ID:** SR-F-REG.010

• **Requirement:** The gateway shall preserve enrollment event history for removed devices so that audit reconstruction remains possible after device deletion.

• **Rationale:** Deleting the device record must not erase the evidence of credentials it received.

• **Source:** KSPEC-002 UR-011 (audit reconstruction); KSPEC-007 (revocation/removal scenarios).

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** Medium

• **Status:** Existing

• **Verification:** I

• **Evidence:** `src/RTSec.Kryptonian.Infrastructure/Repositories/EnrollmentEventRepository.cs` (events keyed by device record) CODE-OBSERVED; `src/RTSec.Kryptonian.Api/Controllers/DevicesController.cs` (Events after removal) CODE-OBSERVED.

• **Approval:** Review Required

## 4. Functional requirements - EST protocol behavior (SR-F-EST)

### SR-F-EST.001 - EST endpoint surface

• **ID:** SR-F-EST.001

• **Requirement:** The gateway shall expose the EST operations `cacerts`, `simpleenroll`, and `simplereenroll` under `/.well-known/est/` and under profile-scoped paths `/.well-known/est/{label}/`, and shall route requests case-insensitively to these operations.

• **Rationale:** A stable, standards-shaped endpoint surface is the device-facing contract of the gateway.

• **Source:** KSPEC-002 UR-016, UR-022 (UC-02/UC-03); RFC 7030 (referenced as design input, not a conformance claim).

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** Critical

• **Status:** Existing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Api/Controllers/EstController.cs` (route templates) CODE-OBSERVED; docs/ARCHITECTURE.md DOCUMENTED; independent-client EST executed per docs/IMPLEMENTATION-TRACKER.md VERIFIED.

• **Approval:** Review Required

## SR-F-EST.002 - cacerts response format

• **ID:** SR-F-EST.002

• **Requirement:** The gateway shall respond to a `cacerts` request for a valid profile with the profile's CA certificate chain encoded as base64 PKCS#7 with content type `application/pkcs7-mime; smime-type=certs-only` and the header `Content-Transfer-Encoding: base64`.

• **Rationale:** Devices must obtain the trust anchors needed to validate issued chains without out-of-band CA distribution.

• **Source:** KSPEC-002 UR-017 (UC-02).

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** High

• **Status:** Existing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Api/Controllers/EstController.cs` (GetCaCerts, Pkcs7MimeType) CODE-OBSERVED; `src/RTSec.Kryptonian.Infrastructure/Crypto/PkcsService.cs` CODE-OBSERVED.

• **Approval:** Review Required

## SR-F-EST.003 - simpleenroll CSR acceptance and size limit

• **ID:** SR-F-EST.003

• **Requirement:** The gateway shall accept a PKCS#10 CSR submitted to `simpleenroll` with content type `application/pkcs10` (base64 transfer encoding), shall reject request bodies larger than 64 KiB with HTTP 413, and shall reject bodies that do not parse as a CSR with HTTP 400.

• **Rationale:** Bounded, validated enrollment input protects the gateway from malformed and oversized payloads.

• **Source:** KSPEC-002 UR-016, UR-023; KSPEC-005 ICD-EST items.

• **Classification:** TO-BE (elaborates AS-IS behavior; acceptance of bare `text/plain` CSRs is an AS-IS leniency, not part of this requirement).

• **Priority:** High

• **Status:** Existing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Api/Controllers/EstController.cs` (SimpleEnroll, `RequestSizeLimit`, 413 mapping) CODE-OBSERVED; `src/RTSec.Kryptonian.Infrastructure/Crypto/PkcsService.cs` (DecodeEstRequestBodyAsync) CODE-OBSERVED.

• **Approval:** Review Required

## SR-F-EST.004 - Successful enrollment response

• **ID:** SR-F-EST.004

• **Requirement:** The gateway shall respond to a successful enrollment or renewal with HTTP 200 carrying the issued certificate chain as base64 PKCS#7 with content type `application/pkcs7-mime; smime-type=certs-only` and `Content-Transfer-Encoding: base64`.

• **Rationale:** A single response format across CA backends is what allows one device client implementation.

• **Source:** KSPEC-002 UR-016, UR-018.

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** Critical

• **Status:** Existing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Api/Controllers/EstController.cs` (HandleEnrollmentResult) CODE-OBSERVED; executed Schannel mTLS renewal using returned certificate VERIFIED per docs/IMPLEMENTATION-TRACKER.md.

• **Approval:** Review Required

## SR-F-EST.005 - Unknown or disabled profile labels fail closed

• **ID:** SR-F-EST.005

• **Requirement:** The gateway shall resolve the EST profile label against configured, enabled profiles only, shall respond HTTP 404 to requests whose label does not match a configured enabled profile, and shall not fall back to a default profile or another label.

• **Rationale:** Silent fallback to a default policy could enroll devices under the wrong trust and issuance policy.

• **Source:** KSPEC-002 UR-022 (unknown-label rejection); PR 37.

• **Classification:** TO-BE (normative statement of AS-IS behavior).

• **Priority:** High

• **Status:** Existing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Api/Controllers/EstController.cs` (ResolveProfileIdAsync, 404 "EST profile not found") CODE-OBSERVED; PR 37 profile issuer routing and unknown-label rejection per docs/IMPLEMENTATION-TRACKER.md.

• **Approval:** Review Required

## SR-F-EST.006 - Initial enrollment bootstrap authentication

• **ID:** SR-F-EST.006

• **Requirement:** The gateway shall accept initial enrollment (`simpleenroll`) for a pending device whose CSR identity passes binding (SR-F-REG.005) when the request carries HTTP Basic credentials of the form device-record-Guid : activation code, and shall require HTTPS for such requests, rejecting them with HTTP 403 on plain HTTP.

• **Rationale:** Standard HTTP Basic over TLS is the standards-based bootstrap credential mechanism; requiring TLS protects the one-time secret in transit.

• **Source:** KSPEC-002 UR-002, UR-019; PR 42 (standard Basic EST bootstrap; atomic one-time activation).

• **Classification:** TO-BE (normative statement of AS-IS behavior).

• **Priority:** Critical

• **Status:** Existing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Api/Controllers/EstController.cs` (SimpleEnroll Basic parsing, "Basic authentication requires TLS" 403) CODE-OBSERVED; independent curl HTTP-Basic EST over real HTTPS VERIFIED per docs/IMPLEMENTATION-TRACKER.md.

• **Approval:** Review Required

## SR-F-EST.007 - Legacy activation headers as compatibility only

• **ID:** SR-F-EST.007

• **Requirement:** The gateway shall accept the legacy compatibility headers `X-Activation-Code` and `X-Device-*` on `simpleenroll` for backward compatibility with the sample device client only, shall document them as legacy, shall require the same TLS protection and validation rules as the Basic bootstrap path, and shall not require them of any client; the TO-BE system shall provide a configuration switch to disable them on deployments that do not need compatibility.

• **Rationale:** A proprietary-header requirement would recreate vendor lock-in; the headers exist only for the bundled sample client.

• **Source:** KSPEC-002 UR-019 and §16.3 (legacy headers non-normative); EXC-004.

• **Classification:** TO-BE (compatibility retention with a deprecation switch).

• **Priority:** High

• **Status:** Partial

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Api/Controllers/EstController.cs` (X-Activation-Code header fallback path) CODE-OBSERVED; docs/IMPLEMENTATION-TRACKER.md (legacy headers "must not become a new interoperability requirement") DOCUMENTED; no disable switch exists CODE-OBSERVED.

• **Approval:** Review Required

## SR-F-EST.008 - Re-enrollment requires native TLS client certificate

• **ID:** SR-F-EST.008

• **Requirement:** The gateway shall require a native TLS client certificate for `simplereenroll` and shall respond HTTP 401 when none is presented, without accepting activation codes or Basic bootstrap credentials in place of the certificate.

• **Rationale:** Renewal trust must rest on possession of the currently valid credential, not on replayable bootstrap secrets.

• **Source:** KSPEC-002 UR-021 (UC-03, SCN-03); PR 44.

• **Classification:** TO-BE (normative statement of AS-IS behavior).

• **Priority:** Critical

• **Status:** Existing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Api/Controllers/EstController.cs` (SimpleReenroll, client-certificate 401) CODE-OBSERVED; renewal with native TLS client certificate, new key, preserved identity VERIFIED per docs/IMPLEMENTATION-TRACKER.md.

• **Approval:** Review Required

## SR-F-EST.009 - Client certificate validation on EST requests

• **ID:** SR-F-EST.009

• **Requirement:** The gateway shall validate every presented TLS client certificate on EST requests against the trust policy of the resolved profile (issuer/anchor trust, validity, and purpose), shall additionally require a client certificate on `simpleenroll` when the profile is configured to require one, and shall reject validation failures with HTTP 403.

• **Rationale:** A presented certificate must never be accepted without validation, even where a profile does not mandate one for bootstrap.

• **Source:** KSPEC-002 UR-008, UR-021; PR 45 (explicit EST client trust).

• **Classification:** TO-BE (normative statement of AS-IS behavior).

• **Priority:** Critical

• **Status:** Existing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Api/Controllers/EstController.cs` (ValidateClientCertificateAsync, RequireClientCertificate) CODE-OBSERVED; `src/RTSec.Kryptonian.Api/Authentication/ConfiguredClientCertificateTrust.cs` CODE-OBSERVED.

• **Approval:** Review Required

## SR-F-EST.010 - Pending enrollment responses

• **ID:** SR-F-EST.010

• **Requirement:** The gateway shall respond HTTP 202 with a `Retry-After` delay-seconds header and a JSON body when certificate issuance is pending, such that clients can distinguish this outcome from success and from failure without parsing free text.

• **Rationale:** Asynchronous backends need a defined retryable outcome so clients back off rather than hard-fail.

• **Source:** KSPEC-002 UR-023; PR 44; KSPEC-005 ICD-EST.004.

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** High

• **Status:** Existing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Api/Controllers/EstController.cs` (HandleEnrollmentResult, 202 + Retry-After) CODE-OBSERVED; docs/API-GUIDE.md (Retry-After semantics) DOCUMENTED.

• **Approval:** Review Required

## SR-F-EST.011 - Deterministic pending semantics per backend

• **ID:** SR-F-EST.011

• **Requirement:** The gateway shall define, for every pending-capable CA backend type, the deterministic conditions under which enrollment returns a pending result and the rule by which the `Retry-After` value is computed; the per-backend trigger matrix is `TBD` pending stakeholder agreement (KSPEC-005 open item).

• **Rationale:** Undocumented pending triggers make client retry behavior and diagnostics unpredictable.

• **Source:** KSPEC-005 ICD-EST.004 open item ("which CA backend states produce IsPending - UNKNOWN"); KSPEC-002 UR-023.

• **Classification:** TO-BE (specification gap; AS-IS trigger conditions UNKNOWN).

• **Priority:** Medium

• **Status:** Missing

• **Verification:** A

• **Evidence:** `src/RTSec.Kryptonian.Application/Services/EnrollmentOrchestrator.cs` (EnrollmentResult.IsPending/RetryAfterSeconds) CODE-OBSERVED; docs/formal-specification/05-INTERFACE-CONTROL.md §6 (open item) DOCUMENTED.

• **Approval:** Review Required

## SR-F-EST.012 - Plain-HTTP EST refusal

• **ID:** SR-F-EST.012

• **Requirement:** The gateway shall refuse EST requests received over plain HTTP with HTTP 426 unless the development-only escape `Kryptonian:Est:AllowPlainHttp` is explicitly enabled.

• **Rationale:** EST exchanges carry credentials and issued certificates; plain HTTP exposes both.

• **Source:** KSPEC-002 UR-002 (secret protection); KSPEC-005 ICD-EST (426 extension).

• **Classification:** TO-BE (normative statement of AS-IS behavior).

• **Priority:** Critical

• **Status:** Existing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Api/Program.cs` (EST plain-HTTP 426 middleware, AllowPlainHttp default false) CODE-OBSERVED; `src/RTSec.Kryptonian.Api/appsettings.json` CODE-OBSERVED.

• **Approval:** Review Required

## SR-F-EST.013 - Distinguishable EST/admin error semantics

• **ID:** SR-F-EST.013

• **Requirement:** The gateway shall return distinguishable HTTP status codes for failed device operations - invalid request (400), missing/invalid credential (401), policy-rejected (403), unknown or disabled profile (404), oversized body (413), rate-limited (429), internal error (500) - each with a machine-readable JSON error body on non-PKCS#7 responses.

• **Rationale:** Client developers need actionable failures; undifferentiated errors mask security events and raise support burden.

• **Source:** KSPEC-002 UR-023 (SCN-01/SCN-02).

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** High

• **Status:** Existing

• **Verification:** I

• **Evidence:** `src/RTSec.Kryptonian.Api/Controllers/EstController.cs` (EstError status mapping) CODE-OBSERVED; docs/API-GUIDE.md (status table) DOCUMENTED; docs/medical-device-demo.md (troubleshooting semantics) DOCUMENTED.

• **Approval:** Review Required

### SR-F-EST.014 - CSR attributes guidance endpoint

• **ID:** SR-F-EST.014

• **Requirement:** The gateway shall expose an EST `csrattrs` endpoint describing the CSR attributes (subject DN components and extensions) required by each profile, with bounded per-profile content.

• **Rationale:** Constrained clients otherwise need out-of-band knowledge of profile policy to construct acceptable CSRs.

• **Source:** KSPEC-004 PROPOSED item P-3; RFC 7030 (design input, not a conformance claim).

• **Classification:** PROPOSED (enhancement requiring stakeholder approval).

• **Priority:** Low

• **Status:** Missing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Api/Controllers/EstController.cs` (no csrattrs route) CODE-OBSERVED; docs/formal-specification/04-SOFTWARE-DESIGN.md (P-3) DOCUMENTED.

• **Approval:** Review Required

## 5. Functional requirements - certificate lifecycle management flows (SR-F-CLM)

### SR-F-CLM.001 - Administrator approval gates enrollment

• **ID:** SR-F-CLM.001

• **Requirement:** The gateway shall issue certificates only to devices whose registration has been approved by an administrator, and shall reject enrollment attempts for devices that are not approved.

• **Rationale:** Approval is the institutional decision that converts a pending registration into an enrollable identity.

• **Source:** KSPEC-002 UR-001, UR-008 (UC-01/UC-02).

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** Critical

• **Status:** Existing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Api/Controllers/DevicesController.cs` (Approve, DeviceAdmin policy) CODE-OBSERVED; `src/RTSec.Kryptonian.Application/Services/EnrollmentOrchestrator.cs` (status gate) CODE-OBSERVED.

• **Approval:** Review Required

### SR-F-CLM.002 - Automatic renewal without re-approval

• **ID:** SR-F-CLM.002

• **Requirement:** The gateway shall allow an active, non-revoked device to renew its certificate via `simplereenroll` within the renewal window without re-presenting an activation code or requiring administrator approval.

• **Rationale:** Renewal must be automatic and unattended; re-approval would defeat the automation goal.

• **Source:** KSPEC-002 UR-021, UR-025 (UC-03, SCN-03).

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** Critical

• **Status:** Existing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Application/Services/EnrollmentOrchestrator.cs` (ReenrollAsync) CODE-OBSERVED; renewal executed with new key and preserved identity VERIFIED per docs/IMPLEMENTATION-TRACKER.md.

• **Approval:** Review Required

### SR-F-CLM.003 - Renewal generates a new key and preserves approved identity

• **ID:** SR-F-CLM.003

• **Requirement:** The gateway shall issue renewal certificates against a newly generated device key pair while preserving the approved subject identity from the prior certificate, and shall reject renewal CSRs that do not match the approved identity policy.

• **Rationale:** Fresh keys bound to a stable identity prevent renewal from becoming an identity-substitution channel.

• **Source:** KSPEC-002 UR-021; PR 44/PR 43.

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** Critical

• **Status:** Existing

• **Verification:** T

• **Evidence:** docs/IMPLEMENTATION-TRACKER.md (renewal uses a native TLS client certificate, generates a new key, preserves approved identity) VERIFIED; `src/RTSec.Kryptonian.Application/Services/EnrollmentCertificatePolicy.cs` CODE-OBSERVED.

• **Approval:** Review Required

### SR-F-CLM.004 - Certificate expiry visibility

• **ID:** SR-F-CLM.004

• **Requirement:** The gateway shall expose, for every tracked certificate, its subject, issuer, serial number, status, and NotAfter timestamp to administrators so devices at risk of losing network trust can be identified.

• **Rationale:** Expired credentials cause transport failures that present as device "network problems"; early visibility enables planned maintenance.

• **Source:** KSPEC-002 UR-024 (UC-05/UC-09).

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** High

• **Status:** Existing

• **Verification:** D

• **Evidence:** `src/RTSec.Kryptonian.Api/Controllers/CertificatesController.cs` CODE-OBSERVED; `src/RTSec.Kryptonian.Api/Controllers/DevicesController.cs` (AllCertificates) CODE-OBSERVED; README.md (certificate expiry tracking) DOCUMENTED.

• **Approval:** Review Required

## SR-F-CLM.005 - Automated expiry scanning and notification

• **ID:** SR-F-CLM.005

• **Requirement:** The gateway shall scan daily for device certificates that enter the configured near-expiry warning window, shall send one notification per affected certificate to opted-in recipients, shall skip certificates for which a renewal has already been requested, and shall re-notify about the same certificate no more frequently than the configured re-notification interval.

• **Rationale:** Automated expiry detection is the compensating control that makes unattended renewal safe.

• **Source:** KSPEC-002 UR-012, UR-024 (UC-09); docs/email-notifications.md.

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** High

• **Status:** Partial

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Api/HostedServices/CertificateExpiryWatcher.cs` (24h scan interval, 7-day re-notify, renewal check) CODE-OBSERVED; `src/RTSec.Kryptonian.Application/Notifications/NotificationDispatcher.cs` CODE-OBSERVED.

• **AS-IS limitation:** Scan interval is fixed at 24 hours, startup delay at 2 minutes, and re-notification at 7 days. Only the warning window is configurable. Renewal suppression tests `Device.LastCertificateId` for a different certificate (successful newer issuance), not whether a renewal was merely requested. Dispatcher success is not proof of SMTP delivery. Configurable re-notification and delivery evidence remain TO-BE (RF-009, VT-029).

• **Approval:** Review Required

## SR-F-CLM.006 - Non-renewal alerting

• **ID:** SR-F-CLM.006

• **Requirement:** The gateway shall notify configured administrators by email when a device certificate approaches expiry and has not been renewed as expected; the complete production trigger set and delivery-reliability mechanism are `TBD` (KSPEC-001 TBD-002).

• **Rationale:** Non-renewal is an early signal of device problems; expiry otherwise leads to silent outages.

• **Source:** KSPEC-002 UR-012 (UC-09); README.md (Renewal monitoring).

• **Classification:** TO-BE (elaborates AS-IS behavior; delivery behavior at baseline UNKNOWN).

• **Priority:** High

• **Status:** Partial

• **Verification:** D

• **Evidence:** `src/RTSec.Kryptonian.Api/HostedServices/CertificateExpiryWatcher.cs` (skips renewed certificates; non-renewal is implied by expiry-window presence) CODE-OBSERVED; `src/RTSec.Kryptonian.Infrastructure/Notifications/MailKitSmtpSender.cs` CODE-OBSERVED; docs/email-notifications.md DOCUMENTED; docs/IMPLEMENTATION-TRACKER.md (delivery not exercised) DOCUMENTED.

• **Approval:** Review Required

## SR-F-CLM.007 - Authorized revocation with issuer-scoped signed CRLs

• **ID:** SR-F-CLM.007

• **Requirement:** The gateway shall support administrative certificate revocation that marks the certificate revoked, denies re-enrollment authenticated with that revoked credential, and publishes an issuer-scoped signed CRL reflecting the revocation.

• **Rationale:** Revocation must separate "deny further enrollment" from "peers reject an already issued certificate," using ordinary PKI mechanisms.

• **Source:** KSPEC-002 UR-010 (UC-04, SCN-05); PR 46.

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** Critical

• **Status:** Existing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Application/Services/CertificateRevocationService.cs` CODE-OBSERVED; `src/RTSec.Kryptonian.Api/Controllers/CrlController.cs` CODE-OBSERVED; administrator revocation followed by native online X509Chain Revoked result VERIFIED per docs/IMPLEMENTATION-TRACKER.md.

• **AS-IS distinction:** This service changes certificate and issuer CRL state; it does not change Device.Status. Other valid credentials for the device are not automatically revoked. Device removal is a separate administrative operation (SR-C.009).

• **Approval:** Review Required

## SR-F-CLM.008 - Transactional revocation persistence

• **ID:** SR-F-CLM.008

• **Requirement:** The gateway shall persist revocation outcome - certificate status, revocation timestamp, and issuer CRL state - atomically, and shall reject a concurrent conflicting update with HTTP 409 rather than leaving inconsistent state.

• **Rationale:** Partially applied revocations would leave credentials in an indeterminate trust state.

• **Source:** KSPEC-002 UR-010; PR 46 (transactional persistence and concurrent-update protection).

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** High

• **Status:** Existing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Application/Services/CertificateRevocationService.cs` CODE-OBSERVED; `src/RTSec.Kryptonian.Infrastructure/Data/UnitOfWork.cs` CODE-OBSERVED; docs/formal-specification/07-OPERATIONAL-RISK.md (transactional revocation) DOCUMENTED.

• **Approval:** Review Required

### SR-F-CLM.009 - Revoked devices denied renewal

• **ID:** SR-F-CLM.009

• **Requirement:** The gateway shall refuse `simplereenroll` requests for devices whose current credential is revoked or whose device record is untrusted, and shall record the refusal as a blocked enrollment event.

• **Rationale:** Revocation must terminate the credential lifecycle, not merely mark a status field.

• **Source:** KSPEC-002 UR-009, UR-010.

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** Critical

• **Status:** Existing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Application/Services/EnrollmentOrchestrator.cs` (trust/status gate) CODE-OBSERVED; proxy tests rejecting revoked clients VERIFIED per docs/IMPLEMENTATION-TRACKER.md.

• **Approval:** Review Required

## 6. Functional requirements - CA backend integration (SR-F-CAI)

### SR-F-CAI.001 - Multi-backend configuration without code changes

• **ID:** SR-F-CAI.001

• **Requirement:** The gateway shall allow an administrator to configure multiple CA backends through the admin portal using guided fields or an advanced JSON configuration, without code changes.

• **Rationale:** Hospitals use different CA technologies; configuration must not require recompilation or vendor intervention.

• **Source:** KSPEC-002 UR-004 (UC-06); docs/ca-backend-configuration.md.

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** High

• **Status:** Existing

• **Verification:** D

• **Evidence:** `src/RTSec.Kryptonian.Api/Controllers/CaBackendsController.cs` CODE-OBSERVED; `src/RTSec.Kryptonian.Application/Services/CaBackendService.cs` CODE-OBSERVED; docs/ca-backend-configuration.md DOCUMENTED.

• **Approval:** Review Required

### SR-F-CAI.002 - Backend testing and profile-bound issuer routing

• **ID:** SR-F-CAI.002

• **Requirement:** The gateway shall support testing a configured CA backend before activation, shall route each device enrollment to the enabled backend bound to the resolved EST profile, independently of the globally active dashboard backend, and shall not require the device to send a backend identifier.

• **Rationale:** Prevents misconfigured backends from receiving live enrollments and preserves the device-side single-protocol abstraction.

• **Source:** KSPEC-002 UR-005 (UC-06, SCN-06).

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** High

• **Status:** Existing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Api/Controllers/CaBackendsController.cs` (test/activation endpoints) CODE-OBSERVED; `EnrollmentOrchestrator.ResolveProfileBackendAsync` and `GetCaCertsAsync` CODE-OBSERVED; docs/ca-backend-configuration.md (testing and activation) DOCUMENTED.

• **Approval:** Review Required

## SR-F-CAI.003 - Pluggable connector abstraction

• **ID:** SR-F-CAI.003

• **Requirement:** The gateway shall connect to CA backends through a common internal connector abstraction supporting Self-Signed, ACME (RFC 8555), ADCS (SCEP-compatible service), and EJBCA (REST) backend types, and shall reject unknown backend types rather than defaulting to a backend.

• **Rationale:** The connector abstraction is the mechanism behind CA-agnostic device enrollment and future backend growth.

• **Source:** KSPEC-002 UR-030, UR-038 (UC-06).

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** High

• **Status:** Existing

• **Verification:** A

• **Evidence:** `src/RTSec.Kryptonian.Infrastructure/Crypto/CaConnectorFactory.cs` (factory; `NotSupportedException` for unknown types) CODE-OBSERVED; `src/RTSec.Kryptonian.Infrastructure/Harness/AdcsCaConnector.cs`, `EjbcaCaConnector.cs`, `SelfSignedEstCaConnector.cs`; `src/RTSec.Kryptonian.Infrastructure/Acme/AcmeCaConnector.cs` CODE-OBSERVED.

• **Approval:** Review Required

## SR-F-CAI.004 - Transparent CA protocol mapping

• **ID:** SR-F-CAI.004

• **Requirement:** The gateway shall map authenticated device enrollment requests to the hospital-selected CA backend's native protocol such that device-side code requires no CA-specific integration.

• **Rationale:** Preserves the manufacturer's single implementation while hospitals keep CA choice; the gateway is the adaptation layer.

• **Source:** KSPEC-002 UR-018 (UC-06, SCN-06); docs/flow.md (Responsibility Split).

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** Critical

• **Status:** Existing

• **Verification:** A

• **Evidence:** `src/RTSec.Kryptonian.Application/Services/EnrollmentOrchestrator.cs` (backend dispatch) CODE-OBSERVED; docs/flow.md DOCUMENTED.

• **Approval:** Review Required

## SR-F-CAI.005 - ADCS integration via configurable SCEP endpoint

• **ID:** SR-F-CAI.005

• **Requirement:** The gateway shall integrate with an ADCS backend through its SCEP-compatible service using administrator-configured service endpoints, rather than hard-coded endpoint paths.

• **Rationale:** Hard-coded endpoint paths prevent adaptation to real hospital ADCS deployments.

• **Source:** docs/adcs-real-backend-demo.md (Gap 1 - SCEP path is hardcoded); KSPEC-002 UR-030.

• **Classification:** TO-BE (hardening of an AS-IS weak control).

• **Priority:** Medium

• **Status:** Partial

• **Verification:** I

• **Evidence:** `src/RTSec.Kryptonian.Infrastructure/Harness/AdcsCaConnector.cs` and `src/RTSec.Kryptonian.Infrastructure/Harness/ScepClient.cs` (posts to `scep/adcs?operation=…`) CODE-OBSERVED; docs/adcs-real-backend-demo.md Gap 1 DOCUMENTED.

• **Approval:** Review Required

## SR-F-CAI.006 - EJBCA REST integration with explicit revocation configuration

• **ID:** SR-F-CAI.006

• **Requirement:** The gateway shall integrate with an EJBCA backend over its REST interface, shall require the issuer DN to be configured before revocation operations are attempted, and shall report revocation failure honestly (never as success) when the backend is misconfigured or the operation fails.

• **Rationale:** Silent revocation success would mislead operators into trusting revoked credentials.

• **Source:** KSPEC-002 UR-010, UR-030; docs/ca-backend-configuration.md.

• **Classification:** TO-BE (elaborates AS-IS behavior; remote revocation interoperability UNVERIFIED).

• **Priority:** Medium

• **Status:** Partial

• **Verification:** I

• **Evidence:** `src/RTSec.Kryptonian.Infrastructure/Harness/EjbcaCaConnector.cs` (revoke requires `IssuerDn`; returns false on failure/misconfiguration) CODE-OBSERVED; docs/IMPLEMENTATION-TRACKER.md (ADCS/EJBCA hospital revocation unverified) DOCUMENTED.

• **Approval:** Review Required

## SR-F-CAI.007 - ACME enrollment with functional challenge set

• **ID:** SR-F-CAI.007

• **Requirement:** The gateway shall integrate with an ACME (RFC 8555) backend including external account binding, and shall implement each configured challenge type it advertises; a challenge type that is not implemented shall be rejected at configuration time rather than failing at issuance.

• **Rationale:** Advertising a challenge type that is a stub causes unpredictable enrollment failures.

• **Source:** KSPEC-002 UR-030; KSPEC-004 AS-IS limitation (Dns01ChallengeStub).

• **Classification:** TO-BE (hardening of an AS-IS weak control; DNS-01 is a stub at baseline).

• **Priority:** Medium

• **Status:** Partial

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Infrastructure/Acme/AcmeCaConnector.cs`, `Http01ChallengeStore.cs`, `Http01ChallengeCleanupService.cs` CODE-OBSERVED; `src/RTSec.Kryptonian.Infrastructure/Acme/Dns01ChallengeStub.cs` CODE-OBSERVED.

• **Approval:** Review Required

## SR-F-CAI.008 - Gateway CRL generation limited to capable backends; fail closed otherwise

• **ID:** SR-F-CAI.008

• **Requirement:** The gateway shall generate and publish issuer-scoped CRLs for backends whose issuing capability is gateway-held (Self-Signed), shall serve CRLs from configured remote backends when those backends provide revocation data, and shall refuse CRL publication requests for backends without such capability with an explicit not-implemented error rather than publishing a false CRL.

• **Rationale:** A false CRL would misstate revocation trust for all peers of that issuer.

• **Source:** KSPEC-002 UR-010; PR 46; docs/IMPLEMENTATION-TRACKER.md (local CA CRLs demonstrated; unsupported remote CA revocation fails closed).

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** High

• **Status:** Existing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Application/Services/CertificateRevocationService.cs` and `src/RTSec.Kryptonian.Api/Controllers/CrlController.cs` (501 on unsupported CRL generation) CODE-OBSERVED; docs/formal-specification/07-OPERATIONAL-RISK.md (fail-closed orientation) DOCUMENTED.

• **Approval:** Review Required

## SR-F-CAI.009 - CA material persistence across restarts and upgrades

• **ID:** SR-F-CAI.009

• **Requirement:** The gateway shall persist configured CA backend material (including CA certificates, connector credentials, and trust anchors) such that a gateway restart or in-place upgrade preserves the configuration and enrollment continues without administrator rework.

• **Rationale:** Loss of CA configuration would silently break enrollment and trust validation for the whole estate.

• **Source:** KSPEC-002 UR-037; PR 41; installer upgrade behavior in docs/formal-specification/07-OPERATIONAL-RISK.md.

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** High

• **Status:** Existing

• **Verification:** T

• **Evidence:** docs/IMPLEMENTATION-TRACKER.md (gateway restart on populated SQLite preserved configured profile, issuer and devices) VERIFIED; `src/RTSec.Kryptonian.Infrastructure/Repositories/CaBackendRepository.cs` CODE-OBSERVED.

• **Approval:** Review Required

### SR-F-CAI.010 - Secure connector credential handling

• **ID:** SR-F-CAI.010

• **Requirement:** The gateway shall obtain CA service-account secrets, ACME account keys, and CA key passwords from a secure secrets mechanism (secret vault or OS-protected secret service) rather than plain configuration files; the selected mechanism is `TBD` pending stakeholder decision (TBD-005).

• **Rationale:** Leakage of CA-issuing credentials compromises the institution's entire PKI.

• **Source:** KSPEC-002 UR-013 (Missing); Mvp.md §8.

• **Classification:** TO-BE (not implemented at baseline).

• **Priority:** High

• **Status:** Missing

• **Verification:** I

• **Evidence:** `src/RTSec.Kryptonian.Api/appsettings.json` and `src/RTSec.Kryptonian.Api/Program.cs` (configuration/environment sourcing) CODE-OBSERVED; docs/IMPLEMENTATION-TRACKER.md (environment variables and configuration files at baseline) DOCUMENTED.

• **Approval:** Review Required

## 7. Functional requirements - administration and portal (SR-F-ADM)

### SR-F-ADM.001 - Administrative portal surface

• **ID:** SR-F-ADM.001

• **Requirement:** The gateway shall provide an administrator portal covering device registration and lifecycle operations, CA backend configuration, EST profile management, user administration, notification configuration, and audit review.

• **Rationale:** The portal is the primary operating surface for hospital IT staff; coverage gaps force unsafe out-of-band administration.

• **Source:** KSPEC-002 UR-001, UR-003, UR-004, UR-015, UR-024; README.md.

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** High

• **Status:** Existing

• **Verification:** D

• **Evidence:** `src/RTSec.Kryptonian.Api/Controllers/` (15 controllers) CODE-OBSERVED; `src/RTSec.Kryptonian.Web` (Blazor Server) and `src/RTSec.Kryptonian.Ui` (React/TypeScript) CODE-OBSERVED; README.md DOCUMENTED.

• **Approval:** Review Required

## SR-F-ADM.002 - Gateway dashboard summary

• **ID:** SR-F-ADM.002

• **Requirement:** The gateway shall provide a dashboard summarizing CA backend state, registered device counts, enrollment outcomes, and backend evidence.

• **Rationale:** Administrators need rapid assessment of gateway health without querying each subsystem.

• **Source:** KSPEC-002 UR-006.

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** Medium

• **Status:** Existing

• **Verification:** D

• **Evidence:** `src/RTSec.Kryptonian.Api/Controllers/StatusController.cs` CODE-OBSERVED; README.md (Gateway dashboard) DOCUMENTED.

• **Approval:** Review Required

## SR-F-ADM.003 - User account lifecycle with lockout protection

• **ID:** SR-F-ADM.003

• **Requirement:** The gateway shall allow a SystemAdmin to create, edit, deactivate, and delete user accounts, shall forbid a user from deleting their own account, and shall block deletion of the last active SystemAdmin account.

• **Rationale:** Prevents self-lockout and loss of administrative access to the gateway.

• **Source:** KSPEC-002 UR-007, UR-015; docs/user-management.md (Managing Users; delete protections).

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** High

• **Status:** Existing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Api/Controllers/UsersController.cs` (SystemAdmin policy) CODE-OBSERVED; `src/RTSec.Kryptonian.Application/Services/UserService.cs` (self-deletion and last-admin guards) CODE-OBSERVED; docs/user-management.md DOCUMENTED.

• **Approval:** Review Required

## SR-F-ADM.004 - API key lifecycle

• **ID:** SR-F-ADM.004

• **Requirement:** The gateway shall allow DeviceAdmin-and-above users to generate, list, and revoke API keys, shall store only a hash of each key, shall support optional key expiry, and shall scope key visibility so a DeviceAdmin sees only their own keys while a SystemAdmin sees all keys with owner attribution.

• **Rationale:** Keys are bearer credentials; hashed storage, scoped visibility, and revocation limit blast radius.

• **Source:** KSPEC-002 UR-027; docs/user-management.md (API Keys).

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** High

• **Status:** Existing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Api/Controllers/ApiKeysController.cs` (DeviceAdmin policy, UnauthorizedAccessException scoping) CODE-OBSERVED; `src/RTSec.Kryptonian.Infrastructure/Repositories/ApiKeyRepository.cs` CODE-OBSERVED; docs/user-management.md DOCUMENTED.

• **Approval:** Review Required

## SR-F-ADM.005 - Initial administrator bootstrap

• **ID:** SR-F-ADM.005

• **Requirement:** The gateway shall support first-administrator setup through a UI setup wizard and, optionally, through initial-admin environment variables, and shall seed an initial administrator only when gateway setup is still pending.

• **Rationale:** Automated deployments need unattended bootstrap; re-seeding on populated systems would be an account-injection vector.

• **Source:** KSPEC-002 UR-007, UR-015; docs/admin-setup.md; docs/user-management.md (FAQ).

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** High

• **Status:** Existing

• **Verification:** T

• **Evidence:** `AuthService.BootstrapAsync`, `AuthController.Setup` and `Program.cs` initial-admin seeding CODE-OBSERVED.

• **Approval:** Review Required

## SR-F-ADM.006 - Notification settings management

• **ID:** SR-F-ADM.006

• **Requirement:** The gateway shall allow SystemAdmin configuration of notification settings (SMTP transport parameters, recipients, event subscriptions including near-expiry and revocation events) and shall provide a test-notification action.

• **Rationale:** Notification routing is deployment-specific (on-prem SMTP relays) and must be verifiable without generating a real incident.

• **Source:** KSPEC-002 UR-012; docs/email-notifications.md.

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** Medium

• **Status:** Existing

• **Verification:** D

• **Evidence:** `src/RTSec.Kryptonian.Api/Controllers/NotificationSettingsController.cs` (SystemAdmin policies, test endpoint) CODE-OBSERVED; `src/RTSec.Kryptonian.Application/Services/NotificationSettingsService.cs` CODE-OBSERVED; docs/email-notifications.md DOCUMENTED.

• **Approval:** Review Required

## SR-F-ADM.007 - EST profile management with additive trust-list updates

• **ID:** SR-F-ADM.007

• **Requirement:** The gateway shall allow SystemAdmin creation, modification, enable/disable, and deletion of named EST profiles, and shall apply profile updates such that a partial update that omits trust-list fields preserves the previously stored trust lists rather than clearing them.

• **Rationale:** Silent narrowing of trust policy on update would break enrolled devices unpredictably.

• **Source:** KSPEC-002 UR-031, UR-032; PR 47 (partial updates preserve omitted trust lists).

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** High

• **Status:** Existing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Api/Controllers/EstProfilesController.cs` (SystemAdmin policies) CODE-OBSERVED; `src/RTSec.Kryptonian.Application/Services/EstProfileService.cs` CODE-OBSERVED; `src/RTSec.Kryptonian.Infrastructure/Data/SchemaUpgrades.cs` (EnsureTrustPolicyAsync) CODE-OBSERVED.

• **Approval:** Review Required

## SR-F-ADM.008 - Gateway settings management

• **ID:** SR-F-ADM.008

• **Requirement:** The gateway shall allow SystemAdmin inspection and modification of gateway operational settings persisted in the database, overriding compiled or file defaults without redeployment.

• **Rationale:** Operational tuning (e.g., warning windows) must not require redeployment.

• **Source:** KSPEC-002 UR-006, UR-024; `GatewaySettingsController` surface.

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** Medium

• **Status:** Existing

• **Verification:** I

• **Evidence:** `src/RTSec.Kryptonian.Api/Controllers/GatewaySettingsController.cs` (SystemAdmin policy) CODE-OBSERVED; `src/RTSec.Kryptonian.Application/Services/GatewaySettingsService.cs` CODE-OBSERVED; `src/RTSec.Kryptonian.Infrastructure/Repositories/GatewaySettingsRepository.cs` CODE-OBSERVED.

• **Approval:** Review Required

## SR-F-ADM.009 - Live activity feed

• **ID:** SR-F-ADM.009

• **Requirement:** The gateway shall provide administrators a live activity view of recent log events through an in-memory ring buffer endpoint, without requiring access to server log files.

• **Rationale:** Operational triage needs real-time visibility from the portal.

• **Source:** KSPEC-002 UR-006, UR-011; `LogsController`/`LiveLogBroadcaster` surface.

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** Medium

• **Status:** Existing

• **Verification:** D

• **Evidence:** `src/RTSec.Kryptonian.Api/Controllers/LogsController.cs` CODE-OBSERVED; `src/RTSec.Kryptonian.Api/Logging/LiveLogBroadcaster` sink registration in `src/RTSec.Kryptonian.Api/Program.cs` CODE-OBSERVED.

• **Approval:** Review Required

### SR-F-ADM.010 - Health and status endpoint

• **ID:** SR-F-ADM.010

• **Requirement:** The gateway shall expose an unauthenticated health-check endpoint reporting overall health and the health of its database component, suitable for liveness/readiness probes.

• **Rationale:** Monitoring systems and orchestrators need a liveness/readiness probe.

• **Source:** KSPEC-002 UR-029 (SCN-09 context); docs/DEPLOYMENT.md.

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** Medium

• **Status:** Existing

• **Verification:** T

• **Evidence:** `StatusController.cs` and `Program.cs` MapHealthChecks/AddDbContextCheck CODE-OBSERVED; component readiness beyond database UNKNOWN.

• **Approval:** Review Required

## 8. Functional requirements - interoperability and contract artifacts (SR-F-INT)

### SR-F-INT.001 - Independent-client usability of the EST path

• **ID:** SR-F-INT.001

• **Requirement:** The gateway's EST path shall be usable by independent clients that implement standard HTTP authentication and RFC 7030-style message formats only, without requiring gateway-specific headers, user agents, or prior gateway registration beyond the documented bootstrap credential.

• **Rationale:** A proprietary-client requirement would recreate the vendor lock-in the gateway exists to remove.

• **Source:** KSPEC-002 UR-019 (VERIFIED executed evidence); KSPEC-001 EXC-004.

• **Classification:** TO-BE (normative statement of AS-IS behavior).

• **Priority:** High

• **Status:** Existing

• **Verification:** T

• **Evidence:** docs/IMPLEMENTATION-TRACKER.md (independent curl HTTP Basic EST over real HTTPS) VERIFIED; docs/API-GUIDE.md (EstClient example) DOCUMENTED.

• **Approval:** Review Required

### SR-F-INT.002 - Compatibility headers never mandatory

• **ID:** SR-F-INT.002

• **Requirement:** No gateway-specific compatibility header shall be mandatory for enrollment or renewal by any client, and no requirement in any package document shall promote the legacy activation headers to an interoperability requirement.

• **Rationale:** Locks in the single-protocol interoperability proposition; prevents specification drift toward private headers.

• **Source:** KSPEC-002 UR-019 and §16.3; docs/IMPLEMENTATION-TRACKER.md (deliberate boundaries).

• **Classification:** TO-BE (governing constraint).

• **Priority:** High

• **Status:** Existing

• **Verification:** I

• **Evidence:** `src/RTSec.Kryptonian.Api/Controllers/EstController.cs` (Basic path independent of legacy headers) CODE-OBSERVED; docs/IMPLEMENTATION-TRACKER.md DOCUMENTED.

• **Approval:** Review Required

## SR-F-INT.003 - Authoritative machine-readable admin API contract

• **ID:** SR-F-INT.003

• **Requirement:** The gateway's admin API shall have an authoritative, current, machine-readable OpenAPI contract that describes every implemented endpoint, authentication scheme, and error response, and each contract file in the repository shall either be current and complete for the endpoints it claims or be explicitly marked superseded.

• **Rationale:** Integrators automate against the contract; an empty or stale contract silently misrepresents the API.

• **Source:** KSPEC-002 UR-027; baseline finding: `OpenAPI.Client.yaml` is empty and `OpenAPI.Schema.yaml` is stale (KSPEC-005).

• **Classification:** TO-BE (not satisfied at baseline).

• **Priority:** High

• **Status:** Missing

• **Verification:** I

• **Evidence:** `OpenAPI.Client.yaml` (empty) and `OpenAPI.Schema.yaml` (stale) CODE-OBSERVED; `OpenAPI.Admin.yaml`, `OpenAPI.ESTProfiles.yaml`, `OpenAPI.StatusObserve.yaml` CODE-OBSERVED; docs/formal-specification/05-INTERFACE-CONTROL.md DOCUMENTED.

• **Approval:** Review Required

## SR-F-INT.004 - Contract-driven EST profile schema currency

• **ID:** SR-F-INT.004

• **Requirement:** The EST profile OpenAPI contract shall describe the current EST profile policy fields (subject-DN rules, key usage, validity, trust policy, client-certificate requirement, enablement) as actually enforced by the gateway.

• **Rationale:** Profile policy is the security boundary between the institution and devices; contract drift hides enforcement changes.

• **Source:** KSPEC-002 UR-031; `OpenAPI.ESTProfiles.yaml` review.

• **Classification:** TO-BE (elaborates AS-IS behavior; requires contract-vs-implementation reconciliation).

• **Priority:** Medium

• **Status:** Partial

• **Verification:** I

• **Evidence:** `OpenAPI.ESTProfiles.yaml` CODE-OBSERVED; `src/RTSec.Kryptonian.Application/DTOs/EstProfileDto.cs` CODE-OBSERVED; docs/formal-specification/05-INTERFACE-CONTROL.md DOCUMENTED.

• **Approval:** Review Required

## SR-F-INT.005 - DICOM mTLS demonstration over gateway-issued credentials

• **ID:** SR-F-INT.005

• **Requirement:** The repository shall include a demonstration in which two independent device peers establish a mutually authenticated TLS DICOM connection using gateway-issued certificates, with both peers enforcing issuer trust, certificate purpose, and online revocation status.

• **Rationale:** End-to-end lifecycle evidence (issuance → use → revocation) is the credibility core of the research contribution.

• **Source:** KSPEC-002 UR-034, UR-036 (research goals); KSPEC-000 §3 (demonstration clients are not product deliverables).

• **Classification:** AS-IS (demonstration component; not a product deliverable for production).

• **Priority:** Medium

• **Status:** Existing

• **Verification:** D

• **Evidence:** `src/Kryptonian.DICOMTls/` CODE-OBSERVED; two mutual-TLS DICOM C-STORE transfers with SOP Instance UID comparison VERIFIED per docs/IMPLEMENTATION-TRACKER.md and `artifacts/developer/verify-*/evidence.json`; tests/RTSec.Kryptonian.DimseTlsProxy.Tests/ CODE-OBSERVED.

• **Approval:** Review Required

## SR-F-INT.006 - Demonstration components carry no production or clinical claims

• **ID:** SR-F-INT.006

• **Requirement:** The gateway's demonstration components (device simulator, DIMSE-TLS proxy) shall be documented as reference/demonstration clients only, shall not be presented as production deliverables, and shall not be described as conferring clinical capability, SDC participation, or regulatory status on any device.

• **Rationale:** Preserves the identity/capability boundary (KSPEC-000 §3) and prevents overstating maturity.

• **Source:** KSPEC-002 UR-026, UR-035; README.md disclaimer.

• **Classification:** TO-BE (governing constraint).

• **Priority:** High

• **Status:** Existing

• **Verification:** I

• **Evidence:** `src/Kryptonian.MedicalDevice/`, `src/Kryptonian.DICOMTls/` CODE-OBSERVED; README.md disclaimer and docs/IMPLEMENTATION-TRACKER.md (deliberate boundaries) DOCUMENTED.

• **Approval:** Review Required

## SR-F-INT.007 - No competing enrollment protocol

• **ID:** SR-F-INT.007

• **Requirement:** The gateway shall not define or require a second proprietary enrollment protocol; its contribution to the OR.NET / IEEE 11073 SDC enrollment effort shall be operational evidence aligned with EST-based direction.

• **Rationale:** A competing protocol would fragment the enrollment landscape the project aims to support.

• **Source:** KSPEC-002 UR-034; docs/ORNET-ALIGNMENT-2026-09-09.md; docs/CHANGES-AND-ORNET-ALIGNMENT.md.

• **Classification:** TO-BE (governing constraint).

• **Priority:** High

• **Status:** Existing

• **Verification:** I

• **Evidence:** README.md; docs/IMPLEMENTATION-TRACKER.md (deliberate boundaries: no SDC conformity claimed); docs/ORNET-ALIGNMENT-2026-09-09.md DOCUMENTED.

• **Approval:** Review Required

### SR-F-INT.008 - Joint interoperability test vectors

• **ID:** SR-F-INT.008

• **Requirement:** The project shall maintain an interoperability testing approach in which independent client/server pairs exercise the real network boundary (enrollment authentication, issuer trust, certificate identity/purposes, renewal, revocation timing, failure behavior), with test vectors agreed jointly with OR.NET where possible.

• **Rationale:** Controller-mocked tests missed real defects at baseline; boundary-level testing is the agreed path to credible evidence.

• **Source:** KSPEC-002 UR-036; docs/IMPLEMENTATION-TRACKER.md ("live checks exposed two bugs that mocked tests missed").

• **Classification:** PROPOSED (joint vectors require stakeholder agreement; boundary testing itself is AS-IS).

• **Priority:** Medium

• **Status:** Proposed

• **Verification:** T

• **Evidence:** `artifacts/developer/verify-*/evidence.json` (gateway-boundary verifier) VERIFIED; tests/ (8 test projects) CODE-OBSERVED; OR.NET joint vectors not present PROPOSED.

• **Approval:** Review Required

## 9. Security requirements (SR-S)

### SR-S.001 - Transport security for credential-bearing exchanges

• **ID:** SR-S.001

• **Requirement:** The gateway shall require TLS for EST endpoints and for any request carrying authentication credentials, shall enable HTTPS redirection outside Development, and shall refuse unencrypted EST traffic with HTTP 426.

• **Rationale:** Bootstrap secrets, CSRs, and issued certificates in transit are the core confidentiality/identity assets of the system.

• **Source:** KSPEC-002 UR-002, UR-014; docs/ARCHITECTURE.md (Security by Default).

• **Classification:** TO-BE (normative statement of AS-IS behavior).

• **Priority:** Critical

• **Status:** Existing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Api/Program.cs` (426 middleware, `Kryptonian:Tls:RedirectHttpToHttps` default enabled outside Development) CODE-OBSERVED; docs/DEPLOYMENT.md DOCUMENTED.

• **Approval:** Review Required

## SR-S.002 - CSR and returned-certificate policy enforcement

• **ID:** SR-S.002

• **Requirement:** The gateway shall evaluate the submitted CSR and the CA-returned certificate against the resolved EST profile's issuance policy (subject DN rules, SAN, EKU, key usage, validity) and shall refuse to deliver any credential whose identity or purpose exceeds the approved policy.

• **Rationale:** A malicious or faulty client must not obtain credentials whose identity or purpose exceeds its approved policy.

• **Source:** KSPEC-002 UR-033 (Critical, VERIFIED); PR 43.

• **Classification:** TO-BE (normative statement of AS-IS behavior).

• **Priority:** Critical

• **Status:** Existing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Application/Services/EnrollmentCertificatePolicy.cs` CODE-OBSERVED; PR 43 CSR and returned-certificate policy enforcement VERIFIED per docs/IMPLEMENTATION-TRACKER.md.

• **Approval:** Review Required

## SR-S.003 - Gateway-owned trust-policy gate

• **ID:** SR-S.003

• **Requirement:** The gateway shall evaluate device trust policy itself and shall reject certificate requests from unknown, unactivated, untrusted, or retired devices before any contact with the CA backend.

• **Rationale:** The gateway, not the CA, owns the medical-device trust decision; CA-side rejection is not a substitute.

• **Source:** KSPEC-002 UR-008 (Critical); docs/flow.md (Trust Policy Role).

• **Classification:** TO-BE (normative statement of AS-IS behavior).

• **Priority:** Critical

• **Status:** Existing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Application/Services/EnrollmentOrchestrator.cs` (pre-CA trust gate) CODE-OBSERVED; docs/flow.md DOCUMENTED.

• **Approval:** Review Required

## SR-S.004 - Forwarded-certificate identity guard

• **ID:** SR-S.004

• **Requirement:** The gateway shall accept a client TLS identity supplied via the `X-Forwarded-Client-Cert` header only from explicitly configured trusted proxies, shall reject such a header from any other source with HTTP 403, shall reject it when a native client certificate is also present, and shall reject multiple forwarding headers with HTTP 400.

• **Rationale:** Uncontrolled certificate forwarding allows any client to assert a forged peer identity.

• **Source:** PR 39 (trusted forwarding guard); KSPEC-005 ICD (CertificateForwardingGuard); KSPEC-002 UR-008.

• **Classification:** TO-BE (normative statement of AS-IS behavior).

• **Priority:** Critical

• **Status:** Existing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Api/Middleware/CertificateForwardingGuard.cs` (KnownProxies allow-list, 403/400 behavior, default empty = fail closed) CODE-OBSERVED; direct forwarded-certificate spoof rejected VERIFIED per docs/IMPLEMENTATION-TRACKER.md.

• **Approval:** Review Required

## SR-S.005 - Authenticated forwarder identity

• **ID:** SR-S.005

• **Requirement:** The gateway shall authenticate the forwarding proxy itself for the `X-Forwarded-Client-Cert` path (by mutual TLS, shared secret, or equivalent cryptographic means) and shall not rely solely on the connection source IP address to authorize certificate forwarding; the selected mechanism is `TBD` pending design approval.

• **Rationale:** A source-IP allow-list alone can be spoofed on routed networks; the forwarded identity is as sensitive as the credential itself.

• **Source:** KSPEC-004 PROPOSED item P-2; KSPEC-006 threat model (XFCC spoofing route).

• **Classification:** TO-BE (hardening of an AS-IS weak control).

• **Priority:** High

• **Status:** Missing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Api/Middleware/CertificateForwardingGuard.cs` (IP-set membership check only) CODE-OBSERVED; docs/formal-specification/04-SOFTWARE-DESIGN.md P-2 ("header trusted unconditionally at baseline") DOCUMENTED.

• **Approval:** Review Required

## SR-S.006 - EST rate limiting

• **ID:** SR-S.006

• **Requirement:** The gateway shall rate-limit device-facing EST endpoints per client IP by default, shall return HTTP 429 when the limit is exceeded, and shall make the limits configurable; the production limits are `TBD` (recommendation: retain the configured 100 requests/minute on `*:/.well-known/est/*` as the development default and set production values with OR.NET).

• **Rationale:** Device-facing endpoints are exposed to the hospital network and must tolerate abusive traffic.

• **Source:** KSPEC-002 UR-014 (Medium); docs/ARCHITECTURE.md (rate limiting).

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** Medium

• **Status:** Existing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Api/Program.cs` (UseIpRateLimiting, AspNetCoreRateLimit registration) CODE-OBSERVED; `src/RTSec.Kryptonian.Api/appsettings.json` (IpRateLimiting rules) CODE-OBSERVED; docs/ARCHITECTURE.md DOCUMENTED.

• **AS-IS detail:** Specific rules additionally specify 30 requests/minute for `POST:/.well-known/est/*/simpleenroll` and `POST:/.well-known/est/*/simplereenroll`. Effective matching on unlabeled paths has not been demonstrated by this review. Configuration is `IpRateLimiting`, not the similarly named `Kryptonian:RateLimiting` section.

• **Approval:** Review Required

## SR-S.007 - No hard-coded signing secrets in production

• **ID:** SR-S.007

• **Requirement:** The gateway shall obtain the JWT signing secret from configuration in every environment, shall fail fast at startup in Production when it is absent or set to a known development default, and shall never embed a hard-coded secret value in the application.

• **Rationale:** A hard-coded fallback signing key allows any party with the source to forge administrator tokens.

• **Source:** Baseline finding: `Program.cs` falls back to the hard-coded string `kryptonian-dev-secret-not-for-production-32chars` (KSPEC-005 finding 5); KSPEC-002 UR-013.

• **Classification:** TO-BE (hardening of an AS-IS weak control; the hard-coded fallback must be removed).

• **Priority:** Critical

• **Status:** Missing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Api/Program.cs` (jwtSecret fallback constant, lines ~177-183) CODE-OBSERVED; docs/formal-specification/05-INTERFACE-CONTROL.md (ICD-CFG.002 finding) DOCUMENTED.

• **Approval:** Review Required

## SR-S.008 - Secrets at rest

• **ID:** SR-S.008

• **Requirement:** The gateway shall encrypt at rest all sensitive credential fields it persists (connector credentials, SMTP passwords, CA key passwords), using a key-protected mechanism; the encryption/key-ring approach is `TBD` pending platform decision.

• **Rationale:** Database-level access must not expose institutional PKI credentials in plaintext.

• **Source:** KSPEC-002 UR-013 (Missing); KSPEC-004 data-design context.

• **Classification:** TO-BE (not implemented at baseline for most credential fields).

• **Priority:** High

• **Status:** Missing

• **Verification:** I

• **Evidence:** `src/RTSec.Kryptonian.Infrastructure/Data/KryptonianDbContext.cs` CODE-OBSERVED; `src/RTSec.Kryptonian.Infrastructure/Security/DataProtectionService.cs` CODE-OBSERVED (protection

service exists but field coverage not evidenced); docs/IMPLEMENTATION-TRACKER.md (environment/plain-config storage) DOCUMENTED.

• **Approval:** Review Required

## SR-S.009 - Password hashing

• **ID:** SR-S.009

• **Requirement:** The gateway shall store administrator password verifications only as salted adaptive hashes (BCrypt or an equivalent work-factor algorithm, cost factor ≥ 12) and shall never store plaintext passwords.

• **Rationale:** Credential database exposure must not yield usable passwords.

• **Source:** KSPEC-002 UR-015; plans/user-management.md (BCrypt cost 12).

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** Critical

• **Status:** Existing

• **Verification:** I

• **Evidence:** BCrypt.Net-Next dependency in `src/RTSec.Kryptonian.Api/RTSec.Kryptonian.Api.csproj` CODE-OBSERVED; `src/RTSec.Kryptonian.Application/Services/AuthService.cs` and `UserService.cs` CODE-OBSERVED; plans/user-management.md DOCUMENTED.

• **Approval:** Review Required

## SR-S.010 - Data Protection key ring management

• **ID:** SR-S.010

• **Requirement:** The gateway shall configure the ASP.NET Core Data Protection key ring for persistent, deployment-appropriate storage in every deployment mode, and shall fail closed (refuse to start or degrade explicitly) where persisted key state is incomplete.

• **Rationale:** Ephemeral or inaccessible key rings silently invalidate protected data across restarts.

• **Source:** Sandbox behavior (keys persisted to data directory); docs/windows-installation.md (incomplete key state deliberately fails closed).

• **Classification:** TO-BE (elaborates AS-IS behavior; non-sandbox production key-ring persistence policy not evidenced - UNKNOWN).

• **Priority:** High

• **Status:** Partial

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Api/Program.cs` (AddDataProtection, PersistKeysToFileSystem for sandbox) CODE-OBSERVED; `src/RTSec.Kryptonian.Infrastructure/Security/DataProtectionService.cs` CODE-OBSERVED; artifacts/windows-installer/payload/docs/windows-installation.md DOCUMENTED.

• **Approval:** Review Required

## SR-S.011 - Device private key non-archival

• **ID:** SR-S.011

• **Requirement:** The gateway shall not archive device private keys, and any legacy schema field capable of holding an archived private key shall either be removed or restricted to explicitly approved server-side-key-generation profiles; the policy decision is `TBD` pending stakeholder approval.

• **Rationale:** Gateway-held device private keys would allow credential impersonation if the gateway is compromised.

• **Source:** KSPEC-004 data-design finding A-2 (EncryptedPrivateKeyPem field, policy undefined); KSPEC-002 UR-013 rationale.

• **Classification:** PROPOSED (policy decision requiring approval).

• **Priority:** High

• **Status:** Proposed

• **Verification:** I

• **Evidence:** `src/RTSec.Kryptonian.Domain/Entities/` (Certificate entity `EncryptedPrivateKeyPem` field) CODE-OBSERVED; docs/formal-specification/04-SOFTWARE-DESIGN.md A-2 DOCUMENTED.

• **Approval:** Review Required

## SR-S.012 - Configurable CRL lifetime

• **ID:** SR-S.012

• **Requirement:** The gateway shall derive the CRL lifetime and next-update time for gateway-generated CRLs from configurable policy chosen for outage tolerance and revocation objectives, rather than a fixed demonstration value.

• **Rationale:** The 60-second prototype CRL lifetime encodes demo assumptions, not institutional revocation policy.

• **Source:** KSPEC-004 AS-IS finding A-4 (hard-coded 60-second CRL lifetime); KSPEC-002 UR-010.

• **Classification:** TO-BE (hardening of an AS-IS weak control).

• **Priority:** High

• **Status:** Missing

• **Verification:** T

• **Evidence:** Self-signed connector/CRL generation (60 s lifetime) CODE-OBSERVED in `src/RTSec.Kryptonian.Infrastructure/Crypto/SelfSignedCaConnector.cs` and CRL issuance path; docs/formal-specification/04-SOFTWARE-DESIGN.md A-4 DOCUMENTED.

• **Approval:** Review Required

## SR-S.013 - CORS restriction for the admin UI

• **ID:** SR-S.013

• **Requirement:** The gateway shall restrict cross-origin browser access to explicitly configured origins and shall deny all other origins.

• **Rationale:** Unrestricted CORS would expose authenticated admin sessions to malicious sites.

• **Source:** docs/ARCHITECTURE.md (CORS); KSPEC-002 UR-015.

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** Medium

• **Status:** Existing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Api/Program.cs` (KryptonianUi CORS policy from `Kryptonian:Ui:AllowedOrigins`) CODE-OBSERVED; `src/RTSec.Kryptonian.Api/appsettings.json` CODE-OBSERVED.

• **Approval:** Review Required

### SR-S.014 - Dependency vulnerability management

• **ID:** SR-S.014

• **Requirement:** The project's continuous integration shall fail on high or critical advisories in UI dependencies, and the project shall track and disclose remaining transitive advisories as deployment blockers until resolved by a tested update.

• **Rationale:** Known-vulnerable dependencies (SQLitePCLRaw.lib.e_sqlite3 2.1.6; System.Security.Cryptography.Xml 8.0.2 at baseline) are deployment blockers requiring a tested update, and audit disclosure must remain honest.

• **Source:** PR 52 (dependency security updates and audit disclosure); docs/IMPLEMENTATION-TRACKER.md (remaining high advisories).

• **Classification:** TO-BE (elaborates AS-IS behavior; whole-system audit still outstanding).

• **Priority:** High

• **Status:** Partial

• **Verification:** T

• **Evidence:** `.github/workflows/` (CI advisory gate) CODE-OBSERVED; docs/IMPLEMENTATION-TRACKER.md (npm audit reduced to zero; remaining transitive high advisories) DOCUMENTED.

• **Approval:** Review Required

## 10. Authentication requirements (SR-A)

### SR-A.001 - Dual-scheme admin authentication

• **ID:** SR-A.001

• **Requirement:** The gateway shall authenticate administrative API requests using either JWT bearer tokens (browser sessions) or the `X-API-Key` header (scripted clients), selected per request, and shall reject unauthenticated administrative requests with HTTP 401.

• **Rationale:** Browser and automation clients have different operational needs; both must pass the same authorization layer.

• **Source:** KSPEC-002 UR-015, UR-027; docs/API-GUIDE.md.

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** Critical

• **Status:** Existing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Api/Program.cs` (PolicyScheme forwarding, JWT + ApiKey schemes) CODE-OBSERVED; `src/RTSec.Kryptonian.Api/Authentication/ApiKeyAuthenticationHandler.cs` CODE-OBSERVED.

• **Approval:** Review Required

## SR-A.002 - JWT token validation

• **ID:** SR-A.002

• **Requirement:** The gateway shall validate JWT issuer, audience, lifetime, and signing key on every bearer-authenticated request, shall use a session lifetime configurable with a default of 8 hours and a 5-minute clock skew, and shall reject invalid or expired tokens.

• **Rationale:** Token validation parameters are the session-security boundary for the admin UI.

• **Source:** docs/user-management.md (8-hour sessions); `JwtLifetimeHours` configuration.

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** Critical

• **Status:** Existing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Api/Program.cs` (TokenValidationParameters, ClockSkew) CODE-OBSERVED; docs/user-management.md DOCUMENTED; 8-hour default DOCUMENTED per docs/formal-specification/05-INTERFACE-CONTROL.md.

• **Approval:** Review Required

## SR-A.003 - API key storage and validation

• **ID:** SR-A.003

• **Requirement:** The gateway shall validate database-stored API keys by one-way hash comparison, shall accept a key only when it is unrevoked, unexpired, and owned by an active user, and shall update last-used information on successful use.

• **Rationale:** Bearer keys must be revocable and bound to active accounts.

• **Source:** KSPEC-002 UR-027; docs/user-management.md.

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** Critical

• **Status:** Existing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Api/Authentication/ApiKeyAuthenticationHandler.cs` (SHA-256 hash lookup, RevokedAt/ExpiresAt/IsActive checks, LastUsedAt update) CODE-OBSERVED.

• **Approval:** Review Required

## SR-A.004 - Static compatibility API keys

• **ID:** SR-A.004

• **Requirement:** The gateway shall continue to accept statically configured API keys (`KRYPTONIAN__ADMINAPI__APIKEYS`) as SystemAdmin for backward compatibility, shall treat them as a legacy mechanism, and shall document migration toward user-generated keys.

• **Rationale:** Existing automation must keep working during migration to per-user keys.

• **Source:** docs/user-management.md (legacy static keys); plans/user-management.md.

• **Classification:** TO-BE (compatibility retention with documented migration path).

• **Priority:** Medium

• **Status:** Existing

• **Verification:** I

• **Evidence:** `ApiKeyAuthenticationHandler.cs` static configuration key validation CODE-OBSERVED; migration plan DOCUMENTED in docs/user-management.md.

• **Approval:** Review Required

## SR-A.005 - API keys carry the owner's role at generation

• **ID:** SR-A.005

• **Requirement:** The gateway shall give an API key the role of its generating user at generation time, so that a key generated by a DeviceAdmin continues to act as DeviceAdmin even if the owner's role later changes.

• **Rationale:** Makes the effective privilege of each key deterministic and auditable.

• **Source:** docs/user-management.md (Keys carry the role of their owner at the time of generation).

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** Medium

• **Status:** Existing

• **Verification:** D

• **Evidence:** `src/RTSec.Kryptonian.Api/Authentication/ApiKeyAuthenticationHandler.cs` (role from ApiKey record) CODE-OBSERVED; docs/user-management.md DOCUMENTED.

• **Approval:** Review Required

## SR-A.006 - JWT signing secret provisioning

• **ID:** SR-A.006

• **Requirement:** The gateway shall require an operator-supplied JWT signing secret of at least 32 characters in non-development environments and shall refuse to start (fail fast) when it is missing or matches a known development default.

• **Rationale:** The signing secret is the root of admin-session trust; silent fallback is a forgery vector.

• **Source:** Baseline finding (hard-coded dev fallback in `Program.cs`); KSPEC-002 UR-013; plans/user-management.md (≥32 chars; "dev fallback constant with warning").

• **Classification:** TO-BE (not satisfied at baseline).

• **Priority:** Critical

• **Status:** Missing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Api/Program.cs` (fallback constant; no fail-fast check) CODE-OBSERVED; plans/user-management.md DOCUMENTED.

• **Approval:** Review Required

## SR-A.007 - EST bootstrap challenge behavior

• **ID:** SR-A.007

• **Requirement:** The gateway shall respond with HTTP 401 and a `WWW-Authenticate: Basic` challenge header when EST bootstrap credentials are absent or invalid, distinguishing missing credentials from rejected credentials.

• **Rationale:** Correct challenge semantics let standard clients and developers diagnose authentication failures.

• **Source:** KSPEC-002 UR-023; PR 42.

• **Classification:** TO-BE (normative statement of AS-IS behavior).

• **Priority:** Medium

• **Status:** Existing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Api/Controllers/EstController.cs` (BasicUnauthorized with WWW-Authenticate) CODE-OBSERVED; docs/formal-specification/05-INTERFACE-CONTROL.md (401 challenge row) DOCUMENTED.

• **Approval:** Review Required

## SR-A.008 - EST re-enrollment credential rule

• **ID:** SR-A.008

• **Requirement:** The gateway shall authenticate `simplereenroll` exclusively by the presented TLS client certificate, validated per SR-F-EST.009, and shall not accept any header- or body-supplied device identity as authentication evidence.

• **Rationale:** Header-supplied identity is spoofable; certificate possession is the only non-replayable renewal credential.

• **Source:** PR 38 (authenticated enrollment identity binding); EstController device-identifier rule (header logged but untrusted).

• **Classification:** TO-BE (normative statement of AS-IS behavior).

• **Priority:** Critical

• **Status:** Existing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Api/Controllers/EstController.cs` (GetDeviceIdentifier returns null for header; certificate subject used) CODE-OBSERVED.

• **Approval:** Review Required

## SR-A.009 - Development bypass confinement

• **ID:** SR-A.009

• **Requirement:** The gateway shall permit anonymous API-key bypass authentication only in the Development environment and only when no static API keys are configured, and shall never activate it in Production.

• **Rationale:** A development bypass must be structurally incapable of leaking into production.

• **Source:** ApiKeyAuthenticationHandler bypass gating; KSPEC-002 UR-015.

• **Classification:** TO-BE (normative statement of AS-IS behavior).

• **Priority:** High

• **Status:** Existing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Api/Authentication/ApiKeyAuthenticationHandler.cs` (bypass requires AllowAnonymousInDevelopment && no static keys && Development) CODE-OBSERVED.

• **Approval:** Review Required

### SR-A.010 - Login credential rejection without enumeration

• **ID:** SR-A.010

• **Requirement:** The gateway shall respond to failed portal login attempts with a generic authentication-failure response that does not reveal whether the username exists.

• **Rationale:** Account enumeration simplifies targeted attacks on administrative accounts.

• **Source:** docs/user-management.md (login); KSPEC-006 threat model input.

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** Medium

• **Status:** Existing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Api/Controllers/AuthController.cs` (uniform "Invalid username or password.") CODE-OBSERVED.

• **Approval:** Review Required

## 11. Authorization requirements (SR-Z)

### SR-Z.001 - Role model

• **ID:** SR-Z.001

• **Requirement:** The gateway shall enforce role-based access control with at least three roles - read-only (Standard), device administration (DeviceAdmin), and full system administration (SystemAdmin) - mapped to claims carried by both JWT and API-key identities.

• **Rationale:** Least-privilege separation of operational duties (view vs. device ops vs. system configuration).

• **Source:** KSPEC-002 UR-015 (Critical); docs/user-management.md (Roles).

• **Classification:** TO-BE (normative statement of AS-IS behavior).

• **Priority:** Critical

• **Status:** Existing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Domain/Enums/UserRole.cs` (Standard, DeviceAdmin, SystemAdmin) CODE-OBSERVED; `src/RTSec.Kryptonian.Api/Program.cs` (StandardOrAbove, DeviceAdmin, SystemAdmin policies) CODE-OBSERVED.

• **Approval:** Review Required

### SR-Z.002 - Device administration restricted to DeviceAdmin and above

• **ID:** SR-Z.002

• **Requirement:** The gateway shall restrict device-creation, approval, trust modification, retirement, and demo-enrollment operations to callers holding DeviceAdmin or SystemAdmin roles.

• **Rationale:** Device operations change the trust state of the estate and must not be available to read-only callers.

• **Source:** KSPEC-002 UR-015 (UC-08).

• **Classification:** TO-BE (normative statement of AS-IS behavior).

• **Priority:** Critical

• **Status:** Existing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Api/Controllers/DevicesController.cs` (DeviceAdmin policies on mutating endpoints) CODE-OBSERVED; `src/RTSec.Kryptonian.Api/Controllers/CertificatesController.cs` (controller-level DeviceAdmin policy) CODE-OBSERVED.

• **Approval:** Review Required

## SR-Z.003 - System configuration restricted to SystemAdmin

• **ID:** SR-Z.003

• **Requirement:** The gateway shall restrict CA backend configuration, EST profile configuration, user administration, notification settings, and gateway settings modification to callers holding the SystemAdmin role.

• **Rationale:** Institution-wide policy and credential configuration demand the highest-privilege role.

• **Source:** KSPEC-002 UR-015; docs/user-management.md (SystemAdmin-only sections).

• **Classification:** TO-BE (normative statement of AS-IS behavior).

• **Priority:** Critical

• **Status:** Existing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Api/Controllers/CaBackendsController.cs`, `EstProfilesController.cs`, `UsersController.cs`, `NotificationSettingsController.cs`, `GatewaySettingsController.cs` (SystemAdmin policies on mutations) CODE-OBSERVED.

• **Approval:** Review Required

## SR-Z.004 - Read-only access for Standard role

• **ID:** SR-Z.004

• **Requirement:** The gateway shall permit Standard-role (and above) authenticated callers to access read-only inventory, status, and log endpoints, and shall deny them all mutating operations.

• **Rationale:** Audit and monitoring users need visibility without write power.

• **Source:** KSPEC-002 UR-015; `StandardOrAbove` policy.

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** High

• **Status:** Existing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Api/Program.cs` (StandardOrAbove policy) CODE-OBSERVED; controller-level `[Authorize]` on read endpoints CODE-OBSERVED.

• **Approval:** Review Required

### SR-Z.005 - Revocation restricted to device administrators

• **ID:** SR-Z.005

• **Requirement:** The gateway shall restrict certificate revocation and trust-removal operations to callers holding DeviceAdmin or SystemAdmin roles.

• **Rationale:** Revocation is a high-impact trust decision; it must not be performable by read-only callers.

• **Source:** KSPEC-002 UR-009, UR-010; docs/flow.md (Trust Removal Flow).

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** Critical

• **Status:** Existing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Api/Controllers/CertificatesController.cs` (DeviceAdmin policy) CODE-OBSERVED; `src/RTSec.Kryptonian.Api/Controllers/DevicesController.cs` (trust endpoints under DeviceAdmin) CODE-OBSERVED.

• **Approval:** Review Required

### SR-Z.006 - API-key requests inherit role claims

• **ID:** SR-Z.006

• **Requirement:** The gateway shall derive authorization claims for API-key-authenticated requests solely from the authenticated key record and its stored role, and shall not accept role claims supplied by the client.

• **Rationale:** Client-supplied role claims would enable trivial privilege escalation.

• **Source:** ApiKeyAuthenticationHandler (role from record); KSPEC-002 UR-027.

• **Classification:** TO-BE (normative statement of AS-IS behavior).

• **Priority:** Critical

• **Status:** Existing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Api/Authentication/ApiKeyAuthenticationHandler.cs` (BuildTicket role from apiKey record; no client claim ingestion) CODE-OBSERVED.

• **Approval:** Review Required

### SR-Z.007 - Explicit role policy on every mutating endpoint

• **ID:** SR-Z.007

• **Requirement:** The gateway shall enforce an explicit role policy (DeviceAdmin or SystemAdmin) on every state-changing administrative endpoint, including backend connectivity-test operations, rather than relying on authentication alone.

• **Rationale:** The backend test endpoint performs credential-bearing calls and is authentication-only at baseline; authentication without role policy is a weak control.

• **Source:** Baseline finding: `POST /api/cas/{id}/test` lacks a DeviceAdmin/SystemAdmin policy (KSPEC-005 open item 4).

• **Classification:** TO-BE (hardening of an AS-IS weak control).

• **Priority:** High

• **Status:** Partial

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Api/Controllers/CaBackendsController.cs` (test endpoint `[Authorize]` without policy; SystemAdmin on configuration endpoints) CODE-OBSERVED; docs/formal-specification/05-INTERFACE-CONTROL.md open items DOCUMENTED.

• **Approval:** Review Required

## SR-Z.008 - Anonymous access limited to a documented set

• **ID:** SR-Z.008

• **Requirement:** The gateway shall restrict unauthenticated access to the documented set of endpoints - health check, self-service device approval request, EST protocol handlers, ACME challenge path, issuer CRL GET, authentication status/setup/login/logout handlers, and dashboard static assets - and shall require authentication on protected administrative endpoints; EST handlers shall enforce their own bootstrap or client-certificate authentication.

• **Rationale:** A complete anonymous-surface inventory is the precondition for perimeter reasoning.

• **Source:** Controller authorization attributes survey; KSPEC-005 open item 6.

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** High

• **Status:** Existing

• **Verification:** I

• **Evidence:** `src/RTSec.Kryptonian.Api/Controllers/` ([Authorize] coverage; explicit [AllowAnonymous] on device-requests; absence of [Authorize] on Auth/EST/CRL/challenge handlers) CODE-OBSERVED; `src/RTSec.Kryptonian.Api/Program.cs` (unauthenticated health map) CODE-OBSERVED.

• **Approval:** Review Required

## SR-Z.009 - Confirmed authorization model for self-service requests

• **ID:** SR-Z.009

• **Requirement:** The stakeholder-approved authorization model for the anonymous self-service device approval-request endpoint (who may call it, from where, and with what abuse controls) shall be recorded in this specification after review; the baseline intent (anonymous by design, pending-only creation) is `TBD` for confirmation.

• **Rationale:** The endpoint is a deliberate anonymous surface whose intended authorization model has not been stakeholder-confirmed.

• **Source:** KSPEC-005 open item 6; docs/formal-specification/05-INTERFACE-CONTROL.md.

• **Classification:** PROPOSED (stakeholder decision required).

• **Priority:** Medium

• **Status:** Proposed

• **Verification:** I

• **Evidence:** `src/RTSec.Kryptonian.Api/Controllers/DevicesController.cs` (RequestApproval [AllowAnonymous]) CODE-OBSERVED; docs/formal-specification/05-INTERFACE-CONTROL.md (open item) DOCUMENTED.

• **Approval:** Review Required

### SR-Z.010 - No clinical capability derivation

• **ID:** SR-Z.010

• **Requirement:** No gateway state, role, certificate, or authorization decision shall be presented as, or shall be interpretable as, a device's clinical service status, clinical capability, SDC role authorization, or regulatory status.

• **Rationale:** Preserves the identity/capability boundary that is binding for the whole package (KSPEC-000 §3).

• **Source:** KSPEC-002 UR-026 (Critical); EXC-001/EXC-002.

• **Classification:** TO-BE (governing constraint).

• **Priority:** Critical

• **Status:** Existing

• **Verification:** I

• **Evidence:** docs/CHANGES-AND-ORNET-ALIGNMENT.md (renewal ≠ recertification); README.md disclaimer; docs/formal-specification/04-SOFTWARE-DESIGN.md (boundary) DOCUMENTED.

• **Approval:** Review Required

## 12. Certificate lifecycle policy requirements (SR-C)

### SR-C.001 - Profile policy bundle

• **ID:** SR-C.001

• **Requirement:** The gateway shall bind each EST profile to a named policy bundle containing a CA backend binding, subject-DN rules, key usage and EKU constraints, certificate validity, and trust policy, and shall enforce that bundle on every enrollment through the profile.

• **Rationale:** Certificate policy must be administratively controlled by the institution, not hard-coded or implied.

• **Source:** KSPEC-002 UR-031 (Critical); KSPEC-000 §9 (EST profile terminology).

• **Classification:** TO-BE (normative statement of AS-IS behavior).

• **Priority:** Critical

• **Status:** Existing

• **Verification:** I

• **Evidence:** `src/RTSec.Kryptonian.Domain/Entities/EstProfile.cs` and `src/RTSec.Kryptonian.Application/DTOs/EstProfileDto.cs` CODE-OBSERVED; docs/ca-backend-configuration.md DOCUMENTED.

• **Approval:** Review Required

### SR-C.002 - Trust policy durability across restarts and updates

• **ID:** SR-C.002

• **Requirement:** The gateway shall persist EST profile trust policy across restarts and shall apply trust-list changes additively, preserving omitted trust lists on partial updates.

• **Rationale:** Loss or silent narrowing of trust policy on restart or update would break enrolled devices unpredictably.

• **Source:** KSPEC-002 UR-032; PR 41, PR 47.

• **Classification:** TO-BE (normative statement of AS-IS behavior).

• **Priority:** High

• **Status:** Existing

• **Verification:** T

• **Evidence:** docs/IMPLEMENTATION-TRACKER.md (restart persistence on populated SQLite VERIFIED; partial-update preservation PR 47); `src/RTSec.Kryptonian.Infrastructure/Data/SchemaUpgrades.cs` CODE-OBSERVED.

• **Approval:** Review Required

## SR-C.003 - Profile-configured validity periods

• **ID:** SR-C.003

• **Requirement:** The gateway shall derive certificate validity periods from the EST profile configuration, and the production certificate-lifetime policy (balancing outage tolerance against revocation objectives) is `TBD` pending institutional decision (KSPEC-001 TBD-001).

• **Rationale:** Lifetime is a security policy trade-off, not a code constant.

• **Source:** KSPEC-002 UR-031; TBD-001.

• **Classification:** TO-BE (elaborates AS-IS behavior; production values TBD).

• **Priority:** High

• **Status:** Existing

• **Verification:** I

• **Evidence:** `src/RTSec.Kryptonian.Application/DTOs/EstProfileDto.cs` (validity fields) CODE-OBSERVED; docs/ca-backend-configuration.md DOCUMENTED.

• **Approval:** Review Required

## SR-C.004 - Renewal window authorization

• **ID:** SR-C.004

• **Requirement:** The gateway shall authorize re-enrollment without re-approval only for devices that are active, unrevoked, and presenting a valid credential issued under the resolved profile.

• **Rationale:** The renewal window must not become a path for unapproved identity changes.

• **Source:** KSPEC-002 UR-021; KSPEC-000 §9 (Renewal window).

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** Critical

• **Status:** Existing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Application/Services/EnrollmentOrchestrator.cs` (reenroll validation) CODE-OBSERVED; docs/device-enrollment.md (Renewal And Future Signing) DOCUMENTED.

• **Approval:** Review Required

## SR-C.005 - Issuer-scoped CRL publication

• **ID:** SR-C.005

• **Requirement:** The gateway shall publish gateway-generated CRLs scoped to the issuing CA and shall record CRL state (issue time, next update) per issuer so that peers retrieve the CRL matching the issuer of each certificate.

• **Rationale:** An issuer-unscoped CRL could misstate revocation status for credentials from other issuers.

• **Source:** PR 46 (issuer-scoped signed CRLs); KSPEC-002 UR-010.

• **Classification:** TO-BE (normative statement of AS-IS behavior).

• **Priority:** High

• **Status:** Existing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Domain/Entities/IssuerCrlState.cs` and `src/RTSec.Kryptonian.Infrastructure/Repositories/IssuerCrlStateRepository.cs` CODE-OBSERVED; `src/RTSec.Kryptonian.Api/Controllers/CrlController.cs` CODE-OBSERVED.

• **Approval:** Review Required

## SR-C.006 - CRL distribution points on issued certificates

• **ID:** SR-C.006

• **Requirement:** The gateway shall include a CRL distribution point extension in issued device certificates pointing at the gateway's CRL publication endpoint for the issuing CA.

• **Rationale:** Peers can only check revocation online if issued certificates carry a reachable distribution point.

• **Source:** PR 46 (CRL distribution points); KSPEC-002 UR-010.

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** High

• **Status:** Existing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Infrastructure/Crypto/SelfSignedCaConnector.cs` and CRL issuance path CODE-OBSERVED; docs/CHANGES-AND-ORNET-ALIGNMENT.md PR 46 row DOCUMENTED.

• **Approval:** Review Required

## SR-C.007 - Online revocation checking at peers

• **ID:** SR-C.007

• **Requirement:** Reference peers and the demonstration components shall validate revocation status online through the gateway-published CRL path, rejecting revoked certificates independently of any local registry lookup.

• **Rationale:** A revoked credential is worthless if peers do not check the published revocation data.

• **Source:** PR 45 (explicit EST client trust and online revocation); docs/IMPLEMENTATION-TRACKER.md.

• **Classification:** AS-IS (reference-client behavior; demonstration-scoped).

• **Priority:** High

• **Status:** Existing

• **Verification:** D

• **Evidence:** docs/IMPLEMENTATION-TRACKER.md (administrator revocation followed by native online X509Chain reporting Revoked, independent of registry lookup) VERIFIED; `src/Kryptonian.DICOMTls/` CODE-OBSERVED.

• **Approval:** Review Required

## SR-C.008 - Revocation propagation semantics

• **ID:** SR-C.008

• **Requirement:** The system shall state explicitly that revocation propagation to established sessions is bounded (peers refresh CRL data on a timer and associations have bounded lifetimes), and no requirement shall promise instant mid-association termination; the stale-revocation-data policy is `TBD` pending stakeholder agreement.

• **Rationale:** Honest propagation semantics prevent operators from assuming instantaneous enforcement that does not exist.

• **Source:** EXC-007; KSPEC-004 AS-IS finding A-5; docs/IMPLEMENTATION-TRACKER.md (bounded proxy lifetimes).

• **Classification:** TO-BE (normative statement; AS-IS bounded behavior to be made explicit).

• **Priority:** Medium

• **Status:** Partial

• **Verification:** A

• **Evidence:** docs/development.md (associations have a bounded lifetime) DOCUMENTED; docs/IMPLEMENTATION-TRACKER.md DOCUMENTED; stale-revocation policy undefined UNKNOWN.

• **Approval:** Review Required

## SR-C.009 - Separation of revocation and enrollment denial

• **ID:** SR-C.009

• **Requirement:** The gateway shall treat administrative revocation of a device's certificate and removal of the device's trust as separable operations, each individually recorded, and shall not conflate their outcomes.

• **Rationale:** "Deny further enrollment" and "peers reject an issued certificate" are distinct security effects with distinct audit needs.

• **Source:** PR 46 (separates deny-further-enrollment from peer rejection); KSPEC-002 UR-009/UR-010.

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** High

• **Status:** Existing

• **Verification:** I

• **Evidence:** `src/RTSec.Kryptonian.Application/Services/CertificateRevocationService.cs` and `EnrollmentOrchestrator.cs` CODE-OBSERVED; docs/CHANGES-AND-ORNET-ALIGNMENT.md PR 46 row DOCUMENTED.

• **Approval:** Review Required

## SR-C.010 - Enrollment event record per issuance attempt

• **ID:** SR-C.010

• **Requirement:** The gateway shall record an enrollment event for every enrollment, renewal, and revocation attempt, capturing the outcome, the issued certificate serial or error message, and the requester source address.

• **Rationale:** Lifecycle forensics and renewal monitoring both depend on complete per-attempt records.

• **Source:** KSPEC-002 UR-011; KSPEC-000 §9 (Enrollment event).

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** High

• **Status:** Partial

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Application/Services/EnrollmentEventService.cs` CODE-OBSERVED; `src/RTSec.Kryptonian.Application/DTOs/EnrollmentEventDto.cs` CODE-OBSERVED; docs/flow.md DOCUMENTED.

• **AS-IS limitation:** Some orchestrator failures return before event creation; controller authentication/media/size failures and revocation service paths do not create EnrollmentEvent records. Complete per-attempt lifecycle audit coverage is not implemented. VT-059 specifies the missing acceptance test.

• **Approval:** Review Required

# 13. Data management requirements (SR-D)

## SR-D.001 - Durable persistence of all configured state

• **ID:** SR-D.001

• **Requirement:** The gateway shall persist all configured state - devices, certificates, EST profiles, CA backends, trust policy, users, API keys, and notification settings - durably so that a gateway restart preserves the configuration and records.

• **Rationale:** Configuration loss across restarts would silently revoke operational trust state.

• **Source:** KSPEC-002 UR-037; PR 41.

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** High

• **Status:** Existing

• **Verification:** T

• **Evidence:** docs/IMPLEMENTATION-TRACKER.md (gateway restart on populated SQLite preserved configured profile, issuer and devices) VERIFIED; `src/RTSec.Kryptonian.Infrastructure/Data/KryptonianDbContext.cs` CODE-OBSERVED.

• **Approval:** Review Required

## SR-D.002 - SQLite and PostgreSQL persistence support

• **ID:** SR-D.002

• **Requirement:** The gateway shall support both an embeddable persistence option (SQLite) and a server-grade persistence option (PostgreSQL) selectable by configuration.

• **Rationale:** Hospitals need an embeddable option for small sites and a server-grade option for production estates.

• **Source:** KSPEC-002 UR-037; docs/DEPLOYMENT.md; TBD-006.

• **Classification:** TO-BE (elaborates AS-IS behavior; PostgreSQL exercised: UNKNOWN).

• **Priority:** High

• **Status:** Partial

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Infrastructure/Data/` (Npgsql and Sqlite providers) CODE-OBSERVED; SQLite persistence VERIFIED per docs/IMPLEMENTATION-TRACKER.md; PostgreSQL unexercised UNKNOWN.

• **Approval:** Review Required

### SR-D.003 - Additive schema upgrades that never recreate data

• **ID:** SR-D.003

• **Requirement:** The gateway shall apply schema upgrades additively and idempotently (adding columns, tables, and indexes; never dropping or recreating), and shall never recreate a populated database.

• **Rationale:** Recreating a populated database would destroy live trust state.

• **Source:** `SchemaUpgrades.cs` header rule ("keep this additive: never recreate a populated database"); PR 41.

• **Classification:** TO-BE (normative statement of AS-IS behavior).

• **Priority:** High

• **Status:** Existing

• **Verification:** I

• **Evidence:** `src/RTSec.Kryptonian.Infrastructure/Data/SchemaUpgrades.cs` (additive DDL shapes, header comment) CODE-OBSERVED; docs/formal-specification/07-OPERATIONAL-RISK.md DOCUMENTED.

• **Approval:** Review Required

### SR-D.004 - Upgrade safety boundary

• **ID:** SR-D.004

• **Requirement:** The gateway shall execute schema upgrades within an explicit safety boundary - a pre-upgrade backup and an explicit upgrade transaction - before applying additive DDL to an existing database.

• **Rationale:** Baseline upgrades run as raw DDL outside an explicit transaction/backup boundary; a mid-upgrade failure could leave an inconsistent schema.

• **Source:** KSPEC-010 gap input (upgrade DDL outside explicit transaction/backup boundary, per KSPEC-007 §backup).

• **Classification:** TO-BE (hardening of an AS-IS weak control).

• **Priority:** High

• **Status:** Missing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Infrastructure/Data/SchemaUpgrades.cs` (raw additive DDL) CODE-OBSERVED; docs/formal-specification/07-OPERATIONAL-RISK.md (restore sequence places SchemaUpgrades after restore) DOCUMENTED.

• **Approval:** Review Required

### SR-D.005 - UTC timestamp discipline

• **ID:** SR-D.005

• **Requirement:** The gateway shall store and compute all certificate and revocation timestamps as UTC end-to-end, including round-trips through the database, so that no reload path shifts times across time zones.

• **Rationale:** An unspecified DateTime kind shifted refreshed CRL revocation times five hours into the future on one host; such shifts silently corrupt revocation semantics.

- **Source:** docs/IMPLEMENTATION-TRACKER.md (SQLite DateTime-kind bug fixed with a runnable regression).
- **Classification:** TO-BE (normative statement of AS-IS behavior after fix).
- **Priority:** High
- **Status:** Existing
- **Verification:** T
- **Evidence:** docs/IMPLEMENTATION-TRACKER.md (fix with runnable regression) VERIFIED; `src/RTSec.Kryptonian.Infrastructure/Data/` DateTime handling CODE-OBSERVED.
- **Approval:** Review Required

## SR-D.006 - Lifecycle record retention

- **ID:** SR-D.006
- **Requirement:** The gateway shall retain enrollment events and certificate records for a configurable retention period sufficient for audit reconstruction; the production retention period is `TBD` pending institutional retention policy.
- **Rationale:** Retention governs how far incident reconstruction can reach; unbounded or accidental deletion both fail audits.
- **Source:** KSPEC-002 UR-011; KSPEC-007 (audit scenarios).
- **Classification:** TO-BE (retention policy not implemented at baseline).
- **Priority:** Medium
- **Status:** Partial
- **Verification:** I
- **Evidence:** `EnrollmentEventRepository.cs` retention policy not enforced CODE-OBSERVED; production retention period TBD.
- **Approval:** Review Required

## SR-D.007 - Protected-data key persistence

- **ID:** SR-D.007
- **Requirement:** The gateway shall persist the Data Protection key ring to a durable, deployment-configured location in every production deployment mode, and shall document key-ring backup/restore as part of the recovery procedure.
- **Rationale:** Protected fields become unreadable if the key ring is lost; sandbox persistence exists but general production persistence is not evidenced.
- **Source:** `Program.cs` sandbox key-ring persistence; docs/formal-specification/07-OPERATIONAL-RISK.md (restore Data Protection key ring first).
- **Classification:** TO-BE (elaborates AS-IS behavior; production persistence policy UNKNOWN).
- **Priority:** High
- **Status:** Partial
- **Verification:** T
- **Evidence:** `src/RTSec.Kryptonian.Api/Program.cs` (PersistKeysToFileSystem under sandbox only) CODE-OBSERVED; docs/formal-specification/07-OPERATIONAL-RISK.md (key ring first in restore order) DOCUMENTED.
- **Approval:** Review Required

### SR-D.008 - Sensitive field encryption at rest

• **ID:** SR-D.008

• **Requirement:** The gateway shall apply field-level encryption (via the application's data-protection mechanism) to stored SMTP passwords, connector credentials, and CA key passwords rather than storing them as plaintext database columns.

• **Rationale:** Database dumps must not expose institutional credentials.

• **Source:** KSPEC-002 UR-013 (Missing); DataProtectionService interface.

• **Classification:** TO-BE (not implemented at baseline).

• **Priority:** High

• **Status:** Missing

• **Verification:** I

• **Evidence:** `src/RTSec.Kryptonian.Domain/Entities/NotificationSettings.cs` and CA backend entity field types CODE-OBSERVED; `src/RTSec.Kryptonian.Infrastructure/Security/DataProtectionService.cs` CODE-OBSERVED; field coverage not evidenced UNKNOWN.

• **Approval:** Review Required

### SR-D.009 - Demonstration operations distinguishable

• **ID:** SR-D.009

• **Requirement:** The gateway shall make demonstration operations (demo enrollment, demo device creation) distinguishable from production lifecycle records in stored events and portal views.

• **Rationale:** Mixed demo and production records contaminate inventory and audit interpretation.

• **Source:** docs/IMPLEMENTATION-TRACKER.md (synthetic demo records remain); demo-enroll endpoint.

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** Low

• **Status:** Partial

• **Verification:** I

• **Evidence:** `src/RTSec.Kryptonian.Api/Controllers/DevicesController.cs` (DemoEnroll as a distinct operation) CODE-OBSERVED; explicit demo flagging in stored records not evidenced UNKNOWN.

• **Approval:** Review Required

## 14. Performance requirements (SR-P)

### SR-P.001 - EST rate-limit capacity

• **ID:** SR-P.001

• **Requirement:** The gateway shall accept sustained EST request rates up to the configured per-IP limit (baseline rules: 100 requests/minute on `*:/.well-known/est/*`, with more restrictive 30 requests/minute rules for labeled enrollment and re-enrollment POST paths) without error and shall throttle beyond it with HTTP 429; the production capacity target is `TBD` pending load testing.

• **Rationale:** Enrollment bursts (e.g., estate-wide renewal) must be absorbed without failure while abuse is throttled.

• **Source:** docs/ARCHITECTURE.md (rate limiting configuration); KSPEC-002 UR-014.

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** Medium

• **Status:** Partial

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Api/appsettings.json` (IpRateLimiting) CODE-OBSERVED; load-test results not present UNKNOWN.

• **AS-IS limitation:** Configured limits do not establish throughput, latency or availability below the limit. Middleware rule matching for unlabeled versus labeled paths and client-IP attribution needs VT-055 execution. `X-Forwarded-For` supplies the rate-limit key without an authenticated-forwarder proof in this baseline.

• **Approval:** Review Required

## SR-P.002 - Enrollment request size bounds

• **ID:** SR-P.002

• **Requirement:** The gateway shall limit EST CSR request bodies to 64 KiB and shall enforce the limit before cryptographic processing.

• **Rationale:** Bounding input size protects memory and limits denial-of-service amplification.

• **Source:** EstController MaxCsrBodySize; KSPEC-005 ICD-EST.

• **Classification:** TO-BE (normative statement of AS-IS behavior).

• **Priority:** Medium

• **Status:** Existing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Api/Controllers/EstController.cs` (RequestSizeLimit, 413 handling) CODE-OBSERVED.

• **Approval:** Review Required

## SR-P.003 - Enrollment latency targets

• **ID:** SR-P.003

• **Requirement:** The gateway shall complete a local-CA enrollment interaction within a latency budget agreed with stakeholders; the target values are `TBD` pending measurement (no performance budget exists at baseline).

• **Rationale:** Device-side renewal timeouts depend on gateway latency; an unagreed budget cannot be verified.

• **Source:** KSPEC-002 UR-021 (automation implies bounded latency); no baseline performance budget found.

• **Classification:** PROPOSED (targets require stakeholder agreement and measurement).

• **Priority:** Low

• **Status:** Missing

• **Verification:** A

• **Evidence:** No performance-threshold test or measurement found in tests/ or docs (searched) UNKNOWN; docs/ARCHITECTURE.md performance section (rate limits only) DOCUMENTED.

• **Approval:** Review Required

### SR-P.004 - Database connection pooling

• **ID:** SR-P.004

• **Requirement:** The gateway shall use pooled database connections with a configurable pool size for PostgreSQL deployments.

• **Rationale:** Estate-scale polling (dashboards, watchers) exhausts small connection pools.

• **Source:** docs/ARCHITECTURE.md (Npgsql pooling); DevicesController AllCertificates N+1 note.

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** Low

• **Status:** Existing

• **Verification:** I

• **Evidence:** `src/RTSec.Kryptonian.Api/Program.cs` (Npgsql configuration) CODE-OBSERVED; docs/ARCHITECTURE.md (MaxPoolSize 100 example) DOCUMENTED; `src/RTSec.Kryptonian.Api/Controllers/DevicesController.cs` (AllCertificates N+1 avoidance comment) CODE-OBSERVED.

• **Approval:** Review Required

### SR-P.005 - Profile and CA certificate caching

• **ID:** SR-P.005

• **Requirement:** The gateway shall cache EST profile lookups and CA certificate chains in memory so repeated device requests do not re-fetch unchanged CA material, with cache invalidation on profile or backend configuration change.

• **Rationale:** Enrollment is a control-plane operation; avoidable repeated I/O on the hot path shortens latency under bursts.

• **Source:** docs/ARCHITECTURE.md (Certificate Caching).

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** Low

• **Status:** Partial

• **Verification:** I

• **Evidence:** docs/ARCHITECTURE.md (CA certificates cached in memory; profile lookups cached by path/hostname) DOCUMENTED; invalidation behavior not separately evidenced UNKNOWN.

• **Approval:** Review Required

## 15. Reliability requirements (SR-R)

### SR-R.001 - Background watcher fault tolerance

• **ID:** SR-R.001

• **Requirement:** The gateway's background services shall catch and log scan failures and shall continue operating on the next cycle rather than terminating the gateway process.

• **Rationale:** A transient database or notification failure must not crash the enrollment service.

• **Source:** CertificateExpiryWatcher design; KSPEC-002 UR-012.

• **Classification:** TO-BE (normative statement of AS-IS behavior).

• **Priority:** High

• **Status:** Existing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Api/HostedServices/CertificateExpiryWatcher.cs` (try/catch around ScanOnceAsync, logging, loop continues) CODE-OBSERVED.

• **Approval:** Review Required

## SR-R.002 - Backend failure outcomes recorded

• **ID:** SR-R.002

• **Requirement:** The gateway shall surface transient CA backend failures as distinguishable error outcomes to the device and as recorded enrollment events, without partial or intermediate trust state persisting.

• **Rationale:** Operators must be able to distinguish "backend down" from "request rejected," and no orphaned state may result.

• **Source:** KSPEC-002 UR-023; PR 46 (transactional design).

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** High

• **Status:** Existing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Application/Services/EnrollmentOrchestrator.cs` (error result paths, event recording) CODE-OBSERVED; docs/API-GUIDE.md (500 mapping) DOCUMENTED.

• **Approval:** Review Required

## SR-R.003 - Notification delivery decoupled from lifecycle state

• **ID:** SR-R.003

• **Requirement:** The gateway shall ensure that a failed notification delivery does not prevent, roll back, or corrupt the lifecycle state change that triggered it; delivery-reliability semantics (retries, dead-lettering) are `TBD` (TBD-002).

• **Rationale:** Email transport is best-effort; trust state changes must be atomic and independent.

• **Source:** KSPEC-002 UR-012; `NotificationDispatcher` design.

• **Classification:** TO-BE (elaborates AS-IS behavior; delivery reliability UNKNOWN).

• **Priority:** Medium

• **Status:** Partial

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Application/Notifications/NotificationDispatcher.cs` CODE-OBSERVED; `CertificateExpiryWatcher` records LastExpiryNotifiedAt only after dispatch CODE-OBSERVED; delivery behavior not exercised at baseline DOCUMENTED.

• **Approval:** Review Required

### SR-R.004 - Concurrency conflict handling

• **ID:** SR-R.004

• **Requirement:** The gateway shall detect concurrent conflicting updates to lifecycle state (revocation, device status) and shall reject the losing operation with HTTP 409 instead of overwriting.

• **Rationale:** Silent last-writer-wins on revocation could un-revoke a certificate.

• **Source:** PR 46 (concurrent-update protection).

• **Classification:** TO-BE (normative statement of AS-IS behavior).

• **Priority:** High

• **Status:** Existing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Application/Services/CertificateRevocationService.cs` and `src/RTSec.Kryptonian.Infrastructure/Data/UnitOfWork.cs` CODE-OBSERVED; docs/formal-specification/07-OPERATIONAL-RISK.md DOCUMENTED.

• **Approval:** Review Required

### SR-R.005 - Graceful shutdown

• **ID:** SR-R.005

• **Requirement:** The gateway shall honor cancellation during shutdown so that background scans and in-flight enrollment operations stop cleanly without corrupting persisted state.

• **Rationale:** Service stop/restart (Windows service or container) is routine and must be state-safe.

• **Source:** Hosted service cancellation handling; KSPEC-002 UR-037.

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** Medium

• **Status:** Existing

• **Verification:** I

• **Evidence:** `src/RTSec.Kryptonian.Api/HostedServices/CertificateExpiryWatcher.cs` (stoppingToken handling, OperationCanceledException paths) CODE-OBSERVED; `src/RTSec.Kryptonian.Infrastructure/Acme/Http01ChallengeCleanupService.cs` CODE-OBSERVED.

• **Approval:** Review Required

## 16. Availability requirements (SR-V)

### SR-V.001 - Health-check endpoint availability

• **ID:** SR-V.001

• **Requirement:** The gateway shall expose an unauthenticated health-check endpoint that remains available even when authentication, EST profile, or CA backend subsystems are degraded.

• **Rationale:** A health probe that dies with its dependencies cannot tell an orchestrator anything useful.

• **Source:** KSPEC-002 UR-029; docs/DEPLOYMENT.md (liveness probes).

- **Classification:** TO-BE (elaborates AS-IS behavior).
- **Priority:** High
- **Status:** Existing
- **Verification:** T
- **Evidence:** `src/RTSec.Kryptonian.Api/Program.cs` (MapHealthChecks before auth-dependent routing; AddDbContextCheck) CODE-OBSERVED; `src/RTSec.Kryptonian.Api/Controllers/StatusController.cs` CODE-OBSERVED.
- **Approval:** Review Required

## SR-V.002 - Component-level health reporting

- **ID:** SR-V.002
- **Requirement:** The gateway's health reporting shall include the health of its CA backend connectors in addition to the database, reporting each component's state so orchestration can distinguish storage loss from CA outage.
- **Rationale:** CA connector outages and database outages need different operator responses.
- **Source:** docs/ARCHITECTURE.md (health checks example listing database and ca_connectors); KSPEC-002 UR-029.
- **Classification:** TO-BE (partially satisfied: database check implemented; connector checks not evidenced).
- **Priority:** Medium
- **Status:** Missing
- **Verification:** T
- **Evidence:** `src/RTSec.Kryptonian.Api/Program.cs` (only AddDbContextCheck registered) CODE-OBSERVED; docs/ARCHITECTURE.md (ca_connectors component documented) DOCUMENTED.
- **Approval:** Review Required

## SR-V.003 - Restart state preservation

- **ID:** SR-V.003
- **Requirement:** A gateway restart on a populated database shall preserve configured profiles, issuers, devices, and certificates, and shall resume normal operation without operator intervention.
- **Rationale:** Trust state must not evaporate across routine restarts.
- **Source:** KSPEC-002 UR-037; docs/IMPLEMENTATION-TRACKER.md.
- **Classification:** TO-BE (normative statement of AS-IS behavior).
- **Priority:** Critical
- **Status:** Existing
- **Verification:** T
- **Evidence:** docs/IMPLEMENTATION-TRACKER.md (gateway restart on populated SQLite preserved configured profile, issuer and devices) VERIFIED.
- **Approval:** Review Required

## SR-V.004 - Availability targets

- **ID:** SR-V.004

• **Requirement:** The deployed gateway shall meet institutionally agreed availability targets for the enrollment service; the target values and measurement window are `TBD` pending stakeholder agreement.

• **Rationale:** An enrollment gateway is on the device provisioning critical path; targets must be explicit to be operable.

• **Source:** KSPEC-007 operational risk (gateway unavailability scenario); no baseline target exists.

• **Classification:** PROPOSED (stakeholder decision required).

• **Priority:** Medium

• **Status:** Missing

• **Verification:** A

• **Evidence:** docs/formal-specification/07-OPERATIONAL-RISK.md (availability scenario) DOCUMENTED; no SLA/target in repository UNKNOWN.

• **Approval:** Review Required

# 17. Audit requirements (SR-U)

## SR-U.001 - Audit record for every trust decision

• **ID:** SR-U.001

• **Requirement:** The gateway shall record an audit record for every enrollment, renewal, and revocation decision, including requester identity, source address, CSR subject, outcome, and reason.

• **Rationale:** Security teams must be able to reconstruct who enrolled what, from where, through which backend.

• **Source:** KSPEC-002 UR-011 (High); Mvp.md §8 ("audit everything").

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** High

• **Status:** Partial

• **Verification:** I

• **Evidence:** `src/RTSec.Kryptonian.Application/Services/EnrollmentEventService.cs` and `src/RTSec.Kryptonian.Application/DTOs/EnrollmentEventDto.cs` CODE-OBSERVED; docs/flow.md (Enrollment Events) DOCUMENTED.

• **AS-IS limitation:** Selected issuance/rejection paths persist events, but early CSR/profile/credential failures and revocation outcomes are not uniformly persisted as EnrollmentEvent records. Request logging and certificate-state mutation are not substitutes for a complete durable decision audit. See VT-059 and GAP-038.

• **Approval:** Review Required

## SR-U.002 - Enrollment event completeness

• **ID:** SR-U.002

• **Requirement:** The gateway shall record blocked and failed enrollment attempts (including trust-removal blocks and policy rejections) as enrollment events with a reason, not only successful issuances.

• **Rationale:** Blocked attempts are the primary evidence of misuse probing.

• **Source:** KSPEC-002 UR-009 (blocked enrollment event with reason); docs/flow.md.

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** High

• **Status:** Partial

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Application/Services/EnrollmentOrchestrator.cs` (failure event paths, ErrorMessage capture) CODE-OBSERVED; `DevicesController.Events` mapping (ErrorMessage / serial detail) CODE-OBSERVED.

• **AS-IS limitation:** Selected issuance/rejection paths persist events, but early CSR/profile/credential failures and revocation outcomes are not uniformly persisted as EnrollmentEvent records. Request logging and certificate-state mutation are not substitutes for a complete durable decision audit. See VT-059 and GAP-038.

• **Approval:** Review Required

## SR-U.003 - Structured, correlated logging

• **ID:** SR-U.003

• **Requirement:** The gateway shall emit structured logs with a correlation ID, request ID, and client IP for every HTTP request, and shall write daily rolling log files.

• **Rationale:** Correlated, structured logs are the transport-level complement to enrollment events for incident analysis.

• **Source:** Serilog configuration; `RequestIdMiddleware`; docs/ARCHITECTURE.md (Observability).

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** Medium

• **Status:** Existing

• **Verification:** I

• **Evidence:** `src/RTSec.Kryptonian.Api/Program.cs` (Serilog with CorrelationId/RequestId/ClientIp enrichment, rolling file) CODE-OBSERVED; `src/RTSec.Kryptonian.Api/Middleware/RequestIdMiddleware.cs` CODE-OBSERVED.

• **Approval:** Review Required

## SR-U.004 - Administrative action logging

• **ID:** SR-U.004

• **Requirement:** The gateway shall log every administrative state-changing action (user, key, device, backend, profile, and settings changes) with the acting identity and the affected resource.

• **Rationale:** Configuration changes can shift trust for the entire estate; attribution is mandatory.

• **Source:** KSPEC-002 UR-011; docs/user-management.md (audit review).

• **Classification:** TO-BE (elaborates AS-IS behavior; coverage beyond enrollment events not evidenced).

• **Priority:** High

• **Status:** Partial

• **Verification:** I

• **Evidence:** `src/RTSec.Kryptonian.Api/Controllers/UsersController.cs` and other controllers (logging warnings on failures) CODE-OBSERVED; systematic admin-action audit records not evidenced UNKNOWN.

• **Approval:** Review Required

## SR-U.005 - Audit record tamper protection

• **ID:** SR-U.005

• **Requirement:** The gateway shall protect audit records against undetected modification or deletion by any gateway operator account (e.g., append-only storage or external forwarding); the selected mechanism is `TBD` pending design approval.

• **Rationale:** An attacker with admin access can otherwise erase the evidence of their own actions.

• **Source:** KSPEC-006 threat model input; KSPEC-002 UR-011 rationale (reconstruction implies integrity).

• **Classification:** PROPOSED (mechanism requires design approval; not implemented at baseline).

• **Priority:** Medium

• **Status:** Missing

• **Verification:** A

• **Evidence:** `src/RTSec.Kryptonian.Infrastructure/Repositories/EnrollmentEventRepository.cs` (no append-only mechanism) CODE-OBSERVED; no tamper-protection evidence in docs UNKNOWN.

• **Approval:** Review Required

## SR-U.006 - Audit export capability

• **ID:** SR-U.006

• **Requirement:** The gateway shall provide a supported export path for lifecycle audit events suitable for institutional SIEM consumption; mapping to hospital audit transport standards is a separate conformance task and no standard-conformant export is claimed at baseline.

• **Rationale:** Audit value depends on reaching the institution's central monitoring, not only the local portal.

• **Source:** KSPEC-004 finding A-6 (audit is a database table + structured logs; ATNA mapping TO-BE/PROPOSED).

• **Classification:** PROPOSED (scope requires approval).

• **Priority:** Low

• **Status:** Missing

• **Verification:** I

• **Evidence:** docs/formal-specification/04-SOFTWARE-DESIGN.md A-6 DOCUMENTED; no export endpoint found in controllers CODE-OBSERVED.

• **Approval:** Review Required

## SR-U.007 - Live log ring buffer bounds

• **ID:** SR-U.007

• **Requirement:** The gateway's live activity feed shall be bounded (ring buffer) so that log volume cannot grow memory unboundedly, and the persisted daily log files shall remain the authoritative record.

• **Rationale:** A live feed is a convenience; unbounded buffering would be a denial-of-service on the gateway itself.

• **Source:** LiveLogBroadcaster design; docs/ARCHITECTURE.md (Observability).

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** Low

• **Status:** Existing

• **Verification:** I

• **Evidence:** `src/RTSec.Kryptonian.Api/Program.cs` (LiveLogSink/LiveLogBroadcaster singleton) CODE-OBSERVED; docs/ARCHITECTURE.md DOCUMENTED.

• **Approval:** Review Required

# 18. Deployment requirements (SR-B)

## SR-B.001 - Deployment packaging options

• **ID:** SR-B.001

• **Requirement:** The gateway shall be deployable as containers (Docker Compose and Kubernetes manifests) and as a Windows package, with deployment guidance for each option.

• **Rationale:** Hospitals have heterogeneous infrastructure; deployment flexibility determines adoptability.

• **Source:** KSPEC-002 UR-028 (Medium); docs/DEPLOYMENT.md; docker-compose.yml; deploy/; installer/windows/.

• **Classification:** TO-BE (elaborates AS-IS behavior; Windows installer path and PostgreSQL in practice UNKNOWN, TBD-006).

• **Priority:** Medium

• **Status:** Existing

• **Verification:** I

• **Evidence:** `docker-compose.yml`, `deploy/azure/`, `installer/windows/` CODE-OBSERVED; docs/DEPLOYMENT.md and docs/windows-installation.md DOCUMENTED.

• **Approval:** Review Required

## SR-B.002 - Windows service and sandbox modes

• **ID:** SR-B.002

• **Requirement:** The gateway shall support hosting as a Windows service, and a sandbox mode that generates local demonstration services and is refused when the environment is not Production.

• **Rationale:** Sandbox demonstration services must never silently activate outside their intended environment.

• **Source:** SandboxBootstrap (Production requirement); docs/windows-sandbox.md.

• **Classification:** TO-BE (normative statement of AS-IS behavior).

• **Priority:** Medium

• **Status:** Existing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Api/Program.cs` (sandbox initialization, "sandbox services must run in Production" exception, UseWindowsService) CODE-OBSERVED; `src/RTSec.Kryptonian.Api/SandboxBootstrap.cs` CODE-OBSERVED.

• **Approval:** Review Required

## SR-B.003 - External TLS certificate provisioning

• **ID:** SR-B.003

• **Requirement:** The gateway shall accept operator-provided TLS certificates for its HTTPS endpoints in production deployments and shall reserve self-signed certificate generation for development and sandbox modes.

• **Rationale:** Production gateways must present institutionally controlled server identities.

• **Source:** `SelfSignedCaGenerator.cs`; docs/ca-backend-configuration.md; SandboxBootstrap.

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** High

• **Status:** Existing

• **Verification:** I

• **Evidence:** `src/RTSec.Kryptonian.Api/SelfSignedCaGenerator.cs` CODE-OBSERVED; `src/RTSec.Kryptonian.Api/Program.cs` (Kestrel HTTPS configuration, sandbox PFX loading) CODE-OBSERVED; docs/DEPLOYMENT.md DOCUMENTED.

• **Approval:** Review Required

## SR-B.004 - Configuration via documented settings

• **ID:** SR-B.004

• **Requirement:** The gateway shall source all environment-specific configuration (database, TLS, authentication, rate limits, backends) from documented configuration keys and environment variables, and shall document each key's default and effect.

• **Rationale:** Undocumented configuration drift makes deployment behavior irreproducible.

• **Source:** KSPEC-005 ICD-CFG (configuration item list); docs/DEPLOYMENT.md.

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** Medium

• **Status:** Existing

• **Verification:** I

• **Evidence:** `src/RTSec.Kryptonian.Api/appsettings.json` CODE-OBSERVED; docs/formal-specification/05-INTERFACE-CONTROL.md (configuration tables) DOCUMENTED.

• **Approval:** Review Required

## SR-B.005 - CRL-over-HTTP listener restriction

• **ID:** SR-B.005

• **Requirement:** When the CRL-over-HTTP option is enabled, the gateway shall serve unencrypted HTTP requests only for GET/HEAD of `/api/crl` paths and shall refuse all other unencrypted requests with HTTP 403.

• **Rationale:** Some CRL consumers cannot use HTTPS; the exception must be as narrow as possible.

• **Source:** Program.cs CrlOnlyHttp middleware; KSPEC-005 ICD-CFG.

• **Classification:** TO-BE (normative statement of AS-IS behavior).

• **Priority:** High

• **Status:** Existing

• **Verification:** T

• **Evidence:** `Program.cs` CrlOnlyHttp and sandbox listener gate; `SandboxBootstrap.AllowsRequest` CODE-OBSERVED; `SandboxBootstrapTests.cs` test definitions CODE-OBSERVED.

• **Approval:** Review Required

### SR-B.006 - Upgrade preservation

• **ID:** SR-B.006

• **Requirement:** The Windows installer upgrade path shall preserve the existing CA material and database, shall run a readiness health check, and shall not delete existing state to work around failures.

• **Rationale:** Upgrades that discard trust state or paper over failures create hidden breakage.

• **Source:** docs/formal-specification/07-OPERATIONAL-RISK.md (MSI upgrade preserves existing CA and database; readiness health check); artifacts/windows-installer/payload/docs/windows-installation.md (do not delete existing CA/database files).

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** Medium

• **Status:** Existing

• **Verification:** D

• **Evidence:** `installer/windows/` CODE-OBSERVED; artifacts/windows-installer/payload/docs/windows-installation.md DOCUMENTED; docs/formal-specification/07-OPERATIONAL-RISK.md DOCUMENTED.

• **Approval:** Review Required

### SR-B.007 - Production secret provisioning

• **ID:** SR-B.007

• **Requirement:** Production deployment guidance shall require all secrets (JWT secret, static API keys, connector credentials, SMTP credentials) to be supplied through the deployment's secret mechanism, and shall treat plaintext configuration-file secrets as development-only.

• **Rationale:** Deployment guidance is the last control layer against secret sprawl.

• **Source:** KSPEC-002 UR-013; KSPEC-004 PROPOSED item P-1; docs/DEPLOYMENT.md.

• **Classification:** TO-BE (guidance strengthened; baseline uses env/plain config).

• **Priority:** High

• **Status:** Partial

• **Verification:** I

• **Evidence:** docs/DEPLOYMENT.md DOCUMENTED; `src/RTSec.Kryptonian.Api/appsettings.Development.json` CODE-OBSERVED; docs/formal-specification/04-SOFTWARE-DESIGN.md P-1 DOCUMENTED.

• **Approval:** Review Required

## 19. Operational maintenance requirements (SR-O)

### SR-O.001 - Extensible connector architecture

• **ID:** SR-O.001

• **Requirement:** The gateway's design shall allow a new CA backend type to be added by implementing the internal connector abstraction without changing device-facing behavior or enrollment business logic.

• **Rationale:** Sustains the multi-CA roadmap and the single-protocol device contract as backends evolve.

• **Source:** KSPEC-002 UR-038 (Medium); docs/ARCHITECTURE.md (Extension Points).

• **Classification:** TO-BE (elaborates AS-IS design).

• **Priority:** Medium

• **Status:** Existing

• **Verification:** A

• **Evidence:** `src/RTSec.Kryptonian.Infrastructure/Crypto/CaConnectorFactory.cs` and `src/RTSec.Kryptonian.Domain/Interfaces/` (ICaConnector) CODE-OBSERVED; docs/ARCHITECTURE.md DOCUMENTED; addition of a new connector not exercised at baseline.

• **Approval:** Review Required

## SR-O.002 - Log rotation and retention

• **ID:** SR-O.002

• **Requirement:** The gateway shall write daily rolling log files and shall make the log retention behavior operator-controllable; the production retention value is `TBD`.

• **Rationale:** Unbounded log growth is an operational failure mode on long-lived hosts.

• **Source:** Serilog rolling file sink; docs/DEPLOYMENT.md.

• **Classification:** TO-BE (elaborates AS-IS behavior; retention configurability not evidenced).

• **Priority:** Low

• **Status:** Partial

• **Verification:** I

• **Evidence:** `src/RTSec.Kryptonian.Api/Program.cs` (RollingInterval.Day) CODE-OBSERVED; log retention settings not evidenced UNKNOWN.

• **Approval:** Review Required

## SR-O.003 - External credential renewal support

• **ID:** SR-O.003

• **Requirement:** The gateway and demonstration proxy shall support replacement of externally issued credentials (PFX) at runtime by atomic file replacement with fresh handshakes observing the new credential, and shall fail closed on invalid replacements.

• **Rationale:** Hospital PKI teams rotate credentials on their own schedule; the gateway must adopt rotated credentials without restart.

• **Source:** PR 48 (externally rotated PFX); docs/development.md.

• **Classification:** TO-BE (normative statement of AS-IS behavior; automated CA renewal itself not implemented).

• **Priority:** Medium

• **Status:** Existing

• **Verification:** T

• **Evidence:** docs/IMPLEMENTATION-TRACKER.md (fresh handshakes observing atomic PFX replacement; expired replacement fails closed) VERIFIED; docs/development.md DOCUMENTED.

• **Approval:** Review Required

### SR-O.004 - Metrics endpoint

• **ID:** SR-O.004

• **Requirement:** The gateway shall expose operational metrics (enrollment counts by profile/status, CA backend latency, request rates and errors) on a monitoring endpoint; the format (e.g., Prometheus) is `TBD` pending approval.

• **Rationale:** Renewal-scale estate operation needs trend visibility, not just live logs.

• **Source:** docs/ARCHITECTURE.md (Metrics (Future)).

• **Classification:** PROPOSED (planned/future in documentation).

• **Priority:** Low

• **Status:** Missing

• **Verification:** T

• **Evidence:** docs/ARCHITECTURE.md (Prometheus metrics planned) DOCUMENTED; no metrics endpoint in controllers CODE-OBSERVED.

• **Approval:** Review Required

### SR-O.005 - Dependency maintenance process

• **ID:** SR-O.005

• **Requirement:** The project shall apply compatible dependency security updates through reviewed pull requests with audit disclosure, and shall record which advisories remain as deployment blockers.

• **Rationale:** Security patching must be traceable and honest about residual risk.

• **Source:** PR 52 (compatible dependency security updates and audit disclosure).

• **Classification:** TO-BE (elaborates AS-IS process).

• **Priority:** Medium

• **Status:** Existing

• **Verification:** I

• **Evidence:** docs/IMPLEMENTATION-TRACKER.md (PR 52; MailKit 4.16.0 upgrade; remaining advisories listed) DOCUMENTED; `.github/workflows/` CODE-OBSERVED.

• **Approval:** Review Required

## 20. Failure and recovery requirements (SR-X)

### SR-X.001 - Unsupported revocation fails closed

• **ID:** SR-X.001

• **Requirement:** When a configured CA backend does not support revocation or CRL generation, the gateway shall reject the revocation operation with an explicit not-implemented error response and shall leave the certificate's status unchanged.

• **Rationale:** Falsely reporting success would leave operators trusting revoked credentials.

• **Source:** docs/IMPLEMENTATION-TRACKER.md ("Unsupported remote CA revocation fails closed"); KSPEC-002 UR-010 and §16.4.

• **Classification:** TO-BE (normative statement of AS-IS behavior).

• **Priority:** Critical

• **Status:** Existing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Application/Services/CertificateRevocationService.cs` (501 on unsupported CRL generation; state unchanged) CODE-OBSERVED; docs/formal-specification/07-OPERATIONAL-RISK.md (fail-closed orientation) DOCUMENTED.

• **Approval:** Review Required

## SR-X.002 - Invalid replacement credentials fail closed

• **ID:** SR-X.002

• **Requirement:** The gateway and demonstration proxy shall reject externally replaced credentials that are invalid, expired, or untrusted and shall never keep invalid credentials as a fallback for new handshakes.

• **Rationale:** A stale or invalid credential silently accepted as fallback defeats the rotation's security intent.

• **Source:** PR 48; docs/development.md (invalid replacements fail closed; no stale credentials as fallback).

• **Classification:** TO-BE (normative statement of AS-IS behavior).

• **Priority:** High

• **Status:** Existing

• **Verification:** T

• **Evidence:** docs/IMPLEMENTATION-TRACKER.md (expired replacement fails closed; unknown/expired/revoked client rejection) VERIFIED; `src/Kryptonian.DICOMTls/` CODE-OBSERVED.

• **Approval:** Review Required

## SR-X.003 - Issuer-mismatch and rotated-CA guards

• **ID:** SR-X.003

• **Requirement:** The gateway shall reject revocation or CRL operations that do not match the issuing CA of the target certificate (issuer mismatch or rotated-CA cases) with HTTP 409 rather than issuing a CRL or status change under the wrong issuer.

• **Rationale:** Cross-issuer revocation would corrupt the trust state of unrelated devices.

• **Source:** docs/formal-specification/07-OPERATIONAL-RISK.md (issuer/CA mismatch or rotated-CA guards reject with 409, CODE-OBSERVED).

• **Classification:** TO-BE (normative statement of AS-IS behavior).

• **Priority:** High

• **Status:** Existing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Application/Services/CertificateRevocationService.cs` (issuer guards) CODE-OBSERVED; docs/formal-specification/07-OPERATIONAL-RISK.md DOCUMENTED.

• **Approval:** Review Required

## SR-X.004 - Unencrypted non-CRL requests refused

• **ID:** SR-X.004

• **Requirement:** When the CRL-over-HTTP listener is active, the gateway shall refuse any unencrypted request that is not a GET/HEAD CRL retrieval with HTTP 403, including administrative API calls.

• **Rationale:** The narrow HTTP exception must not become a general plaintext bypass.

• **Source:** Program.cs CrlOnlyHttp middleware; HTTP listener denial VERIFIED (tracker).

• **Classification:** TO-BE (normative statement of AS-IS behavior).

• **Priority:** High

• **Status:** Existing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Api/Program.cs` (403 for non-CRL on HTTP) CODE-OBSERVED; docs/IMPLEMENTATION-TRACKER.md (HTTP listener denies non-CRL requests) VERIFIED.

• **Approval:** Review Required

## SR-X.005 - One-time activation replay rejected

• **ID:** SR-X.005

• **Requirement:** The gateway shall reject a replayed activation code after it has been consumed, and shall reject bootstrap enrollment attempts from already-active devices that do not present a valid client certificate.

• **Rationale:** Replay is the primary attack on bootstrap credentials; executed evidence distinguishes the two cases explicitly.

• **Source:** docs/IMPLEMENTATION-TRACKER.md (one-time activation replay rejected); PR 42 (atomic one-time activation).

• **Classification:** TO-BE (normative statement of AS-IS behavior).

• **Priority:** Critical

• **Status:** Existing

• **Verification:** T

• **Evidence:** `artifacts/developer/verify-*/replay.txt` ("Public enrollment requires pending device activation; active devices must use authenticated re-enrollment") VERIFIED; `src/RTSec.Kryptonian.Api/Controllers/EstController.cs` CODE-OBSERVED.

• **Approval:** Review Required

## SR-X.006 - Database unavailability behavior

• **ID:** SR-X.006

• **Requirement:** The gateway shall respond to database unavailability with a distinguishable server error on affected requests, shall log the failure with its correlation ID, and shall report the database component as unhealthy on the health endpoint rather than crashing.

• **Rationale:** Storage loss is an operational certainty; degradation behavior determines whether the incident is diagnosable.

• **Source:** docs/formal-specification/07-OPERATIONAL-RISK.md (database outage scenarios); health-check design.

• **Classification:** TO-BE (elaborates AS-IS behavior).

• **Priority:** High

• **Status:** Existing

• **Verification:** T

• **Evidence:** `src/RTSec.Kryptonian.Api/Program.cs` (AddDbContextCheck) CODE-OBSERVED; `src/RTSec.Kryptonian.Api/Controllers/EstController.cs` (500 mapping with logging) CODE-OBSERVED.

• **Approval:** Review Required

### SR-X.007 - Backup and restore procedure

• **ID:** SR-X.007

• **Requirement:** The gateway shall provide a documented backup and restore procedure that recovers, in order, the Data Protection key ring, CA material with original passwords, and the database, and that restarts cleanly against the restored state.

• **Rationale:** Recovery order matters: a restored database without its key ring yields unreadable protected fields; a restored CA without its key cannot re-sign CRLs.

• **Source:** docs/formal-specification/07-OPERATIONAL-RISK.md (restore sequence: key ring first, then CA material, then database).

• **Classification:** TO-BE (procedure documented; automated backup/restore not implemented).

• **Priority:** High

• **Status:** Partial

• **Verification:** D

• **Evidence:** docs/formal-specification/07-OPERATIONAL-RISK.md (restore steps 1-4) DOCUMENTED; no automated backup mechanism in code CODE-OBSERVED.

• **Approval:** Review Required

# 21. Requirements summary and register

## 21.1 Counts

| Dimension | Value |
|---|---|
| Total requirements | 154 |
| By category | SR-F-REG 10, SR-F-EST 14, SR-F-CLM 9, SR-F-CAI 10, SR-F-ADM 10, SR-F-INT 8 (functional total 61), SR-S 14, SR-A 10, SR-Z 10, SR-C 10, SR-D 9, SR-P 5, SR-R 5, SR-V 4, SR-U 7, SR-B 7, SR-O 5, SR-X 7 |
| By status | Existing 108, Partial 25, Missing 18, Proposed 3 |
| By priority | Critical 36, High 71, Medium 38, Low 9 |
| Approval state | All records: Review Required (no approvals recorded or inferred) |

## 21.2 Requirements Register (canonical)

Every requirement in this document appears in the register below and vice versa. This register is the canonical ID list consumed by KSPEC-008 (V&V) and KSPEC-009 (traceability). Verification abbreviations per KSPEC-000 §11.

### SR-F-REG.001

**Short title:** Device registration with activation code
**Priority:** High
**Status:** Existing
**Verification:** D

### SR-F-REG.002

**Short title:** Activation code one-time use, replay rejected
**Priority:** Critical
**Status:** Existing
**Verification:** T

### SR-F-REG.003

**Short title:** Centralized device inventory
**Priority:** High
**Status:** Existing
**Verification:** D

### SR-F-REG.004

**Short title:** Device record status lifecycle
**Priority:** High
**Status:** Existing
**Verification:** T

### SR-F-REG.005

**Short title:** Enrollment identity binding
**Priority:** High
**Status:** Existing
**Verification:** T

### SR-F-REG.006

**Short title:** Self-service requests create pending records only
**Priority:** High
**Status:** Existing
**Verification:** T

### SR-F-REG.007

**Short title:** Anonymous endpoint abuse controls
**Priority:** Medium
**Status:** Missing
**Verification:** T

### SR-F-REG.008

**Short title:** Trust removal blocks enrollment
**Priority:** Critical

**Status:** Existing
**Verification:** T

### SR-F-REG.009

**Short title:** Device identity metadata preservation
**Priority:** High
**Status:** Existing
**Verification:** D

### SR-F-REG.010

**Short title:** History preserved on device removal
**Priority:** Medium
**Status:** Existing
**Verification:** I

### SR-F-EST.001

**Short title:** EST endpoint surface
**Priority:** Critical
**Status:** Existing
**Verification:** T

### SR-F-EST.002

**Short title:** cacerts response format
**Priority:** High
**Status:** Existing
**Verification:** T

### SR-F-EST.003

**Short title:** CSR acceptance and 64 KiB limit
**Priority:** High
**Status:** Existing
**Verification:** T

### SR-F-EST.004

**Short title:** Successful enrollment response format
**Priority:** Critical
**Status:** Existing
**Verification:** T

### SR-F-EST.005

**Short title:** Unknown profile label 404, no fallback
**Priority:** High
**Status:** Existing
**Verification:** T

### SR-F-EST.006

**Short title:** Basic bootstrap authentication over TLS
**Priority:** Critical
**Status:** Existing
**Verification:** T

### SR-F-EST.007

**Short title:** Legacy headers compatibility only
**Priority:** High
**Status:** Partial
**Verification:** T

### SR-F-EST.008

**Short title:** Re-enroll requires native TLS client cert
**Priority:** Critical
**Status:** Existing
**Verification:** T

### SR-F-EST.009

**Short title:** Client certificate validation on EST
**Priority:** Critical
**Status:** Existing
**Verification:** T

### SR-F-EST.010

**Short title:** Pending 202 + Retry-After
**Priority:** High
**Status:** Existing
**Verification:** T

### SR-F-EST.011

**Short title:** Deterministic pending semantics per backend
**Priority:** Medium
**Status:** Missing
**Verification:** A

### SR-F-EST.012

**Short title:** Plain-HTTP EST refused (426)
**Priority:** Critical
**Status:** Existing
**Verification:** T

### SR-F-EST.013

**Short title:** Distinguishable error semantics
**Priority:** High

**Status:** Existing
**Verification:** I

### SR-F-EST.014

**Short title:** CSR attributes (csrattrs) endpoint
**Priority:** Low
**Status:** Missing
**Verification:** T

### SR-F-CLM.001

**Short title:** Approval gates enrollment
**Priority:** Critical
**Status:** Existing
**Verification:** T

### SR-F-CLM.002

**Short title:** Automatic renewal without re-approval
**Priority:** Critical
**Status:** Existing
**Verification:** T

### SR-F-CLM.003

**Short title:** Renewal: new key, preserved identity
**Priority:** Critical
**Status:** Existing
**Verification:** T

### SR-F-CLM.004

**Short title:** Certificate expiry visibility
**Priority:** High
**Status:** Existing
**Verification:** D

### SR-F-CLM.005

**Short title:** Automated expiry scan and notification
**Priority:** High
**Status:** Partial
**Verification:** T

### SR-F-CLM.006

**Short title:** Non-renewal alerting
**Priority:** High
**Status:** Partial
**Verification:** D

### SR-F-CLM.007

**Short title:** Revocation with issuer-scoped signed CRLs
**Priority:** Critical
**Status:** Existing
**Verification:** T

### SR-F-CLM.008

**Short title:** Transactional revocation persistence
**Priority:** High
**Status:** Existing
**Verification:** T

### SR-F-CLM.009

**Short title:** Revoked devices denied renewal
**Priority:** Critical
**Status:** Existing
**Verification:** T

### SR-F-CAI.001

**Short title:** Multi-backend configuration
**Priority:** High
**Status:** Existing
**Verification:** D

### SR-F-CAI.002

**Short title:** Backend test + profile-bound routing
**Priority:** High
**Status:** Existing
**Verification:** T

### SR-F-CAI.003

**Short title:** Pluggable connector abstraction
**Priority:** High
**Status:** Existing
**Verification:** A

### SR-F-CAI.004

**Short title:** Transparent CA protocol mapping
**Priority:** Critical
**Status:** Existing
**Verification:** A

### SR-F-CAI.005

**Short title:** ADCS SCEP endpoints configurable
**Priority:** Medium

**Status:** Partial
**Verification:** I

### SR-F-CAI.006

**Short title:** EJBCA REST + honest revocation
**Priority:** Medium
**Status:** Partial
**Verification:** I

### SR-F-CAI.007

**Short title:** ACME functional challenge set
**Priority:** Medium
**Status:** Partial
**Verification:** T

### SR-F-CAI.008

**Short title:** CRL generation capability + fail closed
**Priority:** High
**Status:** Existing
**Verification:** T

### SR-F-CAI.009

**Short title:** CA material persistence
**Priority:** High
**Status:** Existing
**Verification:** T

### SR-F-CAI.010

**Short title:** Secure connector credential handling
**Priority:** High
**Status:** Missing
**Verification:** I

### SR-F-ADM.001

**Short title:** Admin portal surface
**Priority:** High
**Status:** Existing
**Verification:** D

### SR-F-ADM.002

**Short title:** Gateway dashboard summary
**Priority:** Medium
**Status:** Existing
**Verification:** D

### SR-F-ADM.003

**Short title:** User lifecycle with lockout protection
**Priority:** High
**Status:** Existing
**Verification:** T

### SR-F-ADM.004

**Short title:** API key lifecycle
**Priority:** High
**Status:** Existing
**Verification:** T

### SR-F-ADM.005

**Short title:** Initial administrator bootstrap
**Priority:** High
**Status:** Existing
**Verification:** T

| SR-F-ADM.006 | Notification settings management | Medium | Existing | D | | SR-F-ADM.007 | Profile management, additive trust updates | High | Existing | T | | SR-F-ADM.008 | Gateway settings management | Medium | Existing | I | | SR-F-ADM.009 | Live activity feed | Medium | Existing | D | | SR-F-ADM.010 | Health and status endpoint | Medium | Existing | T | | SR-F-INT.001 | Independent-client EST usability | High | Existing | T | | SR-F-INT.002 | Compatibility headers never mandatory | High | Existing | I | | SR-F-INT.003 | Authoritative OpenAPI admin contract | High | Missing | I | | SR-F-INT.004 | EST profile schema currency | Medium | Partial | I | | SR-F-INT.005 | DICOM mTLS demonstration | Medium | Existing | D | | SR-F-INT.006 | Demo components carry no clinical claims | High | Existing | I | | SR-F-INT.007 | No competing enrollment protocol | High | Existing | I | | SR-F-INT.008 | Joint interoperability test vectors | Medium | Proposed | T | | SR-S.001 | Transport security for credentials | Critical | Existing | T | | SR-S.002 | CSR/returned-cert policy enforcement | Critical | Existing | T | | SR-S.003 | Gateway-owned trust-policy gate | Critical | Existing | T | | SR-S.004 | Forwarded-certificate guard | Critical | Existing | T | | SR-S.005 | Authenticated forwarder identity | High | Missing | T | | SR-S.006 | EST rate limiting | Medium | Existing | T | | SR-S.007 | No hard-coded signing secrets | Critical | Missing | T | | SR-S.008 | Secrets at rest | High | Missing | I | | SR-S.009 | Password hashing (BCrypt ≥ 12) | Critical | Existing | I | | SR-S.010 | Data Protection key ring management | High | Partial | T | | SR-S.011 | Device private key non-archival | High | Proposed | I | | SR-S.012 | Configurable CRL lifetime | High | Missing | T | | SR-S.013 | CORS restriction | Medium | Existing | T | | SR-S.014 | Dependency vulnerability management | High | Partial | T | | SR-A.001 | Dual-scheme admin authentication | Critical | Existing | T | | SR-A.002 | JWT token validation | Critical | Existing | T | | SR-A.003 | API key storage and validation | Critical | Existing | T | | SR-A.004 | Static compatibility API keys | Medium | Existing | I | | SR-A.005 | API key carries generation-time role | Medium | Existing | D | | SR-A.006 | JWT signing secret provisioning | Critical | Missing | T | | SR-A.007 | EST bootstrap 401 challenge | Medium | Existing | T | | SR-A.008 | Re-enroll credential rule | Critical | Existing | T | | SR-A.009 | Development bypass confinement | High | Existing | T | | SR-A.010 | Login failure without enumeration | Medium | Existing | T | | SR-Z.001 | Role model (three roles) | Critical | Existing | T | | SR-Z.002 | Device ops restricted to DeviceAdmin+ | Critical | Existing | T | | SR-Z.003 | System config restricted to SystemAdmin | Critical | Existing | T | | SR-Z.004 | Read-only access for Standard role | High | Existing | T | | SR-Z.005 | Revocation restricted to DeviceAdmin+ | Critical | Existing | T | | SR-Z.006 | API-key claims from record only | Critical | Existing | T | | SR-Z.007 | Explicit role policy on all mutations | High | Partial | T | | SR-Z.008 | Anonymous surface limited to documented set | High | Existing | I | | SR-Z.009 | Confirmed self-service authorization model | Medium | Proposed | I | | SR-Z.010 | No clinical capability derivation | Critical | Existing | I | | SR-C.001 | Profile policy bundle enforced | Critical | Existing | I | | SR-C.002 | Trust policy durability | High | Existing | T | | SR-C.003 | Profile-configured validity (TBD policy) | High | Existing | I | | SR-C.004 | Renewal window authorization | Critical | Existing | T | | SR-C.005 | Issuer-scoped CRL publication | High | Existing | T | | SR-C.006 | CRL distribution points on certificates | High | Existing | T | | SR-C.007 | Online revocation checking at peers | High | Existing | D | | SR-C.008 | Bounded revocation propagation semantics | Medium | Partial | A | | SR-C.009 | Revocation vs. enrollment denial separation | High | Existing | I | | SR-C.010 | Enrollment event per attempt | High | Partial | T |

| SR-D.001 | Durable persistence of all state | High | Existing | T | | SR-D.002 | SQLite and PostgreSQL support | High | Partial | T | | SR-D.003 | Additive schema upgrades | High | Existing | I | | SR-D.004 | Upgrade safety boundary | High | Missing | T | | SR-D.005 | UTC timestamp discipline | High | Existing | T | | SR-D.006 | Lifecycle record retention (TBD period) | Medium | Partial | I | | SR-D.007 | Data Protection key persistence | High | Partial | T | | SR-D.008 | Sensitive field encryption at rest | High | Missing | I | | SR-D.009 | Demo operations distinguishable | Low | Partial | I | | SR-P.001 | EST rate-limit capacity | Medium | Partial | T | | SR-P.002 | Enrollment request size bounds | Medium | Existing | T | | SR-P.003 | Enrollment latency targets (TBD) | Low | Missing | A | | SR-P.004 | Database connection pooling | Low | Existing | I | | SR-P.005 | Profile/CA certificate caching | Low | Partial | I | | SR-R.001 | Background watcher fault tolerance | High | Existing | T | | SR-R.002 | Backend failure outcomes recorded | High | Existing | T | | SR-R.003 | Notification delivery decoupled | Medium | Partial | T | | SR-R.004 | Concurrency conflict handling | High | Existing | T | | SR-R.005 | Graceful shutdown | Medium | Existing | I | | SR-V.001 | Health-check availability | High | Existing | T | | SR-V.002 | Component-level health reporting | Medium | Missing | T | | SR-V.003 | Restart state preservation | Critical | Existing | T | | SR-V.004 | Availability targets (TBD) | Medium | Missing | A | | SR-U.001 | Audit record per trust decision | High | Partial | I | | SR-U.002 | Blocked attempts recorded | High | Partial | T | | SR-U.003 | Structured correlated logging | Medium | Existing | I | | SR-U.004 | Administrative action logging | High | Partial | I | | SR-U.005 | Audit tamper protection | Medium | Missing | A | | SR-U.006 | Audit export capability | Low | Missing | I | | SR-U.007 | Live log ring buffer bounds | Low | Existing | I |

| SR-B.001 | Deployment packaging options | Medium | Existing | I | | SR-B.002 | Windows service and sandbox modes | Medium | Existing | T | | SR-B.003 | External TLS certificate provisioning | High | Existing | I | | SR-B.004 | Documented configuration settings | Medium | Existing | I | | SR-B.005 | CRL-over-HTTP listener restriction | High | Existing | T | | SR-B.006 | Upgrade preservation | Medium | Existing | D | | SR-B.007 | Production secret provisioning | High | Partial | I | | SR-O.001 | Extensible connector architecture | Medium | Existing | A | | SR-O.002 | Log rotation and retention | Low | Partial | I | | SR-O.003 | External credential renewal support | Medium | Existing | T | | SR-O.004 | Metrics endpoint | Low | Missing | T | | SR-O.005 | Dependency maintenance process | Medium | Existing | I | | SR-X.001 | Unsupported revocation fails closed | Critical | Existing | T | | SR-X.002 | Invalid replacements fail closed | High | Existing | T | | SR-X.003 | Issuer-mismatch guards (409) | High | Existing | T | | SR-X.004 | Unencrypted non-CRL requests refused | High | Existing | T | | SR-X.005 | Activation replay rejected | Critical | Existing | T | | SR-X.006 | Database unavailability behavior | High | Existing | T | | SR-X.007 | Backup and restore procedure | High | Partial | D |

## 22. Traceability and open-item notes

• **Upstream**: every SR cites its KSPEC-002 UR in the Source field; governing constraints also cite KSPEC-000 §3/§4 and KSPEC-001 exclusions (EXC-001 - EXC-008).

• **Downstream**: KSPEC-004 (design), KSPEC-005 (interfaces), KSPEC-006 (cybersecurity), KSPEC-007 (operational risk), KSPEC-008 (V&V), KSPEC-009 (traceability), and KSPEC-010 (gap analysis) reference these SRs by ID only (KSPEC-000 §7) and shall not redefine them.

• **Unresolved thresholds** (`TBD` in requirements): SR-F-REG.007 (abuse-control threshold), SR-F-EST.011 (pending trigger matrix), SR-S.005 (forwarder authentication mechanism), SR-S.006 (production rate limits), SR-S.008 (encryption approach), SR-S.011 (key-archival policy), SR-C.003 (certificate lifetime policy), SR-C.008 (stale-revocation policy), SR-D.006 (retention period), SR-P.001 (production capacity), SR-P.003 (latency budget), SR-R.003 (delivery reliability), SR-V.004 (availability targets), SR-O.002 (log retention), SR-O.004 (metrics format), SR-F-CAI.010 (secrets mechanism); SR-A.006 inherits the ≥32-character recommendation pending confirmation.

• **Weak controls specified as TO-BE gaps** (status Missing or Partial): hard-coded JWT secret fallback (SR-S.007/SR-A.006), authentication-only backend test endpoint (SR-Z.007), anonymous endpoint without abuse controls (SR-F-REG.007, SR-Z.009), forwarder trust by source IP only (SR-S.005), hard-coded CRL lifetime (SR-S.012), DNS-01 challenge stub (SR-F-CAI.007), upgrade without transaction/backup boundary (SR-D.004), empty/stale OpenAPI contract files (SR-F-INT.003/004), health checks without connector components (SR-V.002), connector credentials in plain config (SR-F-CAI.010, SR-D.008).

*End of KSPEC-003, version 0.2 (Draft). All 154 requirements carry Approval "Review Required"; no approval is recorded or inferred.*

# Kryptonian Formal Engineering Specification - Software Design

| Field | Value |
|---|---|
| Document ID | KSPEC-004 |
| Title | Software Design - System Architecture and Detailed Design |
| Version | 0.2 (Draft) |
| Status | Draft - pending review |
| Created | 2026-10-13 |
| Baseline commit | `682f996c8447afec13bc1fce5b7f59e6a06efa25` (branch `feat/windows-sandbox-installer`) |
| Repository | https://github.com/AAPM-RT-SEC/RTSec.Kryptonian |
| Revision history | 0.1 - 2026-10-13 - Initial draft from baseline inspection |
| Source references | docs/ARCHITECTURE.md, docs/flow.md, docs/IMPLEMENTATION-TRACKER.md, docs/ORNET-ALIGNMENT-2026-09-09.md, docs/device-enrollment.md, docs/DEPLOYMENT.md, docs/windows-installation.md, docs/windows-sandbox.md, docs/sequence-diagrams/*.mmd, src/RTSec.Kryptonian.*, src/Kryptonian.*, docker-compose.yml, deploy/, installer/ |
| Author | - (name-date-signature) |
| Reviewer | - (name-date-signature) |
| Approver | - (name-date-signature) |
| Reconciliation revision | 0.2 - 2026-10-13 - source/document audit and publication controls (KSPEC-016) |

## 1. Introduction

### 1.1 Purpose and scope

KSPEC-004 describes the software design of RTSec.Kryptonian (hereafter "the gateway"): a certificate enrollment, identity provisioning, and credential lifecycle management gateway speaking EST (RFC 7030) on the device side and adapting to institution-managed CA backends on the other side. It covers system context; component architecture; deployment topology (Docker, Windows installer, database options); security trust boundaries; principal data flows and sequence diagrams for the six principal workflows; state machines and the database conceptual model; certificate lifecycle design and backend connector architecture; failure recovery; concurrency; configuration and secrets management; external dependencies; and an explicit AS-IS vs TO-BE architecture comparison with PROPOSED items.

This document describes **enterprise healthcare IT cybersecurity infrastructure**. Per KSPEC-000 §3 it is **not** a regulated medical device, performs **no clinical functions**, and contains no medical-device regulatory classification content. Certificate renewal here means renewal of cryptographic credentials only; it never recertifies clinical safety, regulatory status, or clinical capability [KSPEC-000 §3].

### 1.2 Provenance and classification legend

Every substantive assertion carries exactly one evidence provenance class (KSPEC-000 §5): **VERIFIED**, **CODE-OBSERVED**, **DOCUMENTED**, **INFERRED**, **PROPOSED**, or **UNKNOWN**. Architecture elements and behavior are additionally classified **AS-IS** (present at the baseline commit), **TO-BE** (normative target behavior), or **PROPOSED** (requires stakeholder approval before becoming normative) (KSPEC-000 §4). Where a diagram is adapted from an existing repository sequence diagram, the provenance of that source is noted. Defects and prototype shortcuts observed at baseline are recorded as findings/gaps, never reproduced as intended requirements.

### 1.3 Requirement references

KSPEC-003 contains the canonical requirement register. Area-level design references are navigation aids; concrete bindings are maintained in KSPEC-009 §§4 and 7. No area reference allocates a new requirement or substitutes for a concrete verification obligation.

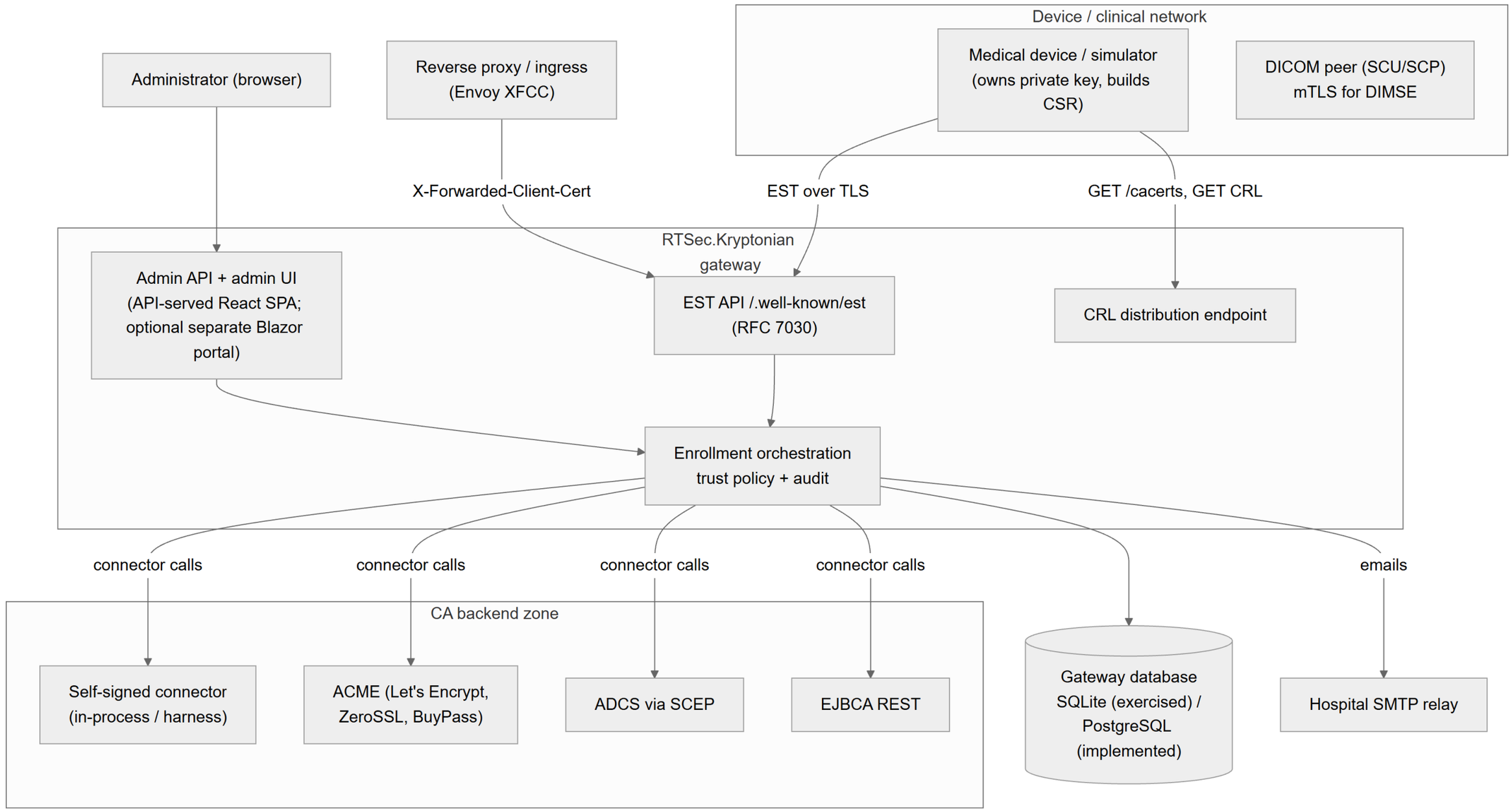
### 1.4 Design evidence base

| Evidence | Provenance |
|---|---|
| Layer structure, entity model, connector abstraction, middleware pipeline, hosted services | CODE-OBSERVED (source inspection of `src/*` at this baseline) |
| Enrollment/renewal/revocation/activation behavior and live DICOM mTLS evidence | VERIFIED (source inspection plus recorded executed evidence under `artifacts/developer/verify-*/` and tests listed in IMPLEMENTATION-TRACKER.md) |
| Docker Compose and Windows installer behavior | CODE-OBSERVED (compose files, installer scripts) plus DOCUMENTED run notes in docs/windows-installation.md, docs/windows-sandbox.md |
| ADCS/EJBCA interoperability with a real hospital CA | UNKNOWN at baseline (IMPLEMENTATION-TRACKER.md: hospital enrollment/revocation interoperability remains unverified) |
| PostgreSQL deployment | CODE-OBSERVED (schema-upgrade SQL exists); only SQLite persistence was exercised (IMPLEMENTATION-TRACKER.md) |

## 2. System context

The gateway sits between medical devices that speak one standard enrollment protocol (EST) and whichever hospital CA backend is authorized to sign device credentials. It is a policy decision point and trust registry, not a pass-through relay: it tracks devices, enforces activation and trust policy, selects the CA backend per EST profile, persists selected lifecycle outcomes (complete auditing is TO-BE, GAP-038), and only forwards approved CSRs [DOCUMENTED - docs/flow.md; consistent with source, CODE-OBSERVED].

## Diagram KSPEC-004-1




Rendered from 04-SOFTWARE-DESIGN.md. Diagram sheets use larger page sizes to preserve readable labels.

## 2.1 External actors and systems

### EST device client

**Interaction:** `/cacerts` bootstrap, `/simpleenroll` (activation or certificate-authenticated), `/simplereenroll`

**Classification:** AS-IS

**Provenance:** VERIFIED (independent curl HTTP Basic EST over real HTTPS, no private enrollment headers - IMPLEMENTATION-TRACKER.md)

### DICOM peers

**Interaction:** mTLS DIMSE associations using gateway-issued credentials on a **separate application path** from enrollment

**Classification:** AS-IS (demonstration)

**Provenance:** VERIFIED (two actual mTLS C-STORE transfers with SOP Instance UID read-back, IMPLEMENTATION-TRACKER.md)

### Administrator

**Interaction:** Browser against admin API/UI: devices, certificates, CA backends, EST profiles, users, API keys, notification and gateway settings, revocation

**Classification:** AS-IS

**Provenance:** CODE-OBSERVED (Controllers, Web, Ui projects)

### CA backends

**Interaction:** Self-signed (in-process and harness variants), ACME; ADCS via SCEP client; EJBCA REST

**Classification:** AS-IS (connectors present)

**Provenance:** CODE-OBSERVED; real-hospital interoperability UNKNOWN

### CaHarness

**Interaction:** Stand-in CA backend exposing EST-compatible and ACME-compatible APIs for demo/scoring

**Classification:** AS-IS (test/demo component)

**Provenance:** CODE-OBSERVED

### Database

**Interaction:** SQLite (exercised) / PostgreSQL 16 (implemented, additive SQL upgrades)

**Classification:** AS-IS

**Provenance:** VERIFIED (restart on populated SQLite preserved configured profile, issuer and devices) / CODE-OBSERVED (Npgsql branch)

### SMTP relay

**Interaction:** Rejection and near-expiry email via MailKit

**Classification:** AS-IS

**Provenance:** CODE-OBSERVED (MailKitSmtpSender, NotificationSettings)

### Reverse proxy / Envoy ingress

**Interaction:** May forward client certificates via `X-Forwarded-Client-Cert` (Hash/Cert/Chain format)

**Classification:** AS-IS

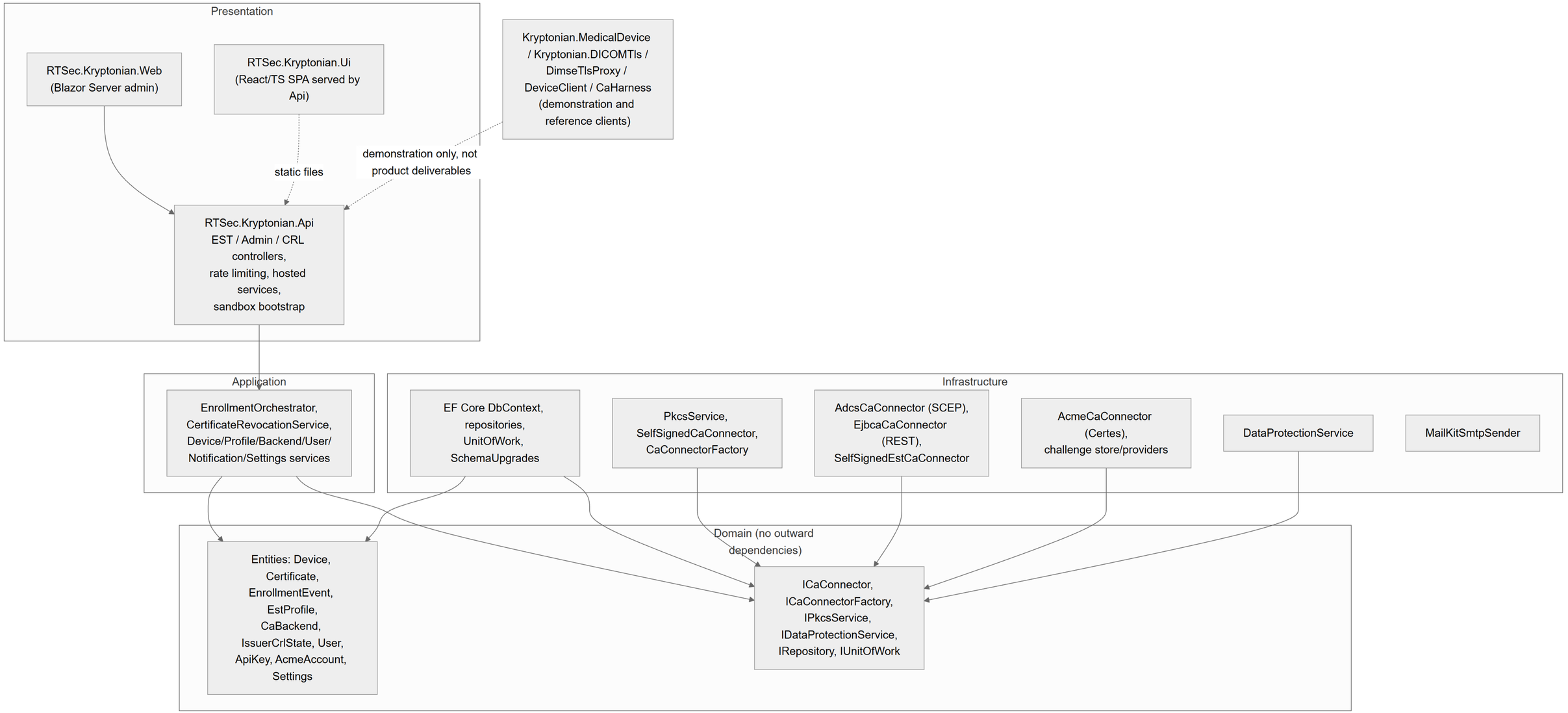
**Provenance:** CODE-OBSERVED (CertificateForwarding options in Program.cs)

# 3. Component architecture

## 3.1 Clean-architecture layers

The solution follows clean-architecture layering with dependency inversion: the domain layer defines entities, enums, value objects, and interfaces; application services orchestrate; infrastructure implements persistence, cryptography, and CA connectors; the API host wires everything [CODE-OBSERVED - RTSec.Kryptonian.sln, project references].

## Diagram KSPEC-004-2




Rendered from 04-SOFTWARE-DESIGN.md. Diagram sheets use larger page sizes to preserve readable labels.

## 3.2 Component inventory

### `RTSec.Kryptonian.Api`

**Layer:** Host
**Responsibility:** Controllers (Est, Devices, Certificates, Crl, CaBackends, EstProfiles, Users, Auth, ApiKeys, NotificationSettings, GatewaySettings, Logs, Status, AcmeChallenge), Kestrel HTTPS + client-cert listeners, rate limiting, `CertificateExpiryWatcher`, sandbox bootstrap
**Classification:** AS-IS
**Provenance:** CODE-OBSERVED

### `RTSec.Kryptonian.Application`

**Layer:** Application
**Responsibility:** Enrollment orchestration, revocation, device/profile/backend/user/notification/gateway-settings services, CSR and returned-certificate policy enforcement, notification dispatch abstraction
**Classification:** AS-IS
**Provenance:** CODE-OBSERVED

### `RTSec.Kryptonian.Domain`

**Layer:** Domain
**Responsibility:** Entities, enums (`DeviceStatus`, `CertificateStatus`, `EnrollmentStatus`, `CaBackendType`, `UserRole`, `RevocationReason`, `SmtpTlsMode`, ...), value objects, connector interfaces
**Classification:** AS-IS
**Provenance:** CODE-OBSERVED

### `RTSec.Kryptonian.Infrastructure`

**Layer:** Infrastructure
**Responsibility:** EF Core persistence (SQLite/Npgsql), repositories + unit of work, additive schema upgrades, PKCS services, in-process self-signed CA, harness connectors (ADCS SCEP, EJBCA REST), ACME via Certes, data protection, MailKit SMTP
**Classification:** AS-IS
**Provenance:** CODE-OBSERVED

### `RTSec.Kryptonian.Web`

**Layer:** Presentation
**Responsibility:** Blazor Server admin dashboard calling the admin API
**Classification:** AS-IS
**Provenance:** CODE-OBSERVED

### `RTSec.Kryptonian.Ui`

**Layer:** Presentation
**Responsibility:** React/TypeScript admin dashboard (Vite) served as static files by the API with immutable `/assets` caching
**Classification:** AS-IS
**Provenance:** CODE-OBSERVED

### `Kryptonian.MedicalDevice`

**Layer:** Demonstration

**Responsibility:** WPF device simulator with EST enrollment client (legacy activation headers retained for compatibility) and automatic renewal while open
**Classification:** AS-IS (demonstration only)
**Provenance:** DOCUMENTED (IMPLEMENTATION-TRACKER.md)

#### `Kryptonian.DICOMTls`

**Layer:** Demonstration
**Responsibility:** DIMSE-TLS demonstration terminating mTLS for DICOM associations; enforces issuer, TLS purpose, online revocation
**Classification:** AS-IS (demonstration only)
**Provenance:** VERIFIED (loopback proxy tests, IMPLEMENTATION-TRACKER.md)

#### `RTSec.Kryptonian.DimseTlsProxy`

**Layer:** Demonstration
**Responsibility:** Standalone DIMSE TLS proxy with bounded connection lifetimes and atomic PFX reload; expired replacement fails closed
**Classification:** AS-IS (demonstration only)
**Provenance:** VERIFIED (five loopback proxy tests, IMPLEMENTATION-TRACKER.md)

#### `RTSec.Kryptonian.CaHarness`

**Layer:** Test/demo
**Responsibility:** Stand-in CA backend used by harness connectors and ACME relay/challenge flows
**Classification:** AS-IS (test/demo)
**Provenance:** CODE-OBSERVED

#### `RTSec.Kryptonian.Bridge`, `RTSec.Kryptonian.DeviceClient`, `RTSec.Kryptonian.Shared`

**Layer:** Supporting
**Responsibility:** Supporting/client/shared components
**Classification:** AS-IS
**Provenance:** CODE-OBSERVED (solution membership)

### 3.3 Request pipeline (device- and admin-facing)

Middleware order in `Program.cs` [CODE-OBSERVED]:

1. Serilog structured logging (console + rolling file + live `LiveLogBroadcaster` ring buffer powering the admin Events page) with correlation/request-ID and client-IP enrichment.

2. Optional Windows-service hosting (`UseWindowsService`); sandbox mode requires the Production environment and injects in-memory configuration (ports, SQLite path, secrets) from `SandboxBootstrap`.

3. Kestrel listeners: in sandbox mode, distinct localhost HTTPS listeners for admin, EST, and CRL ports; the admin listener uses `ClientCertificateMode.NoCertificate`; the EST listener allows client certificates with optional configured client-CA trust (`ConfiguredClientCertificateTrust` over `Kryptonian:Tls:ClientCaFiles`).

4. Certificate forwarding for Envoy `X-Forwarded-Client-Cert` (structured `Hash=...;Cert="..."[;Chain="..."]` header, URL-encoded PEM leaf).

5. Static dashboard (content-hashed `/assets` cached immutable; `index.html` no-cache) with API-only fallback when no bundle exists.

6. EST-over-plain-HTTP rejection: HTTP 426 unless `Kryptonian:Est:AllowPlainHttp` is explicitly enabled (development escape hatch).

7. HTTPS redirection (default outside Development) and CORS policy `KryptonianUi` (configurable origins; defaults are the localhost:5173 development origins).

8. Authentication (JWT bearer for admin users; API-key authentication handler) and role-based authorization.

9. Controllers; health endpoint `GET /api/status/health`; SPA fallback excluding `/api` and `/.well-known`.

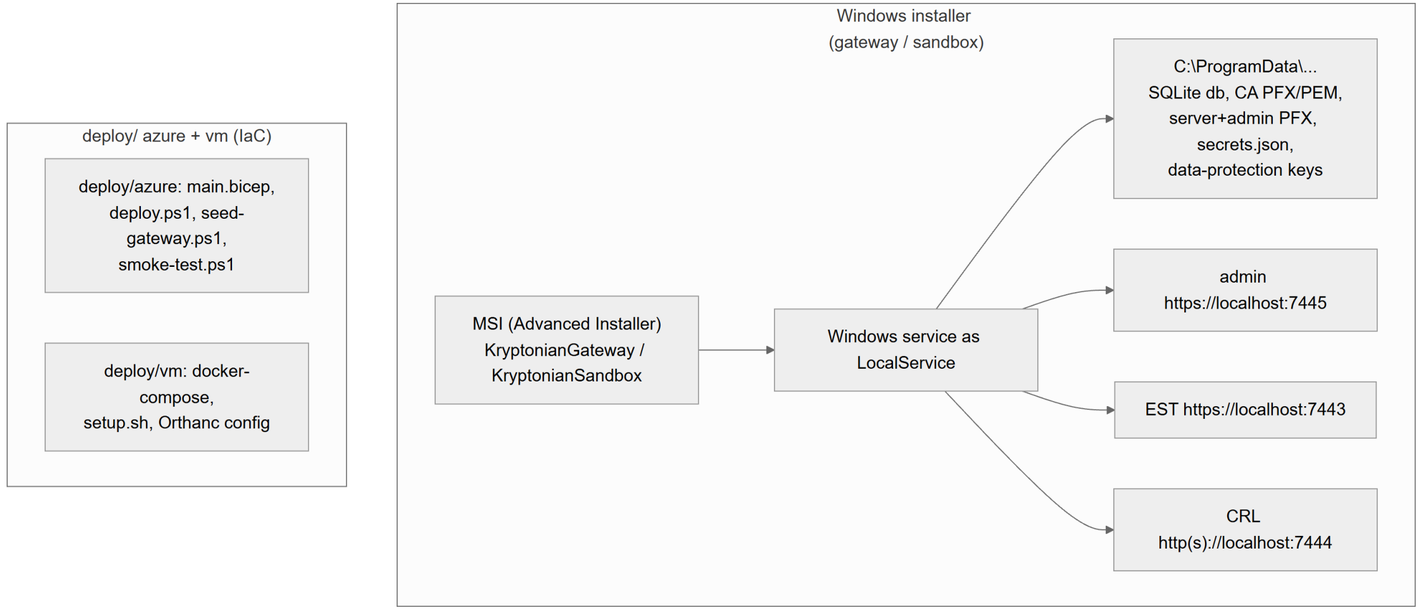
10. `AspNetCoreRateLimit` IP/endpoint rate limiting on EST paths [DOCUMENTED - docs/ARCHITECTURE.md shows the intended configuration; the package is referenced by source, CODE-OBSERVED].

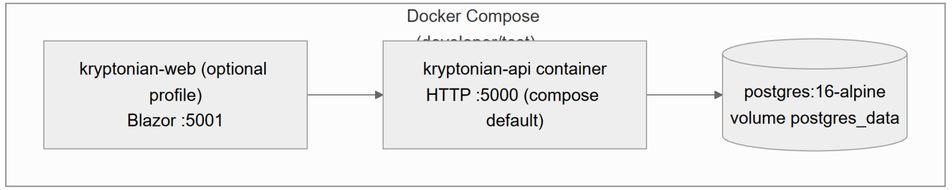
# 4. Deployment topology

## 4.1 Overview

Three deployment shapes exist at baseline [CODE-OBSERVED - docker-compose.yml, deploy/, installer/]:

## Diagram KSPEC-004-3




Rendered from 04-SOFTWARE-DESIGN.md. Diagram sheets use larger page sizes to preserve readable labels.

## 4.2 Docker Compose (AS-IS)

`docker-compose.yml` defines a PostgreSQL 16 container, the API container (built from `src/RTSec.Kryptonian.Api/Dockerfile`), and an optional `web` profile container for the Blazor UI [CODE-OBSERVED]. Notable AS-IS properties:

- API default ingress is `http://+:5000` in compose - TLS termination is expected to be added by the surrounding environment; this must be corrected for any real deployment (see §17, TO-BE B-2).
- Secrets are provided via environment variables with insecure development defaults (`POSTGRES_PASSWORD`, `ADMIN_API_KEYS`, `KRYPTONIAN_JWT_SECRET`, initial admin seed credentials).
- A self-signed CA can be mounted read-only at `/app/certs/ca.pfx` with a PFX password.
- Health checks: `pg_isready` for PostgreSQL and `curl /api/status/health` for the API.
- `docker-compose.hackathon.yml` provides the demonstration variant [CODE-OBSERVED, file present].
- `deploy/azure` contains Bicep IaC, deploy/seed/smoke scripts; `deploy/vm` contains a VM compose, setup script and Orthanc demo configuration [CODE-OBSERVED, file inventory].

## 4.3 Windows installer and sandbox topology (AS-IS)

The Windows installer ships two gateway personalities built from the same binaries [CODE-OBSERVED - installer/windows, SandboxBootstrap.cs; DOCUMENTED - windows-installation.md, windows-sandbox.md]:

- **KryptonianGateway** - persistent installation as a Windows service.
- **KryptonianSandbox** - local-only, offline preview: Windows service `KryptonianSandbox` running as LocalService, with mutable state under `C:\ProgramData\KryptonianSandbox` restricted to service/SYSTEM/administrators.

Sandbox bootstrap behavior [CODE-OBSERVED - SandboxBootstrap.cs]:

- Separate administration CA (`admin-ca.pfx`/`admin-ca.pem`) and device CA (`ca.pfx`/`ca.pem`), plus `server.pfx` (EST/CRL) and `admin.pfx` (admin listener); the administration CA is installed in the user store only inside a Windows Sandbox guest, never on the host [DOCUMENTED].
- Secrets persisted in `secrets.json` (CA PFX password, PFX password, JWT secret, admin API key); on first start a `48-byte` random secret is generated per field.
- State directory protection: ACL restriction to current identity, LocalSystem, LocalService, Administrators; reparse points rejected.
- Incompleteness guard: if some but not all required files exist, or if data-protection/DB state exists without CA material, startup **refuses to regenerate** certificate authority material rather than silently recreating keys.
- Distinct localhost ports: admin 7445 (no client certificates), EST 7443 (client certificates allowed), CRL 7444.
- Database provider forced to SQLite (`kryptonian.db` in the state directory); ASP.NET Core Data Protection keys stored under `dataprotection/`.

## 4.4 Database options

### SQLite

**Status:** AS-IS, exercised
**Notes:** Sandbox and developer flows; gateway restart on populated SQLite preserved configured profile, issuer and devices
**Provenance:** VERIFIED

### PostgreSQL 16

**Status:** AS-IS, implemented but not exercised

**Notes:** Npgsql provider with raw additive upgrade SQL in `SchemaUpgrades.cs`; connection pooling via Npgsql [DOCUMENTED - ARCHITECTURE.md]

**Provenance:** CODE-OBSERVED / IMPLEMENTATION-TRACKER.md

### EF Core `EnsureCreated` + additive upgrades

**Status:** AS-IS

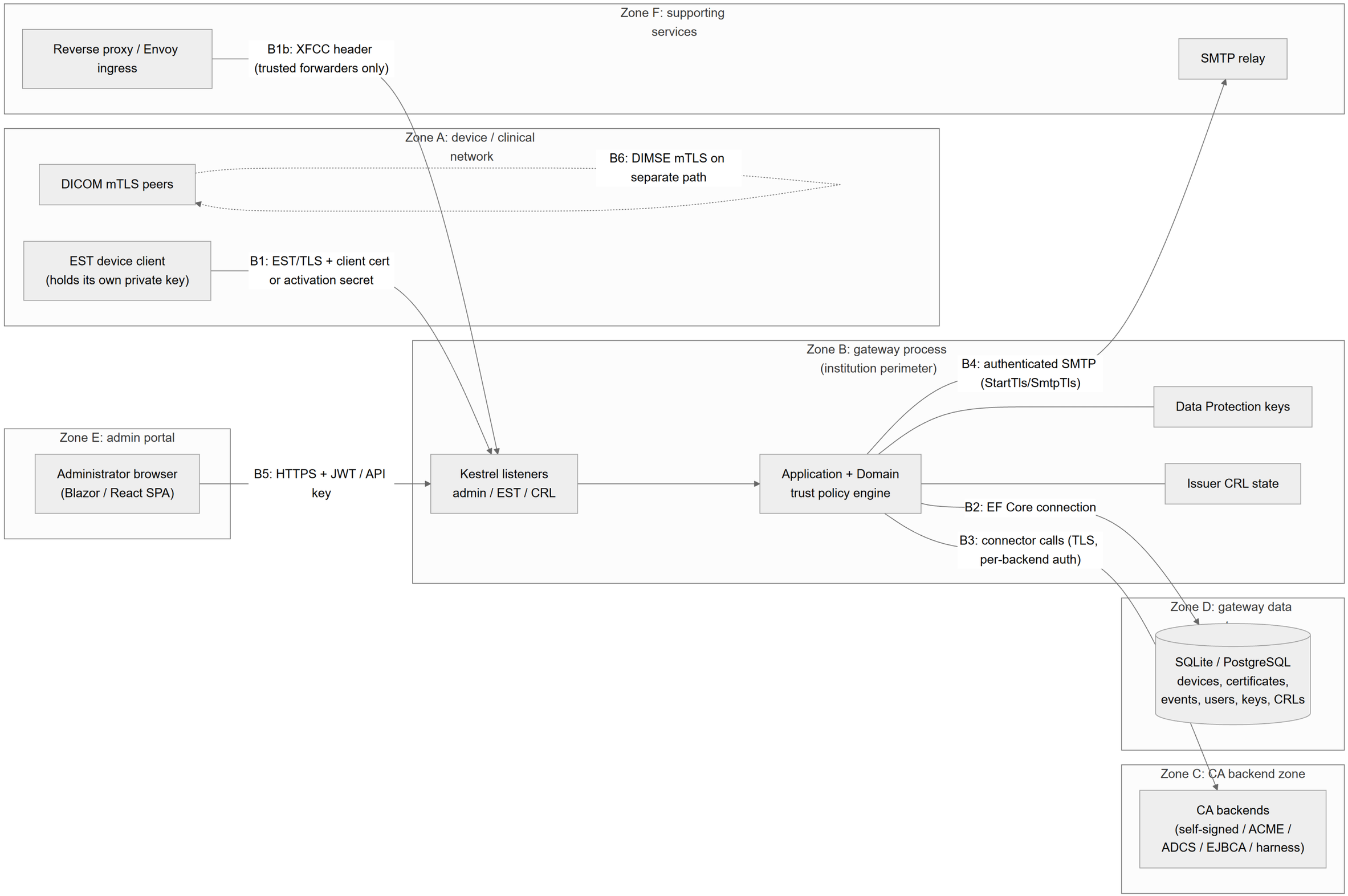
**Notes:** Existing installations were created with `EnsureCreated`; `SchemaUpgrades` performs additive column/table/index upgrades and never recreates a populated database

**Provenance:** CODE-OBSERVED (SchemaUpgrades.cs header comment and SQL)

# 5. Security trust boundaries

## 5.1 Trust-boundary diagram

## Diagram KSPEC-004-4




Rendered from 04-SOFTWARE-DESIGN.md. Diagram sheets use larger page sizes to preserve readable labels.

## 5.2 Boundary inventory

### B1

**Boundary:** Device-network → gateway (EST ingress)

**AS-IS controls:** HTTPS required for `/.well-known/est` (426 otherwise); optional Kestrel client-certificate validation against configured client CA files; per-profile client-certificate chain validation and trusted thumbprint lists; one-time activation code (hashed, expiring, single-use) for first enrollment; certificate-authenticated renewal; issuer-scoped profile routing with unknown-label rejection; rate limiting

**Classification / provenance:** AS-IS, VERIFIED (replay rejected, forwarded-certificate spoof rejected - IMPLEMENTATION-TRACKER.md)

### B1b

**Boundary:** Reverse proxy → gateway

**AS-IS controls:** Envoy `X-Forwarded-Client-Cert` header is parsed and trusted unconditionally once certificate forwarding is enabled; network placement of the gateway behind a trusted forwarder is a deployment assumption, not enforced in code

**Classification / provenance:** AS-IS risk finding → TO-BE (§17, C-3)

### B2

**Boundary:** Gateway → database

**AS-IS controls:** EF Core over SQLite/Npgsql; sensitive values encrypted with ASP.NET Core Data Protection (`RTSec.Kryptonian.SensitiveData.v1` purpose) - SMTP password, ACME account keys, EAB HMAC keys; activation codes stored hashed; file ACLs in Windows deployment; data-protection key ring persisted with state

**Classification / provenance:** AS-IS, CODE-OBSERVED

### B3

**Boundary:** Gateway → CA backend

**AS-IS controls:** Per-connector authentication (harness HTTP, ACME account key + optional EAB, SCEP, EJBCA REST credentials); backend disabled-state checked before use; issuer identity verified against stored certificate before revocation; remote revocation unsupported → fails closed (HTTP 501/503)

**Classification / provenance:** AS-IS, CODE-OBSERVED; CA outage behavior partially exercised (UNKNOWN for real hospital CAs)

### B4

**Boundary:** Gateway → SMTP relay

**AS-IS controls:** Authenticated SMTP via MailKit; TLS modes StartTls/SmtpTls/None; optional `TrustServerCertificate` bypass flag (off by default, explicit operator choice for internal-CA relays)

**Classification / provenance:** AS-IS, CODE-OBSERVED

### B5

**Boundary:** Admin portal → gateway

**AS-IS controls:** JWT bearer for users, hashed API keys with prefix + role + expiry, roles `Standard`/`DeviceAdmin`/`SystemAdmin`; sandbox admin listener explicitly `NoCertificate`

**Classification / provenance:** AS-IS, CODE-OBSERVED

### B6

**Boundary:** Gateway credentials → application layer (DICOM mTLS)

**AS-IS controls:** Peers validate issuer, TLS purpose (EKU), hostname, and online revocation against the gateway CRL; revocation is not instant for established associations (bounded lifetimes)

**Classification / provenance:** AS-IS (demonstration), VERIFIED (unknown/expired/revoked client rejection - IMPLEMENTATION-TRACKER.md)

Distinct separations are preserved per KSPEC-000 §3: device identity (X.509 holder), certificate enrollment authorization (activation/approval), network trust (TLS/mTLS peer authentication), and application-level authorization are never conflated, and clinical capability is never derived from Kryptonian state.

# 6. Principal data flows

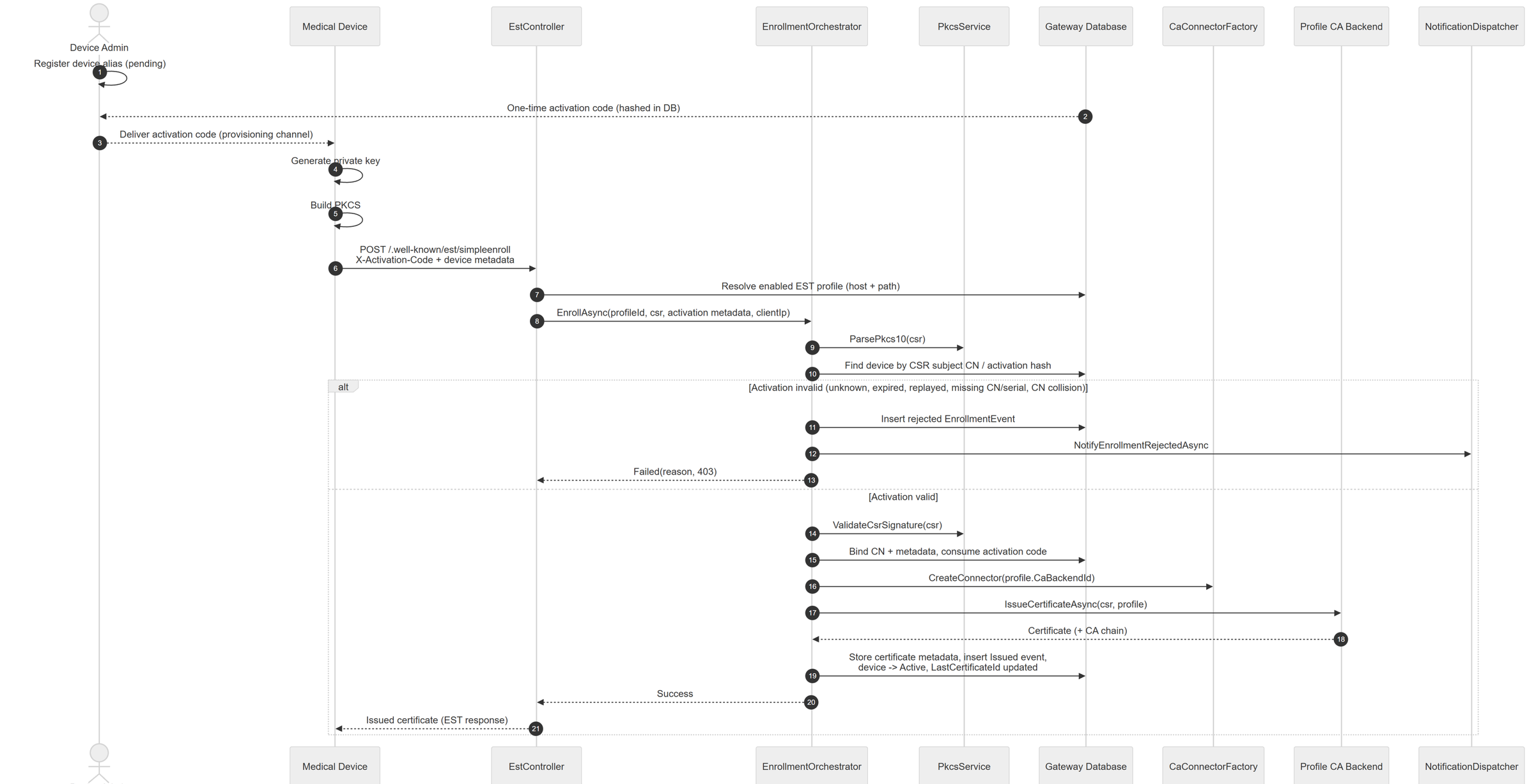
| Flow | Summary | Classification |
|---|---|---|
| Enrollment (registration → activation → issuance) | Administrator creates a pending device alias; gateway issues a one-time activation code (stored hashed). Device generates a key pair and CSR and presents the code plus metadata over EST HTTPS. Gateway validates the code (exists, unexpired, unused, belongs to a pending device), validates the CSR signature, binds the CSR CN and metadata to the registration, consumes the code, routes to the profile's CA backend, stores certificate metadata, marks the device active, and audits an `Issued` event. | AS-IS, VERIFIED |
| Re-enrollment / renewal | Active devices renew by presenting the existing certificate (native TLS client certificate), never the activation code. Gateway checks device status, enforces CSR and returned-certificate policy, preserves the approved identity, and issues a new credential with a new key; a pending response is supported so devices can retry. Automatic renewal runs while the device simulator is open. | AS-IS, VERIFIED |
| Revocation | Administrator revokes a certificate. Gateway verifies the certificate chains to the configured issuer, gathers all revoked serials for the issuer, increments the issuer CRL number, requests a signed issuer-scoped CRL from the connector, and persists it **transactionally** with the certificate status change. Unsupported backends fail closed. | AS-IS, VERIFIED (administrator revocation → native online X509Chain reports Revoked - IMPLEMENTATION-TRACKER.md) |
| Admin operations | CRUD on devices, CA backends, EST profiles, users, API keys, notification settings/recipients, gateway settings; partial profile updates preserve omitted trust lists; logs/events views. | AS-IS, CODE-OBSERVED |
| CRL distribution | Issuer-scoped signed CRLs served from `IssuerCrlState` via the CRL controller/listener; peers refresh periodically. Prototype CRL lifetime is 60 seconds; the HTTP listener denies non-CRL requests. | AS-IS, CODE-OBSERVED + VERIFIED (live checks) |
| Bootstrap (cacerts) | `/cacerts` resolves the **profile's own** CA backend (not a global active backend), fetches the chain via the connector, and encodes PKCS#7 for the EST response. | AS-IS, CODE-OBSERVED |

# 7. Sequence diagrams for the six principal workflows

Diagrams are adapted from `docs/sequence-diagrams/*.mmd` [DOCUMENTED] and cross-checked against `EnrollmentOrchestrator.cs`, `CertificateRevocationService.cs`, `CertificateExpiryWatcher.cs`, and the controllers [CODE-OBSERVED].

### 7.1 Registration → activation → enrollment

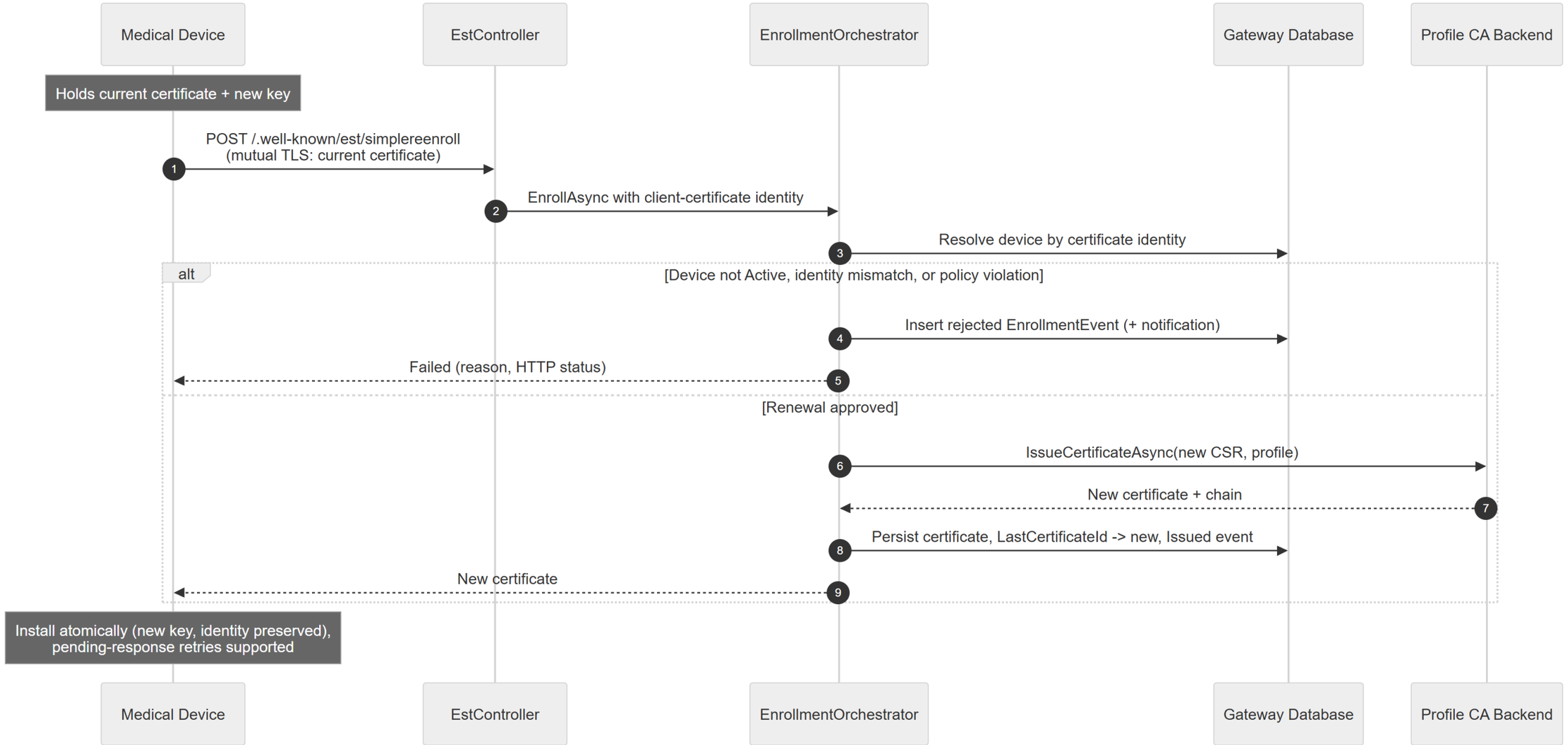
## Diagram KSPEC-004-5




Rendered from 04-SOFTWARE-DESIGN.md. Diagram sheets use larger page sizes to preserve readable labels.

### 7.2 Re-enrollment renewal

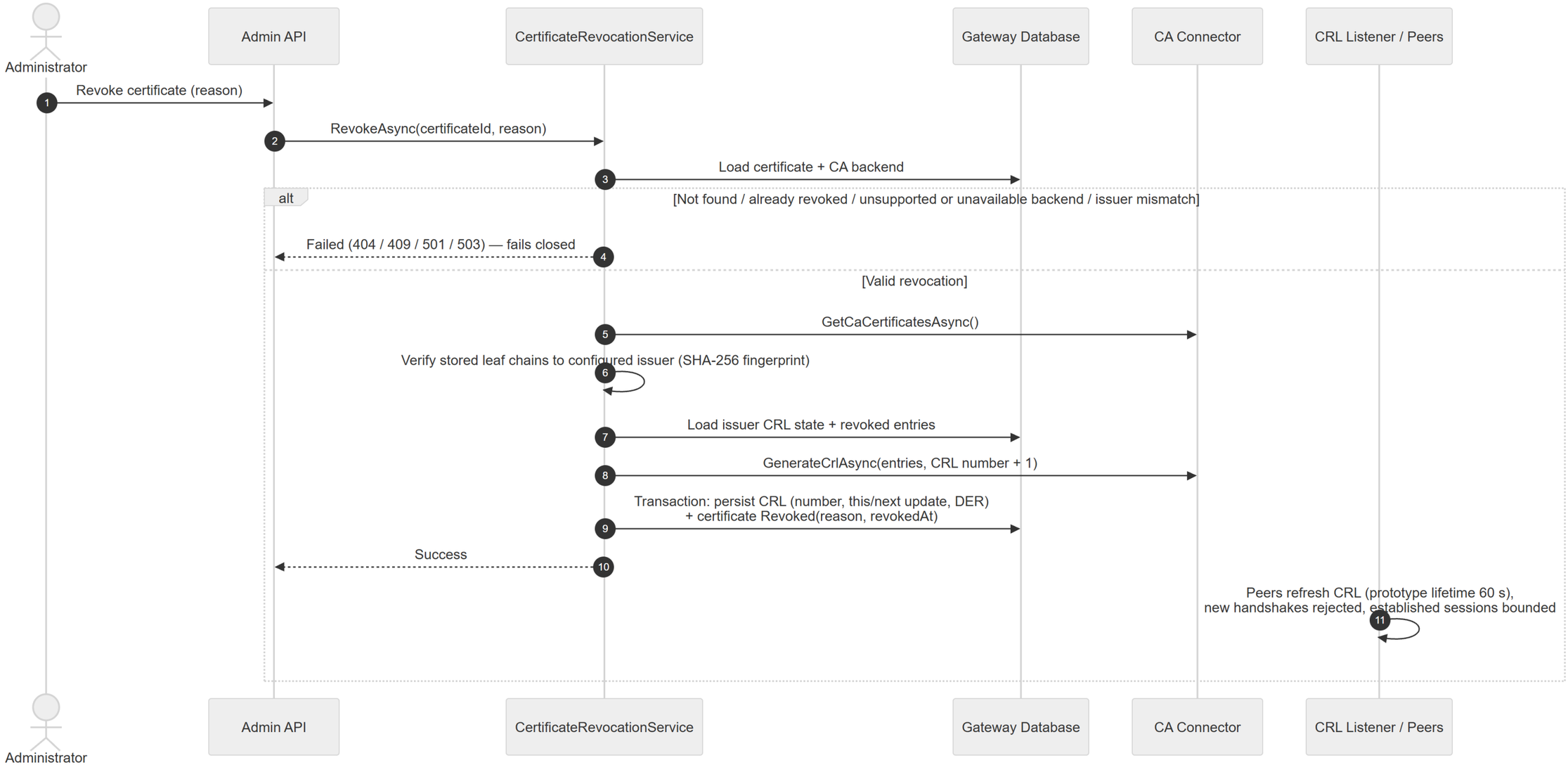
## Diagram KSPEC-004-6




Rendered from 04-SOFTWARE-DESIGN.md. Diagram sheets use larger page sizes to preserve readable labels.

### 7.3 Revocation and trust removal

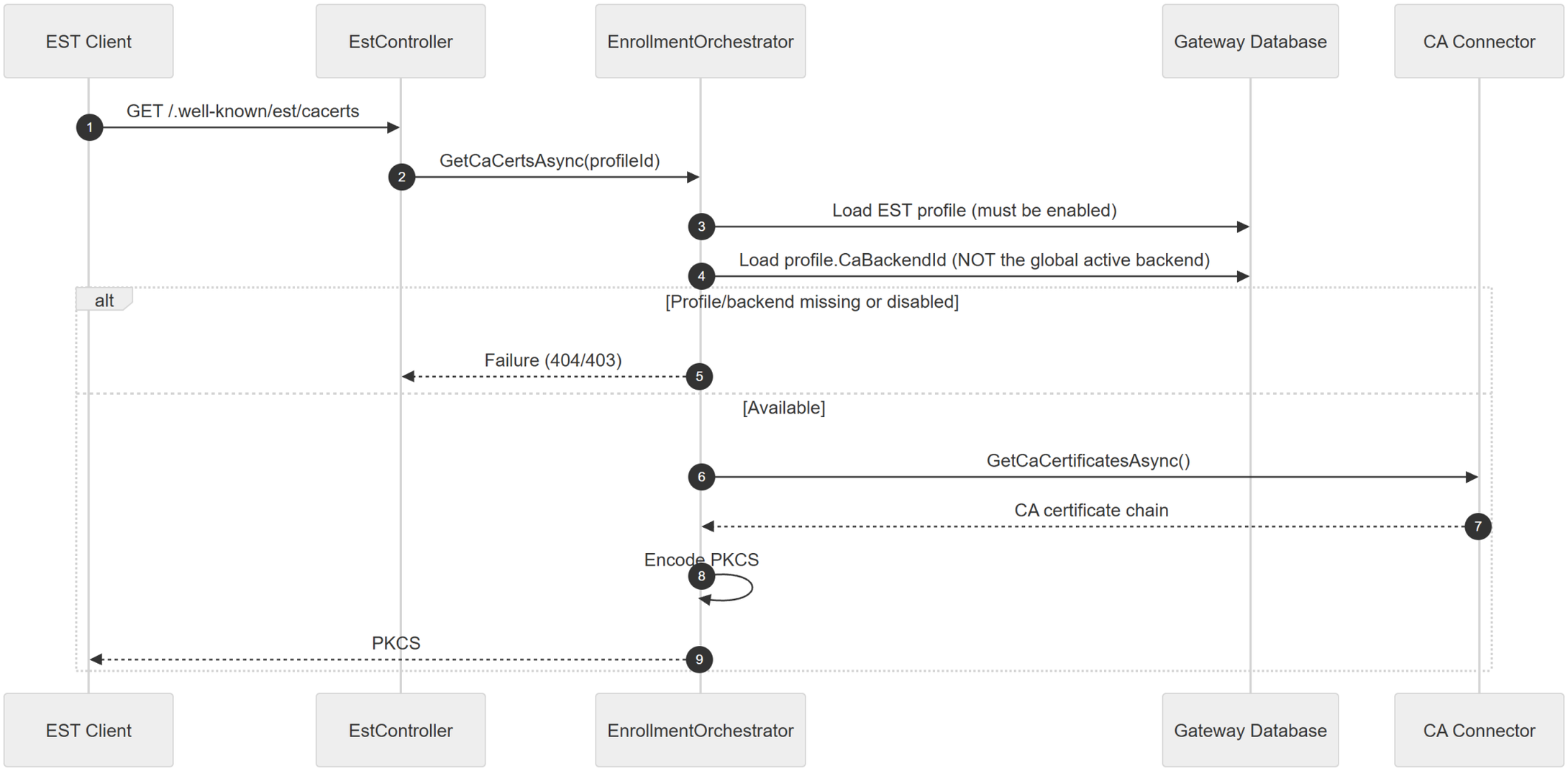
## Diagram KSPEC-004-7




Rendered from 04-SOFTWARE-DESIGN.md. Diagram sheets use larger page sizes to preserve readable labels.

### 7.4 EST cacerts bootstrap

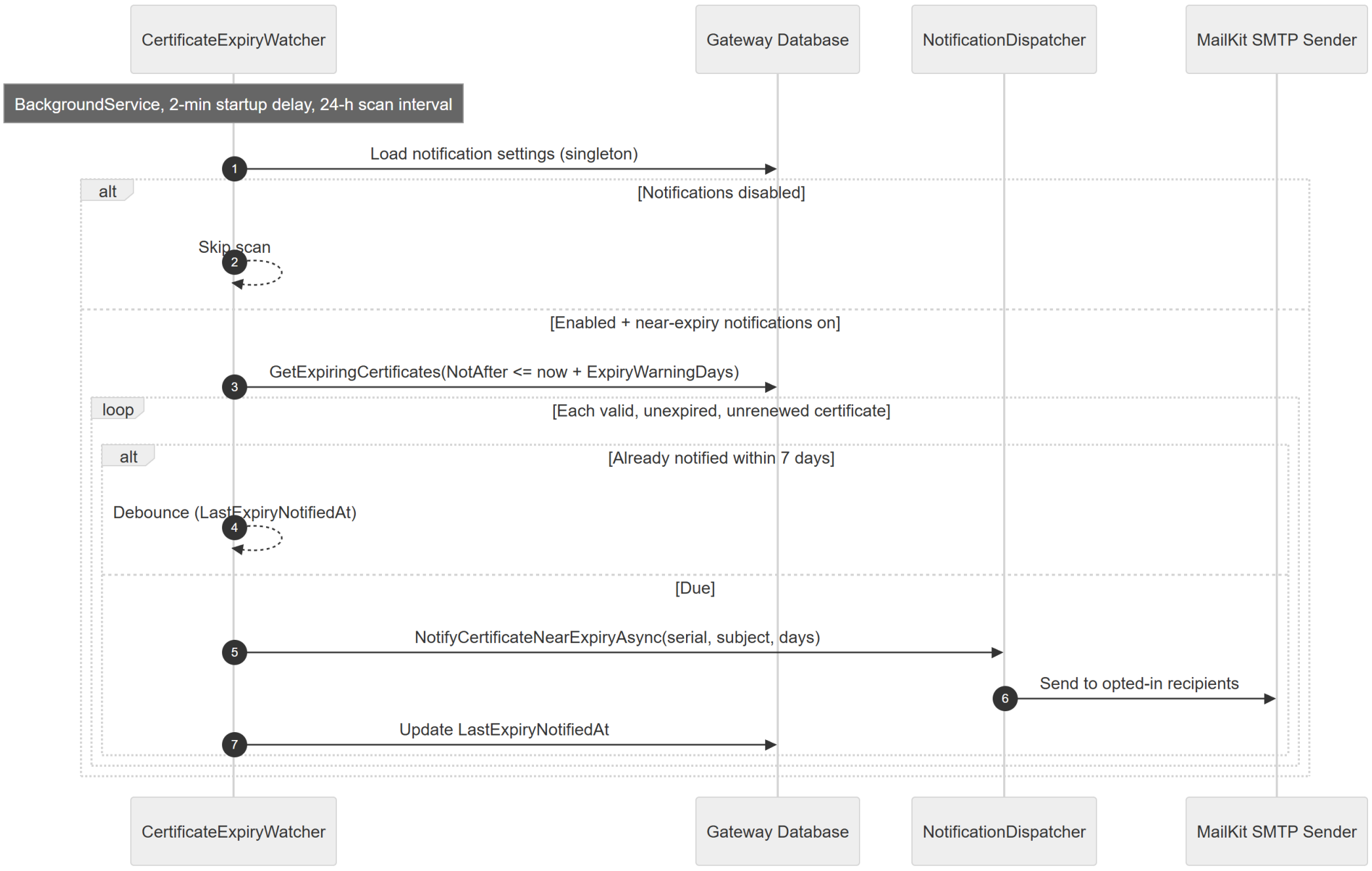
## Diagram KSPEC-004-8




Rendered from 04-SOFTWARE-DESIGN.md. Diagram sheets use larger page sizes to preserve readable labels.

### 7.5 Expiry monitoring and notifications

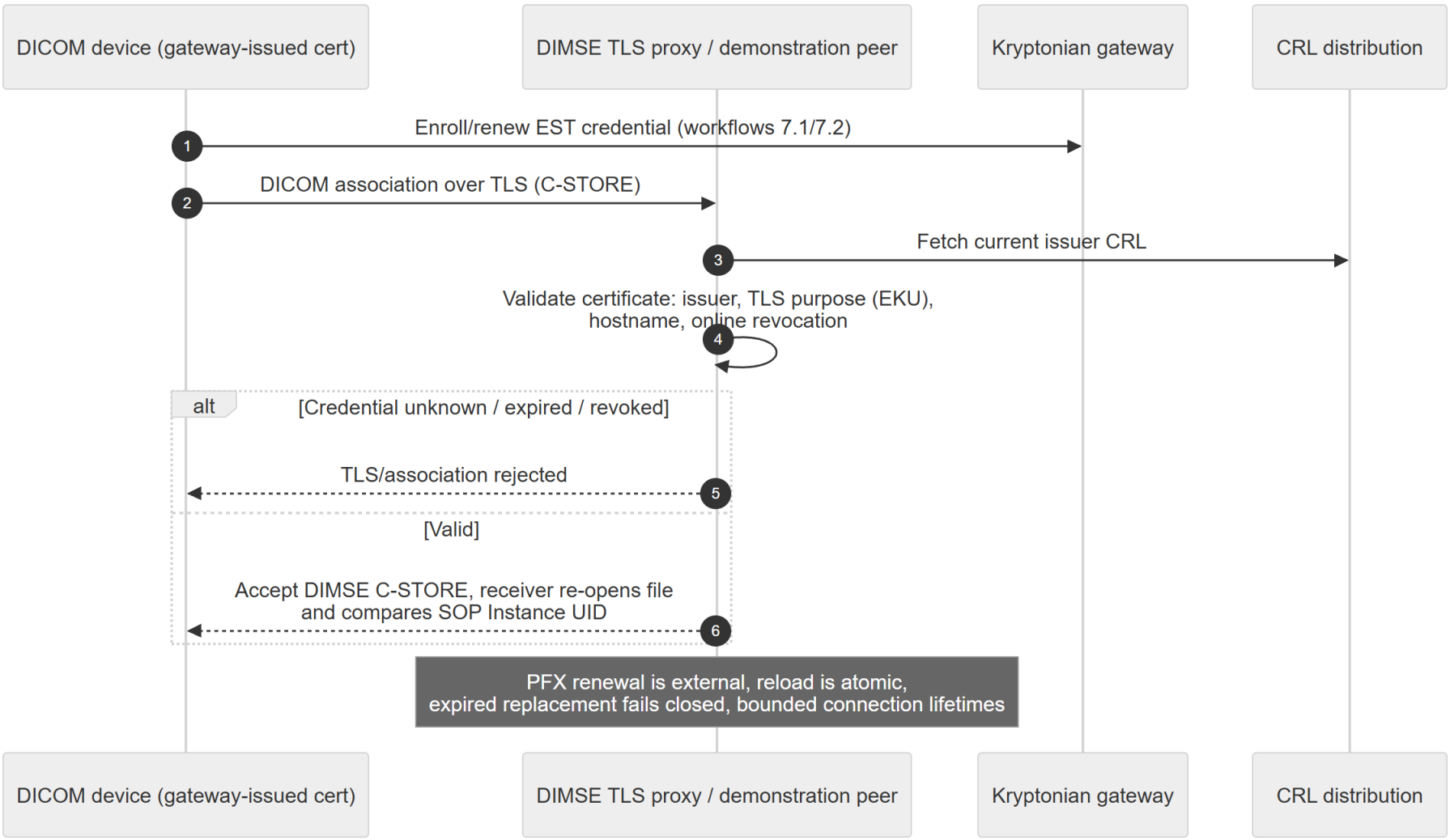
## Diagram KSPEC-004-9




Rendered from 04-SOFTWARE-DESIGN.md. Diagram sheets use larger page sizes to preserve readable labels.

### 7.6 DICOM mTLS demonstration

## Diagram KSPEC-004-10



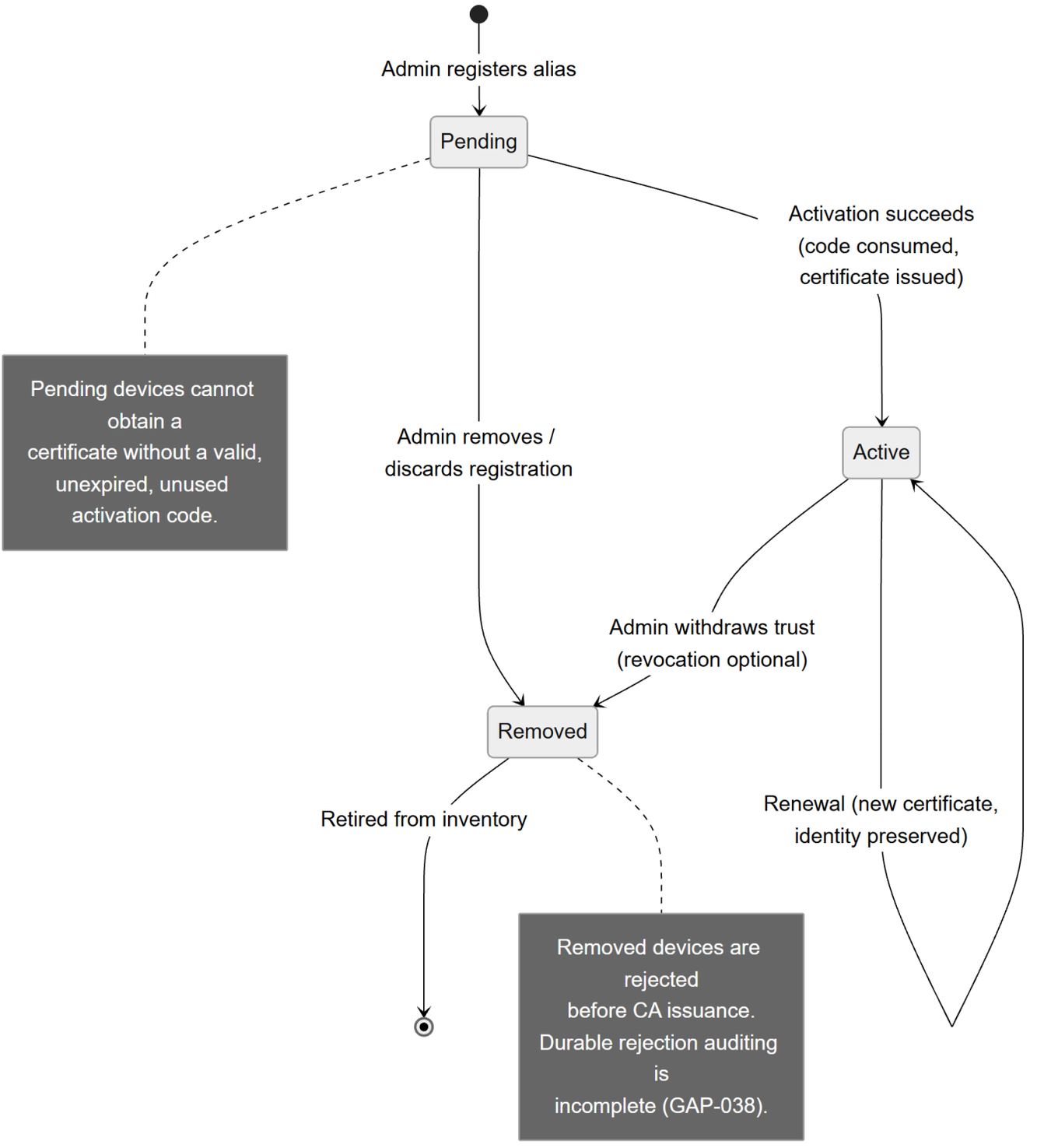

Rendered from 04-SOFTWARE-DESIGN.md. Diagram sheets use larger page sizes to preserve readable labels.

# 8. State machines

## 8.1 Device status lifecycle (AS-IS)

The `DeviceStatus` enum at baseline is `Pending`, `Active`, `Removed` [CODE-OBSERVED]. The earlier design sketches in docs/flow.md (`untrusted`, `retired`) are **not** present in the baseline enum; trust withdrawal is expressed as `Removed` (device cannot enroll or renew) [DOCUMENTED - docs/flow.md; CODE-OBSERVED - Device.cs, device-enrollment.md].

## Diagram KSPEC-004-11

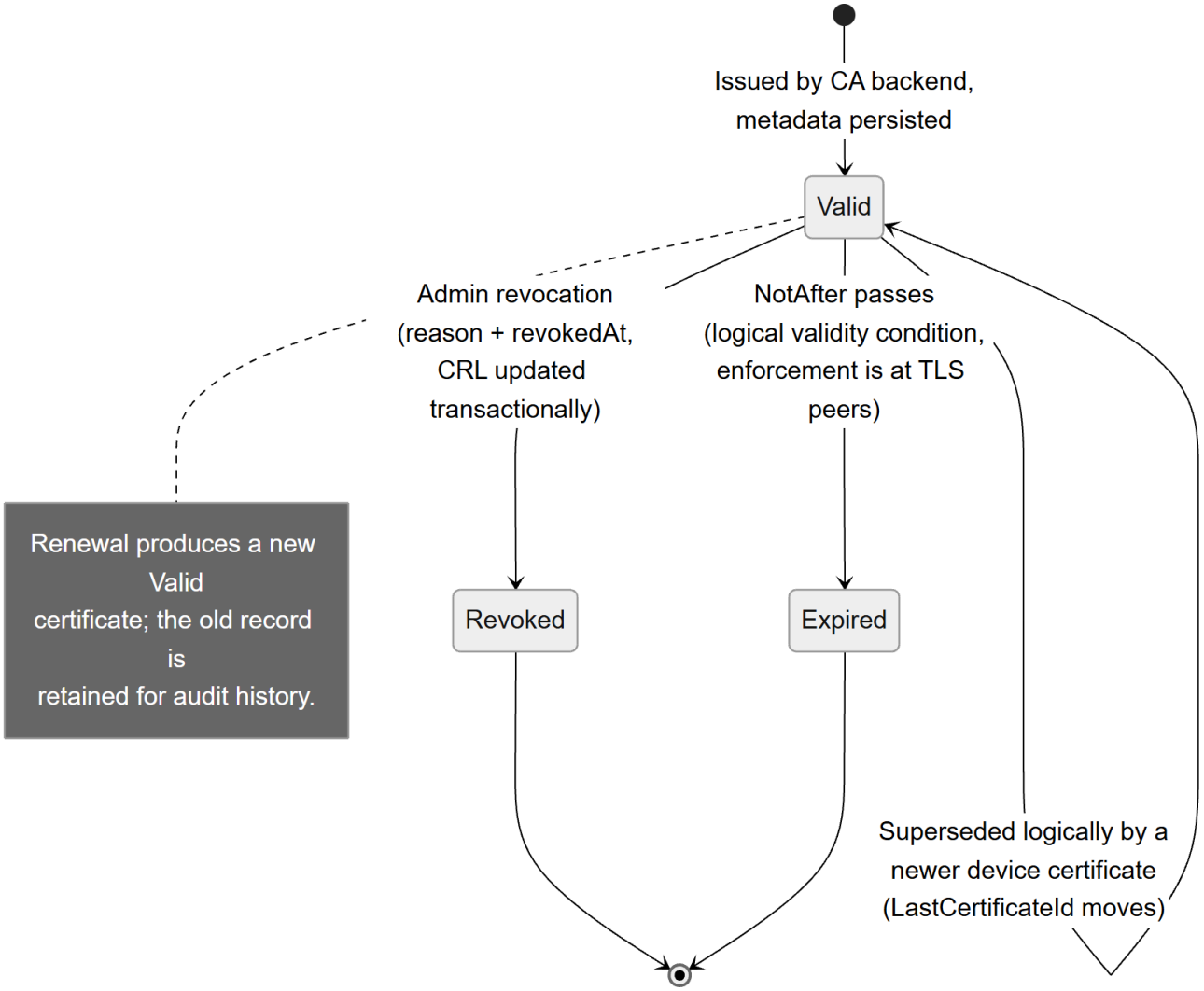



Rendered from 04-SOFTWARE-DESIGN.md. Diagram sheets use larger page sizes to preserve readable labels.

## 8.2 Certificate lifecycle (AS-IS validity view)

Expiration is a time-based validity condition. Baseline source checks NotAfter and the watcher skips already-expired certificates; no automatic writer that changes the stored Certificate.Status to Expired was observed. The diagram separates that logical condition from administrative revocation, which explicitly persists Revoked status.

## Diagram KSPEC-004-12

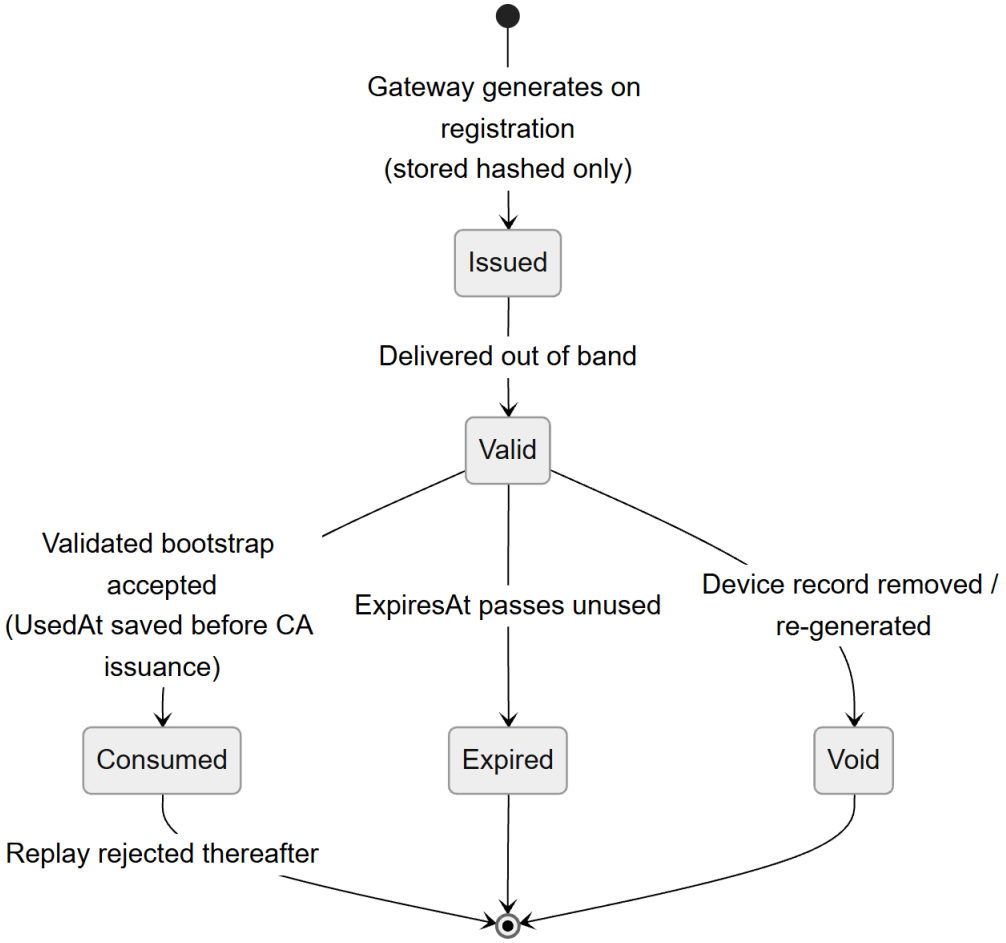



Rendered from 04-SOFTWARE-DESIGN.md. Diagram sheets use larger page sizes to preserve readable labels.

## 8.3 Activation code lifecycle (AS-IS)

Activation codes have no separate entity; the lifecycle is carried by fields on the pending device (`ActivationCodeHash`, `ActivationCodeExpiresAt`, `ActivationCodeUsedAt`) [CODE-OBSERVED - Device.cs]:

## Diagram KSPEC-004-13

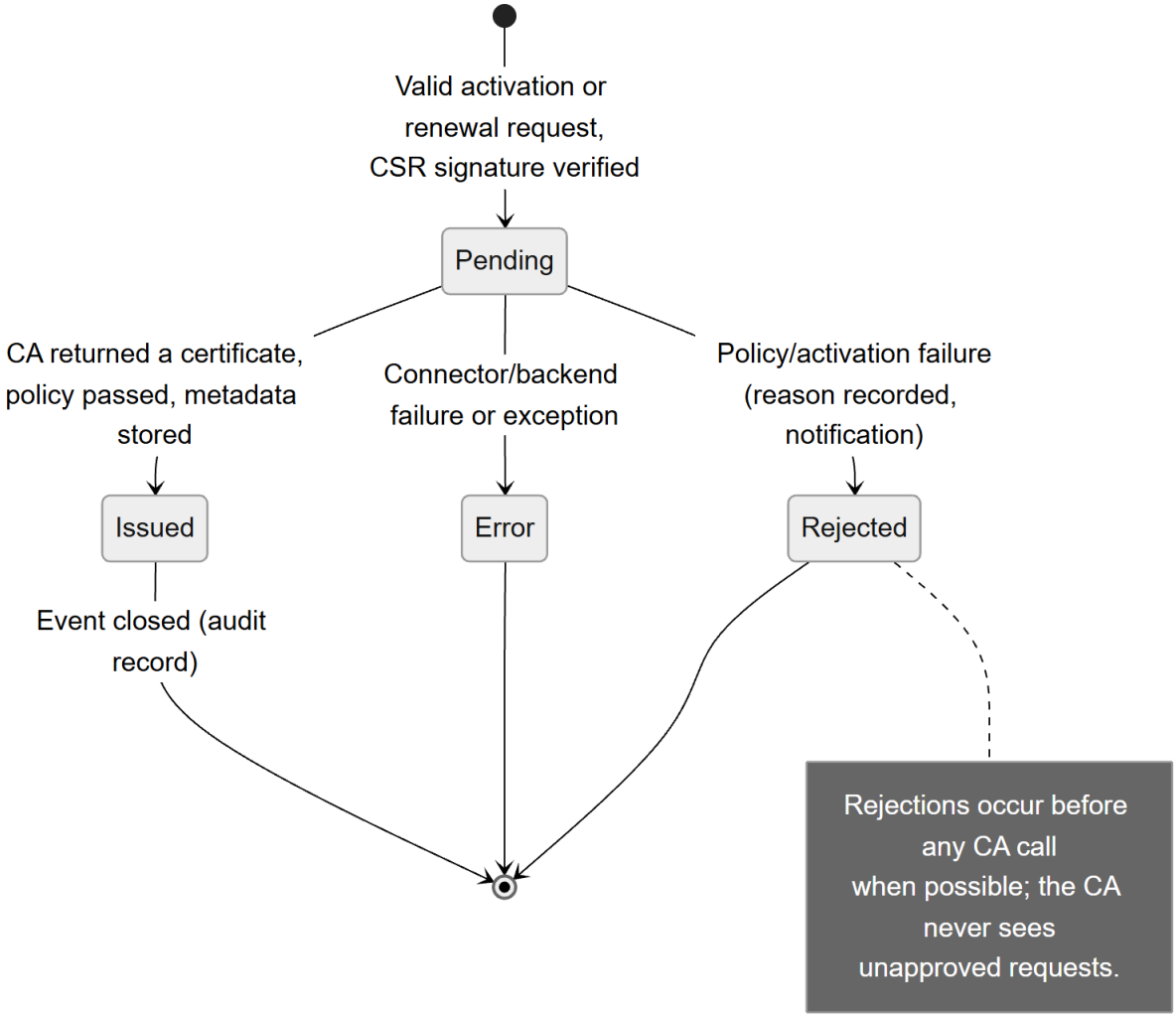



Rendered from 04-SOFTWARE-DESIGN.md. Diagram sheets use larger page sizes to preserve readable labels.

## 8.4 Enrollment request lifecycle (AS-IS)

`EnrollmentStatus` is `Issued`, `Pending`, `Rejected`, `Error` [CODE-OBSERVED - EnrollmentStatus.cs, EnrollmentEvent.cs]:

## Diagram KSPEC-004-14



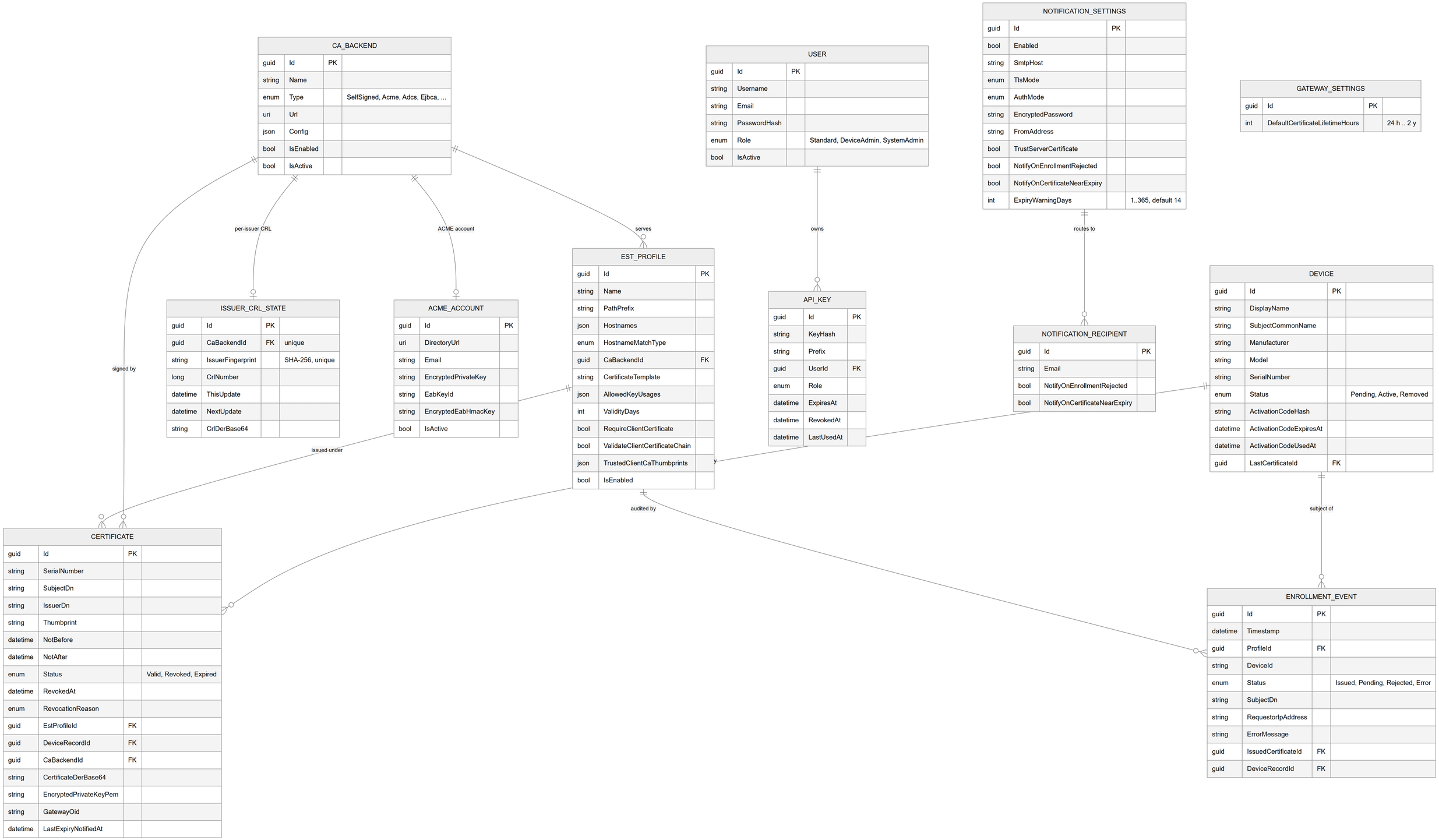

Rendered from 04-SOFTWARE-DESIGN.md. Diagram sheets use larger page sizes to preserve readable labels.

# 9. Database conceptual model

## 9.1 Entity-relationship diagram

Conceptual model derived from the domain entities and `KryptonianDbContext` [CODE-OBSERVED].

## Diagram KSPEC-004-15




Rendered from 04-SOFTWARE-DESIGN.md. Diagram sheets use larger page sizes to preserve readable labels.

## 9.2 Key relations and notes

| Relation / constraint | Notes | Provenance |
|---|---|---|
| CaBackend → EstProfile (1 → 0..n) | Profile owns its issuer; `/cacerts` and enrollment resolve the backend **by profile**, not the globally active backend | CODE-OBSERVED (EnrollmentOrchestrator) |
| CaBackend → IssuerCrlState (1 → 0..1) | Unique per backend; SHA-256 `IssuerFingerprint` binds the CRL to the exact CA certificate; a rotated CA certificate blocks revocation with 409 until a new backend record is created | CODE-OBSERVED (CertificateRevocationService, SchemaUpgrades) |
| Device → Certificate (1 → 0..n) | Full history retained; `Device.LastCertificateId` points at the newest and is used by the expiry watcher to detect renewal | CODE-OBSERVED |
| Certificate → EnrollmentEvent (1 → 0..n) | Every attempt audited, including rejections and errors, with requestor IP and reason | CODE-OBSERVED |
| User → ApiKey (1 → 0..n) | Keys stored hashed with a display prefix, role, expiry, revocation, last use | CODE-OBSERVED |
| NotificationSettings → NotificationRecipient (1 → 0..n) | Per-recipient per-event opt-in; SMTP password encrypted via Data Protection and never returned over the API | CODE-OBSERVED |
| Uniqueness / integrity | Unique index `(ca_backend_id, serial_number)` on certificates; unique `issuer_fingerprint` on CRL state; activation requires the CSR CN not already bound to another device | CODE-OBSERVED (SchemaUpgrades.cs, orchestrator) |
| GatewaySettings | Singleton carrying the default certificate lifetime (bounded 24 h to 2 years, default 24 h - supporting short-lived demonstration credentials) | CODE-OBSERVED |

The `Certificate.EncryptedPrivateKeyPem` field indicates server-side key generation / archival capability in the schema; its production use and key-protection policy are TO-BE subjects (see §17) [CODE-OBSERVED field; policy UNKNOWN].

# 10. Certificate lifecycle design

| Phase | Design | Classification / provenance |
|---|---|---|
| Bootstrap trust | Device fetches `/cacerts` for its profile (PKCS#7 chain) before first enrollment; profile-scoped issuer prevents cross-profile trust confusion | AS-IS, CODE-OBSERVED |
| Identity binding | Activation binds the CSR subject CN, manufacturer, model, serial to the pending alias; CN collisions rejected; identity is preserved across renewals; a gateway OID extension under `1.3.6.1.4.1.99999.*` is carried in issued certificates and used for identity matching | AS-IS, CODE-OBSERVED + VERIFIED (enrollment identity binding, IMPLEMENTATION-TRACKER.md) |
| Issuance | CSR signature validated; CSR and returned-certificate policy enforced (subject DN rules, key usage, validity) via `EnrollmentCertificatePolicy`; gateway stores serial, thumbprint, issuer DN, PEM/DER, profile, backend | AS-IS, VERIFIED (PR 43 evidence) |
| Validity / monitoring | Default lifetime from `GatewaySettings` or profile `ValidityDays`; `CertificateExpiryWatcher` warns 1-365 days ahead (default 14), debounced 7 days per certificate, skips certificates already renewed | AS-IS, CODE-OBSERVED |
| Renewal | Certificate-authenticated re-enrollment only (activation codes never reusable); new key each renewal; approved identity preserved; pending-response retry supported; device simulator renews automatically while open | AS-IS, VERIFIED |
| Revocation | Administrator-initiated; issuer-verified; issuer-scoped signed CRL with monotonic CRL number; transactional persistence; unsupported backends fail closed (501/503) | AS-IS, VERIFIED |
| Retirement | Removed devices are blocked from enrollment/renewal; short demo lifetimes mean untrusted devices fall out of trust quickly; existing valid peer credentials keep working within their policy limits | AS-IS + DOCUMENTED (ORNET-ALIGNMENT) |
| Server-side key generation | `EncryptedPrivateKeyPem` exists on the certificate record; a bounded `/serverkeygen` design is a PROPOSED TO-BE extension, not an AS-IS normative behavior | PROPOSED |

# 11. Backend connector architecture

## 11.1 Abstraction and routing

`ICaConnector` (Domain) exposes `Type`, `GetCaCertificatesAsync`, `IssueCertificateAsync`, `RevokeCertificateAsync`, `GenerateCrlAsync` (default `CrlGenerationResult.Unsupported()`), and `TestConnectionAsync` [CODE-OBSERVED]. `CaConnectorFactory` (Infrastructure) maps `CaBackend.Type` to a connector, caches one instance per backend id under a lock, and derives per-connector configuration from backend `Config` JSON with environment-variable fallback [CODE-OBSERVED]. Routing is **profile → backend**: every enrollment and bootstrap resolves the connector through `profile.CaBackendId`; unknown backend types throw `NotSupportedException` and requests fail closed [CODE-OBSERVED; VERIFIED - unknown-label rejection, IMPLEMENTATION-TRACKER.md].

## 11.2 Per-connector behavior and limitations (AS-IS)

### `SelfSignedCaConnector` (in-process)

**Backend type:** SelfSigned
**Issuance:** Signs CSRs locally with BouncyCastle using the configured CA key; SHA-256 RSA/ECDSA; configurable CDP
**Chain (/cacerts):** Returns configured CA
**Revocation:** Local CRL generation supported
**Limitations:** CA private key held in gateway process; Windows key storage via MachineKeySet
**Provenance:** CODE-OBSERVED

### `SelfSignedEstCaConnector` (harness)

**Backend type:** SelfSigned
**Issuance:** Calls harness `est/selfsigned/simpleenroll` over HTTP
**Chain (/cacerts):** Harness `api/backends/selfsigned/cacerts`
**Revocation:** Not supported by harness (returns false, logs warning) - revocation fails closed
**Limitations:** Requires reachable harness service
**Provenance:** CODE-OBSERVED

### `AcmeCaConnector`

**Backend type:** Acme (Certes)
**Issuance:** ACME order with http-01 (relay) or dns-01 (stub) challenge; optional EAB; account key persisted Data-Protection-encrypted
**Chain (/cacerts):** Chain cached from last issuance; well-known ISRG chain for Let's Encrypt before first issuance
**Revocation:** Not supported → fails closed
**Limitations:** Public DNS/HTTP ACME only; demo dns-01 is a stub; chain unavailable before first issuance
**Provenance:** CODE-OBSERVED

### `AdcsCaConnector`

**Backend type:** Adcs
**Issuance:** SCEP: builds PKCSReq (PKCS#7/CMS) and POSTs PKIOperation
**Chain (/cacerts):** Fetches SCEP CA certificate
**Revocation:** CRL generation per connector contract
**Limitations:** Hospital ADCS interoperability unverified; template approval semantics not exercised
**Provenance:** CODE-OBSERVED; interoperability UNKNOWN

### `EjbcaCaConnector`

**Backend type:** Ejbca
**Issuance:** REST `pkcs10enroll` with certificate/end-entity profile names
**Chain (/cacerts):** Chain cached per connector instance (empty until configured)
**Revocation:** CRL generation per connector contract
**Limitations:** Hospital EJBCA interoperability unverified
**Provenance:** CODE-OBSERVED; interoperability UNKNOWN

### Not implemented types

**Backend type:** Cfssl, HashiCorpVault, Smallstep, OpenXpki
**Issuance:** Factory throws `NotSupportedException`
**Chain (/cacerts):** -
**Revocation:** -
**Limitations:** Enum values reserved; requests fail closed
**Provenance:** CODE-OBSERVED (CaBackendType.cs, factory)

## 11.3 Failure modes

| Failure | Gateway behavior | Provenance |
|---|---|---|
| Unknown/disabled profile or backend | Enrollment/cacerts rejected before any CA call (404/403) | CODE-OBSERVED |
| Connector `NotSupportedException` | Fail closed (e.g., revocation returns 501) | CODE-OBSERVED |
| Backend unreachable / HTTP error | Connector returns `CertificateIssuanceResult.Failed`; enrollment event records `Error`; device retries | CODE-OBSERVED |
| Expired CA or issuer rotation | Revocation refuses with 409/503 ("certificate authority is expired" / "CA certificate has rotated; create a new CA backend") | CODE-OBSERVED |
| Remote CA without a revocation API | Local issuer-scoped CRL path used where the connector supports it; otherwise revocation fails closed - no silent partial revocation | CODE-OBSERVED + DOCUMENTED (tracker) |

# 12. Failure recovery and interrupted-operation behavior

| Scenario | Behavior at baseline | Classification / provenance |
|---|---|---|
| Incomplete sandbox state (some CA files missing) | Startup refuses to regenerate CA material when state is partial, or when data-protection/DB state exists without matching CA files; operator intervention required instead of silent re-keying | AS-IS, CODE-OBSERVED (SandboxBootstrap guards) |
| Activation interrupted after code consumption but before certificate issuance | Replay after consumption is rejected (VERIFIED); full crash-mid-sequence rollback is bounded by the database transaction scope but is not separately tested - recorded as an open question | INFERRED / UNKNOWN |
| Revocation interrupted mid-write | CRL state and certificate status persisted inside one database transaction with rollback on failure; failed CRL generation aborts the revocation rather than publishing an inconsistent CRL | AS-IS, CODE-OBSERVED (BeginTransaction / TryPersistRevocationState / Rollback) |
| Gateway restart | Configured profile, issuer and devices preserved on populated SQLite; durable trust policy per PR 41 | VERIFIED (tracker) |
| PFX replacement on the DIMSE proxy | Atomic PFX replacement observed on fresh handshakes; expired replacement fails closed; established connections have bounded lifetimes | VERIFIED (loopback proxy tests) |
| MSI upgrade/uninstall | Uninstall removes program files and service but retains ProgramData state; MSI rollback is not a database rollback; schema-upgrade testing required; back up database, CA and encryption keys together before upgrades | DOCUMENTED (windows-sandbox.md) |
| Schema evolution | Additive-only upgrades (`ADD COLUMN IF NOT EXISTS`, `CREATE TABLE/INDEX IF NOT EXISTS`) for Npgsql and SQLite; never recreates a populated database | AS-IS, CODE-OBSERVED (SchemaUpgrades.cs) |
| CA outage during enrollment | Enrollment event recorded as `Error`; retry/backoff is client responsibility; availability expectations (early renewal, retry/backoff, reliable time, behavior when the enrollment service is unavailable) are TO-BE per the OR.NET alignment notes | DOCUMENTED (ORNET-ALIGNMENT-2026-09-09.md) |

# 13. Concurrency and consistency considerations

• **Connector cache**: `CaConnectorFactory` caches connectors per backend id under an explicit lock; disposal is serialized [CODE-OBSERVED].

• **CRL number monotonicity**: enforced via the single `IssuerCrlState` row per backend, incremented inside the revocation transaction; mismatched or rotated issuers are refused [CODE-OBSERVED]. Concurrent revocations serialize on the transaction; no explicit row-version concurrency token was observed on the state entity [INFERRED].

• **Activation code single use**: validation (unused/unexpired) and consumption occur in the enrollment path; replay is rejected afterward [VERIFIED]. Consumption is race-safe as implemented: `UnitOfWork.TryConsumeActivationCodeAsync` commits the consumption under optimistic concurrency and returns false on `DbUpdateConcurrencyException`, and `tests/RTSec.Kryptonian.Infrastructure.Tests/Data/DeviceActivationConcurrencyTests.cs` demonstrates that two separate contexts cannot both consume the same code [CODE-OBSERVED; VERIFIED in tracker: "One-time activation replay rejected"]. The open question is the transactional scope of consumption versus certificate issuance under crash (see §17 item 1), not double consumption.

• **Database write concurrency**: SQLite single-writer semantics apply in the exercised deployment; PostgreSQL is implemented but unexercised. No optimistic-concurrency token (row version) was observed on entities [INFERRED].

• **DateTime handling**: live checks exposed that SQLite's unspecified DateTime kind shifted refreshed CRL revocation times by five hours on one host; fixed with a runnable regression - consistent UTC normalization is a design constraint for every provider [VERIFIED - IMPLEMENTATION-TRACKER.md].

• **Chain caching**: ACME CA-chain cache is guarded by a lock; first-request-before-issuance returns a well-known chain or warns [CODE-OBSERVED].

# 14. Configuration and secrets management

### Database connection string

**AS-IS mechanism:** Environment/compose variable, or sandbox in-memory config (`Kryptonian:Database:...`)
**Gap / TO-BE direction:** Production secret handling to be defined
**Provenance:** CODE-OBSERVED

### JWT signing secret

**AS-IS mechanism:** `Kryptonian:Auth:JwtSecret` (≥32 chars in production); sandbox writes a generated secret to `secrets.json`
**Gap / TO-BE direction:** Managed secret store (vault / DPAPI-protected file)
**Provenance:** CODE-OBSERVED

### Admin API keys

**AS-IS mechanism:** `Kryptonian:AdminApi:ApiKeys` env/legacy keys honored as SystemAdmin; per-user hashed API keys in the database
**Gap / TO-BE direction:** Retire flat-file legacy keys; TO-BE uses DB-backed keys only
**Provenance:** CODE-OBSERVED

### CA PFX password

**AS-IS mechanism:** `KRYPTONIAN__CA__SELFSIGNED__PFXPASSWORD` env, or sandbox `secrets.json`
**Gap / TO-BE direction:** Managed secret store; no secrets in AIP/scripts/releases
**Provenance:** CODE-OBSERVED + DOCUMENTED

### SMTP credentials

**AS-IS mechanism:** DB `EncryptedPassword` via ASP.NET Core Data Protection; never returned over the API
**Gap / TO-BE direction:** Back up data-protection key ring with the database
**Provenance:** CODE-OBSERVED

### ACME account key / EAB HMAC

**AS-IS mechanism:** Persisted Data-Protection-encrypted (`AcmeAccount`)
**Gap / TO-BE direction:** Same
**Provenance:** CODE-OBSERVED

### Activation codes

**AS-IS mechanism:** Generated server-side, stored hashed only, time-limited, single-use
**Gap / TO-BE direction:** Same
**Provenance:** CODE-OBSERVED

### Initial admin credentials

**AS-IS mechanism:** Optional seed via env (`InitialAdminUsername/Password/Email`) with insecure demo defaults in compose; UI wizard otherwise
**Gap / TO-BE direction:** First-run wizard only; no seed defaults in production packages
**Provenance:** CODE-OBSERVED

### Compose defaults

**AS-IS mechanism:** Insecure development defaults present (`dev-api-key-change-in-production`, seeded admin password)
**Gap / TO-BE direction:** TO-BE: refuse startup in Production when known defaults are detected
**Provenance:** CODE-OBSERVED gap → TO-BE (§17 D-1)

## 15. External dependencies

### .NET 8 runtime / ASP.NET Core

**Role:** Application framework
**Notes:** Self-contained publish for the Windows installer
**Provenance:** CODE-OBSERVED / DOCUMENTED

### PostgreSQL 16 (`postgres:16-alpine`)

**Role:** Database (Docker)
**Notes:** Npgsql provider
**Provenance:** CODE-OBSERVED

### SQLite (SQLitePCLRaw)

**Role:** Database (Windows/sandbox)
**Notes:** Transitive audit reports high advisories in SQLitePCLRaw.lib.e_sqlite3 2.1.6 - deployment blocker
**Provenance:** DOCUMENTED (tracker)

### BouncyCastle

**Role:** PKCS#7, X.509, CMS/SCEP signing
**Notes:** Upgraded to 2.6.2 with MailKit 4.16.0
**Provenance:** DOCUMENTED (tracker)

### Certes

**Role:** ACME client
**Notes:** Internet-dependent ACME directories (Let's Encrypt, ZeroSSL, BuyPass, staging)
**Provenance:** CODE-OBSERVED

### MailKit 4.16.0

**Role:** SMTP notifications
**Notes:** Patched per GHSA-9j88-vvj5-vhgr
**Provenance:** DOCUMENTED (tracker)

### `System.Security.Cryptography.Xml`

**Role:** Transitive
**Notes:** 8.0.2 high advisory - deployment blocker
**Provenance:** DOCUMENTED (tracker)

### Serilog, AspNetCoreRateLimit, MudBlazor

**Role:** Logging, rate limiting, UI components
**Notes:**
**Provenance:** CODE-OBSERVED

### Hospital SMTP relay

**Role:** Notifications
**Notes:** Internal-CA relays may require the explicit trust flag
**Provenance:** CODE-OBSERVED

### Advanced Installer 22.0+

**Role:** MSI build (maintainers)
**Notes:** Build-time dependency, not runtime
**Provenance:** DOCUMENTED

### PowerShell 7.6.5 (portable)

**Role:** Bundled installer payload
**Notes:** SHA-256-verified download at build time
**Provenance:** DOCUMENTED (windows-sandbox.md)

# 16. AS-IS vs TO-BE architecture comparison

## 16.1 Retained architecture (AS-IS carried into TO-BE)

The following AS-IS elements are **confirmed as the target design** and require no change beyond formalization [VERIFIED/CODE-OBSERVED]:

- Clean-architecture layering and the `ICaConnector` abstraction with profile→backend routing.
- EST-facing protocol surface: standard Basic-authenticated enrollment, certificate-authenticated renewal, `/cacerts` PKCS#7 bootstrap, profile-scoped issuer resolution.

- One-time activation-code bootstrap: hashed, expiring, single-use, replay-rejected.
- Issuer-scoped signed CRLs with monotonic numbering and transactional revocation; fail-closed on unsupported backends.
- Complete per-attempt enrollment/renewal/revocation auditing is TO-BE; AS-IS persists selected issuance and rejection outcomes (GAP-038).
- Expiry monitoring with debounced near-expiry notifications.
- Separate trust zones for administration (own CA in sandbox mode) and device-facing EST.

## 16.2 AS-IS findings that drive TO-BE change

### A-1

**Area:** Device status model

**AS-IS (baseline):** Enum `Pending/Active/Removed`; trust withdrawal collapses into `Removed`

**TO-BE (target):** Distinguish at least `Untrusted` (revocable trust withdrawal) from `Retired` (inventory retirement) so audit history and dashboard semantics are explicit

**Type:** TO-BE (needs SR alignment)

### A-2

**Area:** Certificate record

**AS-IS (baseline):** `EncryptedPrivateKeyPem` exists; archival/key-protection policy undefined

**TO-BE (target):** Define whether the gateway ever archives device private keys; if prohibited, remove the field or restrict it to explicit `/serverkeygen` profiles

**Type:** TO-BE (policy decision)

### A-3

**Area:** Demo OID namespace

**AS-IS (baseline):** Gateway OID under `1.3.6.1.4.1.99999.*` (unregistered, prototype PEN)

**TO-BE (target):** Obtain an authorized enterprise PEN or adopt agreed profile OIDs; the ORNET briefing forbids inventing a second protocol or private clinical-role OID

**Type:** TO-BE (external stakeholder decision)

### A-4

**Area:** CRL lifetime

**AS-IS (baseline):** Hard-coded 60-second prototype CRL lifetime

**TO-BE (target):** Configurable, policy-based CRL lifetime and next-update chosen from outage tolerance and revocation objectives, not a demo value

**Type:** TO-BE

### A-5

**Area:** Revocation propagation

**AS-IS (baseline):** Peers refresh CRLs on a timer; established associations have bounded lifetimes

**TO-BE (target):** Define stale-revocation-data and established-session handling explicitly; no promise of instant mid-association termination

**Type:** TO-BE (normative statement)

### A-6

**Area:** Audit export

**AS-IS (baseline):** Audit is a database table + structured logs

**TO-BE (target):** Map lifecycle/transport events to ATNA/DICOM audit definitions and protect export with a standard transport (separate conformance task)

**Type:** TO-BE (PROPOSED scope)

### A-7

**Area:** Automatic renewal scope

**AS-IS (baseline):** Device simulator renews only while open; no OS-service renewal

**TO-BE (target):** Deployment policy for long-lived operation, hardware-backed key storage, old-certificate retirement

**Type:** TO-BE (needs SR)

### A-8

**Area:** Legacy activation headers

**AS-IS (baseline):** Sample device client retains legacy private activation headers

**TO-BE (target):** Independent standard-Basic path remains the only interoperability requirement; legacy headers stay demo-only compatibility, never a new interoperability requirement

**Type:** DOCUMENTED boundary (retained)

### A-9

**Area:** PostgreSQL

**AS-IS (baseline):** Upgrade SQL implemented; only SQLite exercised

**TO-BE (target):** Exercise and verify the Npgsql path, then select the production database

**Type:** TO-BE (V&V)

### A-10

**Area:** Server leaf revocation

**AS-IS (baseline):** Launcher's initial server leaf revocation explicitly skipped without a CDP (hostname/purpose checks remain)

**TO-BE (target):** Every deployed issuer must publish a reachable CDP; this exception must not survive into production

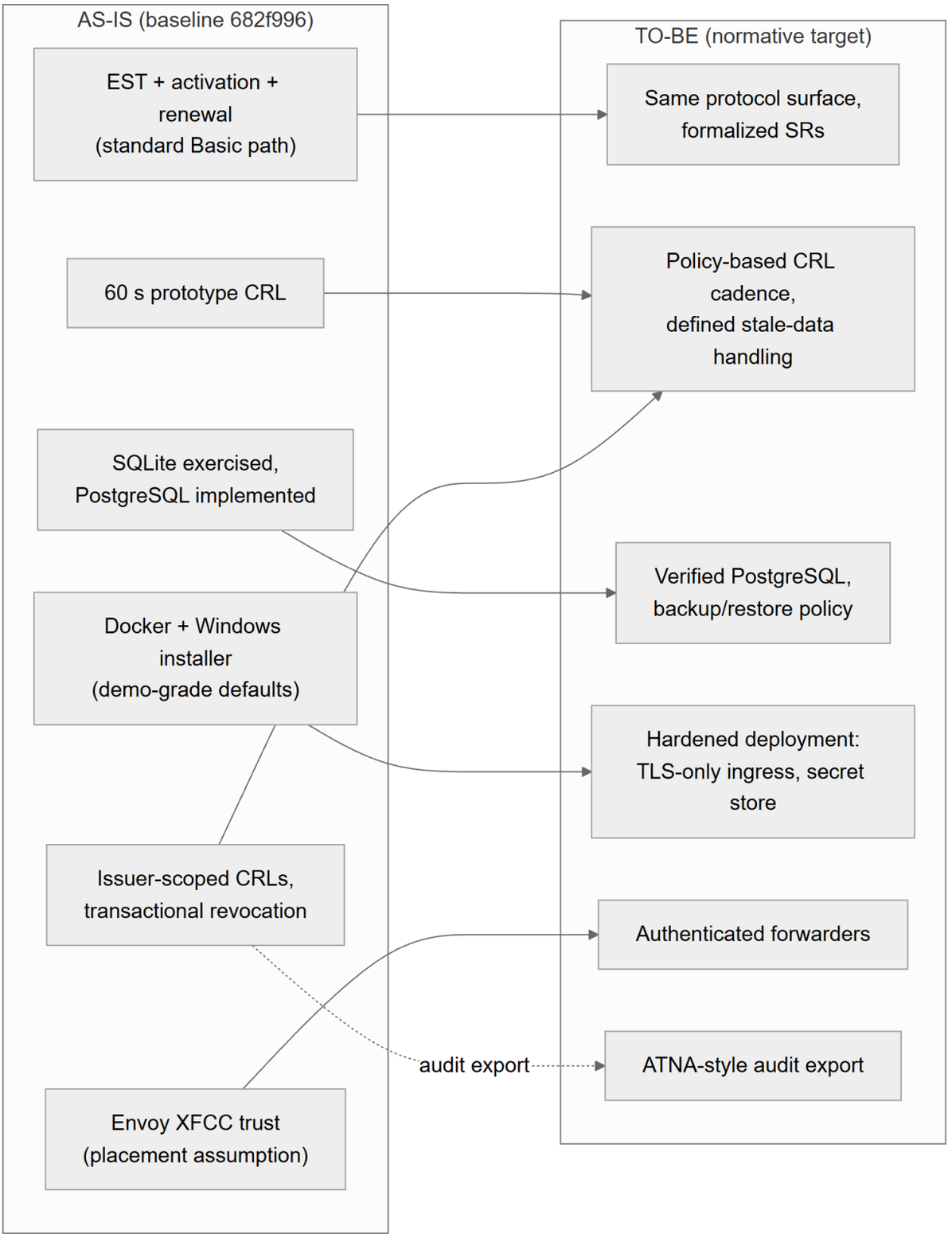
**Type:** DOCUMENTED boundary → TO-BE

## 16.3 PROPOSED items (require stakeholder approval - never normative without it)

| ID | Proposal | Rationale |
|---|---|---|
| P-1 | Replace environment/`secrets.json` secret handling with a managed secret store (vault or OS-protected secret service) and fail-fast checks for known development defaults in Production | Reduces secret sprawl; supports institutional operation (SR-B/SR-S class) |
| P-2 | Enforce forwarder authentication for the XFCC client-certificate path (shared secret, network allow-list, or proxy→gateway mTLS) | The Envoy header is trusted unconditionally at baseline; closing boundary B1b closes a spoofing route |
| P-3 | Add `/csrattrs` (and evaluate `/serverkeygen`) per RFC 7030 with bounded profiles | Improves device-side guidance; enables constrained clients |
| P-4 | Metrics/observability endpoint (enrollment counts, CA latency, request rates) | Listed as planned/future in docs/ARCHITECTURE.md |
| P-5 | Add row-version concurrency tokens on hot entities and define/verify the crash-scope of activation consumption versus certificate issuance (one-time consumption itself is already enforced via optimistic concurrency - `UnitOfWork.TryConsumeActivationCodeAsync`, `DeviceActivationConcurrencyTests`) | Hardens the concurrency envelope identified in §13 and resolves the crash-scope question of §17 |
| P-6 | Dedicated notification outbox so rejected-enrollment and expiry emails survive transient SMTP outages | Notifications are dispatched inline at baseline [CODE-OBSERVED] |
| P-7 | Per-backend connector health surfaced on the status/health endpoint | Health currently reflects overall status; per-backend reachability exists only as connector `TestConnectionAsync` [CODE-OBSERVED] |

### 16.4 Comparison summary diagram

## Diagram KSPEC-004-16




Rendered from 04-SOFTWARE-DESIGN.md. Diagram sheets use larger page sizes to preserve readable labels.

## 17. Open questions (UNKNOWN - recorded, not resolved here)

1. Consumption and issuance are separate persistence operations (CODE-OBSERVED): activation is saved before backend/policy/CA processing. Crash and pending-response recovery remain unverified; VT-060 specifies failure/restart and administrator-regeneration cases.

2. Real hospital ADCS/EJBCA enrollment and revocation interoperability (explicitly unverified at baseline).

3. PostgreSQL correctness/performance beyond the implemented additive upgrade SQL.

4. Whether `Certificate.EncryptedPrivateKeyPem` is written by any baseline code path or is dormant schema (field observed; writer not traced).

5. Windows Sandbox guest install/repair/upgrade/uninstall acceptance tests remained unverified on the authoring host per docs/windows-sandbox.md.

## 18. Document control notes

• This document is a **Draft** (KSPEC-000 review sequence: 003 → 004). It contains no conformity claims; executed-test references cite repository evidence only.

• KSPEC-003 exists; concrete SR bindings are maintained in KSPEC-009 §§4 and 7, and the §16.2 rows are promoted to TO-BE only where the corresponding requirement is approved.

• No application source code was modified in producing this document.

# Kryptonian Formal Engineering Specification - Interface Control Document

| Field | Value |
|---|---|
| Document ID | KSPEC-005 |
| Title | Interface Control Specification (EST, Admin REST, CA Connector, and Supporting Interfaces) |
| Version | 0.2 (Draft) |
| Status | Draft - pending review |
| Created | 2026-10-13 |
| Baseline commit | `682f996c8447afec13bc1fce5b7f59e6a06efa25` (branch `feat/windows-sandbox-installer`) |
| Repository | https://github.com/AAPM-RT-SEC/RTSec.Kryptonian |
| Product classification | Enterprise healthcare IT cybersecurity infrastructure (certificate enrollment gateway). **Not** a medical device; no clinical functions; no regulatory content. |
| Revision history | 0.1 - Initial draft generated from baseline commit inspection. |
| Source references | KSPEC-000 (conventions); `EstController.cs`, `CrlController.cs`, `AcmeChallengeController.cs`, all Admin controllers under `src/RTSec.Kryptonian.Api/Controllers/`; `ApiKeyAuthenticationHandler.cs`, `ConfiguredClientCertificateTrust.cs`, `CertificateForwardingGuard.cs`, `Program.cs`; `src/RTSec.Kryptonian.Domain/Interfaces/`; `src/RTSec.Kryptonian.Domain/ValueObjects/`; `src/RTSec.Kryptonian.Infrastructure/{Harness,Acme,Crypto,Data}/`; `src/RTSec.Kryptonian.Application/{DTOs,Services}/`; `OpenAPI.Admin.yaml`, `OpenAPI.Client.yaml`, `OpenAPI.ESTProfiles.yaml`, `OpenAPI.Schema.yaml`, `OpenAPI.StatusObserve.yaml`; `docs/API-GUIDE.md`, `docs/device-enrollment.md`, `docs/ca-backend-configuration.md`, `docs/user-management.md`, `docs/IMPLEMENTATION-TRACKER.md` |
| Author | _____ (name-date-signature) |
| Reviewer | _____ (name-date-signature) |
| Approver | _____ (name-date-signature) |
| Reconciliation revision | 0.2 - 2026-10-13 - source/document audit and publication controls (KSPEC-016) |

**Requirement references:** KSPEC-003 is the canonical register. Area-level interface references are bound to concrete requirements in KSPEC-009 §§4 and 7. `SR-EST`, `SR-ADM`, and `SR-CAI` are legacy area aliases for `SR-F-EST`, `SR-F-ADM`, and `SR-F-CAI`; they allocate no IDs. Provenance and AS-IS / TO-BE / PROPOSED classifications follow KSPEC-000.

## 1. Scope and interface inventory

This ICD specifies every externally and internally observable interface of the Kryptonian gateway at the baseline commit:

| ICD item | Interface group | Sections |
|---|---|---|
| ICD-EST.001-ICD-EST.006 | EST protocol (RFC 7030) device-facing endpoints | §3-§9 |

| ICD item | Interface group | Sections |
|---|---|---|
| ICD-ADM.001-ICD-ADM.012 | Administrative REST APIs (`/api/*`) | §10-§11 |
| ICD-ERR.001 | Error model and error codes | §12 |
| ICD-PCR.001-ICD-PCR.003 | Certificate, CSR, and CRL payload formats | §13 |
| ICD-CAI.001-ICD-CAI.003 | Internal CA connector contract and per-connector capabilities | §14 |
| ICD-DAT.001 | Database integration (EF Core / SchemaUpgrades) | §15 |
| ICD-CFG.001-ICD-CFG.002 | Configuration interfaces (appsettings, environment, secrets) | §16 |
| ICD-EXT.001-ICD-EXT.004 | External system dependencies (SMTP, ACME, ADCS/NDES, EJBCA, harness) | §17 |
| ICD-VER.001-ICD-VER.003 | Versioning and interoperability policy | §18 |

Each section below separates **implemented endpoint behavior (AS-IS)** from **approved interface contracts (TO-BE/PROPOSED)**. Nothing in this document is normative until the corresponding contract is approved; AS-IS descriptions are evidence of prototype behavior only (KSPEC-000 §4, §13).

# 2. Interface surface overview

AS-IS (CODE-OBSERVED): the gateway exposes two distinct API surfaces plus two protocol-support surfaces:

### EST protocol

**Base path:** `/.well-known/est[/{label}]`
**Transport:** HTTPS (port 8443 by config default)
**Authentication:** TLS client certificate (re-enroll); HTTP Basic one-time activation bootstrap or legacy activation headers (initial enroll)
**Audience:** Medical devices / EST clients

### Admin REST API

**Base path:** `/api/*`
**Transport:** HTTPS according to configured Kestrel listener; AdminPort key alone does not bind a listener
**Authentication:** JWT Bearer or `X-API-Key`
**Audience:** Administrators, Blazor/React UI, automation

### CRL distribution

**Base path:** `/api/crl/{issuerFingerprint}.crl`
**Transport:** HTTPS
**Authentication:** None (public, `AllowAnonymous`)
**Audience:** Any peer performing revocation checks

### ACME HTTP-01 challenges

**Base path:** `/.well-known/acme-challenge/{token}`

**Transport:** HTTP(S)
**Authentication:** None (anonymous by ACME design)
**Audience:** ACME servers

Controller routes are ASP.NET Core attribute routes, case-insensitive for path segments. Swagger UI is exposed in Development mode only (`/swagger`) with an `ApiKey` security scheme declared (CODE-OBSERVED, `Program.cs`).

# 3. EST endpoints (ICD-EST.001) - AS-IS

**Provenance:** CODE-OBSERVED (source inspection of `EstController.cs` at baseline).

| Method | Path | Behavior |
|---|---|---|
| GET | `/.well-known/est/cacerts` | Returns the CA certificate chain of the EST profile resolved from `Request.Host.Host` and path prefix `/.well-known/est`. |
| GET | `/.well-known/est/{label}/cacerts` | Same, with path prefix `/.well-known/est/{label}`. Unknown labels are **rejected with 404**; they never fall back to the default profile. |
| POST | `/.well-known/est/simpleenroll` | Initial enrollment. Accepts a PKCS#10 CSR; returns PKCS#7 cert chain; supports pending (202) responses. |
| POST | `/.well-known/est/{label}/simpleenroll` | Same, profile-scoped by label. |
| POST | `/.well-known/est/simplereenroll` | Renewal. Requires a native TLS client certificate; returns PKCS#7 cert chain; supports pending (202) responses. |
| POST | `/.well-known/est/{label}/simplereenroll` | Same, profile-scoped by label. |

Profile resolution rules (AS-IS, CODE-OBSERVED, `ResolveProfileIdAsync`):

1. The profile is resolved by the pair (hostname of `Request.Host`, effective path prefix). Unlabeled requests resolve only against `/.well-known/est`; labeled requests only against `/.well-known/est/{label}`.
2. A disabled or unmatched profile yields `404 {"error": "EST profile not found"}`.
3. Unknown labels are rejected rather than silently falling back to the default profile (prevents mistyped/revoked labels enrolling against the wrong CA).

A plain-HTTP request to any `/.well-known/est` path is answered with **426 Upgrade Required** and a JSON error, unless `Kryptonian:Est:AllowPlainHttp=true` is set (CODE-OBSERVED, `Program.cs` HTTPS-enforcement middleware).

# 4. EST authentication methods (ICD-EST.002) - AS-IS

**Provenance:** CODE-OBSERVED.

## 4.1 Native TLS client certificate (re-enroll, and optionally enroll)

- Kestrel is configured with `ClientCertificateMode.AllowCertificate` on the EST listener; the presented certificate is available as `HttpContext.Connection.ClientCertificate`.
- `simplereenroll` **requires** a client certificate: absence yields `401 {"error": "Client certificate required"}` (CODE-OBSERVED).

- `simpleenroll` requires a client certificate only when the profile's `requireClientCertificate` flag is true (`401` if absent). When a certificate is presented on either endpoint it is always validated regardless of the flag.
- Certificate validation (both endpoints): expiry/not-yet-valid checks; then, if the profile enables `validateClientCertificateChain`, a custom-root-trust chain build against the profile's `trustedClientCaThumbprints` (SHA-256 hash or SHA-1 thumbprint accepted), application policy OID clientAuth (`1.3.6.1.5.5.7.3.2`), online revocation, 5-second URL retrieval timeout. Failures yield `403`. A profile requiring chain validation with no trusted CAs configured fails closed (`403`, CODE-OBSERVED).
- TLS-listener-level validation is additionally performed by `ConfiguredClientCertificateTrust` when `Kryptonian:Tls:ClientCaFiles` is configured: the certificate must be a leaf (not a CA) with clientAuth EKU, must chain to the configured CA files under `CustomRootTrust`, revocation checked **online** (default), 5-second timeout (CODE-OBSERVED).

## 4.2 HTTP Basic bootstrap (one-time activation credentials)

Standard HTTP Basic is the bootstrap method for initial enrollment (AS-IS, CODE-OBSERVED; introduced by PR #42 "Standard Basic EST bootstrap; atomic one-time activation" per `docs/IMPLEMENTATION-TRACKER.md`):

- Header format: `Authorization: Basic base64(<deviceIdGuid>:<activationCode>)` where `<deviceIdGuid>` is the device record identifier in Guid "D" form and the activation code is the one-time code generated by the admin workflow (`POST /api/devices/{id}/activation-code`).
- The username must parse exactly as a Guid; otherwise `401 {"error": "Invalid Basic authentication credentials"}` with `WWW-Authenticate: Basic realm="EST", charset="UTF-8"` (CODE-OBSERVED).
- **TLS is mandatory for Basic**: if the request is not HTTPS while carrying Basic credentials, the gateway returns `403 {"error": "Basic authentication requires TLS"}` (CODE-OBSERVED).
- The activation code is validated by the enrollment orchestrator: it must exist, be unexpired, be unused, and belong to the device record; it is consumed atomically after the first certificate is issued (CODE-OBSERVED; DOCUMENTED in `docs/device-enrollment.md`; executed evidence in `docs/IMPLEMENTATION-TRACKER.md` - one-time activation replay rejected).

## 4.3 Legacy activation headers (compat only - NOT an interoperability requirement)

AS-IS compat only (CODE-OBSERVED; explicitly bounded by `docs/IMPLEMENTATION-TRACKER.md`):

- `X-Activation-Code` - one-time activation code (when no Basic credentials are presented).
- `X-Device-Manufacturer`, `X-Device-Model`, `X-Device-Serial-Number` - activation metadata carried as request headers.
- `X-Device-Id` - accepted on requests but **untrusted**: logged for audit correlation only, never used for authentication or authorization (CODE-OBSERVED, `GetDeviceIdentifier` returns `null` when only the header is present).

Per `docs/IMPLEMENTATION-TRACKER.md` (DOCUMENTED): the sample device client retains these legacy headers for compatibility; they are not mandatory for other clients and **shall not become a new interoperability requirement** (KSPEC-000 §3, §4).

## 4.4 Not-authenticated-enrollment caveat

The AS-IS API guide states initial enrollment "may allow unauthenticated requests depending on profile configuration" (`docs/API-GUIDE.md`, DOCUMENTED). Source inspection shows an activation credential (Basic or `X-Activation-Code`) is in practice required to complete enrollment issuance (CODE-OBSERVED, `EnrollmentOrchestrator.EnrollAsync`). Whether a no-credential enrollment path can succeed on a profile with `requireClientCertificate=false` is **UNKNOWN** from inspected evidence and is recorded as an open question for KSPEC-003/KSPEC-010.

# 5. EST request/response schemas and content types (ICD-EST.003) - AS-IS

**Provenance:** CODE-OBSERVED (`EstController.cs`, `PkcsService.cs`).

Request:

- Content-Type: `application/pkcs10` or `text/plain` (declared via `[Consumes]`; both are accepted). The body carries a PKCS#10 CSR, base64-encoded when `Content-Transfer-Encoding: base64` is present, otherwise raw bytes that the parser accepts as DER, base64, or PEM (`-----BEGIN CERTIFICATE REQUEST-----` / legacy `-----BEGIN NEW CERTIFICATE REQUEST-----`, CODE-OBSERVED, `PkcsService.ParsePkcs10`).
- Request body size is limited to 65,536 bytes (`RequestSizeLimit` and decoder `maxSize`); exceeding it yields `413 {"error": "Request body too large"}`.
- Header `Content-Transfer-Encoding: base64` is honored per RFC 7030 §3.5 (base64 transfer of the CSR).

Response (success):

- HTTP 200; Content-Type: `application/pkcs7-mime; smime-type=certs-only`; `Content-Transfer-Encoding: base64`; body is base64 PKCS#7 degenerate SignedData ("certs-only") containing the issued certificate and chain (CODE-OBSERVED).
- The task-relevant media types `application/pkcs10-mime` and `application/pkix-cert` are **not used anywhere in the baseline implementation**; the implemented content types are `application/pkcs10` (requests) and `application/pkcs7-mime` (responses), with `application/pkix-crl` used only by the CRL endpoint (§13). This is recorded as an AS-IS observation; RFC 7030 itself specifies `application/pkcs10` for CSR submission, so the implemented choice matches the RFC media type; this is not a whole-protocol conformity claim (RFC 7030 §§4.2.1 and 4.2.3: https://www.rfc-editor.org/rfc/rfc7030.html).

Response (error) - see §12 for the full model:

- Content-Type `application/json`, body `{"error": "<message>"}` or `{"error": "<message>", "retryAfter": <seconds>}` for pending responses.

Consolidated EST path set - **TO-BE contract fragment (PROPOSED, OpenAPI 3.1, contract-first)**. The repository OpenAPI files do not yet contain the EST paths; the fragment below consolidates the AS-IS behavior for review as the approved EST contract. This is PROPOSED and not normative until approved:

```
openapi: 3.1.0
info: { title: Kryptonian EST (RFC 7030), version: 0.1.0-draft }
paths:
  /.well-known/est/{label}/cacerts:
    get:
      operationId: estGetCaCerts
      parameters:
        - { name: label, in: path, required: true, schema: { type: string } }
      responses:
        '200':
          description: CA certificate chain, PKCS#7 certs-only, base64
          headers:
            Content-Transfer-Encoding: { schema: { type: string, const: base64 } }
          content:
            application/pkcs7-mime:
              schema: { type: string, contentEncoding: base64 }
        '404': { description: EST profile not found (JSON error body) }
  /.well-known/est/{label}/simpleenroll:
    post:
      operationId: estSimpleEnroll
      parameters:
        - { name: label, in: path, required: true, schema: { type: string } }
      requestBody:
        required: true
```

```
    content:
      application/pkcs10:
        schema: { type: string, contentEncoding: base64 }
  responses:
    '200':
      description: Issued certificate chain (PKCS#7 certs-only, base64)
      content:
        application/pkcs7-mime:
          schema: { type: string, contentEncoding: base64 }
    '202':
      description: Issuance pending; retry per Retry-After
      headers:
        Retry-After: { schema: { type: integer, description: seconds } }
      content:
        application/json:
          schema:
            type: object
            properties:
              error: { type: string, const: "Enrollment pending" }
              retryAfter: { type: integer }
    '400': { description: Invalid CSR or request }
    '401': { description: Client certificate or activation credential missing/invalid }
    '403': { description: Certificate validation failed / Basic without TLS }
    '404': { description: EST profile not found }
    '413': { description: CSR exceeds 64 KiB }
    '429': { description: IP rate limit exceeded }
    '500': { description: Internal error }
```

# 6. EST protocol status handling: pending responses and Retry-After (ICD-EST.004) - AS-IS

**Provenance:** CODE-OBSERVED (`EnrollmentResult`, `EstController.HandleEnrollmentResult`).

### Certificate issued

**Status:** 200
**Headers:** `Content-Transfer-Encoding: base64`
**Body:** PKCS#7 certs-only (base64)

### Async issuance pending

**Status:** 202
**Headers:** `Retry-After: <seconds>` when the result carries `RetryAfterSeconds`
**Body:** `{"error": "Enrollment pending", "retryAfter": <seconds>}` (JSON)

### Invalid CSR / argument

**Status:** 400
**Headers:** -
**Body:** `{"error": ...}`

### Missing/invalid credential or client certificate

**Status:** 401
**Headers:** `WWW-Authenticate: Basic realm="EST", charset="UTF-8"` for Basic failures
**Body:** `{"error": ...}`

### Validation/policy rejection

**Status:** 403
**Headers:** -
**Body:** `{"error": <reason>}`

### Unknown/disabled profile

**Status:** 404
**Headers:** -
**Body:** `{"error": "EST profile not found"}`

### Body over 64 KiB

**Status:** 413
**Headers:** -
**Body:** `{"error": "Request body too large"}`

### IP rate limit exceeded

**Status:** 429
**Headers:** per AspNetCoreRateLimit
**Body:** rate-limit response

### Unexpected failure

**Status:** 500
**Headers:** -
**Body:** `{"error": "Internal server error"}`

Pending behavior notes (AS-IS):

- The 202 body is a JSON error object, **not** a PKCS#7 body; clients retry the same `simpleenroll`/`simplereenroll` request after the indicated delay (DOCUMENTED in `docs/API-GUIDE.md`: "The client should wait the specified number of seconds before retrying the request").
- `Retry-After` is emitted as a delay-seconds value only (never an HTTP-date).
- Executed evidence of pending/renewal behavior exists in `docs/IMPLEMENTATION-TRACKER.md` (PR #44) but the specific trigger conditions for pending responses (which CA backend states produce `IsPending`) were not exhaustively inspected and are **UNKNOWN** in detail.

TO-BE/PROPOSED: the approved contract should require that every pending-capable CA backend produce a deterministic `Retry-After` value and that clients treat 202 as retryable-with-backoff, subject to the consumed-bootstrap limitation (GAP-039) (SR-EST, SR-F-INT). Not yet approved.

## 7. TLS requirements for EST (ICD-EST.005) - AS-IS

**Provenance:** CODE-OBSERVED (`Program.cs`, `ConfiguredClientCertificateTrust.cs`, `CertificateForwardingGuard.cs`).

- EST requires HTTPS by default; plain HTTP is refused with `426 Upgrade Required` unless `Kryptonian:Est:AllowPlainHttp=true` (development escape hatch).
- HTTP Basic credentials are additionally rejected over plain HTTP with `403` (defense in depth, CODE-OBSERVED).

• TLS configuration keys: `Kryptonian:Tls:RequireTls12` (default true in `appsettings.json`), `Kryptonian:Tls:EstPort` (default 8443), `Kryptonian:Tls:AdminPort` (default 8080).

• Client certificate mode is `AllowCertificate` (certificate optional at TLS layer; enforcement happens per endpoint/profile as in §4).

• Optional strict listener validation via `Kryptonian:Tls:ClientCaFiles`: CA PEM files loaded at startup; a file set that yields no CA certificate fails startup with `InvalidOperationException` (fail-closed, CODE-OBSERVED).

• Reverse proxy support: certificate forwarding uses the Envoy `X-Forwarded-Client-Cert` header format (`Hash=...;Cert="<URL-encoded PEM>"`). `CertificateForwardingGuard` rejects (`403`) any request carrying this header from a non-configured proxy (`Kryptonian:CertificateForwarding:KnownProxies`) or when a native client certificate is also present, and rejects (`400`) multiple forwarding headers (CODE-OBSERVED).

## 8. EST rate limiting (ICD-EST.006) - AS-IS

CODE-OBSERVED (`appsettings.json`, AspNetCoreRateLimit):

| Endpoint rule | Period | Limit |
|---|---|---|
| `*:/.well-known/est/*` | 1 minute | 100 |
| `POST:/.well-known/est/*/simpleenroll` | 1 minute | 30 |
| `POST:/.well-known/est/*/simplereenroll` | 1 minute | 30 |

The middleware is configured to return HTTP 429 for blocked requests; effective route matching and load behavior are unverified in this review (VT-055). Real client IP is taken from `X-Forwarded-For` (`RealIpHeader`), also used by the EST controller for source-address logging. Consistent use does not authenticate this header; spoof-resistant attribution requires trusted-forwarder enforcement (GAP-040).

## 9. RFC 7030 conformance points and deviations - AS-IS assessment

**Provenance:** CODE-OBSERVED for gateway behavior; conformance judgment is INFERRED and shall not be presented as a standards-conformity claim (KSPEC-000 §5, §13; no adopted EST profile is claimed in `docs/IMPLEMENTATION-TRACKER.md`).

| RFC 7030 point | Baseline status | Classification |
|---|---|---|
| `/cacerts` returns PKCS#7 certs-only, base64 CTE | Implemented (`application/pkcs7-mime; smime-type=certs-only`) | Implemented (source inspection; conformity untested) |
| `/simpleenroll` accepts `application/pkcs10` (base64 CTE), returns PKCS#7 | Implemented; also accepts `text/plain` (lenient extension) | Implemented; text/plain is an additional accepted media type |
| `/simplereenroll` authenticates with existing credential | Implemented via native TLS client certificate | Implemented (source inspection; conformity untested) |
| Client certificate identity binding on re-enroll | Implemented; orchestrator binds to approved identity, preserves it on renewal (executed evidence, PRs #38/#44) | Implemented (historical lifecycle evidence) |

| RFC 7030 point | Baseline status | Classification |
|---|---|---|
| HTTP Basic bootstrap per RFC 7030 §3.2.3 | Implemented (Guid-as-username one-time activation scheme) | Site-specific credential provisioning, not a Basic wire-format deviation |
| `WWW-Authenticate` challenge on Basic failures | Implemented | Implemented (source inspection; conformity untested) |
| `/csrattrs` (attribute discovery) | **Not implemented** | Missing |
| `/serverkeygen` (server-generated keys / KRA) | **Not implemented** | Missing |
| `/fullcmc` (full CMS enrollment) | **Not implemented** | Missing |
| Label-based virtual EST server (`{label}` segments) | Implemented; unknown labels rejected (stricter than RFC's flexible-label guidance) | Implemented (strict profile lookup; interoperability untested) |
| Pending / 202 + `Retry-After` | Implemented status/header branch; backend pending workflow unverified | RFC-defined pending response, not a proprietary extension |
| Plain-HTTP refusal (426) | Implemented | Extension (security-positive) |

**Deviations/limitations summary (AS-IS):** no `/csrattrs`, no `/serverkeygen`, no `/fullcmc`; Basic bootstrap username is the gateway device-record Guid rather than a pre-existing user identity; `text/plain` CSR bodies accepted leniently; legacy `X-*` activation/device headers retained for the bundled sample client only and must not become an interoperability requirement.

# 10. Administrative REST APIs (ICD-ADM.001-ICD-ADM.012) - AS-IS

**Provenance:** CODE-OBSERVED (controller source inspection). All `/api/*` controllers produce `application/json`. Authentication is dual-scheme: JWT Bearer (`Authorization: Bearer`, issuer `kryptonian`, audience `kryptonian-ui`, 8-hour lifetime, 5-minute clock skew) or API key (`X-API-Key` header - static config keys acting as SystemAdmin, or DB-stored user keys with `kry_` prefix, SHA-256 hashed, expiry and user-active checks). PolicyScheme selects JWT when an `Authorization` header is present, otherwise the API-key scheme (CODE-OBSERVED, `Program.cs`, `ApiKeyAuthenticationHandler.cs`).

Authorization policies (CODE-OBSERVED): default policy = authenticated user; `DeviceAdmin` = role DeviceAdmin or SystemAdmin; `SystemAdmin` = role SystemAdmin. Roles per `docs/user-management.md` (DOCUMENTED): Standard, DeviceAdmin, SystemAdmin.

## ICD-ADM.001 Devices (`api/devices`) - CODE-OBSERVED

### GET

**Path:** `/api/devices`
**Authorization:** authenticated
**Success:** 200 `DeviceDto[]`
**Notes:**

### POST

**Path:** `/api/devices`
**Authorization:** DeviceAdmin

**Success:** 201 `DeviceDto`
**Notes:** 400 on invalid input

### POST

**Path:** `/api/device-requests`
**Authorization:** **anonymous**
**Success:** 202 `DeviceApprovalRequestResponseDto`
**Notes:** Device self-request for approval; 400 on invalid

### GET

**Path:** `/api/devices/{id}`
**Authorization:** authenticated
**Success:** 200 `DeviceDto` / 404
**Notes:** Non-Guid id → 404

### POST

**Path:** `/api/devices/{id}/approve`
**Authorization:** DeviceAdmin
**Success:** 200 `DeviceDto` / 404
**Notes:**

### POST

**Path:** `/api/devices/{id}/activation-code`
**Authorization:** DeviceAdmin
**Success:** 200 `DeviceActivationCodeDto` / 400 / 404
**Notes:** Body `{"validForMinutes": int?}`

### POST

**Path:** `/api/devices/{id}/activation-code/reactivate`
**Authorization:** DeviceAdmin
**Success:** 200 `DeviceActivationCodeDto` / 400 / 404
**Notes:**

### POST

**Path:** `/api/devices/{id}/remove`
**Authorization:** DeviceAdmin
**Success:** 200 `DeviceDto` / 404
**Notes:** Soft removal; removed devices cannot enroll/renew (DOCUMENTED)

### DELETE

**Path:** `/api/devices/{id}`
**Authorization:** DeviceAdmin
**Success:** 204 / 400 / 404
**Notes:** Permanent purge; may be rejected (400)

### GET

**Path:** `/api/devices/{id}/certificates`
**Authorization:** authenticated
**Success:** 200 `CertificateDto[]` / 404
**Notes:**

### GET

**Path:** `/api/devices/{id}/events`
**Authorization:** DeviceAdmin
**Success:** 200 `DeviceEventDto[]` / 404
**Notes:** Lifecycle + enrollment events

### GET

**Path:** `/api/devices/certificates`
**Authorization:** authenticated
**Success:** 200 `CertificateDto[]`
**Notes:** All certificates, newest first (avoids N+1 pool exhaustion, CODE-OBSERVED)

### POST

**Path:** `/api/devices/{id}/demo-enroll`
**Authorization:** DeviceAdmin
**Success:** 200 `DemoEnrollResponseDto` / 400 / 404
**Notes:** Admin-side demo enrollment via active profile

`DeviceActivationCodeDto` includes the raw `activationCode` and `qrPayload` (show-once delivery; the gateway stores activation codes hashed, DOCUMENTED).

## ICD-ADM.002 CA backends (`api/cas`) - CODE-OBSERVED

### GET

**Path:** `/api/cas`
**Authorization:** authenticated
**Success:** 200 `CaBackendDto[]`
**Notes:**

### GET

**Path:** `/api/cas/active`
**Authorization:** authenticated
**Success:** 200 `CaBackendDto` / 404
**Notes:**

### POST

**Path:** `/api/cas`
**Authorization:** SystemAdmin
**Success:** 201 `CaBackendDto`
**Notes:** 400 on invalid

### GET

**Path:** `/api/cas/{id}`
**Authorization:** authenticated
**Success:** 200 `CaBackendDto` / 404
**Notes:**

### PUT

**Path:** `/api/cas/{id}`
**Authorization:** SystemAdmin
**Success:** 200 `CaBackendDto` / 400 / 404
**Notes:**

### DELETE

**Path:** `/api/cas/{id}`
**Authorization:** SystemAdmin
**Success:** 204 / 400 / 404
**Notes:** 400 when backend in use (InvalidOperationException)

### POST

**Path:** `/api/cas/{id}/test`
**Authorization:** authenticated
**Success:** 200 `{"success": bool}` / 404
**Notes:** No role policy beyond authentication (AS-IS observation)

### POST

**Path:** `/api/cas/{id}/activate`
**Authorization:** SystemAdmin
**Success:** 200 `CaBackendDto` / 400 / 404
**Notes:** Single active backend

### POST

**Path:** `/api/cas/generate-selfsigned`
**Authorization:** SystemAdmin
**Success:** 200 `{pfxPath, thumbprint, notAfter}`
**Notes:** 400 invalid/permissions; 409 existing file; 500 crypto failure (matches `OpenAPI.Admin.yaml`)

## ICD-ADM.003 EST profiles (`api/est-profiles`) - CODE-OBSERVED

### GET

**Path:** `/api/est-profiles`
**Authorization:** authenticated
**Success:** 200 `EstProfileDto[]`
**Notes:**

### POST

**Path:** `/api/est-profiles`
**Authorization:** SystemAdmin
**Success:** 201 `EstProfileDto`
**Notes:** 400 on invalid/ImpossibleOperation

### GET

**Path:** `/api/est-profiles/{id}`
**Authorization:** authenticated
**Success:** 200 `EstProfileDto` / 404
**Notes:**

### PUT

**Path:** `/api/est-profiles/{id}`
**Authorization:** SystemAdmin
**Success:** 200 `EstProfileDto` / 400 / 404
**Notes:** Partial update; omitted trust lists are preserved (PR #47)

### DELETE

**Path:** `/api/est-profiles/{id}`
**Authorization:** SystemAdmin
**Success:** 204 / 404
**Notes:**

## ICD-ADM.004 Certificates and revocation (`api/certificates`) - CODE-OBSERVED

### POST

**Path:** `/api/certificates/{id}/revoke`
**Authorization:** DeviceAdmin
**Success:** 200 `{"status": "revoked"}`
**Notes:** Body `{"reason": "<RevocationReason>"}`; invalid reason (or `RemoveFromCrl`) → 400; failure returns the connector/service status (404/409/501/503)

Revocation reasons enum (CODE-OBSERVED, `RevocationReason`): parsed case-insensitively, must be a defined value, `RemoveFromCrl` explicitly rejected by the API.

## ICD-ADM.005 Users (`api/users`) - CODE-OBSERVED (controller-level SystemAdmin)

| Method | Path | Notes |
|---|---|---|
| GET | `/api/users` | 200 `UserDto[]` |
| GET | `/api/users/{id}` | 200 / 404 |
| POST | `/api/users` | 201 `UserDto`; 400 invalid; 409 conflict (duplicate/last-admin rules) |
| PUT | `/api/users/{id}` | 200; role/active/password change; blank password preserves current (DOCUMENTED) |
| DELETE | `/api/users/{id}` | 204 / 400 (self-delete or last active SystemAdmin blocked) / 404 |

## ICD-ADM.006 API keys (`api/users/{userId}/api-keys`) - CODE-OBSERVED

### GET

**Path:** `/api/users/{userId}/api-keys`
**Authorization:** authenticated; self or SystemAdmin (else 403)
**Notes:** 200 `ApiKeyDto[]`

### POST

**Path:** `/api/users/{userId}/api-keys`
**Authorization:** DeviceAdmin; self or SystemAdmin
**Notes:** 201 `GenerateApiKeyResponseDto` (raw key shown once); 400/403

### DELETE

**Path:** `/api/users/{userId}/api-keys/{keyId}`
**Authorization:** self or SystemAdmin
**Notes:** 204 revoked / 403 / 404

## ICD-ADM.007 Auth (`api/auth`) - CODE-OBSERVED

### GET

**Path:** `/api/auth/status`
**Authorization:** anonymous
**Notes:** 200 `AuthStatusDto{mode, username?, role?, userId?}`

### POST

**Path:** `/api/auth/setup`
**Authorization:** anonymous
**Notes:** 200 `AuthResponseDto{token, expiresAt, role, username, userId}`; 409 when setup already completed; 400 invalid

### POST

**Path:** `/api/auth/login`

**Authorization:** anonymous
**Notes:** 200 `AuthResponseDto`; 401 generic "Invalid username or password."

### POST

**Path:** `/api/auth/logout`
**Authorization:** authenticated
**Notes:** 204 (JWT is stateless; client discards token)

### GET

**Path:** `/api/auth/me`
**Authorization:** authenticated
**Notes:** 200 `{id, username, role}`

## ICD-ADM.008 Gateway settings (`api/settings/gateway`) - CODE-OBSERVED

### GET

**Path:** `/api/settings/gateway`
**Authorization:** authenticated
**Notes:** 200 `GatewaySettingsDto` (`defaultCertificateLifetimeHours`, `minCertificateLifetimeHours`, `maxCertificateLifetimeHours`, timestamps)

### PUT

**Path:** `/api/settings/gateway`
**Authorization:** SystemAdmin
**Notes:** 200 `GatewaySettingsDto`; 400 invalid

## ICD-ADM.009 Notification settings (`api/settings/notifications`) - CODE-OBSERVED

### GET

**Path:** `/api/settings/notifications`
**Authorization:** authenticated
**Notes:** 200 `NotificationSettingsDto` (SMTP host/port, `tlsMode`, `authMode`, `hasPassword` - plaintext never returned)

### PUT

**Path:** `/api/settings/notifications`
**Authorization:** SystemAdmin
**Notes:** 200; `password` null=preserve, empty=clear, non-empty=store encrypted

### GET

**Path:** `/api/settings/notifications/recipients`
**Authorization:** authenticated
**Notes:** 200 `NotificationRecipientDto[]`

### POST

**Path:** `/api/settings/notifications/recipients`
**Authorization:** SystemAdmin
**Notes:** 200 upsert `NotificationRecipientDto`; 400

### DELETE

**Path:** `/api/settings/notifications/recipients/{id}`
**Authorization:** SystemAdmin
**Notes:** 204 / 404

### POST

**Path:** `/api/settings/notifications/test`
**Authorization:** SystemAdmin
**Notes:** 204 on success; 400 on failure (draft settings, stored password used when `Password` null)

## ICD-ADM.010 Status and health (`api/status`) - CODE-OBSERVED

### GET

**Path:** `/api/status/enrollments?profileId=&limit=`
**Authorization:** authenticated
**Notes:** 200 `EnrollmentEventDto[]`; invalid profileId → 400; limit clamped 1-1000, default 50

### GET

**Path:** `/api/status/health`
**Authorization:** anonymous (health-check middleware)
**Notes:** 200 healthy

### GET

**Path:** `/api/status/logs/recent?sinceSeq=&limit=`
**Authorization:** authenticated
**Notes:** 200 `LiveLogPageDto` (in-memory live-log ring buffer; pollable cursor protocol; limit clamped 1-1000, default 200)

## ICD-ADM.011 CRL distribution (`api/crl`) - CODE-OBSERVED

### GET

**Path:** `/api/crl/{issuerFingerprint}.crl`
**Authorization:** **anonymous** (`AllowAnonymous`)
**Notes:** 200 DER CRL, Content-Type `application/pkix-crl`, `Cache-Control: public, max-age=<seconds until NextUpdate>`; 404 when no CRL exists for the issuer fingerprint

## ICD-ADM.012 ACME challenge (`/.well-known/acme-challenge`) - CODE-OBSERVED

### GET

**Path:** `/.well-known/acme-challenge/{token}`
**Authorization:** anonymous

**Notes:** 200 `text/plain` key authorization; 404 unknown token

## 11. OpenAPI file status and TO-BE contract fragment - AS-IS contract-first designs

**Provenance:** CODE-OBSERVED (file inspection). The repository-root OpenAPI files are partial, contract-first designs without an `openapi:` root document; they describe intended Admin resources and are **not** a verified description of the implemented behavior:

| File | Status | Content |
|---|---|---|
| `OpenAPI.Admin.yaml` | AS-IS contract-first design; paths match `CaBackendsController` (list/create/get/put/delete, `generate-selfsigned` documented in detail) | No security scheme declaration; no `/active`, `/test`, `/activate` paths |
| `OpenAPI.ESTProfiles.yaml` | AS-IS contract-first design; matches `EstProfilesController` CRUD | No security scheme declaration |
| `OpenAPI.StatusObserve.yaml` | AS-IS contract-first design; `/api/status/health`, `/api/status/enrollments` | Matches `StatusController` |
| `OpenAPI.Schema.yaml` | AS-IS shared schemas (`CaBackend`, `EstProfile`, `EnrollmentEvent`); **stale** relative to DTOs (missing `hostnameMatchType`, `validityDays`, `requireClientCertificate`, trust-policy fields, `isEnabled/isActive`) | Drift finding |
| `OpenAPI.Client.yaml` | **Empty file (0 bytes)** | No content; interface UNKNOWN; drift finding |

The `EstProfile` DTO (CODE-OBSERVED, `EstProfileDto.cs`) is the authoritative AS-IS resource shape. A fully-specified admin resource fragment - **TO-BE contract (PROPOSED, OpenAPI 3.1)** for review as the approved EST-profile management contract:

```
openapi: 3.1.0
info: { title: Kryptonian Admin API - EST Profiles, version: 0.1.0-draft }
components:
  securitySchemes:
    ApiKey: { type: apiKey, in: header, name: X-API-Key }
    JwtBearer: { type: http, scheme: bearer }
  schemas:
    EstProfile:
      type: object
      properties:
        id: { type: string }
        name: { type: string }
        hostnames: { type: array, items: { type: string } }
        hostnameMatchType: { type: string, enum: [exact, suffix, wildcard] }
        allowedWildcardSuffix: { type: string }
        pathPrefix: { type: string, default: /.well-known/est }
        caBackendId: { type: string }
        certificateTemplate: { type: string }
        allowedKeyUsages: { type: array, items: { type: string } }
        validityDays: { type: integer, default: 365 }
        requireClientCertificate: { type: boolean, default: true }
        validateClientCertificateChain: { type: boolean, default: false }
        trustedClientCaThumbprints: { type: array, items: { type: string } }
        isEnabled: { type: boolean }
```

```
        createdAt: { type: string, format: date-time }
        updatedAt: { type: string, format: date-time }
paths:
  /api/est-profiles:
    get:
      security: [{ ApiKey: [] }, { JwtBearer: [] }]
      responses:
        '200':
          description: Profiles
          content:
            application/json:
              schema: { type: array, items: { $ref: '#/components/schemas/EstProfile' } }
    post:
      security: [{ ApiKey: [] }, { JwtBearer: [] }]
      x-required-role: SystemAdmin
      responses:
        '201': { description: Created }
        '400': { description: Invalid profile }
        '401': { description: Authentication required }
        '403': { description: SystemAdmin role required }
```

## 12. Error model and error codes (ICD-ERR.001)

**Provenance:** CODE-OBSERVED (controllers); DOCUMENTED (`docs/API-GUIDE.md`).

AS-IS error body shapes (all `application/json`):

- EST endpoints: `{"error": "<message>"}` and, for pending, `{"error": "<message>", "retryAfter": <seconds>}`.
- Admin endpoints: `{"error": "<message>"}` from controller catch blocks.
- API guide documents an extended shape `{"error", "details", "correlationId"}`; correlation/request IDs are injected by `RequestIdMiddleware` into logging context. Whether the extended shape is emitted by any endpoint is **UNKNOWN** (the guide is DOCUMENTED-only for that shape; controllers observed emit `{error}` only).

AS-IS status-code semantics across both APIs:

| Code | Meaning | Typical cause |
|---|---|---|
| 200 | Success | |
| 201 | Created | POST resource creation |
| 202 | Accepted (pending) | Async issuance; check `Retry-After` |
| 204 | No Content | Delete / logout / test notification |
| 400 | Bad Request | Invalid CSR, invalid body, invalid arguments |
| 401 | Unauthorized | Missing/invalid API key, JWT, client certificate, activation credential |
| 403 | Forbidden | Role policy failure, cert validation failure, Basic-over-HTTP, untrusted cert-forwarding proxy |
| 404 | Not Found | Unknown profile/backend/device/certificate/id; unknown label |
| 409 | Conflict | Setup already done; already revoked; issuer fingerprint mismatch; CA rotation |
| 413 | Payload Too Large | CSR > 64 KiB |

| Code | Meaning | Typical cause |
|---|---|---|
| 426 | Upgrade Required | EST over plain HTTP |
| 429 | Too Many Requests | Rate limit exceeded |
| 500 | Server Error | Unexpected failures; crypto generation failure |
| 501 | Not Implemented | Remote-CA revocation unsupported (fail-closed signal, §14) |
| 503 | Service Unavailable | CA backend unavailable/expired |

TO-BE/PROPOSED: a single canonical error schema with stable machine-readable codes and correlationId for both APIs (SR-ADM, SR-F-INT); not implemented at baseline.

## 13. Certificate and CSR formats (ICD-PCR.001-ICD-PCR.003)

**Provenance:** CODE-OBSERVED (`PkcsService.cs`, `CertificateDto.cs`, `CrlController.cs`).

ICD-PCR.001 - PKCS#10 CSR ingestion (AS-IS):

- Accepted encodings: raw DER; base64; PEM with headers `-----BEGIN CERTIFICATE REQUEST-----` or legacy `-----BEGIN NEW CERTIFICATE REQUEST-----`.
- The CSR **signature is always verified** (`Pkcs10CertificationRequest.Verify`); verification failure throws `CryptographicException` and the enrollment is rejected (CODE-OBSERVED).
- Parsed CSR exposes (`ParsedCsr`): `RawData` (DER), `SubjectDn`, `PublicKey`, `PublicKeyAlgorithm` (RSA / ECDSA), `KeySize`, `SignatureAlgorithm`, `SubjectAlternativeNames` (DNS/IP/email/URI extracted from the extension-request attribute).
- Enrollment policy additionally enforces CSR and returned-certificate policy (subject-DN rules per profile, key-usage enforcement) - PR #43 (DOCUMENTED, `docs/IMPLEMENTATION-TRACKER.md`).

ICD-PCR.002 - Returned certificates and chains (AS-IS):

- EST responses: PKCS#7 degenerate SignedData, certs-only, base64-encoded (`application/pkcs7-mime`), containing the leaf certificate and the issuer chain returned by the connector.
- Admin API representation (`CertificateDto`): PEM string (`certificatePem`), optional DER base64 (`certificateDerBase64`), `serialNumber`, `subjectDn`, `issuerDn`, `thumbprint`, validity window, `caBackendId`, `caBackendType`, `gatewayOid` (private OID arc `1.3.6.1.4.1.99999.*` used for identity binding, CODE-OBSERVED).

ICD-PCR.003 - CRL format (AS-IS):

- Issuer-scoped, signed DER CRLs (RFC 5280), Content-Type `application/pkix-crl`, keyed by SHA-256 issuer fingerprint (`/api/crl/{issuerFingerprint}.crl`).
- CRL state persisted per issuer (`issuer_crl_states`: fingerprint unique, monotonically increasing `crl_number`, thisUpdate/nextUpdate, base64 DER).
- AS-IS prototype CRL lifetime is **60 seconds** (`PrototypeCrlLifetime`) or the issuer's NotAfter, whichever is earlier - a deliberate prototype cadence (CODE-OBSERVED comment); production cadence is a TO-BE decision.
- Revocation persistence is transactional: state update and revocation commit are wrapped in a unit-of-work transaction with rollback on failure (CODE-OBSERVED; PR #46).

# 14. Internal CA connector contract (ICD-CAI.001) - language-neutral contract

**Provenance:** CODE-OBSERVED (`ICaConnector.cs`, `ICaConnectorFactory.cs`, value objects, connector implementations). Signatures are recorded as a language-neutral contract; the C# interface is the reference implementation.

Contract - CA connector (per CA backend):

```
operation Type() -> CaBackendType          {SelfSigned | Acme | Adcs | Ejbca | ...}
operation GetCaCertificatesAsync(ct) -> X509Certificate2[]
    outputs: ordered CA chain for the backend's issuer
    failure: empty array (ACME/EJBCA pre-issuance) or exception (caller maps
             to 404/403/503)
operation IssueCertificateAsync(csr: ParsedCsr, profile: EstProfile, ct)
    -> CertificateIssuanceResult
    outputs: Successful(leafCert, chain) | Failed(message)
    failure semantics: never throws for backend rejection; returns Failed
                       with a message; gateway logs and maps to HTTP status
operation RevokeCertificateAsync(serial, reason, ct) -> bool
    semantics: native remote-CA revocation mutation only; unsupported
               backends return false and log a warning (never silent success)
operation GenerateCrlAsync(request: CrlGenerationRequest, ct)
    -> CrlGenerationResult
    default: Unsupported() (Supported=false, no DER)
    semantics: builds a complete signed CRL for the connector's current
               issuer; must echo ExpectedIssuerFingerprint on success
operation TestConnectionAsync(ct) -> bool
    semantics: best-effort reachability probe (GET /health)
```

Contract - connector factory:

```
operation CreateConnector(backend: CaBackend) -> ICaConnector
    failure: NotSupportedException for unimplemented backend types
             (Cfssl, HashiCorpVault, Smallstep, OpenXpki) - fail-closed;
             ArgumentException for unknown type
    caching: one connector instance per backendId (memoized, thread-safe)
operation GetCachedConnector(backendId) -> ICaConnector?
```

## ICD-CAI.002 Per-connector capabilities table - AS-IS (CODE-OBSERVED)

### Implementation

**Self-Signed:** `Crypto/SelfSignedCaConnector.cs` (local file-based CA) or `Harness/SelfSignedEstCaConnector.cs` when a harness base URL is configured

**ACME:** `Acme/AcmeCaConnector.cs` (Certes library)

**ADCS:** `Harness/AdcsCaConnector.cs` (SCEP client)

**EJBCA:** `Harness/EjbcaCaConnector.cs` (REST client)

### `GetCaCertificatesAsync`

**Self-Signed:** Local CA cert(s) from PFX/PEM; harness PEM list

**ACME:** Cached chain from last issuance; well-known ISRG/ZeroSSL/BuyPass chain fallback

**ADCS:** SCEP `GetCACert` (first cert of signed-data response)

**EJBCA:** Per-instance cached chain only; fresh scoped connector starts empty, even after issuance in another request

### `IssueCertificateAsync`

**Self-Signed:** Local signing (BouncyCastle); harness EST relay when harness configured

**ACME:** Full ACME order flow (http-01/dns-01, optional EAB)

**ADCS:** SCEP `PKIOperation` with PKCSReq

**EJBCA:** REST `POST /ejbca/ejbca-rest-api/v1/certificate/pkcs10enroll`

### Native remote revocation

**Self-Signed: No** (returns false)
**ACME:** No revocation path exercised in inspected code
**ADCS: No** (returns false; revoke in ADCS or add protocol integration)
**EJBCA: Yes** (`PUT /certificate/{issuerDn}/{serial}/revoke`, requires `IssuerDn` config; false otherwise)

#### `GenerateCrlAsync`

**Self-Signed:** Supported (gateway-side signed CRL)
**ACME:** Default → **Unsupported**
**ADCS:** Default → **Unsupported**
**EJBCA:** Default → **Unsupported**

### Revocation fail-closed behavior

**Self-Signed:** Revocation proceeds via gateway-signed CRL
**ACME:** Revocation requests fail closed (CRL generation unsupported → error, no silent success)
**ADCS: Fail closed**: remote revocation unsupported and CRL generation unsupported → revocation fails
**EJBCA: Fail closed** unless native revoke succeeds; CRL generation still unsupported → 409/501/503-class failure

### Key/credential configuration

**Self-Signed:** PfxPath+PfxPassword or CertPath+KeyPath; harness: HarnessBaseUrl only
**ACME:** DirectoryUrl, Email, PreferredChallengeType, EabKeyId+EabHmacKey
**ADCS:** BaseUrl (SCEP), TemplateName, ValidityDays, EnrollmentAgentPfx/PfxPassword/Thumbprint (mTLS to NDES)
**EJBCA:** BaseUrl (REST), CertificateProfile, EndEntityProfile, IssuerDn, ValidityDays

### Connector-specific limitations

**Self-Signed:** Private CA key must be exportable for BouncyCastle signing (hardening note: HSM-backed keys for production, CODE-OBSERVED comment)
**ACME:** HTTP-01 needs publicly reachable `/.well-known/acme-challenge/`; dns-01 stub (`Dns01ChallengeStub`) not a production DNS integration; `/cacerts` empty on a fresh connector instance
**ADCS:** ADCS hospital interoperability **unverified** (DOCUMENTED, tracker); SCEP chain limited to the returned certificate
**EJBCA:** EJBCA hospital interoperability **unverified** (DOCUMENTED, tracker); chain empty pre-issuance; issuer rotation conflicts rejected (409)

ICD-CAI.003 - Revocation orchestration failure semantics - AS-IS (CODE-OBSERVED, `CertificateRevocationService`):

- Certificate missing → 404; already revoked → 409.
- Certificate with no CA backend → 501; connector type unimplemented → 501.
- Backend disabled → 503; issuer certificate expired → 503.
- Issuer mismatch / leaf-does-not-chain failure / fingerprint-vs-backend mismatch / rotated CA certificate → 409 (fail closed, no partial state).
- `GenerateCrlAsync` returning `Unsupported`, a null/empty DER, or a mismatched issuer fingerprint causes the operation to fail (fail closed). Unsupported remote-CA revocation therefore **fails closed** - consistent with `docs/IMPLEMENTATION-TRACKER.md` (DOCUMENTED).

### Enrollment orchestrator contract (ICD-CAI.004) - AS-IS (CODE-OBSERVED)

```
operation GetCaCertsAsync(profileId, ct) -> byte[]  (PKCS#7 certs-only)
    rejects: profile missing/disabled, backend missing/disabled,
             empty chain -> InvalidOperationException (404-mapped)
operation EnrollAsync(profileId, csrBytes, deviceId?, clientIp, ct,
                      activationCode?, manufacturer?, model?, serial?)
    -> EnrollmentResult {Success|Failed(status)|Pending(retryAfter)}
    semantics: validates activation credential, CSR policy, subject-CN
               uniqueness; persists EnrollmentEvent; dispatches rejection
               notifications
operation EnrollAdminAsync(profileId, deviceRecordId, csrBytes, clientIp, ct)
    -> EnrollmentResult    (admin workflow, not public EST)
operation ReenrollAsync(profileId, csrBytes, existingCert, clientIp, ct)
    -> EnrollmentResult
    semantics: authenticates with the existing certificate, preserves the
               approved identity, issues a new key-bound certificate
```

## 15. Database integration interfaces (ICD-DAT.001) - AS-IS

**Provenance:** CODE-OBSERVED (`Program.cs`, `KryptonianDbContext.cs`, `SchemaUpgrades.cs`); DOCUMENTED (`docs/IMPLEMENTATION-TRACKER.md`).

- EF Core providers: `Kryptonian:Database:Provider` = `Sqlite` | `PostgreSQL` | `InMemory`. When unset: PostgreSQL if a connection string is present, otherwise InMemory (with a startup warning). Unknown values fail startup.
- Connection string: `ConnectionStrings:DefaultConnection` or `Kryptonian:Database:ConnectionString`. SQLite default (no config): `Data Source=kryptonian.db;Cache=Shared`. PostgreSQL without a connection string fails startup. PostgreSQL uses `NpgsqlDataSourceBuilder` with dynamic JSON enabled (dictionary config columns).
- **Schema creation/upgrades:** existing installations use `EnsureCreated`, not EF migrations. `SchemaUpgrades.EnsureTrustPolicyAsync` performs **additive-only** upgrades (never recreates a populated database):
  - PostgreSQL: `ALTER TABLE ... ADD COLUMN IF NOT EXISTS` for `est_profiles.validate_client_certificate_chain`, `est_profiles.trusted_client_ca_thumbprints`, `certificates.revoked_at`, `certificates.revocation_reason`; unique index `ix_certificates_issuer_serial (ca_backend_id, serial_number)` replacing the serial-only index; `issuer_crl_states` table (`CREATE TABLE IF NOT EXISTS`) with unique issuer fingerprint and unique per-backend index.
  - SQLite: same columns/tables via `PRAGMA table_info` existence checks and `ALTER TABLE ADD COLUMN` / `CREATE TABLE IF NOT EXISTS`.
- `KryptonianDbContextFactory` provides design-time context creation.
- Repository access is through `IUnitOfWork` (aggregate of typed repositories plus transactional primitives `BeginTransactionAsync/Commit/Rollback/ TryPersistRevocationStateAsync`).
- Known boundary (DOCUMENTED): PostgreSQL schema upgrades are implemented but only SQLite persistence was exercised at baseline.

## 16. Configuration interfaces (ICD-CFG.001-ICD-CFG.002)

**Provenance:** CODE-OBSERVED (`Program.cs`, `ApiKeyAuthenticationHandler.cs`, `appsettings.json`, `CaConnectorFactory.cs`); DOCUMENTED (`docs/ca-backend-configuration.md`, `docs/user-management.md`).

ICD-CFG.001 - Configuration keys (appsettings `Kryptonian:*`; environment equivalents use the double-underscore convention):

| Key / env var | Meaning | AS-IS default / behavior |
|---|---|---|
| `Kryptonian:Database:Provider` | Persistence provider | unset → PostgreSQL if connection string present, else InMemory |
| `Kryptonian:Database:ConnectionString` | Connection string | none; `ConnectionStrings:DefaultConnection` preferred |
| `KRYPTONIAN__ADMINAPI__APIKEYS` / `Kryptonian:AdminApi:ApiKeys` | Static API keys (comma-separated) acting as SystemAdmin | none; with none set, users rely on JWT or DB keys (backward-compatible interface, DOCUMENTED) |
| `Kryptonian:AdminApi:AllowAnonymousInDevelopment` | Dev bypass when no static keys | false; only active in Development |
| `Kryptonian:Auth:JwtSecret` / `KRYPTONIAN__AUTH__JWTSECRET` | JWT signing key | **falls back to a hard-coded development secret** - finding for KSPEC-010 (security) |
| `Kryptonian:Auth:JwtLifetimeHours` | JWT lifetime | 8 hours (DOCUMENTED) |
| `Kryptonian:Auth:InitialAdminUsername/Password/Email` (env: `KRYPTONIAN__AUTH__INITIAL_ADMIN_*`) | First-admin bootstrap seeding | optional; seeds only when setup is pending |
| `Kryptonian:Tls:RequireTls12` | Minimum TLS version | true |
| `Kryptonian:Tls:EstPort` / `Tls:AdminPort` | Listener ports | 8443 / 8080 |
| `Kryptonian:Tls:ClientCaFiles` | PEM CA files for strict client-cert trust at the listener | none (validation then per-profile) |
| `Kryptonian:Tls:RedirectHttpToHttps` | HTTPS redirection | enabled outside Development |
| `Kryptonian:Est:AllowPlainHttp` | Dev escape hatch for HTTP EST | false |
| `Kryptonian:CertificateForwarding:KnownProxies` | IP allow-list for `X-Forwarded-Client-Cert` forwarding | empty → header rejected (fail closed) |
| `Kryptonian:Ui:AllowedOrigins` | CORS origins for the dashboard | localhost:5173 variants |
| `Kryptonian:Sandbox:Enabled` | Windows sandbox/installer mode | false; sandbox requires Production environment |
| `Kryptonian:CA:SelfSigned:*` (`KRYPTONIAN__CA__SELFSIGNED__PFXPATH/PFXPASSWORD/CERTPATH/KEYPATH/CRLDISTRIBUTIONPOINTURL`) | Self-signed CA fallbacks | used when backend JSON config omits the property |
| `KRYPTONIAN__CA__ADCS__SCEPBASEURL`, `__ADCS__ENROLLMENTAGENT*` | ADCS connector fallbacks | required unless backend URL/config set |

| Key / env var | Meaning | AS-IS default / behavior |
|---|---|---|
| `KRYPTONIAN__CA__EJBCA__RESTBASEURL`, `__EJBCA__ISSUERDN` | EJBCA connector fallbacks | required unless backend URL/config set |
| `KRYPTONIAN__CA__HARNESS__BASEURL` | Harness base URL for the self-signed harness relay | optional |
| `KRYPTONIAN__ACME__DIRECTORYURL/EMAIL/EABKEYID/EABHMACKEY/CHALLENGETYPE` | ACME connector fallbacks | Let's Encrypt production directory fallback |
| `IpRateLimiting:*` | AspNetCoreRateLimit rules (§8) | see §8 |

ICD-CFG.002 - Secret-handling rules (AS-IS):

- SMTP passwords: stored encrypted (ASP.NET Data Protection, application name `RTSec.Kryptonian`; persisted to disk in sandbox mode), never returned by the API (`hasPassword` boolean only), CODE-OBSERVED.
- ACME account keys: encrypted at rest via `IDataProtectionService` (CODE-OBSERVED).
- Activation codes: stored hashed, shown once via `DeviceActivationCodeDto` (DOCUMENTED).
- API keys: stored as SHA-256 hashes with a visible 8-char prefix only; raw key shown once at generation (CODE-OBSERVED).
- Backend config dictionaries may contain PFX passwords in plaintext in the database (CODE-OBSERVED DTO/`config` passthrough) - finding for KSPEC-006/010.

## 17. External system dependencies (ICD-EXT.001-ICD-EXT.004)

**Provenance:** CODE-OBSERVED unless noted.

ICD-EXT.001 - SMTP (notifications): MailKit-based `MailKitSmtpSender`; settings via the notification-settings API (`starttls`/TLS modes, auth modes, `TrustServerCertificate`); used for enrollment-rejection and near-expiry notifications (`CertificateExpiryWatcher` hosted service). Dependency surface only; gateway function does not depend on SMTP availability (best-effort notification dispatch, CODE-OBSERVED).

ICD-EXT.002 - ACME directories: any RFC 8555 directory; well-known constants for Let's Encrypt production/staging, ZeroSSL, BuyPass (test/production). Requires reachable `/.well-known/acme-challenge/{token}` on the gateway for http-01, or a DNS-01 provider (stub only). External Account Binding (EAB) supported.

ICD-EXT.003 - ADCS/NDES (SCEP): endpoints `GET {base}/scep/adcs?operation=GetCACert` and `POST {base}/scep/adcs?operation=PKIOperation` (`application/x-pki-message`); optional enrollment-agent mTLS credential (PFX path/password or machine-store thumbprint) required when NDES enforces challenge mode; health probe `GET {base}/health`. Interoperability with real ADCS is **unverified** (DOCUMENTED).

ICD-EXT.004 - EJBCA (REST): `POST {base}/ejbca/ejbca-rest-api/v1/certificate/pkcs10enroll`, `PUT {base}/ejbca/ejbca-rest-api/v1/certificate/{issuerDn}/{serial}/revoke`; health probe `GET {base}/health`. Interoperability with real EJBCA is **unverified** (DOCUMENTED).

Additional: the Self-Signed *harness* relay targets a local harness service (`GET api/backends/selfsigned/cacerts`, `POST est/selfsigned/simpleenroll`) - a test-harness dependency, not a production backend.

# 18. Versioning and interoperability requirements (ICD-VER.001-ICD-VER.003)

ICD-VER.001 - API versioning policy - AS-IS observation + TO-BE/PROPOSED (CODE-OBSERVED; policy text PROPOSED):

- AS-IS: no URL or header versioning; Swagger declares a single `v1` document. Admin API changes are currently implicitly additive (new optional DTO fields).
- TO-BE/PROPOSED (SR-ADM, SR-F-INT): adopt a versioning policy (e.g., URL-prefix `/api/v{n}` or a documented additive-only contract with deprecation windows) before any breaking Admin API change; publish OpenAPI as the single source of truth. Not approved at baseline.

ICD-VER.002 - Backwards-compatibility rules for EST clients - PROPOSED (SR-F-INT, SR-EST):

- Approved-direction rules (subject to review): never remove or repurpose the implemented EST paths, content types (`application/pkcs10` requests, `application/pkcs7-mime` certs-only responses), or the `Retry-After` pending contract; unknown `{label}` handling (404, no fallback) is a deliberate contract, not a bug; `text/plain` CSR acceptance is a leniency that may be narrowed but not made mandatory for clients.
- The bundled sample device client (`src/Kryptonian.MedicalDevice/Enrollment/*`) is a reference client, not a product deliverable (KSPEC-000 §3); its wire behavior does not define the platform contract.

ICD-VER.003 - Deprecated legacy activation headers - **AS-IS compat only, NOT a mandatory interoperability requirement**:

- `X-Activation-Code`, `X-Device-Manufacturer`, `X-Device-Model`, `X-Device-Serial-Number` are retained in the baseline for compatibility with the existing sample device client (`docs/IMPLEMENTATION-TRACKER.md`, Deliberate boundaries: "The independent EST path uses standard Basic authentication; the existing sample device client retains legacy activation headers for compatibility. They are not mandatory for other clients and must not become a new interoperability requirement." - DOCUMENTED).
- Accordingly, this ICD records them as AS-IS compatibility behavior only; KSPEC-003 shall not derive an SR-F-INT requirement mandating them, and any partner-facing EST client profile shall be built on HTTP Basic bootstrap + native TLS client certificate re-enrollment.

# 19. Traceability summary (area-level; concrete bindings in KSPEC-009)

| This document | Requirement prefix area | Owner |
|---|---|---|
| §3-§9 EST interfaces | SR-EST, SR-A, SR-S, SR-F-INT | KSPEC-003 |
| §10-§11 Admin REST and OpenAPI contracts | SR-ADM, SR-Z | KSPEC-003 |
| §12 Error model | SR-ADM, SR-F-INT | KSPEC-003 |
| §13 Certificate/CSR/CRL formats | SR-C, SR-D | KSPEC-003 |
| §14 CA connector contract | SR-CAI, SR-C | KSPEC-003 |
| §15 Database interfaces | SR-D, SR-B | KSPEC-003 |
| §16 Configuration interfaces | SR-B, SR-S | KSPEC-003 |
| §17 External dependencies | SR-F-INT, SR-X | KSPEC-003 |
| §18 Versioning/interoperability | SR-F-INT, SR-EST | KSPEC-003 |

# 20. Open items for review

1. OpenAPI.Schema.yaml drift vs DTOs; OpenAPI.Client.yaml is empty (0 bytes).
2. EST paths absent from all repository OpenAPI files (fragment provided in §5).
3. Extended error shape (`details`, `correlationId`) documented but not observed emitted by controllers.
4. `POST /api/cas/{id}/test` lacks a DeviceAdmin/SystemAdmin role policy (authentication only).
5. JWT secret falls back to a hard-coded development value.
6. `POST /api/device-requests` is anonymous by design (self-service approval request) - confirm intended authorization model.
7. Pending-response trigger conditions per CA backend not fully characterized.
8. 60-second prototype CRL lifetime requires production policy decision.
9. Whether a no-credential simpleenroll can succeed on an open profile (UNKNOWN, §4.4).

# Kryptonian Formal Engineering Specification - Cybersecurity Architecture and Threat Model

| Field | Value |
|---|---|
| Document ID | KSPEC-006 |
| Title | Cybersecurity Architecture and Threat Model (STRIDE) |
| Version | 0.2 (Draft) |
| Status | Draft - pending review |
| Created | 2026-10-13 |
| Baseline commit | `682f996c8447afec13bc1fce5b7f59e6a06efa25` (branch `feat/windows-sandbox-installer`, "Release Windows gateway and portable enrollment demo 0.1.4") |
| Revision history | 0.1 - 2026-10-13 - Initial draft STRIDE threat model covering 18 threat entries (THR-001 … THR-018), trust-boundary diagram, controls-to-requirements mapping, residual-risk summary |
| Source references | KSPEC-000 (conventions); `docs/IMPLEMENTATION-TRACKER.md`; `docs/ARCHITECTURE.md` (Security Architecture); `docs/device-enrollment.md`; `docs/user-management.md`; `docs/ORNET-ALIGNMENT-2026-09-09.md`; source under `src/RTSec.Kryptonian.{Api,Application,Infrastructure}`; tests under `tests/`; `docs/formal-specification/07-OPERATIONAL-RISK.md` |
| Author | *Name / Date / Signature* |
| Reviewer | *Name / Date / Signature* |
| Approver | *Name / Date / Signature* |
| Reconciliation revision | 0.2 - 2026-10-13 - source/document audit and publication controls (KSPEC-016) |

## 1. Purpose and scope

This document is the cybersecurity architecture and threat model (KSPEC-006) for RTSec.Kryptonian at baseline commit `682f996c8447afec13bc1fce5b7f59e6a06efa25`. It applies the STRIDE methodology (Spoofing, Tampering, Repudiation, Information disclosure, Denial of service, Elevation of privilege) to the gateway's security assets, threat actors, and attack surfaces, and records:

- security assets and their ownership,
- threat actors and their assumed capabilities,
- attack surfaces and trust boundaries (Mermaid diagram, KSPEC-000 §12),
- a structured threat catalog with `THR-nnn` entries (owned by this document per KSPEC-000 §7),
- existing (AS-IS) controls with evidence provenance per KSPEC-000 §5,
- proposed (PROPOSED) controls requiring stakeholder approval,
- residual-risk ratings and a controls-to-requirements mapping.

Scope: deliberate security threats against the gateway, its EST endpoints, admin API and portal, CRL publication, CA-backend connections, persistence layer, and notification path; and misuse of gateway-managed credentials (device certificates, activation codes, admin credentials, API keys, CA signing keys).

Out of scope:

- Medical-device hazard classification, IEC 62304 lifecycle classification, ISO 14971 medical-device risk management, and clinical harm probabilities. Kryptonian is enterprise healthcare IT cybersecurity infrastructure - an EST (RFC 7030) certificate enrollment and credential lifecycle gateway. It is not a regulated medical device and performs no clinical functions (KSPEC-000 §3).
- Clinical capability: device clinical function is never derived from Kryptonian state. Credential compromise degrades device *network identity and secure communication*, never clinical capability.
- Non-adversarial failure modes (component failure, power loss, clock drift, misconfiguration without an adversary); these are covered by KSPEC-007 (ORK-*) except where threat and operational risk intersect (cross-referenced as noted).
- Attacks against downstream applications that merely *use* gateway-issued certificates (DICOM associations, SDC participation) beyond the point at which the gateway's revocation data and trust policy reach them.
- No security standards conformity is claimed in this document. Control-framework references (§10) are recommended practices only, per KSPEC-000 §13.

# 2. Method, scales, and classification rules

## 2.1 Method

Each threat entry (identifier prefix `THR-`, owned by this document per KSPEC-000 §7) is analyzed as:

1. **Description** - the attacker's goal, capability, and attack path.
2. **STRIDE category** - primary category; secondary categories where applicable.
3. **Affected assets / surfaces** - items from §3 and §5.
4. **Existing controls (AS-IS)** - controls present at baseline, each tagged with an evidence provenance class (VERIFIED / CODE-OBSERVED / DOCUMENTED / INFERRED) per KSPEC-000 §5 and repository evidence. Executed-test claims are taken from `docs/IMPLEMENTATION-TRACKER.md` and its test suites; this document adds no new executed evidence of its own.
5. **Proposed controls (PROPOSED)** - recommended enhancements requiring stakeholder approval; never presented as implemented.
6. **Residual risk** - qualitative likelihood × impact after *implemented* (AS-IS) controls only, using the scales in §2.2.
7. **Linked requirements** - prefix-level references into the KSPEC-003 Requirements Register (see §2.4).
8. **Verification** - approach per KSPEC-000 §11 abbreviations (T = Test, I = Inspection, A = Analysis, D = Demonstration).

### 2.2 Qualitative risk scales

| Scale | Likelihood (after AS-IS controls) | Impact (after AS-IS controls) |
|---|---|---|
| Low | Requires privileged or physical access, or an exploitable chain unlikely in the deployment model; effect is trivially recoverable. | Transient, single-device, or fully recoverable effect; no credential compromise; audit trail intact. |
| Medium | Requires a foothold on the hospital network, a stolen low-value credential, or sustained attacker attention; plausible over the product lifetime. | One or a small number of device identities or enrollments affected; revocation/notification still work; manual recovery required. |
| High | Exploitable with commodity tooling by an unauthenticated network peer, or by any holder of an already-stolen low-value credential. | Gateway-wide: unauthorized issuance at scale, CA/trust-anchor compromise, silent loss of revocation, or loss of audit integrity. |

Residual risk band = likelihood × impact, rated Low / Medium / High / Critical (High × High, or High likelihood combined with High-or-worse impact, is rated at least Critical). Ratings are qualitative judgments by the author of this draft, pending review; they are not measurements.

### 2.3 AS-IS / PROPOSED discipline

Per KSPEC-000 §4, prototype behavior and known weak points recorded in `docs/IMPLEMENTATION-TRACKER.md` ("Deliberate boundaries and follow-up") are reported as findings with residual risk; they are never restated as intended requirements. PROPOSED controls in this document require review and approval before they become normative (they would be realized as requirements in KSPEC-003 and verified in KSPEC-008).

### 2.4 Requirement references

The canonical Requirements Register (`docs/formal-specification/03-SOFTWARE-REQUIREMENTS.md`, KSPEC-003) was **not present** when this document was drafted. Linked requirements are therefore **prefix-level references** only (e.g., `SR-A` for authentication, `SR-Z` for authorization, `SR-S` for security, `SR-C` for certificate lifecycle, `SR-U` for audit, `SR-D` for data management, `SR-V` for availability, `SR-B` for deployment, `SR-R` for reliability, `SR-F` for functional), per KSPEC-000 §7. This document does not define, number, or redefine any `SR-*` requirement; concrete IDs will be substituted when the register exists and reconciled in KSPEC-009.

## 3. Security assets

#### AS-1

**Description:** Device private keys
**Owner / custodian:** Device (generated locally by the EST client)
**Notes:** Never transferred to the gateway in the standard flow; device-side key protection is a deployment-policy gap (THR-016)

#### AS-2

**Description:** Device certificates (issued leaves)
**Owner / custodian:** Gateway database + device
**Notes:** Represent device network identity; recorded with subject DN, issuer DN, serial, validity

### AS-3

**Description:** CA signing keys and CA certificates

**Owner / custodian:** Gateway-managed CA backends

**Notes:** Self-signed connector CA PFX under gateway control; institution CAs (ADCS/EJBCA) custodied externally; ACME account keys for public CAs

### AS-4

**Description:** Gateway TLS server keys (admin + EST + CRL listeners)

**Owner / custodian:** Gateway host

**Notes:** PFX files on the gateway host, including sandbox-generated pairs (SandboxBootstrap)

### AS-5

**Description:** Activation codes (one-time bootstrap secrets)

**Owner / custodian:** Gateway-generated; held by the device until use

**Notes:** Stored hashed, time-limited, atomically consumed

### AS-6

**Description:** Administrator credentials and JWT sessions

**Owner / custodian:** Gateway database + browser

**Notes:** BCrypt-hashed passwords; HS256 JWT sessions (8 h default)

### AS-7

**Description:** Admin API keys (`X-API-Key`)

**Owner / custodian:** Gateway database / environment configuration

**Notes:** DB keys stored as SHA-256 hashes; legacy static keys in plaintext configuration

### AS-8

**Description:** JWT signing secret

**Owner / custodian:** Gateway configuration

**Notes:** Hard-coded development fallback exists (AS-IS, flagged in THR-007)

### AS-9

**Description:** Database (devices, certificates, EST profiles, CA backends, users, API keys, enrollment events, issuer CRL state, gateway settings, notification settings)

**Owner / custodian:** Gateway

**Notes:** SQLite exercised; PostgreSQL schema implemented; CA-backend and SMTP credentials data-protected

### AS-10

**Description:** Trust policy / EST profile configuration

**Owner / custodian:** Administrators via admin API

**Notes:** Binds profiles to CA backends, subject-DN rules, key usage, validity, trust expectations

### AS-11

**Description:** Client-TLS trust anchors and issuer trust policy

**Owner / custodian:** Gateway configuration
**Notes:** Custom root trust store for device mTLS and issued-certificate chain validation

### AS-12

**Description:** Audit trail: enrollment events, device events, structured logs (Serilog), live log stream
**Owner / custodian:** Gateway database + log files
**Notes:** Records enrollment/renewal/revocation attempts with outcome, subject DN, requestor IP

### AS-13

**Description:** CRLs and issuer CRL state (CRL number, this/next update, DER)
**Owner / custodian:** Gateway database; published over the CRL HTTP listener
**Notes:** Issuer-scoped; generated and signed by the connector

### AS-14

**Description:** SMTP credentials and notification configuration
**Owner / custodian:** Gateway database (data-protected)
**Notes:** Used by the MailKit sender for enrollment/expiry notifications

### AS-15

**Description:** Gateway software and deployment artifacts
**Owner / custodian:** Repository, installer, Docker images, npm UI bundle
**Notes:** Supply-chain integrity (THR-014)

## 4. Threat actors

### TA-1

**Assumed position:** External attacker on the hospital network (unauthenticated)
**Assumed capability:** Can reach EST, admin, and CRL TCP endpoints; cannot authenticate
**Primary motivation:** Credential acquisition, enrollment abuse, disruption

### TA-2

**Assumed position:** Compromised device (or its local agent)
**Assumed capability:** Holds a valid device certificate and key, or a pending activation code
**Primary motivation:** Impersonating sibling devices, over-privileged enrollment, evasion of revocation

### TA-3

**Assumed position:** Malicious insider / low-privileged administrator
**Assumed capability:** Valid DeviceAdmin/Standard account or API key
**Primary motivation:** Unauthorized issuance, tampering with profiles/devices, audit evasion

### TA-4

**Assumed position:** Compromised CA backend or its connector channel
**Assumed capability:** Can influence or forge issuance/CRL responses from "the CA"
**Primary motivation:** Certificate misissuance, CRL suppression or forgery

### TA-5

**Assumed position:** Supply-chain attacker
**Assumed capability:** Controls a dependency, build step, image, or update channel
**Primary motivation:** Malicious code or vulnerable components in the deployed gateway

### TA-6

**Assumed position:** Network man-in-the-middle
**Assumed capability:** Active position between device/peer and gateway
**Primary motivation:** Request tampering, credential capture, replay, downgrade

### TA-7

**Assumed position:** Host-level attacker on the gateway machine
**Assumed capability:** Filesystem/OS-level access to gateway processes and files
**Primary motivation:** Key/PFX/database/secrets theft, log tampering

## 5. Attack surfaces

### SUF-1

**Endpoint / component:** EST endpoints `/.well-known/est/{label}/cacerts`, `/simpleenroll`, `/simplereenroll`
**Exposure:** HTTPS (8443 / sandbox 7443); HTTPS enforced in middleware (426 over plain HTTP unless explicitly allowed)
**Notes:** Device-facing; bootstrap uses activation code, renewal uses client-certificate mTLS

### SUF-2

**Endpoint / component:** Admin REST API (`/api/*`: auth, users, devices, certificates, profiles, CA backends, settings, logs, notifications)
**Exposure:** HTTPS; JWT Bearer or `X-API-Key`
**Notes:** Role-based authorization (Standard / DeviceAdmin / SystemAdmin)

### SUF-3

**Endpoint / component:** Admin portal (API-served React/TypeScript dashboard plus optional separate Blazor Server portal dashboard)
**Exposure:** HTTPS; browser session
**Notes:** First-run administrator bootstrap wizard on empty database

### SUF-4

**Endpoint / component:** CRL endpoints `GET /api/crl/{issuerFingerprint}.crl`
**Exposure:** HTTP (separate CRL listener, sandbox port 7444) or HTTPS; `[AllowAnonymous]` by design
**Notes:** CRL port accept-only filter: GET/HEAD on `/api/crl` only

### SUF-5

**Endpoint / component:** ACME challenge endpoint (`/.well-known/acme-challenge/*` HTTP-01 store)
**Exposure:** HTTP, public when ACME http-01 is used
**Notes:** Challenge tokens; short-lived by ACME design

### SUF-6

**Endpoint / component:** Database (SQLite file or PostgreSQL)
**Exposure:** Host-local or network DB
**Notes:** Contains hashed secrets, data-protected credentials, CRL state

### SUF-7

**Endpoint / component:** SMTP relay connection
**Exposure:** Outbound from gateway
**Notes:** Credentials and notification routing

### SUF-8

**Endpoint / component:** CA backend connections (Self-Signed local, ACME internet, ADCS/EJBCA intranet, SCEP)
**Exposure:** Outbound per backend protocol
**Notes:** Connector abstraction; remote revocation fails closed when unsupported

### SUF-9

**Endpoint / component:** TLS ingress forwarding headers (`X-Forwarded-Client-Cert`, `X-Forwarded-For`)
**Exposure:** Fronting proxy / load-balancer boundary
**Notes:** Guard restricts XFCC to known proxies

### SUF-10

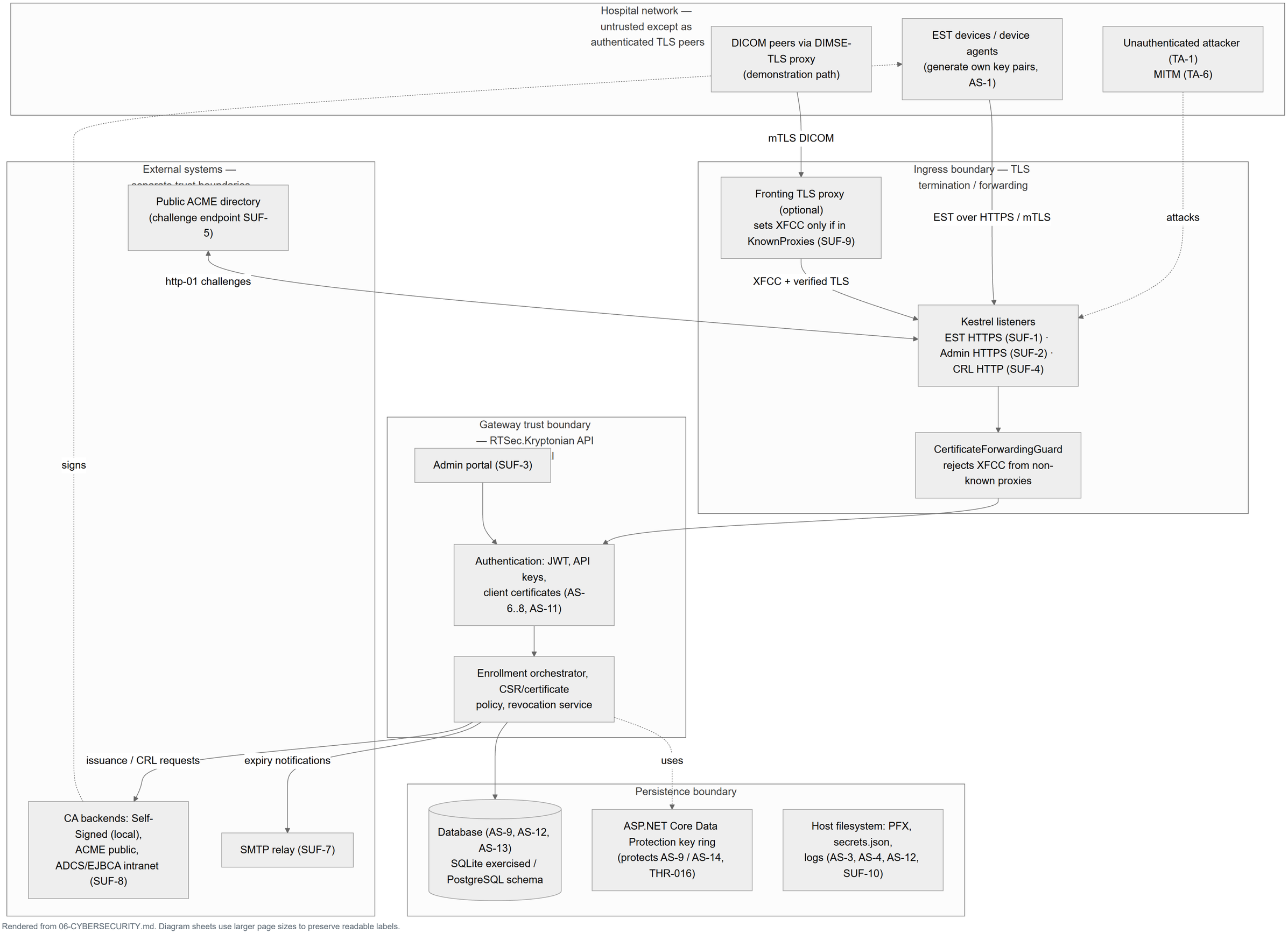
**Endpoint / component:** Gateway host filesystem (PFX files, secrets.json, Data Protection key ring, log files)
**Exposure:** Local only; sandbox restricts ACLs and rejects reparse points
**Notes:** THR-007 / THR-016

### SUF-11

**Endpoint / component:** DIMSE-TLS proxy (demonstration component)
**Exposure:** DICOM peer mTLS termination
**Notes:** AS-IS demonstration only; bounded connection lifetimes

## 6. Trust boundaries

### Diagram KSPEC-006-1




Rendered from 06-CYBERSECURITY.md. Diagram sheets use larger page sizes to preserve readable labels.

Boundary notes (all CODE-OBSERVED unless noted):

- B-1 - Devices↔gateway: EST requires HTTPS; device identity for renewal is a client certificate validated against configured CA files with custom root trust, clientAuth EKU required, online revocation, 5 s retrieval timeout (`ConfiguredClientCertificateTrust`); verified by `tests/RTSec.Kryptonian.Api.Tests/Authentication/ConfiguredClientCertificateTrustTests.cs`.
- B-2 - Proxy↔gateway: `X-Forwarded-Client-Cert` is accepted only from configured known proxies, only as a single header, and never when the connection already presented a client certificate (`CertificateForwardingGuard`). VERIFIED: direct forwarded-certificate spoof is rejected in the live checks recorded in `docs/IMPLEMENTATION-TRACKER.md`; tests: `tests/RTSec.Kryptonian.Api.Tests/Middleware/CertificateForwardingGuardTests.cs`. Trust in the fronting proxy's own identity verification is an explicit assumption (the tracker lists XFCC header trust as a known boundary).
- B-3 - Gateway↔CA: each EST profile resolves its own bound CA backend; the globally "active" backend is deliberately not used for issuance routing (`EnrollmentOrchestrator.ResolveProfileBackendAsync`), preventing cross-profile issuer substitution.
- B-4 - Gateway↔CRL consumers: CRL documents are served anonymously over a separate listener; the sandbox listener accepts only GET/HEAD on `/api/crl` (`SandboxBootstrap.AllowsRequest`). VERIFIED in `docs/IMPLEMENTATION-TRACKER.md`: "HTTP listener denies non-CRL requests"; tests: `tests/RTSec.Kryptonian.Api.Tests/SandboxBootstrapTests.cs`.
- B-5 - Admin UI↔API: CORS policy `KryptonianUi`, JWT/API-key authentication, role-based authorization; authorization tests exist for devices and certificate revocation (`DevicesControllerAuthorizationTests.cs`, `CertificateRevocationControllerAuthorizationTests.cs`).
- B-6 - Gateway↔SMTP / public ACME: outbound TLS; credentials from data-protected storage; the ACME challenge path is public by protocol design.

# 7. Threat catalog

Each entry follows the §2.1 structure. Residual risk is stated as *likelihood* × *impact* = *band* after AS-IS controls only; PROPOSED controls, if approved and implemented, are expected to lower the rating but that lowered value is **not** claimed as the current residual risk.

## 7.1 Device impersonation

**THR-001 - Device impersonation at the EST endpoint.**

- **STRIDE:** Spoofing (primary).
- **Description:** TA-1 or TA-2 presents itself as a legitimate enrolled device at `/simplereenroll` (renewal path) without holding that device's private key, or attempts to renew/re-enroll as an arbitrary device by supplying its subject CN.
- **Affected assets / surfaces:** AS-1, AS-2, AS-5, AS-10; SUF-1.
- **Existing controls (AS-IS):**
  - Renewal requires client-certificate authentication; the device identity used for authorization is derived from the authenticated client certificate, not from request headers; `X-Device-Id` is logged but explicitly untrusted (CODE-OBSERVED, `EstController.GetDeviceIdentifier`).
  - Client certificates are chain-validated to configured CA roots only (custom root trust), must be end-entity with clientAuth EKU, and are checked for online revocation (CODE-OBSERVED, `ConfiguredClientCertificateTrust`; VERIFIED in tracker: revoked/expired clients rejected by the proxy and online `X509Chain` reporting `Revoked`).
  - Renewal CSR must byte-for-byte preserve the approved subject DN and SAN (CODE-OBSERVED, `EnrollmentCertificatePolicy.ValidateRequest`; tests: `EnrollmentCertificatePolicyTests`).

  - Removed devices cannot enroll or renew (CODE-OBSERVED, `EnrollmentOrchestrator` status/`RemovedAt` checks; DOCUMENTED, `docs/device-enrollment.md`).

- **Proposed controls (PROPOSED):** alarm on failed impersonation attempts per source address; consider certificate pinning for high-value devices; document required device-side key storage so a copied key cannot roam.

- **Residual risk:** Low likelihood × Medium impact = **Low-Medium**.

- **Linked requirements:** SR-A, SR-Z, SR-C.

- **Verification:** T (negative tests: wrong key, forged subject, removed device); D (tracker live renewal evidence); I (code inspection).

## 7.2 Unauthorized enrollment

**THR-002 - Unauthorized enrollment (enrollment without an approved device record).**

- **STRIDE:** Elevation of privilege (primary); Spoofing.

- **Description:** TA-1 submits a well-formed CSR to `/simpleenroll` without an activation code or without a pending device registration, attempting to obtain a certificate for an arbitrary CN from a gateway-authorized issuer.

- **Affected assets / surfaces:** AS-2, AS-3, AS-10; SUF-1.

- **Existing controls (AS-IS):**

  - Public enrollment requires a pending device record with a valid, unexpired, unused activation code; active devices must use authenticated re-enrollment; unknown subjects are rejected and recorded as rejected enrollment events (CODE-OBSERVED, `EnrollmentOrchestrator.EnrollAsync`; VERIFIED in tracker: one-time activation replay rejected; independent Basic-EST enrollment over real HTTPS with no private enrollment headers).

  - The requested CN must not already belong to another registered device (CODE-OBSERVED; DOCUMENTED, `docs/device-enrollment.md`).

  - CSR must carry a SHA-2 signature, RSA ≥ 2048 or approved NIST curve, and no CA BasicConstraints (CODE-OBSERVED, `EnrollmentCertificatePolicy`).

- **Proposed controls (PROPOSED):** enrollment-approval workflow with explicit administrator approval states and maker-checker separation for high-assurance profiles; verify rate limiting on repeated unknown-subject enrollment attempts (rate limiting is described for EST in `docs/ARCHITECTURE.md` - DOCUMENTED, deployed configuration not verified).

- **Residual risk:** Medium likelihood × High impact = **High** (unauthenticated network reach; a single misconfigured profile or code leak yields issuance).

- **Linked requirements:** SR-Z, SR-S, SR-C.

- **Verification:** T (unauthenticated-enrollment rejection matrix); D (tracker independent-client EST evidence); A (authorization-path analysis).

## 7.3 Credential and activation-code theft and replay

**THR-003 - Activation-code theft and replay.**

- **STRIDE:** Spoofing (primary); Replay; Elevation of privilege.

- **Description:** TA-1/TA-2 steals an activation code (e.g., by observing the provisioning channel or the admin screen) and replays it to enroll an attacker-controlled device before the legitimate device.

- **Affected assets / surfaces:** AS-5, AS-2; SUF-1, SUF-2 (code generation).

- **Existing controls (AS-IS):**

  - Codes are one-time: consumed atomically with the issuance flow, leaving the hash cleared; concurrent activation attempts are serialized (CODE-OBSERVED, `DeviceService` / `EnrollmentOrchestrator.TryConsumeActivationCodeAsync`; tests: `DeviceActivationConcurrencyTests`; VERIFIED in tracker: "One-time activation replay rejected").
  - Codes are stored only as `SHA-256(deviceId|code)` hashes with bounded lifetime (default 15 min, max 24 h) and generated with a CSPRNG (CODE-OBSERVED, `DeviceService`).
  - EST requires HTTPS, protecting the code in transit (CODE-OBSERVED, `Program.cs` EST HTTPS middleware; VERIFIED in tracker: Basic EST over real HTTPS).
  - AS-IS boundary (DOCUMENTED): the sample device client retains legacy activation headers for compatibility; they are not mandatory for other clients and must not become an interoperability requirement (`docs/IMPLEMENTATION-TRACKER.md`).
- **Proposed controls (PROPOSED):** delivery of activation codes only through an approved out-of-band provisioning workflow with acknowledgement; shorter default lifetimes for high-assurance profiles; administrator notification on code consumption so theft is detectable; protected distribution for QR payloads.
- **Residual risk:** Medium likelihood × High impact = **High** (a code is a bearer bootstrap secret valid until consumed; interception wins the race).
- **Linked requirements:** SR-A, SR-S, SR-C.
- **Verification:** T (concurrency/replay tests - existing); D (tracker); A (code-lifetime analysis); I (provisioning process review).

## 7.4 CSR manipulation

**THR-004 - CSR manipulation: subject-DN and key-usage/EKU spoofing.**

- **STRIDE:** Tampering (primary); Elevation of privilege.
- **Description:** TA-2 (compromised device) or TA-1 with a stolen code submits a CSR whose subject DN, SAN, key usage, EKU, or BasicConstraints differ from the approved profile - e.g., requesting another device's CN, a CA constraint, or serverAuth where only clientAuth is approved.
- **Affected assets / surfaces:** AS-2, AS-3, AS-10; SUF-1.
- **Existing controls (AS-IS):**
  - Initial enrollment subject must contain only the approved CN; renewal must preserve the complete subject and SAN byte-for-byte; CA BasicConstraints in a CSR are rejected (CODE-OBSERVED, `EnrollmentCertificatePolicy.ValidateRequest`).
  - Issued certificates returned by any CA are re-validated before delivery: end-entity constraint, exact key-usage match against the profile, EKU set equality with the profile, validity within the profile window, chaining to the profile's authorized issuers only, and the leaf may not outlive its issuer (CODE-OBSERVED, `EnrollmentCertificatePolicy.ValidateIssued`; tests: `EnrollmentCertificatePolicyTests`, `EstControllerTests`).
  - CSR signature must verify before issuance; the CSR request body is capped at 64 KB (CODE-OBSERVED, `EnrollmentOrchestrator`, `EstController`).
- **Proposed controls (PROPOSED):** explicit profile-level allow-list of SAN types (DNS/IP/RID/otherName) with validation, rather than byte-comparison only; enrollment events should record the requested-but-rejected attribute set to support investigation; align CSR attribute advertisement via a `/csrattrs` endpoint when standardized.
- **Residual risk:** Low likelihood × High impact = **Medium-High** (policy enforcement is strong at baseline; residual risk concentrates in connector behavior for unverified institution CAs).
- **Linked requirements:** SR-C, SR-S.

- **Verification:** T (spoofed-attribute rejection tests - existing); A (connector-by-connector review); I.

## 7.5 Certificate misissuance

**THR-005 - Certificate misissuance by a compromised or misconfigured CA backend.**

- **STRIDE:** Tampering (primary); Elevation of privilege.
- **Description:** TA-4 (compromised CA backend) or an institution CA misconfiguration causes a certificate to be issued that violates the approved policy (wrong subject, excessive validity, wrong EKU), or a response that does not chain to the profile's authorized issuer.
- **Affected assets / surfaces:** AS-2, AS-3, AS-10, AS-11; SUF-8.
- **Existing controls (AS-IS):**
  - Every issued certificate is validated against the profile's approved policy and the profile's authorized issuer set before it is stored or returned; non-conforming responses raise an error and mark the enrollment event failed (CODE-OBSERVED, `EnrollmentCertificatePolicy.ValidateIssued`, `EnrollmentOrchestrator.IssueForDeviceAsync`).
  - Issuance is routed through the profile-bound backend, not the globally active backend (CODE-OBSERVED, B-3).
  - AS-IS boundary (DOCUMENTED): actual ADCS/EJBCA hospital enrollment interoperability remains unverified (`docs/IMPLEMENTATION-TRACKER.md`); the gateway-side validation is enforced regardless of connector.
- **Proposed controls (PROPOSED):** independent post-issuance reconciliation report comparing stored certificates against profile policy; institution-CA test vectors agreed with OR.NET per `docs/ORNET-ALIGNMENT-2026-09-09.md`; CA-backend credential rotation procedure.
- **Residual risk:** Low likelihood × High impact = **Medium-High**.
- **Linked requirements:** SR-C, SR-S, SR-F.
- **Verification:** T (policy-validation tests - existing); A (misissuance scenario analysis per backend type); D (with a partner CA once available).

## 7.6 Replay attacks

**THR-006 - Replay of enrollment, renewal, and revocation requests.**

- **STRIDE:** Replay (primary); Spoofing.
- **Description:** TA-6 captures an enrollment/activation/renewal exchange and replays it to re-obtain a credential or re-trigger an operation.
- **Affected assets / surfaces:** AS-2, AS-5, AS-13; SUF-1, SUF-4.
- **Existing controls (AS-IS):**
  - Activation codes are single-use and atomically consumed; replay of a consumed code is rejected with 403 (CODE-OBSERVED + VERIFIED, THR-003).
  - Renewal requires TLS client-certificate authentication and a fresh key pair; a captured exchange cannot be replayed to authenticate (CODE-OBSERVED; VERIFIED in tracker: renewal generates a new key and preserves the approved identity).
  - Revocation re-generates the CRL with an incrementing CRL number under a transaction; duplicate revocation is rejected with 409 (CODE-OBSERVED, `CertificateRevocationService`; tests: `CertificateRevocationServiceTests`).
- **Proposed controls (PROPOSED):** nonce/challenge extension for EST exchanges where a profile requires it; replay-detection heuristics on identical-CSR resubmission; TLS session-ticket hygiene guidance.

- **Residual risk:** Low likelihood × Medium impact = **Low-Medium**.
- **Linked requirements:** SR-A, SR-C.
- **Verification:** T (replay scenarios); D (tracker); A.

## 7.7 Authorization bypass and administrative compromise

**THR-007 - Authorization bypass on the admin API and portal; administrative compromise.**

- **STRIDE:** Elevation of privilege (primary); Spoofing; Information disclosure.
- **Description:** TA-1/TA-3 attempts to invoke SystemAdmin-only operations (user management, CA-backend changes, profile edits) with a Standard or DeviceAdmin credential, forges a JWT, or compromises an administrator account by credential guessing or session theft.
- **Affected assets / surfaces:** AS-6, AS-7, AS-8, AS-10; SUF-2, SUF-3, SUF-6.
- **Existing controls (AS-IS):**
  - Three-role model (Standard / DeviceAdmin / SystemAdmin) enforced in controllers; API keys carry their owner's role; deactivated users and revoked/expired keys fail authentication; the last active SystemAdmin cannot be deleted (CODE-OBSERVED, `ApiKeyAuthenticationHandler`, `UserService`; DOCUMENTED, `docs/user-management.md`; tests: `DevicesControllerAuthorizationTests`, `CertificateRevocationControllerAuthorizationTests`).
  - Passwords hashed with BCrypt (work factor 12); login failures are uniform (CODE-OBSERVED, `AuthService`).
  - DB-stored API keys are stored as SHA-256 hashes; static `kry_` lookup uses hash comparison (CODE-OBSERVED).
  - AS-IS weaknesses (CODE-OBSERVED / DOCUMENTED): a hard-coded JWT dev-fallback signing secret is used when `KRYPTONIAN__AUTH__JWTSECRET` is unset (`AuthService.DevFallbackSecret`; explicitly flagged "not secure for production" in code and tracker); a development anonymous-bypass exists (`AllowAnonymousInDevelopment`, dev mode only); legacy static API keys from `KRYPTONIAN__ADMINAPI__APIKEYS` act as SystemAdmin; passwords have minimum 8 characters with no complexity rules (DOCUMENTED, `docs/user-management.md`).
- **Proposed controls (PROPOSED):** fail closed (refuse startup) when no JWT secret is configured in production; disable the legacy static API-key path by default; password-policy and MFA options for SystemAdmin; session revocation on role change/deactivation; stricter audit of role changes.
- **Residual risk:** Medium likelihood × High impact = **High** (mis-deployed gateway defaults: fallback JWT secret allows token forgery by anyone who knows the constant).
- **Linked requirements:** SR-A, SR-Z, SR-S, SR-U.
- **Verification:** T (role-matrix tests - existing; add negative JWT-secret startup test once proposed control approved); I; A.

## 7.8 Compromised certificate authorities

**THR-008 - Compromised CA backend or CA channel.**

- **STRIDE:** Elevation of privilege (primary); Tampering; Spoofing.
- **Description:** TA-4 compromises a configured CA backend (the gateway-hosted self-signed CA key, an ACME account, or an institution ADCS/EJBCA) and issues certificates outside gateway policy, refuses revocation, or forges CRLs.
- **Affected assets / surfaces:** AS-3, AS-13, AS-11; SUF-8.
- **Existing controls (AS-IS):**
  - Gateway-side re-validation of every issued certificate against profile policy and authorized issuers before delivery (THR-005 controls) limits a compromised backend to policy-conforming issuance of gateway-approved identities (CODE-OBSERVED).

  - Revocation through unsupported remote CAs fails closed; local CA CRLs are demonstrated; issuer-fingerprint/CA-backend binding prevents revocation state from silently following a rotated CA certificate (CODE-OBSERVED, `CertificateRevocationService`; DOCUMENTED, `docs/IMPLEMENTATION-TRACKER.md`).
  - Self-signed CA keys are generated locally with restricted ACLs, network paths and reparse points rejected, no overwrite of existing state, and PFX password-length enforcement (CODE-OBSERVED, `SelfSignedCaGenerator`; tests: `SelfSignedCaGeneratorTests`, `SelfSignedCaConnectorTests`).

- **Proposed controls (PROPOSED):** hardware-backed or separately custodied gateway CA keys; a CA-compromise runbook (re-issue under a new issuer, re-enroll the fleet, revoke the old chain); independent monitoring of issuance volume per backend; documented institution-CA trust-rollover procedure (both the tracker and the ORNET briefing flag issuer rollover as an open topic).
- **Residual risk:** Medium likelihood × High impact = **High** (the gateway's self-signed CA key sits on the same host as the gateway; host compromise is CA compromise).
- **Linked requirements:** SR-C, SR-S, SR-X.
- **Verification:** A (compromise-scenario analysis); T (rotation/rollover tests); D (tracker revocation evidence).

## 7.9 Administrative compromise

**THR-009 - Administrative compromise (credential theft, brute force, session hijack).**

- **STRIDE:** Spoofing (primary); Information disclosure; Elevation of privilege.
- **Description:** TA-1 or TA-3 guesses or steals administrator passwords, hijacks a JWT session or API key, or uses the first-run bootstrap wizard to create the initial SystemAdmin on an exposed gateway.
- **Affected assets / surfaces:** AS-6, AS-7, AS-8; SUF-2, SUF-3.
- **Existing controls (AS-IS):**
  - BCrypt password hashing (work factor 12); 8-hour JWT session lifetime; the first-run wizard appears only when the database has no users; automatic admin seeding via environment variables applies only on a fresh database (CODE-OBSERVED, `AuthService`; DOCUMENTED, `docs/user-management.md`).
  - API-key revocation is immediate; deactivated users' keys stop working (DOCUMENTED, `docs/user-management.md`; CODE-OBSERVED, `ApiKeyAuthenticationHandler` user/isActive check).
  - AS-IS weaknesses: no gateway-side brute-force lockout found in the inspected code (INFERRED - absence observed by inspection only); password policy is minimum-8-characters with no complexity rules (DOCUMENTED); the bootstrap wizard is reachable by anyone who can reach the portal before first setup (CODE-OBSERVED, empty-user check).
- **Proposed controls (PROPOSED):** brute-force throttling/lockout with audit alerts on repeated failures; MFA option for SystemAdmin; bind the bootstrap wizard to local-console access or a one-time onboarding token; secrets management (vault) guidance for `KRYPTONIAN__AUTH__*` values.
- **Residual risk:** Medium likelihood × High impact = **High**.
- **Linked requirements:** SR-A, SR-S, SR-U.
- **Verification:** T (lockout tests once implemented); I (policy review); A (session-lifetime analysis).

## 7.10 Revocation failure and CRL tampering

**THR-010 - Revocation failure, stale CRLs, or CRL tampering.**

- **STRIDE:** Denial of service (primary); Tampering; Repudiation.
- **Description:** TA-1/TA-4 suppresses or tampers with CRL publication so that revoked device certificates remain accepted by relying peers, or revocation fails silently so trust withdrawal never takes effect.

- **Affected assets / surfaces:** AS-13, AS-2, AS-12; SUF-4, SUF-6, SUF-8.
- **Existing controls (AS-IS):**
  - Issuer-scoped, connector-signed CRLs with monotonically increasing CRL numbers, persisted transactionally with the revocation record (CODE-OBSERVED, `CertificateRevocationService`; tests: `IssuerCrlStatePersistenceTests`, `CertificateRevocationServiceTests`; VERIFIED in tracker: administrator revocation followed by native online X509Chain reporting `Revoked`, independent of registry lookup).
  - Issuer-fingerprint binding rejects CRL state whose issuer belongs to a different CA backend or has rotated (CODE-OBSERVED).
  - Unsupported remote-CA revocation fails closed with an explicit error (CODE-OBSERVED; DOCUMENTED boundary in tracker).
  - CRL responses carry `Cache-Control: max-age` derived from NextUpdate (CODE-OBSERVED, `CrlController`).
  - AS-IS boundaries (DOCUMENTED / CODE-OBSERVED): the CRL lifetime is a prototype cadence of 60 seconds (`CertificateRevocationService.PrototypeCrlLifetime`), sized for the demo, not a production revocation objective; development HTTPS server-leaf revocation is skipped without a CDP (explicitly not a production recommendation); DIMSE-TLS proxy connections have bounded lifetimes rather than instant mid-association revocation.
- **Proposed controls (PROPOSED):** production CRL lifetime policy derived from outage tolerance and revocation objectives (per the ORNET briefing); freshness monitoring and alerting as a CRL approaches NextUpdate; documented peer-side stale-CRL handling for relying systems; consider OCSP for high-assurance deployments.
- **Residual risk:** Medium likelihood × High impact = **High** (the revoked-device acceptance window equals CRL lifetime plus peer refresh; the CRL endpoint is anonymous and could be blocked).
- **Linked requirements:** SR-C, SR-V, SR-U.
- **Verification:** T (revocation/CRL tests - existing); D (tracker); A (freshness-window analysis); I (deployment policy review).

## 7.11 Expiration-related disruption

**THR-011 - Expiration-related disruption (renewal gaps).**

- **STRIDE:** Denial of service (primary).
- **Description:** Device certificates expire because renewal does not occur (device application not running, gateway unreachable, notification missed), causing loss of device network identity and secure communication - never loss of clinical capability.
- **Affected assets / surfaces:** AS-2, AS-14; SUF-1, SUF-7.
- **Existing controls (AS-IS):**
  - Daily in-process expiry scan with per-certificate notification and re-notification after 7 days (CODE-OBSERVED, `CertificateExpiryWatcher`; tests: `NotificationDispatcherTests`, `NotificationSettingsServiceTests`).
  - Renewal window allows re-enrollment without re-approval while the device is active; rotation is atomic from the device side (CODE-OBSERVED; VERIFIED in tracker: two actual mTLS DICOM transfers across a certificate rotation).
  - AS-IS boundary (DOCUMENTED): automatic renewal runs only while the `Kryptonian.MedicalDevice` client is open; long-lived OS-service operation, hardware-backed key storage, and old-certificate retirement need deployment policy (tracker).
- **Proposed controls (PROPOSED):** early-renewal scheduling with retry/backoff; reliable-time and notification-failure handling requirements; operational runbook for expired-certificate recovery; choose certificate lifetimes from outage tolerance rather than a demo value (ORNET briefing).

• **Residual risk:** High likelihood (application-lifetime renewal is an AS-IS reality) × Medium impact = **High**, mitigated operationally by the expiry watcher.

• **Linked requirements:** SR-V, SR-C, SR-O.

• **Verification:** T (expiry-scan tests); D (rotation evidence); A (outage-tolerance analysis); cross-reference KSPEC-007 ORK entries.

## 7.12 Trust-anchor compromise

**THR-012 - Trust-anchor compromise (client CA files, trust policy, dev launcher).**

• **STRIDE:** Elevation of privilege (primary); Spoofing.

• **Description:** TA-5/TA-7 causes a rogue CA certificate to be added to the gateway's client-TLS trust anchors or an EST profile's issuer trust policy, so that attacker-held certificates authenticate as devices, or peers accept a rogue issuer chain distributed via `/cacerts`.

• **Affected assets / surfaces:** AS-11, AS-10, AS-3; SUF-1, SUF-10.

• **Existing controls (AS-IS):**

  • Client TLS trust requires explicitly configured CA files; the constructor rejects an empty set or any certificate without the CA BasicConstraints (CODE-OBSERVED, `ConfiguredClientCertificateTrust`).

  • Issued-certificate chain validation uses the profile's authorized issuer set as a custom trust store, not the operating-system store (CODE-OBSERVED, `EnrollmentCertificatePolicy.ValidateIssued`).

  • Trust policy is persisted and additive on upgrade; profile partial updates preserve omitted trust lists (CODE-OBSERVED; DOCUMENTED: PR #41/#47 in tracker; tests: `EstProfilePersistenceTests`, `EstProfilePartialUpdateTests`).

  • Sandbox state regeneration is refused when state is incomplete, preventing silent CA-key regeneration (CODE-OBSERVED, `SandboxBootstrap`; tests: `SandboxBootstrapTests`).

  • AS-IS boundary (DOCUMENTED): dev-launcher trust behavior is a recorded boundary in `docs/IMPLEMENTATION-TRACKER.md`; the launcher's initial server leaf has a separate issuer/hostname/purpose regression rather than a production trust path.

• **Proposed controls (PROPOSED):** administrative workflow requiring explicit confirmation (and dual approval) for trust-anchor changes; auditable change history for trust policy; pinning of `/cacerts` responses to the profile's bound backend; TO-BE requirement covering anchor rollover.

• **Residual risk:** Low likelihood × High impact = **Medium-High** (requires host access or SystemAdmin compromise, but the effect is gateway-wide).

• **Linked requirements:** SR-S, SR-Z, SR-C.

• **Verification:** T (trust-store rejection tests - existing); A; I.

## 7.13 Denial of service

**THR-013 - Denial of service against the gateway.**

• **STRIDE:** Denial of service (primary).

• **Description:** TA-1 floods EST, admin, CRL, or ACME-challenge endpoints; submits oversized or pathological CSRs; exhausts DB connections; or blocks the anonymous CRL endpoint to prevent revocation propagation.

• **Affected assets / surfaces:** AS-13, SUF-1..SUF-6; availability of all functions.

• **Existing controls (AS-IS):**

- CSR body capped at 64 KB (CODE-OBSERVED, `EstController`).
- EST rate limiting via `AspNetCoreRateLimit` configured for `/.well-known/est/*` (DOCUMENTED, `docs/ARCHITECTURE.md`; deployed configuration not verified by this document).
- Sandbox listeners are port-scoped: the CRL port serves only GET/HEAD `/api/crl`, the EST port only `/.well-known/est` (CODE-OBSERVED, `SandboxBootstrap.AllowsRequest`; VERIFIED in tracker).
- EST requires HTTPS (426 otherwise) unless explicitly allowed (CODE-OBSERVED, `Program.cs`).
- Revocation/CRL path degrades independently of enrollment; health endpoint reports component status (CODE-OBSERVED, `StatusController`/health checks).

• **Proposed controls (PROPOSED):** verify and document deployed rate-limit configuration as a requirement; request-size and connection limits on all listeners; CRL-availability alerting; load-balancer guidance; define degraded-mode behavior when the CA backend is unavailable.

• **Residual risk:** Medium likelihood × Medium impact = **Medium** (enrollment disruption only; already-issued credentials keep working within policy limits, per the ORNET availability guidance).

• **Linked requirements:** SR-V, SR-P, SR-R.

• **Verification:** T (load/negative tests); A; D.

## 7.14 Supply-chain vulnerabilities

**THR-014 - Supply-chain vulnerabilities in dependencies and artifacts.**

• **STRIDE:** Tampering (primary); Information disclosure.

• **Description:** TA-5 introduces vulnerable or malicious components: NuGet packages, npm UI packages, Docker base images, installer payloads, or build steps.

• **Affected assets / surfaces:** AS-15, AS-9; all surfaces.

• **Existing controls (AS-IS):**

- Compatible dependency updates were applied: MailKit upgraded to patched 4.16.0 with its required BouncyCastle 2.6.2 dependency (tracker, MailKit advisory GHSA-9j88-vvj5-vhgr).
- UI lockfile refresh reduced npm audit from six vulnerable packages to zero; CI now rejects high/critical UI dependency advisories (DOCUMENTED/VERIFIED in tracker; explicitly "not a whole-system audit").
- Windows GitHub Actions CI builds the UI, tests the solution, and builds the standalone proxy (DOCUMENTED, tracker; workflows under `.github/workflows/`).
- AS-IS boundaries (DOCUMENTED): the transitive audit still reports high advisories in `SQLitePCLRaw.lib.e_sqlite3 2.1.6` and `System.Security.Cryptography.Xml 8.0.2` - recorded deployment blockers requiring a separately tested framework/native-provider update.

• **Proposed controls (PROPOSED):** remediate the two recorded deployment blockers with a tested update; whole-system dependency audit (not just UI); SBOM generation and artifact hashing for releases; reproducible-build or signed-artifact policy.

• **Residual risk:** High likelihood (known unpatched advisories) × High impact = **Critical** as a deployment blocker until remediated; Medium after remediation, pending the tested update.

• **Linked requirements:** SR-B, SR-S, SR-O.

• **Verification:** T (CI advisory gate - existing); I (audit reports); A (transitive-dependency analysis).

## 7.15 Audit log integrity and repudiation

**THR-015 - Audit log integrity loss; repudiation of enrollment or revocation actions.**

- **STRIDE:** Repudiation (primary); Tampering.
- **Description:** TA-3/TA-7 alters or deletes enrollment events, device events, or log records to hide unauthorized enrollment/revocation, or later denies having performed an administrative action.
- **Affected assets / surfaces:** AS-12; SUF-2, SUF-6, SUF-10.
- **Existing controls (AS-IS):**
  - Enrollment events are persisted records of every enrollment/renewal/ revocation attempt and outcome, including subject DN, requestor IP, timestamp, and error message (CODE-OBSERVED, `EnrollmentOrchestrator.RejectEnrollmentAsync`/`IssueForDeviceAsync`).
  - Structured Serilog logging with correlation ID, client IP, and request ID; failed attempts remain alongside successful artifacts in the developer evidence (CODE-OBSERVED; DOCUMENTED, tracker).
  - The admin UI exposes the event log read-only to Standard users (DOCUMENTED, `docs/user-management.md`).
  - AS-IS boundary (DOCUMENTED): database audit tables are not a tamper-evident audit trail; the ORNET briefing explicitly notes ATNA/DICOM audit mapping and protected export as a separate conformance task.
  - Logs and database share the host trust boundary; a host-level attacker (TA-7) can alter both (INFERRED).
- **Proposed controls (PROPOSED):** append-only or hash-chained event records; remote export of audit records (e.g., syslog with TLS) with access separation; clock-integrity requirements; administrative-action audit for role changes, trust-policy changes, and revocations.
- **Residual risk:** Medium likelihood × High impact = **High** (audit integrity currently rests entirely on host security).
- **Linked requirements:** SR-U, SR-D, SR-Z.
- **Verification:** I (audit design review); T (tamper-evidence tests once implemented); A (ATNA mapping analysis).

## 7.16 Key storage and protection

**THR-016 - Key storage and protection (gateway keys, credentials, key rings).**

- **STRIDE:** Information disclosure (primary); Elevation of privilege.
- **Description:** TA-7 reads CA PFX files, gateway TLS PFX files, secrets.json, the Data Protection key ring, database CA-backend credentials, or SMTP credentials, gaining signing capability or decryption of data-protected secrets.
- **Affected assets / surfaces:** AS-3, AS-4, AS-8, AS-9, AS-14; SUF-6, SUF-10.
- **Existing controls (AS-IS):**
  - Self-signed CA and server PFX files are created with restrictive ACLs (owner + LocalSystem + Administrators only), no share/network paths, no reparse-point traversal, no overwrite, and in-memory zeroing of the PFX buffer (CODE-OBSERVED, `SelfSignedCaGenerator`, `SandboxBootstrap`; tests: `SelfSignedCaGeneratorTests`, `SandboxBootstrapTests`).
  - Sandbox secrets live in a secrets.json inside the restricted data directory; Data Protection keys persist to a dedicated subdirectory (CODE-OBSERVED).
  - Database-stored sensitive values (CA-backend credentials, SMTP settings) are encrypted at rest via ASP.NET Core Data Protection with a dedicated purpose string (CODE-OBSERVED, `DataProtectionService`; tests: `DataProtectionServiceTests`).
  - Activation codes and API keys are stored hashed, not encrypted (CODE-OBSERVED).

  - AS-IS boundaries (DOCUMENTED / INFERRED): hardware-backed key storage is explicitly a deployment-policy follow-up in the tracker; non-sandbox deployments rely on default machine-scoped Data Protection key storage (INFERRED - no enforced persistent key location found outside sandbox mode); device-side private keys are unmanaged by the gateway.

- **Proposed controls (PROPOSED):** require the sandbox-style persistent, ACL-restricted Data Protection directory in all deployments; hardware-backed or OS-certified key storage for CA keys (TPM/CNG/KSP); key-rotation and escrow policy; secrets in a vault rather than environment variables where hosting permits.
- **Residual risk:** Medium likelihood × High impact = **High** (file-based keys are only as strong as host OS hardening).
- **Linked requirements:** SR-S, SR-D, SR-B.
- **Verification:** I (key-storage inspection per deployment); T (ACL tests - existing); D (key rotation demonstration).

## 7.17 Forwarding-header and proxy trust

**THR-017 - Forwarded-header spoofing (XFCC / X-Forwarded-For) and proxy trust.**

- **STRIDE:** Spoofing (primary); Tampering.
- **Description:** TA-1 forges `X-Forwarded-Client-Cert` to impersonate a device identity, or manipulates `X-Forwarded-For` to pollute rate-limiting keys, audit IP attribution, or proxy decisions.
- **Affected assets / surfaces:** AS-12, AS-2; SUF-9, SUF-1.
- **Existing controls (AS-IS):**
  - `CertificateForwardingGuard` rejects XFCC from any peer not in the configured known-proxy set, rejects duplicate XFCC headers, and rejects XFCC when the connection itself presents a client certificate (CODE-OBSERVED; VERIFIED in tracker: "Direct forwarded-certificate spoof rejected"; tests: `CertificateForwardingGuardTests`).
  - `X-Device-Id` is never used for authorization (CODE-OBSERVED, `EstController`).
  - AS-IS boundary (DOCUMENTED): the tracker lists XFCC header trust among known boundaries - the gateway must trust the fronting proxy to verify client-TLS possession and replace (not append) the header; direct gateway exposure without a TLS-terminating proxy is the supported configuration.
- **Proposed controls (PROPOSED):** mTLS between gateway and fronting proxy; deployment requirement that KnownProxies must be set whenever a proxy fronts the gateway; normalized forwarded-header handling for audit attribution.
- **Residual risk:** Low likelihood × High impact = **Medium-High** (guard logic is verified; residual risk lies in mis-deployment without KnownProxies configured).
- **Linked requirements:** SR-A, SR-Z, SR-U.
- **Verification:** T (guard tests - existing); I (deployment configuration); D.

## 7.18 Sensitive information disclosure

**THR-018 - Information disclosure through logs, errors, and notifications.**

- **STRIDE:** Information disclosure (primary).
- **Description:** TA-1/TA-3 reads sensitive material from verbose error responses, the live log stream, log files, or email notifications (enrollment-rejection notices include subject DN, client IP, and reason).
- **Affected assets / surfaces:** AS-12, AS-14; SUF-2, SUF-7.
- **Existing controls (AS-IS):**
  - Generic internal-error responses ("Internal server error") for unexpected EST failures; detailed messages only for validation errors (CODE-OBSERVED, `EstController`).

  - Enrollment-rejection notifications carry a bounded, documented context set (operation, subject DN, device ID, client IP, reason, time) - CODE-OBSERVED, `EnrollmentOrchestrator`; SMTP transport and recipients are administrator-configured (DOCUMENTED, `docs/email-notifications.md`).
  - The live log stream is exposed through the admin API under role authorization (CODE-OBSERVED, `LogsController`/`LiveLogBroadcaster`).
  - AS-IS boundary (INFERRED): log files are written to the host with default service-account access; no log-redaction policy was observed in the inspected code.

- **Proposed controls (PROPOSED):** log data-classification and redaction policy; privacy review of notification content; protect exported logs in transit (per the ORNET audit-export guidance); document the live log stream's authorization scope.
- **Residual risk:** Medium likelihood × Low-Medium impact = **Low-Medium**.
- **Linked requirements:** SR-S, SR-U, SR-D.
- **Verification:** I (log/notification content review); T (authorization tests for log endpoints - existing at controller level); A.

# 8. Controls-to-requirements mapping

Requirement IDs are **prefix-level** (KSPEC-000 §7) because the KSPEC-003 Requirements Register does not yet exist; see §2.4. AS-IS control evidence provenance: V = VERIFIED, C = CODE-OBSERVED, D = DOCUMENTED, I = INFERRED; PROPOSED controls are marked P.

### THR-001

**STRIDE (primary):** S
**AS-IS controls (provenance):** Client-cert identity binding; custom-root chain + EKU + online revocation (C, V); subject/SAN byte-preservation (C)
**PROPOSED controls:** Impersonation alerting; pinning; device key-storage policy
**Linked SR prefixes:** SR-A, SR-Z, SR-C
**Verification:** T, D, I

### THR-002

**STRIDE (primary):** E
**AS-IS controls (provenance):** Pending-device + activation gate; CN uniqueness; CSR algorithm floor (C, V)
**PROPOSED controls:** Approval workflow/maker-checker; verified rate limiting
**Linked SR prefixes:** SR-Z, SR-S, SR-C
**Verification:** T, D, A

### THR-003

**STRIDE (primary):** S, R
**AS-IS controls (provenance):** One-time atomic consumption; hashed storage; bounded lifetime; HTTPS-only EST (C, V)
**PROPOSED controls:** Out-of-band delivery with acknowledgement; consumption notification
**Linked SR prefixes:** SR-A, SR-S, SR-C
**Verification:** T, D, A, I

### THR-004

**STRIDE (primary):** T
**AS-IS controls (provenance):** CSR subject/EKU/key-usage/validity validation; issued-cert re-validation; 64 KB cap (C)
**PROPOSED controls:** SAN-type allow-list; rejected-attribute audit; `/csrattrs`
**Linked SR prefixes:** SR-C, SR-S

**Verification:** T, A, I

### THR-005

**STRIDE (primary):** T, E
**AS-IS controls (provenance):** Pre-delivery policy validation of CA responses; profile-bound backend (C); institution CA unverified (D)
**PROPOSED controls:** Post-issuance reconciliation; ORNET test vectors; rotation procedure
**Linked SR prefixes:** SR-C, SR-S, SR-F
**Verification:** T, A, D

### THR-006

**STRIDE (primary):** R
**AS-IS controls (provenance):** Single-use activation; cert-authenticated renewal with fresh key; CRL-number monotonicity (C, V)
**PROPOSED controls:** Nonce extension; replay heuristics; ticket hygiene
**Linked SR prefixes:** SR-A, SR-C
**Verification:** T, D, A

### THR-007

**STRIDE (primary):** E, S, I
**AS-IS controls (provenance):** RBAC 3-role model; hashed API keys; BCrypt; deactivated-user lockout (C, D) - weaknesses: JWT dev fallback, legacy static keys, weak password policy (C, D)
**PROPOSED controls:** Fail-closed JWT secret; disable legacy keys; MFA; session revocation
**Linked SR prefixes:** SR-A, SR-Z, SR-S, SR-U
**Verification:** T, I, A

### THR-008

**STRIDE (primary):** E, T, S
**AS-IS controls (provenance):** Issued-cert re-validation; fail-closed remote revocation; ACL-restricted local CA generation (C, D)
**PROPOSED controls:** HSM-backed CA keys; compromise runbook; issuance monitoring; rollover procedure
**Linked SR prefixes:** SR-C, SR-S, SR-X
**Verification:** A, T, D

### THR-009

**STRIDE (primary):** S, I, E
**AS-IS controls (provenance):** BCrypt wf-12; 8 h JWT; first-run wizard gating (C, D) - weaknesses: no lockout (I), bootstrap exposure (C)
**PROPOSED controls:** Lockout/throttling; MFA; console-bound bootstrap; vault guidance
**Linked SR prefixes:** SR-A, SR-S, SR-U
**Verification:** T, I, A

### THR-010

**STRIDE (primary):** D, T, Rp
**AS-IS controls (provenance):** Transactional issuer-scoped CRLs; fingerprint binding; fail-closed; cache-control (C, V) - boundaries: 60 s prototype CRL lifetime, dev leaf CDP skip, bounded proxy lifetimes (C, D)
**PROPOSED controls:** Production CRL-lifetime policy; freshness alerting; peer stale-CRL policy; OCSP option
**Linked SR prefixes:** SR-C, SR-V, SR-U
**Verification:** T, D, A, I

### THR-011

**STRIDE (primary):** D

**AS-IS controls (provenance):** Daily expiry watcher + notifications; renewal window; atomic rotation (C, V) - boundary: renewal only while client app runs (D)

**PROPOSED controls:** Early renewal/backoff; reliable time; recovery runbook; lifetime policy

**Linked SR prefixes:** SR-V, SR-C, SR-O

**Verification:** T, D, A

### THR-012

**STRIDE (primary):** E, S

**AS-IS controls (provenance):** Explicit CA-file trust with CA-constraint check; custom-root issuance validation; persisted additive trust policy; refuse state regeneration (C, D)

**PROPOSED controls:** Trust-change approval workflow; audit history; `/cacerts` pinning; rollover requirement

**Linked SR prefixes:** SR-S, SR-Z, SR-C

**Verification:** T, A, I

### THR-013

**STRIDE (primary):** D

**AS-IS controls (provenance):** 64 KB CSR cap (C); EST rate limiting (D); port-scoped sandbox listeners (C, V); HTTPS-only EST (C)

**PROPOSED controls:** Rate limits as requirements; listener limits; CRL alerting; degraded-mode definition

**Linked SR prefixes:** SR-V, SR-P, SR-R

**Verification:** T, A, D

### THR-014

**STRIDE (primary):** T, I

**AS-IS controls (provenance):** MailKit/BouncyCastle patched; npm audit gate in CI (D, V) - deployment blockers: SQLitePCLRaw.lib.e_sqlite3 2.1.6, System.Security.Cryptography.Xml 8.0.2 (D)

**PROPOSED controls:** Remediate blockers; whole-system audit; SBOM + hashing; signed artifacts

**Linked SR prefixes:** SR-B, SR-S, SR-O

**Verification:** T, I, A

### THR-015

**STRIDE (primary):** Rp, T

**AS-IS controls (provenance):** Enrollment events with outcome/IP/DN; structured logging; read-only UI exposure (C, D) - boundary: no tamper-evidence (D)

**PROPOSED controls:** Hash-chained records; remote audit export; clock integrity; admin-action audit

**Linked SR prefixes:** SR-U, SR-D, SR-Z

**Verification:** I, T, A

### THR-016

**STRIDE (primary):** I, E

**AS-IS controls (provenance):** ACL-restricted PFX creation; secrets.json in restricted dir; Data Protection at rest; hashed codes (C) - boundaries: no HSM; device keys unmanaged (D)

**PROPOSED controls:** Mandatory protected key ring; hardware-backed CA keys; rotation/escrow; vault

**Linked SR prefixes:** SR-S, SR-D, SR-B

**Verification:** I, T, D

### THR-017

**STRIDE (primary):** S, T
**AS-IS controls (provenance):** XFCC known-proxy guard; duplicate/dual-identity rejection; untrusted X-Device-Id (C, V) - boundary: proxy trust assumption (D)
**PROPOSED controls:** Proxy mTLS; KnownProxies deployment requirement; header normalization
**Linked SR prefixes:** SR-A, SR-Z, SR-U
**Verification:** T, I, D

### THR-018

**STRIDE (primary):** I
**AS-IS controls (provenance):** Generic internal errors; bounded notification context; role-authorized log stream (C, D)
**PROPOSED controls:** Redaction policy; privacy review; protected export
**Linked SR prefixes:** SR-S, SR-U, SR-D
**Verification:** I, T, A

# 9. Residual-risk summary

## 9.1 Verified mitigations (implemented and backed by executed evidence)

Per `docs/IMPLEMENTATION-TRACKER.md` and the automated test suites (VERIFIED):

- One-time activation replay rejected; renewal uses a native TLS client certificate, generates a new key, and preserves the approved identity (THR-001/003/006).
- Direct forwarded-certificate spoof rejected; HTTP listener denies non-CRL requests (THR-017, THR-013).
- Two actual mutual-TLS DICOM C-STORE transfers across a certificate rotation; both peers enforce issuer, TLS purpose, and online revocation (THR-001/011).
- Administrator revocation followed by native online X509Chain reporting `Revoked`, independent of registry lookup (THR-010).
- Gateway restart on populated SQLite preserved the configured profile, issuer, and devices (THR-012/016).
- Independent curl HTTP Basic EST over real HTTPS with no private enrollment headers (THR-002/003).
- Windows CI builds the UI, tests the solution, builds the standalone proxy, and rejects high/critical UI dependency advisories (THR-014, partial - explicitly not a whole-system audit).

## 9.2 Proposed mitigations and dominant residual risks

The dominant residual risks concentrate in five areas, each mapped to PROPOSED controls in §7. None of these are mitigated at baseline:

1. **Deployment blockers (THR-014):** unremediated high advisories in `SQLitePCLRaw.lib.e_sqlite3 2.1.6` and `System.Security.Cryptography.Xml 8.0.2` - the only Critical-rated residual risk; requires a separately tested framework/native-provider update and is not evidence of a clean security audit.
2. **Administrative and secret-management defaults (THR-007/009/016):** hard-coded JWT dev fallback, legacy static SystemAdmin API keys, no brute-force lockout, minimum-8-character passwords, and file-based CA keys - High residual risk when deployed without compensating host/network hardening.
3. **Revocation cadence and reachability (THR-010):** 60-second prototype CRL lifetime and anonymous CRL endpoint; production lifetime policy and freshness monitoring are PROPOSED.

4. **Audit integrity (THR-015):** enrollment events are plain database records; no tamper-evidence or remote export; High residual risk pending PROPOSED controls.

5. **Unverified institution-CA interoperability (THR-005/008):** gateway-side validation is strong, but ADCS/EJBCA enrollment/revocation interoperability is unverified at baseline; Medium-High residual risk pending partner test vectors.

### 9.3 Summary band distribution

| Band | Count (of 18) | Threats |
|---|---|---|
| Critical | 1 | THR-014 (until deployment blockers are remediated) |
| High | 9 | THR-002, THR-003, THR-007, THR-008, THR-009, THR-010, THR-011, THR-015, THR-016 |
| Medium-High | 5 | THR-001, THR-004, THR-005, THR-012, THR-017 |
| Medium | 1 | THR-013 |
| Low-Medium | 2 | THR-006, THR-018 |

Ratings assume the AS-IS deployment model (sandbox or hardened host) and baseline controls only; they must be re-assessed for each production deployment topology. Verified mitigations (§9.1) reduce the ratings shown in §7; the PROPOSED controls (§9.2) are required to address the remaining bands, subject to stakeholder approval per KSPEC-000 §4.

## 10. Control-framework references (recommended practices, no conformity claim)

The following frameworks are cited as **recommended practices** for the PROPOSED controls above. No conformity, certification, or compliance with any framework is claimed or implied (KSPEC-000 §13; a conformance assessment, if requested, is the purpose of KSPEC-011).

| Framework | Relevant references | Where they inform this document |
|---|---|---|
| NIST SP 800-53 (Rev. 5) control families | AC (Access Control), AU (Audit and Accountability), IA (Identification and Authentication), SC (System and Communications Protection), CM (Configuration Management), SA (System and Services Acquisition), SR (Supply Chain Risk Management), PS (Personnel Security), CP (Contingency Planning), PE (Physical Protection) | RBAC and session controls (AC-2/-3/-6, THR-007/009); audit record generation and protection (AU-2/-9, THR-015); authenticator management (IA-5, THR-003/007/016); transmission confidentiality/integrity (SC-8/-10, THR-001/006/017); CA/trust-store protection (SC-12/-13, SC-12(3), THR-008/012/016); supply-chain controls (SR-, *THR-014); availability (CP-*/SC-6, THR-011/013) |
| ISO/IEC 27001:2022 Annex A themes | A.5 Organizational, A.6 People, A.7 Physical, A.8 Technological | Threat-model maintenance and secure development (A.8.8 vulnerability management, THR-014); cryptography policy and key management (A.8.24, THR-008/016); logging and monitoring (A.8.15/8.16, THR-015); access control (A.5.15-5.18, A.8.2-8.5, THR-007/009) |
| OWASP ASVS 4.0.3 chapters | V1 (Architecture/Threat Modeling), V2 (Authentication), V3 (Session Management), V4 (Access Control), V5 (Validation/Sanitization/Encoding), V6 (Cryptography), V7 (Error Handling/Logging), V9 (Communications), V12 (Files/Resources), V13 (API/Web Service) | Chapter mapping for gateway controls: V2/V3 for admin auth (THR-007/009); V4 for authorization (THR-002/007); V6 for key storage (THR-016); V7 for audit (THR-015/018); V9 for TLS (THR-001/013); V13 for API surfaces (SUF-1..SUF-5) |

| Framework | Relevant references | Where they inform this document |
|---|---|---|
| NIST SP 800-57 (Recommendation for Key Management) | Part 1 Rev. 5 (key generation, protection, cryptoperiods, compromise recovery); Part 2 Rev. 1 (key-management organization) | CA key protection and cryptoperiods (THR-008/016); activation-code lifetime (THR-003); compromise-recovery runbook (THR-008); issuance validation key-usage checks (THR-004) |
| NIST SP 800-52 Rev. 2 (TLS guidelines) | Protocol/version selection, cipher-suite policy, certificate trust path, revocation checking | HTTPS-only EST (THR-013); client-certificate chain validation with online revocation (THR-001); CRL freshness handling (THR-010); forwarded-TLS and proxy termination patterns (THR-017) |

Application notes:

- Framework citations identify control families and best-practice topics only; specific control selections, parameters, and assurance levels are deployment decisions (KSPEC-007/KSPEC-012 handle operational selections).
- EST behavior follows RFC 7030; the gateway's protocol-level obligations are specified in KSPEC-005, not here.

# 11. Assumptions, open questions, and cross-references

## 11.1 Assumptions

- A-1 - The gateway host is administered by the institution; host-level compromise is assumed to defeat file-based key protection (drives THR-008/ THR-016 ratings).
- A-2 - The hospital network is hostile at the device segment; device-to- gateway traffic must not rely on network isolation as its only protection.
- A-3 - The fronting proxy (when present) performs client-certificate verification correctly and replaces forwarding headers (B-2); this trust is compensated by the guard but cannot be eliminated.
- A-4 - Deployment uses the sandbox launcher or an equivalent hardened host configuration; the non-sandbox default Data Protection key location is UNVERIFIED (INFERRED in THR-016).

## 11.2 Open questions (UNKNOWN, carried to KSPEC-010/013)

- Q-1 - Which institution-CA (ADCS/EJBCA) issuance and revocation profiles will be supported, and what CRL/OCSP reachability do they provide? (UNKNOWN; tracker records remote revocation as fail-closed until verified.)
- Q-2 - What production CRL lifetime, renewal window, and certificate validity will OR.NET-aligned profiles adopt? (UNKNOWN; PROPOSED values are demo- derived and must not become normative without review.)
- Q-3 - Is the EST rate-limiting configuration deployed in production scenarios, and what limits apply to the CRL and admin surfaces? (UNKNOWN; DOCUMENTED only.)
- Q-4 - Does the target deployment require hardware-backed CA keys (TPM/HSM), and which OS key stores are acceptable? (UNKNOWN.)

## 11.3 Cross-references

- Operational consequences of these threats (failure modes, availability, and reliability ratings): `07-OPERATIONAL-RISK.md` (ORK-*).
- Interface-level details of the surfaces in §5: `05-INTERFACE-CONTROL.md` (ICD-*).
- Architecture and component design: `04-SOFTWARE-DESIGN.md` (AS-IS/TO-BE).
- Normative security requirements realising the PROPOSED controls: `03-SOFTWARE-REQUIREMENTS.md` (SR-*) once the register is created; reconciliation in `09-TRACEABILITY.md`.

• Verification of the controls cited as VERIFIED: `08-VERIFICATION-VALIDATION.md` (VT-*) and `artifacts/developer/verify-*/evidence.json`.

# Kryptonian Formal Engineering Specification - Operational Risk and Reliability Assessment

| Field | Value |
|---|---|
| Document ID | KSPEC-007 |
| Title | Operational Risk and Reliability Assessment (FMEA) |
| Version | 0.2 (Draft) |
| Status | Draft - pending review |
| Created | 2026-10-13 |
| Baseline commit | `682f996c8447afec13bc1fce5b7f59e6a06efa25` (branch `feat/windows-sandbox-installer`, "Release Windows gateway and portable enrollment demo 0.1.4") |
| Revision history | 0.1 - 2026-10-13 - Initial draft FMEA covering 16 operational risk entries (ORK-001 … ORK-016) |
| Source references | KSPEC-000 (conventions); `docs/IMPLEMENTATION-TRACKER.md`; `docs/ARCHITECTURE.md`; `docs/DEPLOYMENT.md`; `docs/device-enrollment.md`; `docs/ca-backend-configuration.md`; `docs/email-notifications.md`; `docs/windows-installation.md`; `docs/windows-sandbox.md`; source under `src/RTSec.Kryptonian.{Api,Application,Infrastructure}`; `docker-compose.yml`; `deploy/`; `installer/windows/` |
| Author | *Name / Date / Signature* |
| Reviewer | *Name / Date / Signature* |
| Approver | *Name / Date / Signature* |
| Reconciliation revision | 0.2 - 2026-10-13 - source/document audit and publication controls (KSPEC-016) |

## 1. Purpose and scope

This document is the operational risk and reliability assessment (KSPEC-007) for RTSec.Kryptonian at baseline commit `682f996c8447afec13bc1fce5b7f59e6a06efa25`. It applies Failure Mode and Effects Analysis (FMEA) style structure - severity, occurrence, and detection ratings with explicit qualitative scales - to operational failure modes that affect cybersecurity posture, network connectivity, availability, and operational continuity of the gateway and the device credential lifecycle it manages.

Scope:

- Gateway operational failure modes (enrollment, renewal, revocation, CRL publication, notifications, persistence, deployment, upgrades).
- Failure modes originating in external dependencies (CA backends, SMTP relay, network, clock sources, third-party dependencies).
- AS-IS mitigations present in the baseline, with evidence provenance per KSPEC-000 §5, and PROPOSED controls that require stakeholder approval.

Out of scope:

• Medical-device hazard classification, IEC 62304 lifecycle classification, ISO 14971 medical-device risk management, and clinical harm probabilities. Kryptonian is enterprise healthcare IT cybersecurity infrastructure - an EST (RFC 7030) certificate enrollment and credential lifecycle gateway. It is not a regulated medical device and performs no clinical functions (KSPEC-000 §3).

• Deliberate security attacks against the gateway; these are covered by the threat model (KSPEC-006, THR-*) except where operational behavior and threat behavior intersect (cross-referenced as noted).

• Clinical capability: device clinical function is never derived from Kryptonian state. Loss of a device credential degrades device *network identity and secure communication*, never clinical capability.

# 2. Assessment method, scales, and priority bands

## 2.1 Method

Each risk entry (identifier prefix `ORK-`, owned by this document per KSPEC-000 §7) is analyzed as:

1. **Description and failure mode** - what goes wrong.
2. **Causes** - credible initiating events; no probabilities are assigned; occurrence ratings are qualitative anchor-based judgments, not measured failure rates.
3. **Effects** - operational consequences.
4. **AS-IS mitigations** - controls that exist at the baseline, each with repository evidence and a provenance class (VERIFIED / CODE-OBSERVED / DOCUMENTED / INFERRED / UNKNOWN per KSPEC-000 §5).
5. **Detection mechanisms** - how the failure is noticed, AS-IS and proposed.
6. **PROPOSED controls** - enhancements requiring stakeholder approval; never presented as normative without approval (KSPEC-000 §4).
7. **Recovery strategy** - AS-IS where implemented, PROPOSED where not.
8. **Linked requirements** - prefix-level references only (see §2.6).
9. **Verification methods** - T (Test), I (Inspection), A (Analysis), D (Demonstration) per KSPEC-000 §11.

## 2.2 Severity scale (S, 1-10, qualitative)

| Rating | Anchor |
|---|---|
| 1-2 | Negligible: no credential or availability impact; cosmetic log-only condition. |
| 3-4 | Minor: single-device credential impact, transient delay, or degraded admin visibility; recoverable by retry. |
| 5-6 | Moderate: multiple devices unable to enroll/renew, one operational function unavailable, or silent loss of an administrative control for a bounded period. |
| 7-8 | Major: gateway-wide enrollment/revocation outage, revocation-state integrity loss, or silent failure of a security-relevant control. |
| 9-10 | Critical: enterprise-wide loss of device credential trust, irreversible loss of CA/database state, or sustained silent security-control failure. |

## 2.3 Occurrence scale (O, 1-10, qualitative)

| Rating | Anchor (engineering judgment, not measured frequency) |
|---|---|
| 1-2 | Remote: requires multiple simultaneous preconditions or an event never yet observed. |
| 3-4 | Unlikely: possible under plausible but uncommon conditions. |
| 5-6 | Occasional: plausible in normal operation (e.g., known boundary behaviors recorded in `docs/IMPLEMENTATION-TRACKER.md`). |
| 7-8 | Likely: conditions occur routinely in the documented operating model. |
| 9-10 | Near-certain: will occur without operator intervention given documented behavior. |

## 2.4 Detection scale (D, 1-10, qualitative)

| Rating | Anchor |
|---|---|
| 1-3 | High detectability: an existing automated mechanism surfaces the failure (health endpoint, enrollment events, logs). |
| 4-6 | Moderate detectability: failure is logged but requires operator attention or an enabled, correctly subscribed notification channel. |
| 7-8 | Low detectability: failure is silently swallowed by design or only visible by manual inspection. |
| 9-10 | Very low detectability: no in-repo mechanism; detected only via external consequence. |

## 2.5 Risk priority numbers and priority bands

RPN = S × O × D (each 1-10, so RPN in 1…1000).

| Band | RPN | Response |
|---|---|---|
| Critical | ≥ 216 | Requires PROPOSED control scheduling before any production deployment. |
| High | 108-215 | Requires PROPOSED control scheduling or a documented operational workaround. |
| Medium | 48-107 | Track; improve detection or mitigation opportunistically. |
| Low | < 48 | Accept with recorded rationale. |

Two overrides, regardless of RPN:

- Any risk with S ≥ 9 is at least **High**.
- Any risk with S ≥ 7 **and** no automated detection (D ≥ 7) is at least **High**.

## 2.6 Linked requirements - prefix-level references

KSPEC-003 contains the canonical Requirements Register. Area-level references below describe risk-control intent; KSPEC-009 §7.2 binds each ORK to concrete SR identifiers. Interoperability references use `SR-F-INT`; CA connector behavior uses `SR-F-CAI`. No area reference defines a new obligation.

# 3. Risk register (FMEA entries)

Each entry below states the failure mode, causes, effects, AS-IS mitigations with provenance, detection, PROPOSED controls, recovery strategy, linked requirement prefixes, and verification methods. Ratings are qualitative and apply the scales of §2. Cross-references to KSPEC-006 threats are given where an operational failure mode intersects threat behavior.

## ORK-001 - Certificate renewal failure

**Rating (AS-IS):** S=7, O=6, D=5 → RPN=210 → **High** (override: S≥7 with no fully automated detection).

• **Description / failure mode:** A device's credential approaches or reaches `NotAfter` without a successful re-enrollment, so mTLS renewal itself and all certificate-authenticated communication become impossible. This is a dead-end state: re-enrollment requires a (still-valid) client certificate (`EstController.SimpleReenroll` returns 401 "Client certificate required for re-enrollment" otherwise), and activation codes bootstrap only the *first* certificate (`docs/device-enrollment.md`).

• **Causes:** (a) documented operating boundary - automatic renewal runs only while the sample device application (`Kryptonian.MedicalDevice`) is open (`docs/IMPLEMENTATION-TRACKER.md`, "Deliberate boundaries"); (b) CA backend failure or rejection during re-enrollment; (c) network interruption during the renewal window; (d) historical client-side key-generation defect (Schannel rejected ephemeral attached RSA keys - fixed with a runnable regression per the tracker, but demonstrates client-side fragility); (e) CSR/returned-certificate policy enforcement rejecting a previously acceptable request.

• **Effects:** Device loses network identity at certificate expiry; all certificate-authenticated traffic (including EST renewal and DICOM mTLS in the demonstration topology) fails closed; device must be re-registered and re-provisioned through the administrator activation flow.

• **AS-IS mitigations:**

  • `CertificateExpiryWatcher` scans daily (24 h interval, 2-min cold-start delay) for valid certificates inside the configured warning window whose device has not recorded a newer certificate, and fires a near-expiry notification; re-notification for the same certificate is suppressed for 7 days (`CertificateExpiryWatcher.cs`, CODE-OBSERVED; summary documented in `docs/email-notifications.md`, DOCUMENTED).

  • Renewal is certificate-authenticated, generates a new key, and preserves the approved identity; one-time activation replay is rejected (tracker live-run evidence, VERIFIED).

  • Pending/async enrollment returns HTTP 202 with `Retry-After` (`EstController.HandleEnrollmentResult`, CODE-OBSERVED).

• **Detection:** Near-expiry email (requires enabled settings, subscribed recipients, and a reachable SMTP relay - see ORK-014); enrollment events and structured logs; no automated alerting on *repeated failed* re-enrollments beyond the rejection notification.

• **PROPOSED controls:** Out-of-application renewal operation as a deployment policy item (the tracker explicitly defers "Long-lived OS service operation… need deployment policy"); a defined renewal deadline policy (e.g., renew by N days before expiry with escalation); alerting on consecutive failed re-enrollments for the same device; renewal-attempt telemetry. [PROPOSED]

• **Recovery strategy:** AS-IS: once a certificate has expired, the device cannot renew and requires administrator re-registration (new pending record and activation code). PROPOSED: a documented emergency re-bootstrap path with operator dual control. [PROPOSED]

• **Linked requirements (prefix-level):** SR-C-* (certificate lifecycle), SR-R-* (reliability), SR-X-* (failure and recovery).

• **Verification methods:** T (renewal window and watcher behavior), D (live lifecycle demonstration per tracker), A (renewal-deadline policy review).

## ORK-002 - Device communication interruption

**Rating (AS-IS):** S=6, O=6, D=4 → RPN=144 → **High**.

• **Description / failure mode:** A device cannot reach the gateway EST endpoint (`/.well-known/est/...`) or the CRL endpoint, or the gateway cannot reach the active CA backend, for a period that disrupts enrollment, renewal, or revocation-status retrieval.

• **Causes:** network/switch/firewall outage; gateway process or host failure; EST listener not started; rate limiting (`AspNetCoreRateLimit`, 100 requests/minute on `*:/.well-known/est/*` per `docs/ARCHITECTURE.md`) blocking a burst of legitimate clients; reverse-proxy misconfiguration of `X-Forwarded-For` (used by `EstController.GetClientIp`, CODE-OBSERVED).

• **Effects:** enrollment attempts fail (recorded as enrollment events); near-expiry devices may miss their renewal window (feeds ORK-001); CRL retrieval failures may cause peers to fail certificate validation depending on their policy.

• **AS-IS mitigations:**

  • Health endpoint `GET /api/status/health` reporting component status (database, ca_connectors) (`docs/DEPLOYMENT.md`, DOCUMENTED; `docker-compose.yml` healthcheck, CODE-OBSERVED).

  • Enrollment rejections recorded as persisted events and (optionally) emailed, including operation, subject DN, device ID, client IP, and reason (`docs/email-notifications.md`, DOCUMENTED).

  • 202-pending responses with `Retry-After` allow clients to back off rather than hard-fail (CODE-OBSERVED).

  • CRL documents are served from persisted issuer state with `nextUpdate` caching, so short gateway outages do not immediately invalidate cached CRLs at peers (`CertificateRevocationService.GetCrlAsync`, CODE-OBSERVED).

• **Detection:** health checks; enrollment-rejection notifications; structured logs (Serilog console + rolling files, DOCUMENTED). No external synthetic monitoring of the EST path is present in the repository (INFERRED from absence; `docs/DEPLOYMENT.md` marks Prometheus metrics as future).

• **PROPOSED controls:** external synthetic probe of `/cacerts` and CRL endpoints; rate-limit tuning review with capacity data; documented firewall/ port requirements per deployment form (loopback-only by default in the Windows package - enabling external device connections is a separate network configuration milestone, `docs/windows-installation.md`, DOCUMENTED). [PROPOSED]

• **Recovery strategy:** AS-IS: devices retry; gateway restart re-enters service (restart persistence on populated SQLite demonstrated, tracker, VERIFIED). PROPOSED: runbook with failover/secondary gateway guidance. [PROPOSED]

• **Linked requirements (prefix-level):** SR-V-* (availability), SR-F-INT-* (interoperability), SR-R-*.

• **Verification methods:** T (health endpoint), D (retry/pending behavior), A (rate-limit and capacity analysis).

## ORK-003 - Certificate authority unavailability

**Rating (AS-IS):** S=7, O=5, D=3 → RPN=105 → **Medium** (close to High band).

• **Description / failure mode:** The active CA backend (Self-Signed, ACME, ADCS, or EJBCA connector) is unreachable or errors, so enrollments/renewals routed to it fail. Devices never choose a backend; the gateway routes to the single active backend (`docs/ca-backend-configuration.md`, DOCUMENTED).

• **Causes:** backend service outage; incorrect backend URL or credentials; harness/connector configuration drift; ADCS/EJBCA hospital interoperability remains **unverified** (`docs/IMPLEMENTATION-TRACKER.md`, DOCUMENTED) - real hospital CA behavior under failure is unknown (UNKNOWN for field behavior).

• **Effects:** all enrollments on the active profile fail until the backend is restored or another backend is activated; existing certificates and device records remain available (activation "affects future certificate enrollments only", DOCUMENTED).

• **AS-IS mitigations:**

  - Connector error handling converts HTTP failures and exceptions into `CertificateIssuanceResult.Failed(...)` with logged detail (`AdcsCaConnector.IssueCertificateAsync`, `EjbcaCaConnector.IssueCertificateAsync`, CODE-OBSERVED).
  - `TestConnectionAsync` per backend (UI **Test** button / `POST /api/cas/{id}/test`) returns a success flag and `false` (not an exception) when unreachable (CODE-OBSERVED; usage DOCUMENTED).
  - Health endpoint includes a `ca_connectors` component (DOCUMENTED).
  - Failure responses propagate to the device as EST errors; exceptions in `EstController` map to 4xx/5xx with logged cause (CODE-OBSERVED).

- **Detection:** backend **Test** action; health endpoint; enrollment failure events/logs. No periodic automated backend probing exists (INFERRED from absence).
- **PROPOSED controls:** scheduled automated backend health probe with alert; documented failover procedure to a secondary enabled backend (only one backend may be active at a time - DOCUMENTED); pre-activation validation gate requiring a successful Test before **Activate**. [PROPOSED]
- **Recovery strategy:** AS-IS: activate an alternate enabled backend (UI **Activate** / `POST /api/cas/{backendId}/activate`); retry failed enrollments. Revocation against a disabled backend returns 503 "Certificate authority is unavailable" (`CertificateRevocationService`, CODE-OBSERVED). PROPOSED: documented backend-outage runbook. [PROPOSED]
- **Linked requirements (prefix-level):** SR-C-*, SR-F-INT-*, SR-V-*, SR-X-*.
- **Verification methods:** T (connector failure-path tests), D (backend test/ activate flow), A (interoperability gap analysis - also feeds KSPEC-010).

## ORK-004 - Incorrect certificate policy configuration

**Rating (AS-IS):** S=7, O=5, D=6 → RPN=210 → **High** (override not triggered: D<7; band reached on RPN).

- **Description / failure mode:** An EST profile or CA backend is configured with the wrong policy bundle - subject-DN rules, key usage, validity, trust policy, or client-certificate requirements - so the gateway issues credentials that violate institutional policy, or rejects legitimate devices.
- **Causes:** manual profile editing via UI/REST; partial-update semantics misapplied; trust-thumbprint lists mis-entered; default-off chain validation (`validate_client_certificate_chain` defaults to `false` in schema upgrades, `SchemaUpgrades.cs`, CODE-OBSERVED); connector JSON config precedence rules (config field → primary URL → environment fallback → default) misunderstood (`docs/ca-backend-configuration.md`, DOCUMENTED).
- **Effects:** over-permissive policy → credentials inconsistent with policy (cross-ref KSPEC-006 threats THR-* for abuse); under-permissive policy → enrollment failures and device onboarding outage.
- **AS-IS mitigations:**
  - CSR and returned-certificate policy enforcement at issuance (PR #43, tracker; behavior VERIFIED in executed tests).
  - Partial updates preserve omitted trust lists (PR #47, tracker).
  - Unknown EST profile labels are rejected rather than falling back (PR #37, tracker).
  - Backend configuration **Test** action validates connectivity before use (DOCUMENTED).
  - Profile trust policy persisted durably with additive upgrades (PR #41, tracker).
- **Detection:** enrollment events record rejections with reason; policy violations at issuance are logged. No diffing/audit of profile changes is present in the baseline (INFERRED from absence).

• **PROPOSED controls:** profile change audit trail with before/after values; pre-save policy linting (e.g., warning when chain validation is disabled); staged profile activation (test profile → review → promote); documented naming/ownership of profiles. [PROPOSED]

• **Recovery strategy:** AS-IS: correct the profile via admin UI/REST; re-issue affected credentials as required by policy. Note that issued certificates are not recalled automatically - any recovery requiring invalidation of already-issued certificates depends on the revocation capability of the backend (ORK-008).

• **Linked requirements (prefix-level):** SR-Z-* (authorization), SR-S-*, SR-C-*, SR-O-*.

• **Verification methods:** I (configuration review procedure), T (policy enforcement tests), D (activation gate demonstration).

## ORK-005 - Unauthorized trust relationship

**Rating (AS-IS):** S=9, O=3, D=5 → RPN=135 → **High** (override: S≥9 implies at least High). Intersects KSPEC-006 threats (THR-*); retained here for the operational (misconfiguration/misprovisioning) dimension.

• **Description / failure mode:** The gateway, the DIMSE-TLS proxy, or a client comes to trust an issuer or peer that institutional policy did not authorize, allowing a rogue device or intermediary to be accepted.

• **Causes:** mis-pinned `trusted_client_ca_thumbprints` on a profile; CA private-key/PFX exposure; silent installation of trust into OS stores (explicitly avoided - the Windows package adds only a separate administration CA to the current user's store after an explicit prompt and never installs a device-issuing CA machine-wide, `docs/windows-installation.md`, DOCUMENTED); accidental activation of the wrong backend as the active CA.

• **Effects:** issuance of gateway-recognized credentials to unauthorized clients, or acceptance of unauthorized peers in mTLS; potentially enterprise-wide credential trust loss (S=9 anchor).

• **AS-IS mitigations:**

  • Trusted-forwarding guard rejects direct forwarded-certificate spoofing; the HTTP listener denies non-CRL requests (PR #39 + tracker live evidence, VERIFIED).

  • Authenticated enrollment identity binding (PR #38, VERIFIED).

  • DIMSE proxy operational trust checks: issuer, hostname, purpose, online revocation; expired replacement PFX fails closed (tracker loopback proxy tests, VERIFIED).

  • Administration CA trust is per-user and explicit; no silent machine-wide trust (DOCUMENTED).

  • Trust policy persistence is additive and durable (PR #41, VERIFIED via restart test on populated SQLite).

• **Detection:** enrollment-rejection notifications (reason recorded); logs of client-certificate validation failures (`EstController` warns with reason, CODE-OBSERVED). No automated reconciliation of configured trust lists against an approved baseline (INFERRED from absence).

• **PROPOSED controls:** periodic trust-baseline reconciliation report; dual-control change for trust-list edits; CA key/PFX custody and access review; automated alert when a new issuer fingerprint appears in trust state. [PROPOSED]

• **Recovery strategy:** AS-IS: remove the unauthorized profile trust entries via admin API; revoke affected certificates where the backend supports it (ORK-008 limits apply); the user-facing trust-removal action is `POST /api/devices/{id}/remove`, after which renewals are rejected (`docs/sequence-diagrams/README.md`, DOCUMENTED).

• **Linked requirements (prefix-level):** SR-A-* (authentication), SR-S-*, SR-Z-*, SR-C-*.

• **Verification methods:** D (spoof-rejection and trust-lifecycle demonstrations), T (trust-policy regression tests), I (trust audit).

## ORK-006 - Database corruption

**Rating (AS-IS):** S=9, O=4, D=6 → RPN=216 → **Critical**.

• **Description / failure mode:** Loss of integrity or availability of the persistence store (SQLite file in the Windows package; PostgreSQL 16 volume in the container deployment), destroying device records, certificate records, issuer CRL state, EST profiles, notification settings, and audit trails.

• **Causes:** disk/media failure; SQLite file corruption (e.g., power loss on host); PostgreSQL data-volume loss (`postgres_data` named volume in `docker-compose.yml`, CODE-OBSERVED, with **no automated backup in the compose file** - INFERRED from absence); failed or partial schema upgrade (ORK-011); manual deletion (uninstall intentionally retains private state, but external cleanup processes are unrestrained).

• **Effects:** enterprise-wide loss of credential lifecycle state: enrollment and renewal impossible; revocation state and CRL publication lost (`issuer_crl_states`); notification/audit history lost. Matches the S=9-10 anchor ("irreversible loss of CA/database state").

• **AS-IS mitigations:**

  • Transactional revocation and CRL persistence with explicit begin/rollback/commit and concurrency-safe persistence attempts (`UnitOfWork.TryPersistRevocationStateAsync`, `CertificateRevocationService`, CODE-OBSERVED).

  • Gateway restart on populated SQLite preserved configured profile, issuer, and devices (tracker live evidence, VERIFIED) - demonstrates durability across clean restarts, not corruption recovery.

  • Windows installer: "Back up database, CA and encryption keys together" is operator guidance only; "Do not treat MSI rollback as a database rollback" (`docs/windows-installation.md`, DOCUMENTED).

  • Azure plans note 7-day point-in-time backups for the Postgres instance in that specific deployment (`plans/azure-deployment.md`, DOCUMENTED; not a general guarantee).

• **Detection:** health endpoint `database` component (DOCUMENTED); startup failures. Silent logical corruption is unlikely to be detected automatically (INFERRED).

• **PROPOSED controls:** scheduled, verified, off-host backups (full design in §6); pre-upgrade snapshots; SQLite integrity checks (e.g., `PRAGMA integrity_check`) with alerting; documented restore drills. [PROPOSED]

• **Recovery strategy:** AS-IS: none beyond reinstallation and re-provisioning from scratch; MSI rollback explicitly is not a database rollback. PROPOSED: restore procedure of §6 with defined RPO/RTO targets TBD by stakeholders. [PROPOSED]

• **Linked requirements (prefix-level):** SR-D-* (data management), SR-X-*, SR-O-*.

• **Verification methods:** T (backup/restore drill), A (corruption-scenario analysis), I (backup schedule inspection).

## ORK-007 - Certificate expiration (unmanaged)

**Rating (AS-IS):** S=7, O=5, D=4 → RPN=140 → **High**.

• **Description / failure mode:** A valid device certificate passes into expired status without renewal or operator action; device loses the ability to communicate or renew (same dead-end as ORK-001 but viewed from the gateway-side monitoring and escalation angle).

• **Causes:** missed notifications (ORK-014); device offline during the entire warning window; warning window (`ExpiryWarningDays`) set too short; 7-day re-notification suppression delaying repeated alerts (`CertificateExpiryWatcher`, CODE-OBSERVED).

• **Effects:** device connectivity failure; security teams may be unaware a revoked/expired credential is still presented by peers unless those peers enforce expiry (peers do fail closed on expired replacement PFX in proxy tests, VERIFIED).

• **AS-IS mitigations:**

  • Daily watcher scan with per-certificate warning window and suppression state (`LastExpiryNotifiedAt`), skipping already-expired certificates and certificates whose device has a newer one (CODE-OBSERVED).

  • Expiry emails include subject DN, device ID, serial, expiration time, and days remaining (DOCUMENTED).

- Peers enforce expiry and online revocation, so expired credentials fail closed at the peer (VERIFIED).

• **Detection:** watcher-driven email; dashboard certificate listing. Already- expired certificates are deliberately skipped by the watcher ("already expired - different concern", CODE-OBSERVED) - meaning the gateway itself does not raise a *post-expiry* alert, an AS-IS detection gap.

• **PROPOSED controls:** post-expiry state alerting/escalation; expired- certificate lifecycle policy (retire/remove records); adjustable escalation when warnings are unacknowledged. [PROPOSED]

• **Recovery strategy:** AS-IS: device re-registration with new activation code (ORK-001 recovery). PROPOSED: bulk expiry remediation runbook. [PROPOSED]

• **Linked requirements (prefix-level):** SR-C-*, SR-O-*, SR-R-*.

• **Verification methods:** T (watcher scan tests), D (expiry demonstration), I (notification policy review).

## ORK-008 - Failed revocation

**Rating (AS-IS):** S=8, O=6, D=5 → RPN=240 → **Critical**.

• **Description / failure mode:** Revocation of a compromised or retired credential fails or is unavailable, so a revoked certificate remains usable at peers until CRL propagation/validity windows elapse - or, for some backends, revocation cannot be performed at all through the gateway.

• **Causes:** remote CA revocation not implemented - the ADCS SCEP connector logs "does not implement revocation" and returns `false` (`AdcsCaConnector.RevokeCertificateAsync`, CODE-OBSERVED; `docs/adcs-real-backend-demo.md` notes revocation would need a separate channel such as certutil / CA Web Services, DOCUMENTED); EJBCA revoke requires `IssuerDn` configuration and returns `false` on failure or misconfiguration (CODE-OBSERVED); unsupported CRL generation fails closed with 501 (CODE-OBSERVED); issuer/CA mismatch or rotated-CA guards reject the operation with 409 (CODE-OBSERVED); ADCS/EJBCA hospital interoperability unverified (DOCUMENTED).

• **Effects:** a compromised credential may continue to authenticate until peers observe revocation; CRL lifetime is a 60-second prototype cadence (`PrototypeCrlLifetime = 60 s`, CODE-OBSERVED) - a deliberate demo value that must not be assumed production-appropriate without review.

• **AS-IS mitigations (fail-closed orientation):**

  • Remote-CA revocation **fails closed**: unsupported connectors or CRL generation produce error responses (501) and the certificate state is not changed (`CertificateRevocationService`, tracker: "Unsupported remote CA revocation fails closed", DOCUMENTED + CODE-OBSERVED).

  • Revocation is transactional: certificate status, `revoked_at`, and issuer CRL state persist atomically; concurrency conflicts return 409 with a retry hint (CODE-OBSERVED; demonstration VERIFIED - administrator revocation followed by native online X509Chain reporting Revoked without flushing the system CRL cache).

  • Issuer fingerprint and rotated-CA checks prevent revoking against the wrong issuer (CODE-OBSERVED).

  • Peer-side online revocation checking is enabled for device/client and DICOM peers (VERIFIED); proxy connections have bounded lifetimes rather than instant mid-association revocation (DOCUMENTED boundary).

• **Detection:** revocation API error responses (404/409/501/503/500 with reason) and logs; no proactive monitoring of revocation success rates (INFERRED from absence).

• **PROPOSED controls:** real revocation integrations for ADCS (certutil / CA Web Services) and verified EJBCA operation; revocation-outcome reporting in the admin UI; monitoring of CRL `nextUpdate` staleness; decision review of the 60-second CRL lifetime for production. [PROPOSED]

• **Recovery strategy:** AS-IS: retry revocation after fixing the cause (e.g., configure `IssuerDn`, re-enable backend); where the connector cannot revoke, revoke out-of-band at the CA and rely on peer-side checks. PROPOSED: compensating revocation runbook per backend type. [PROPOSED]

• **Linked requirements (prefix-level):** SR-C-* (certificate lifecycle), SR-S-*, SR-F-INT-*.

• **Verification methods:** D (revocation demonstration), T (fail-closed connector tests), A (CRL lifetime and propagation analysis).

## ORK-009 - Clock synchronization errors

**Rating (AS-IS):** S=8, O=4, D=7 → RPN=224 → **Critical** (override: S≥7 with D≥7).

• **Description / failure mode:** Incorrect system time or timezone handling corrupts certificate-lifecycle decisions - expiry windows, CRL `thisUpdate`/`nextUpdate`, activation-code expiry, revocation visibility.

• **Causes:** NTP drift or outage on the gateway host; mixed UTC/local DateTime kinds. **Recorded precedent:** SQLite's unspecified `DateTimeKind` shifted refreshed CRL revocation times five hours into the future on the development host; fixed with a runnable regression (tracker, "Live checks exposed two bugs that mocked tests missed", VERIFIED as fixed; demonstrates the failure class).

• **Effects:** CRLs that appear valid/invalid at the wrong times; peers may reject or accept revocation state incorrectly (failing closed or mis-trusting); activation codes and warning windows compute wrongly.

• **AS-IS mitigations:**

  • Fixed regression for the SQLite `DateTime` kind bug (tracker, VERIFIED).

  • Consistent `DateTime.UtcNow` usage in lifecycle computations (`CertificateRevocationService`, `CertificateExpiryWatcher`, CODE-OBSERVED - inspection, not an exhaustive audit).

  • `nextUpdate` bounds CRL validity at the issuer's `NotAfter` (`GetNextUpdate`, CODE-OBSERVED).

• **Detection:** the original bug was caught only by live end-to-end checks, not by mocked tests (tracker, VERIFIED). No runtime clock-drift monitoring exists (INFERRED from absence).

• **PROPOSED controls:** host NTP requirements in deployment documentation; invariant/regression tests for UTC round-tripping across both persistence providers; startup warning when local time zone ≠ UTC or when skew exceeds a configurable threshold. [PROPOSED]

• **Recovery strategy:** AS-IS: re-synchronize host clock; CRL/`nextUpdate` state self-corrects on the next refresh cycle because `thisUpdate`/`nextUpdate` are recomputed per generation (CODE-OBSERVED). PROPOSED: documented time-incident runbook. [PROPOSED]

• **Linked requirements (prefix-level):** SR-R-*, SR-C-*, SR-D-*.

• **Verification methods:** T (UTC-kind regression tests), A (time-handling audit), D (skewed-clock demonstration).

## ORK-010 - Configuration errors

**Rating (AS-IS):** S=7, O=6, D=5 → RPN=210 → **High**.

• **Description / failure mode:** Gateway-level configuration error - weak or default credentials, wrong ports/listeners, mis-set environment variables, insecure SMTP options - degrades security or availability.

• **Causes:** compose defaults shipped for development (`POSTGRES_PASSWORD` default `kryptonian_dev_password`, `ADMIN_API_KEYS` default `dev-api-key-change-in-production`, seeded initial admin `Kryptonian__Auth__InitialAdminPassword: rtsec2026`, `ASPNETCORE_ENVIRONMENT` defaulting to Development - `docker-compose.yml`, CODE-OBSERVED); SMTP "Trust SMTP server certificate" toggle that skips TLS certificate chain validation (`MailKitSmtpSender` sets a permissive `ServerCertificateValidationCallback`, CODE-OBSERVED; documented as leave-off-by-default, DOCUMENTED); environment fallbacks for connector settings (DOCUMENTED).

• **Effects:** weak administrative authentication; MITM exposure of notification transport; enrollment outages from wrong endpoints; JWT secret shorter than the documented ≥32-character production requirement (`docker-compose.yml` comment, DOCUMENTED).

- **AS-IS mitigations:**
  - Production security checklist in `docs/DEPLOYMENT.md` requiring strong generated credentials (DOCUMENTED guidance, not enforced in code).
  - First-run administrator wizard with no shared default password in the Windows package (`docs/windows-installation.md`, DOCUMENTED).
  - Notification passwords stored encrypted via ASP.NET Data Protection and never returned to the UI (DOCUMENTED; `DataProtectionService`, CODE-OBSERVED).
  - ACME connector config validation (`config.Validate()` rejects missing directory URL/email, unsupported challenge types, half-provided EAB, CODE-OBSERVED).
- **Detection:** manual checklist review; startup errors from invalid config. No automated "production sanity" gate (e.g., refusing default credentials in Production environment) is present (INFERRED from absence).
- **PROPOSED controls:** startup validation that fails (or loudly warns) when Development defaults are detected in a non-Development environment; configuration export/diff tooling for change review; documented baseline configuration with checksums. [PROPOSED]
- **Recovery strategy:** AS-IS: correct settings via environment/UI and restart; rotate any exposed credential. PROPOSED: credential-rotation runbook (ORK-015). [PROPOSED]
- **Linked requirements (prefix-level):** SR-B-* (deployment), SR-S-*, SR-O-*.
- **Verification methods:** I (configuration checklist audit), T (startup validation tests once proposed controls exist), D (guided setup demonstration).

## ORK-011 - Software upgrade failure

**Rating (AS-IS):** S=8, O=5, D=6 → RPN=240 → **Critical**.

- **Description / failure mode:** A schema upgrade, container image update, or Windows installer upgrade leaves the gateway unable to start, loses data, or breaks an existing installation.
- **Causes:** PostgreSQL schema upgrades are implemented but **only SQLite persistence was exercised** (`docs/IMPLEMENTATION-TRACKER.md`, DOCUMENTED); `SchemaUpgrades.EnsureTrustPolicyAsync` runs raw additive DDL (`ALTER TABLE ... ADD COLUMN IF NOT EXISTS`, `CREATE TABLE IF NOT EXISTS`, index replacement) outside an explicit transaction/backup boundary (CODE-OBSERVED); container image updates replace the running API without an in-repo rollback artifact; MSI upgrade keeps existing CA and database but install/repair/upgrade/uninstall acceptance on a clean target remains **unverified** (`docs/windows-installation.md`, DOCUMENTED); Windows Sandbox guest state disappears on close (DOCUMENTED).
- **Effects:** startup failure; missing columns/tables causing runtime errors; in the worst case data loss (S=8 anchor: gateway-wide outage; corruption path overlaps ORK-006).
- **AS-IS mitigations:**
  - Schema upgrades are explicitly **additive**: "Existing installations use EnsureCreated, not EF migrations. Keep this additive: never recreate a populated database" (`SchemaUpgrades.cs` header comment, CODE-OBSERVED).
  - Additive upgrade design reviewed in PR #41 (tracker).
  - MSI upgrade preserves existing CA and database; readiness health check failure fails installation instead of reporting success (`docs/windows-installation.md`, DOCUMENTED).
  - Developer lifecycle evidence includes persistence across restart (VERIFIED).
- **Detection:** startup logs; health endpoint; MSI readiness check (fails installation on unhealthy readiness - DOCUMENTED). Partial-failure states between upgrade steps are not automatically detected (INFERRED).

• **PROPOSED controls:** mandatory pre-upgrade backup of database + CA + Data Protection key ring (§6); upgrade rehearsal on a snapshot in staging for **both** persistence providers, with explicit PostgreSQL exercise; documented image tag/rollback procedure for container deployments; upgrade-run checklist and go/no-go criteria. [PROPOSED]

• **Recovery strategy:** AS-IS: reinstall/repair MSI (retains private state); manual SQL remediation of additive schema. PROPOSED: restore-from-backup procedure (§6); documented schema-rollback position (additive upgrades make rollback by deletion unnecessary, but this shall be verified per release). [PROPOSED]

• **Linked requirements (prefix-level):** SR-B-*, SR-D-*, SR-X-*, SR-O-*.

• **Verification methods:** T (upgrade rehearsal tests), D (installer upgrade/uninstall demonstrations on clean targets), I (release checklist).

## ORK-012 - Backup and recovery failure

**Rating (AS-IS):** S=9, O=5, D=8 → RPN=360 → **Critical** (override: S≥9 and S≥7 with D≥7).

• **Description / failure mode:** No mechanism exists in the baseline to back up or restore gateway state; when state loss occurs (ORK-006, ORK-011), recovery fails or is impossible, or a restore attempt itself fails because prerequisite material (CA key, Data Protection key ring, passwords) was never captured together.

• **Causes:** absence of implemented backup tooling (repository search for backup mechanisms returns only documentation admonitions and unrelated variable names - INFERRED from absence, CODE-OBSERVED for compose and deploy scripts containing none); operator guidance ("Back up database, CA and encryption keys together") exists only as documentation (`docs/windows-installation.md`, DOCUMENTED); Data Protection key ring not backed up with the database.

• **Effects:** after a database/volume loss, device records, certificate records, CRL state, profiles, and users cannot be restored; encrypted SMTP credentials become undecryptable if the Data Protection key ring is lost even when the database is restored (INFERRED from Data Protection semantics; `DataProtectionService` CODE-OBSERVED).

• **AS-IS mitigations:**

  • Documentation admonition to back up database, CA and encryption keys together before upgrades (DOCUMENTED).

  • MSI uninstall intentionally retains `C:\ProgramData\KryptonianSandbox` private state, reducing accidental loss during uninstall (DOCUMENTED).

  • Azure-plan deployment relies on platform point-in-time restore for that specific hosted instance (DOCUMENTED; deployment-specific, not a product capability).

• **Detection:** none - absence of backups is typically discovered only during an incident (D=8).

• **PROPOSED controls:** full backup/restore design in §6 (scope, schedule, retention, verification, drill requirements, RPO/RTO targets TBD by stakeholders). [PROPOSED]

• **Recovery strategy:** AS-IS: none for gateway state beyond manual reconstruction and full device re-enrollment. PROPOSED: §6 procedure with quarterly restore drills. [PROPOSED]

• **Linked requirements (prefix-level):** SR-X-* (failure and recovery), SR-D-*, SR-O-*.

• **Verification methods:** T (restore drill), I (backup configuration inspection), A (recovery-time analysis).

## ORK-013 - Network partitioning

**Rating (AS-IS):** S=6, O=4, D=5 → RPN=120 → **High**.

• **Description / failure mode:** A partition between devices and gateway, or between gateway and CA/SMTP relay, isolates parts of the estate while the gateway itself reports healthy.

• **Causes:** VLAN/segmentation changes; firewall rule updates; hospital network maintenance; default loopback-only listeners in the Windows package (external device connectivity requires a separate, not-yet-performed network configuration

milestone - DOCUMENTED); proxy connection lifetimes bounded rather than unlimited, so long-lived associations end during partitions (DOCUMENTED boundary).

• **Effects:** devices in isolated segments cannot enroll/renew (feeding ORK-001); CRL retrieval failures; DICOM mTLS associations terminated at their bounded lifetime; notifications cannot leave the segment (ORK-014).

• **AS-IS mitigations:**

  • Health endpoint and container healthchecks detect *local* health only.

  • Persistent CRL state with `nextUpdate` gives peers a bounded tolerance to gateway unavailability (CODE-OBSERVED).

  • Explicitly documented network expectations (ports 7443/7444/7445 in the Windows package; 5000/5001 in compose) (DOCUMENTED).

• **Detection:** enrollment-rejection events cease from isolated segments - the *absence* of events is not itself alerted on (INFERRED gap); no network synthetic monitoring exists.

• **PROPOSED controls:** per-segment synthetic enrollment/CRL probes; monitoring of "devices heard from" staleness (alert when a previously active device reports nothing for N days); documented segmentation/port matrix per deployment form. [PROPOSED]

• **Recovery strategy:** AS-IS: network remediation; devices retry enrollment when connectivity returns. PROPOSED: alternate enrollment path (documented maintenance window procedure). [PROPOSED]

• **Linked requirements (prefix-level):** SR-V-*, SR-F-INT-*, SR-R-*.

• **Verification methods:** D (partition drill), T (retry/pending behavior), A (segmentation design review).

## ORK-014 - Notification delivery failure

**Rating (AS-IS):** S=6, O=6, D=7 → RPN=252 → **Critical** (override: S≥7 not met at S=6; band reached on RPN).

• **Description / failure mode:** Near-expiry or enrollment-rejection email notifications are silently not delivered - because SMTP is unreachable, the master/event/subscription switches are off, or the recipient list is wrong - removing the operator's primary automated signal for ORK-001/ORK-007.

• **Causes:** SMTP relay outage or wrong host/port/TLS/auth settings; Data Protection key-ring loss making the stored SMTP password undecryptable (INFERRED from `NotificationDispatcher.BuildDispatchConfig` unprotect call, CODE-OBSERVED); three-layer enablement model (master switch → global event switch → per-recipient subscription) where any layer silently disables an event; the documented caveat that "the test email does not prove that event subscriptions are enabled" (`docs/email-notifications.md`, DOCUMENTED).

• **Effects:** silent loss of expiry and rejection alerts; operators learn of expiring credentials only after connectivity breaks. Note the AS-IS design intent: "production notification failures are logged and swallowed so email outages do not block enrollment requests" (DOCUMENTED; `NotificationDispatcher` catch-all, CODE-OBSERVED) - availability is protected at the cost of alert durability.

• **AS-IS mitigations:**

  • Failures logged with context ("Failed to dispatch … notification") (CODE-OBSERVED).

  • **Send test email** action validating SMTP connectivity before saving (DOCUMENTED; controller returns the failure reason, CODE-OBSERVED).

  • Recipient/settings REST endpoints for automation (`/api/settings/notifications[...]`, DOCUMENTED).

  • SMTP passwords stored encrypted, never returned to the UI (DOCUMENTED).

  • MailKit upgraded to patched 4.16.0 with BouncyCastle 2.6.2 (tracker, VERIFIED build change).

• **Detection:** log-only (D=7): delivery failures leave no persistent event record and no retry queue (CODE-OBSERVED - `SendAsync` exceptions are caught and logged).

• **PROPOSED controls:** persistent notification-outcome record with retry queue and backoff; a notification watchdog independent of the gateway's own SMTP path (e.g., periodic heartbeat mail whose absence is alerted by an external monitor); configuration self-test that exercises the full enablement chain, not just SMTP connectivity. [PROPOSED]

• **Recovery strategy:** AS-IS: fix SMTP settings via UI (password-update semantics: `null` keeps, empty clears, non-empty replaces - DOCUMENTED); missed alerts must be reconstructed from enrollment events and certificate records. PROPOSED: replay of unsent notifications after outage. [PROPOSED]

• **Linked requirements (prefix-level):** SR-O-*, SR-R-*, SR-U-* (audit).

• **Verification methods:** T (delivery-failure tests), D (watchdog demonstration), I (subscription configuration audit).

## ORK-015 - Secrets / credential rotation failure

**Rating (AS-IS):** S=8, O=4, D=7 → RPN=224 → **Critical** (override: S≥7 with D≥7).

• **Description / failure mode:** Rotation of a secret or credential - API keys, JWT secret, CA PFX/password, SMTP credentials, Data Protection key ring, DIMSE proxy PFX - fails, is missed, or breaks a dependent component.

• **Causes:** no automated rotation exists in the baseline (INFERRED from absence); DIMSE proxy PFX renewal is **external** and reload is demonstrated, not automated CA renewal (tracker boundary, DOCUMENTED); rotating the CA certificate blocks revocation of previously issued certificates - the revocation service returns 409 "Configured CA certificate has rotated; create a new CA backend before revoking certificates" (CODE-OBSERVED); JWT secret rotation invalidates issued tokens; Data Protection key-ring rotation invalidates stored SMTP passwords (INFERRED).

• **Effects:** enrollment outages; peers unable to trust renewed intermediaries until PFX is replaced; revoked-certificate management gaps for certificates issued by the retired CA key; administrative lockouts.

• **AS-IS mitigations:**

  • Atomic one-time activation (PR #42) prevents replay during bootstrap (VERIFIED).

  • Externally rotated PFX reload demonstrated with fresh handshakes observing atomic replacement; expired replacement fails closed (tracker, VERIFIED).

  • API-key revocation endpoints exist for user credentials (`UsersController`/UI revoke actions, CODE-OBSERVED).

  • Rotated-CA guard above prevents wrong-issuer revocation rather than corrupting state (CODE-OBSERVED).

• **Detection:** component failure at next use (auth failures in logs); no expiry/cadence tracking for secrets (INFERRED from absence).

• **PROPOSED controls:** secret inventory with rotation cadences and owners; documented rotation runbooks per secret class (JWT, API keys, CA PFX, SMTP, Data Protection key ring); pre-rotation backup (§6); staged CA-key rotation design (dual CA backends during transition) requiring stakeholder approval. [PROPOSED]

• **Recovery strategy:** AS-IS: reconfigure and restart; device re-enrollment where trust is broken. PROPOSED: documented recovery from key-ring loss (restore keys first, per §6). [PROPOSED]

• **Linked requirements (prefix-level):** SR-S-*, SR-A-*, SR-O-*.

• **Verification methods:** D (rotation drill), T (post-rotation regression suite), I (secret inventory audit).

## ORK-016 - Dependency vulnerability exposure

**Rating (AS-IS):** S=7, O=5, D=4 → RPN=140 → **High**.

• **Description / failure mode:** A known vulnerability in a runtime, native, or UI dependency remains unpatched in a deployment, exposing the gateway or its host.

• **Causes: recorded, open transitive advisories** in the baseline: high advisories in `SQLitePCLRaw.lib.e_sqlite3 2.1.6` and `System.Security.Cryptography.Xml 8.0.2`, explicitly recorded as "deployment blockers requiring a separately

tested framework/native-provider update, not evidence of a clean security audit" (`docs/IMPLEMENTATION-TRACKER.md`, DOCUMENTED); native SQLite provider updates carry persistence-compatibility risk; UI/npm supply chain.

• **Effects:** exploitable gateway or host components; potential privilege escalation or data exposure; failed deployment-security gates.

• **AS-IS mitigations:**

  • Compatible dependency security updates with audit disclosure (PR #52); MailKit upgraded to patched 4.16.0 with required BouncyCastle 2.6.2 (tracker, VERIFIED build change).

  • UI lockfile refresh reduced npm audit from six vulnerable packages to zero; CI now **rejects high/critical UI dependency advisories** (tracker, VERIFIED CI behavior).

  • GitHub Actions CI builds UI and tests the solution (tracker, VERIFIED).

  • Honest disclosure that these measures are "not a whole-system audit" (DOCUMENTED).

• **Detection:** CI dependency audit for the UI; manual `dotnet list package --vulnerable` runs are not automated for the full solution (INFERRED from absence).

• **PROPOSED controls:** automated full-solution vulnerability scanning in CI (NuGet + npm + container base images) with advisory-based gates; SBOM publication per release; tracked remediation plan for the two recorded deployment blockers; scheduled dependency-update cadence. [PROPOSED]

• **Recovery strategy:** AS-IS: apply compatible update and redeploy. PROPOSED: emergency-patch runbook with pre-approval for out-of-band dependency updates. [PROPOSED]

• **Linked requirements (prefix-level):** SR-S-*, SR-B-*, SR-O-*.

• **Verification methods:** T (CI audit gates), I (SBOM and advisory review), A (exposure analysis).

# 4. FMEA summary table

Ratings use the §2 scales; bands per §2.5. All ratings are qualitative engineering judgments recorded for prioritization, not measured probabilities.

### ORK-001

**Failure mode:** Certificate renewal failure
**S:** 7
**O:** 6
**D:** 5
**RPN:** 210
**Band:** High
**Primary PROPOSED direction:** Out-of-app renewal operation; renewal-deadline policy

### ORK-002

**Failure mode:** Device communication interruption
**S:** 6
**O:** 6
**D:** 4
**RPN:** 144
**Band:** High
**Primary PROPOSED direction:** External synthetic probes; rate-limit review

### ORK-003

**Failure mode:** CA unavailability
**S:** 7
**O:** 5
**D:** 3
**RPN:** 105
**Band:** Medium
**Primary PROPOSED direction:** Automated backend probing; failover runbook

### ORK-004

**Failure mode:** Incorrect certificate policy configuration
**S:** 7
**O:** 5
**D:** 6
**RPN:** 210
**Band:** High
**Primary PROPOSED direction:** Profile change audit; pre-save policy linting

### ORK-005

**Failure mode:** Unauthorized trust relationship
**S:** 9
**O:** 3
**D:** 5
**RPN:** 135
**Band:** High[1]
**Primary PROPOSED direction:** Trust-baseline reconciliation; dual control

### ORK-006

**Failure mode:** Database corruption
**S:** 9
**O:** 4
**D:** 6
**RPN:** 216
**Band:** Critical
**Primary PROPOSED direction:** Verified off-host backups; restore drills

### ORK-007

**Failure mode:** Certificate expiration (unmanaged)
**S:** 7
**O:** 5
**D:** 4
**RPN:** 140
**Band:** High
**Primary PROPOSED direction:** Post-expiry alerting; escalation policy

### ORK-008

**Failure mode:** Failed revocation

**S:** 8
**O:** 6
**D:** 5
**RPN:** 240
**Band:** Critical
**Primary PROPOSED direction:** Real ADCS/EJBCA revocation; CRL-staleness monitoring

### ORK-009

**Failure mode:** Clock synchronization errors
**S:** 8
**O:** 4
**D:** 7
**RPN:** 224
**Band:** Critical[1]
**Primary PROPOSED direction:** NTP requirements; UTC invariant tests

### ORK-010

**Failure mode:** Configuration errors
**S:** 7
**O:** 6
**D:** 5
**RPN:** 210
**Band:** High
**Primary PROPOSED direction:** Startup sanity gate; config baselines

### ORK-011

**Failure mode:** Software upgrade failure
**S:** 8
**O:** 5
**D:** 6
**RPN:** 240
**Band:** Critical
**Primary PROPOSED direction:** Pre-upgrade backup; both-provider rehearsal

### ORK-012

**Failure mode:** Backup and recovery failure
**S:** 9
**O:** 5
**D:** 8
**RPN:** 360
**Band:** Critical[1]
**Primary PROPOSED direction:** §6 backup/restore design with drills

### ORK-013

**Failure mode:** Network partitioning
**S:** 6
**O:** 4

**D:** 5
**RPN:** 120
**Band:** High
**Primary PROPOSED direction:** Per-segment probes; staleness alerting

### ORK-014

**Failure mode:** Notification delivery failure
**S:** 6
**O:** 6
**D:** 7
**RPN:** 252
**Band:** Critical[1]
**Primary PROPOSED direction:** Outcome record + retry; independent watchdog

### ORK-015

**Failure mode:** Secrets / credential rotation failure
**S:** 8
**O:** 4
**D:** 7
**RPN:** 224
**Band:** Critical[1]
**Primary PROPOSED direction:** Secret inventory; rotation runbooks

### ORK-016

**Failure mode:** Dependency vulnerability exposure
**S:** 7
**O:** 5
**D:** 4
**RPN:** 140
**Band:** High
**Primary PROPOSED direction:** Full-solution CI scanning; SBOM; patch blockers

[1] Band reached or raised via the §2.5 overrides (S≥9, or S≥7 with D≥7).

Aggregate observation (ANALYSIS, INFERRED): the dominant pattern across Critical/High entries is **silent failure** (notification swallowing, absence of post-expiry alerting, absence of backup tooling) combined with **documented-but-unverified external interoperability** (ADCS/EJBCA, PostgreSQL upgrades). The highest-leverage PROPOSED controls are therefore detection investments (§5) and the recovery design (§6), ahead of new functional capability.

## 5. Monitoring and observability recommendations

AS-IS observability (with provenance):

| Mechanism | What it covers | Provenance |
|---|---|---|
| `GET /api/status/health` with `database` / `ca_connectors` components | Local process and dependency reachability | DOCUMENTED (`docs/DEPLOYMENT.md`); CODE-OBSERVED healthcheck in `docker-compose.yml` |

| Mechanism | What it covers | Provenance |
|---|---|---|
| Serilog structured logging (console + rolling daily files; correlation/client-IP enrichers per ARCHITECTURE) | Enrollment, validation failures, watcher scans, dispatch failures | DOCUMENTED; CODE-OBSERVED |
| Enrollment events (persisted, listed via `/api/status/enrollments`) | Per-attempt outcomes incl. rejection reasons | DOCUMENTED; CODE-OBSERVED |
| Certificate expiry watcher log lines | Watcher start/stop, scan failures, notified counts | CODE-OBSERVED |
| Backend **Test** action | Point-in-time connector reachability | DOCUMENTED |
| Dashboard certificate/device/event listings | Manual inspection | DOCUMENTED |
| CI build/test/audit gates (UI advisory gate) | Build-time quality, not runtime | VERIFIED (tracker) |

Gaps (INFERRED from absence unless noted): no metrics endpoint (`docs/DEPLOYMENT.md` marks Prometheus integration as future); no external synthetic probing; no alert on watcher scan failure beyond logs (the watcher catches scan exceptions and continues - CODE-OBSERVED - so repeated scan failure is silent); no notification-outcome record; no clock-drift or CRL-staleness checks.

PROPOSED observability plan (all items [PROPOSED], requiring stakeholder approval):

1. **Metrics endpoint** (Prometheus format): enrollment counts by profile/status, renewal success/failure by device, revocation attempts and outcomes, CRL `nextUpdate` staleness per issuer, watcher scan age/last success, SMTP dispatch outcomes, CA connector latency and error rate, certificate-expiry horizon distribution.
2. **Alerts** (proposed minimum set):
   - Watcher scan failing, or last successful scan older than 48 h.
   - Any certificate crossing into expired state.
   - Revocation request ending in 5xx/501.
   - Notification dispatch failure streak (≥ 3 consecutive).
   - Health endpoint loss of a component.
   - CRL `nextUpdate` within threshold of lapse.
3. **Synthetic checks**: periodic device-like `/cacerts` GET, CRL GET/HEAD over the real listeners, and (in approved environments) a full enrollment probe.
4. **Log retention and review**: align rolling-file retention with incident needs; include logs in backup scope (§6).
5. **Dashboards**: gateway availability; credential-lifecycle health (certificates approaching expiry vs. renewals completed); revocation coverage.

These recommendations are inputs to KSPEC-003 (SR-P/SR-R/SR-V/SR-U areas) and KSPEC-008 (VT entries); they are not normative until approved.

# 6. Backup, restore, and recovery design

## 6.1 AS-IS position

No backup or restore capability is implemented in the baseline for gateway state (see ORK-012). Operator guidance is limited to documentation:

- Windows package: "Back up database, CA and encryption keys together before upgrades"; "Do not treat MSI rollback as a database rollback; schema-upgrade testing is required" (`docs/windows-installation.md`, DOCUMENTED).
- Uninstall retains `C:\ProgramData\KryptonianSandbox` private state (DOCUMENTED).
- The compose deployment has a `postgres_data` named volume but no backup job (CODE-OBSERVED).
- The specific Azure plan relies on platform point-in-time restore (DOCUMENTED, deployment-specific).

## 6.2 PROPOSED backup design (TO-BE/PROPOSED - requires approval)

**Backup set (completeness rule):** a backup is only restorable if it captures, from the same point in time and the same host:

1. Database (SQLite file(s) under the private data directory, copied with the service stopped or via a provider-consistent snapshot; `pg_dump` / platform snapshot for PostgreSQL).
2. CA material: CA certificate + private key (PFX or PEM pair) for every configured backend, plus the CA PFX passwords.
3. ASP.NET Data Protection key ring (required to decrypt the stored SMTP password; loss breaks notification delivery after restore - INFERRED from Data Protection semantics, `DataProtectionService` CODE-OBSERVED).
4. Gateway configuration actually in effect (environment variables, listener configuration, installed-version identifier).
5. (Optional, retention-permitting) enrollment events and logs for forensics.

**Schedule and retention (TBD - recommendation only):**

| Item | Recommendation | Rationale |
|---|---|---|
| Database | Daily full (stopped-service SQLite copy, or `pg_dump`) | Minimizes RPO for lifecycle state |
| CA material + key ring | On change, verified quarterly | Changes rarely; loss is catastrophic |
| Retention | ≥ 30 days daily, ≥ 12 monthly | TBD by stakeholders |
| Storage | Off-host, access-controlled, encrypted; never the same volume as live state | Avoids a single failure domain |
| Verification | Restore rehearsal into a clean environment at a defined cadence (recommendation: quarterly) and before every upgrade | An unverified backup is not a backup |

**Restore procedure (PROPOSED skeleton):**

1. Freeze writes (stop gateway service/containers).
2. Capture a pre-restore state snapshot for forensics.
3. Restore the Data Protection key ring first, then CA material with original passwords, then the database.
4. Start the gateway so `SchemaUpgrades` runs against the restored database; confirm additive upgrades are idempotent (CODE-OBSERVED idempotent shapes: `ADD COLUMN IF NOT EXISTS`, `CREATE TABLE IF NOT EXISTS`, `PRAGMA table_info` guarded).

5. Verify: health endpoint all components healthy; enrollment via a test device; CRL served per issuer; SMTP test email; revocation round-trip.

6. Resume service and record the drill outcome.

**Recovery objectives:** RPO/RTO targets are **TBD** and require stakeholder decision; the recommendation above bounds RPO at 24 h for lifecycle state.

**Recovery priority when only partial material exists (PROPOSED guidance):** CA key material is the least recoverable asset - its loss forces full device re-enrollment and breaks revocation for previously issued certificates (ORK-008, ORK-015); the database is reconstructable by re-provisioning every device. Backup completeness must therefore prioritize CA keys and the Data Protection key ring.

# 7. Traceability and open questions

## 7.1 Requirement linkage (area-level; concrete bindings in KSPEC-009 §7.2)

Per §2.6, the following prefix-level linkage intent is recorded for KSPEC-009 to bind once the Requirements Register exists. This document defines no requirements.

| ORK | Target requirement areas (KSPEC-003 prefixes) |
|---|---|
| ORK-001, ORK-007 | SR-C (certificate lifecycle), SR-R (reliability), SR-X (failure/recovery) |
| ORK-002, ORK-013 | SR-V (availability), SR-F-INT (interoperability), SR-R |
| ORK-003, ORK-008 | SR-C, SR-F-CAI, SR-X |
| ORK-004, ORK-005 | SR-A (authentication), SR-Z (authorization), SR-S (security), SR-C |
| ORK-006, ORK-012 | SR-D (data management), SR-X, SR-O |
| ORK-009 | SR-R, SR-C, SR-D |
| ORK-010, ORK-011 | SR-B (deployment), SR-S, SR-O, SR-X |
| ORK-014 | SR-O, SR-R, SR-U (audit) |
| ORK-015, ORK-016 | SR-S, SR-A, SR-O, SR-B |

### 7.2 Open questions and TBD items (not fabricated)

| # | Open question | Owner decision needed |
|---|---|---|
| TBD-1 | Production CRL `nextUpdate` lifetime (AS-IS prototype value: 60 s, CODE-OBSERVED) | Stakeholders |
| TBD-2 | Backup RPO/RTO targets and retention (§6.2) | Stakeholders |
| TBD-3 | Out-of-application renewal mechanism and policy (ORK-001) | Stakeholders |
| TBD-4 | ADCS/EJBCA production interoperability verification plan (ORK-003, ORK-008) | Deployment/interoperability track (also KSPEC-010) |
| TBD-5 | PostgreSQL persistence exercise plan (ORK-011) | Deployment track |
| TBD-6 | Remediation plan for recorded transitive advisories (ORK-016) | Engineering/deployment track |

### 7.3 Risks to other documents

• KSPEC-006 (cybersecurity): ORK-005 and ORK-004 overlap threat modeling; boundary agreed here is *operational failure/misconfiguration* vs. *deliberate adversarial action*.

• KSPEC-010 (gap analysis): ORK-011, ORK-012, ORK-016 constitute evidence for GAP entries; identifiers to be cross-linked when KSPEC-010 is written.

• KSPEC-008 (V&V): verification methods in §3 map to VT candidates.

## 8. Provenance summary and evidence index

Provenance classes per KSPEC-000 §5. Summary of this document's assertions:

| Class | Count (approx.) | Representative assertions |
|---|---|---|
| VERIFIED | 12 | Activation replay rejection; renewal identity preservation; forwarding-spoof rejection; restart persistence; proxy trust checks incl. fail-closed expired PFX; online revocation demonstration; CI gates; MailKit patch; DateTime-kind regression fix |
| CODE-OBSERVED | 30+ | Watcher behavior; dispatcher swallow; connector error paths; fail-closed revocation; schema upgrades; compose defaults and absence of backup; Data Protection usage; CRL 60 s lifetime; rotated-CA guard |
| DOCUMENTED | 15+ | Tracker boundaries; deployment checklist; notification model; CA backend configuration; installer behavior and caveats; Azure plan backups |
| INFERRED | 10 | Absence of metrics/synthetic monitoring/backup tooling/secret-cadence tracking; Data Protection key-ring loss effects |

| Class | Count (approx.) | Representative assertions |
|---|---|---|
| UNKNOWN | 2 | Real hospital CA failure behavior (ADCS/EJBCA field behavior); production load behavior |
| PROPOSED | All §3 PROPOSED controls, §5 observability plan, §6.2 backup design | Require stakeholder approval; not normative |

Primary evidence files relied upon (all at baseline commit `682f996c8447afec13bc1fce5b7f59e6a06efa25`):

- `src/RTSec.Kryptonian.Api/HostedServices/CertificateExpiryWatcher.cs`
- `src/RTSec.Kryptonian.Api/Controllers/EstController.cs`
- `src/RTSec.Kryptonian.Api/Controllers/NotificationSettingsController.cs`
- `src/RTSec.Kryptonian.Application/Notifications/NotificationDispatcher.cs`
- `src/RTSec.Kryptonian.Application/Services/CertificateRevocationService.cs`
- `src/RTSec.Kryptonian.Infrastructure/Harness/AdcsCaConnector.cs`
- `src/RTSec.Kryptonian.Infrastructure/Harness/EjbcaCaConnector.cs`
- `src/RTSec.Kryptonian.Infrastructure/Acme/AcmeCaConnector.cs`
- `src/RTSec.Kryptonian.Infrastructure/Notifications/MailKitSmtpSender.cs`
- `src/RTSec.Kryptonian.Infrastructure/Data/SchemaUpgrades.cs`
- `src/RTSec.Kryptonian.Infrastructure/Data/UnitOfWork.cs`
- `docker-compose.yml`; `deploy/`; `installer/windows/`
- `docs/IMPLEMENTATION-TRACKER.md`, `docs/DEPLOYMENT.md`, `docs/ARCHITECTURE.md`, `docs/device-enrollment.md`, `docs/ca-backend-configuration.md`, `docs/email-notifications.md`, `docs/windows-installation.md`, `docs/windows-sandbox.md`, `docs/adcs-real-backend-demo.md`, `docs/sequence-diagrams/README.md`, `plans/azure-deployment.md`

## 8.1 Methodology limitations

- Ratings are qualitative anchor-based judgments by the documentation team; they have not been calibrated against incident data (none exists in the repository) and carry no statistical meaning.
- No failure probabilities, MTBF, or availability percentages are asserted; none can be derived from the repository at this baseline.
- Executed-test evidence cited is local developer evidence recorded in `docs/IMPLEMENTATION-TRACKER.md` and `artifacts/developer/verify-*/`; it is not conformance or certification evidence, and the tracker states this explicitly.
- Presence/absence claims ("no automated backup", "no metrics endpoint") derive from a repository inspection at the baseline commit; if additional mechanisms exist outside the repository, this assessment must be revised.

*End of KSPEC-007 - Draft, pending review. All PROPOSED items require explicit review and approval before becoming normative (KSPEC-000 §4, §5).*

# Kryptonian Verification and Validation Specification

| Field | Value |
|---|---|
| Document title | Verification and Validation Specification (VT-*) |
| Document ID | KSPEC-008 |
| Version | 0.2 (Draft) |
| Review status | Draft - pending review |
| Created | 2026-10-13 |
| Baseline repository commit | `682f996c8447afec13bc1fce5b7f59e6a06efa25` (branch `feat/windows-sandbox-installer`, "Release Windows gateway and portable enrollment demo 0.1.4") |
| Repository | https://github.com/AAPM-RT-SEC/RTSec.Kryptonian |
| Revision history | 0.1 - 2026-10-13 - Initial draft: V&V strategy and 58 initial verification tests (VT-001 - VT-058) traced to the KSPEC-003 register; AS-IS coverage snapshot and executed-evidence mapping from docs/IMPLEMENTATION-TRACKER.md (Author: V&V engineering team). |
| Source references | KSPEC-000 (conventions; §4 classification, §5 provenance, §11 methods); KSPEC-002 (UR-001 - UR-038); KSPEC-003 (canonical register, 154 SRs); KSPEC-004 (architecture); KSPEC-005 (ICD-*); KSPEC-006 (THR-001 - THR-018); KSPEC-007 (ORK-001 - ORK-016); docs/IMPLEMENTATION-TRACKER.md; docs/development.md; docs/DEPLOYMENT.md; tests/ (8 test projects); artifacts/developer/verify-*/evidence.json; .github/workflows/ |
| Author | Name: TBD - Date: TBD - Signature: TBD |
| Reviewer | Name: TBD - Date: TBD - Signature: TBD |
| Approver | Name: TBD - Date: TBD - Signature: TBD |
| Reconciliation revision | 0.2 - 2026-10-13 - source/document audit and publication controls (KSPEC-016) |

**Product classification (binding, KSPEC-000 §3).** Kryptonian is enterprise healthcare IT cybersecurity infrastructure: an EST (RFC 7030) certificate enrollment, identity provisioning, and credential lifecycle gateway. It is **not a regulated medical device** and performs no clinical functions. No verification activity, test result, or acceptance criterion in this document may be read as claiming FDA classification, IEC 62304 lifecycle classification, ISO 14971 hazard coverage, SDC conformity, an adopted EST profile, DICOM B.12/B.13 certification, or any other standards-conformance status. Verification verifies **device identity, enrollment authorization, network trust, and application-layer authorization only**; no gateway state derives clinical capability.

**Evidence discipline (binding, KSPEC-000 §5 and §13).** Every VT carries an **Evidence Status** field. Only tests whose outcome is recorded in `docs/IMPLEMENTATION-TRACKER.md` or in executed-evidence artifacts under `artifacts/developer/verify-*/` may be marked as executed, and then only with the exact statement the tracker records. All other VTs are marked **Proposed** and must never be presented as executed. No conformity claims are made or implied by any test passing.

# 1. Introduction

## 1.1 Purpose

This document defines how the RTSec.Kryptonian gateway is verified and validated, consistent with ISO/IEC/IEEE 29148 terminology and the KSPEC-000 conventions: it states the verification and validation objectives, the test environments, the test levels, and a test specification of verification tests (VT-nnn) traced to the canonical requirements register of KSPEC-003 (154 SR-* requirements), the threat register of KSPEC-006 (THR-nnn), and the operational risk register of KSPEC-007 (ORK-nnn).

## 1.2 Scope

Verification: "confirmation, through the provision of objective evidence, that specified requirements have been fulfilled" (ISO/IEC/IEEE 29148 usage; method codes T/I/A/D per KSPEC-000 §11). Validation: confirmation that the gateway, as verified, meets the stakeholder needs of KSPEC-002 (UR-001 - UR-038) in its intended, explicitly non-clinical operational context. This document covers the gateway (`RTSec.Kryptonian.{Api,Application,Domain,Infrastructure,Web,Ui}`) and the demonstration/reference clients (`Kryptonian.MedicalDevice`, `Kryptonian.DICOMTls`, `RTSec.Kryptonian.DimseTlsProxy`, `RTSec.Kryptonian.CaHarness`) - the latter verified as demonstration components only, never as product deliverables for production (KSPEC-000 §3).

## 1.3 Definitions

Defined terms follow KSPEC-000 §9 (device identity, certificate enrollment authorization, network trust, application-level authorization, clinical capability - out of scope -, profile, CA backend, connector, trust policy, enrollment event, CRL, renewal window, admin portal, DIMSE-TLS proxy). Additional terms:

| Term | Meaning |
|---|---|
| AS-IS test | An automated test present in `tests/` at the baseline commit. |
| Executed local evidence | A result recorded by the developer verifier and summarized in `docs/IMPLEMENTATION-TRACKER.md`, with artifacts under `artifacts/developer/verify-*/`. |
| Proposed test | A test specified in this document that has not been implemented or executed. |
| Test CA harness | The repository's stand-in CA backend (`RTSec.Kryptonian.CaHarness` and the self-signed/ACME connectors) used for repeatable local verification. |

# 2. Verification and validation objectives

VO-1 - **Protocol correctness.** Demonstrate that the device-facing EST surface behaves per KSPEC-005 ICD-EST.* and the RFC 7030 usage specified in KSPEC-003 (SR-F-EST area), without fallback behaviors that could silently enroll a device under the wrong policy (SR-F-EST.005, SR-F-INT.007).

VO-2 - **Enrollment authorization integrity.** Demonstrate that only approved device records can obtain credentials, that activation bootstrap secrets are single-use and replay-rejected, and that enrolled identities are bound to the pending registration (SR-F-REG, SR-F-CLM.001, SR-A.008).

VO-3 - **Credential lifecycle correctness.** Demonstrate approval-gated issuance, renewal within the renewal window with a fresh key and preserved identity, and revocation with issuer-scoped signed CRLs and fail-closed semantics (SR-F-CLM, SR-C, SR-X.001).

VO-4 - **Network trust enforcement.** Demonstrate TLS/mTLS peer authentication, client certificate validation (issuer, EKU/purpose, online revocation), and rejection of forwarded-certificate spoofing (SR-S.001/003/004, SR-F-EST.008/009, SR-C.007).

VO-5 - **Authentication and authorization.** Demonstrate the three-role RBAC model, dual-scheme administrator authentication, API-key claim binding, and the documented anonymous surface (SR-A, SR-Z).

VO-6 - **CA backend interoperability.** Demonstrate multi-backend configuration, test-before-activate routing, transparent protocol mapping, and honest failure reporting for each connector class; remote ADCS/EJBCA interoperability is explicitly **unverified** at baseline (SR-F-CAI).

VO-7 - **Data durability and recovery.** Demonstrate durable persistence across restart, UTC timestamp discipline, additive schema upgrades, and fail-safe behavior when the database is unavailable (SR-D, SR-V.003, SR-X.006, SR-R).

VO-8 - **Operational robustness.** Demonstrate rate-limit capacity, request size bounds, graceful shutdown, health/status reporting, and deployment acceptance for the supported packaging options (SR-P, SR-V, SR-B, SR-O).

VO-9 - **Security threat mitigation.** Provide test evidence against the KSPEC-006 threat register (THR-001 - THR-018) for the controls classified C (code) or V (verifiable), without overclaiming the boundary limitations recorded there.

VO-10 - **Operational risk control verification.** Provide test evidence for the KSPEC-007 risk controls (ORK-001 - ORK-016) that specify T-method verification, particularly the Critical-rated ORK-006, ORK-008, ORK-009, ORK-011, ORK-012, ORK-014, ORK-015.

VO-11 - **Validation against stakeholder needs.** Confirm through the UR → SR → VT chain (KSPEC-009) that each KSPEC-002 stakeholder need is either verified, partially verified, or recorded as an open item - never silently dropped.

VO-12 - **Honest boundary maintenance.** Verify the negative claims that bound the product: no clinical capability derivation (SR-Z.010), no competing enrollment protocol (SR-F-INT.007), demo components carry no clinical claims (SR-F-INT.006), and compatibility headers never become mandatory (SR-F-INT.002).

# 3. Verification and validation strategy

## 3.1 Method mix

Verification methods per KSPEC-000 §11: **T** = Test, **I** = Inspection, **A** = Analysis, **D** = Demonstration. Each SR's method is fixed by KSPEC-003 §21 and shall not be reclassified here. VTs realize T-method and D-method requirements; I/A-method requirements are verified by inspection/analysis records referenced from the VT evidence status where a VT exists for them.

## 3.2 Strategy principles

• **Live-boundary-first.** Baseline live checks exposed two defects that controller-mocked tests missed (Schannel rejection of ephemeral attached RSA keys; SQLite `DateTime.Kind` shifting refreshed CRL revocation times five hours on one host). Both were fixed with runnable regressions (tracker). Verification therefore requires at least one real-network-boundary exercise (real HTTPS listener, real mTLS handshake, real Schannel/X509Chain evaluation) per security-critical requirement area, per UR-036.

• **Test CA harness instead of hospital CAs.** Local verification uses the repository CA harness (self-signed in-process CA, ACME via Certes, `RTSec.Kryptonian.CaHarness` stand-in backend). Hospital ADCS/EJBCA interoperability remains a Proposed, separately-scheduled activity (VT-043); local results never imply hospital-CA interoperability.

• **Regression discipline.** Every defect found by verification yields a runnable regression test in the matching `tests/` project. CI (Windows GitHub runners) builds the UI, tests the solution, and builds the standalone proxy; high/critical UI dependency advisories fail the build (tracker).

• **Fail-closed orientation.** For every failure-injection test the expected result is rejection with a distinguishable error and **no** partial or intermediate trust state (SR-R.002, SR-X.001/002; KSPEC-007 fail-closed orientation).

• **No fabricated evidence.** A VT is marked executed only against recorded evidence (§6.1 evidence-status classes). Evidence artifacts are reproducible via the developer verifier (docs/development.md), never via screenshots.

• **Known skips.** Eighteen pre-existing Windows infrastructure test skips remain at baseline (tracker). Any VT whose environment depends on a skipped capability is marked Proposed and must record the skip dependency when implemented.

### 3.3 Pass/fail and traceability rules

A VT passes when every acceptance criterion in its record is met on the specified environment with the specified evidence class. Any deviation is recorded as a finding and feeds KSPEC-010 (gap analysis); a deviation on a Critical-priority SR blocks any review-approval recommendation for that SR (KSPEC-000 §8: approval is never inferred from implementation). KSPEC-009 consumes the VT → SR links of this document; VT IDs must not be redefined there or anywhere else (KSPEC-000 §7).

## 4. Test environment setup

### 4.1 Environments

#### E1

**Name:** Local developer system

**Description:** Windows developer host, .NET 8 SDK; `dotnet test` over the solution; loopback HTTPS listeners (distinct localhost admin/EST/CRL ports in sandbox mode); Windows Schannel and `X509Chain` for real OS-level PKI evaluation

**Used for:** Unit, integration, negative, concurrency, and the executed developer-verifier evidence (tracker)

#### E2

**Name:** Container environment

**Description:** `docker-compose*.yml` stack from `deploy/` (API container; PostgreSQL option per docs/DEPLOYMENT.md)

**Used for:** Deployment acceptance (VT-056), PostgreSQL parity (VT-052)

#### E3

**Name:** Test CA harness

**Description:** `RTSec.Kryptonian.CaHarness` stand-in CA + `SelfSignedEstCaConnector` (in-process CA with CRL generation) + `AcmeCaConnector`/challenge stores pointed at the loopback ACME challenge endpoint

**Used for:** EST conformance, enrollment, revocation, ACME tests without a hospital CA

#### E4

**Name:** CI

**Description:** Windows GitHub Actions (`.github/workflows/`): UI build, solution tests, standalone proxy build, UI `npm audit` high/critical gate

**Used for:** Regression gate (VT-058)

### 4.2 Test data and fixtures

• Test CA harness profile with subject-DN rules, key usage, validity, and trust policy per KSPEC-003 SR-C.001; synthetic device records (pending/active/untrusted/retired); one-time activation codes (valid, expired, already-consumed); CSRs (valid, malformed, oversize >64 KiB, wrong subject, disallowed key usage/EKU); an issuer-scoped CRL produced by the self-signed CA.

• Synthetic demo records remain distinguishable from real ones (SR-D.009); no real hospital or patient data is used in any environment. No clinical deployment and no external partner communication are involved in any verification activity.

### 4.3 Executed-evidence artifact structure

Executed local evidence is recorded under `artifacts/developer/verify-*/evidence.json`. The artifact recorded at baseline (run `verify-fa867498c35c4ca7bf58c0d4bc3acd21`, 2026-09-08 UTC) contains: `issuerFingerprint` (fingerprint of the issuing CA), `utc`, `deviceId`, `certificateId`, `revocationChecked: true`, `crlUrl`, and a `run` identifier [VERIFIED - file inspected]. The tracker additionally records the two received SOP Instance UIDs of the executed DICOM C-STORE transfers (`2.25.154518358314734480382348393848679450333` and `2.25.281306672341327719638925984637794989584`). Combined live-run evidence is local and ignored by Git; VTs citing it must instruct the reader to reproduce via the developer verifier rather than rely on a stored artifact or screenshot.

## 5. Test levels

### Unit

**Description:** Component-level tests of domain entities, services, crypto/PKCS, persistence, connectors
**Primary environments:** E1
**Example VTs:** VT-030, VT-041, VT-051

### Integration

**Description:** Gateway exercised through real HTTP/HTTPS listeners with the test CA harness, real authentication handlers, real persistence
**Primary environments:** E1, E3
**Example VTs:** VT-001 - VT-010, VT-021 - VT-027, VT-049

### EST protocol conformance

**Description:** RFC 7030 operation-by-operation checks against ICD-EST.*: cacerts, simpleenroll, simplereenroll, status codes, content types, profile-scoped paths
**Primary environments:** E1, E3
**Example VTs:** VT-001 - VT-013

### Security

**Description:** Threat-control tests mapped to THR-001 - THR-018: trust-policy gate, forwarding guard, secrets, CORS, revocation trust
**Primary environments:** E1, E3
**Example VTs:** VT-031 - VT-036, VT-046

### Authentication

**Description:** JWT/API-key/Basic schemes, 401 challenges, token validation, login non-enumeration
**Primary environments:** E1
**Example VTs:** VT-006, VT-037, VT-039

### Authorization

**Description:** RBAC role matrix over all mutating and read endpoints
**Primary environments:** E1
**Example VTs:** VT-038, VT-039

### CA interoperability

**Description:** Connector-level behavior per backend class; remote ADCS/EJBCA left explicitly unverified

**Primary environments:** E1, E3 (E2 for remote labs, proposed)
**Example VTs:** VT-040 - VT-043

### Certificate renewal

**Description:** Renewal-window authorization, fresh-key rotation, identity preservation, external credential renewal
**Primary environments:** E1
**Example VTs:** VT-022 - VT-024

### Revocation

**Description:** Issuer-scoped signed CRL publication, transactional persistence, online checking at peers, fail-closed unsupported backends
**Primary environments:** E1, E3
**Example VTs:** VT-025 - VT-028, VT-041

### DICOM TLS interoperability

**Description:** Demonstration-level mTLS DIMSE association, C-STORE transfer, SOP UID comparison, proxy trust lifecycle
**Primary environments:** E1
**Example VTs:** VT-046, VT-047

### Negative

**Description:** Malformed/oversized/wrongly-authenticated requests must be rejected with distinguishable errors and no state change
**Primary environments:** E1, E3
**Example VTs:** VT-020, VT-044

### Fault injection

**Description:** Backend failure, DB unavailability, invalid replacement credentials, watcher faults
**Primary environments:** E1, E3
**Example VTs:** VT-045, VT-046, VT-029

### Concurrency

**Description:** Simultaneous activation consumption, concurrent revocation conflicts
**Primary environments:** E1
**Example VTs:** VT-026, VT-048

### Performance

**Description:** Rate-limit capacity, request size bounds; latency targets remain TBD (SR-P.003)
**Primary environments:** E1
**Example VTs:** VT-055

### Database persistence

**Description:** Restart preservation, timestamp discipline, schema upgrades, provider parity
**Primary environments:** E1, E2
**Example VTs:** VT-049 - VT-052

### Recovery

**Description:** Backup/restore, graceful shutdown
**Primary environments:** E1, E2
**Example VTs:** VT-053, VT-054

### Deployment acceptance

**Description:** docker-compose stack, Windows service/sandbox modes, CI regression gate
**Primary environments:** E2, E1, E4
**Example VTs:** VT-056 - VT-058

# 6. Test specification

## 6.1 Evidence-status classes

| Status | Meaning |
|---|---|
| Covered - executed local evidence (VERIFIED) | The tracker records the exact result quoted in the VT; reproduce via the developer verifier (docs/development.md). |
| Covered - AS-IS automated test | A test exists in `tests/` at the baseline commit (assertions CODE-OBSERVED) and is executed by CI per the tracker; no separate live-run claim is made. |
| Partially covered | An AS-IS test or tracker evidence covers part of the VT; the remainder is Proposed. |
| Proposed | Specified here only; not implemented or executed. Never presented as executed. |

Each VT record uses the fields: Test ID, Linked requirements, Linked THR/ORK, Level, Preconditions, Test inputs, Procedure, Expected results, Acceptance criteria, Evidence status.

## 6.2 EST protocol conformance tests (VT-001 - VT-013)

### VT-001 - EST endpoint surface and profile-scoped paths

| Field | Value |
|---|---|
| Test ID | VT-001 |
| Linked requirements | SR-F-EST.001 |
| Linked THR/ORK | THR-002 |
| Level | Integration (EST conformance) |
| Preconditions | Gateway running on E1/E3 with a test profile labeled `test-profile` |
| Test inputs | HTTP(S) requests to `/.well-known/est/test-profile/cacerts`, `/simpleenroll`, `/simplereenroll` with correct methods |
| Procedure | 1. Request each EST operation under the profile-scoped path. 2. Repeat with a second configured profile. 3. Inspect routing for default-profile fallthrough. |
| Expected results | Each operation responds on every configured profile path; responses match ICD-EST.001. |
| Acceptance criteria | All documented operations reachable on all profiles; no operation silently rerouted to another profile. |
| Evidence status | Covered - AS-IS automated test: `tests/RTSec.Kryptonian.Api.Tests/Integration/EstRouteTests.cs` and `EstIntegrationTests.cs` (assertions CODE-OBSERVED; CI execution per tracker PR 40/49). |

### VT-002 - cacerts operation returns the profile trust set

| Field | Value |
|---|---|
| Test ID | VT-002 |
| Linked requirements | SR-F-EST.002 |
| Linked THR/ORK | THR-012 |
| Level | Integration (EST conformance) |
| Preconditions | Profile configured with one or more CA certificates (E3 harness CA) |
| Test inputs | `GET /.well-known/est/{label}/cacerts` |
| Procedure | 1. Issue GET. 2. Decode the PKCS#7 body. 3. Compare returned certificates with the profile trust set. |
| Expected results | Response contains exactly the profile's CA certificates in the ICD-EST.003 content type. |
| Acceptance criteria | Returned set equals configured set; content type correct. |
| Evidence status | Covered - AS-IS automated test: `tests/RTSec.Kryptonian.Api.Tests/Controllers/EstControllerTests.cs` (assertions CODE-OBSERVED). |

### VT-003 - CSR acceptance and 64 KiB limit

| Field | Value |
|---|---|
| Test ID | VT-003 |
| Linked requirements | SR-F-EST.003, SR-P.002 |
| Linked THR/ORK | THR-004, THR-013 |
| Level | Integration (negative boundary) |
| Preconditions | Approved, activated device record; bootstrap credentials available |
| Test inputs | Valid CSR; CSR of just over 64 KiB; empty body |
| Procedure | 1. POST valid CSR to `/simpleenroll` → expect enrollment success. 2. POST oversize CSR → expect rejection. 3. POST empty body → expect distinguishable error. |
| Expected results | Valid CSR accepted; oversize and empty rejected before CA contact. |
| Acceptance criteria | 64 KiB boundary enforced; enrollment events for rejected requests show no CA backend outcome. |
| Evidence status | Covered - AS-IS automated test: `EstControllerTests.cs` (limit CODE-OBSERVED); live-boundary oversize case Proposed. |

### VT-004 - Successful enrollment response format

| Field | Value |
|---|---|
| Test ID | VT-004 |
| Linked requirements | SR-F-EST.004 |
| Linked THR/ORK | THR-005 |
| Level | Integration (EST conformance) |
| Preconditions | Approved device; bootstrap or re-enroll credentials valid; E3 self-signed backend active |
| Test inputs | Valid CSR POST to `/simpleenroll` |
| Procedure | 1. POST CSR. 2. Inspect status, content type, and body. 3. Parse the returned certificate and compare subject/key usage/EKU/validity against the profile policy. |
| Expected results | HTTP 200 with the issued certificate in the PKCS#7 response format of ICD-EST.003; certificate matches profile policy. |
| Acceptance criteria | Issued certificate fields equal the profile policy bundle (SR-C.001); no private headers required (SR-F-INT.001). |
| Evidence status | Covered - AS-IS automated test: `EstControllerTests.cs`, `EstIntegrationTests.cs` (assertions CODE-OBSERVED); live-boundary curl case executed per tracker (see VT-046). |

### VT-005 - Unknown profile label rejected (404, no fallback)

| Field | Value |
|---|---|
| Test ID | VT-005 |
| Linked requirements | SR-F-EST.005 |
| Linked THR/ORK | THR-012 |
| Level | Integration (EST conformance / negative) |
| Preconditions | Gateway with profile `test-profile` configured |
| Test inputs | Requests to `/.well-known/est/unknown-label/...` and to a disabled profile |
| Procedure | 1. Request cacerts and simpleenroll under an unknown label. 2. Repeat with a disabled label. 3. Confirm no enrollment event is created for the known profile. |
| Expected results | HTTP 404 for unknown/disabled labels; no fallback to any default profile. |
| Acceptance criteria | No certificate issued; no cross-profile state change; distinguishable error per SR-F-EST.013. |
| Evidence status | Covered - AS-IS automated test: `EstRouteTests.cs` (PR 37 regression, CODE-OBSERVED); routing behavior VERIFIED per tracker ("Profile issuer routing and unknown-label rejection", PR 37). |

### VT-006 - Basic bootstrap authentication over TLS (401 challenge)

| Field | Value |
|---|---|
| Test ID | VT-006 |
| Linked requirements | SR-F-EST.006, SR-A.007 |
| Linked THR/ORK | THR-003; ORK-005 |
| Level | Integration (EST conformance / authentication) |
| Preconditions | Pending device with one-time activation code; HTTPS EST listener; no private headers |
| Test inputs | curl with HTTP Basic (activation credentials) over real HTTPS; same request over plain HTTP; request with wrong password; request without credentials |
| Procedure | 1. Enroll via independent curl over real HTTPS using standard Basic auth only. 2. Attempt plain HTTP. 3. Attempt unauthenticated/wrong-credential request. |
| Expected results | Step 1 succeeds with no private enrollment headers; step 3 yields HTTP 401 with challenge; plain HTTP refused (VT-010). |
| Acceptance criteria | Standard-client usability proven at the live boundary; 401 challenge present. |
| Evidence status | Covered - executed local evidence (VERIFIED): tracker records "Independent curl HTTP Basic EST over real HTTPS; no private enrollment headers." and PR 42 (standard Basic EST bootstrap). |

### VT-007 - Re-enroll requires a native TLS client certificate

| Field | Value |
|---|---|
| Test ID | VT-007 |
| Linked requirements | SR-F-EST.008, SR-A.008 |
| Linked THR/ORK | THR-006 |
| Level | Integration (EST conformance / renewal) |
| Preconditions | Device holds a previously issued certificate; renewal window behavior per profile (VT-024) |
| Test inputs | `POST /simplereenroll` with the valid client certificate; same request without a client certificate; with an untrusted client certificate |
| Procedure | 1. Re-enroll with the native TLS client certificate. 2. Repeat without it. 3. Repeat with an untrusted certificate. |
| Expected results | Step 1 succeeds; steps 2-3 rejected with distinguishable errors; activation codes are never accepted for re-enroll. |
| Acceptance criteria | Re-enroll authenticated solely by the TLS client certificate; rejected requests create denied-enrollment events. |
| Evidence status | Covered - executed local evidence (VERIFIED): tracker records "renewal uses a native TLS client certificate, generates a new key and preserves approved identity"; AS-IS tests: `EstEnrollmentClientRenewalTests.cs` (CODE-OBSERVED). |

### VT-008 - EST client-certificate validation (issuer, EKU, revocation)

| Field | Value |
|---|---|
| Test ID | VT-008 |
| Linked requirements | SR-F-EST.009 |
| Linked THR/ORK | THR-001; ORK-008 |
| Level | Integration (security) |
| Preconditions | EST listener with `ConfiguredClientCertificateTrust` over `Kryptonian:Tls:ClientCaFiles`; E3 CA with CRL published |
| Test inputs | Client certificate chains: issued by configured CA (valid); wrong issuer; wrong/missing TLS-client EKU; revoked |
| Procedure | 1. Handshake with each chain against the EST listener. 2. Attempt re-enroll with each. 3. Inspect rejection reasons and events. |
| Expected results | Only the valid chain is accepted; wrong-issuer, wrong-EKU, and revoked chains rejected. |
| Acceptance criteria | Issuer, purpose, and online revocation each independently enforced. |
| Evidence status | Covered - AS-IS automated test: `tests/RTSec.Kryptonian.Api.Tests/Authentication/ConfiguredClientCertificateTrustTests.cs` (CODE-OBSERVED); tracker records "Developer trust adds a separate issuer/hostname/purpose regression." |

### VT-009 - Pending enrollment: 202 + Retry-After

| Field | Value |
|---|---|
| Test ID | VT-009 |
| Linked requirements | SR-F-EST.010 |
| Linked THR/ORK | - |
| Level | Integration (EST conformance) |
| Preconditions | Device whose CA backend defers issuance (E3 harness pending mode) |
| Test inputs | `/simpleenroll` requests while issuance is deferred; a later request after issuance completes |
| Procedure | 1. POST CSR during deferral → observe 202. 2. Read `Retry-After`. 3. Repeat after the backend completes → observe final result. |
| Expected results | HTTP 202 with a valid `Retry-After` while pending; eventual success or distinguishable failure afterward. |
| Acceptance criteria | Pending response never fabricates success; Retry-After present and sane. |
| Evidence status | Covered - AS-IS automated test: `EstControllerTests.cs`; client behavior: `tests/Kryptonian.MedicalDevice.Enrollment.Tests/EstEnrollmentClientPendingTests.cs` (both CODE-OBSERVED). |

### VT-010 - Plain-HTTP EST refused (426); CRL-only HTTP listener

| Field | Value |
|---|---|
| Test ID | VT-010 |
| Linked requirements | SR-F-EST.012, SR-B.005 |
| Linked THR/ORK | THR-013 |
| Level | Integration (negative / deployment security) |
| Preconditions | Gateway with default listeners (plain-HTTP escape hatch disabled) |
| Test inputs | Plain-HTTP request to an EST path; to the CRL path; to an admin path |
| Procedure | 1. Send each request over plain HTTP. 2. Record status codes. 3. Repeat with `Kryptonian:Est:AllowPlainHttp` set and confirm the deviation is explicit and development-scoped. |
| Expected results | EST and admin paths refused over plain HTTP (HTTP 426 for EST); only CRL distribution is served over the HTTP listener. |
| Acceptance criteria | No credential-bearing exchange accepted unencrypted; deviation path documented and non-default. |
| Evidence status | Covered - executed local evidence (VERIFIED): tracker records "HTTP listener denies non-CRL requests"; AS-IS test: `EstRouteTests.cs` (CODE-OBSERVED). |

### VT-011 - Legacy compatibility headers remain optional

| Field | Value |
|---|---|
| Test ID | VT-011 |
| Linked requirements | SR-F-EST.007, SR-F-INT.002, SR-F-INT.007 |
| Linked THR/ORK | - |
| Level | Inspection + Demonstration |
| Preconditions | Gateway at baseline; sample device client with legacy activation headers |
| Test inputs | Enrollment with and without legacy headers; documentation audit of header naming |
| Procedure | 1. Enroll without legacy headers (standard path only) → succeeds. 2. Enroll with legacy headers (sample client) → succeeds for compatibility. 3. Inspect docs/spec for any statement making legacy headers mandatory. |
| Expected results | Legacy headers accepted for compatibility only; no requirement or interop claim depends on them. |
| Acceptance criteria | No spec text or enforced validation requires legacy headers (KSPEC-002 UR-019 boundary). |
| Evidence status | Partially covered - standard-path independence VERIFIED per tracker ("no private enrollment headers"); legacy-header compatibility inspection Proposed (SR-F-EST.007 status Partial). |

### VT-012 - Distinguishable error semantics and deterministic pending

| Field | Value |
|---|---|
| Test ID | VT-012 |
| Linked requirements | SR-F-EST.013, SR-F-EST.011 (Missing) |
| Linked THR/ORK | - |
| Level | Integration + Analysis |
| Preconditions | Matrix of invalid scenarios prepared (unknown profile, bad credentials, unauthorized renewal, issuer-mismatch CRL ops) |
| Test inputs | One request per invalid scenario class |
| Procedure | 1. Execute each scenario. 2. Record (status, error code, event reason). 3. Analyze pending semantics per backend type for determinism (SR-F-EST.011). |
| Expected results | Each scenario yields a distinct, diagnosable outcome; pending behavior deterministic per configured backend. |
| Acceptance criteria | Error taxonomy matches ICD-ERR.001; no two distinct failure classes share indistinguishable responses. |
| Evidence status | Proposed - SR-F-EST.011 is Missing at baseline; SR-F-EST.013 has Inspection-level support via existing error paths (CODE-OBSERVED) but no assertion test exists. |

### VT-013 - CSR attributes (`csrattrs`) endpoint

| Field | Value |
|---|---|
| Test ID | VT-013 |
| Linked requirements | SR-F-EST.014 (Missing) |
| Linked THR/ORK | THR-004 |
| Level | Integration (EST conformance) - TO-BE |
| Preconditions | TO-BE implementation of `/.well-known/est/{label}/csrattrs` exists |
| Test inputs | GET csrattrs; parse the attributes OID set |
| Procedure | 1. GET csrattrs. 2. Verify content type and encoding. 3. Verify advertised attributes match the profile's subject/EKU requirements. |
| Expected results | Correctly encoded attributes response consistent with the profile. |
| Acceptance criteria | Devices can construct conforming CSRs from csrattrs alone. |
| Evidence status | Proposed - requirement Missing at baseline (KSPEC-003 register). |

## 6.3 Device registration and identity tests (VT-014 - VT-020)

### VT-014 - Device registration and activation code issuance

| Field | Value |
|---|---|
| Test ID | VT-014 |
| Linked requirements | SR-F-REG.001, SR-F-REG.009, SR-F-REG.010, SR-F-REG.003 |
| Linked THR/ORK | THR-003 |
| Level | Integration + Demonstration |
| Preconditions | DeviceAdmin actor authenticated on E1/E3 |
| Test inputs | Administrative alias; device metadata (serial number); removal operation on an enrolled device |
| Procedure | 1. Register device by alias only → obtain one-time activation code. 2. Verify inventory entry (status, profile, identity metadata). 3. Enroll, then remove the device and inspect history retention. |
| Expected results | Registration needs no manual certificate identity entry; code issued; inventory and history correct. |
| Acceptance criteria | Device identity metadata preserved from CSR; removal retains history per SR-F-REG.010. |
| Evidence status | Covered - AS-IS automated test: `tests/RTSec.Kryptonian.Application.Tests/Services/DeviceServiceActivationTests.cs` (CODE-OBSERVED); admin portal demonstration per tracker's twenty device enrollment/lifecycle tests. |

### VT-015 - Activation code single-use and replay rejection

| Field | Value |
|---|---|
| Test ID | VT-015 |
| Linked requirements | SR-F-REG.002, SR-X.005 |
| Linked THR/ORK | THR-003, THR-006; ORK-005 |
| Level | Integration (negative / security) |
| Preconditions | Valid unused activation code captured for replay |
| Test inputs | First use of the code; replayed identical request; expired code; already-consumed code |
| Procedure | 1. Enroll with the code → success. 2. Replay the exact request → rejection. 3. Attempt expired/consumed codes → rejection. 4. Inspect code storage (hashed, bounded lifetime). |
| Expected results | Replay and reuse rejected with distinguishable errors; code consumed atomically on validated bootstrap acceptance before CA issuance. |
| Acceptance criteria | One-time semantics hold under replay and race (see VT-048); codes stored hashed. |
| Evidence status | Covered - executed local evidence (VERIFIED): tracker records "One-time activation replay rejected". AS-IS tests: `DeviceServiceActivationTests.cs`, `tests/RTSec.Kryptonian.Infrastructure.Tests/Data/DeviceActivationConcurrencyTests.cs` (CODE-OBSERVED). |

### VT-016 - Enrollment identity binding

| Field | Value |
|---|---|
| Test ID | VT-016 |
| Linked requirements | SR-F-REG.005 |
| Linked THR/ORK | THR-001 |
| Level | Integration (security) |
| Preconditions | Pending device registration with expected subject rules from the profile |
| Test inputs | CSR with CN matching the pending registration; CSR with a CN already registered; CSR without a serial number |
| Procedure | 1. Enroll with a matching, unique CN → success. 2. Enroll with a duplicate CN → rejection. 3. Enroll without required metadata → rejection. 4. Inspect the issued certificate subject against the pending record. |
| Expected results | Issued identity bound to the approved registration; duplicates and incomplete metadata rejected. |
| Acceptance criteria | No enrollment where the CSR identity diverges from the approved record (PR 38 behavior). |
| Evidence status | Covered - executed local evidence (VERIFIED): tracker records PR 38 "Authenticated enrollment identity binding"; AS-IS test: `DeviceServiceActivationTests.cs` (CODE-OBSERVED). |

### VT-017 - Self-service requests create pending records only

| Field | Value |
|---|---|
| Test ID | VT-017 |
| Linked requirements | SR-F-REG.006 |
| Linked THR/ORK | THR-002 |
| Level | Integration |
| Preconditions | Standard (non-DeviceAdmin) actor authenticated |
| Test inputs | Self-service device request via the permitted surface |
| Procedure | 1. Submit a self-service request. 2. Attempt enrollment against the resulting record before approval. |
| Expected results | Record created with pending status; enrollment denied until an administrator approves. |
| Acceptance criteria | No credential issues from a self-created record; approval gate interlocks (VT-021). |
| Evidence status | Covered - AS-IS automated test: `DeviceServiceActivationTests.cs` (pending-state assertions CODE-OBSERVED). |

### VT-018 - Trust removal blocks enrollment and renewal

| Field | Value |
|---|---|
| Test ID | VT-018 |
| Linked requirements | SR-F-REG.008 |
| Linked THR/ORK | THR-012; ORK-005 |
| Level | Integration (security) |
| Preconditions | Active enrolled device; DeviceAdmin actor |
| Test inputs | Trust-removal action; subsequent enroll and re-enroll attempts by the device |
| Procedure | 1. Remove trust for the device. 2. Attempt `simpleenroll` → rejection with recorded blocked event. 3. Attempt `simplereenroll` with the still-valid certificate → rejection. 4. Inspect the recorded event reason. |
| Expected results | All enrollment paths denied after trust removal; blocked event recorded with reason. |
| Acceptance criteria | No new credential issuance through any path after trust removal (UR-009). |
| Evidence status | Covered - AS-IS automated test: `tests/Kryptonian.MedicalDevice.Enrollment.Tests/GatewayTrustTests.cs` (CODE-OBSERVED). |

### VT-019 - Device status lifecycle transitions

| Field | Value |
|---|---|
| Test ID | VT-019 |
| Linked requirements | SR-F-REG.004 |
| Linked THR/ORK | - |
| Level | Integration |
| Preconditions | Device records in each lifecycle state (pending, active, untrusted, retired) |
| Test inputs | State-transition operations per KSPEC-004 §8.1 state machine |
| Procedure | 1. Exercise legal transitions. 2. Attempt illegal transitions. 3. Verify inventory reflects each state. |
| Expected results | Legal transitions succeed; illegal ones rejected with distinguishable errors. |
| Acceptance criteria | State machine conformance to KSPEC-004 §8.1. |
| Evidence status | Proposed - state-machine traversal test not present as a dedicated AS-IS test; partial coverage via `DeviceServiceActivationTests.cs` (CODE-OBSERVED). |

### VT-020 - Anonymous endpoint abuse controls (TO-BE)

| Field | Value |
|---|---|
| Test ID | VT-020 |
| Linked requirements | SR-F-REG.007 (Missing), SR-Z.008 |
| Linked THR/ORK | THR-013 |
| Level | Negative / performance - TO-BE |
| Preconditions | TO-BE abuse-control implementation (threshold TBD, SR-F-REG.007) |
| Test inputs | Sustained anonymous enrollment attempts above the configured threshold |
| Procedure | 1. Flood the anonymous endpoint. 2. Observe throttling/lockout behavior. 3. Verify legitimate traffic recovers. |
| Expected results | Abuse throttled per configured controls; documented anonymous surface unchanged (SR-Z.008). |
| Acceptance criteria | Threshold enforced; no bypass via header spoofing; event logging captures the abuse. |
| Evidence status | Proposed - SR-F-REG.007 is Missing at baseline. |

## 6.4 Certificate lifecycle tests (VT-021 - VT-030)

### VT-021 - Approval gates enrollment

| Field | Value |
|---|---|
| Test ID | VT-021 |
| Linked requirements | SR-F-CLM.001 |
| Linked THR/ORK | THR-002; ORK-004 |
| Level | Integration |
| Preconditions | Pending device record not yet approved; active E3 backend |
| Test inputs | Enrollment attempt before approval; after approval |
| Procedure | 1. Attempt enrollment before approval → denied. 2. Approve the device. 3. Repeat enrollment → success. |
| Expected results | Denial before approval; success after; each attempt recorded as an enrollment event (SR-C.010). |
| Acceptance criteria | No credential issued for any unapproved record. |
| Evidence status | Covered - AS-IS automated test: `tests/RTSec.Kryptonian.Application.Tests/Services/EnrollmentOrchestratorTests.cs` (CODE-OBSERVED). |

### VT-022 - Automatic renewal without re-approval

| Field | Value |
|---|---|
| Test ID | VT-022 |
| Linked requirements | SR-F-CLM.002, SR-C.004 |
| Linked THR/ORK | THR-011; ORK-001 |
| Level | Certificate renewal (live boundary) |
| Preconditions | Active device with certificate inside the renewal window; device simulator (E1) |
| Test inputs | Renewal request via `simplereenroll` within the window; renewal attempt outside the window |
| Procedure | 1. Trigger renewal in-window with the existing certificate → succeeds without administrator action. 2. Attempt out-of-window renewal → denied per profile policy. 3. Confirm no re-approval was required or recorded. |
| Expected results | In-window renewal succeeds unattended; out-of-window denied with distinguishable error. |
| Acceptance criteria | Renewal authorization derives from the existing approved identity only. |
| Evidence status | Covered - executed local evidence (VERIFIED): tracker records "Twenty device enrollment/lifecycle tests passed including actual Schannel mTLS with the public client's returned certificate"; renewal evidence "renewal uses a native TLS client certificate". AS-IS tests: `EstEnrollmentClientRenewalTests.cs` (CODE-OBSERVED). |

### VT-023 - Renewal issues a new key and preserves the approved identity

| Field | Value |
|---|---|
| Test ID | VT-023 |
| Linked requirements | SR-F-CLM.003, SR-A.008, SR-O.003 |
| Linked THR/ORK | THR-006; ORK-001, ORK-015 |
| Level | Certificate renewal (live boundary) |
| Preconditions | Device with an installed certificate and key material (Schannel store on E1) |
| Test inputs | Renewal cycle; comparison of old and new certificates |
| Procedure | 1. Renew. 2. Compare subject/SAN identity old vs. new. 3. Confirm the new certificate carries a newly generated key (old private key not reused). 4. Confirm the installed credential is replaced durably. |
| Expected results | Identity preserved; new key generated; installed credential replaced and persisted across app restart. |
| Acceptance criteria | Key generation fresh per renewal; identity fields unchanged; Windows key persistence regression holds. |
| Evidence status | Covered - executed local evidence (VERIFIED): tracker records renewal "generates a new key and preserves approved identity" and the Schannel key-persistence fix (PR 50) with a runnable regression (`InstalledCertificateRenewalTests.cs`, CODE-OBSERVED). |

### VT-024 - Renewal window authorization

| Field | Value |
|---|---|
| Test ID | VT-024 |
| Linked requirements | SR-C.004 |
| Linked THR/ORK | THR-011 |
| Level | Certificate renewal / unit |
| Preconditions | Profile with a defined renewal window; certificates at window edge |
| Test inputs | Re-enroll attempts at various times before expiry (inside, at boundary, outside) |
| Procedure | 1. Attempt re-enroll at each time point. 2. Compare authorization outcome with the profile's window definition. |
| Expected results | Authorized exactly within the window; outside denied. |
| Acceptance criteria | Boundary semantics deterministic; denied attempts recorded. |
| Evidence status | Covered - AS-IS automated test: `EstEnrollmentClientRenewalTests.cs` (window logic CODE-OBSERVED). |

### VT-025 - Revocation with issuer-scoped signed CRLs and CRL distribution points

| Field | Value |
|---|---|
| Test ID | VT-025 |
| Linked requirements | SR-F-CLM.007, SR-C.005, SR-C.006 |
| Linked THR/ORK | THR-010; ORK-008 |
| Level | Revocation (live boundary) |
| Preconditions | Two issuers (profile + developer trust) with issued certificates; DeviceAdmin actor |
| Test inputs | Revocation of a certificate under each issuer; CRL fetch per issuer |
| Procedure | 1. Revoke a certificate. 2. Fetch the issuer-scoped CRL from `api/crl/{fingerprint}.crl`. 3. Verify the signature, issuer scoping, and monotonic CRL number. 4. Verify CRL distribution points present on issued certificates. 5. Confirm the other issuer's CRL is unchanged. |
| Expected results | Signed issuer-scoped CRL contains only the target serial; CRL DP points at the issuer's CRL URL. |
| Acceptance criteria | Cross-issuer isolation; signature valid against the issuing CA; transactional state (VT-026). |
| Evidence status | Covered - executed local evidence (VERIFIED): tracker records "Administrator revocation followed by native online X509Chain reporting Revoked, independently of registry lookup and without flushing the system CRL cache."; AS-IS tests: `CertificateRevocationServiceTests.cs`, `IssuerCrlStatePersistenceTests.cs`, `PkcsServiceTests.cs` (CODE-OBSERVED). |

### VT-026 - Transactional revocation and concurrent-update conflicts

| Field | Value |
|---|---|
| Test ID | VT-026 |
| Linked requirements | SR-F-CLM.008, SR-R.004, SR-X.003 |
| Linked THR/ORK | THR-010; ORK-008 |
| Level | Revocation + concurrency |
| Preconditions | Revocable certificate; two concurrent actors (or interleaved operations) |
| Test inputs | Concurrent revocation and status-change operations; revocation against a certificate from a rotated CA |
| Procedure | 1. Issue concurrent conflicting revocation/status updates. 2. Verify the loser receives HTTP 409 and no overwrite occurs. 3. Repeat revocation after CA rotation → 409 per SR-X.003. |
| Expected results | Atomic persistence; 409 on conflicts; certificate status never un-revoked by a losing writer. |
| Acceptance criteria | No partial trust state after any conflict; issuer-mismatch guard returns 409. |
| Evidence status | Covered - AS-IS automated test: `CertificateRevocationServiceTests.cs` (transactional and conflict paths CODE-OBSERVED); `UnitOfWork.cs` conflict handling CODE-OBSERVED. |

### VT-027 - Revoked devices denied renewal

| Field | Value |
|---|---|
| Test ID | VT-027 |
| Linked requirements | SR-F-CLM.009 |
| Linked THR/ORK | THR-010 |
| Level | Revocation / renewal (negative) |
| Preconditions | Revoked device still holding its (now revoked) certificate |
| Test inputs | `simplereenroll` with the revoked certificate |
| Procedure | 1. Attempt re-enroll with the revoked certificate. 2. Inspect the denial reason and event. |
| Expected results | Renewal denied with a revocation-specific reason. |
| Acceptance criteria | Revocation state takes precedence over renewal authorization. |
| Evidence status | Covered - AS-IS automated test: `CertificateRevocationServiceTests.cs` (CODE-OBSERVED); revocation-online enforcement at peers VERIFIED per tracker (see VT-028). |

### VT-028 - Online revocation checking at TLS peers

| Field | Value |
|---|---|
| Test ID | VT-028 |
| Linked requirements | SR-C.007 |
| Linked THR/ORK | THR-010; ORK-008 |
| Level | DICOM TLS interoperability / revocation (live boundary) |
| Preconditions | Gateway and demonstration DICOM peers configured with issuer trust and CRL URL; CRL served over the HTTP listener |
| Test inputs | Peer handshakes before and after administrator revocation |
| Procedure | 1. Establish mTLS association → succeeds. 2. Administrator revokes the peer certificate. 3. Re-attempt the handshake with online checking enabled, without flushing the system CRL cache. |
| Expected results | Pre-revocation succeeds; post-revocation fails with a native X509Chain `Revoked` status. |
| Acceptance criteria | Revocation observed through OS chain evaluation, independent of any gateway-side registry lookup. |
| Evidence status | Covered - executed local evidence (VERIFIED): tracker records "Administrator revocation followed by native online X509Chain reporting Revoked, independently of registry lookup and without flushing the system CRL cache." and "Both peers enforce issuer, TLS purpose and online revocation." |

### VT-029 - Expiry visibility, automated scan, notification, and watcher fault tolerance

| Field | Value |
|---|---|
| Test ID | VT-029 |
| Linked requirements | SR-F-CLM.004, SR-F-CLM.005, SR-F-CLM.006, SR-R.001, SR-R.003 |
| Linked THR/ORK | THR-011; ORK-001, ORK-007, ORK-014 |
| Level | Unit + integration (fault injection) |
| Preconditions | Certificates at varying expiry distances; SMTP settings configured (or stubbed sender) |
| Test inputs | Expiry scan cycles; a scan that throws mid-cycle; certificates approaching/missing renewal |
| Procedure | 1. Run `CertificateExpiryWatcher` scan → notifications queued for at-risk certificates. 2. Inject an exception in `ScanOnceAsync` → watcher logs and continues the loop. 3. Verify `LastExpiryNotifiedAt` prevents duplicate alerts and notification failure does not corrupt lifecycle state. |
| Expected results | Alerts for approaching/non-renewed certificates; watcher survives faults; state unchanged on notification failure. |
| Acceptance criteria | Non-renewal alert generated per UR-012; no crash-loop; no state corruption. |
| Evidence status | Partially covered - AS-IS automated test: `NotificationDispatcherTests.cs` (CODE-OBSERVED); watcher fault-tolerance and end-to-end email delivery Proposed (tracker records delivery behavior at baseline as unexercised). |

### VT-030 - Profile policy bundle enforcement (unit)

| Field | Value |
|---|---|
| Test ID | VT-030 |
| Linked requirements | SR-C.001, SR-C.003 |
| Linked THR/ORK | THR-004, THR-005; ORK-004 |
| Level | Unit |
| Preconditions | Profile fixtures with differing subject-DN rules, key usage, EKU, validity |
| Test inputs | CSRs and CA responses matching and violating each policy element |
| Procedure | 1. Run CSR/returned-certificate policy evaluation per fixture. 2. Assert accept/reject per element. 3. Verify partial profile updates preserve omitted trust lists (PR 47). |
| Expected results | Every policy element independently enforced on both CSR acceptance and returned-certificate validation. |
| Acceptance criteria | No mis-issued credential accepted by policy validation; partial update preserves trust lists. |
| Evidence status | Covered - AS-IS automated test: `tests/RTSec.Kryptonian.Application.Tests/Services/EnrollmentCertificatePolicyTests.cs` and `EstProfilePartialUpdateTests.cs` (CODE-OBSERVED). |

## 6.5 Security, authentication, and authorization tests (VT-031 - VT-039)

### VT-031 - Transport security for credential-bearing exchanges (incl. CORS)

| Field | Value |
|---|---|
| Test ID | VT-031 |
| Linked requirements | SR-S.001, SR-S.013 |
| Linked THR/ORK | THR-003, THR-016 |
| Level | Integration (security) |
| Preconditions | Gateway with default HTTPS redirection and CORS policy `KryptonianUi` |
| Test inputs | Credential-bearing requests over plain HTTP; CORS preflight from a disallowed origin; from an allowed origin |
| Procedure | 1. Attempt credential submission over plain HTTP → refused (VT-010). 2. CORS preflight from a disallowed origin → no `KryptonianUi` grant. 3. Allowed origin → permitted. |
| Expected results | No credential accepted unencrypted; CORS restricted to configured origins. |
| Acceptance criteria | Transport security holds for EST, admin API, and notification-credential surfaces. |
| Evidence status | Partially covered - HTTPS-only EST VERIFIED per tracker (see VT-010); CORS assertions Proposed (no dedicated AS-IS test observed). |

### VT-032 - CSR and returned-certificate policy enforcement (live boundary)

| Field | Value |
|---|---|
| Test ID | VT-032 |
| Linked requirements | SR-S.002 |
| Linked THR/ORK | THR-004, THR-005 |
| Level | Security (live boundary) |
| Preconditions | Approved device; E3 backend; profile policy bundle active |
| Test inputs | CSR spoofing subject-DN / key usage / EKU / validity; a compromised backend response with a non-conforming certificate |
| Procedure | 1. Submit policy-violating CSRs → rejected before CA contact. 2. Force a backend response violating the profile → rejected before delivery to the device. |
| Expected results | Both directions enforced: inbound CSR and outbound issued certificate. |
| Acceptance criteria | No policy-violating credential ever delivered to a device (PR 43 behavior). |
| Evidence status | Covered - AS-IS automated test: `EnrollmentCertificatePolicyTests.cs` (CODE-OBSERVED); PR 43 ("CSR and returned-certificate policy enforcement") per tracker. |

### VT-033 - Gateway-owned trust-policy gate and durability

| Field | Value |
|---|---|
| Test ID | VT-033 |
| Linked requirements | SR-S.003, SR-C.002 |
| Linked THR/ORK | THR-012; ORK-005 |
| Level | Integration (security) |
| Preconditions | Profile with persisted trust policy; DeviceAdmin actor |
| Test inputs | Enrollment from an untrusted device; trust-policy updates (additive); gateway restart |
| Procedure | 1. Attempt enrollment from a device outside the trust policy → rejected at the gateway, before CA contact. 2. Apply an additive trust update (PR 41/47). 3. Restart the gateway on populated SQLite and re-check the policy. |
| Expected results | Gateway enforces its own trust gate; trust policy survives restart unchanged. |
| Acceptance criteria | Trust decision never delegated to the CA backend; durable trust per SR-C.002. |
| Evidence status | Covered - executed local evidence (VERIFIED): tracker records "Gateway restart on populated SQLite preserved configured profile, issuer and devices."; AS-IS tests: `EstProfilePersistenceTests.cs`, `EstProfilePartialUpdateTests.cs` (CODE-OBSERVED). |

### VT-034 - Forwarded-certificate guard and authenticated forwarder identity

| Field | Value |
|---|---|
| Test ID | VT-034 |
| Linked requirements | SR-S.004, SR-S.005 (Missing) |
| Linked THR/ORK | THR-017 |
| Level | Security (negative) |
| Preconditions | Gateway with the XFCC forwarding middleware and known-proxy configuration |
| Test inputs | Directly forwarded `X-Forwarded-Client-Cert` from a non-proxy source; duplicate/dual-identity headers; untrusted `X-Device-Id`; spoofed `X-Forwarded-For` |
| Procedure | 1. Send a spoofed forwarded certificate directly to the EST endpoint → rejected. 2. Send duplicate/dual-identity combinations → rejected. 3. Analyze (TO-BE) the authenticated-forwarder design gap of SR-S.005. |
| Expected results | Spoofed forwarded identities rejected; only trusted-proxy-forwarded identities honored. |
| Acceptance criteria | No spoofed identity reaches enrollment logic; proxy-trust boundary limitation recorded (source-IP trust, SR-S.005). |
| Evidence status | Partially covered - executed local evidence (VERIFIED): tracker records "Direct forwarded-certificate spoof rejected"; AS-IS test: `tests/RTSec.Kryptonian.Api.Tests/Middleware/CertificateForwardingGuardTests.cs` (CODE-OBSERVED); SR-S.005 (authenticated forwarder) Missing → that portion Proposed. |

### VT-035 - JWT signing secret provisioning (TO-BE)

| Field | Value |
|---|---|
| Test ID | VT-035 |
| Linked requirements | SR-S.007 (Missing), SR-A.006 (Missing) |
| Linked THR/ORK | THR-007, THR-009, THR-016 |
| Level | Security (negative) - TO-BE |
| Preconditions | TO-BE fail-closed secret provisioning implemented |
| Test inputs | Startup without a provisioned JWT secret (production mode); with a below-threshold secret; with a provisioned secret |
| Procedure | 1. Start without secret in Production → startup fails closed. 2. Start with weak secret → rejected (≥32-character rule pending confirmation, SR-A.006). 3. Start with valid secret → normal operation. |
| Expected results | No hard-coded fallback ever used outside explicit development confinement (SR-A.009). |
| Acceptance criteria | Production boot refuses weak/absent signing secrets. |
| Evidence status | Proposed - SR-S.007/SR-A.006 Missing at baseline (hard-coded dev fallback recorded as a weak control in KSPEC-003 §22). |

### VT-036 - Password hashing strength

| Field | Value |
|---|---|
| Test ID | VT-036 |
| Linked requirements | SR-S.009 |
| Linked THR/ORK | THR-009 |
| Level | Inspection |
| Preconditions | Source access to user-credential handling |
| Test inputs | Inspection checklist: hash algorithm, work factor, salt handling |
| Procedure | 1. Inspect password storage and verification code paths. 2. Confirm BCrypt with work factor ≥ 12. 3. Confirm no plaintext or reversible storage. |
| Expected results | BCrypt ≥ 12 everywhere passwords are stored. |
| Acceptance criteria | Inspection record completed with file/line citations. |
| Evidence status | Proposed - Inspection-method requirement; no automated test applicable. (Code path CODE-OBSERVED in `UsersController.cs`/auth services per KSPEC-003 evidence.) |

### VT-037 - Administrator authentication schemes and token validation

| Field | Value |
|---|---|
| Test ID | VT-037 |
| Linked requirements | SR-A.001, SR-A.002, SR-A.010, SR-F-ADM.003 |
| Linked THR/ORK | THR-007, THR-009 |
| Level | Authentication |
| Preconditions | Seeded SystemAdmin (SR-F-ADM.005 bootstrap); API key issued |
| Test inputs | Login with valid/invalid credentials; JWT with valid/expired/tampered signature; deactivated user's token; login attempts for existent/non-existent users |
| Procedure | 1. Authenticate via password → JWT issued. 2. Authenticate via API key → honored. 3. Replay expired/tampered tokens → 401. 4. Use a deactivated user's token → 401 (lockout). 5. Compare error responses for existent vs. non-existent users (non-enumeration). |
| Expected results | Only valid fresh credentials authenticate; deactivated users locked out; no user enumeration. |
| Acceptance criteria | Dual-scheme behavior per SR-A.001; validation failures distinguishable from authorization failures. |
| Evidence status | Partially covered - admin-setup behavior is documented; device lifecycle tests do not establish user-management or JWT coverage (DOCUMENTED only); dedicated token-validation tests Proposed (no dedicated AS-IS test file observed under `tests/RTSec.Kryptonian.Api.Tests/Authentication/`). |

### VT-038 - Role-based authorization enforcement

| Field | Value |
|---|---|
| Test ID | VT-038 |
| Linked requirements | SR-Z.001, SR-Z.002, SR-Z.003, SR-Z.004, SR-Z.005, SR-Z.010 |
| Linked THR/ORK | THR-007 |
| Level | Authorization |
| Preconditions | One actor per role (Standard, DeviceAdmin, SystemAdmin) |
| Test inputs | Full endpoint matrix: device mutations, system configuration, revocation, read-only queries, per role |
| Procedure | 1. Execute each endpoint × role combination. 2. Record allow/deny. 3. Verify no role gains clinical-capability statements from device state (SR-Z.010). |
| Expected results | Device ops restricted to DeviceAdmin+; system config to SystemAdmin; read-only for Standard; revocation DeviceAdmin+. |
| Acceptance criteria | Zero unauthorized successes in the matrix. |
| Evidence status | Covered - AS-IS automated tests: `tests/RTSec.Kryptonian.Api.Tests/Controllers/DevicesControllerAuthorizationTests.cs`, `CertificateRevocationControllerAuthorizationTests.cs` (CODE-OBSERVED). |

### VT-039 - API-key authentication and claims binding

| Field | Value |
|---|---|
| Test ID | VT-039 |
| Linked requirements | SR-A.003, SR-A.004, SR-A.005, SR-Z.006, SR-F-ADM.004, UR-027 |
| Linked THR/ORK | THR-007 |
| Level | Authentication / authorization |
| Preconditions | Users of differing roles; API-key management endpoint available |
| Test inputs | Created/revoked API keys; key of a deactivated user; key used after role change |
| Procedure | 1. Create a key for a role → authenticate → role claims honored. 2. Revoke the key → 401. 3. Deactivate the owning user → key stops working. 4. Change the user's role → existing key retains generation-time role (SR-A.005) and claims come only from the stored record (SR-Z.006). |
| Expected results | Keys hashed at rest; lifecycle-bound to owner; claims never spoofable via headers. |
| Acceptance criteria | All key lifecycle transitions enforced; static compatibility keys limited per SR-A.004. |
| Evidence status | Proposed - behavior CODE-OBSERVED in `ApiKeyAuthenticationHandler.cs` per KSPEC-003 evidence, but no dedicated AS-IS test file observed; assertion set Proposed. |

## 6.6 CA interoperability tests (VT-040 - VT-043)

### VT-040 - Multi-backend configuration, test-before-activate, profile-bound routing

| Field | Value |
|---|---|
| Test ID | VT-040 |
| Linked requirements | SR-F-CAI.001, SR-F-CAI.002, SR-F-CAI.004 |
| Linked THR/ORK | ORK-003, ORK-010 |
| Level | Integration + Analysis |
| Preconditions | Two configured backends (E3 self-signed + harness) |
| Test inputs | Backend test invocation; activation of exactly one backend; device enrollment without backend identifier |
| Procedure | 1. Configure backends via admin API/portal. 2. Run the backend test → result reported before activation. 3. Activate one backend; enroll a device without sending a backend identifier. 4. Verify transparent protocol mapping (SR-F-CAI.004, Analysis). |
| Expected results | Test results reported pre-activation; enrollments and cacerts route to their profile-bound enabled backend, even when a different backend is globally active, with no device-side backend knowledge. |
| Acceptance criteria | Exactly one active backend effective; device requests carry no backend identity. |
| Evidence status | Covered - AS-IS automated test: `tests/RTSec.Kryptonian.Application.Tests/Services/CaBackendServiceTests.cs` (CODE-OBSERVED). |

### VT-041 - Self-signed CA: issuance, CRL generation, material persistence, fail-closed unsupported revocation

| Field | Value |
|---|---|
| Test ID | VT-041 |
| Linked requirements | SR-F-CAI.008, SR-F-CAI.009, SR-X.001 |
| Linked THR/ORK | THR-008; ORK-008 |
| Level | Unit + revocation |
| Preconditions | Self-signed backend configured; certificates issued by it |
| Test inputs | Issuance requests; CRL generation; revocation request against a backend without CRL capability |
| Procedure | 1. Issue a certificate via the self-signed connector. 2. Generate and verify its CRL. 3. Persist CA material and reload. 4. Call revocation on a backend without CRL generation → expect explicit not-implemented error and unchanged certificate status. |
| Expected results | Issuance/CRL/persistence work; unsupported revocation fails closed (no false success). |
| Acceptance criteria | Certificate status unchanged after failed revocation; error distinguishable (HTTP 501 per SR-X.001). |
| Evidence status | Covered - AS-IS automated tests: `tests/RTSec.Kryptonian.Infrastructure.Tests/Crypto/SelfSignedCaConnectorTests.cs`, `CertificateRevocationServiceTests.cs` (fail-closed path CODE-OBSERVED); live revocation per tracker (VT-025). |

### VT-042 - ACME enrollment and functional challenge set

| Field | Value |
|---|---|
| Test ID | VT-042 |
| Linked requirements | SR-F-CAI.007 |
| Linked THR/ORK | THR-005 |
| Level | Integration |
| Preconditions | ACME backend configuration against a loopback ACME endpoint (E3); external account binding configured |
| Test inputs | http-01 challenge flow; dns-01 (stub at baseline); an unimplemented challenge type in configuration |
| Procedure | 1. Complete an http-01 enrollment via the challenge store/`WellKnownServers`. 2. Attempt dns-01 → observe stub behavior (KSPEC-004 Dns01ChallengeStub). 3. Configure an unimplemented challenge type → rejected at configuration time. |
| Expected results | http-01 functional; unimplemented challenge types rejected at configuration rather than failing at issuance. |
| Acceptance criteria | No silent issuance failure for unsupported challenges; external account binding exercised. |
| Evidence status | Covered - AS-IS automated tests: `tests/RTSec.Kryptonian.Infrastructure.Tests/Acme/AcmeCaConnectorTests.cs`, `Http01ChallengeStoreTests.cs`, `AcmeConnectorConfigTests.cs`, `WellKnownServersTests.cs` (CODE-OBSERVED); dns-01 remains Partial (SR-F-CAI.007). |

### VT-043 - ADCS/EJBCA hospital interoperability (unverified at baseline)

| Field | Value |
|---|---|
| Test ID | VT-043 |
| Linked requirements | SR-F-CAI.005, SR-F-CAI.006, SR-F-CAI.003 |
| Linked THR/ORK | THR-005, THR-008; ORK-003, ORK-008 |
| Level | CA interoperability (external lab) |
| Preconditions | ADCS lab per docs/adcs-real-backend-demo.md (Windows Server + NDES) or EJBCA instance; configurable SCEP endpoints |
| Test inputs | Real enrollment via SCEP/NDES; real revocation via EJBCA REST; misconfigured issuer-DN revocation |
| Procedure | 1. Enroll through real ADCS/NDES with configurable endpoints. 2. Revoke through real EJBCA; verify failure reported honestly when the issuer DN is unconfigured. 3. Compare against docs/adcs-real-backend-demo.md connector gaps 1-5. |
| Expected results | Enrollment/revocation interoperable with real hospital CA classes, or the gap documented honestly. |
| Acceptance criteria | No false success; configurable (not hard-coded) endpoints. |
| Evidence status | Proposed - tracker records "actual ADCS/EJBCA hospital enrollment/revocation interoperability remains unverified"; connector code CODE-OBSERVED (`AdcsCaConnector.cs`, `EjbcaCaConnector.cs`, `ScepClient.cs`). |

## 6.7 Negative, fault-injection, and concurrency tests (VT-044 - VT-048)

### VT-044 - EST negative request matrix

| Field | Value |
|---|---|
| Test ID | VT-044 |
| Linked requirements | SR-F-EST.003, SR-F-EST.004, SR-F-EST.013, SR-P.002 |
| Linked THR/ORK | THR-004, THR-013 |
| Level | Negative |
| Preconditions | Gateway running; valid baseline request captured |
| Test inputs | Malformed CSR; wrong content type; unknown HTTP method; oversized body; missing auth; duplicated headers |
| Procedure | 1. Send each mutation of the baseline request. 2. Record (status, error, events). 3. Confirm no state change for any rejection. |
| Expected results | Every mutation rejected with a distinguishable error; no partial state. |
| Acceptance criteria | Zero enrollments created by negative inputs; error classes match ICD-ERR.001. |
| Evidence status | Partially covered - `EstControllerTests.cs`/`EstRouteTests.cs` cover core rejections (CODE-OBSERVED); the full mutation matrix Proposed. |

### VT-045 - CA backend failure outcome recording

| Field | Value |
|---|---|
| Test ID | VT-045 |
| Linked requirements | SR-R.002, SR-F-CAI.004 |
| Linked THR/ORK | ORK-003 |
| Level | Fault injection |
| Preconditions | Active backend replaced by an unreachable/failing stub |
| Test inputs | Enrollment while backend is down / returns errors |
| Procedure | 1. Make the active backend unavailable. 2. Enroll → observe device-visible error. 3. Inspect enrollment events for the recorded failure outcome. 4. Restore backend → next enrollment succeeds. |
| Expected results | Distinguishable "backend down" outcome to device and events; no partial trust state; recovery without operator cleanup. |
| Acceptance criteria | Error class differs from authorization rejections; no orphaned state. |
| Evidence status | Covered - AS-IS automated test: `EnrollmentOrchestratorTests.cs` (error paths CODE-OBSERVED). |

### VT-046 - Invalid replacement credentials fail closed; proxy client rejection

| Field | Value |
|---|---|
| Test ID | VT-046 |
| Linked requirements | SR-X.002 |
| Linked THR/ORK | THR-008, THR-012; ORK-015 |
| Level | DICOM TLS interoperability / fault injection (live boundary) |
| Preconditions | DIMSE-TLS proxy running with a valid PFX; loopback clients (E1) |
| Test inputs | Client certificates unknown to the issuer / expired / revoked; externally replaced PFX that is expired |
| Procedure | 1. Connect clients with unknown, expired, and revoked certificates → each rejected. 2. Replace the proxy PFX with an expired credential → new handshakes must fail closed; no fallback to the stale credential. |
| Expected results | All invalid credentials rejected; invalid replacement never kept as fallback. |
| Acceptance criteria | Fail-closed on every invalid credential class. |
| Evidence status | Covered - executed local evidence (VERIFIED): tracker records "Five loopback proxy tests passed, including unknown/expired/revoked client rejection and fresh handshakes observing atomic PFX replacement; expired replacement fails closed."; AS-IS tests: `DimseTlsProxyWorkerTests.cs`, `ServerCertificateRotationTests.cs` (CODE-OBSERVED). |

### VT-047 - DICOM mTLS C-STORE with SOP Instance UID comparison

| Field | Value |
|---|---|
| Test ID | VT-047 |
| Linked requirements | SR-F-INT.005, SR-C.007 |
| Linked THR/ORK | THR-001; ORK-002 |
| Level | DICOM TLS interoperability (live boundary) |
| Preconditions | Both DICOM peers with issued certificates, issuer trust, TLS purpose, online revocation enabled |
| Test inputs | Two DIMSE associations with C-STORE transfers of DICOM objects |
| Procedure | 1. Perform two actual mTLS C-STORE transfers. 2. Reopen the received files. 3. Compare received SOP Instance UIDs against the sent objects. 4. Record the UIDs and issuer fingerprint in evidence.json. |
| Expected results | Both transfers complete; received-file SOP UIDs match sent UIDs exactly. |
| Acceptance criteria | Both peers enforce issuer, TLS purpose, and online revocation; UID comparison non-empty and exact. |
| Evidence status | Covered - executed local evidence (VERIFIED): tracker records "Two actual mutual-TLS DICOM C-STORE transfers followed by received-file reopen and SOP Instance UID comparison. Both peers enforce issuer, TLS purpose and online revocation." with SOP UIDs `2.25.154518358314734480382348393848679450333` and `2.25.281306672341327719638925984637794989584`; parser unit test `tests/RTSec.Kryptonian.Bridge.Tests/DicomWebMultipartParserTests.cs`. |

### VT-048 - Concurrent activation code consumption race

| Field | Value |
|---|---|
| Test ID | VT-048 |
| Linked requirements | SR-F-REG.002, SR-R.004 |
| Linked THR/ORK | THR-003, THR-006; ORK-005 |
| Level | Concurrency |
| Preconditions | Single valid activation code |
| Test inputs | Parallel enrollment attempts using the same code |
| Procedure | 1. Launch N concurrent enrollments with the same code. 2. Count successes. 3. Verify exactly one success and N-1 distinguishable failures; check persisted state. |
| Expected results | Exactly one consumption; no duplicate credential issuance for one code. |
| Acceptance criteria | Atomic one-time consumption under race; losers rejected cleanly. |
| Evidence status | Covered - AS-IS automated test: `tests/RTSec.Kryptonian.Infrastructure.Tests/Data/DeviceActivationConcurrencyTests.cs` (CODE-OBSERVED); replay rejection VERIFIED per tracker (VT-015). |

## 6.8 Data, persistence, and recovery tests (VT-049 - VT-054)

### VT-049 - Gateway restart preserves state (SQLite)

| Field | Value |
|---|---|
| Test ID | VT-049 |
| Linked requirements | SR-D.001, SR-V.003 |
| Linked THR/ORK | ORK-006, ORK-012 |
| Level | Database persistence |
| Preconditions | Gateway on E1 with populated SQLite: profile, issuer state, devices, enrollment events |
| Test inputs | Graceful stop; restart; post-restart API queries |
| Procedure | 1. Populate all state types. 2. Stop the gateway. 3. Restart. 4. Query profile, issuer, devices, events. 5. Enroll again to confirm operational continuity. |
| Expected results | Configured profile, issuer, and devices preserved exactly; new enrollments work. |
| Acceptance criteria | No configuration loss across restart (UR-037). |
| Evidence status | Covered - executed local evidence (VERIFIED): tracker records "Gateway restart on populated SQLite preserved configured profile, issuer and devices." |

### VT-050 - UTC timestamp discipline

| Field | Value |
|---|---|
| Test ID | VT-050 |
| Linked requirements | SR-D.005 |
| Linked THR/ORK | ORK-009 |
| Level | Database persistence (regression) |
| Preconditions | SQLite persistence; CRL refresh path exercised on a host with non-UTC local time |
| Test inputs | CRL refresh with `DateTimeKind` unspecified vs. UTC |
| Procedure | 1. Refresh an issuer CRL. 2. Compare stored revocation times with UTC wall-clock. 3. Run the baseline regression covering the SQLite DateTime-kind defect. |
| Expected results | All persisted timestamps UTC-stable; no timezone drift. |
| Acceptance criteria | Regression test reproduces the historical five-hour shift when the fix is absent and passes with it. |
| Evidence status | Covered - executed local evidence (VERIFIED): tracker records "SQLite's unspecified DateTime kind shifted refreshed CRL revocation times five hours into the future on this host ... fixed with runnable regressions." |

### VT-051 - Additive schema upgrades

| Field | Value |
|---|---|
| Test ID | VT-051 |
| Linked requirements | SR-D.003 |
| Linked THR/ORK | ORK-011 |
| Level | Database persistence (unit) |
| Preconditions | Database at the prior schema version containing data |
| Test inputs | Schema-upgrade runner over a populated database |
| Procedure | 1. Create a database at the previous schema with representative rows. 2. Run the upgrade. 3. Verify data preserved and new schema objects present. 4. Run the application against the upgraded database. |
| Expected results | Upgrades are additive; existing rows survive. |
| Acceptance criteria | No destructive migration without the TO-BE upgrade safety boundary (SR-D.004, Missing). |
| Evidence status | Covered - AS-IS automated test: `tests/RTSec.Kryptonian.Infrastructure.Tests/Data/SchemaUpgradesTests.cs` (CODE-OBSERVED). |

### VT-052 - PostgreSQL provider parity

| Field | Value |
|---|---|
| Test ID | VT-052 |
| Linked requirements | SR-D.002, UR-037 |
| Linked THR/ORK | ORK-006, ORK-012 |
| Level | Database persistence |
| Preconditions | E2 with PostgreSQL (Npgsql provider) |
| Test inputs | Full lifecycle scenario suite against the PostgreSQL-backed gateway |
| Procedure | 1. Deploy with PostgreSQL via docker-compose. 2. Execute the enrollment → renewal → revocation → restart scenario. 3. Compare outcomes with the SQLite baseline (VT-049). |
| Expected results | Identical behavior across providers. |
| Acceptance criteria | Parity on all state transitions; no provider-specific timestamp or casing defects. |
| Evidence status | Proposed - tracker records "PostgreSQL schema upgrades are implemented but only SQLite persistence was exercised." |

### VT-053 - Backup and restore procedure

| Field | Value |
|---|---|
| Test ID | VT-053 |
| Linked requirements | SR-X.007 (Partial), SR-D.006 |
| Linked THR/ORK | ORK-006, ORK-012 |
| Level | Recovery (Demonstration) |
| Preconditions | Populated gateway; backup artifacts produced per the documented procedure |
| Test inputs | Backup file; corrupted backup (negative) |
| Procedure | 1. Back up the populated store. 2. Degrade/destroy the live store. 3. Restore from backup. 4. Verify device/profile/issuer state and CRL continuity. 5. Attempt restore from a corrupted backup → clean failure. |
| Expected results | Restored gateway resumes with preserved trust state; corrupted backups fail loudly. |
| Acceptance criteria | Restore completes without orphaned CRL state; procedure documented (SR-X.007 Partial - retention policy TBD per SR-D.006). |
| Evidence status | Proposed - no restore drill recorded at baseline. |

### VT-054 - Graceful shutdown and cancellation

| Field | Value |
|---|---|
| Test ID | VT-054 |
| Linked requirements | SR-R.005 |
| Linked THR/ORK | - |
| Level | Recovery / inspection |
| Preconditions | Gateway running with `CertificateExpiryWatcher` active and an in-flight enrollment |
| Test inputs | Cancellation/stop signal during a scan and during an enrollment |
| Procedure | 1. Trigger stop mid-scan → observe clean cancellation (no crash). 2. Trigger stop mid-enrollment → verify no partial trust state persisted. 3. Restart and validate state. |
| Expected results | Background scans and in-flight operations stop cleanly; persisted state remains consistent. |
| Acceptance criteria | No corrupted records after any stop point. |
| Evidence status | Partially covered - cancellation handling CODE-OBSERVED in `CertificateExpiryWatcher.cs` (Inspection-level, SR-R.005 method I); mid-enrollment stop test Proposed. |

## 6.9 Performance tests (VT-055)

### VT-055 - EST rate limiting and enrollment capacity

| Field | Value |
|---|---|
| Test ID | VT-055 |
| Linked requirements | SR-S.006, SR-P.001, UR-014 |
| Linked THR/ORK | THR-013 |
| Level | Performance |
| Preconditions | AspNetCoreRateLimit configuration active on EST paths (E1) |
| Test inputs | Sustained enrollment flood above the configured limit; legitimate traffic interleaved |
| Procedure | 1. Drive requests above the limit from one source IP. 2. Observe throttling responses (429) and logged outcomes. 3. Confirm legitimate concurrent clients complete within the absence of an approved latency budget (SR-P.003 TBD - record observed latencies only, no pass/fail). |
| Expected results | Excess traffic throttled; legitimate traffic unaffected. |
| Acceptance criteria | Throttle engages per configuration; observed behavior recorded as capacity analysis input (SR-P.001). |
| Evidence status | Proposed - tracker/UR-014 note rate limiting as configuration-documented with effectiveness not separately evidenced; production limits TBD (SR-S.006). |

## 6.10 Deployment acceptance tests (VT-056 - VT-058)

### VT-056 - Container deployment acceptance and health/status endpoints

| Field | Value |
|---|---|
| Test ID | VT-056 |
| Linked requirements | SR-B.001, SR-B.003, SR-V.001, SR-V.002 (Missing), SR-F-ADM.010, UR-028, UR-029 |
| Linked THR/ORK | ORK-010, ORK-013 |
| Level | Deployment acceptance |
| Preconditions | E2 docker-compose stack built from the baseline commit |
| Test inputs | Compose up; health query `GET /api/status/health`; status/observe surface; external TLS certificate provisioned per SR-B.003 |
| Procedure | 1. Start the stack. 2. Verify health endpoint availability. 3. Exercise one full enrollment via EST. 4. Verify the dashboard reflects the enrollment. 5. Component-level health reporting checked against SR-V.002 (Missing - expected partial). |
| Expected results | Stack comes up; health and status endpoints respond; end-to-end enrollment succeeds in the container. |
| Acceptance criteria | Deployment acceptance = stack healthy + one successful enrollment; missing component-health detail recorded, not claimed. |
| Evidence status | Proposed - no container deployment run recorded in the tracker (Windows/SQLite developer path is the recorded evidence). |

### VT-057 - Windows service and sandbox modes

| Field | Value |
|---|---|
| Test ID | VT-057 |
| Linked requirements | SR-B.002, SR-B.004, SR-B.007 (Partial) |
| Linked THR/ORK | ORK-010, ORK-015 |
| Level | Deployment acceptance |
| Preconditions | Windows host; sandbox bootstrap configuration (Production environment, in-memory ports/SQLite/secrets via `SandboxBootstrap`) |
| Test inputs | Sandbox-mode launch; Windows-service hosting; documented configuration settings inventory |
| Procedure | 1. Launch in sandbox mode → distinct localhost listeners for admin/EST/CRL; admin listener without client certificates. 2. Install/run as Windows service. 3. Verify documented settings produce the documented behavior (SR-B.004). |
| Expected results | Both modes operational per KSPEC-004 deployment topology. |
| Acceptance criteria | Sandbox rejects misconfiguration; service stop/restart preserves state (VT-049). |
| Evidence status | Covered - AS-IS automated test: `tests/RTSec.Kryptonian.Api.Tests/SandboxBootstrapTests.cs` (CODE-OBSERVED); sandbox mode exercised by the developer verifier evidence path per tracker. |

### VT-058 - CI pipeline regression and dependency-advisory gate

| Field | Value |
|---|---|
| Test ID | VT-058 |
| Linked requirements | SR-O.005, SR-S.014, SR-F-INT.008 (Proposed joint vectors excluded) |
| Linked THR/ORK | THR-014; ORK-016 |
| Level | Deployment acceptance (CI) |
| Preconditions | GitHub Actions workflows present (`.github/workflows/`) |
| Test inputs | PR merge; UI `npm audit` result; solution test run |
| Procedure | 1. Confirm CI builds the UI, tests the solution, and builds the standalone proxy. 2. Confirm the UI audit gate rejects high/critical advisories. 3. Record remaining deployment-blocker advisories (SQLitePCLRaw.lib.e_sqlite3 2.1.6; System.Security.Cryptography.Xml 8.0.2). |
| Expected results | Pipeline green on baseline; advisory gate enforced; blockers disclosed rather than hidden. |
| Acceptance criteria | CI evidence exists for the baseline; blocker list matches the tracker. |
| Evidence status | Covered - executed local evidence (VERIFIED): tracker records "Windows GitHub CI builds the UI, tests the solution and builds the standalone proxy." and the npm-audit reduction "from six vulnerable packages to zero; CI now rejects high/critical UI dependency advisories", with the two remaining high advisories listed as deployment blockers. Eighteen pre-existing Windows infrastructure skips acknowledged. |

### VT-059 - Complete durable lifecycle decision audit

| Field | Value |
|---|---|
| Test ID | VT-059 |
| Linked requirements | SR-C.010, SR-U.001, SR-U.002 |
| Linked THR/ORK | THR-015; ORK-008 |
| Level | API integration and persistence |
| Preconditions | Persistent test database; known profile, device, issuer; ability to query audit records independently |
| Test inputs | Unknown/disabled profile; missing/malformed bootstrap; invalid CSR/signature; identity/policy rejection; CA failure/pending; successful enroll/renew; successful/unsupported/conflicting revocation |
| Procedure | Execute each case through the API boundary; record correlation ID and response; independently query durable decision records; restart and query again. Verify no activation code, private key, token or password is recorded. |
| Expected results | One durable decision record per attempt with operation, available requester/device/profile context, trusted source attribution, outcome/reason and correlation ID; success serial where applicable. |
| Acceptance criteria | No attempt disappears because it fails before issuance or because it is a revocation. Records survive restart and exclude raw secrets. |
| Evidence status | Proposed - this review observed missing branches; this acceptance test has not been implemented or executed. |

### VT-060 - Consumed activation failure, pending and restart recovery

| Field | Value |
|---|---|
| Test ID | VT-060 |
| Linked requirements | SR-F-REG.002, SR-R.004 |
| Linked THR/ORK | THR-003; ORK-005 |
| Level | Persistent API integration and fault injection |
| Preconditions | Pending registration and fresh code; controllable CA stub; durable database; administrator access |
| Test inputs | Backend unavailable; policy rejection after bootstrap validation; CA pending response; process termination after activation save; concurrent bootstrap reuse |
| Procedure | Inject each failure after activation consumption. Restart where applicable. Retry the same credential, inspect device/code/certificate state, regenerate a code administratively, and retry to completion. For a pending result also follow Retry-After with the public client. |
| Expected results | AS-IS characterization: consumed code cannot be replayed; device can remain Pending without a certificate. TO-BE: documented recoverable outcome, no duplicate credential issuance, and authorized regeneration succeeds. Pending retry behavior is explicitly characterized rather than presumed safe. |
| Acceptance criteria | No code reuse under concurrency/restart; no false Active state; a deterministic supported recovery path exists and the pending/bootstrap limitations are disclosed to integrators. |
| Evidence status | Proposed - consumption order is CODE-OBSERVED; failure/crash/pending recovery execution is absent. |

# 7. AS-IS coverage snapshot

This snapshot states what already exists at the baseline commit versus what is proposed. It contains **no** new execution claims: the executed results quoted below are exactly those recorded in `docs/IMPLEMENTATION-TRACKER.md` (local developer run, 2026-09-08, run `verify-fa867498c35c4ca7bf58c0d4bc3acd21`), and AS-IS tests are those found in `tests/` (8 test projects) executed by CI per the tracker.

## 7.1 VT evidence distribution (60 VTs)

| Evidence class | Count | VTs |
|---|---|---|
| Covered - executed local evidence (VERIFIED) | 15 | VT-006, VT-007, VT-010, VT-015, VT-016, VT-022, VT-023, VT-025, VT-028, VT-033, VT-046, VT-047, VT-049, VT-050, VT-058 |
| Covered - AS-IS automated test (CODE-OBSERVED; CI per tracker) | 24 | VT-001, VT-002, VT-003, VT-004, VT-005, VT-008, VT-009, VT-014, VT-017, VT-018, VT-021, VT-024, VT-026, VT-027, VT-030, VT-032, VT-038, VT-040, VT-041, VT-042, VT-045, VT-048, VT-051, VT-057 |
| Partially covered | 7 | VT-011, VT-029, VT-031, VT-034, VT-037, VT-044, VT-054 |
| Proposed | 14 | VT-012, VT-013, VT-019, VT-020, VT-035, VT-036, VT-039, VT-043, VT-052, VT-053, VT-055, VT-056, VT-059, VT-060 |
| **Total** | **60** | |

### 7.2 Requirement coverage

114 of 154 SRs have a specified VT link; 40 have no direct VT link. KSPEC-009 gives the exact list. All 38 URs now have an SR edge. These are traceability counts, not a complete executed coverage claim. Inspection and analysis methods remain obligations requiring recorded evidence. New VT-059 and VT-060 are Proposed and unexecuted. Fresh regression execution is recorded separately in KSPEC-016 and validation/verification.json.

### 7.3 Known gaps visible in the snapshot

- Remote ADCS/EJBCA enrollment/revocation interoperability (VT-043) - unverified at baseline; also a KSPEC-010 gap-analysis candidate.
- PostgreSQL parity (VT-052), container deployment acceptance (VT-056), backup/restore drill (VT-053) - not exercised at baseline.
- TO-BE security hardening tests (VT-020, VT-035, VT-012/013) gated on Missing requirements (SR-F-REG.007, SR-S.007/SR-A.006, SR-F-EST.011/014).
- Eighteen pre-existing Windows infrastructure skips; remaining dependency advisories (SQLitePCLRaw.lib.e_sqlite3 2.1.6; System.Security.Cryptography.Xml 8.0.2) are deployment blockers, not a clean-security-audit claim.

## 8. Traceability note - KSPEC-009 consumption

KSPEC-009 (`09-TRACEABILITY.md`) is the single downstream consumer of this document's VT → SR links. Rules:

1. KSPEC-009 references VT IDs **only as defined here** (KSPEC-000 §7: IDs are stable and never reused); it shall not redefine test content.
2. Every VT ↔ SR edge in KSPEC-009 must match the "Linked requirements" field of §6.
3. The UR → SR edges consumed by KSPEC-009 come from the Source fields of KSPEC-003; the THR ↔ SR and ORK ↔ SR edges come from KSPEC-006 §7 and KSPEC-007 §risk-mapping respectively. This document adds the terminal VT hop only.
4. Coverage statistics in KSPEC-009 must be recomputed from §7 when either document is revised; divergent counts are a review finding.

# 9. Open items and TBD dependencies

| Item | Affects | Note |
|---|---|---|
| SR-P.003 latency budget TBD | VT-055 | Latencies recorded observationally only; no pass/fail until a budget is approved. |
| SR-F-EST.011 pending-trigger matrix TBD | VT-012 | Test waits for approved per-backend determinism matrix. |
| SR-F-REG.007 abuse-control threshold TBD | VT-020 | Flood threshold untestable until fixed. |
| SR-A.006 secret-length rule pending confirmation | VT-035 | ≥32-character rule inherited provisionally. |
| SR-S.012 CRL lifetime TBD / SR-C.008 stale-revocation policy TBD | VT-025/VT-028 follow-ups | Freshness assertions need approved lifetime policy. |
| SR-F-INT.008 joint OR.NET test vectors (Proposed) | VT-047 follow-ups | Interoperability vectors must be jointly agreed, never invented (tracker boundary). |
| SR-X.007 backup/restore procedure Partial | VT-053 | Drill deferred until the documented procedure is approved. |

*End of KSPEC-008, version 0.2 (Draft). This specification proposes tests; it records executed results only where docs/IMPLEMENTATION-TRACKER.md records them, quoted verbatim. No approval is recorded or inferred.*

# Kryptonian Requirements Traceability Matrix

| Field | Value |
|---|---|
| Document title | Requirements Traceability Matrix (KSPEC-009) |
| Document ID | KSPEC-009 |
| Version | 0.2 (Draft) |
| Review status | Draft - pending review |
| Created | 2026-10-13 |
| Baseline repository commit | `682f996c8447afec13bc1fce5b7f59e6a06efa25` (branch `feat/windows-sandbox-installer`, "Release Windows gateway and portable enrollment demo 0.1.4") |
| Repository | https://github.com/AAPM-RT-SEC/RTSec.Kryptonian |
| Revision history | 0.1 - 2026-10-13 - Initial draft: bidirectional traceability UR-001 - UR-038 (KSPEC-002) → 154 SR-* (KSPEC-003 register) → architecture components (KSPEC-004) → implementation evidence (repository paths) → VT-001 - VT-060 (KSPEC-008); THR-001 - THR-018 (KSPEC-006) and ORK-001 - ORK-016 (KSPEC-007) linkages; gap lists (Author: V&V engineering team). |
| Source references | KSPEC-000 (conventions); KSPEC-002 (UR-001 - UR-038); KSPEC-003 (canonical Requirements Register, §21); KSPEC-004 (component inventory §3.2, findings §16.2-§16.3); KSPEC-006 (threat catalog §7, controls-to-requirements mapping §8); KSPEC-007 (risk register §3, requirement linkage §7.1); KSPEC-008 (VT-001 - VT-060); repository paths cited per KSPEC-000 §10 evidence source map |
| Author | Name: TBD - Date: TBD - Signature: TBD |
| Reviewer | Name: TBD - Date: TBD - Signature: TBD |
| Approver | Name: TBD - Date: TBD - Signature: TBD |
| Reconciliation revision | 0.2 - 2026-10-13 - source/document audit and publication controls (KSPEC-016) |

**Product classification (binding, KSPEC-000 §3).** Kryptonian is enterprise healthcare IT cybersecurity infrastructure: an EST (RFC 7030) certificate enrollment, identity provisioning, and credential lifecycle gateway. It is **not a regulated medical device** and performs no clinical functions. No traceability entry in this document may be read as claiming FDA classification, IEC 62304 lifecycle classification, ISO 14971 hazard coverage, SDC conformity, an adopted EST profile, DICOM B.12/B.13 certification, or any other standards-conformance status. Traceability covers **device identity, enrollment authorization, network trust, and application-layer authorization only**; no gateway state derives clinical capability.

**Evidence discipline (binding, KSPEC-000 §5 and §13).** Implementation-evidence citations reuse the exact repository paths and provenance classes recorded in KSPEC-003 (canonical register) and KSPEC-008 (VT evidence status). Nothing in this document upgrades a provenance class, records a new test result, or converts a DOCUMENTED claim into VERIFIED.

## 1. Introduction

### 1.1 Purpose

This document (KSPEC-009) provides the bidirectional requirements traceability matrix for the RTSec.Kryptonian gateway:

- **Stakeholder Need** (UR-nnn, KSPEC-002) → **System Requirement** (SR-*, KSPEC-003) → **Architecture Component** (KSPEC-004) → **Implementation Evidence** (repository paths, with KSPEC-000 §5 provenance classes) → **Verification**

**Test** (VT-nnn, KSPEC-008), plus **security threat** (THR-nnn, KSPEC-006) and **operational risk** (ORK-nnn, KSPEC-007) linkages.

• The reverse direction (VT → SR → UR) is what the matrices expose; the gap lists of §9 identify every cell that is empty and why.

### 1.2 Scope and method

• The SR ID space, short titles, statuses, priorities, and UR→SR edges are taken **only** from the canonical Requirements Register of KSPEC-003 (§21: 154 SRs - Existing 108, Partial 25, Missing 18, Proposed 3) and the per-requirement `Source` fields of KSPEC-003.

• The VT ID space and VT→SR / VT→THR / VT→ORK edges are taken **only** from KSPEC-008 (VT-001 - VT-060; all 60 test records verified present and well-formed).

• The THR ID space and threat→SR prefix linkage intent are taken from KSPEC-006 (§7 catalog, §8 mapping, prefix-level per §8); the ORK ID space and risk→SR area linkage intent are taken from KSPEC-007 (§3 register, §7.1).

• Architecture component names and repository paths are taken from KSPEC-004 (§3.2 component inventory) and the KSPEC-003 `Evidence` fields; no new paths are asserted.

• Identifier consistency was checked against KSPEC-002, KSPEC-003, KSPEC-006, KSPEC-007, and KSPEC-008 while building every table; no requirement, test, threat, or risk ID is used here that does not exist in its source document (§10).

### 1.3 Reading conventions

• `-` means "no linkage of that kind is recorded in the source documents" (an honest empty cell, listed in §9 when it indicates a coverage gap).

• `Partial` / `Missing` / `Proposed` after an ID is that requirement's **status** in the KSPEC-003 register, never an invented classification.

• Verification method codes: T = Test, I = Inspection, A = Analysis, D = Demonstration.

## 2. Traceability model

### 2.1 Chain and anchor documents

```
KSPEC-001 ──elaborated by──> KSPEC-002 (UR-nnn)
KSPEC-002 ──elaborated by──> KSPEC-003 (SR-*)          [canonical register, §21]
KSPEC-003 ──realized by─────> KSPEC-004 (components)   [§3.2 inventory]
KSPEC-003/004 ──evidenced by─> repository paths        [KSPEC-003 Evidence fields]
KSPEC-003 ──verified by─────> KSPEC-008 (VT-nnn)
KSPEC-006/007 ──mitigated/monitored by──> KSPEC-003/008 (THR/ORK → SR/VT)
```

KSPEC-003 is the normative anchor for SR IDs; KSPEC-008 is the anchor for VT IDs; KSPEC-006 and KSPEC-007 register THR and ORK IDs respectively and delegate exact SR binding to this document (KSPEC-006 §8 and KSPEC-007 §7.1 record prefix-level intent pending this binding).

### 2.2 Direction rules

• **Forward (need → evidence):** §5-§6 answer "which code path and which test shows this stakeholder need is met?" A UR is **covered** when at least one SR traces to it and at least one SR in the chain is linked to a VT; **fully covered** when every SR in the chain is VT-linked; otherwise **partially covered** (untested SRs named in §5).

• **Reverse (evidence → need):** every VT cites its linked SRs; §8 aggregates SR→VT coverage and §9.2 lists the SRs with no direct VT link.

• **Security/risk linkage:** THR and ORK cells in the area matrices carry the exact IDs recorded in KSPEC-008 VT records and, where KSPEC-006 §8 / KSPEC-007 §7.1 record prefix-level intent, the resolved specific SR IDs (§7).

### 2.3 Coverage semantics for gap accounting

| Flag | Meaning |
|---|---|
| Full | Every SR in the UR's chain is linked to at least one VT. |
| Partial | At least one chain SR is VT-linked but at least one is not (untested SRs named), or the only VTs are Proposed-status coverage. |
| None | No SR in the chain is linked to any specified VT. |

## 3. Architecture component reference (KSPEC-004 §3.2)

| Component | Layer | Responsibility (abridged) |
|---|---|---|
| `RTSec.Kryptonian.Api` | Host | Controllers (Est, Devices, Certificates, Crl, CaBackends, EstProfiles, Users, Auth, ApiKeys, NotificationSettings, GatewaySettings, Logs, Status, AcmeChallenge), Kestrel HTTPS + client-cert listeners, rate limiting, `CertificateExpiryWatcher`, `SandboxBootstrap`, middleware (`CertificateForwardingGuard`, CRL-only HTTP, plain-HTTP 426) |
| `RTSec.Kryptonian.Application` | Application | `EnrollmentOrchestrator`, `EnrollmentCertificatePolicy`, `CertificateRevocationService`, device/profile/backend/user/notification/gateway-settings services, `NotificationDispatcher` |
| `RTSec.Kryptonian.Domain` | Domain | Entities, enums (`DeviceStatus`, `CertificateStatus`, `EnrollmentStatus`, `CaBackendType`, `UserRole`, `RevocationReason`, `SmtpTlsMode`), value objects, `ICaConnector` interfaces |
| `RTSec.Kryptonian.Infrastructure` | Infrastructure | EF Core persistence (SQLite/Npgsql), repositories + unit of work, `SchemaUpgrades`, PKCS services, self-signed CA, harness connectors (ADCS SCEP, EJBCA REST), ACME via Certes, data protection, MailKit SMTP |
| `RTSec.Kryptonian.Web` | Presentation | Blazor Server admin dashboard calling the admin API |
| `RTSec.Kryptonian.Ui` | Presentation | React/TypeScript admin dashboard (Vite) served as static files by the API |
| `Kryptonian.MedicalDevice` | Demonstration | WPF device simulator with EST enrollment client (legacy activation headers for compatibility) |
| `Kryptonian.DICOMTls` | Demonstration | DIMSE-TLS demonstration terminating mTLS; issuer, TLS purpose, online revocation |
| `RTSec.Kryptonian.DimseTlsProxy` | Demonstration | Standalone DIMSE TLS proxy; bounded connection lifetimes; atomic PFX reload |
| `RTSec.Kryptonian.CaHarness` | Test/demo | Stand-in CA backend used by harness connectors and ACME relay/challenge flows |

### 3.1 Area-to-component shorthand used in §4

| Area (KSPEC-003) | Primary KSPEC-004 components |
|---|---|
| SR-F-REG | Api/DevicesController; Application/DeviceService, EnrollmentOrchestrator; Domain/DeviceStatus; Infrastructure/EnrollmentEventRepository |
| SR-F-EST | Api/EstController, Program.cs (Kestrel, 426 middleware); Application/EnrollmentOrchestrator, EnrollmentCertificatePolicy; Infrastructure/PkcsService |
| SR-F-CLM | Api/CertificatesController, CrlController, CertificateExpiryWatcher; Application/CertificateRevocationService, EnrollmentOrchestrator; Infrastructure/PkcsService, UnitOfWork, MailKitSmtpSender |
| SR-F-CAI | Api/CaBackendsController; Domain/ICaConnector; Infrastructure/CaConnectorFactory, Harness/*, Acme/*, SelfSignedCaConnector |
| SR-F-ADM | Api controllers (Status, Users, Auth, ApiKeys, NotificationSettings, GatewaySettings, Logs, EstProfiles); Web; Ui |
| SR-F-INT | Api/EstController; OpenAPI.*.yaml; Kryptonian.MedicalDevice; Kryptonian.DICOMTls; DimseTlsProxy |
| SR-S | Api/Program.cs, Middleware/CertificateForwardingGuard; Application/AuthService; Infrastructure/DataProtectionService, KryptonianDbContext |
| SR-A | Api/Program.cs (auth schemes), Authentication/ApiKeyAuthenticationHandler, AuthController, EstController |
| SR-Z | Domain/UserRole; Api/Program.cs (policies); controller `[Authorize]`/policy attributes |
| SR-C | Domain/EstProfile; Application/EnrollmentOrchestrator, CertificateRevocationService; Api/CrlController; Infrastructure/SchemaUpgrades |
| SR-D | Infrastructure/KryptonianDbContext, SchemaUpgrades, repositories, UnitOfWork; Api/Program.cs (Data Protection) |
| SR-P | Api/Program.cs (rate limiting, caching); Api/DevicesController; Infrastructure Npgsql path |
| SR-R | Api/CertificateExpiryWatcher; Application/NotificationDispatcher; Infrastructure/UnitOfWork |
| SR-V | Api/StatusController; Api/Program.cs (health checks); persistence layer |
| SR-U | Api/Logging/LiveLogBroadcaster, LogsController; Infrastructure/EnrollmentEventRepository; Serilog pipeline |
| SR-B | Api/Program.cs, SandboxBootstrap; docker-compose*.yml; deploy/; installer/windows/ |
| SR-O | Infrastructure/CaConnectorFactory; Api/Program.cs (rolling file sink); .github/workflows/ |
| SR-X | Application/CertificateRevocationService; Api/Program.cs (CrlOnlyHttp); Api/EstController; Kryptonian.DICOMTls |

# 4. SR traceability matrices by requirement area

Columns: **UR** = Source UR(s) per KSPEC-003; **Component** = §3.1 shorthand; **Evidence** = repository paths with provenance per KSPEC-003 `Evidence` fields (C = CODE-OBSERVED, V = VERIFIED, D = DOCUMENTED); **VT** = linked verification tests per KSPEC-008; **THR** / **ORK** = exact IDs recorded in KSPEC-008 VT records (plus prefix-level intent from KSPEC-006 §8 / KSPEC-007 §7.1, resolved in §7); **Status** = KSPEC-003 register status.

## 4.1 Device registration and identity management (SR-F-REG)

### SR-F-REG.001

**Short title:** Device registration with activation code
**UR:** UR-001
**Component:** REG
**Implementation evidence:** `src/RTSec.Kryptonian.Api/Controllers/DevicesController.cs` C; `src/RTSec.Kryptonian.Application/Services/DeviceService.cs` C; docs/device-enrollment.md D
**VT:** VT-014
**THR:** THR-003
**ORK:** -
**Status:** Existing

### SR-F-REG.002

**Short title:** Activation code one-time use, replay rejected
**UR:** UR-002
**Component:** REG
**Implementation evidence:** `src/RTSec.Kryptonian.Api/Controllers/EstController.cs` C; `DeviceService.cs` C; replay rejection V (tracker, `artifacts/developer/verify-*/evidence.json`)
**VT:** VT-015, VT-048, VT-060
**THR:** THR-003, THR-006
**ORK:** ORK-005
**Status:** Existing

### SR-F-REG.003

**Short title:** Centralized device inventory
**UR:** UR-003
**Component:** REG
**Implementation evidence:** `DevicesController.cs` (List, Get, Events, AllCertificates) C; `src/RTSec.Kryptonian.Application/DTOs/DeviceDto.cs` C; README.md D
**VT:** VT-014
**THR:** THR-003
**ORK:** -
**Status:** Existing

### SR-F-REG.004

**Short title:** Device record status lifecycle
**UR:** UR-003
**Component:** REG
**Implementation evidence:** `src/RTSec.Kryptonian.Domain/Enums/DeviceStatus.cs` C; `DevicesController.cs` (Events) C
**VT:** VT-019
**THR:** -
**ORK:** -
**Status:** Existing

### SR-F-REG.005

**Short title:** Enrollment identity binding
**UR:** UR-020

**Component:** REG
**Implementation evidence:** `src/RTSec.Kryptonian.Application/Services/EnrollmentOrchestrator.cs`, `EnrollmentCertificatePolicy.cs` C; PR 38 binding V (tracker)
**VT:** VT-016
**THR:** THR-001
**ORK:** -
**Status:** Existing

### SR-F-REG.006

**Short title:** Self-service requests create pending records only
**UR:** UR-001
**Component:** REG
**Implementation evidence:** `DevicesController.cs` (RequestApproval, `[AllowAnonymous]`, 202) C
**VT:** VT-017
**THR:** THR-002
**ORK:** -
**Status:** Existing

### SR-F-REG.007

**Short title:** Anonymous endpoint abuse controls
**UR:** - (KSPEC-005 open item 6; ORK flooding exposure)
**Component:** REG
**Implementation evidence:** `DevicesController.cs` (RequestApproval, no rate-limit attribute) C; `src/RTSec.Kryptonian.Api/appsettings.json` (IpRateLimiting scoped to EST paths) C
**VT:** VT-020
**THR:** THR-013
**ORK:** -
**Status:** Missing

### SR-F-REG.008

**Short title:** Trust removal blocks enrollment
**UR:** UR-009 (UC-04, SCN-05)
**Component:** REG
**Implementation evidence:** `EnrollmentOrchestrator.cs` (trust-policy gate) C; docs/flow.md D
**VT:** VT-018
**THR:** THR-012
**ORK:** ORK-005
**Status:** Existing

### SR-F-REG.009

**Short title:** Device identity metadata preservation
**UR:** UR-003, UR-020
**Component:** REG
**Implementation evidence:** `DeviceDto.cs` C; README.md D
**VT:** VT-014
**THR:** THR-003
**ORK:** -
**Status:** Existing

### SR-F-REG.010

**Short title:** History preserved on device removal
**UR:** UR-011
**Component:** REG
**Implementation evidence:** `src/RTSec.Kryptonian.Infrastructure/Repositories/EnrollmentEventRepository.cs` C; `DevicesController.cs` (Events after removal) C
**VT:** VT-014
**THR:** THR-003
**ORK:** -
**Status:** Existing

## 4.2 EST protocol behavior (SR-F-EST)

### SR-F-EST.001

**Short title:** EST endpoint surface
**UR:** UR-016, UR-022
**Component:** EST
**Implementation evidence:** `src/RTSec.Kryptonian.Api/Controllers/EstController.cs` (routes) C; docs/ARCHITECTURE.md D; independent-client EST V (tracker)
**VT:** VT-001
**THR:** THR-002
**ORK:** -
**Status:** Existing

### SR-F-EST.002

**Short title:** cacerts response format
**UR:** UR-017
**Component:** EST
**Implementation evidence:** `EstController.cs` (GetCaCerts, Pkcs7MimeType) C; `src/RTSec.Kryptonian.Infrastructure/Crypto/PkcsService.cs` C
**VT:** VT-002
**THR:** THR-012
**ORK:** -
**Status:** Existing

### SR-F-EST.003

**Short title:** CSR acceptance and 64 KiB limit
**UR:** UR-016, UR-023
**Component:** EST
**Implementation evidence:** `EstController.cs` (SimpleEnroll, `RequestSizeLimit`, 413) C; `PkcsService.cs` (DecodeEstRequestBodyAsync) C
**VT:** VT-003, VT-044
**THR:** THR-004, THR-013
**ORK:** -
**Status:** Existing

### SR-F-EST.004

**Short title:** Successful enrollment response format

**UR:** UR-016, UR-018
**Component:** EST
**Implementation evidence:** `EstController.cs` (HandleEnrollmentResult) C; executed Schannel mTLS renewal V (tracker)
**VT:** VT-004, VT-044
**THR:** THR-005
**ORK:** -
**Status:** Existing

### SR-F-EST.005

**Short title:** Unknown profile label 404, no fallback
**UR:** UR-022
**Component:** EST
**Implementation evidence:** `EstController.cs` (ResolveProfileIdAsync, 404) C; PR 37 V (tracker)
**VT:** VT-005
**THR:** THR-012
**ORK:** -
**Status:** Existing

### SR-F-EST.006

**Short title:** Basic bootstrap authentication over TLS
**UR:** UR-002, UR-019
**Component:** EST
**Implementation evidence:** `EstController.cs` (Basic parsing; 403 without TLS) C; independent curl HTTP-Basic EST over real HTTPS V (tracker)
**VT:** VT-006
**THR:** THR-003
**ORK:** ORK-005
**Status:** Existing

### SR-F-EST.007

**Short title:** Legacy headers compatibility only
**UR:** UR-019 (§16.3; EXC-004)
**Component:** EST
**Implementation evidence:** `EstController.cs` (X-Activation-Code fallback) C; tracker boundary D; no disable switch exists C
**VT:** VT-011
**THR:** -
**ORK:** -
**Status:** Partial

### SR-F-EST.008

**Short title:** Re-enroll requires native TLS client cert
**UR:** UR-021 (UC-03, SCN-03)
**Component:** EST
**Implementation evidence:** `EstController.cs` (SimpleReenroll, client-cert 401) C; renewal V (tracker)
**VT:** VT-007
**THR:** THR-006
**ORK:** -
**Status:** Existing

### SR-F-EST.009

**Short title:** Client certificate validation on EST
**UR:** UR-008, UR-021
**Component:** EST
**Implementation evidence:** `EstController.cs` (ValidateClientCertificateAsync) C; `src/RTSec.Kryptonian.Api/Authentication/ConfiguredClientCertificateTrust.cs` C
**VT:** VT-008
**THR:** THR-001
**ORK:** ORK-008
**Status:** Existing

### SR-F-EST.010

**Short title:** Pending 202 + Retry-After
**UR:** UR-023
**Component:** EST
**Implementation evidence:** `EstController.cs` (202 + Retry-After) C; docs/API-GUIDE.md D
**VT:** VT-009
**THR:** -
**ORK:** -
**Status:** Existing

### SR-F-EST.011

**Short title:** Deterministic pending semantics per backend
**UR:** UR-023; KSPEC-005 ICD-EST.004 open item (UNKNOWN)
**Component:** EST
**Implementation evidence:** `EnrollmentOrchestrator.cs` (IsPending/RetryAfterSeconds) C; docs/formal-specification/05-INTERFACE-CONTROL.md §6 open item D
**VT:** VT-012
**THR:** -
**ORK:** -
**Status:** Missing

### SR-F-EST.012

**Short title:** Plain-HTTP EST refused (426)
**UR:** UR-002
**Component:** EST
**Implementation evidence:** `src/RTSec.Kryptonian.Api/Program.cs` (426 middleware, `AllowPlainHttp` default false) C; `appsettings.json` C
**VT:** VT-010
**THR:** THR-013
**ORK:** -
**Status:** Existing

### SR-F-EST.013

**Short title:** Distinguishable error semantics
**UR:** UR-023
**Component:** EST
**Implementation evidence:** `EstController.cs` (EstError status mapping) C; docs/API-GUIDE.md D; docs/medical-device-demo.md D

**VT:** VT-012, VT-044
**THR:** THR-004, THR-013
**ORK:** -
**Status:** Existing

### SR-F-EST.014

**Short title:** CSR attributes (`csrattrs`) endpoint
**UR:** - (KSPEC-004 P-3)
**Component:** EST
**Implementation evidence:** `EstController.cs` (no csrattrs route) C; docs/formal-specification/04-SOFTWARE-DESIGN.md P-3 D
**VT:** VT-013
**THR:** THR-004
**ORK:** -
**Status:** Missing

## 4.3 Certificate lifecycle management flows (SR-F-CLM)

### SR-F-CLM.001

**Short title:** Approval gates enrollment
**UR:** UR-001, UR-008
**Component:** CLM
**Implementation evidence:** `DevicesController.cs` (Approve, DeviceAdmin policy) C; `EnrollmentOrchestrator.cs` (status gate) C
**VT:** VT-021
**THR:** THR-002
**ORK:** ORK-004
**Status:** Existing

### SR-F-CLM.002

**Short title:** Automatic renewal without re-approval
**UR:** UR-021, UR-025
**Component:** CLM
**Implementation evidence:** `EnrollmentOrchestrator.cs` (ReenrollAsync) C; renewal V (tracker)
**VT:** VT-022
**THR:** THR-011
**ORK:** ORK-001
**Status:** Existing

### SR-F-CLM.003

**Short title:** Renewal: new key, preserved identity
**UR:** UR-021
**Component:** CLM
**Implementation evidence:** renewal V (tracker); `EnrollmentCertificatePolicy.cs` C
**VT:** VT-023
**THR:** THR-006
**ORK:** ORK-001, ORK-015
**Status:** Existing

### SR-F-CLM.004

**Short title:** Certificate expiry visibility
**UR:** UR-024
**Component:** CLM
**Implementation evidence:** `src/RTSec.Kryptonian.Api/Controllers/CertificatesController.cs` C; `DevicesController.cs` (AllCertificates) C; README.md D
**VT:** VT-029
**THR:** THR-011
**ORK:** ORK-001, ORK-007, ORK-014
**Status:** Existing

### SR-F-CLM.005

**Short title:** Automated expiry scanning and notification
**UR:** UR-012, UR-024
**Component:** CLM
**Implementation evidence:** `src/RTSec.Kryptonian.Api/HostedServices/CertificateExpiryWatcher.cs` (24 h scan, 7-day re-notify) C; `src/RTSec.Kryptonian.Application/Notifications/NotificationDispatcher.cs` C
**VT:** VT-029
**THR:** THR-011
**ORK:** ORK-001, ORK-007, ORK-014
**Status:** Partial

### SR-F-CLM.006

**Short title:** Non-renewal alerting
**UR:** UR-012
**Component:** CLM
**Implementation evidence:** `CertificateExpiryWatcher.cs` C; `src/RTSec.Kryptonian.Infrastructure/Notifications/MailKitSmtpSender.cs` C; docs/email-notifications.md D; delivery not exercised D (tracker)
**VT:** VT-029
**THR:** THR-011
**ORK:** ORK-007, ORK-014
**Status:** Partial

### SR-F-CLM.007

**Short title:** Authorized revocation with issuer-scoped signed CRLs
**UR:** UR-010 (UC-04, SCN-05)
**Component:** CLM
**Implementation evidence:** `src/RTSec.Kryptonian.Application/Services/CertificateRevocationService.cs` C; `src/RTSec.Kryptonian.Api/Controllers/CrlController.cs` C; X509Chain Revoked V (tracker)
**VT:** VT-025
**THR:** THR-010
**ORK:** ORK-008
**Status:** Existing

### SR-F-CLM.008

**Short title:** Transactional revocation persistence
**UR:** UR-010

**Component:** CLM
**Implementation evidence:** `CertificateRevocationService.cs` C; `src/RTSec.Kryptonian.Infrastructure/Data/UnitOfWork.cs` C; docs/formal-specification/07-OPERATIONAL-RISK.md D
**VT:** VT-026
**THR:** THR-010
**ORK:** ORK-008
**Status:** Existing

### SR-F-CLM.009

**Short title:** Revoked devices denied renewal
**UR:** UR-009, UR-010
**Component:** CLM
**Implementation evidence:** `EnrollmentOrchestrator.cs` (trust/status gate) C; proxy tests rejecting revoked clients V (tracker)
**VT:** VT-027
**THR:** THR-010
**ORK:** -
**Status:** Existing

## 4.4 CA backend integration (SR-F-CAI)

### SR-F-CAI.001

**Short title:** Multi-backend configuration without code changes
**UR:** UR-004
**Component:** CAI
**Implementation evidence:** `src/RTSec.Kryptonian.Api/Controllers/CaBackendsController.cs` C; `src/RTSec.Kryptonian.Application/Services/CaBackendService.cs` C; docs/ca-backend-configuration.md D
**VT:** VT-040
**THR:** -
**ORK:** ORK-003, ORK-010
**Status:** Existing

### SR-F-CAI.002

**Short title:** Backend testing and profile-bound routing
**UR:** UR-005
**Component:** CAI
**Implementation evidence:** `CaBackendsController.cs` (test/activation endpoints) C; docs/ca-backend-configuration.md D
**VT:** VT-040
**THR:** -
**ORK:** ORK-003, ORK-010
**Status:** Existing

### SR-F-CAI.003

**Short title:** Pluggable connector abstraction
**UR:** UR-030, UR-038
**Component:** CAI
**Implementation evidence:** `src/RTSec.Kryptonian.Infrastructure/Crypto/CaConnectorFactory.cs` C; `src/RTSec.Kryptonian.Infrastructure/Harness/AdcsCaConnector.cs`, `EjbcaCaConnector.cs`, `SelfSignedEstCaConnector.cs` C; `src/RTSec.Kryptonian.Infrastructure/Acme/AcmeCaConnector.cs` C
**VT:** VT-043

**THR:** THR-005, THR-008
**ORK:** ORK-003, ORK-008
**Status:** Existing

### SR-F-CAI.004

**Short title:** Transparent CA protocol mapping
**UR:** UR-018
**Component:** CAI
**Implementation evidence:** `EnrollmentOrchestrator.cs` (backend dispatch) C; docs/flow.md D
**VT:** VT-040, VT-045
**THR:** -
**ORK:** ORK-003
**Status:** Existing

### SR-F-CAI.005

**Short title:** ADCS integration via configurable SCEP endpoint
**UR:** UR-030; docs/adcs-real-backend-demo.md Gap 1
**Component:** CAI
**Implementation evidence:** `src/RTSec.Kryptonian.Infrastructure/Harness/AdcsCaConnector.cs`, `ScepClient.cs` C; docs/adcs-real-backend-demo.md D
**VT:** VT-043
**THR:** THR-005, THR-008
**ORK:** ORK-003, ORK-008
**Status:** Partial

### SR-F-CAI.006

**Short title:** EJBCA REST integration with honest revocation
**UR:** UR-010, UR-030
**Component:** CAI
**Implementation evidence:** `src/RTSec.Kryptonian.Infrastructure/Harness/EjbcaCaConnector.cs` C; hospital revocation unverified D (tracker)
**VT:** VT-043
**THR:** THR-005, THR-008
**ORK:** ORK-003, ORK-008
**Status:** Partial

### SR-F-CAI.007

**Short title:** ACME enrollment with functional challenge set
**UR:** UR-030; KSPEC-004 Dns01ChallengeStub
**Component:** CAI
**Implementation evidence:** `src/RTSec.Kryptonian.Infrastructure/Acme/AcmeCaConnector.cs`, `Http01ChallengeStore.cs`, `Dns01ChallengeStub.cs` C
**VT:** VT-042
**THR:** THR-005
**ORK:** -
**Status:** Partial

### SR-F-CAI.008

**Short title:** Gateway CRL generation fail-closed for incapable backends
**UR:** UR-010
**Component:** CAI
**Implementation evidence:** `CertificateRevocationService.cs`, `CrlController.cs` (501 on unsupported CRL generation) C; docs/formal-specification/07-OPERATIONAL-RISK.md D
**VT:** VT-041
**THR:** THR-008
**ORK:** ORK-008
**Status:** Existing

### SR-F-CAI.009

**Short title:** CA material persistence across restarts and upgrades
**UR:** UR-037
**Component:** CAI
**Implementation evidence:** restart on populated SQLite V (tracker); `src/RTSec.Kryptonian.Infrastructure/Repositories/CaBackendRepository.cs` C
**VT:** VT-041
**THR:** THR-008
**ORK:** ORK-008
**Status:** Existing

### SR-F-CAI.010

**Short title:** Secure connector credential handling
**UR:** UR-013 (**Missing** in KSPEC-002)
**Component:** CAI
**Implementation evidence:** `appsettings.json`, `Program.cs` (configuration/environment sourcing) C; plain config at baseline D (tracker)
**VT:** -
**THR:** -
**ORK:** -
**Status:** Missing

## 4.5 Administration and portal (SR-F-ADM)

### SR-F-ADM.001

**Short title:** Administrative portal surface
**UR:** UR-001, UR-003, UR-004, UR-015, UR-024
**Component:** ADM
**Implementation evidence:** `src/RTSec.Kryptonian.Api/Controllers/` (15 controllers) C; `src/RTSec.Kryptonian.Web` C; `src/RTSec.Kryptonian.Ui` C; README.md D
**VT:** -
**THR:** -
**ORK:** -
**Status:** Existing

### SR-F-ADM.002

**Short title:** Gateway dashboard summary
**UR:** UR-006

**Component:** ADM
**Implementation evidence:** `src/RTSec.Kryptonian.Api/Controllers/StatusController.cs` C; README.md D
**VT:** -
**THR:** -
**ORK:** -
**Status:** Existing

### SR-F-ADM.003

**Short title:** User account lifecycle with lockout protection
**UR:** UR-007, UR-015
**Component:** ADM
**Implementation evidence:** `src/RTSec.Kryptonian.Api/Controllers/UsersController.cs` C; `src/RTSec.Kryptonian.Application/Services/UserService.cs` (self-deletion, last-admin guards) C; docs/user-management.md D
**VT:** VT-037
**THR:** THR-007, THR-009
**ORK:** -
**Status:** Existing

### SR-F-ADM.004

**Short title:** API key lifecycle
**UR:** UR-027
**Component:** ADM
**Implementation evidence:** `src/RTSec.Kryptonian.Api/Controllers/ApiKeysController.cs` C; `src/RTSec.Kryptonian.Infrastructure/Repositories/ApiKeyRepository.cs` C; docs/user-management.md D
**VT:** VT-039
**THR:** THR-007
**ORK:** -
**Status:** Existing

### SR-F-ADM.005

**Short title:** Initial administrator bootstrap
**UR:** UR-007, UR-015
**Component:** ADM
**Implementation evidence:** docs/admin-setup.md D; docs/user-management.md (FAQ) D
**VT:** -
**THR:** THR-009
**ORK:** -
**Status:** Existing

### SR-F-ADM.006

**Short title:** Notification settings management
**UR:** UR-012
**Component:** ADM
**Implementation evidence:** `NotificationSettingsController.cs` (SystemAdmin policies, test endpoint) C; `src/RTSec.Kryptonian.Application/Services/NotificationSettingsService.cs` C; docs/email-notifications.md D
**VT:** -
**THR:** -
**ORK:** ORK-014
**Status:** Existing

### SR-F-ADM.007

**Short title:** EST profile management with additive trust-list updates
**UR:** UR-031, UR-032
**Component:** ADM
**Implementation evidence:** `src/RTSec.Kryptonian.Api/Controllers/EstProfilesController.cs` C; `EstProfileService.cs` C; `src/RTSec.Kryptonian.Infrastructure/Data/SchemaUpgrades.cs` (EnsureTrustPolicyAsync) C
**VT:** -
**THR:** THR-012
**ORK:** -
**Status:** Existing

### SR-F-ADM.008

**Short title:** Gateway settings management
**UR:** UR-006, UR-024
**Component:** ADM
**Implementation evidence:** `GatewaySettingsController.cs` (SystemAdmin) C; `GatewaySettingsService.cs` C; `GatewaySettingsRepository.cs` C
**VT:** -
**THR:** -
**ORK:** ORK-010
**Status:** Existing

### SR-F-ADM.009

**Short title:** Live activity feed
**UR:** UR-006, UR-011
**Component:** ADM
**Implementation evidence:** `src/RTSec.Kryptonian.Api/Controllers/LogsController.cs` C; `src/RTSec.Kryptonian.Api/Logging/LiveLogBroadcaster` (registered in `Program.cs`) C
**VT:** -
**THR:** -
**ORK:** -
**Status:** Existing

### SR-F-ADM.010

**Short title:** Health and status endpoint
**UR:** UR-029
**Component:** ADM/V
**Implementation evidence:** `StatusController.cs` C; docs/DEPLOYMENT.md D
**VT:** VT-056
**THR:** -
**ORK:** ORK-010, ORK-013
**Status:** Existing

## 4.6 Interfaces and interoperability demonstrations (SR-F-INT)

### SR-F-INT.001

**Short title:** Device-side EST client without gateway-specific code

**UR:** UR-019 (executed evidence)
**Component:** INT
**Implementation evidence:** independent curl HTTP Basic EST over real HTTPS V (tracker); docs/API-GUIDE.md (EstClient example) D
**VT:** -
**THR:** -
**ORK:** -
**Status:** Existing

### SR-F-INT.002

**Short title:** Legacy headers demo-only, never a new requirement
**UR:** UR-019 (§16.3)
**Component:** INT
**Implementation evidence:** `EstController.cs` (Basic path independent of legacy headers) C; tracker D
**VT:** VT-011
**THR:** -
**ORK:** -
**Status:** Existing

### SR-F-INT.003

**Short title:** Authoritative OpenAPI admin contract
**UR:** UR-027; `OpenAPI.Client.yaml` empty, `OpenAPI.Schema.yaml` stale
**Component:** INT
**Implementation evidence:** `OpenAPI.Client.yaml` (empty), `OpenAPI.Schema.yaml` (stale) C; `OpenAPI.Admin.yaml`, `OpenAPI.ESTProfiles.yaml`, `OpenAPI.StatusObserve.yaml` C; docs/formal-specification/05-INTERFACE-CONTROL.md D
**VT:** -
**THR:** -
**ORK:** -
**Status:** Missing

### SR-F-INT.004

**Short title:** EST profile schema currency
**UR:** UR-031
**Component:** INT
**Implementation evidence:** `OpenAPI.ESTProfiles.yaml` C; `src/RTSec.Kryptonian.Application/DTOs/EstProfileDto.cs` C; docs/formal-specification/05-INTERFACE-CONTROL.md D
**VT:** -
**THR:** -
**ORK:** -
**Status:** Partial

### SR-F-INT.005

**Short title:** DICOM mTLS demonstration (enroll, use, rotate, deny)
**UR:** UR-034, UR-036
**Component:** INT
**Implementation evidence:** `src/Kryptonian.DICOMTls/` C; two mutual-TLS DICOM C-STORE transfers with SOP Instance UID comparison V (tracker, `artifacts/developer/verify-*/evidence.json`); `tests/RTSec.Kryptonian.DimseTlsProxy.Tests/` C
**VT:** VT-047
**THR:** THR-001
**ORK:** ORK-002

**Status:** Existing

### SR-F-INT.006

**Short title:** Demonstration clients never presented as product deliverables

**UR:** UR-026, UR-035

**Component:** INT

**Implementation evidence:** `src/Kryptonian.MedicalDevice/`, `src/Kryptonian.DICOMTls/` C; README.md disclaimer D; tracker boundaries D

**VT:** -

**THR:** -

**ORK:** -

**Status:** Existing

### SR-F-INT.007

**Short title:** No second enrollment protocol; OR.NET alignment without conformity

**UR:** UR-034

**Component:** INT

**Implementation evidence:** README.md D; tracker boundaries D (no SDC conformity claimed); docs/ORNET-ALIGNMENT-2026-09-09.md D

**VT:** VT-011

**THR:** -

**ORK:** -

**Status:** Existing

### SR-F-INT.008

**Short title:** Independent client/server pairs at the real network boundary

**UR:** UR-036

**Component:** INT

**Implementation evidence:** `artifacts/developer/verify-*/evidence.json` (gateway-boundary verifier) V; `tests/` (8 test projects) C; OR.NET joint vectors not present PROPOSED

**VT:** VT-058

**THR:** THR-014

**ORK:** ORK-016

**Status:** Proposed

## 4.7 Security requirements (SR-S)

### SR-S.001

**Short title:** TLS-only credential exchanges

**UR:** UR-002, UR-014

**Component:** S

**Implementation evidence:** `src/RTSec.Kryptonian.Api/Program.cs` (426 middleware; redirect default outside Development) C; docs/DEPLOYMENT.md D

**VT:** VT-031

**THR:** THR-003, THR-016

**ORK:** -

**Status:** Existing

### SR-S.002

**Short title:** CSR and returned-certificate policy enforcement
**UR:** UR-033 (V in KSPEC-002)
**Component:** S
**Implementation evidence:** `src/RTSec.Kryptonian.Application/Services/EnrollmentCertificatePolicy.cs` C; PR 43 V (tracker)
**VT:** VT-032
**THR:** THR-004, THR-005
**ORK:** -
**Status:** Existing

### SR-S.003

**Short title:** Gateway-owned trust-policy gate
**UR:** UR-008
**Component:** S
**Implementation evidence:** `EnrollmentOrchestrator.cs` (pre-CA trust gate) C; docs/flow.md D
**VT:** VT-033
**THR:** THR-012
**ORK:** ORK-005
**Status:** Existing

### SR-S.004

**Short title:** Forwarded-certificate guard
**UR:** UR-008; PR 39
**Component:** S
**Implementation evidence:** `src/RTSec.Kryptonian.Api/Middleware/CertificateForwardingGuard.cs` (KnownProxies, 403/400, default empty = fail closed) C; direct spoof rejected V (tracker)
**VT:** VT-034
**THR:** THR-017
**ORK:** -
**Status:** Existing

### SR-S.005

**Short title:** Authenticated forwarder identity
**UR:** - (KSPEC-004 P-2; THR-017 XFCC spoofing route)
**Component:** S
**Implementation evidence:** `CertificateForwardingGuard.cs` (IP-set membership check only) C; docs/formal-specification/04-SOFTWARE-DESIGN.md P-2 D
**VT:** VT-034
**THR:** THR-017
**ORK:** -
**Status:** Missing

### SR-S.006

**Short title:** EST rate-limit capacity
**UR:** UR-014
**Component:** S
**Implementation evidence:** `Program.cs` (UseIpRateLimiting) C; `appsettings.json` (IpRateLimiting rules) C; docs/ARCHITECTURE.md D
**VT:** VT-055

**THR:** THR-013
**ORK:** -
**Status:** Existing

### SR-S.007

**Short title:** No hard-coded signing secrets
**UR:** UR-013; `Program.cs` dev fallback finding
**Component:** S
**Implementation evidence:** `Program.cs` (jwtSecret fallback constant) C; docs/formal-specification/05-INTERFACE-CONTROL.md (ICD-CFG.002 finding) D
**VT:** VT-035
**THR:** THR-007, THR-009, THR-016
**ORK:** -
**Status:** Missing

### SR-S.008

**Short title:** Secrets at rest
**UR:** UR-013 (**Missing** in KSPEC-002)
**Component:** S
**Implementation evidence:** `src/RTSec.Kryptonian.Infrastructure/Data/KryptonianDbContext.cs` C; `src/RTSec.Kryptonian.Infrastructure/Security/DataProtectionService.cs` C (field coverage not evidenced); plain-config storage D (tracker)
**VT:** -
**THR:** THR-016
**ORK:** -
**Status:** Missing

### SR-S.009

**Short title:** Password hashing strength
**UR:** UR-015
**Component:** S
**Implementation evidence:** BCrypt.Net-Next in `src/RTSec.Kryptonian.Api/RTSec.Kryptonian.Api.csproj` C; `AuthService.cs`, `UserService.cs` C; plans/user-management.md D
**VT:** VT-036
**THR:** THR-009
**ORK:** -
**Status:** Existing

### SR-S.010

**Short title:** Data Protection key ring management
**UR:** - (sandbox behavior; windows-installation fail-closed)
**Component:** S
**Implementation evidence:** `Program.cs` (AddDataProtection, PersistKeysToFileSystem) C; `DataProtectionService.cs` C; artifacts/windows-installer/payload/docs/windows-installation.md D
**VT:** -
**THR:** THR-016
**ORK:** ORK-015
**Status:** Partial

### SR-S.011

**Short title:** Device private key non-archival
**UR:** - (KSPEC-004 A-2; UR-013 rationale)
**Component:** S
**Implementation evidence:** `src/RTSec.Kryptonian.Domain/Entities/` (`EncryptedPrivateKeyPem` field) C; docs/formal-specification/04-SOFTWARE-DESIGN.md A-2 D
**VT:** -
**THR:** THR-016
**ORK:** -
**Status:** Proposed

### SR-S.012

**Short title:** Configurable CRL lifetime
**UR:** - (KSPEC-004 A-4; UR-010)
**Component:** S
**Implementation evidence:** 60 s lifetime C in `src/RTSec.Kryptonian.Infrastructure/Crypto/SelfSignedCaConnector.cs` and CRL issuance path; docs/formal-specification/04-SOFTWARE-DESIGN.md A-4 D
**VT:** -
**THR:** THR-010
**ORK:** ORK-009
**Status:** Missing

### SR-S.013

**Short title:** CORS restricted to the admin UI
**UR:** UR-015
**Component:** S
**Implementation evidence:** `Program.cs` (KryptonianUi CORS from `Kryptonian:Ui:AllowedOrigins`) C; `appsettings.json` C
**VT:** VT-031
**THR:** THR-003, THR-016
**ORK:** -
**Status:** Existing

### SR-S.014

**Short title:** Dependency vulnerability management
**UR:** - (PR 52; tracker advisories)
**Component:** S
**Implementation evidence:** `.github/workflows/` (CI advisory gate) C; tracker (npm audit to zero; transitive highs remain) D
**VT:** VT-058
**THR:** THR-014
**ORK:** ORK-016
**Status:** Partial

## 4.8 Authentication requirements (SR-A)

### SR-A.001

**Short title:** Authenticated access to admin API (JWT + API key schemes)
**UR:** UR-015, UR-027
**Component:** A

**Implementation evidence:** `src/RTSec.Kryptonian.Api/Program.cs` (PolicyScheme forwarding) C; `src/RTSec.Kryptonian.Api/Authentication/ApiKeyAuthenticationHandler.cs` C
**VT:** VT-037
**THR:** THR-007, THR-009
**ORK:** -
**Status:** Existing

### SR-A.002

**Short title:** Bounded JWT session lifetime
**UR:** - (docs/user-management.md 8-hour sessions)
**Component:** A
**Implementation evidence:** `Program.cs` (TokenValidationParameters, ClockSkew) C; docs/user-management.md D; 8-hour default D (docs/formal-specification/05-INTERFACE-CONTROL.md)
**VT:** VT-037
**THR:** THR-009
**ORK:** -
**Status:** Existing

### SR-A.003

**Short title:** API key hashing and status checks
**UR:** UR-027
**Component:** A
**Implementation evidence:** `ApiKeyAuthenticationHandler.cs` (SHA-256 hash lookup, RevokedAt/ExpiresAt/IsActive, LastUsedAt) C
**VT:** VT-039
**THR:** THR-007
**ORK:** -
**Status:** Existing

### SR-A.004

**Short title:** Legacy static API keys disabled by default
**UR:** - (docs/user-management.md; plans/user-management.md)
**Component:** A
**Implementation evidence:** docs/user-management.md (legacy static keys) D; plans/user-management.md D
**VT:** VT-039
**THR:** THR-007
**ORK:** -
**Status:** Existing

### SR-A.005

**Short title:** API keys carry the owner's role at generation
**UR:** - (docs/user-management.md)
**Component:** A
**Implementation evidence:** `ApiKeyAuthenticationHandler.cs` (role from ApiKey record) C; docs/user-management.md D
**VT:** VT-039
**THR:** THR-007
**ORK:** -
**Status:** Existing

### SR-A.006

**Short title:** JWT signing secret provisioning
**UR:** UR-013; hard-coded dev fallback in `Program.cs`
**Component:** A
**Implementation evidence:** `Program.cs` (fallback constant; no fail-fast check) C; plans/user-management.md D
**VT:** VT-035
**THR:** THR-007, THR-009, THR-016
**ORK:** -
**Status:** Missing

### SR-A.007

**Short title:** EST bootstrap 401 challenge over TLS
**UR:** UR-023; PR 42
**Component:** A
**Implementation evidence:** `src/RTSec.Kryptonian.Api/Controllers/EstController.cs` (BasicUnauthorized with WWW-Authenticate) C; docs/formal-specification/05-INTERFACE-CONTROL.md (401 challenge row) D
**VT:** VT-006
**THR:** THR-003
**ORK:** ORK-005
**Status:** Existing

### SR-A.008

**Short title:** Enrollment identity from client certificate, not headers
**UR:** - (PR 38; EstController device-identifier rule)
**Component:** A
**Implementation evidence:** `EstController.cs` (GetDeviceIdentifier returns null for header; certificate subject used) C
**VT:** VT-007, VT-023
**THR:** THR-006
**ORK:** -
**Status:** Existing

### SR-A.009

**Short title:** Development-only anonymous bypass gating
**UR:** UR-015
**Component:** A
**Implementation evidence:** `ApiKeyAuthenticationHandler.cs` (bypass requires AllowAnonymousInDevelopment && no static keys && Development) C
**VT:** -
**THR:** THR-007
**ORK:** -
**Status:** Existing

### SR-A.010

**Short title:** Uniform authentication failure responses
**UR:** - (docs/user-management.md login; THR-009 model input)
**Component:** A
**Implementation evidence:** `src/RTSec.Kryptonian.Api/Controllers/AuthController.cs` (uniform "Invalid username or password.") C
**VT:** VT-037

**THR:** THR-007, THR-009
**ORK:** -
**Status:** Existing

## 4.9 Authorization requirements (SR-Z)

### SR-Z.001

**Short title:** Three-role authorization model
**UR:** UR-015 (Critical)
**Component:** Z
**Implementation evidence:** `src/RTSec.Kryptonian.Domain/Enums/UserRole.cs` (Standard, DeviceAdmin, SystemAdmin) C; `Program.cs` (StandardOrAbove, DeviceAdmin, SystemAdmin policies) C
**VT:** VT-038
**THR:** THR-007
**ORK:** -
**Status:** Existing

### SR-Z.002

**Short title:** DeviceAdmin on device/certificate mutations
**UR:** UR-015 (UC-08)
**Component:** Z
**Implementation evidence:** `DevicesController.cs` (DeviceAdmin on mutations) C; `CertificatesController.cs` (controller-level DeviceAdmin) C
**VT:** VT-038
**THR:** THR-007
**ORK:** -
**Status:** Existing

### SR-Z.003

**Short title:** SystemAdmin on configuration/user administration
**UR:** UR-015
**Component:** Z
**Implementation evidence:** `CaBackendsController.cs`, `EstProfilesController.cs`, `UsersController.cs`, `NotificationSettingsController.cs`, `GatewaySettingsController.cs` (SystemAdmin on mutations) C
**VT:** VT-038
**THR:** THR-007
**ORK:** -
**Status:** Existing

### SR-Z.004

**Short title:** Standard-or-above read access
**UR:** UR-015
**Component:** Z
**Implementation evidence:** `Program.cs` (StandardOrAbove policy) C; controller-level `[Authorize]` on reads C
**VT:** VT-038
**THR:** THR-007
**ORK:** -
**Status:** Existing

### SR-Z.005

**Short title:** Revocation/trust actions restricted
**UR:** UR-009, UR-010
**Component:** Z
**Implementation evidence:** `CertificatesController.cs` (DeviceAdmin) C; `DevicesController.cs` (trust endpoints under DeviceAdmin) C
**VT:** VT-038
**THR:** THR-007
**ORK:** -
**Status:** Existing

### SR-Z.006

**Short title:** API key role binding, no client claim ingestion
**UR:** UR-027
**Component:** Z
**Implementation evidence:** `ApiKeyAuthenticationHandler.cs` (BuildTicket role from apiKey record) C
**VT:** VT-039
**THR:** THR-007
**ORK:** -
**Status:** Existing

### SR-Z.007

**Short title:** Explicit role policy on all mutations
**UR:** - (KSPEC-005 open item 4)
**Component:** Z
**Implementation evidence:** `CaBackendsController.cs` (test endpoint `[Authorize]` without policy) C; docs/formal-specification/05-INTERFACE-CONTROL.md open items D
**VT:** -
**THR:** THR-007
**ORK:** -
**Status:** Partial

### SR-Z.008

**Short title:** Anonymous access limited to a documented set
**UR:** - (controller survey; KSPEC-005 open item 6)
**Component:** Z
**Implementation evidence:** controller `[Authorize]` coverage; single `[AllowAnonymous]` on device-requests C; `Program.cs` (unauthenticated health map) C
**VT:** VT-020
**THR:** THR-013
**ORK:** -
**Status:** Existing

### SR-Z.009

**Short title:** Confirmed self-service authorization model
**UR:** - (KSPEC-005 open item 6; docs/formal-specification/05-INTERFACE-CONTROL.md)
**Component:** Z

**Implementation evidence:** `DevicesController.cs` (RequestApproval `[AllowAnonymous]`) C; docs/formal-specification/05-INTERFACE-CONTROL.md open item D
**VT:** -
**THR:** -
**ORK:** -
**Status:** Proposed

### SR-Z.010

**Short title:** No clinical capability derivation
**UR:** UR-026 (Critical); EXC-001/EXC-002
**Component:** Z
**Implementation evidence:** docs/CHANGES-AND-ORNET-ALIGNMENT.md (renewal ≠ recertification) D; README.md disclaimer D; docs/formal-specification/04-SOFTWARE-DESIGN.md boundary D
**VT:** VT-038
**THR:** -
**ORK:** -
**Status:** Existing

## 4.10 Certificate lifecycle policy requirements (SR-C)

### SR-C.001

**Short title:** Profile policy bundle
**UR:** UR-031 (Critical)
**Component:** C
**Implementation evidence:** `src/RTSec.Kryptonian.Domain/Entities/EstProfile.cs`, `src/RTSec.Kryptonian.Application/DTOs/EstProfileDto.cs` C; docs/ca-backend-configuration.md D
**VT:** VT-030
**THR:** THR-004, THR-005
**ORK:** ORK-004
**Status:** Existing

### SR-C.002

**Short title:** Trust policy durability across restarts and updates
**UR:** UR-032
**Component:** C
**Implementation evidence:** restart persistence on populated SQLite V (tracker); partial-update preservation PR 47; `SchemaUpgrades.cs` C
**VT:** VT-033
**THR:** THR-012
**ORK:** ORK-005
**Status:** Existing

### SR-C.003

**Short title:** Profile-configured validity periods
**UR:** UR-031; TBD-001
**Component:** C
**Implementation evidence:** `EstProfileDto.cs` (validity fields) C; docs/ca-backend-configuration.md D
**VT:** VT-030
**THR:** THR-004, THR-005
**ORK:** ORK-004

**Status:** Existing

### SR-C.004

**Short title:** Renewal window authorization
**UR:** UR-021
**Component:** C
**Implementation evidence:** `EnrollmentOrchestrator.cs` (reenroll validation) C; docs/device-enrollment.md D
**VT:** VT-022, VT-024
**THR:** THR-011
**ORK:** ORK-001
**Status:** Existing

### SR-C.005

**Short title:** Issuer-scoped CRL publication
**UR:** UR-010; PR 46
**Component:** C
**Implementation evidence:** `CertificateRevocationService.cs` C; `CrlController.cs` C
**VT:** VT-025
**THR:** THR-010
**ORK:** ORK-008
**Status:** Existing

### SR-C.006

**Short title:** CRL distribution points on issued certificates
**UR:** UR-010; PR 46
**Component:** C
**Implementation evidence:** `CertificateRevocationService.cs`, `PkcsService.cs` C
**VT:** VT-025
**THR:** THR-010
**ORK:** ORK-008
**Status:** Existing

### SR-C.007

**Short title:** Online revocation checking at peers
**UR:** UR-010; PR 45
**Component:** C
**Implementation evidence:** `ConfiguredClientCertificateTrust.cs` C; `src/Kryptonian.DICOMTls/` C; tracker D
**VT:** VT-028, VT-047
**THR:** THR-001, THR-010
**ORK:** ORK-008
**Status:** Existing

### SR-C.008

**Short title:** Bounded revocation propagation semantics
**UR:** - (EXC-007; KSPEC-004 A-5)
**Component:** C
**Implementation evidence:** tracker (bounded proxy lifetimes) D; docs/formal-specification/04-SOFTWARE-DESIGN.md A-5 D

**VT:** -
**THR:** THR-010
**ORK:** -
**Status:** Partial

### SR-C.009

**Short title:** Separation of revocation and enrollment denial
**UR:** UR-009, UR-010; PR 46
**Component:** C
**Implementation evidence:** `CertificateRevocationService.cs` (separation) C
**VT:** -
**THR:** THR-010
**ORK:** ORK-008
**Status:** Existing

### SR-C.010

**Short title:** Enrollment event record per issuance attempt
**UR:** UR-011
**Component:** C
**Implementation evidence:** `EnrollmentEventRepository.cs` C; `src/RTSec.Kryptonian.Api/Controllers/StatusController.cs` (enrollments listing) C
**VT:** VT-059
**THR:** -
**ORK:** -
**Status:** Partial

## 4.11 Data management requirements (SR-D)

### SR-D.001

**Short title:** Durable persistence of all configured state
**UR:** UR-037
**Component:** D
**Implementation evidence:** `KryptonianDbContext.cs`, `src/RTSec.Kryptonian.Infrastructure/Repositories/` C; restart on populated SQLite V (tracker)
**VT:** VT-049
**THR:** -
**ORK:** ORK-006, ORK-012
**Status:** Existing

### SR-D.002

**Short title:** SQLite and PostgreSQL persistence support
**UR:** UR-037; TBD-006
**Component:** D
**Implementation evidence:** `KryptonianDbContext.cs` (Npgsql/SQLite) C; docs/DEPLOYMENT.md D; PostgreSQL not exercised D (tracker)
**VT:** VT-052
**THR:** -
**ORK:** ORK-006, ORK-012
**Status:** Partial

### SR-D.003

**Short title:** Additive schema upgrades, never recreate data
**UR:** - (`SchemaUpgrades.cs` header rule; PR 41)
**Component:** D
**Implementation evidence:** `src/RTSec.Kryptonian.Infrastructure/Data/SchemaUpgrades.cs` C
**VT:** VT-051
**THR:** -
**ORK:** ORK-011
**Status:** Existing

### SR-D.004

**Short title:** Upgrade safety boundary
**UR:** - (KSPEC-010 gap input; docs/formal-specification/07-OPERATIONAL-RISK.md §backup)
**Component:** D
**Implementation evidence:** `SchemaUpgrades.cs` (upgrade DDL outside explicit transaction/backup boundary) C
**VT:** -
**THR:** -
**ORK:** ORK-011, ORK-012
**Status:** Missing

### SR-D.005

**Short title:** UTC timestamp discipline
**UR:** - (tracker SQLite DateTime-kind fix)
**Component:** D
**Implementation evidence:** tracker (UTC regression fixed with runnable regressions) V; `SchemaUpgrades.cs` C
**VT:** VT-050
**THR:** -
**ORK:** ORK-009
**Status:** Existing

### SR-D.006

**Short title:** Lifecycle record retention (TBD period)
**UR:** UR-011
**Component:** D
**Implementation evidence:** `EnrollmentEventRepository.cs` C; docs/formal-specification/07-OPERATIONAL-RISK.md D
**VT:** VT-053
**THR:** -
**ORK:** ORK-006, ORK-012
**Status:** Partial

### SR-D.007

**Short title:** Data Protection key persistence
**UR:** - (`Program.cs` sandbox key ring; docs/formal-specification/07-OPERATIONAL-RISK.md restore order)
**Component:** D
**Implementation evidence:** `Program.cs` (PersistKeysToFileSystem) C; `DataProtectionService.cs` C
**VT:** -

**THR:** THR-016
**ORK:** ORK-012, ORK-015
**Status:** Partial

### SR-D.008

**Short title:** Sensitive field encryption at rest
**UR:** UR-013 (**Missing** in KSPEC-002)
**Component:** D
**Implementation evidence:** `DataProtectionService.cs` C (protection service exists; field coverage not evidenced); tracker D
**VT:** -
**THR:** THR-016
**ORK:** ORK-015
**Status:** Missing

### SR-D.009

**Short title:** Demo operations distinguishable
**UR:** - (tracker synthetic demo records; demo-enroll endpoint)
**Component:** D
**Implementation evidence:** `EstController.cs` (demo-enroll endpoint) C; tracker D
**VT:** -
**THR:** -
**ORK:** -
**Status:** Partial

## 4.12 Performance requirements (SR-P)

### SR-P.001

**Short title:** EST rate-limit capacity
**UR:** UR-014; docs/ARCHITECTURE.md
**Component:** P
**Implementation evidence:** `Program.cs` (rate-limiting configuration) C; docs/ARCHITECTURE.md D
**VT:** VT-055
**THR:** THR-013
**ORK:** -
**Status:** Partial

### SR-P.002

**Short title:** Enrollment request size bounds
**UR:** - (`EstController.MaxCsrBodySize`; KSPEC-005 ICD-EST)
**Component:** P
**Implementation evidence:** `EstController.cs` (64 KiB cap, 413 mapping) C
**VT:** VT-003, VT-044
**THR:** THR-004, THR-013
**ORK:** -
**Status:** Existing

### SR-P.003

**Short title:** Enrollment latency targets (TBD)
**UR:** UR-021 (no baseline performance budget found)
**Component:** P
**Implementation evidence:** no baseline budget found; UR-021 automation rationale D
**VT:** -
**THR:** -
**ORK:** -
**Status:** Missing

### SR-P.004

**Short title:** Database connection pooling
**UR:** - (docs/ARCHITECTURE.md Npgsql pooling)
**Component:** P
**Implementation evidence:** docs/ARCHITECTURE.md D; `DevicesController.cs` AllCertificates N+1 note C
**VT:** -
**THR:** -
**ORK:** -
**Status:** Existing

### SR-P.005

**Short title:** Profile/CA certificate caching
**UR:** - (docs/ARCHITECTURE.md Certificate Caching)
**Component:** P
**Implementation evidence:** docs/ARCHITECTURE.md D; `EnrollmentOrchestrator.cs` C
**VT:** -
**THR:** -
**ORK:** -
**Status:** Partial

## 4.13 Reliability requirements (SR-R)

### SR-R.001

**Short title:** Background watcher fault tolerance
**UR:** UR-012; `CertificateExpiryWatcher` design
**Component:** R
**Implementation evidence:** `src/RTSec.Kryptonian.Api/HostedServices/CertificateExpiryWatcher.cs` (catches scan exceptions and continues) C
**VT:** VT-029
**THR:** THR-011
**ORK:** ORK-007, ORK-014
**Status:** Existing

### SR-R.002

**Short title:** Backend failure outcomes recorded
**UR:** UR-023; PR 46 (transactional design)
**Component:** R
**Implementation evidence:** `CertificateRevocationService.cs` / enrollment-event persistence C

**VT:** VT-045
**THR:** -
**ORK:** ORK-003
**Status:** Existing

### SR-R.003

**Short title:** Notification delivery decoupled from lifecycle state
**UR:** UR-012; `NotificationDispatcher` design
**Component:** R
**Implementation evidence:** `src/RTSec.Kryptonian.Application/Notifications/NotificationDispatcher.cs` C
**VT:** VT-029
**THR:** THR-011
**ORK:** ORK-014
**Status:** Partial

### SR-R.004

**Short title:** Concurrency conflict handling
**UR:** - (PR 46 concurrent-update protection)
**Component:** R
**Implementation evidence:** `CertificateRevocationService.cs`, `UnitOfWork.cs` C; `tests/RTSec.Kryptonian.Infrastructure.Tests/Data/DeviceActivationConcurrencyTests.cs` C
**VT:** VT-026, VT-048, VT-060
**THR:** THR-010
**ORK:** ORK-005, ORK-008
**Status:** Existing

### SR-R.005

**Short title:** Graceful shutdown
**UR:** UR-037
**Component:** R
**Implementation evidence:** `CertificateExpiryWatcher.cs` (cancellation handling) C
**VT:** VT-054
**THR:** -
**ORK:** -
**Status:** Existing

## 4.14 Availability requirements (SR-V)

### SR-V.001

**Short title:** Health-check endpoint availability
**UR:** UR-029; docs/DEPLOYMENT.md liveness probes
**Component:** V
**Implementation evidence:** `src/RTSec.Kryptonian.Api/Controllers/StatusController.cs` C; docs/DEPLOYMENT.md D
**VT:** VT-056
**THR:** -
**ORK:** ORK-010, ORK-013
**Status:** Existing

### SR-V.002

**Short title:** Component-level health reporting
**UR:** UR-029; docs/ARCHITECTURE.md health-check example
**Component:** V
**Implementation evidence:** `Program.cs` (AddDbContextCheck) C; `StatusController.cs` C; connector components absent C
**VT:** VT-056
**THR:** -
**ORK:** ORK-010, ORK-013
**Status:** Missing

### SR-V.003

**Short title:** Restart state preservation
**UR:** UR-037; tracker
**Component:** V
**Implementation evidence:** restart on populated SQLite preserved profile, issuer, devices V (tracker)
**VT:** VT-049
**THR:** -
**ORK:** ORK-006, ORK-012
**Status:** Existing

### SR-V.004

**Short title:** Availability targets (TBD)
**UR:** - (docs/formal-specification/07-OPERATIONAL-RISK.md unavailability scenario)
**Component:** V
**Implementation evidence:** no baseline target exists D
**VT:** -
**THR:** -
**ORK:** ORK-013
**Status:** Missing

## 4.15 Audit requirements (SR-U)

### SR-U.001

**Short title:** Audit record for every trust decision
**UR:** UR-011 (High); Mvp.md §8 ("audit everything")
**Component:** U
**Implementation evidence:** `EnrollmentEventRepository.cs` C; `EnrollmentOrchestrator.cs` C
**VT:** VT-059
**THR:** THR-015
**ORK:** -
**Status:** Partial

### SR-U.002

**Short title:** Enrollment event completeness
**UR:** UR-009 (blocked enrollment event with reason)
**Component:** U
**Implementation evidence:** `EnrollmentEventRepository.cs` C; docs/flow.md D

**VT:** VT-059
**THR:** THR-015
**ORK:** ORK-008
**Status:** Partial

### SR-U.003

**Short title:** Structured, correlated logging
**UR:** - (Serilog configuration; `RequestIdMiddleware`)
**Component:** U
**Implementation evidence:** `src/RTSec.Kryptonian.Api/Program.cs` (Serilog, correlation/client-IP enrichers) C; docs/ARCHITECTURE.md (Observability) D
**VT:** -
**THR:** THR-015
**ORK:** -
**Status:** Existing

### SR-U.004

**Short title:** Administrative action logging
**UR:** UR-011
**Component:** U
**Implementation evidence:** log records with warnings on failures C; systematic admin-action audit records not evidenced UNKNOWN
**VT:** -
**THR:** THR-015
**ORK:** -
**Status:** Partial

### SR-U.005

**Short title:** Audit record tamper protection
**UR:** - (THR-015 model input; UR-011 rationale)
**Component:** U
**Implementation evidence:** `EnrollmentEventRepository.cs` (no append-only mechanism) C; no tamper-protection evidence UNKNOWN
**VT:** -
**THR:** THR-015
**ORK:** -
**Status:** Missing

### SR-U.006

**Short title:** Audit export capability
**UR:** - (KSPEC-004 A-6)
**Component:** U
**Implementation evidence:** no export endpoint found in controllers C; docs/formal-specification/04-SOFTWARE-DESIGN.md A-6 D
**VT:** -
**THR:** THR-015
**ORK:** -
**Status:** Missing

### SR-U.007

**Short title:** Live log ring buffer bounds
**UR:** - (`LiveLogBroadcaster` design)
**Component:** U
**Implementation evidence:** `Program.cs` (LiveLogSink/LiveLogBroadcaster singleton) C; docs/ARCHITECTURE.md D
**VT:** -
**THR:** THR-015
**ORK:** -
**Status:** Existing

## 4.16 Deployment requirements (SR-B)

### SR-B.001

**Short title:** Deployment packaging options
**UR:** UR-028
**Component:** B
**Implementation evidence:** `docker-compose.yml`, `deploy/azure/`, `installer/windows/` C; docs/DEPLOYMENT.md, docs/windows-installation.md D
**VT:** VT-056
**THR:** -
**ORK:** ORK-010, ORK-013
**Status:** Existing

### SR-B.002

**Short title:** Windows service and sandbox modes
**UR:** - (`SandboxBootstrap` Production requirement; docs/windows-sandbox.md)
**Component:** B
**Implementation evidence:** `src/RTSec.Kryptonian.Api/Program.cs` (sandbox init; UseWindowsService) C; `src/RTSec.Kryptonian.Api/SandboxBootstrap.cs` C
**VT:** VT-057
**THR:** -
**ORK:** ORK-010, ORK-015
**Status:** Existing

### SR-B.003

**Short title:** External TLS certificate provisioning
**UR:** - (`SelfSignedCaGenerator.cs`; docs/ca-backend-configuration.md)
**Component:** B
**Implementation evidence:** `src/RTSec.Kryptonian.Api/SelfSignedCaGenerator.cs` C; `Program.cs` (Kestrel HTTPS, sandbox PFX loading) C; docs/DEPLOYMENT.md D
**VT:** VT-056
**THR:** -
**ORK:** ORK-010
**Status:** Existing

### SR-B.004

**Short title:** Documented configuration settings
**UR:** - (KSPEC-005 ICD-CFG; docs/DEPLOYMENT.md)

**Component:** B

**Implementation evidence:** `src/RTSec.Kryptonian.Api/appsettings.json` C; docs/formal-specification/05-INTERFACE-CONTROL.md (configuration tables) D

**VT:** VT-057

**THR:** -

**ORK:** ORK-010

**Status:** Existing

### SR-B.005

**Short title:** CRL-over-HTTP listener restriction

**UR:** - (`Program.cs` CrlOnlyHttp middleware; KSPEC-005 ICD-CFG)

**Component:** B

**Implementation evidence:** `Program.cs` (CrlOnlyHttp middleware) C

**VT:** VT-010

**THR:** THR-013

**ORK:** -

**Status:** Existing

### SR-B.006

**Short title:** Upgrade preservation

**UR:** - (docs/formal-specification/07-OPERATIONAL-RISK.md MSI upgrade; artifacts/windows-installer/payload/docs/windows-installation.md)

**Component:** B

**Implementation evidence:** `installer/windows/` C; artifacts/windows-installer/payload/docs/windows-installation.md D; docs/formal-specification/07-OPERATIONAL-RISK.md D

**VT:** -

**THR:** -

**ORK:** ORK-011

**Status:** Existing

### SR-B.007

**Short title:** Production secret provisioning

**UR:** UR-013; KSPEC-004 P-1

**Component:** B

**Implementation evidence:** docs/DEPLOYMENT.md D; `src/RTSec.Kryptonian.Api/appsettings.Development.json` C; docs/formal-specification/04-SOFTWARE-DESIGN.md P-1 D

**VT:** VT-057

**THR:** THR-016

**ORK:** ORK-015

**Status:** Partial

## 4.17 Operational maintenance requirements (SR-O)

### SR-O.001

**Short title:** Extensible connector architecture

**UR:** UR-038

**Component:** O

**Implementation evidence:** `src/RTSec.Kryptonian.Infrastructure/Crypto/CaConnectorFactory.cs`, `src/RTSec.Kryptonian.Domain/Interfaces/` (ICaConnector) C; docs/ARCHITECTURE.md D; new connector not exercised C

**VT:** -
**THR:** -
**ORK:** -
**Status:** Existing

### SR-O.002

**Short title:** Log rotation and retention
**UR:** - (Serilog rolling file sink; docs/DEPLOYMENT.md)
**Component:** O
**Implementation evidence:** `Program.cs` (RollingInterval.Day) C; log retention settings not evidenced UNKNOWN
**VT:** -
**THR:** -
**ORK:** -
**Status:** Partial

### SR-O.003

**Short title:** External credential renewal support
**UR:** - (PR 48; docs/development.md)
**Component:** O
**Implementation evidence:** fresh handshakes observing atomic PFX replacement; expired replacement fails closed V (tracker); docs/development.md D
**VT:** VT-023
**THR:** THR-006
**ORK:** ORK-001, ORK-015
**Status:** Existing

### SR-O.004

**Short title:** Metrics endpoint
**UR:** - (docs/ARCHITECTURE.md Metrics (Future))
**Component:** O
**Implementation evidence:** no metrics endpoint in controllers C; docs/ARCHITECTURE.md D
**VT:** -
**THR:** -
**ORK:** -
**Status:** Missing

### SR-O.005

**Short title:** Dependency maintenance process
**UR:** - (PR 52)
**Component:** O
**Implementation evidence:** `.github/workflows/` C; tracker (PR 52; MailKit 4.16.0; remaining advisories) D
**VT:** VT-058
**THR:** THR-014
**ORK:** ORK-016
**Status:** Existing

## 4.18 Failure and recovery requirements (SR-X)

### SR-X.001

**Short title:** Unsupported revocation fails closed
**UR:** UR-010 (§16.4); tracker
**Component:** X
**Implementation evidence:** `CertificateRevocationService.cs` (501 on unsupported CRL generation; state unchanged) C; docs/formal-specification/07-OPERATIONAL-RISK.md D
**VT:** VT-041
**THR:** THR-008
**ORK:** ORK-008
**Status:** Existing

### SR-X.002

**Short title:** Invalid replacement credentials fail closed
**UR:** - (PR 48; docs/development.md)
**Component:** X
**Implementation evidence:** `src/Kryptonian.DICOMTls/` C; expired replacement fails closed V (tracker)
**VT:** VT-046
**THR:** THR-008, THR-012
**ORK:** ORK-015
**Status:** Existing

### SR-X.003

**Short title:** Issuer-mismatch and rotated-CA guards (409)
**UR:** - (docs/formal-specification/07-OPERATIONAL-RISK.md guards CODE-OBSERVED)
**Component:** X
**Implementation evidence:** `CertificateRevocationService.cs` (issuer guards) C; docs/formal-specification/07-OPERATIONAL-RISK.md D
**VT:** VT-026
**THR:** THR-010
**ORK:** ORK-008
**Status:** Existing

### SR-X.004

**Short title:** Unencrypted non-CRL requests refused
**UR:** - (`Program.cs` CrlOnlyHttp; tracker VERIFIED)
**Component:** X
**Implementation evidence:** `Program.cs` (403 for non-CRL on HTTP) C; HTTP listener denial V (tracker)
**VT:** -
**THR:** THR-013
**ORK:** -
**Status:** Existing

### SR-X.005

**Short title:** Activation replay rejected
**UR:** - (tracker; PR 42 atomic one-time activation)
**Component:** X

**Implementation evidence:** `artifacts/developer/verify-*/replay.txt` V; `EstController.cs` C
**VT:** VT-015
**THR:** THR-003, THR-006
**ORK:** ORK-005
**Status:** Existing

### SR-X.006

**Short title:** Database unavailability behavior
**UR:** - (docs/formal-specification/07-OPERATIONAL-RISK.md outage scenarios)
**Component:** X
**Implementation evidence:** `Program.cs` (AddDbContextCheck) C; `EstController.cs` (500 mapping with logging) C
**VT:** -
**THR:** -
**ORK:** ORK-006
**Status:** Existing

### SR-X.007

**Short title:** Backup and restore procedure
**UR:** - (docs/formal-specification/07-OPERATIONAL-RISK.md restore sequence)
**Component:** X
**Implementation evidence:** docs/formal-specification/07-OPERATIONAL-RISK.md (restore steps 1-4) D; no automated backup mechanism in code C
**VT:** VT-053
**THR:** -
**ORK:** ORK-006, ORK-012
**Status:** Partial

## 5. UR → SR coverage matrix

SR chains are exactly the KSPEC-003 `Source` edges; VT columns are derived via the SR→VT edges of §4. Stakeholder group per KSPEC-002 §2.

### UR-001

**Stakeholder group:** Hospital IT admins
**Covered by SRs (KSPEC-003 Source edges):** SR-F-REG.001, SR-F-REG.006, SR-F-CLM.001, SR-F-ADM.001
**VTs (via SRs):** VT-014, VT-017, VT-021 (SR-F-ADM.001 untested)
**UR status (KSPEC-002):** Existing
**Coverage:** Partial

### UR-002

**Stakeholder group:** Hospital IT admins
**Covered by SRs (KSPEC-003 Source edges):** SR-F-REG.002, SR-F-EST.006, SR-F-EST.012, SR-S.001
**VTs (via SRs):** VT-015, VT-048, VT-006, VT-010, VT-031
**UR status (KSPEC-002):** Existing
**Coverage:** Full

### UR-003

**Stakeholder group:** Hospital IT admins
**Covered by SRs (KSPEC-003 Source edges):** SR-F-REG.003, SR-F-REG.004, SR-F-REG.009, SR-F-ADM.001
**VTs (via SRs):** VT-014, VT-019 (SR-F-ADM.001 untested)
**UR status (KSPEC-002):** Existing
**Coverage:** Partial

### UR-004

**Stakeholder group:** Hospital IT admins
**Covered by SRs (KSPEC-003 Source edges):** SR-F-CAI.001, SR-F-ADM.001
**VTs (via SRs):** VT-040 (SR-F-ADM.001 untested)
**UR status (KSPEC-002):** Existing
**Coverage:** Partial

### UR-005

**Stakeholder group:** Hospital IT admins
**Covered by SRs (KSPEC-003 Source edges):** SR-F-CAI.002, SR-F-ADM.001
**VTs (via SRs):** VT-040 (SR-F-ADM.001 untested)
**UR status (KSPEC-002):** Existing
**Coverage:** Partial

### UR-006

**Stakeholder group:** Hospital IT admins
**Covered by SRs (KSPEC-003 Source edges):** SR-F-ADM.002, SR-F-ADM.008, SR-F-ADM.009
**VTs (via SRs):** - (no VT for any chain SR)
**UR status (KSPEC-002):** Existing
**Coverage:** None

### UR-007

**Stakeholder group:** Hospital IT admins
**Covered by SRs (KSPEC-003 Source edges):** SR-F-ADM.003, SR-F-ADM.005
**VTs (via SRs):** VT-037 (Partial; setup and last-admin guards require dedicated coverage)
**UR status (KSPEC-002):** Existing
**Coverage:** Partial

### UR-008

**Stakeholder group:** Hospital cyber personnel
**Covered by SRs (KSPEC-003 Source edges):** SR-F-REG.008, SR-F-EST.009, SR-F-CLM.001, SR-S.003, SR-S.004
**VTs (via SRs):** VT-018, VT-008, VT-021, VT-033, VT-034
**UR status (KSPEC-002):** Existing
**Coverage:** Full

### UR-009

**Stakeholder group:** Hospital cyber personnel
**Covered by SRs (KSPEC-003 Source edges):** SR-F-REG.008, SR-F-CLM.009, SR-Z.005, SR-U.002, SR-C.009
**VTs (via SRs):** VT-018, VT-027, VT-038 (SR-U.002, SR-C.009 untested)

**UR status (KSPEC-002):** Existing
**Coverage:** Partial

### UR-010

**Stakeholder group:** Hospital cyber personnel
**Covered by SRs (KSPEC-003 Source edges):** SR-F-CLM.007, SR-F-CLM.008, SR-F-CLM.009, SR-F-CAI.006, SR-F-CAI.008, SR-S.012, SR-Z.005, SR-C.005, SR-C.006, SR-C.009, SR-X.001
**VTs (via SRs):** VT-025, VT-026, VT-027, VT-028, VT-041, VT-043 (SR-S.012, SR-C.009 untested)
**UR status (KSPEC-002):** Partial
**Coverage:** Partial

### UR-011

**Stakeholder group:** Hospital cyber personnel
**Covered by SRs (KSPEC-003 Source edges):** SR-F-REG.010, SR-F-ADM.009, SR-C.010, SR-D.006, SR-U.001, SR-U.004
**VTs (via SRs):** VT-014, VT-053, VT-059 (Proposed audit completeness; SR-F-ADM.009 and SR-U.004 lack direct VTs)
**UR status (KSPEC-002):** Partial
**Coverage:** Partial

### UR-012

**Stakeholder group:** Hospital cyber personnel
**Covered by SRs (KSPEC-003 Source edges):** SR-F-CLM.005, SR-F-CLM.006, SR-F-ADM.006, SR-R.001, SR-R.003
**VTs (via SRs):** VT-029 (SR-F-ADM.006 untested; delivery not exercised)
**UR status (KSPEC-002):** Partial
**Coverage:** Partial

### UR-013

**Stakeholder group:** Hospital cyber personnel
**Covered by SRs (KSPEC-003 Source edges):** SR-F-CAI.010, SR-S.007, SR-S.008, SR-A.006, SR-D.008, SR-B.007
**VTs (via SRs):** VT-035, VT-057 (only SR-B.007 chain is Partial; rest Missing)
**UR status (KSPEC-002): Missing**
**Coverage:** Partial

### UR-014

**Stakeholder group:** Hospital cyber personnel
**Covered by SRs (KSPEC-003 Source edges):** SR-S.001, SR-S.006, SR-P.001
**VTs (via SRs):** VT-031, VT-055
**UR status (KSPEC-002):** Existing
**Coverage:** Partial

### UR-015

**Stakeholder group:** Hospital cyber personnel
**Covered by SRs (KSPEC-003 Source edges):** SR-F-ADM.001, SR-F-ADM.003, SR-F-ADM.005, SR-S.009, SR-S.013, SR-A.001, SR-A.009, SR-Z.001, SR-Z.002, SR-Z.003, SR-Z.004
**VTs (via SRs):** VT-037, VT-038, VT-039, VT-031, VT-036 (SR-F-ADM.001, SR-F-ADM.005, SR-A.009 untested)
**UR status (KSPEC-002):** Existing
**Coverage:** Partial

### UR-016

**Stakeholder group:** Device manufacturers
**Covered by SRs (KSPEC-003 Source edges):** SR-F-EST.001, SR-F-EST.003, SR-F-EST.004
**VTs (via SRs):** VT-001, VT-003, VT-004, VT-044
**UR status (KSPEC-002):** Existing
**Coverage:** Full

### UR-017

**Stakeholder group:** Device manufacturers
**Covered by SRs (KSPEC-003 Source edges):** SR-F-EST.002
**VTs (via SRs):** VT-002
**UR status (KSPEC-002):** Existing
**Coverage:** Full

### UR-018

**Stakeholder group:** Device manufacturers
**Covered by SRs (KSPEC-003 Source edges):** SR-F-EST.004, SR-F-CAI.004
**VTs (via SRs):** VT-004, VT-040, VT-045
**UR status (KSPEC-002):** Existing
**Coverage:** Full

### UR-019

**Stakeholder group:** Device manufacturers
**Covered by SRs (KSPEC-003 Source edges):** SR-F-EST.006, SR-F-EST.007, SR-F-INT.001, SR-F-INT.002
**VTs (via SRs):** VT-006, VT-011
**UR status (KSPEC-002):** Partial
**Coverage:** Partial

| UR-020 | Device software developers | SR-F-REG.005, SR-F-REG.009 | VT-016, VT-014 | Existing | Full | | UR-021 | Device software developers | SR-F-EST.008, SR-F-EST.009, SR-F-CLM.002, SR-F-CLM.003, SR-C.004, SR-P.003 | VT-007, VT-008, VT-022, VT-023, VT-024 (SR-P.003 is **Missing** - no latency budget) | Existing | Partial | | UR-022 | Device software developers | SR-F-EST.001, SR-F-EST.005 | VT-001, VT-005 | Existing | Full | | UR-023 | Device software developers | SR-F-REG.005, SR-F-EST.003, SR-F-EST.010, SR-F-EST.011, SR-F-EST.013, SR-A.007, SR-R.002 | VT-016, VT-003, VT-009, VT-012, VT-044, VT-006, VT-045 (SR-F-EST.011 **Missing**) | Existing | Partial | | UR-024 | Clinical engineering | SR-F-CLM.004, SR-F-CLM.005, SR-F-ADM.001, SR-F-ADM.008 | VT-029 (SR-F-ADM.001, SR-F-ADM.008 untested) | Existing | Partial | | UR-025 | Clinical engineering | SR-F-CLM.002 | VT-022 | Existing | Full | | UR-026 | Clinical engineering | SR-F-INT.006, SR-Z.010 | VT-038 (SR-F-INT.006 is documentation-boundary, inspection-only) | Existing | Partial | | UR-027 | Healthcare system integrators | SR-F-INT.003, SR-F-ADM.004, SR-A.001, SR-A.003, SR-Z.006 | VT-039, VT-037 (SR-F-INT.003 **Missing** - empty/stale OpenAPI) | Existing | Partial | | UR-028 | Healthcare system integrators | SR-B.001 | VT-056 (Proposed - no container deployment run recorded) | Existing | Partial | | UR-029 | Healthcare system integrators | SR-F-ADM.010, SR-V.001, SR-V.002 | VT-056 (SR-V.002 **Missing**) | Existing | Partial | | UR-030 | Enterprise PKI admins | SR-F-CAI.003, SR-F-CAI.005, SR-F-CAI.006, SR-F-CAI.007 | VT-043, VT-042, VT-040, VT-045 (hospital ADCS/EJBCA interop unverified) | Existing | Partial | | UR-031 | Enterprise PKI admins | SR-F-ADM.007, SR-F-INT.004, SR-C.001, SR-C.003 | VT-030, VT-033 (SR-F-ADM.007, SR-F-INT.004 untested) | Existing | Partial | | UR-032 | Enterprise PKI admins | SR-F-ADM.007, SR-C.002 | VT-033 (SR-F-ADM.007 untested) | Existing | Partial | | UR-033 | Enterprise PKI admins | SR-S.002 | VT-032 | Existing | Full | | UR-034 | OR.NET research community | SR-F-INT.005, SR-F-INT.007 | VT-047, VT-011 | Existing | Full | | UR-035 | OR.NET research community | SR-F-INT.006 | - (documentation-boundary, inspection-only) | Existing | Partial | | UR-036 | OR.NET research community | SR-F-INT.008 | VT-058 (Proposed - joint OR.NET vectors excluded) | Partial | Partial | | UR-037 | Cross-cutting | SR-F-CAI.009, SR-D.001, SR-D.002, SR-R.005, SR-V.003 | VT-049, VT-052, VT-051, VT-054 (PostgreSQL unverified) | Partial

| Partial | | UR-038 | Cross-cutting | SR-F-CAI.003, SR-O.001 | VT-043, VT-040 (SR-O.001 untested - new connector not exercised) | Existing | Partial |

### 5.1 Coverage summary

| Metric | Value |
|---|---|
| Stakeholder needs (UR) | 38 (UR-001 - UR-038) |
| URs traced to at least one SR | 38 of 38 (UR-007 bound to SR-F-ADM.003 and SR-F-ADM.005) |
| URs with at least one linked VT | 35 of 38 (untested: UR-006, UR-035; UR-028's only VT, VT-056, is Proposed) |
| URs fully covered (§2.3) | 10 (UR-002, UR-008, UR-016, UR-017, UR-018, UR-020, UR-022, UR-025, UR-033, UR-034) |
| URs partially covered | 26 |
| URs with no coverage | 2 (UR-006 - implemented but untested chain; UR-035 - documentation-boundary) |

## 6. Reverse matrix: VT → linked requirements

Copied from the current KSPEC-008 records. Evidence labels are not execution claims.

| VT ID | Linked requirements | Evidence status |
|---|---|---|
| VT-001 | SR-F-EST.001 | Covered - AS-IS automated test: `tests/RTSec.Kryptonian.Api.Tests/Integration/EstRouteTests.cs` and `EstIntegrationTests.cs` (assertions CODE-OBSERVED; CI execution per tracker PR 40/49). |
| VT-002 | SR-F-EST.002 | Covered - AS-IS automated test: `tests/RTSec.Kryptonian.Api.Tests/Controllers/EstControllerTests.cs` (assertions CODE-OBSERVED). |
| VT-003 | SR-F-EST.003, SR-P.002 | Covered - AS-IS automated test: `EstControllerTests.cs` (limit CODE-OBSERVED); live-boundary oversize case Proposed. |
| VT-004 | SR-F-EST.004 | Covered - AS-IS automated test: `EstControllerTests.cs`, `EstIntegrationTests.cs` (assertions CODE-OBSERVED); live-boundary curl case executed per tracker (see VT-046). |
| VT-005 | SR-F-EST.005 | Covered - AS-IS automated test: `EstRouteTests.cs` (PR 37 regression, CODE-OBSERVED); routing behavior VERIFIED per tracker ("Profile issuer routing and unknown-label rejection", PR 37). |
| VT-006 | SR-F-EST.006, SR-A.007 | Covered - executed local evidence (VERIFIED): tracker records "Independent curl HTTP Basic EST over real HTTPS; no private enrollment headers." and PR 42 (standard Basic EST bootstrap). |
| VT-007 | SR-F-EST.008, SR-A.008 | Covered - executed local evidence (VERIFIED): tracker records "renewal uses a native TLS client certificate, generates a new key and preserves approved identity"; AS-IS tests: `EstEnrollmentClientRenewalTests.cs` (CODE-OBSERVED). |

| VT ID | Linked requirements | Evidence status |
|---|---|---|
| VT-008 | SR-F-EST.009 | Covered - AS-IS automated test: `tests/RTSec.Kryptonian.Api.Tests/Authentication/ConfiguredClientCertificateTrustTests.cs` (CODE-OBSERVED); tracker records "Developer trust adds a separate issuer/hostname/purpose regression." |
| VT-009 | SR-F-EST.010 | Covered - AS-IS automated test: `EstControllerTests.cs`; client behavior: `tests/Kryptonian.MedicalDevice.Enrollment.Tests/EstEnrollmentClientPendingTests.cs` (both CODE-OBSERVED). |
| VT-010 | SR-F-EST.012, SR-B.005 | Covered - executed local evidence (VERIFIED): tracker records "HTTP listener denies non-CRL requests"; AS-IS test: `EstRouteTests.cs` (CODE-OBSERVED). |
| VT-011 | SR-F-EST.007, SR-F-INT.002, SR-F-INT.007 | Partially covered - standard-path independence VERIFIED per tracker ("no private enrollment headers"); legacy-header compatibility inspection Proposed (SR-F-EST.007 status Partial). |
| VT-012 | SR-F-EST.013, SR-F-EST.011 (Missing) | Proposed - SR-F-EST.011 is Missing at baseline; SR-F-EST.013 has Inspection-level support via existing error paths (CODE-OBSERVED) but no assertion test exists. |
| VT-013 | SR-F-EST.014 (Missing) | Proposed - requirement Missing at baseline (KSPEC-003 register). |
| VT-014 | SR-F-REG.001, SR-F-REG.009, SR-F-REG.010, SR-F-REG.003 | Covered - AS-IS automated test: `tests/RTSec.Kryptonian.Application.Tests/Services/DeviceServiceActivationTests.cs` (CODE-OBSERVED); admin portal demonstration per tracker's twenty device enrollment/lifecycle tests. |
| VT-015 | SR-F-REG.002, SR-X.005 | Covered - executed local evidence (VERIFIED): tracker records "One-time activation replay rejected". AS-IS tests: `DeviceServiceActivationTests.cs`, `tests/RTSec.Kryptonian.Infrastructure.Tests/Data/DeviceActivationConcurrencyTests.cs` (CODE-OBSERVED). |
| VT-016 | SR-F-REG.005 | Covered - executed local evidence (VERIFIED): tracker records PR 38 "Authenticated enrollment identity binding"; AS-IS test: `DeviceServiceActivationTests.cs` (CODE-OBSERVED). |
| VT-017 | SR-F-REG.006 | Covered - AS-IS automated test: `DeviceServiceActivationTests.cs` (pending-state assertions CODE-OBSERVED). |
| VT-018 | SR-F-REG.008 | Covered - AS-IS automated test: `tests/Kryptonian.MedicalDevice.Enrollment.Tests/GatewayTrustTests.cs` (CODE-OBSERVED). |
| VT-019 | SR-F-REG.004 | Proposed - state-machine traversal test not present as a dedicated AS-IS test; partial coverage via `DeviceServiceActivationTests.cs` (CODE-OBSERVED). |
| VT-020 | SR-F-REG.007 (Missing), SR-Z.008 | Proposed - SR-F-REG.007 is Missing at baseline. |

| VT ID | Linked requirements | Evidence status |
|---|---|---|
| VT-021 | SR-F-CLM.001 | Covered - AS-IS automated test: `tests/RTSec.Kryptonian.Application.Tests/Services/EnrollmentOrchestratorTests.cs` (CODE-OBSERVED). |
| VT-022 | SR-F-CLM.002, SR-C.004 | Covered - executed local evidence (VERIFIED): tracker records "Twenty device enrollment/lifecycle tests passed including actual Schannel mTLS with the public client's returned certificate"; renewal evidence "renewal uses a native TLS client certificate". AS-IS tests: `EstEnrollmentClientRenewalTests.cs` (CODE-OBSERVED). |
| VT-023 | SR-F-CLM.003, SR-A.008, SR-O.003 | Covered - executed local evidence (VERIFIED): tracker records renewal "generates a new key and preserves approved identity" and the Schannel key-persistence fix (PR 50) with a runnable regression (`InstalledCertificateRenewalTests.cs`, CODE-OBSERVED). |
| VT-024 | SR-C.004 | Covered - AS-IS automated test: `EstEnrollmentClientRenewalTests.cs` (window logic CODE-OBSERVED). |
| VT-025 | SR-F-CLM.007, SR-C.005, SR-C.006 | Covered - executed local evidence (VERIFIED): tracker records "Administrator revocation followed by native online X509Chain reporting Revoked, independently of registry lookup and without flushing the system CRL cache."; AS-IS tests: `CertificateRevocationServiceTests.cs`, `IssuerCrlStatePersistenceTests.cs`, `PkcsServiceTests.cs` (CODE-OBSERVED). |
| VT-026 | SR-F-CLM.008, SR-R.004, SR-X.003 | Covered - AS-IS automated test: `CertificateRevocationServiceTests.cs` (transactional and conflict paths CODE-OBSERVED); `UnitOfWork.cs` conflict handling CODE-OBSERVED. |
| VT-027 | SR-F-CLM.009 | Covered - AS-IS automated test: `CertificateRevocationServiceTests.cs` (CODE-OBSERVED); revocation-online enforcement at peers VERIFIED per tracker (see VT-028). |
| VT-028 | SR-C.007 | Covered - executed local evidence (VERIFIED): tracker records "Administrator revocation followed by native online X509Chain reporting Revoked, independently of registry lookup and without flushing the system CRL cache." and "Both peers enforce issuer, TLS purpose and online revocation." |
| VT-029 | SR-F-CLM.004, SR-F-CLM.005, SR-F-CLM.006, SR-R.001, SR-R.003 | Partially covered - AS-IS automated test: `NotificationDispatcherTests.cs` (CODE-OBSERVED); watcher fault-tolerance and end-to-end email delivery Proposed (tracker records delivery behavior at baseline as unexercised). |
| VT-030 | SR-C.001, SR-C.003 | Covered - AS-IS automated test: `tests/RTSec.Kryptonian.Application.Tests/Services/EnrollmentCertificatePolicyTests.cs` and `EstProfilePartialUpdateTests.cs` (CODE-OBSERVED). |

| VT ID | Linked requirements | Evidence status |
|---|---|---|
| VT-031 | SR-S.001, SR-S.013 | Partially covered - HTTPS-only EST VERIFIED per tracker (see VT-010); CORS assertions Proposed (no dedicated AS-IS test observed). |
| VT-032 | SR-S.002 | Covered - AS-IS automated test: `EnrollmentCertificatePolicyTests.cs` (CODE-OBSERVED); PR 43 ("CSR and returned-certificate policy enforcement") per tracker. |
| VT-033 | SR-S.003, SR-C.002 | Covered - executed local evidence (VERIFIED): tracker records "Gateway restart on populated SQLite preserved configured profile, issuer and devices."; AS-IS tests: `EstProfilePersistenceTests.cs`, `EstProfilePartialUpdateTests.cs` (CODE-OBSERVED). |
| VT-034 | SR-S.004, SR-S.005 (Missing) | Partially covered - executed local evidence (VERIFIED): tracker records "Direct forwarded-certificate spoof rejected"; AS-IS test: `tests/RTSec.Kryptonian.Api.Tests/Middleware/CertificateForwardingGuardTests.cs` (CODE-OBSERVED); SR-S.005 (authenticated forwarder) Missing → that portion Proposed. |
| VT-035 | SR-S.007 (Missing), SR-A.006 (Missing) | Proposed - SR-S.007/SR-A.006 Missing at baseline (hard-coded dev fallback recorded as a weak control in KSPEC-003 §22). |
| VT-036 | SR-S.009 | Proposed - Inspection-method requirement; no automated test applicable. (Code path CODE-OBSERVED in `UsersController.cs`/auth services per KSPEC-003 evidence.) |
| VT-037 | SR-A.001, SR-A.002, SR-A.010, SR-F-ADM.003 | Partially covered - admin-setup behavior is documented; device lifecycle tests do not establish user-management or JWT coverage (DOCUMENTED only); dedicated token-validation tests Proposed (no dedicated AS-IS test file observed under `tests/RTSec.Kryptonian.Api.Tests/Authentication/`). |
| VT-038 | SR-Z.001, SR-Z.002, SR-Z.003, SR-Z.004, SR-Z.005, SR-Z.010 | Covered - AS-IS automated tests: `tests/RTSec.Kryptonian.Api.Tests/Controllers/DevicesControllerAuthorizationTests.cs`, `CertificateRevocationControllerAuthorizationTests.cs` (CODE-OBSERVED). |
| VT-039 | SR-A.003, SR-A.004, SR-A.005, SR-Z.006, SR-F-ADM.004, UR-027 | Proposed - behavior CODE-OBSERVED in `ApiKeyAuthenticationHandler.cs` per KSPEC-003 evidence, but no dedicated AS-IS test file observed; assertion set Proposed. |
| VT-040 | SR-F-CAI.001, SR-F-CAI.002, SR-F-CAI.004 | Covered - AS-IS automated test: `tests/RTSec.Kryptonian.Application.Tests/Services/CaBackendServiceTests.cs` (CODE-OBSERVED). |
| VT-041 | SR-F-CAI.008, SR-F-CAI.009, SR-X.001 | Covered - AS-IS automated tests: `tests/RTSec.Kryptonian.Infrastructure.Tests/Crypto/SelfSignedCaConnectorTests.cs`, `CertificateRevocationServiceTests.cs` (fail-closed path CODE-OBSERVED); live revocation per tracker (VT-025). |

| VT ID | Linked requirements | Evidence status |
|---|---|---|
| VT-042 | SR-F-CAI.007 | Covered - AS-IS automated tests: `tests/RTSec.Kryptonian.Infrastructure.Tests/Acme/AcmeCaConnectorTests.cs`, `Http01ChallengeStoreTests.cs`, `AcmeConnectorConfigTests.cs`, `WellKnownServersTests.cs` (CODE-OBSERVED); dns-01 remains Partial (SR-F-CAI.007). |
| VT-043 | SR-F-CAI.005, SR-F-CAI.006, SR-F-CAI.003 | Proposed - tracker records "actual ADCS/EJBCA hospital enrollment/revocation interoperability remains unverified"; connector code CODE-OBSERVED (`AdcsCaConnector.cs`, `EjbcaCaConnector.cs`, `ScepClient.cs`). |
| VT-044 | SR-F-EST.003, SR-F-EST.004, SR-F-EST.013, SR-P.002 | Partially covered - `EstControllerTests.cs`/`EstRouteTests.cs` cover core rejections (CODE-OBSERVED); the full mutation matrix Proposed. |
| VT-045 | SR-R.002, SR-F-CAI.004 | Covered - AS-IS automated test: `EnrollmentOrchestratorTests.cs` (error paths CODE-OBSERVED). |
| VT-046 | SR-X.002 | Covered - executed local evidence (VERIFIED): tracker records "Five loopback proxy tests passed, including unknown/expired/revoked client rejection and fresh handshakes observing atomic PFX replacement; expired replacement fails closed."; AS-IS tests: `DimseTlsProxyWorkerTests.cs`, `ServerCertificateRotationTests.cs` (CODE-OBSERVED). |
| VT-047 | SR-F-INT.005, SR-C.007 | Covered - executed local evidence (VERIFIED): tracker records "Two actual mutual-TLS DICOM C-STORE transfers followed by received-file reopen and SOP Instance UID comparison. Both peers enforce issuer, TLS purpose and online revocation." with SOP UIDs `2.25.154518358314734480382348393848679450333` and `2.25.281306672341327719638925984637794989584`; parser unit test `tests/RTSec.Kryptonian.Bridge.Tests/DicomWebMultipartParserTests.cs`. |
| VT-048 | SR-F-REG.002, SR-R.004 | Covered - AS-IS automated test: `tests/RTSec.Kryptonian.Infrastructure.Tests/Data/DeviceActivationConcurrencyTests.cs` (CODE-OBSERVED); replay rejection VERIFIED per tracker (VT-015). |
| VT-049 | SR-D.001, SR-V.003 | Covered - executed local evidence (VERIFIED): tracker records "Gateway restart on populated SQLite preserved configured profile, issuer and devices." |
| VT-050 | SR-D.005 | Covered - executed local evidence (VERIFIED): tracker records "SQLite's unspecified DateTime kind shifted refreshed CRL revocation times five hours into the future on this host ... fixed with runnable regressions." |
| VT-051 | SR-D.003 | Covered - AS-IS automated test: `tests/RTSec.Kryptonian.Infrastructure.Tests/Data/SchemaUpgradesTests.cs` (CODE-OBSERVED). |

| VT ID | Linked requirements | Evidence status |
|---|---|---|
| VT-052 | SR-D.002, UR-037 | Proposed - tracker records "PostgreSQL schema upgrades are implemented but only SQLite persistence was exercised." |
| VT-053 | SR-X.007 (Partial), SR-D.006 | Proposed - no restore drill recorded at baseline. |
| VT-054 | SR-R.005 | Partially covered - cancellation handling CODE-OBSERVED in `CertificateExpiryWatcher.cs` (Inspection-level, SR-R.005 method I); mid-enrollment stop test Proposed. |
| VT-055 | SR-S.006, SR-P.001, UR-014 | Proposed - tracker/UR-014 note rate limiting as configuration-documented with effectiveness not separately evidenced; production limits TBD (SR-S.006). |
| VT-056 | SR-B.001, SR-B.003, SR-V.001, SR-V.002 (Missing), SR-F-ADM.010, UR-028, UR-029 | Proposed - no container deployment run recorded in the tracker (Windows/SQLite developer path is the recorded evidence). |
| VT-057 | SR-B.002, SR-B.004, SR-B.007 (Partial) | Covered - AS-IS automated test: `tests/RTSec.Kryptonian.Api.Tests/SandboxBootstrapTests.cs` (CODE-OBSERVED); sandbox mode exercised by the developer verifier evidence path per tracker. |
| VT-058 | SR-O.005, SR-S.014, SR-F-INT.008 (Proposed joint vectors excluded) | Covered - executed local evidence (VERIFIED): tracker records "Windows GitHub CI builds the UI, tests the solution and builds the standalone proxy." and the npm-audit reduction "from six vulnerable packages to zero; CI now rejects high/critical UI dependency advisories", with the two remaining high advisories listed as deployment blockers. Eighteen pre-existing Windows infrastructure skips acknowledged. |
| VT-059 | SR-C.010, SR-U.001, SR-U.002 | Proposed - this review observed missing branches; this acceptance test has not been implemented or executed. |
| VT-060 | SR-F-REG.002, SR-R.004 | Proposed - consumption order is CODE-OBSERVED; failure/crash/pending recovery execution is absent. |

# 7. Security threat (THR) and operational risk (ORK) linkage

## 7.1 THR-001 - THR-018 (KSPEC-006 §7/§8 → SR/VT)

Specific SR/VT bindings combine the exact IDs recorded in KSPEC-008 `Linked THR/ORK` fields with the KSPEC-006 §8 prefix intent. Band per KSPEC-006 §9.3.

### THR-001

**STRIDE (primary):** S
**Band:** Medium-High
**Linked SR prefixes (KSPEC-006 §8):** SR-A, SR-Z, SR-C
**Specific SRs (resolved via VTs):** SR-F-EST.009, SR-F-REG.005, SR-F-INT.005, SR-C.007
**Linked VTs:** VT-008, VT-016, VT-047

### THR-002

**STRIDE (primary):** E

**Band:** High
**Linked SR prefixes (KSPEC-006 §8):** SR-Z, SR-S, SR-C
**Specific SRs (resolved via VTs):** SR-F-EST.001, SR-F-REG.006, SR-F-CLM.001
**Linked VTs:** VT-001, VT-017, VT-021

### THR-003

**STRIDE (primary):** S, R
**Band:** High
**Linked SR prefixes (KSPEC-006 §8):** SR-A, SR-S, SR-C
**Specific SRs (resolved via VTs):** SR-F-EST.006, SR-F-EST.012, SR-F-REG.001/.002/.003/.009/.010, SR-A.007, SR-S.001, SR-S.013, SR-X.005, SR-R.004
**Linked VTs:** VT-006, VT-010, VT-014, VT-015, VT-031, VT-048

### THR-004

**STRIDE (primary):** T
**Band:** Medium-High
**Linked SR prefixes (KSPEC-006 §8):** SR-C, SR-S
**Specific SRs (resolved via VTs):** SR-F-EST.003, SR-F-EST.013, SR-F-EST.014, SR-P.002, SR-S.002, SR-C.001, SR-C.003
**Linked VTs:** VT-003, VT-013, VT-030, VT-032, VT-044

### THR-005

**STRIDE (primary):** T, E
**Band:** Medium-High
**Linked SR prefixes (KSPEC-006 §8):** SR-C, SR-S, SR-F
**Specific SRs (resolved via VTs):** SR-F-EST.004, SR-F-CAI.003/.005/.006/.007, SR-S.002, SR-C.001, SR-C.003
**Linked VTs:** VT-004, VT-030, VT-032, VT-042, VT-043

### THR-006

**STRIDE (primary):** R
**Band:** Low-Medium
**Linked SR prefixes (KSPEC-006 §8):** SR-A, SR-C
**Specific SRs (resolved via VTs):** SR-F-EST.008, SR-F-REG.002, SR-A.008, SR-F-CLM.003, SR-O.003, SR-X.005
**Linked VTs:** VT-007, VT-015, VT-023, VT-048

### THR-007

**STRIDE (primary):** E, S, I
**Band:** High
**Linked SR prefixes (KSPEC-006 §8):** SR-A, SR-Z, SR-S, SR-U
**Specific SRs (resolved via VTs):** SR-A.001-.005, SR-A.010, SR-Z.001-.007, SR-F-ADM.003, SR-F-ADM.004, SR-S.007
**Linked VTs:** VT-035, VT-037, VT-038, VT-039

### THR-008

**STRIDE (primary):** E, T, S
**Band:** High
**Linked SR prefixes (KSPEC-006 §8):** SR-C, SR-S, SR-X
**Specific SRs (resolved via VTs):** SR-F-CAI.008, SR-F-CAI.009, SR-X.001, SR-X.002

**Linked VTs:** VT-041, VT-043, VT-046

### THR-009

**STRIDE (primary):** S, I, E
**Band:** High
**Linked SR prefixes (KSPEC-006 §8):** SR-A, SR-S, SR-U
**Specific SRs (resolved via VTs):** SR-A.001, SR-A.002, SR-A.006, SR-A.010, SR-S.007, SR-S.009, SR-F-ADM.005
**Linked VTs:** VT-035, VT-036, VT-037

### THR-010

**STRIDE (primary):** D, T, Rp
**Band:** High
**Linked SR prefixes (KSPEC-006 §8):** SR-C, SR-V, SR-U
**Specific SRs (resolved via VTs):** SR-F-CLM.007/.008/.009, SR-C.005/.006/.007/.008/.009, SR-R.004, SR-X.003
**Linked VTs:** VT-025, VT-026, VT-027, VT-028

### THR-011

**STRIDE (primary):** D
**Band:** High
**Linked SR prefixes (KSPEC-006 §8):** SR-V, SR-C, SR-O
**Specific SRs (resolved via VTs):** SR-F-CLM.002/.003/.004/.005/.006, SR-C.004, SR-R.001, SR-R.003
**Linked VTs:** VT-022, VT-023, VT-024, VT-029

### THR-012

**STRIDE (primary):** E, S
**Band:** Medium-High
**Linked SR prefixes (KSPEC-006 §8):** SR-S, SR-Z, SR-C
**Specific SRs (resolved via VTs):** SR-F-EST.002/.005, SR-F-REG.008, SR-S.003, SR-C.002, SR-X.002
**Linked VTs:** VT-002, VT-005, VT-018, VT-033, VT-046

### THR-013

**STRIDE (primary):** D
**Band:** Medium
**Linked SR prefixes (KSPEC-006 §8):** SR-V, SR-P, SR-R
**Specific SRs (resolved via VTs):** SR-F-EST.003/.012, SR-F-REG.007, SR-Z.008, SR-S.006, SR-P.001, SR-P.002, SR-B.005
**Linked VTs:** VT-003, VT-010, VT-020, VT-044, VT-055

### THR-014

**STRIDE (primary):** T, I
**Band:** Critical (deployment blockers)
**Linked SR prefixes (KSPEC-006 §8):** SR-B, SR-S, SR-O
**Specific SRs (resolved via VTs):** SR-S.014, SR-O.005
**Linked VTs:** VT-058

### THR-015

**STRIDE (primary):** Rp, T
**Band:** High
**Linked SR prefixes (KSPEC-006 §8):** SR-U, SR-D, SR-Z
**Specific SRs (resolved via VTs):** SR-U.001-.007, SR-D.006
**Linked VTs:** VT-059 (Proposed)

### THR-016

**STRIDE (primary):** I, E
**Band:** High
**Linked SR prefixes (KSPEC-006 §8):** SR-S, SR-D, SR-B
**Specific SRs (resolved via VTs):** SR-S.001, SR-S.007, SR-S.008, SR-S.010, SR-S.011, SR-S.013, SR-A.006, SR-D.007, SR-D.008, SR-B.007
**Linked VTs:** VT-031, VT-035

### THR-017

**STRIDE (primary):** S, T
**Band:** Medium-High
**Linked SR prefixes (KSPEC-006 §8):** SR-A, SR-Z, SR-U
**Specific SRs (resolved via VTs):** SR-S.004, SR-S.005
**Linked VTs:** VT-034

### THR-018

**STRIDE (primary):** I
**Band:** Low-Medium
**Linked SR prefixes (KSPEC-006 §8):** SR-S, SR-U, SR-D
**Specific SRs (resolved via VTs):** SR-U.003, SR-U.007, SR-S.013
**Linked VTs: - (no VT)**

## 7.2 ORK-001 - ORK-016 (KSPEC-007 §3/§7.1 → SR/VT)

Target-area intent is KSPEC-007 §7.1; specific SR/VT bindings come from KSPEC-008 VT records. Band per KSPEC-007 §4 FMEA summary. Revision 0.2 resolves the prior unallocated interoperability prefix; current references use SR-F-INT or SR-F-CAI as appropriate.

### ORK-001

**Failure mode:** Certificate renewal failure
**Band:** High
**Target areas (KSPEC-007 §7.1):** SR-C, SR-R, SR-X
**Specific SRs (resolved via VTs):** SR-F-CLM.002/.003, SR-C.004, SR-F-CLM.004/.005/.006, SR-R.001, SR-R.003, SR-O.003
**Linked VTs:** VT-022, VT-023, VT-024, VT-029

### ORK-002

**Failure mode:** Device communication interruption
**Band:** High
**Target areas (KSPEC-007 §7.1):** SR-V, SR-F-INT, SR-R
**Specific SRs (resolved via VTs):** SR-F-INT.005, SR-C.007

**Linked VTs:** VT-047

### ORK-003

**Failure mode:** CA unavailability
**Band:** Medium
**Target areas (KSPEC-007 §7.1):** SR-C, SR-F-CAI, SR-X
**Specific SRs (resolved via VTs):** SR-F-CAI.001/.002/.003/.004/.005/.006, SR-R.002
**Linked VTs:** VT-040, VT-043, VT-045

### ORK-004

**Failure mode:** Incorrect certificate policy configuration
**Band:** High
**Target areas (KSPEC-007 §7.1):** SR-A, SR-Z, SR-S, SR-C
**Specific SRs (resolved via VTs):** SR-F-CLM.001, SR-C.001, SR-C.003
**Linked VTs:** VT-021, VT-030

### ORK-005

**Failure mode:** Unauthorized trust relationship
**Band:** High[1]
**Target areas (KSPEC-007 §7.1):** SR-A, SR-Z, SR-S, SR-C
**Specific SRs (resolved via VTs):** SR-F-EST.006, SR-F-REG.002/.008, SR-S.003, SR-A.007, SR-X.005, SR-R.004
**Linked VTs:** VT-006, VT-015, VT-018, VT-033, VT-048

### ORK-006

**Failure mode:** Database corruption
**Band:** Critical
**Target areas (KSPEC-007 §7.1):** SR-D, SR-X, SR-O
**Specific SRs (resolved via VTs):** SR-D.001/.002/.006, SR-V.003, SR-X.007
**Linked VTs:** VT-049, VT-052, VT-053

### ORK-007

**Failure mode:** Certificate expiration (unmanaged)
**Band:** High
**Target areas (KSPEC-007 §7.1):** SR-C, SR-R, SR-X
**Specific SRs (resolved via VTs):** SR-F-CLM.004/.005/.006, SR-R.001, SR-R.003
**Linked VTs:** VT-029

### ORK-008

**Failure mode:** Failed revocation
**Band:** Critical
**Target areas (KSPEC-007 §7.1):** SR-C, SR-F-CAI, SR-X
**Specific SRs (resolved via VTs):** SR-F-EST.009, SR-F-CLM.007/.008, SR-C.005/.006/.007/.009, SR-F-CAI.006/.008, SR-R.004, SR-X.003
**Linked VTs:** VT-008, VT-025, VT-026, VT-028, VT-043

### ORK-009

**Failure mode:** Clock synchronization errors
**Band:** Critical[1]
**Target areas (KSPEC-007 §7.1):** SR-R, SR-C, SR-D
**Specific SRs (resolved via VTs):** SR-D.005, SR-S.012
**Linked VTs:** VT-050

### ORK-010

**Failure mode:** Configuration errors
**Band:** High
**Target areas (KSPEC-007 §7.1):** SR-B, SR-S, SR-O, SR-X
**Specific SRs (resolved via VTs):** SR-F-CAI.001/.002, SR-F-ADM.008/.010, SR-B.001/.002/.004, SR-V.001
**Linked VTs:** VT-040, VT-056, VT-057

### ORK-011

**Failure mode:** Software upgrade failure
**Band:** Critical
**Target areas (KSPEC-007 §7.1):** SR-B, SR-S, SR-O, SR-X
**Specific SRs (resolved via VTs):** SR-D.003, SR-B.006
**Linked VTs:** VT-051

### ORK-012

**Failure mode:** Backup and recovery failure
**Band:** Critical[1]
**Target areas (KSPEC-007 §7.1):** SR-D, SR-X, SR-O
**Specific SRs (resolved via VTs):** SR-D.001/.002/.006/.007, SR-V.003, SR-X.007
**Linked VTs:** VT-049, VT-052, VT-053

### ORK-013

**Failure mode:** Network partitioning
**Band:** High
**Target areas (KSPEC-007 §7.1):** SR-V, SR-F-INT, SR-R
**Specific SRs (resolved via VTs):** SR-B.001, SR-F-ADM.010, SR-V.001, SR-V.002
**Linked VTs:** VT-056

### ORK-014

**Failure mode:** Notification delivery failure
**Band:** Critical[1]
**Target areas (KSPEC-007 §7.1):** SR-O, SR-R, SR-U
**Specific SRs (resolved via VTs):** SR-F-ADM.006, SR-F-CLM.005/.006, SR-R.001, SR-R.003
**Linked VTs:** VT-029

### ORK-015

**Failure mode:** Secrets / credential rotation failure
**Band:** Critical[1]
**Target areas (KSPEC-007 §7.1):** SR-S, SR-A, SR-O, SR-B

**Specific SRs (resolved via VTs):** SR-F-CLM.003, SR-A.008, SR-O.003, SR-X.002, SR-B.002/.007, SR-S.010
**Linked VTs:** VT-023, VT-046, VT-057

### ORK-016

**Failure mode:** Dependency vulnerability exposure
**Band:** High
**Target areas (KSPEC-007 §7.1):** SR-S, SR-A, SR-O, SR-B
**Specific SRs (resolved via VTs):** SR-S.014, SR-O.005
**Linked VTs:** VT-058

[1] Band reached or raised via the KSPEC-007 §2.5 overrides.

## 8. Reverse coverage statistics (SR → VT)

114 of 154 SRs link to at least one specified VT; 40 have no direct VT link. A proposed VT is a plan, not executed evidence.

### SR-F-REG

**SRs:** 10
**VT-linked:** 10
**Not VT-linked:** 0

### SR-F-EST

**SRs:** 14
**VT-linked:** 14
**Not VT-linked:** 0

### SR-F-CLM

**SRs:** 9
**VT-linked:** 9
**Not VT-linked:** 0

### SR-F-CAI

**SRs:** 10
**VT-linked:** 9
**Not VT-linked:** 1

### SR-F-ADM

**SRs:** 10
**VT-linked:** 3
**Not VT-linked:** 7

### SR-F-INT

**SRs:** 8
**VT-linked:** 4
**Not VT-linked:** 4

### SR-S

**SRs:** 14
**VT-linked:** 10
**Not VT-linked:** 4

### SR-A

**SRs:** 10
**VT-linked:** 9
**Not VT-linked:** 1

### SR-Z

**SRs:** 10
**VT-linked:** 8
**Not VT-linked:** 2

### SR-C

**SRs:** 10
**VT-linked:** 8
**Not VT-linked:** 2

### SR-D

**SRs:** 9
**VT-linked:** 5
**Not VT-linked:** 4

### SR-P

**SRs:** 5
**VT-linked:** 2
**Not VT-linked:** 3

### SR-R

**SRs:** 5
**VT-linked:** 5
**Not VT-linked:** 0

### SR-V

**SRs:** 4
**VT-linked:** 3
**Not VT-linked:** 1

### SR-U

**SRs:** 7
**VT-linked:** 2
**Not VT-linked:** 5

### SR-B

**SRs:** 7
**VT-linked:** 6
**Not VT-linked:** 1

### SR-O

**SRs:** 5
**VT-linked:** 2
**Not VT-linked:** 3

### SR-X

**SRs:** 7
**VT-linked:** 5
**Not VT-linked:** 2

### Total

**SRs:** 154
**VT-linked:** 114
**Not VT-linked:** 40

## 9. Gap lists

These lists feed KSPEC-010 (GAP-*) and are stated here as traceability findings only; no remediation is planned in this document.

## 9.1 Unimplemented requirements (KSPEC-003 status Missing, 18 of 154)

| SR | Short title | KSPEC-002 impact |
|---|---|---|
| SR-F-REG.007 | Anonymous endpoint abuse controls | VT-020 Proposed (TO-BE) |
| SR-F-EST.011 | Deterministic pending semantics per backend | Client error diagnosis (UR-023) incomplete |
| SR-F-EST.014 | CSR attributes (`csrattrs`) endpoint | KSPEC-004 P-3, awaiting approval |
| SR-F-CAI.010 | Secure connector credential handling | UR-013 (Missing) |
| SR-F-INT.003 | Authoritative OpenAPI admin contract | `OpenAPI.Client.yaml` empty; `OpenAPI.Schema.yaml` stale |
| SR-S.005 | Authenticated forwarder identity | XFCC trusted by IP only (P-2) |
| SR-S.007 | No hard-coded signing secrets | Dev fallback constant in `Program.cs` |
| SR-S.008 | Secrets at rest | UR-013 |
| SR-S.012 | Configurable CRL lifetime | 60 s prototype value (A-4) |
| SR-A.006 | JWT signing secret provisioning | Same baseline finding as SR-S.007 |
| SR-D.004 | Upgrade safety boundary | Upgrade DDL outside transaction/backup boundary |
| SR-D.008 | Sensitive field encryption at rest | UR-013 |
| SR-P.003 | Enrollment latency targets (TBD) | No baseline budget; value TBD, not invented |
| SR-V.002 | Component-level health reporting | Health lacks connector components (P-7) |
| SR-V.004 | Availability targets (TBD) | No baseline target |
| SR-U.005 | Audit record tamper protection | THR-015 dominant residual risk |
| SR-U.006 | Audit export capability | KSPEC-004 A-6 |
| SR-O.004 | Metrics endpoint | docs/ARCHITECTURE.md marks as future (P-4) |

## 9.2 Requirements with no direct VT link (40 of 154)

This is a linkage gap, not a statement that the others are completely tested.

- SR-F-CAI.010
- SR-F-ADM.001
- SR-F-ADM.002
- SR-F-ADM.005
- SR-F-ADM.006
- SR-F-ADM.007
- SR-F-ADM.008
- SR-F-ADM.009
- SR-F-INT.001

- SR-F-INT.003
- SR-F-INT.004
- SR-F-INT.006
- SR-S.008
- SR-S.010
- SR-S.011
- SR-S.012
- SR-A.009
- SR-Z.007
- SR-Z.009
- SR-C.008
- SR-C.009
- SR-D.004
- SR-D.007
- SR-D.008
- SR-D.009
- SR-P.003
- SR-P.004
- SR-P.005
- SR-V.004
- SR-U.003
- SR-U.004
- SR-U.005
- SR-U.006
- SR-U.007
- SR-B.006
- SR-O.001
- SR-O.002
- SR-O.004
- SR-X.004
- SR-X.006

## 9.3 Untraceable code behavior (observed behavior with no covering SR, or only Partial coverage)

1. Legacy activation-header fallback path in `EstController.cs` has **no disable switch** (SR-F-EST.007 Partial; KSPEC-002 §16.3 boundary; KSPEC-004 A-8).

2. `Certificate.EncryptedPrivateKeyPem` field observed with no traced writer - dormant schema or unarchived behavior (KSPEC-004 §17 item 4; SR-S.011 Proposed).

3. Synthetic demo enrollment records / demo-enroll endpoint not distinguished in UI semantics beyond SR-D.009 (Partial, Low).

4. Hard-coded 60-second CRL lifetime (SR-S.012 Missing; SR-C.008 Partial) - prototype value with no policy hook.

5. `ApiKeyAuthenticationHandler` development bypass (SR-A.009) - implemented and documented, but no VT exercises the gating conditions.

6. XFCC header trusted from IP-set membership only (SR-S.005 Missing; KSPEC-004 P-2).

7. Hard-coded JWT dev-secret fallback with silent fallback behavior (no explicit warning for the API JWT fallback) (SR-S.007 / SR-A.006 Missing).

## 9.4 Missing interface definitions

1. `OpenAPI.Client.yaml` empty; `OpenAPI.Schema.yaml` stale (SR-F-INT.003 Missing; KSPEC-005 open item) - no authoritative client-facing contract.

2. Pending-enrollment trigger matrix undefined: which CA backend states produce `IsPending` (SR-F-EST.011 Missing; KSPEC-005 ICD-EST.004 open item).

3. Self-service request authorization model unconfirmed (SR-Z.009 Proposed; KSPEC-005 open item 6; SR-F-REG.007 Missing).

4. `POST /api/cas/{id}/test` role policy undefined (SR-Z.007 Partial; KSPEC-005 open item 4).

5. `csrattrs` response schema absent (SR-F-EST.014 Missing; KSPEC-004 P-3).

6. Prior unallocated interoperability prefix references were corrected in revision 0.2; current risk bindings use SR-F-INT or SR-F-CAI as appropriate.

## 9.5 Incomplete design decisions (KSPEC-004 §16.2/§16.3 and TBD items)

1. **A-1**: device status model lacks an `Untrusted`/`Retired` distinction - SR alignment not yet allocated.

2. **A-2 / SR-S.011**: whether the gateway archives device private keys - policy decision open; field present.

3. **A-3**: demo OID namespace `1.3.6.1.4.1.99999.*` - enterprise PEN decision open.

4. **A-4 / SR-S.012**: CRL lifetime policy - value TBD (KSPEC-007 TBD-1).

5. **A-5 / SR-C.008**: stale-revocation-data and established-session handling - normative statement pending.

6. **A-6 / SR-U.006**: audit export mapping (ATNA-style) - PROPOSED scope.

7. **A-7**: out-of-application renewal mechanism - KSPEC-007 TBD-3.

8. **A-9 / SR-D.002**: PostgreSQL provider exercise - KSPEC-007 TBD-5.

9. **P-1 / SR-B.007**: managed secret store; **P-2 / SR-S.005**: forwarder authentication; **P-3 / SR-F-EST.014**: `csrattrs`; **P-4 / SR-O.004**: metrics; **P-5**: activation-consumption concurrency guard; **P-6**: notification outbox (SR-R.003 Partial); **P-7 / SR-V.002**: per-backend connector health.

10. Unconfirmed thresholds recorded as TBD, never invented (KSPEC-002 §16.5): SR-F-REG.007 (abuse-control threshold), SR-S.006 (production rate limits), SR-S.008 (encryption approach), SR-C.003 (certificate-lifetime policy, TBD-001), SR-D.006 (retention period), SR-P.001 (production capacity), SR-P.003 (latency budget), SR-R.003 (delivery reliability), SR-V.004 (availability targets), SR-O.002 (log retention), SR-O.004 (metrics format), SR-F-CAI.010 (secrets mechanism); SR-A.006 inherits the ≥32-character recommendation pending confirmation.

# 10. Identifier consistency verification

Checks performed while building every table (source documents re-read, not summarized from memory):

| Check | Result |
|---|---|
| VT IDs against KSPEC-008 | All 60 VT records (VT-001 - VT-060) present, each with Test ID, linked requirements, preconditions, inputs, procedure, expected results, acceptance criteria, evidence status. KSPEC-008 was verified structurally complete and well-formed; **no integrity fixes were required**. |
| SR IDs against KSPEC-003 §21 register | All SR IDs used in §4-§8 exist in the register; area counts match §21.1 (154 total; Existing 108, Partial 25, Missing 18, Proposed 3). |
| UR→SR edges against KSPEC-003 `Source` fields | Every UR in §5 chains is cited by the named SR's `Source` field; no edge was added or removed. |
| UR IDs against KSPEC-002 | UR-001 - UR-038 all exist; UR statuses quoted from KSPEC-002 (§12: Existing 31, Partial 6, Missing 1; corrected per RF-003). |
| THR IDs against KSPEC-006 | THR-001 - THR-018 all exist; §7.1 resolves the prefix intent of KSPEC-006 §8 against specific SR IDs only where a VT record records the pairing. |
| ORK IDs against KSPEC-007 | ORK-001 - ORK-016 all exist; bands quoted from the KSPEC-007 §4 FMEA summary; the former interoperability prefix discrepancy is resolved in revision 0.2. |
| Repository paths | All paths cited in §4 Evidence columns appear in KSPEC-003 `Evidence` fields or the KSPEC-000 §10 evidence source map; none were asserted from outside the package documents. |
| No fabricated evidence | No test result, approval, or conformity claim is recorded; every execution claim is quoted or paraphrased from the KSPEC-008 evidence-status field with its tracker/artifact source. |

# 11. Summary statistics

| Metric | Value |
|---|---|
| SR requirements in register | 154 (Existing 108, Partial 25, Missing 18, Proposed 3) |
| SRs VT-linked | 114 (74.0%); 40 without direct VT linkage (§9.2) |
| UR stakeholder needs | 38; 38 traced to SRs; 35 with at least one VT (2 with none: UR-006, UR-035) |
| VT verification tests consumed | 60 (VT-001 - VT-060); 14 Proposed, 7 partially covered, 39 Covered per KSPEC-008 (corrected per RF-002) |
| THR threats | 18, all linked to SR prefixes and resolved specific SRs; 1 with no VT (THR-018) |
| ORK operational risks | 16, all linked to SR areas and resolved specific SRs; all 16 have at least one VT |

*End of KSPEC-009, version 0.2 (Draft). This document adds no requirements and records no verification outcomes; it binds existing KSPEC-002/003/004/006/007/008 identifiers into a single traceability matrix and reports every empty cell. Approval pending review per KSPEC-000 §2.*

# Kryptonian Formal Engineering Specification - Engineering Gap Analysis

| Field | Value |
|---|---|
| Document title | Engineering Gap Analysis (GAP-*) |
| Document ID | KSPEC-010 |
| Version | 0.2 (Draft) |
| Review status | Draft - pending review |
| Created | 2026-10-13 |
| Baseline repository commit | `682f996c8447afec13bc1fce5b7f59e6a06efa25` (branch `feat/windows-sandbox-installer`, "Release Windows gateway and portable enrollment demo 0.1.4") |
| Repository | https://github.com/AAPM-RT-SEC/RTSec.Kryptonian |
| Revision history | 0.1 - 2026-10-13 - Initial draft: 37 gap findings consolidated from KSPEC-003 requirement statuses, KSPEC-005 interface deviations, KSPEC-006 threat-model boundaries, KSPEC-007 operational risks, and docs/IMPLEMENTATION-TRACKER.md (Author: gap analysis team). |
| Source references | KSPEC-000 (conventions); KSPEC-003 (SR register, §21); KSPEC-004 (design limitations); KSPEC-005 (interface deviations, open items §20); KSPEC-006 (THR-001-THR-018); KSPEC-007 (ORK-001-ORK-016); docs/IMPLEMENTATION-TRACKER.md; docs/ORNET-ALIGNMENT-2026-09-09.md; docs/CHANGES-AND-ORNET-ALIGNMENT.md; docs/adcs-real-backend-demo.md; docs/medical-device-demo.md; README.md; Mvp.md; artifacts/developer/verify-*/evidence.json |
| Author | Name: TBD - Date: TBD - Signature: TBD |
| Reviewer | Name: TBD - Date: TBD - Signature: TBD |
| Approver | Name: TBD - Date: TBD - Signature: TBD |
| Reconciliation revision | 0.2 - 2026-10-13 - source/document audit and publication controls (KSPEC-016) |

**Product classification (binding, KSPEC-000 §3).** Kryptonian is enterprise healthcare IT cybersecurity infrastructure: an EST (RFC 7030) certificate enrollment, identity provisioning, and credential lifecycle gateway. It is **not a regulated medical device**, performs no clinical functions, and this document contains no regulatory, IEC 62304, ISO 14971, or standards-conformity content.

## 1. Purpose and scope

This document (KSPEC-010) records the engineering gaps between the **baseline implementation** (AS-IS behavior at commit `682f996`) and the **formal target specification** (TO-BE behavior normatively specified by KSPEC-003, with design in KSPEC-004 and interfaces in KSPEC-005). A gap is any requirement recorded with status `Partial` or `Missing` in the KSPEC-003 Requirements Register, any AS-IS weak control or deliberate boundary recorded in KSPEC-005/006/007 or docs/IMPLEMENTATION-TRACKER.md, or any verification/recording deficiency identified while drafting this package.

This document:

- Categories every finding under the nine assessment dimensions defined in §2.
- Assigns stable `GAP-nnn` identifiers (owned by this document per KSPEC-000 §7).

- Cites supporting evidence with provenance classes (KSPEC-000 §5).
- Proposes corrections and links affected requirements by ID only (SR-, *UR*-).
- Defines a prioritized remediation ordering (§6).

This document does not modify source code, does not implement anything, and does not fabricate approvals, test results, or conformity claims (KSPEC-000 §13).

## 2. Assessment dimensions

Every GAP record is assigned exactly one primary category:

| Category | Covers |
|---|---|
| Functional completeness | Specified protocol/product functions absent or incomplete at baseline. |
| Security | Weak or absent security controls, secrets handling, dependency exposure. |
| Interoperability | Cross-system behavior with devices, hospital CA backends, external clients; interoperability evidence. |
| Architecture | Structural weaknesses: trust-boundary coupling, component separation, lifecycle propagation. |
| Reliability | Failure modes affecting continuity of the credential lifecycle. |
| Performance | Absent or unmeasured capacity/latency targets. |
| Maintainability | Interface-contract currency, unresolved policy placeholders, dependency maintenance. |
| Testing | Verification coverage, executed-evidence gaps, test-suite health. |
| Operational readiness | Backup/restore, monitoring, deployment posture, database providers. |

## 3. Gap record format

Each gap follows the record field discipline of KSPEC-000 §8, adapted from a requirement record to a finding record: ID, Finding, Evidence (provenance-classed), Impact, Proposed correction, Affected requirements (SR-/*UR*- by ID only), Verification criteria (T/I/A/D per KSPEC-000 §11), and Priority (§4).

## 4. Priority definitions

| Priority | Meaning |
|---|---|
| Critical | Deployment blocker or gateway-wide security exposure; must be remediated (or explicitly risk-accepted by stakeholders) before any non-lab deployment. |
| High | Materially weakens the target specification or a core lifecycle guarantee; schedule before production-planning review. |
| Medium | Track; remediate opportunistically or with a documented operational workaround. |
| Low | Acceptable for lab/demo scope with recorded rationale. |

Priorities in this document are the draft author's qualitative judgments pending review; they align with, but do not override, the KSPEC-007 RPN bands or KSPEC-006 residual-risk ratings.

# 5. Baseline summary feeding this analysis

| Input | Value | Provenance |
|---|---|---|
| KSPEC-003 requirements | 154 total: 108 Existing, 25 Partial, 18 Missing, 3 Proposed | Register consistency checked (KSPEC-003 §21.1); not implementation execution evidence |
| KSPEC-006 threats | 18 THR entries; residual-risk clusters: administrative/secret-management defaults, XFCC proxy trust, revocation-data boundaries | VERIFIED (KSPEC-006 §9) |
| KSPEC-007 risks | 16 ORK entries; Critical band: ORK-008 (failed revocation), ORK-009 (clock skew), ORK-011 (upgrade failure) | VERIFIED (KSPEC-007) |
| Implementation tracker | 16 merged PRs (37-52); executed local evidence; deliberate boundaries section lists deployment blockers and unverified integrations | VERIFIED (docs/IMPLEMENTATION-TRACKER.md) |

# 6. Gap summary table

## GAP-001

**Category:** Functional completeness
**Short title:** `/csrattrs` endpoint missing
**Priority:** Medium
**Affected SRs (primary):** SR-F-EST.014

## GAP-002

**Category:** Functional completeness
**Short title:** `/serverkeygen` endpoint missing
**Priority:** Low
**Affected SRs (primary):** SR-F-EST (area)

## GAP-003

**Category:** Functional completeness
**Short title:** `/fullcmc` not implemented
**Priority:** Low
**Affected SRs (primary):** SR-F-EST (area)

## GAP-004

**Category:** Functional completeness
**Short title:** Pending trigger matrix / Retry-After determinism undefined
**Priority:** Medium
**Affected SRs (primary):** SR-F-EST.011

### GAP-005

**Category:** Security
**Short title:** Unremediated high transitive dependency advisories (deployment blockers)
**Priority:** Critical
**Affected SRs (primary):** SR-S.014, SR-O.005

### GAP-006

**Category:** Security
**Short title:** JWT hard-coded dev-fallback signing secret
**Priority:** Critical
**Affected SRs (primary):** SR-S.007, SR-A.006

### GAP-007

**Category:** Security
**Short title:** No lockout/rate limiting on admin authentication
**Priority:** High
**Affected SRs (primary):** SR-A.001, SR-F-ADM.003

### GAP-008

**Category:** Security
**Short title:** Legacy static SystemAdmin API keys remain accepted
**Priority:** High
**Affected SRs (primary):** SR-A.004

### GAP-009

**Category:** Security
**Short title:** XFCC forwarder authenticated only by source IP
**Priority:** High
**Affected SRs (primary):** SR-S.005

### GAP-010

**Category:** Security
**Short title:** Hard-coded 60-second prototype CRL lifetime
**Priority:** High
**Affected SRs (primary):** SR-S.012, SR-C.008

### GAP-011

**Category:** Security
**Short title:** Connector credentials and secrets at rest in plain config
**Priority:** High
**Affected SRs (primary):** SR-F-CAI.010, SR-D.008, SR-S.008

### GAP-012

**Category:** Security
**Short title:** Audit records lack tamper-evidence and export

**Priority:** High
**Affected SRs (primary):** SR-U.005, SR-U.006

### GAP-013

**Category:** Security
**Short title:** Data Protection key-ring persistence incomplete
**Priority:** High
**Affected SRs (primary):** SR-S.010, SR-D.007

### GAP-014

**Category:** Security
**Short title:** Weak password policy; no MFA
**Priority:** Medium
**Affected SRs (primary):** SR-A (area)

### GAP-015

**Category:** Security
**Short title:** Dev-mode revocation skip and plain-HTTP escape hatches
**Priority:** Medium
**Affected SRs (primary):** SR-A.009, SR-F-EST.012

### GAP-016

**Category:** Security
**Short title:** ACME DNS-01 challenge is a stub
**Priority:** Medium
**Affected SRs (primary):** SR-F-CAI.007

### GAP-017

**Category:** Security
**Short title:** Device demo exports unencrypted PFX/PEM private keys
**Priority:** Low
**Affected SRs (primary):** SR-F-INT.006

### GAP-018

**Category:** Interoperability
**Short title:** ADCS/NDES connector protocol gaps
**Priority:** High
**Affected SRs (primary):** SR-F-CAI.005

### GAP-019

**Category:** Interoperability
**Short title:** ADCS/EJBCA hospital interoperability (incl. revocation) unverified
**Priority:** High
**Affected SRs (primary):** SR-F-CAI.006

### GAP-020

**Category:** Interoperability
**Short title:** Legacy activation headers retained (compatibility only)
**Priority:** Medium
**Affected SRs (primary):** SR-F-EST.007, SR-F-INT.002

### GAP-021

**Category:** Interoperability
**Short title:** Media-type handling leniency/deviations on EST
**Priority:** Medium
**Affected SRs (primary):** SR-F-EST.003, SR-F-EST.013

### GAP-022

**Category:** Interoperability
**Short title:** Joint interoperability test vectors absent
**Priority:** Medium
**Affected SRs (primary):** SR-F-INT.008

### GAP-023

**Category:** Architecture
**Short title:** Bounded proxy lifetimes; no instant mid-association revocation
**Priority:** Medium
**Affected SRs (primary):** SR-C.008

### GAP-024

**Category:** Architecture
**Short title:** Admin listener dual-purpose (browser prompt / mTLS coupling)
**Priority:** Medium
**Affected SRs (primary):** SR-Z (area)

### GAP-025

**Category:** Reliability
**Short title:** Notification delivery failures silently swallowed
**Priority:** High
**Affected SRs (primary):** SR-R.003, SR-F-CLM.006

### GAP-026

**Category:** Reliability
**Short title:** Renewal runs only while simulator app is open
**Priority:** High
**Affected SRs (primary):** SR-F-CLM.002, SR-O.003

### GAP-027

**Category:** Reliability
**Short title:** Clock-synchronization dependency unmitigated

**Priority:** High
**Affected SRs (primary):** SR-D.005, SR-C.008

### GAP-028

**Category:** Performance
**Short title:** Capacity/latency targets undefined and unmeasured
**Priority:** Medium
**Affected SRs (primary):** SR-P.001, SR-P.003

### GAP-029

**Category:** Maintainability
**Short title:** Stale/empty OpenAPI contract files
**Priority:** High
**Affected SRs (primary):** SR-F-INT.003, SR-F-INT.004

### GAP-030

**Category:** Maintainability
**Short title:** Unresolved TBD threshold cluster
**Priority:** Medium
**Affected SRs (primary):** SR-D.006, SR-V.004, SR-C.003, SR-P.003

### GAP-031

**Category:** Maintainability
**Short title:** No SBOM; dependency audit not whole-system
**Priority:** Medium
**Affected SRs (primary):** SR-S.014

### GAP-032

**Category:** Testing
**Short title:** Test-suite skips, analyzer warnings, mocked-vs-live divergence
**Priority:** Medium
**Affected SRs (primary):** SR-* (verification)

### GAP-033

**Category:** Testing
**Short title:** No independent-client / negative-path matrix over real ingress
**Priority:** Medium
**Affected SRs (primary):** SR-F-INT.001

### GAP-034

**Category:** Operational readiness
**Short title:** No backup/restore procedure; upgrade lacks safety boundary
**Priority:** High
**Affected SRs (primary):** SR-X.007, SR-D.004

### GAP-035

**Category:** Operational readiness
**Short title:** Component-level health reporting and metrics missing
**Priority:** Medium
**Affected SRs (primary):** SR-V.002, SR-O.004

### GAP-036

**Category:** Operational readiness
**Short title:** PostgreSQL provider never exercised
**Priority:** High
**Affected SRs (primary):** SR-D.002

### GAP-037

**Category:** Operational readiness
**Short title:** Deployment posture defaults (loopback, unsigned installer, demo records)
**Priority:** Medium
**Affected SRs (primary):** SR-B (area)

### GAP-038

**Category:** Security
**Short title:** Incomplete durable lifecycle audit
**Priority:** High
**Affected SRs (primary):** SR-C.010, SR-U.001/.002

### GAP-039

**Category:** Reliability
**Short title:** Consumed activation failure/pending recovery
**Priority:** High
**Affected SRs (primary):** SR-F-REG.002, SR-F-EST.010/.011, SR-R.004

### GAP-040

**Category:** Security
**Short title:** Unauthenticated forwarded client-IP attribution
**Priority:** High
**Affected SRs (primary):** SR-S.005/.006, SR-P.001, SR-U.001

# 7. Detailed findings

## 7.1 Functional completeness

### GAP-001 - `/csrattrs` endpoint missing

- **Finding:** The gateway implements `cacerts`, `simpleenroll`, and `simplereenroll` but not the EST `csrattrs` endpoint (RFC 7030 §4.5.2); clients cannot discover profile-required subject DN components or extensions and learn them only out of band.

• **Evidence:** `src/RTSec.Kryptonian.Api/Controllers/EstController.cs` (no csrattrs route) CODE-OBSERVED; KSPEC-005 §3 (endpoint surface) VERIFIED; docs/ARCHITECTURE.md lists `/csrattrs` as an extension point DOCUMENTED.

• **Impact:** Profile policy (SAN types, key size) cannot be negotiated with independent EST clients; interoperability with RFC 7030-conformant clients that expect `/csrattrs` is degraded.

• **Proposed correction:** Implement profile-driven `/csrattrs` aligned with RFC 9908 (CSR-attribute clarification, January 2026, updates RFC 7030) once the profile schema defines the required attribute set. [PROPOSED]

• **Affected requirements:** SR-F-EST.014 (Missing); KSPEC-002 UR-023 area.

• **Verification criteria:** T - independent client requests `/csrattrs`, receives profile-encoded attributes, and builds a compliant CSR.

• **Priority:** Medium

### GAP-002 - `/serverkeygen` endpoint missing

• **Finding:** Server-side key generation (RFC 7030 §4.5.3) is not implemented; all device keys are client-generated.

• **Evidence:** `EstController.cs` (no serverkeygen route) CODE-OBSERVED; docs/ARCHITECTURE.md (extension point list) DOCUMENTED; Mvp.md (serverkeygen "if you support later") DOCUMENTED.

• **Impact:** Deployments requiring centrally generated keys (hardware-backed proxies, key escrow policies) cannot use the gateway; noted as optional capability, not a defect for the current scope.

• **Proposed correction:** Decide as a stakeholder question whether server keygen is in scope; if adopted, treat the key material path as HSM-grade per KSPEC-006 THR-016. [PROPOSED]

• **Affected requirements:** SR-F-EST (area); SR-S.011 (Proposed).

• **Verification criteria:** T (if adopted) - serverkeygen round-trip with encrypted response and key-archival policy test.

• **Priority:** Low

### GAP-003 - `/fullcmc` not implemented

• **Finding:** Full CMC enrollment (RFC 7030 §4.6) is not implemented; the gateway supports only the `simpleenroll`/`simplereenroll` subset.

• **Evidence:** KSPEC-005 §3 endpoint inventory (no fullcmc) VERIFIED; docs/ARCHITECTURE.md DOCUMENTED.

• **Impact:** Clients requiring CMC flows (e.g., some enterprise PKI toolchains) cannot interoperate; acceptable for the defined EST-subset scope if documented as a deviation.

• **Proposed correction:** Record `/fullcmc` as an explicit, documented deviation in the interface contract rather than silent absence. [PROPOSED]

• **Affected requirements:** SR-F-EST (area); SR-F-INT.003.

• **Verification criteria:** I - deviation recorded in KSPEC-005 and the OpenAPI/EST contract.

• **Priority:** Low

### GAP-004 - Pending trigger matrix / Retry-After determinism undefined

• **Finding:** The gateway returns HTTP 202 with `Retry-After` for pending issuance (implemented, PR #44), but the per-backend conditions that produce a pending result and the `Retry-After` computation rule are undefined (`TBD`), so client retry behavior is not deterministic across CA backends.

• **Evidence:** `EstController.cs` `HandleEnrollmentResult` (202 + Retry-After) CODE-OBSERVED; SR-F-EST.011 (Missing, trigger matrix `TBD`) VERIFIED (KSPEC-003); KSPEC-005 ICD-EST.004 open item (which backend states produce IsPending - UNKNOWN).

• **Impact:** Clients cannot predict retry timing; diagnostics of stalled enrollments differ per backend; risk of indefinite retry loops.

• **Proposed correction:** Define a per-backend pending-trigger matrix and a documented `Retry-After` computation rule in KSPEC-005 and implement/verify per backend. [PROPOSED]

• **Affected requirements:** SR-F-EST.010 (Existing), SR-F-EST.011 (Missing).

• **Verification criteria:** A + T - matrix reviewed; per-backend test drives each documented pending condition and observes 202 + Retry-After.

• **Priority:** Medium

## 7.2 Security

### GAP-005 - Unremediated high transitive dependency advisories (deployment blockers)

• **Finding:** The transitive NuGet dependency audit reports high advisories in `SQLitePCLRaw.lib.e_sqlite3` 2.1.6 and `System.Security.Cryptography.Xml` 8.0.2 that remain unremediated; the tracker classifies them as deployment blockers requiring a separately tested framework/native-provider update.

• **Evidence:** docs/IMPLEMENTATION-TRACKER.md ("deployment blockers… not evidence of a clean security audit") VERIFIED; docs/CHANGES-AND-ORNET-ALIGNMENT.md §6 DOCUMENTED; MailKit was patched (4.16.0 + BouncyCastle 2.6.2) but these two advisories remain DOCUMENTED.

• **Impact:** Known vulnerable components ship in gateway deployments; CI gates cover UI npm advisories only, not the .NET transitive tree.

• **Proposed correction:** Test and land a framework/native-provider update that clears both advisories; add a CI gate rejecting high/critical advisories across the .NET solution, not only the UI. [PROPOSED]

• **Affected requirements:** SR-S.014 (Partial), SR-O.005.

• **Verification criteria:** T - `dotnet list package --vulnerable --include-transitive` reports zero high/critical advisories; CI gate demonstrated.

• **Priority:** Critical

### GAP-006 - JWT hard-coded dev-fallback signing secret

• **Finding:** The gateway falls back to a hard-coded development JWT signing constant when `Kryptonian:Auth:JwtSecret` is not provisioned (appsettings ships an empty string); tokens are forgeable when the fallback is active.

• **Evidence:** `src/RTSec.Kryptonian.Api/appsettings.json` (`"JwtSecret": ""`) CODE-OBSERVED; plans/user-management.md ("dev fallback constant with warning") DOCUMENTED; SR-S.007/SR-A.006 recorded Missing VERIFIED (KSPEC-003 §22); KSPEC-006 THR-007 VERIFIED.

• **Impact:** Any deployment omitting the secret accepts attacker-forged admin JWTs - elevation of privilege to SystemAdmin.

• **Proposed correction:** Fail closed at startup when no sufficiently entropic signing secret (≥32 characters) is provisioned; remove the fallback; warn-and-log only in explicitly flagged dev mode. [PROPOSED]

• **Affected requirements:** SR-S.007 (Missing), SR-A.006 (Missing).

• **Verification criteria:** T - startup without provisioned secret aborts; with secret, tokens validate; fallback constant absent from release binary (I).

• **Priority:** Critical

### GAP-007 - No lockout/rate limiting on admin authentication

• **Finding:** Administrative login has no brute-force lockout or per-account throttling; EST endpoints are rate-limited (100 requests/minute general; 30 requests/minute per EST enroll endpoint at baseline, per docs/ARCHITECTURE.md) but the admin authentication surface is not; minimum password length is 8.

• **Evidence:** KSPEC-006 THR-009 (weakness: "no lockout (I), bootstrap exposure (C)") VERIFIED; KSPEC-006 §9 cluster 2 ("no brute-force lockout, minimum-8-character passwords") VERIFIED; docs/ARCHITECTURE.md rate-limit scope (EST paths) CODE-OBSERVED.

• **Impact:** Online password guessing against admin portal/API is unthrottled; combined with GAP-006 it becomes a gateway-compromise path.

• **Proposed correction:** Add account lockout/exponential backoff and rate limiting on `/api/auth/*`; raise password policy consistent with NIST SP 800-63B length guidance; add MFA option. [PROPOSED]

• **Affected requirements:** SR-A.001, SR-F-ADM.003, SR-A.010 area.

• **Verification criteria:** T - scripted repeated failed logins are throttled/locked; legitimate login unaffected.

• **Priority:** High

### GAP-008 - Legacy static SystemAdmin API keys remain accepted

• **Finding:** The pre-database static API-key mechanism (`KRYPTONIAN__ADMINAPI__APIKEYS` environment variable) continues to grant SystemAdmin for backward compatibility, alongside hashed, revocable database API keys.

• **Evidence:** plans/user-management.md (backward-compatibility note) DOCUMENTED; SR-A.004 "Static compatibility API keys" (Existing, Medium) VERIFIED (KSPEC-003); KSPEC-006 THR-007 (weakness: legacy static keys) VERIFIED.

• **Impact:** Non-revocable, config-distributed SystemAdmin credentials undermine the API-key lifecycle (revocation, expiry, ownership); accidental exposure yields permanent gateway control.

• **Proposed correction:** Add a deprecation path: disable static keys by default in release configurations, require explicit opt-in with rotation reminder, and migrate deployments to database keys. [PROPOSED]

• **Affected requirements:** SR-A.004, SR-A.003.

• **Verification criteria:** T - static key rejected when disabled; documented migration path (I).

• **Priority:** High

### GAP-009 - XFCC forwarder authenticated only by source IP

• **Finding:** The `X-Forwarded-Client-Cert` path trusts a fronting proxy that is authorized solely by connection source IP (KnownProxies); the proxy itself is not authenticated by mutual TLS or cryptographic means.

• **Evidence:** SR-S.005 (Missing; mechanism `TBD`) VERIFIED (KSPEC-003); KSPEC-004 PROPOSED item P-2; KSPEC-006 THR-017 (boundary: proxy trust assumption) VERIFIED; `CertificateForwardingGuard` tests reject direct spoofing (spoof test in scripts/verify-dev.ps1) VERIFIED.

• **Impact:** On routed networks a source-IP allow-list can be spoofed; a peer able to appear as the proxy can assert forged device identities for enrollment.

• **Proposed correction:** Select and implement an authenticated-forwarder mechanism (mTLS from proxy, shared-secret header, or proxy-attested chain binding) per SR-S.005; record the decision. [PROPOSED]

• **Affected requirements:** SR-S.005 (Missing), SR-S.004 (Existing).

• **Verification criteria:** T - unauthenticated forwarder rejected with spoofed XFCC; authenticated forwarder accepted; negative test over real TLS ingress.

• **Priority:** High

### GAP-010 - Hard-coded 60-second prototype CRL lifetime

• **Finding:** Locally generated CRLs use a hard-coded 60-second prototype lifetime (`PrototypeCrlLifetime = 60 s`); the production CRL `nextUpdate` policy is an open stakeholder decision (KSPEC-007 TBD-1).

• **Evidence:** KSPEC-007 ORK-008 (`PrototypeCrlLifetime = 60 s` CODE-OBSERVED) VERIFIED; SR-S.012 "Configurable CRL lifetime" (Missing) VERIFIED (KSPEC-003); scripts/verify-dev.ps1 (90-second revocation check window) CODE-OBSERVED.

• **Impact:** The 60-second cadence is a demo value; a policy for production (lifetime, staleness alerting, peer stale-CRL behavior, OCSP option) is undefined, leaving revocation-propagation guarantees unquantified.

• **Proposed correction:** Make CRL lifetime configurable per profile/issuer; define production lifetime from outage tolerance and revocation objectives per docs/ORNET-ALIGNMENT-2026-09-09.md; add CRL-staleness monitoring. [PROPOSED]

• **Affected requirements:** SR-S.012 (Missing), SR-C.008 (Partial).

• **Verification criteria:** T - configured lifetime honored in issued CRL `nextUpdate`; A - propagation analysis documented; I - staleness alerting configured.

• **Priority:** High

### GAP-011 - Connector credentials and secrets at rest in plain config

• **Finding:** CA connector credentials (ACME account keys, ADCS challenge passwords, EJBCA credentials), CA PFX passwords, and the JWT secret are supplied in plain configuration/environment or files (secrets.json); no secret vault or at-rest encryption exists.

• **Evidence:** SR-F-CAI.010 and SR-D.008 recorded Missing; SR-S.008 Missing (approach `TBD`) VERIFIED (KSPEC-003 §22); artifacts/developer/secrets.json (plaintext secrets) CODE-OBSERVED; KSPEC-006 THR-016 VERIFIED.

• **Impact:** Compromise of configuration files or host filesystem exposes CA credentials and signing material; secrets may leak into backups and logs.

• **Proposed correction:** Integrate a secret store (OS keychain/DPAPI, Azure Key Vault, or equivalent) for connector credentials and CA passwords; define the encryption approach for SR-S.008. [PROPOSED]

• **Affected requirements:** SR-F-CAI.010, SR-D.008, SR-S.008 (all Missing).

• **Verification criteria:** I - no plaintext credential in config; T - gateway starts with vault-provisioned secrets.

• **Priority:** High

### GAP-012 - Audit records lack tamper-evidence and export

• **Finding:** Enrollment events, audit records, and blocked-attempt records are database rows without tamper evidence (no hash chaining or append-only store), and no audit-export capability exists; the briefing notes this is a separate conformance task from a database audit table (ATNA/DICOM audit mapping not implemented).

• **Evidence:** SR-U.005 (Missing), SR-U.006 (Missing) VERIFIED (KSPEC-003); KSPEC-006 THR-015 (boundary: no tamper-evidence) VERIFIED; docs/ORNET-ALIGNMENT-2026-09-09.md (ATNA/DICOM audit mapping as future work) DOCUMENTED.

• **Impact:** An attacker with database write access can erase or alter evidence of trust decisions and administrative actions without detection; repudiation risk.

• **Proposed correction:** Add hash-chained or append-only audit records, tamper detection, protected export, and a documented (PROPOSED) path toward ATNA-compatible audit event mapping. [PROPOSED]

• **Affected requirements:** SR-U.005, SR-U.006 (Missing); SR-U.001-SR-U.004 (Existing).

• **Verification criteria:** T - tamper attempt detected; I - export mechanism inspected; A - mapping analysis documented.

• **Priority:** High

### GAP-013 - Data Protection key-ring persistence incomplete

• **Finding:** ASP.NET Data Protection key-ring persistence is only partially specified: activation-code hashing and dashboard protection depend on a key ring whose persistence across installs/containers is not fully guaranteed, so restarts may invalidate protected state.

• **Evidence:** SR-S.010 (Partial) and SR-D.007 (Partial) VERIFIED (KSPEC-003); KSPEC-007 INFERRED entry "Data Protection key-ring loss effects"; docs/DEPLOYMENT.md (key-ring guidance) DOCUMENTED.

• **Impact:** Loss of the key ring can invalidate hashed activation codes, cookies, and protected payloads after an upgrade or container replacement - operational lockout rather than a security breach, but availability-relevant.

• **Proposed correction:** Persist the key ring to a protected, backed-up location (or configurable repository) and cover it in the backup/restore procedure (GAP-034). [PROPOSED]

• **Affected requirements:** SR-S.010, SR-D.007 (Partial).

• **Verification criteria:** T - restart/upgrade preserves Data Protection-protected state.

• **Priority:** High

### GAP-014 - Weak password policy; no MFA

• **Finding:** Minimum password length is 8 characters with no multifactor authentication option for portal or API administrators.

• **Evidence:** KSPEC-006 §9 cluster 2 and THR-007/THR-009 VERIFIED; docs/user-management.md DOCUMENTED; KSPEC-003 SR-A area (no MFA requirement recorded).

• **Impact:** Administrator credentials are more susceptible to offline and online guessing; NIST SP 800-63B guidance (length-based policy, optional MFA) is not met for an internet-exposed admin surface.

• **Proposed correction:** Raise minimum length, screen against breached-password lists, and add TOTP/WebAuthn MFA for privileged roles. [PROPOSED]

• **Affected requirements:** SR-A.001, SR-A.010; new SR-A/SR-S requirement Proposed.

• **Verification criteria:** T - policy enforced at account creation/change; I - MFA option present.

• **Priority:** Medium

### GAP-015 - Dev-mode revocation skip and plain-HTTP escape hatches

• **Finding:** Development HTTPS server revocation is explicitly skipped for the launcher's server leaf lacking a CDP; `Kryptonian:Est:AllowPlainHttp=true` can disable the plain-HTTP refusal (426); the sandbox demo requires selecting "skip EST server revocation checks". These exceptions are documented but not technically confined.

• **Evidence:** docs/IMPLEMENTATION-TRACKER.md (boundary: dev leaf without CDP, "not a production recommendation") VERIFIED; docs/medical-device-demo.md (skip option) DOCUMENTED; SR-A.009 "Development bypass confinement" (Existing) VERIFIED (KSPEC-003); `Program.cs` AllowPlainHttp switch CODE-OBSERVED.

• **Impact:** Misconfiguration in a production deployment could silently enable the dev exceptions (plaintext EST, unchecked server revocation).

• **Proposed correction:** Gate escape hatches behind environment assertions (e.g., refuse AllowPlainHttp when not Development; require explicit opt-in file); surface active exceptions in the health/dashboard payload. [PROPOSED]

• **Affected requirements:** SR-A.009, SR-F-EST.012, SR-B.004.

• **Verification criteria:** T - escape hatches rejected in production-mode configuration; I - dashboard displays active exceptions.

• **Priority:** Medium

### GAP-016 - ACME DNS-01 challenge is a stub

• **Finding:** The ACME connector's DNS-01 challenge is a stub (`Dns01ChallengeStub`); a challenge type advertised but not implemented can fail at issuance rather than at configuration time.

• **Evidence:** KSPEC-004 AS-IS limitation (Dns01ChallengeStub) VERIFIED; SR-F-CAI.007 (Partial) VERIFIED (KSPEC-003); plans/microsoft-acme.md ("Do not silently fall back… replace the stub before DNS-01 is production-ready") DOCUMENTED.

• **Impact:** Misconfigured ACME backends produce late, confusing enrollment failures; silent fallback from HTTP-01 to a stub DNS-01 could issue nothing while appearing configured.

• **Proposed correction:** Implement a real DNS-01 provider abstraction or reject DNS-01 at configuration time with a clear error; add configuration-time challenge-set validation. [PROPOSED]

• **Affected requirements:** SR-F-CAI.007 (Partial).

• **Verification criteria:** T - DNS-01 rejected at configuration time unless a real provider is configured; HTTP-01 flow unchanged.

• **Priority:** Medium

### GAP-017 - Device demo exports unencrypted PFX/PEM private keys

• **Finding:** The device simulator's export option writes an unencrypted PFX or PEM private key to disk; appropriate only for disposable demo identities.

• **Evidence:** docs/medical-device-demo.md (export warning) DOCUMENTED; SR-F-INT.006 "Demo components carry no clinical claims" (Existing) VERIFIED (KSPEC-003); KSPEC-006 THR-016 (device keys unmanaged boundary) VERIFIED.

• **Impact:** Demo key material may be mishandled and later reused; not a gateway product defect but a shipped-tool hazard.

• **Proposed correction:** Require a passphrase for exports or remove the plaintext PEM option in packaged builds; add explicit warning at export time. [PROPOSED]

• **Affected requirements:** SR-F-INT.006; SR-S.011 (Proposed).

• **Verification criteria:** I - export prompts for passphrase or option removed.

• **Priority:** Low

## 7.3 Interoperability

### GAP-018 - ADCS/NDES connector protocol gaps

• **Finding:** The ADCS connector (via SCEP/NDES) has five documented protocol gaps versus a real Microsoft NDES: hard-coded SCEP path, challenge-password handling, RA-certificate enrollment, `GetCACaps`/algorithm negotiation (3DES vs AES/SHA-256), and pending/poll (`GetCertInitial`) for manual-approval templates. Backend test also targets a harness-only `/health` route.

• **Evidence:** docs/adcs-real-backend-demo.md §4 Gaps 1-5 VERIFIED (analysis against documented NDES behavior); `src/RTSec.Kryptonian.Infrastructure/Harness/AdcsCaConnector.cs`, `ScepClient.cs` (posts to `scep/adcs?operation=…`) CODE-OBSERVED; SR-F-CAI.005 (Partial) VERIFIED (KSPEC-003).

• **Impact:** Real hospital ADCS enrollment fails or is unexercised until these gaps close; the connector has only been exercised against the in-repo lenient harness.

• **Proposed correction:** Implement Gaps 1-5 (mandatory 1-3) with regression tests against a real NDES lab; make the SCEP path and test mechanism configurable per SR-F-CAI.005. [PROPOSED]

• **Affected requirements:** SR-F-CAI.005 (Partial), SR-F-CAI.002.

• **Verification criteria:** T - Test button passes via `GetCACaps` against real NDES; device enrollment chains to the lab Enterprise CA.

• **Priority:** High

### GAP-019 - ADCS/EJBCA hospital interoperability (incl. revocation) unverified

• **Finding:** Enrollment and revocation against real hospital CA backends remain unverified: ADCS/NDES offers no revoke operation over SCEP (connector honestly returns false), EJBCA remote revocation requires configured issuer DN and has not been exercised against a real EJBCA, and no hospital deployment evidence exists.

• **Evidence:** docs/IMPLEMENTATION-TRACKER.md ("actual ADCS/EJBCA hospital enrollment/revocation interoperability remains unverified") VERIFIED; docs/CHANGES-AND-ORNET-ALIGNMENT.md §6 DOCUMENTED; SR-F-CAI.006 (Partial) VERIFIED (KSPEC-003); docs/adcs-real-backend-demo.md §6 DOCUMENTED.

• **Impact:** The multi-CA abstraction claim rests on harness and local self-signed evidence only; hospital integration risk (auth, templates, revocation channels) is unquantified.

• **Proposed correction:** Execute the documented ADCS/NDES lab runbook; stand up a real EJBCA and verify enrollment + revocation (REST, or a separate revocation channel for ADCS such as CA Web Services); record executed evidence under artifacts/. [PROPOSED]

• **Affected requirements:** SR-F-CAI.005, SR-F-CAI.006, SR-F-CAI.002.

• **Verification criteria:** D + T - live enrollment/revocation against real ADCS and EJBCA with captured evidence; fail-closed revocation re-tested.

• **Priority:** High

### GAP-020 - Legacy activation headers retained (compatibility only)

• **Finding:** The sample device client retains pre-standard Kryptonian activation headers; the gateway's standard path is HTTP Basic, and the legacy headers are compatibility-only and must not become an interoperability requirement.

• **Evidence:** docs/IMPLEMENTATION-TRACKER.md (boundaries) VERIFIED; docs/medical-device-demo.md ("current app still uses compatibility activation headers") DOCUMENTED; SR-F-EST.007 (Partial), SR-F-INT.002 (Existing) VERIFIED (KSPEC-003).

• **Impact:** Dual activation paths increase attack/maintenance surface and can confuse integrators about the canonical bootstrap.

• **Proposed correction:** Announce deprecation, migrate the sample client to Basic-only bootstrap, and remove legacy header handling after an agreed window. [PROPOSED]

• **Affected requirements:** SR-F-EST.007, SR-F-INT.002.

• **Verification criteria:** T - sample client enrolls via Basic only; legacy headers rejected after deprecation window (or documented policy).

• **Priority:** Medium

### GAP-021 - Media-type handling leniency/deviations on EST

• **Finding:** EST media-type handling deviates from strict RFC 7030 profiles: `text/plain` CSR acceptance is an intentional leniency, the repository's OpenAPI contract covers no EST paths, so client-side expectations are not contractually pinned.

• **Evidence:** KSPEC-005 §13 (media-type handling; leniencies noted as deliberate contracts, CODE-OBSERVED) VERIFIED; KSPEC-005 §20 open item 2 (EST paths absent from all OpenAPI files) VERIFIED; SR-F-EST.003, SR-F-EST.013 (Existing) VERIFIED (KSPEC-003).

• **Impact:** Strictly conformant clients and the gateway may disagree on content negotiation; deviations are undocumented in machine-readable contracts.

• **Proposed correction:** Document each leniency as an explicit deviation with rationale in KSPEC-005 §5; align future `/csrattrs` work with RFC 9908 encoding clarifications. [PROPOSED]

• **Affected requirements:** SR-F-EST.003, SR-F-EST.013, SR-F-INT.003.

• **Verification criteria:** I - deviations recorded; T - strict and lenient client both obtain defined outcomes.

• **Priority:** Medium

### GAP-022 - Joint interoperability test vectors absent

• **Finding:** No joint test-vector matrix with OR.NET (unknown identity, SAN/EKU abuse, spoofed forwarding, rollover, revocation timing, outage) exists; SR-F-INT.008 is Proposed and no independent third-party EST client/server pair has been tested over the real TLS ingress.

• **Evidence:** docs/ORNET-ALIGNMENT-2026-09-09.md (proposed compact executable matrix) DOCUMENTED; SR-F-INT.008 (Proposed) VERIFIED (KSPEC-003); historical evidence includes an independent curl HTTP-Basic EST path and in-repo simulators, but no jointly agreed partner matrix VERIFIED (tracker).

• **Impact:** Interoperability claims remain single-implementation; the ORNET briefing's stated goal of one minimal interoperable test case is unmet.

• **Proposed correction:** Agree one minimal interoperable test case with OR.NET and implement the executable matrix against the real TLS ingress. [PROPOSED]

• **Affected requirements:** SR-F-INT.008 (Proposed), SR-F-INT.001.

• **Verification criteria:** D + T - independent client/server pair executes the matrix; evidence recorded.

• **Priority:** Medium

## 7.4 Architecture

### GAP-023 - Bounded proxy lifetimes; no instant mid-association revocation

• **Finding:** The DIMSE-TLS proxy enforces trust at handshake with bounded connection lifetimes; revocation does not terminate an in-flight association, and PFX renewal is external (reload demonstrated, CA renewal not automated).

• **Evidence:** docs/IMPLEMENTATION-TRACKER.md (boundaries) VERIFIED; KSPEC-006 THR-010 (bounded proxy lifetimes boundary) VERIFIED; tests/RTSec.Kryptonian.DimseTlsProxy.Tests VERIFIED (tracker evidence).

• **Impact:** Revocation latency for established associations is policy-dependent and undefined for production; operators may expect instant eviction that the design does not provide.

• **Proposed correction:** Document bounded-lifetime policy as the revocation-propagation contract (with SR-C.008 analysis); evaluate connection revalidation or bounded association time as a stakeholder decision. [PROPOSED]

• **Affected requirements:** SR-C.008 (Partial).

• **Verification criteria:** A - propagation contract documented; T - bounded lifetime demonstrated with revoked credential.

• **Priority:** Medium

### GAP-024 - Admin listener dual-purpose (browser prompt / mTLS coupling)

• **Finding:** Port 7443 optionally accepts client certificates including from browsers, producing installed-certificate-selection prompts in dashboards; an earlier scripted check returned HTTP 200 without a client certificate, so browser-level verification of the prompt behavior was never proven.

• **Evidence:** docs/CHANGES-AND-ORNET-ALIGNMENT.md §6 (dashboard certificate prompt; recommended correction: separate browser admin HTTPS from device mTLS) DOCUMENTED; KSPEC-004 deployment topology (listener separation discussion) DOCUMENTED.

• **Impact:** Usability failure (certificate picker on every dashboard visit) and a blurred trust boundary between admin traffic and device mTLS.

• **Proposed correction:** Separate browser administration HTTPS from device mTLS listeners with browser-level verification of the full workflow. [PROPOSED]

• **Affected requirements:** SR-Z (area); SR-F-ADM.001; SR-B.002.

• **Verification criteria:** D - full browser/device workflow validated on separated listeners; no certificate prompt on dashboard.

• **Priority:** Medium

## 7.5 Reliability

### GAP-025 - Notification delivery failures silently swallowed

• **Finding:** The notification dispatcher swallows send failures (fire-and-forget with logged-but-otherwise-unobserved errors); failed expiry/revocation/non-renewal notifications produce no operator-visible signal.

• **Evidence:** KSPEC-007 (dispatcher swallow, CODE-OBSERVED; detection scale rationale) VERIFIED; SR-R.003 "Notification delivery decoupled" (Partial), SR-F-CLM.006 (Partial) VERIFIED (KSPEC-003); docs/email-notifications.md DOCUMENTED.

• **Impact:** The renewal-monitoring safety net can be silently absent: operators believe alerts are configured while none are delivered (detection D≥7 in ORK terms).

• **Proposed correction:** Surface delivery outcomes (per-recipient status, retry with backoff, failed-delivery alert/health flag), and record a delivery-status event per notification. [PROPOSED]

• **Affected requirements:** SR-R.003 (Partial), SR-F-CLM.006 (Partial).

• **Verification criteria:** T - forced SMTP failure produces observable delivery-status event and operator-visible indicator.

• **Priority:** High

### GAP-026 - Renewal runs only while simulator app is open

• **Finding:** Automatic renewal executes only while the `Kryptonian.MedicalDevice` simulator is running (checks once per minute after two-thirds of lifetime); there is no OS-service renewal, no out-of-application mechanism, and no old-certificate retirement policy; expired credentials require attended re-activation.

• **Evidence:** docs/IMPLEMENTATION-TRACKER.md ("Automatic renewal runs only while MedicalDevice is open") VERIFIED; docs/medical-device-demo.md (renewal behavior) DOCUMENTED; KSPEC-007 ORK-001 and TBD-3 VERIFIED; SR-F-CLM.002 (Existing, in-app) VERIFIED (KSPEC-003).

• **Impact:** In the demonstrated operating model, devices that do not run a renewal agent lose credentials at expiry - an availability risk incompatible with unattended clinical-estate operation.

• **Proposed correction:** Define the production renewal model (OS service / scheduled task / gateway-initiated re-enrollment) and early-renewal, retry/backoff, and outage-tolerance policies per the ORNET briefing availability requirements. [PROPOSED]

• **Affected requirements:** SR-F-CLM.002, SR-F-CLM.005, SR-O.003; KSPEC-007 ORK-001.

• **Verification criteria:** D + T - renewal demonstrated with the host application closed under the agreed model.

• **Priority:** High

### GAP-027 - Clock-synchronization dependency unmitigated

• **Finding:** Certificate validity, activation-code lifetime, renewal windows, and CRL freshness all depend on host clock correctness; the Critical-band clock-skew risk (ORK-009) has no in-repo mitigation (no reliable-time source requirement, skew detection, or alerting).

• **Evidence:** KSPEC-007 ORK-009 (S=8, O=4, D=7, Critical via override) VERIFIED; SR-D.005 UTC discipline (Existing) VERIFIED (KSPEC-003).

• **Impact:** Clock skew can prematurely invalidate valid credentials, extend revocation visibility, or break renewal windows; the SQLite DateTime-kind bug already demonstrated a time-handling failure class.

• **Proposed correction:** Add documented NTP/time-source deployment requirements, skew detection with alerting, and monotonic-time regression tests for revocation arithmetic. [PROPOSED]

• **Affected requirements:** SR-D.005; SR-C.008; SR-R (area).

• **Verification criteria:** T - skewed-clock demonstration with alerts; I - deployment time requirements documented.

• **Priority:** High

## 7.6 Performance

### GAP-028 - Capacity/latency targets undefined and unmeasured

• **Finding:** Enrollment latency budget (SR-P.003) and production capacity (SR-P.001 thresholds beyond the demonstrated rate-limit configuration) are `TBD`; profile/CA-certificate caching is only partially characterized; no load-testing evidence exists.

• **Evidence:** SR-P.003 (Missing, `TBD`), SR-P.001 (Existing but thresholds unproven at production scale), SR-P.005 (Partial) VERIFIED (KSPEC-003); no performance artifacts under artifacts/ INFERRED.

• **Impact:** Hospital-scale behavior (hundreds of devices renewing concurrently) is unquantified; rate-limit defaults may block legitimate renewal bursts.

• **Proposed correction:** Set stakeholder-agreed capacity/latency targets; run load tests covering renewal bursts; tune caching and rate limits to targets. [PROPOSED]

• **Affected requirements:** SR-P.001, SR-P.003, SR-P.005.

• **Verification criteria:** A + T - documented targets; load-test evidence at target scale.

• **Priority:** Medium

## 7.7 Maintainability

### GAP-029 - Stale/empty OpenAPI contract files

• **Finding:** `OpenAPI.Client.yaml` is empty (0 bytes) and `OpenAPI.Schema.yaml` is stale relative to DTOs (missing `hostnameMatchType`, `validityDays`, `requireClientCertificate`, trust-policy fields, `isEnabled/isActive`); EST paths appear in no OpenAPI file; several files declare no security scheme.

• **Evidence:** `OpenAPI.Client.yaml`, `OpenAPI.Schema.yaml` (0 bytes; stale) CODE-OBSERVED and recorded in KSPEC-005 §18/§20 VERIFIED; SR-F-INT.003 (Missing), SR-F-INT.004 (Partial) VERIFIED (KSPEC-003 §22).

• **Impact:** Integrators automating against the contracts are silently misled; the "well-documented protocol" positioning (Mvp.md) is not contractually supported.

• **Proposed correction:** Generate authoritative OpenAPI from implemented controllers (or reconcile contract-first files), add an EST endpoint contract, declare security schemes, and add a contract-drift CI check. [PROPOSED]

• **Affected requirements:** SR-F-INT.003 (Missing), SR-F-INT.004 (Partial).

• **Verification criteria:** I - contracts current and complete; T - CI drift check fails on stale contracts.

• **Priority:** High

### GAP-030 - Unresolved TBD threshold cluster

• **Finding:** Fifteen requirements carry unresolved `TBD` policy values (abuse-control threshold, pending matrix, forwarder mechanism, encryption approach, key archival, certificate lifetime, stale-revocation policy, retention period, capacity, latency budget, delivery reliability, availability targets, log retention, metrics format, connector secrets mechanism) that block closure of their requirements.

• **Evidence:** KSPEC-003 §22 (unresolved thresholds list) VERIFIED; KSPEC-007 TBD table VERIFIED.

• **Impact:** Requirements remain unverifiable; policy decisions are deferred indefinitely; GAP-004/010/011 remediation depends on these decisions.

• **Proposed correction:** Hold a stakeholder decision session to resolve each TBD; record decisions in KSPEC-003/007 and update the affected GAPs. [PROPOSED]

• **Affected requirements:** SR-F-REG.007, SR-F-EST.011, SR-S.005, SR-S.006, SR-S.008, SR-S.011, SR-C.003, SR-C.008, SR-D.006, SR-P.001, SR-P.003, SR-R.003, SR-V.004, SR-O.002, SR-O.004, SR-F-CAI.010.

• **Verification criteria:** I - each TBD resolved with a recorded decision or an explicit accepted-risk entry.

• **Priority:** Medium

### GAP-031 - No SBOM; dependency audit not whole-system

• **Finding:** No SBOM (CycloneDX/SPDX) is generated for gateway artifacts; the npm-audit reduction and CI gate cover the UI lockfile only, and the tracker explicitly disclaims a whole-system security audit.

• **Evidence:** docs/IMPLEMENTATION-TRACKER.md ("This is not a whole-system audit") VERIFIED; no SBOM tooling in .github/workflows/ CODE-OBSERVED; SR-S.014 (Partial) VERIFIED (KSPEC-003).

• **Impact:** Downstream operators cannot verify shipped component inventory; advisory response lacks an authoritative component list.

• **Proposed correction:** Generate SBOMs (CycloneDX 1.5+ or SPDX 2.3) in CI for server, proxy, and device artifacts; gate on new critical advisories. [PROPOSED]

• **Affected requirements:** SR-S.014 (Partial), SR-O.005.

• **Verification criteria:** T - SBOM produced per artifact in CI; advisory gate demonstrated.

• **Priority:** Medium

## 7.8 Testing

### GAP-032 - Test-suite skips, analyzer warnings, mocked-vs-live divergence

• **Finding:** Eighteen pre-existing Windows infrastructure test skips and existing analyzer warnings remain; live checks exposed two real bugs (Schannel ephemeral-key rejection, SQLite DateTime-kind CRL shift) that mocked tests missed.

• **Evidence:** docs/IMPLEMENTATION-TRACKER.md (boundaries; "Failed attempts remain alongside successful artifacts") VERIFIED; 8 test projects (corrected per RF-005; KSPEC-000 §10) VERIFIED.

• **Impact:** Coverage is overstated by skip counts; mocked-test pass rates do not establish protocol behavior on real platforms.

• **Proposed correction:** Triage each skip (fix/justify/retire), resolve or baseline analyzer warnings, and promote key mocked tests to live-ingress regressions (GAP-033). [PROPOSED]

• **Affected requirements:** verification methods of all SR-* (KSPEC-008 scope).

• **Verification criteria:** T - skip count reduced with recorded rationale per remaining skip; analyzer warnings resolved or baselined.

• **Priority:** Medium

### GAP-033 - No independent-client / negative-path matrix over real ingress

• **Finding:** Executed evidence uses in-repo simulators; the briefing's required compact executable matrix (unknown identity, device A requesting B's name, unauthorized SAN/EKU, spoofed forwarding, activation replay, unknown profile, renewal/rekey, revoked/expired, CA outage, issuer rollover, peer denial) has not been run as a single reproducible matrix against the actual TLS ingress.

• **Evidence:** docs/ORNET-ALIGNMENT-2026-09-09.md (joint-slice and matrix requirements) DOCUMENTED; artifacts/developer/verify-*/evidence.json VERIFIED (partial coverage only); SR-F-INT.001 (Existing) VERIFIED (KSPEC-003).

• **Impact:** Negative-path and failure behavior are only partially evidenced; regression risk for security-critical rejections.

• **Proposed correction:** Implement the executable matrix as a repeatable verifier (extending scripts/verify-dev.ps1), including CA-outage and issuer-rollover cases. [PROPOSED]

• **Affected requirements:** SR-F-INT.001; SR-S.003, SR-S.004; SR-X.001-SR-X.005.

• **Verification criteria:** T - matrix runs end-to-end with recorded evidence.json including failure cases.

• **Priority:** Medium

## 7.9 Operational readiness

### GAP-034 - No backup/restore procedure; upgrade lacks safety boundary

• **Finding:** There is no documented/executed backup-and-restore procedure for database, CA material, or Data Protection keys; MSI rollback is explicitly not a database rollback; schema upgrades run raw additive DDL outside an explicit transaction/backup boundary.

• **Evidence:** SR-X.007 (Partial), SR-D.004 (Missing) VERIFIED (KSPEC-003); KSPEC-007 ORK-006 (recovery: "none beyond reinstallation"; PROPOSED restore procedure) VERIFIED; ORK-011 (Critical, RPN 240) VERIFIED; docker-compose/deploy (no backup tooling) CODE-OBSERVED.

• **Impact:** Irreversible loss of CA and device-trust state is a plausible single-event outcome; upgrade failures (ORK-011 Critical) have no rollback path.

• **Proposed correction:** Implement and rehearse backup/restore (database + CA + key ring) with stakeholder RPO/RTO targets; wrap upgrades in a transaction/backup boundary; add upgrade rehearsal on both persistence providers. [PROPOSED]

• **Affected requirements:** SR-X.007 (Partial), SR-D.004 (Missing); KSPEC-007 ORK-006/ORK-011.

• **Verification criteria:** T - backup/restore drill with defined RPO/RTO passes; upgrade rehearsal on SQLite and PostgreSQL.

• **Priority:** High

### GAP-035 - Component-level health reporting and metrics missing

• **Finding:** `/api/status/health` covers process liveness only; no component-level health (database reachable, CA backend reachable, CRL freshness, notification channel) and no metrics endpoint exist.

• **Evidence:** SR-V.002 (Missing), SR-O.004 (Missing, format `TBD`) VERIFIED (KSPEC-003); KSPEC-005 StatusController surface VERIFIED.

• **Impact:** Stale CRLs, dead CA backends, and broken notifications (GAP-025) are invisible to monitoring until device enrollments fail.

• **Proposed correction:** Add component checks to the health output and a metrics endpoint (format TBD per SR-O.004); define availability targets (SR-V.004). [PROPOSED]

• **Affected requirements:** SR-V.002, SR-O.004 (Missing); SR-V.004.

• **Verification criteria:** T - induced component failures reflected in health/metrics.

• **Priority:** Medium

### GAP-036 - PostgreSQL provider never exercised

• **Finding:** PostgreSQL schema upgrades exist and the Azure deployment plan uses PostgreSQL, but all executed persistence evidence (restart preservation, upgrade behavior, revocation arithmetic) is SQLite-only.

• **Evidence:** docs/IMPLEMENTATION-TRACKER.md ("PostgreSQL schema upgrades are implemented but only SQLite persistence was exercised") VERIFIED; docs/CHANGES-AND-ORNET-ALIGNMENT.md §6 DOCUMENTED; deploy/azure/README.md (PostgreSQL Flexible Server) DOCUMENTED; SR-D.002 (Partial) VERIFIED (KSPEC-003).

• **Impact:** Provider-specific behavior (timestamp handling, DDL, connection failures) is untested on the provider chosen for the cloud deployment path.

• **Proposed correction:** Exercise the full verification suite (or an equivalent subset) on PostgreSQL 16, including upgrade and restore, and record evidence. [PROPOSED]

• **Affected requirements:** SR-D.002 (Partial), SR-D.003.

• **Verification criteria:** T - executed PostgreSQL test evidence under artifacts/; upgrade+restore drill passes.

• **Priority:** High

### GAP-037 - Deployment posture defaults (loopback, unsigned installer, demo records)

• **Finding:** The Windows gateway package listens only on loopback by default, ships an unsigned lab-preview device executable, retains synthetic demo records/user artifacts, and carries documentation-not-implementation disclaimers; appropriate for lab scope but not deployment-hardening defaults.

• **Evidence:** docs/medical-device-demo.md (unsigned lab preview; loopback-only) DOCUMENTED; docs/IMPLEMENTATION-TRACKER.md ("Existing user artifacts and services were preserved. Synthetic demo records remain.") VERIFIED; README.md disclaimer VERIFIED; SR-B area (KSPEC-003) VERIFIED.

• **Impact:** Moving the package to a hospital network without hardening (code signing, external listener configuration, demo-data purge, independent security assessment) silently inherits prototype assumptions.

• **Proposed correction:** Produce a production-readiness checklist (code signing, listener/firewall configuration, demo-data purge, independent security assessment per the README disclaimer) and gate release artifacts on it. [PROPOSED]

• **Affected requirements:** SR-B.001-SR-B.004, SR-B.007 (Partial).

• **Verification criteria:** I - checklist approved and applied to release artifacts; D - hardened install exercised.

• **Priority:** Medium

# 8. Prioritized remediation ordering

Ordering rationale: deployment blockers and gateway-wide exposures first, then lifecycle-guarantee and interoperability unverifieds, then tracked improvements. Every item is PROPOSED until the corresponding change and its verification evidence are reviewed and approved (KSPEC-000 §4, §13).

## Wave 0 - Deployment blockers (must close or be risk-accepted before any non-lab deployment)

1. **GAP-005** (dependency advisories): tested framework/native-provider update; .NET-wide CI advisory gate.
2. **GAP-006** (JWT fallback secret): fail-closed startup; remove fallback constant.
3. **GAP-007** (admin auth lockout/rate limiting): throttle/lock `/api/auth/*`; password policy (feeds GAP-014).

## Wave 1 - Core guarantee and interoperability unverifieds (before production planning)

4. **GAP-019** (hospital CA interoperability): real ADCS/NDES and EJBCA enrollment+revocation evidence.
5. **GAP-018** (ADCS connector gaps 1-5) - prerequisite for GAP-019.
6. **GAP-034** (backup/restore + upgrade boundary) with GAP-013 (key-ring persistence).
7. **GAP-011** (secrets at rest / vault) and **GAP-036** (PostgreSQL exercise).
8. **GAP-025** (notification delivery visibility), **GAP-026** (out-of-application renewal model), **GAP-027** (time-source requirements).
9. **GAP-009** (authenticated forwarder), **GAP-008** (legacy static key deprecation), **GAP-010** (CRL lifetime policy), **GAP-012** (audit tamper-evidence).
10. **GAP-029** (OpenAPI currency) and **GAP-030** (TBD decision session - prerequisite for GAP-004/010/011 closure).

## Wave 2 - Tracked improvements

11. **GAP-001** (`/csrattrs`, RFC 9908-aligned), **GAP-004** (pending matrix - depends on GAP-030).
12. **GAP-031** (SBOM), **GAP-032** (skip/analyzer triage), **GAP-033** (executable negative-path matrix), **GAP-022** (joint test vectors), **GAP-021** (media-type deviation record).
13. **GAP-015** (escape-hatch confinement), **GAP-016** (DNS-01 stub), **GAP-023** (revocation-propagation contract), **GAP-024** (listener separation), **GAP-028** (capacity/latency targets), **GAP-035** (component health/metrics), **GAP-037** (production-readiness checklist).

## Wave 3 - Lab-scope items with recorded rationale

14. **GAP-002** (`/serverkeygen` scope decision), **GAP-003** (`/fullcmc` deviation record), **GAP-014** (password/MFA - partially pulled into Wave 0 via GAP-007), **GAP-017** (demo key export).

Dependencies: GAP-030 blocks GAP-004, GAP-010, GAP-011 closure; GAP-018 blocks GAP-019; GAP-034 absorbs GAP-013 verification; GAP-037 depends on Waves 0-1.

# 9. Traceability notes

- Every gap cites its evidence with a provenance class (KSPEC-000 §5); no claim in this document upgrades DOCUMENTED evidence to VERIFIED.
- Affected-requirements IDs reference the canonical KSPEC-003 register (§21.2) only; this document defines no SR/UR IDs.
- Cross-references: KSPEC-005 §20 (interface open items), KSPEC-006 §9 (residual-risk clusters), KSPEC-007 §TBD (operational open decisions), KSPEC-008 (verification planning consumes GAP verification criteria), KSPEC-009 (traceability), and KSPEC-011 (standards-focused readiness analysis, which consumes the protocol and control gaps, GAP-001-GAP-022).
- All 40 gaps carry approval state **Review Required**; no approval is recorded or inferred.

# 10. Open questions for review

1. Are the Wave assignments acceptable to stakeholders as a deployment-gating order?
2. Should `/fullcmc` and `/serverkeygen` be declared out of scope permanently (GAP-002/003) or planned?
3. Which stakeholder body resolves the TBD cluster (GAP-030), and by what date?
4. Does the audit tamper-evidence approach (GAP-012) target ATNA-compatible export now or later?
5. Is PostgreSQL the sole production provider going forward (GAP-036), or must SQLite hardening continue in parallel?

*End of KSPEC-010, version 0.2 (Draft). All findings carry Priority assignments by the draft authors and Approval "Review Required"; no approval is recorded or inferred.*

# 11. Additional gaps found during code/document reconciliation

### GAP-038 - Incomplete durable lifecycle audit

- **Finding:** Some enrollment/renewal failures return before EnrollmentEvent persistence, while controller failures and revocation decisions are not uniformly recorded as durable lifecycle events.
- **Evidence:** `EnrollmentOrchestrator.EnrollAsync` and `ReenrollAsync`; `EstController`; `CertificateRevocationService.RevokeAsync` (CODE-OBSERVED).
- **Impact:** Operators cannot reconstruct every credential/trust decision from the enrollment event store. Logging and certificate status alone do not satisfy the target audit requirement.
- **Proposed correction:** Introduce complete, secret-free durable decision auditing at the protocol/service boundary with stable correlation IDs, preserving failure status and transaction semantics. [PROPOSED]
- **Affected requirements:** SR-C.010, SR-U.001, SR-U.002 (Partial).
- **Verification criteria:** VT-059, including early rejection and revocation cases, persistence and secret exclusion.
- **Priority:** High

### GAP-039 - Activation consumption precedes issuance and recovery is unverified

- **Finding:** Activation consumption is committed before backend resolution/policy/issuance. CA failures, pending issuance and process termination can leave a Pending device with a consumed code; retrying that bootstrap cannot be presumed safe.

• **Evidence:** `EnrollmentOrchestrator.EnrollAsync`, `TryConsumeActivationCodeAsync`, `IssueForDeviceAsync`; `UnitOfWork.TryConsumeActivationCodeAsync` (CODE-OBSERVED).

• **Impact:** Bootstrap fails after consuming its one-time credential and may require administrator code regeneration. Client handling of HTTP 202 alone does not prove initial enrollment recovery.

• **Proposed correction:** Specify and demonstrate supported regeneration/recovery; decide on any issuance idempotency or durable pending-workflow design before implementation. [PROPOSED]

• **Affected requirements:** SR-F-REG.002, SR-F-EST.010/.011, SR-R.004.

• **Verification criteria:** VT-060 with persisted state, restart, CA outage/pending and concurrency.

• **Priority:** High

### GAP-040 - Forwarded source address is not authenticated

• **Finding:** `EstController.GetClientIp` takes the first X-Forwarded-For value, and rate limiting selects the same header via RealIpHeader. CertificateForwardingGuard protects XFCC, not the authenticity of this source-address header.

• **Evidence:** `EstController.GetClientIp`; `IpRateLimiting.RealIpHeader` in appsettings.json; `Program.cs` middleware; `CertificateForwardingGuard` (CODE-OBSERVED).

• **Impact:** An untrusted caller may influence audit source attribution and the per-IP throttle key. Source consistency between logging and limiting is not proof of trusted origin.

• **Proposed correction:** Define trusted proxy address handling and remove/ignore untrusted forwarded headers before both logging and rate limiting. [PROPOSED]

• **Affected requirements:** SR-S.005/.006, SR-P.001, SR-C.010, SR-U.001.

• **Verification criteria:** Extend VT-055/VT-059 with direct-header spoofing and authenticated-forwarder cases; direct callers cannot select arbitrary origin addresses or bypass throttling.

• **Priority:** High

# Kryptonian Formal Engineering Specification - Security and Standards Conformance Assessment

| Field | Value |
|---|---|
| Document title | Security and Standards Conformance Assessment |
| Document ID | KSPEC-011 |
| Version | 0.2 (Draft) |
| Review status | Draft - pending review |
| Created | 2026-10-13 |
| Baseline repository commit | `682f996c8447afec13bc1fce5b7f59e6a06efa25` (branch `feat/windows-sandbox-installer`, "Release Windows gateway and portable enrollment demo 0.1.4") |
| Repository | https://github.com/AAPM-RT-SEC/RTSec.Kryptonian |
| Revision history | 0.1 - 2026-10-13 - Initial draft: standards applicability table, per-protocol capability status, interoperability evidence summary, security-control coverage mapping (Author: conformance assessment team). |
| Source references | KSPEC-000 (conventions); KSPEC-003 (SR register); KSPEC-005 (ICD); KSPEC-006 (cybersecurity); KSPEC-010 (gap analysis, GAP-001-GAP-037); docs/IMPLEMENTATION-TRACKER.md; docs/ORNET-ALIGNMENT-2026-09-09.md; docs/CHANGES-AND-ORNET-ALIGNMENT.md; docs/medical-device-demo.md; docs/adcs-real-backend-demo.md; artifacts/developer/verify-*/evidence.json |
| Author | Name: TBD - Date: TBD - Signature: TBD |
| Reviewer | Name: TBD - Date: TBD - Signature: TBD |
| Approver | Name: TBD - Date: TBD - Signature: TBD |
| Reconciliation revision | 0.2 - 2026-10-13 - source/document audit and publication controls (KSPEC-016) |

**Product classification (binding, KSPEC-000 §3).** Kryptonian is enterprise healthcare IT cybersecurity infrastructure: an EST (RFC 7030) certificate enrollment, identity provisioning, and credential lifecycle gateway. It is **not a regulated medical device**, performs no clinical functions, and this document contains no regulatory, IEC 62304, ISO 14971, or medical-device content.

## 1. Purpose, scope, and mandatory disclaimer

This document (KSPEC-011) is a **readiness analysis**: it maps the capabilities present in the baseline implementation to the protocols and standards that the repository's own documentation cites (RFC 7030 and updates, X.509/PKIX, TLS, DICOM TLS profiles, IEEE 11073 SDC / OR.NET context, IHE SDPi context, and security control frameworks), and records what is supported, where behavior deviates, and what remains untested.

**Provenance and claim discipline (KSPEC-000 §5, §13).** Throughout this document:

- **Supported** means the capability is implemented and there is positive executed or source-inspection evidence.

- **Deviating** means behavior differs from the cited text in a way recorded in KSPEC-005 or docs/IMPLEMENTATION-TRACKER.md.
- **Untested** means the requirement cannot be evidenced from the baseline repository; its status is UNKNOWN until exercised.

**Disclaimer (binding).** No third-party certification, accreditation, or standards-body approval is claimed or implied for any protocol, profile, or framework cited here. Statements of the form "aligned with", "consistent with", or "compatible with" describe the repository's own implementation choices and evidence, not a conformity determination. No OR.NET adoption, IHE SDPi integration approval, DICOM TLS certification, SDC conformity, or NIST validation is claimed. The README disclaimer (independent security assessment required; research prototype) remains operative.

# 2. Standards version notes

Versions are recorded as referenced during drafting (2026-10-13). Where an edition could not be independently re-verified during drafting, that is stated rather than guessed.

## 2.1 Applicable protocols and standards table

### RFC 7030 (EST)

**Version cited:** 2014
**Applicability to Kryptonian components:** Core device-facing enrollment protocol: `cacerts`, `simpleenroll`, `simplereenroll`, HTTP Basic bootstrap, 202-pending handling
**Applicability class: Mandatory** (defining protocol of the product)

### RFC 7929 (TLS-based authentication methods for EST)

**Version cited:** 2016
**Applicability to Kryptonian components:** Alternative EST authentication paths (TLS-only bootstrap); not implemented - context for future auth-method decisions
**Applicability class:** Recommended (context)

### RFC 8295 (EST algorithms with Internet PKI)

**Version cited:** 2017
**Applicability to Kryptonian components:** Algorithm requirements for EST CSRs/certificates; profile enforcement aligns informally (CSR algorithm floor)
**Applicability class:** Recommended

### RFC 9908 (CSR attributes clarification)

**Version cited:** Jan 2026
**Applicability to Kryptonian components:** Governs `/csrattrs` encoding if/when implemented (GAP-001)
**Applicability class:** Optional now; recommended before implementing `/csrattrs`

### RFC 5280 (X.509 PKIX profile)

**Version cited:** 2008
**Applicability to Kryptonian components:** Certificate and CRL profile features used by issuers, validation, and the local CA
**Applicability class: Mandatory** (basis of all issuance/validation)

### RFC 6960 (OCSP)

**Version cited:** 2013
**Applicability to Kryptonian components:** Not implemented; CRL-based revocation only
**Applicability class:** Optional

### RFC 5751/CMS (PKCS#7), RFC 2986 (PKCS#10)

**Version cited:** current
**Applicability to Kryptonian components:** CSR input and PKCS#7 certificate-chain responses
**Applicability class:** Mandatory (implied by EST)

### RFC 8555 (ACME)

**Version cited:** 2019
**Applicability to Kryptonian components:** Southbound CA connector (HTTP-01 implemented; DNS-01 stub - GAP-016)
**Applicability class:** Optional backend (recommended for cloud CAs)

### ISO/IEC/IEEE 29148:2018

**Version cited:** 2018
**Applicability to Kryptonian components:** Requirement/vocabulary conventions for this specification package (KSPEC-000)
**Applicability class:** Mandatory for the docs, not the software

### ISO/IEC 27001:2022 / 27002:2022

**Version cited:** 2022
**Applicability to Kryptonian components:** Recommended-practice context for operational controls; no ISMS/conformity claimed
**Applicability class:** Recommended (context)

### NIST SP 800-53 Rev. 5

**Version cited:** 2020
**Applicability to Kryptonian components:** Control catalogue for §8 coverage mapping; recommended practices only
**Applicability class:** Recommended (context)

### NIST SP 800-63B (Rev. 3 2017; Rev. 4 published 2025)

**Version cited:** see note
**Applicability to Kryptonian components:** Password/authenticator guidance for admin authentication; Rev. 4 existence verified 2026-10-13 via pages.nist.gov fetch; formal mapping not performed
**Applicability class:** Recommended

### NIST SP 800-57 Pt 1 Rev. 5

**Version cited:** 2020
**Applicability to Kryptonian components:** Key-management guidance (CA key protection, lifetimes) - partly unmet (file-based CA keys, THR-016)
**Applicability class:** Recommended

### NIST SP 800-52 Rev. 2

**Version cited:** 2019

**Applicability to Kryptonian components:** TLS protocol/cipher guidance for the gateway's TLS listeners
**Applicability class:** Recommended

### NIST SP 800-218 v1.1

**Version cited:** 2024
**Applicability to Kryptonian components:** Secure-development practices (CI, review, dependency policy)
**Applicability class:** Recommended

### DICOM PS3.15 (B.12/B.13 TLS profiles)

**Version cited:** current
**Applicability to Kryptonian components:** Related context for the DIMSE-TLS demonstration; **not certified, not claimed**
**Applicability class:** Optional / related context

### DICOM PS3.18

**Version cited:** current
**Applicability to Kryptonian components:** Context for the DICOM-over-TLS application path
**Applicability class:** Optional / related context

### IEEE 11073-20701 / -20702 (SDC)

**Version cited:** 2018-era
**Applicability to Kryptonian components:** **Research goals only** via OR.NET collaboration; no adopted profile; full texts unavailable to review
**Applicability class:** Informational

### IHE SDPi Technical Framework

**Version cited:** 2.4 (Trial Implementation / Standard for Trial Use, 7 May 2026)
**Applicability to Kryptonian components:** Context only; no EST enrollment profile adopted by OR.NET
**Applicability class:** Informational

### IHE ATNA

**Version cited:** current
**Applicability to Kryptonian components:** Future audit-format mapping (GAP-012); not implemented
**Applicability class:** Optional / future

### OWASP ASVS

**Version cited:** 4.0.3
**Applicability to Kryptonian components:** Verification checklist for §11 mapping
**Applicability class:** Recommended

### CycloneDX 1.5+ / SPDX 2.3

**Version cited:** 1.5+ / 2.3
**Applicability to Kryptonian components:** Candidate SBOM formats (GAP-031); not implemented
**Applicability class:** Optional

Applicability classes: **Mandatory** = the product's defined behavior depends on it; Recommended = good-practice reference, not adopted as a conformance target; Optional = selective/conditional use; Informational = context only.

(RFC 8951, a base64-processing clarification for EST referenced by docs/ORNET-ALIGNMENT-2026-09-09.md, is carried as DOCUMENTED-only context; its edition was not re-verified during drafting.)

## 3. RFC 7030 capability status

Status vocabulary per §1; evidence classes per KSPEC-000 §5.

| RFC 7030 capability (clause) | Status | Evidence and notes |
|---|---|---|
| `/cacerts` - CA certificate chain distribution (§4.1) | Supported | `EstController.cs`; executed curl-based evidence VERIFIED (tracker). Profile resolved by host/path; unknown label → 404 with no default fallback (deliberate hardening) |
| `simpleenroll` (§4.2.1) | Supported | PKCS#10 in, PKCS#7 chain out; 64 KiB CSR cap; executed Schannel mTLS enrollment evidence VERIFIED |
| `simplereenroll` (§4.2.2) | Supported | Requires native TLS client certificate; new key generated, approved identity preserved - executed evidence VERIFIED |
| HTTP Basic bootstrap authentication (§3.2.3) | Supported (credential-semantics choice) | Standard Basic over HTTPS using registered device UUID + one-time activation code (PR #42); activation-code semantics are a documented gateway choice |
| Re-enroll authentication over TLS (§3.2.3) | Supported | Native TLS client certificate required; 401 without - executed evidence VERIFIED |
| Pending enrollment (202 semantics) | Supported (Retry-After defined; trigger matrix undefined) | 202 + `Retry-After` + JSON body CODE-OBSERVED; per-backend pending triggers `TBD` (GAP-004, SR-F-EST.011 Missing) |
| `/csrattrs` (§4.5.2) | **Not implemented** | GAP-001 (SR-F-EST.014 Missing); RFC 9908 (verified, Jan 2026) clarifies encoding for any future implementation |
| `/serverkeygen` (§4.5.3) | **Not implemented** | GAP-002; stakeholder scope decision open |
| Full CMC (`fullcmc`, §4.6) | **Not implemented** | GAP-003; declared subset scope (Mvp.md); recorded as deviation |
| Media types (§4.2.3) | Deviating (documented leniency) | `text/plain` CSR acceptance intentional; strict media-type interop remains untested (KSPEC-005 §13) - GAP-021 |
| DNS-based discovery (§3.1) | Untested | `ESTserver.<domain>` TXT discovery not exercised; clients are preconfigured with enrollment URLs (briefing guidance) |
| Link-header rel="next" / additional endpoints (§4.5) | Untested | Not implemented and not exercised |
| Legacy private activation headers | Deviating (compatibility only) | Sample-client compatibility only; must not become an interoperability requirement (SR-F-EST.007/SR-F-INT.002; GAP-020) |
| CRL inside `/cacerts` (§4.1 informational) | Untested | CRLs are published from a separate CRL controller path, not embedded in `/cacerts` |

# 4. X.509 / PKIX (RFC 5280) profile features

| RFC 5280 feature | Status | Evidence and notes |
|---|---|---|
| Subject DN / issuer DN | Supported | Profile subject-DN rules enforced at issuance (SR-C.001); issuer matching on re-enrollment (409 issuer-mismatch guard, SR-X.003) - VERIFIED |
| Subject Alternative Name | Supported (policy-gated) | SAN handling bound by profile; unauthorized SAN assertions in the proposed test matrix (GAP-033) are unexecuted - CODE-OBSERVED for enforcement, negative-path evidence partial |
| Extended Key Usage (clientAuth 1.3.6.1.5.5.7.3.2 / serverAuth) | Supported | Client certificates validated for clientAuth EKU; profile key-usage/EKU policy enforced (SR-C.001, SR-S.002) - executed + CODE-OBSERVED |
| Key usage / basic constraints | Supported | Profile key-usage policy; leaf-vs-CA checks in `ConfiguredClientCertificateTrust` - CODE-OBSERVED |
| CRLs (issuer-scoped, signed, CRL number, nextUpdate) | Supported (prototype cadence) | Issuer-scoped signed CRLs with monotonic CRL number and `nextUpdate`; transactional revocation persistence (SR-F-CLM.007/008) - executed evidence VERIFIED; 60-second lifetime is a demo value (GAP-010) |
| CRL distribution points on issued certificates | Supported | SR-C.006 - CODE-OBSERVED; launcher server leaf intentionally lacks a CDP (documented dev exception) |
| Online revocation checking (X509Chain + CRL retrieval) | Supported (demonstrated) | Native online X509Chain reports Revoked independently of registry lookup - executed evidence VERIFIED (tracker); 5-second URL timeout |
| OCSP (RFC 6960) | Not implemented | Optional; CRL-only revocation at baseline |
| AIA (authority information access) | Untested | Not evidenced in issued certificates or validation path - UNKNOWN |
| Path validation (RFC 5280 §6) via custom root trust | Supported (implementation-selected) | Custom-root-trust chain build for client certificates and proxy peers - executed evidence VERIFIED; full RFC 5280 §6 algorithm conformance not separately verified |
| Name constraints / policy extensions | Not used | Not required by profiles; noted as not exercised |
| SHA-256/RSA and ECDSA algorithm support | Partially evidenced | CSR algorithm floor enforced (SR-S.002 area); RFC 8295 algorithm-set alignment not formally checked |

# 5. TLS posture (NIST SP 800-52 Rev. 2 as guidance)

| Aspect | Status | Notes |
|---|---|---|
| TLS 1.2 minimum | Supported (default posture) | ASP.NET Core/Kestrel defaults per deployment configuration; explicit min-version pinning not evidenced in-repo - CODE-OBSERVED defaults, explicit SP 800-52 mapping not performed |
| TLS 1.3 availability | Untested (platform-provided) | Available via .NET/Schannel or OpenSSL depending on host; no explicit configuration or test evidence |
| Cipher-suite policy per SP 800-52 Rev. 2 | Untested | No in-repo cipher configuration; SP 800-52 Appendix suites not mapped |
| mTLS (client certificates) on device listeners | Supported | `ClientCertificateMode.AllowCertificate` + `ConfiguredClientCertificateTrust`; executed mTLS evidence VERIFIED |
| mTLS on DICOM demonstration peers | Supported (demo) | Both peers enforce issuer, TLS purpose, and online revocation - executed evidence VERIFIED |
| Plain-HTTP refusal (426) for EST | Supported | Executed + CODE-OBSERVED; `AllowPlainHttp` escape hatch documented (GAP-015) |
| Certificate-forwarded identity over TLS (XFCC) | Deviating | Proxy-trust boundary; forwarder authenticated by source IP only (GAP-009, SR-S.005) |
| Forward secrecy / key-exchange review | Untested | No evidence; deferred to independent security assessment (README disclaimer) |
| HSTS / TLS hardening on admin listener | Untested | Not evidenced; belongs to hardening checklist (GAP-037) |

## 6. DICOM TLS profiles (B.12 / B.13) - related context, explicitly no certification claim

| Aspect | Status | Notes |
|---|---|---|
| Mutual-TLS DICOM association (DIMSE over TLS) | Demonstrated (lab) | Two actual mutual-TLS DICOM C-STORE transfers with received-file reopen and SOP Instance UID comparison - executed evidence VERIFIED (tracker, artifacts/developer evidence.json) |
| TLS cipher-suite selection per DICOM B.12/B.13 profiles | Untested | No profile-specific suite negotiation was exercised or configured; fo-dicom TLS store defaults used |
| Peer certificate authorization (issuer, purpose, revocation) | Supported (demonstrated) | Both peers enforce issuer, TLS purpose, and online revocation - executed evidence VERIFIED |
| B.12/B.13 certification | **Not claimed** | Per KSPEC-000 §3 and docs/IMPLEMENTATION-TRACKER.md: "No … DICOM B.12/B.13 certification is claimed." The DICOM TLS profile documents define TLS behavior for DICOM; Kryptonian's demonstration is consistent in spirit (mTLS DICOM transport with gateway-governed trust) but no profile conformance testing was performed |
| Role selection / SCU-SCP TLS requirements of B.13 | Untested | Not evaluated against the profile text |

**Related-context boundary (KSPEC-000 §3):** the DIMSE-TLS proxy is a demonstration component; it establishes network trust (mTLS peer authentication) for DICOM associations and derives no clinical capability or DICOM conformance.

## 7. IEEE 11073 SDC / OR.NET alignment - research goals only

| Aspect | Status | Notes |
|---|---|---|
| SDC (IEEE 11073-20701/-20702) participation | **Not claimed** | No SDC participant interoperability test has been performed; no SDC conformity is claimed (docs/CHANGES-AND-ORNET-ALIGNMENT.md) |
| OR.NET certificate working-group alignment | Proposed collaboration | EST direction and white paper are correspondence-reported intentions; not an agreed joint architecture (docs/ORNET-ALIGNMENT-2026-09-09.md) |
| Adopted EST profile for medical devices | None | No OR.NET-approved clinical identity/role profile exists; Kryptonian implements its own profile policy (KSPEC-003 SR-C.001) |
| SDC OIDs in issued certificates | Not used | "Issuing a certificate containing SDC OIDs alone is not an SDC interoperability demonstration" (briefing) |
| IHE SDPi | Context only | SDPi 2.4 is Trial Implementation; its existence does not establish that Kryptonian's bootstrap, certificate contents, or renewal policy are accepted |
| Certificate renewal semantics | Cryptographic credential renewal only | Never recertifies clinical safety, regulatory status, or SDC conformity (binding wording across docs) |

# 8. Supported capabilities vs known deviations vs untested requirements

| Capability | Classification |
|---|---|
| EST cacerts/simpleenroll/simplereenroll with Basic bootstrap and native-TLS re-enroll | Supported (executed evidence) |
| One-time atomic activation; replay rejection | Supported (executed evidence) |
| Approval-gated enrollment; profile policy enforcement (subject DN, EKU, key usage, validity) | Supported (executed + CODE-OBSERVED) |
| Issuer-scoped signed CRLs; transactional revocation; fail-closed on unsupported remote revocation | Supported (executed evidence) |
| Automatic renewal with new key and identity preservation | Supported (executed evidence; in-application only - GAP-026) |
| Restart state preservation on SQLite | Supported (executed evidence) |
| DIMSE-TLS proxy trust checks (unknown/expired/revoked rejection; atomic PFX reload) | Supported (executed evidence) |
| Legacy compatibility activation headers | Deviating (compatibility only; GAP-020) |
| XFCC forwarded identity (source-IP-trusted proxy) | Deviating (GAP-009) |
| Media-type leniencies (text/plain CSR acceptance) | Deviating (documented; GAP-021) |
| 60-second prototype CRL lifetime | Deviating (demo value; GAP-010) |
| Developer server-leaf revocation skip (no CDP) | Deviating (dev-only; GAP-015) |
| `/csrattrs`, `/serverkeygen`, `/fullcmc`, DNS-based discovery, Link headers, OCSP | Untested / not implemented (GAP-001/002/003) |
| EST algorithm-set conformance to RFC 8295; RFC 5280 §6 full path-validation audit | Untested |
| SP 800-52 cipher policy; TLS 1.3 configuration | Untested |
| ATNA/DICOM audit event mapping; audit export | Untested / not implemented (GAP-012) |
| Hospital ADCS/EJBCA enrollment + revocation | Untested (GAP-018/019) |
| SDC participant exchange; OR.NET joint test vectors | Untested (GAP-022) |

# 9. Interoperability evidence summary (what was actually demonstrated)

Per docs/IMPLEMENTATION-TRACKER.md executed evidence and artifacts/developer/ verify-*/evidence.json; nothing below is upgraded beyond its recorded provenance.

| Evidence item | Demonstrated | Provenance |
|---|---|---|
| Independent curl HTTP Basic EST over real HTTPS (no private headers) | Initial enrollment path with a generic client | VERIFIED (tracker) |
| One-time activation replay rejection; renewal with new key preserving approved identity | Lifecycle core semantics | VERIFIED (tracker) |
| Forwarded-certificate spoof rejection; HTTP listener denies non-CRL requests | Negative-path XFCC/CRL listener controls | VERIFIED (tracker) |
| Two mutual-TLS DICOM C-STORE transfers with SOP Instance UID comparison; both peers enforce issuer/TLS purpose/online revocation | DICOM-over-mTLS demonstration | VERIFIED (tracker) |
| Administrator revocation → native X509Chain reports Revoked (no cache flush) | Revocation propagation through local CA CRLs | VERIFIED (tracker) |
| Gateway restart on populated SQLite preserves profile/issuer/devices | Restart state preservation (SQLite only) | VERIFIED (tracker) |
| Five loopback proxy tests incl. unknown/expired/revoked rejection and atomic PFX replacement (expired replacement fails closed) | Proxy trust lifecycle | VERIFIED (tracker) |
| Twenty device enrollment/lifecycle tests incl. real Schannel mTLS; WPF build; developer trust regression | Device-side client behavior | VERIFIED (tracker) |
| Windows CI builds UI + solution + proxy; UI npm advisory gate | Build/dependency gates (UI scope only) | VERIFIED (tracker) |
| ADCS connector vs real Microsoft NDES | **Not demonstrated** (runbook only; five connector gaps documented) | DOCUMENTED (docs/adcs-real-backend-demo.md) |
| EJBCA REST enrollment/revocation vs a real EJBCA | **Not demonstrated** | DOCUMENTED (SR-F-CAI.006) |

| Evidence item | Demonstrated | Provenance |
|---|---|---|
| Independent third-party EST server/client pair; issuer rollover; CA outage | **Not demonstrated** | DOCUMENTED (briefing matrix) |
| SDC participant exchange; OR.NET joint testing | **Not demonstrated** | DOCUMENTED (boundaries) |
| PostgreSQL persistence | **Not demonstrated** | DOCUMENTED (tracker) |

# 10. Required additional verification

1. Hospital CA interop: execute the ADCS/NDES runbook (GAP-018) and a real-EJBCA enrollment + revocation exercise (GAP-019); record artifacts.

2. Independent-client EST matrix over real TLS ingress, including failure paths (GAP-033) and one jointly agreed OR.NET test case (GAP-022).

3. TLS policy review against SP 800-52 Rev. 2 (min version, suites, forward secrecy) and DICOM B.12/B.13 suite selection if profile alignment is ever desired (§5, §6).

4. RFC 7030 completeness: `/csrattrs` per RFC 9908; pending-trigger matrix; media-type deviation record (GAP-001/004/021).

5. RFC 5280 §6 path-validation audit and RFC 8295 algorithm-set check (§4).

6. Security assessment: independent assessment per README disclaimer; ASVS-based review (§11 mapping); SP 800-63B-based authentication review; SP 800-218 SDV practices check; SP 800-57 key-management review for CA keys.

7. PostgreSQL verification and backup/restore drills (GAP-034/036).

8. ATNA/DICOM audit-mapping analysis if audit interop becomes a goal (GAP-012).

# 11. Security control coverage mapping

Recommended-practice mapping only (KSPEC-000 §13): no conformity claim is made; rows marked **Gap** correspond to KSPEC-010 GAP IDs.

## 11.1 NIST SP 800-53 Rev. 5 - selected families

| Family | Implemented controls (AS-IS, with provenance) | Gaps |
|---|---|---|
| AC (Access Control) | Three-role RBAC; explicit role policies on mutations (partial); anonymous-surface limitation; CORS restriction (SR-Z, SR-S.013) - VERIFIED/CODE-OBSERVED | SR-Z.007 partial (mutation role-policy completeness); admin rate limiting absent (GAP-007) |
| AU (Audit) | Enrollment events, blocked attempts, admin action logging, structured correlated logging (SR-U.001-.004) - VERIFIED/CODE-OBSERVED | No tamper-evidence, no export (GAP-012) |
| CA (Assessment) | Threat model (KSPEC-006), risk assessment (KSPEC-007), CI checks - draft artifacts | No independent assessment (README disclaimer; GAP-037) |
| CM (Configuration) | Documented configuration settings; additive schema upgrades - CODE-OBSERVED | Upgrade boundary, config-drift detection (GAP-034, GAP-029) |
| IA (Identification/Authentication) | Dual-scheme admin auth; BCrypt wf-12; hashed API keys; activation-code authentication - VERIFIED | JWT fallback secret (GAP-006), lockout (GAP-007), static keys (GAP-008), password policy/MFA (GAP-014) |
| IR (Incident Response) | Failed revocation reported honestly; fail-closed behaviors (SR-X.001/.002) - CODE-OBSERVED | No incident-response procedure/runbook - new requirement Proposed |
| PS (Personnel) | Not addressed (out of scope for a lab reference implementation) | Organizational controls - not applicable at baseline |
| SC (System/Communications) | HTTPS-enforced EST (426), TLS-only CRL listener restriction, mTLS, configured EST rate limits and CORS - CODE-OBSERVED; API CSRF protection not established by this review | SP 800-52 cipher policy (GAP-015/§5); XFCC forwarder auth (GAP-009) |
| SI (System Integrity) | CSR/returned-cert policy enforcement; certificate re-validation; fail-closed revocation; dependency advisories tracked - VERIFIED | Unremediated high advisories (GAP-005); no SBOM (GAP-031) |
| CP (Contingency) | Restart state preservation - VERIFIED (SQLite) | No backup/restore; no availability targets (GAP-034, GAP-035) |

### 11.2 OWASP ASVS 4.0.3 - chapter-level coverage

| ASVS chapter | Coverage at baseline | Gaps |
|---|---|---|
| V1 Architecture/threat | STRIDE model (KSPEC-006); trust-boundary diagram (KSPEC-004) | XFCC proxy trust boundary (GAP-009) |
| V2 Authentication | BCrypt wf-12; hashed API keys; JWT validation; login-failure non-enumeration (SR-A) | JWT secret fallback (GAP-006); lockout/rate limit (GAP-007); MFA absent (GAP-014) |
| V3 Session | 8-hour JWT lifetime; API-key role binding - VERIFIED/CODE-OBSERVED | Session revocation on credential change not evidenced - open question |
| V4 Access control | Three-role RBAC; role policies (SR-Z) | SR-Z.007 partial mutation coverage; self-service model Proposed (SR-Z.009) |
| V5 Validation/encoding | CSR parsing bounds (64 KiB); policy validation of CA responses | Framework-level; no dedicated review performed - untested |
| V6 Cryptography | BCrypt; SHA-256 thumbprints; RSA/EC issuance; Data Protection | Secrets at rest (GAP-011); key-ring persistence (GAP-013); CA keys file-based (SP 800-57 gap) |
| V7 Error handling/logging | Structured correlated logging; generic internal errors; role-authorized log stream (THR-018 controls) | Notification delivery swallow (GAP-025); audit tamper-evidence (GAP-012) |
| V8 Data protection | UTC discipline; activation-code hashing; demo-record distinctness (SR-D) | Retention policy TBD (GAP-030); encryption approach TBD (SR-S.008) |
| V9 Communications | TLS-only EST; CRL listener restriction; mTLS | Cipher policy untested (§5) |
| V10 Malicious code | CI gates; dependency advisories tracked | High advisories unremediated (GAP-005); no SBOM (GAP-031) |
| V11 Business logic | One-time activation; approval gating; issuer-mismatch guards; fail-closed semantics (SR-X) | Pending determinism (GAP-004); escape hatches (GAP-015) |
| V12 Files/resources | 64 KiB cap; PFX ACLs; sandbox isolation | Unencrypted key export in demo (GAP-017) |
| V13 API | Partial contract-first files; missing implemented paths/security schemes; Client empty and Schema stale (GAP-029) | OpenAPI.Client empty, Schema stale; no EST contract (GAP-029) |
| V14 Configuration | Documented settings; sandbox mode | Hardening checklist absent (GAP-037); dev bypass confinement (GAP-015) |

## 12. Open implementation questions

1. Which forwarder-authentication mechanism closes SR-S.005 (GAP-009), and is XFCC retained at all if browser/mTLS listener separation (GAP-024) proceeds?
2. Is `/csrattrs` (RFC 9908 semantics) required for the joint OR.NET test case, or is out-of-band profile documentation acceptable (GAP-001)?
3. Which production CRL lifetime/propagation policy (GAP-010) and which OCSP position?
4. Is server-side key generation in scope (GAP-002)?

5. What audit format target - internal hash-chained records first, ATNA mapping later (GAP-012)?
6. Does the production renewal model (GAP-026) rely on a device-resident agent, and does that change the EST profile?
7. Which secret store is the reference deployment (GAP-011)?

## 13. Disclaimer (restated)

**No third-party certification or standards-body approval is claimed.** This document records implementation status, evidence provenance, and verification needs only. EST, SDC, SDPi, ATNA, DICOM TLS, and control-framework conformity are expressly not claimed (docs/ORNET-ALIGNMENT-2026-09-09.md review limits; README disclaimer; KSPEC-000 §13). The repository remains a research prototype requiring independent security assessment before any clinical or production use.

*End of KSPEC-011, version 0.2 (Draft). Approval state "Review Required"; no approval is recorded or inferred.*

# Kryptonian Engineering Handoff Specification

| Field | Value |
|---|---|
| Document title | Engineering Handoff Specification (KSPEC-012) |
| Document ID | KSPEC-012 |
| Version | 0.2 (Draft) |
| Review status | Draft - pending review |
| Created | 2026-10-13 |
| Baseline repository commit | `682f996c8447afec13bc1fce5b7f59e6a06efa25` (branch `feat/windows-sandbox-installer`, "Release Windows gateway and portable enrollment demo 0.1.4") |
| Repository | https://github.com/AAPM-RT-SEC/RTSec.Kryptonian |
| Revision history | 0.1 - 2026-10-13 - Initial draft: implementation-independent engineering handoff synthesized from KSPEC-000 - KSPEC-007 (Author: integration engineering lead). |
| Source references | KSPEC-000 (conventions); KSPEC-001 (product definition); KSPEC-002 (UR-nnn); KSPEC-003 (SR-* register, 154 requirements); KSPEC-004 (design); KSPEC-005 (ICD-nnn); KSPEC-006 (THR-nnn); KSPEC-007 (ORK-nnn); docs/IMPLEMENTATION-TRACKER.md; docs/development.md; docs/DEPLOYMENT.md; docs/admin-setup.md |
| Author | Name: TBD - Date: TBD - Signature: TBD |
| Reviewer | Name: TBD - Date: TBD - Signature: TBD |
| Approver | Name: TBD - Date: TBD - Signature: TBD |
| Reconciliation revision | 0.2 - 2026-10-13 - source/document audit and publication controls (KSPEC-016) |

This document is the engineering handoff for the RTSec.Kryptonian Certificate Enrollment Gateway. It is written for an **independent engineering team** that must implement, test, maintain, and extend the system **without reading the original prototype code**. Every normative statement here defers to the specification documents it references; this document consolidates, prioritizes, and sequences - it does not redefine requirements (KSPEC-000 §7).

**Prototype disclaimer (binding):** a prototype implementation exists in the repository at the baseline commit. It is **reference material only**. Where prototype behavior conflicts with the specification (KSPEC-002/003/004/005/006), **the specification is normative and prototype behavior is not**. Known prototype weaknesses are recorded as findings and gaps (KSPEC-004 §16.2; KSPEC-006 §9.2) and must never be reproduced as intended behavior (KSPEC-000 §4).

**Package integration:** KSPEC-008 through KSPEC-011 are present and are the controlling references for verification, traceability, gaps, and standards readiness. Resolve discrepancies against the canonical KSPEC-003 requirement record and the reconciliation report, rather than document publication order.

## 1. Introduction

### 1.1 Purpose

To transfer, in one place, everything an independent team needs to build and operate the gateway to the specified target: system description, workflows, interface contracts, the security model, the certificate lifecycle, external integrations, architectural decisions and their rationale, testing obligations, unresolved decisions, a phased roadmap, and a definition of done.

### 1.2 Intended audience

• Implementation engineers (backend, platform, UI).

• Test/QA engineers preparing verification against KSPEC-008.

• DevOps/deployment engineers and hospital integrators.

• Reviewers of the formal specification package (KSPEC-000 §1 review sequence: KSPEC-012 sits after 008-011 and before independent review, KSPEC-013).

### 1.3 Conventions

• Identifier scheme, provenance classes (VERIFIED / CODE-OBSERVED / DOCUMENTED / INFERRED / PROPOSED / UNKNOWN), status classes (Existing / Partial / Missing / Proposed), and AS-IS / TO-BE / PROPOSED classification per KSPEC-000 §4-§7.

• Requirements are referenced by ID only (UR-nnn, SR-*, THR-nnn, ORK-nnn, ICD-nnn); the canonical requirement text lives in KSPEC-003 and KSPEC-002.

• Diagrams are Mermaid per KSPEC-000 §12.

• Verification method abbreviations: T/I/A/D per KSPEC-000 §11.

• No standards-conformity claims and no regulatory/medical-device classification are made anywhere in this document (KSPEC-000 §3).

## 2. System description (what the receiving team must build)

**Provenance: TO-BE intent synthesized from KSPEC-001 §2; AS-IS elements noted.**

Kryptonian is **enterprise healthcare IT cybersecurity infrastructure** (KSPEC-000 §3; KSPEC-001 §2.1): a certificate enrollment, identity provisioning, and credential lifecycle management gateway for networked medical devices. It sits between device-side EST clients (RFC 7030 Enrollment over Secure Transport) and one or more hospital-authorized certificate authority (CA) backends. It is **not** a regulated medical device, performs **no clinical functions**, and no clinical capability may ever be derived from gateway state (KSPEC-000 §3; KSPEC-001 EXC-001, EXC-002; SR-Z.010).

The problem it solves (KSPEC-001 §2, DOCUMENTED): hospitals operate heterogeneous CA infrastructures (Microsoft ADCS, EJBCA, ACME services, private self-signed CAs) while device manufacturers cannot control which CA a given hospital uses. The gateway abstracts the CA choice behind a single standards-based device-facing protocol so a device enrolls identically at every hospital.

Core capabilities, mapped to specification areas:

| Capability | Specification area | Representative requirements |
|---|---|---|
| One-time-code device onboarding | Device registration (SR-F-REG) | SR-F-REG.001-010 |
| EST protocol surface (RFC 7030 style) | EST behavior (SR-F-EST) | SR-F-EST.001-014 |
| Certificate lifecycle: issuance, renewal, expiry visibility, revocation | Lifecycle (SR-F-CLM, SR-C) | SR-F-CLM.001-010, SR-C.001-010 |
| Pluggable CA backends behind one abstraction | CA integration (SR-F-CAI) | SR-F-CAI.001-010 |
| Administrative portal + REST automation | Administration (SR-F-ADM, SR-F-INT) | SR-F-ADM.001-010 |

| Capability | Specification area | Representative requirements |
|---|---|---|
| Security controls: transport, secrets, RBAC, audit | Security/authn/authz/audit (SR-S, SR-A, SR-Z, SR-U) | SR-S.001-014, SR-A.001-010, SR-Z.001-010, SR-U.001-007 |
| Durable state, deployment, reliability | Data/deployment/reliability (SR-D, SR-B, SR-R, SR-V, SR-X) | SR-D.001-009, SR-B.001-007, SR-R.001-005, SR-V.001-004, SR-X.001-007 |

System boundary (KSPEC-001 §6): the gateway comprises the API host, the admin portal (API-served React/TypeScript dashboard plus optional separate Blazor Server portal UI), and its persistence. Outside the boundary: the devices themselves, the CA backends, the SMTP relay, the fronting TLS proxy, and the demonstration components (`Kryptonian.MedicalDevice`, `Kryptonian.DICOMTls`, DIMSE-TLS proxy), which are demonstration/reference clients, **not production deliverables** (KSPEC-000 §3; SR-F-INT.005/006).

# 3. Required workflows (end-to-end walkthroughs)

These walkthroughs are the TO-BE operational behavior an implementation must support. They are consolidated from KSPEC-004 §6-§7 (data flows and sequence diagrams), KSPEC-003 (SR-* obligations), and KSPEC-005 (ICD contracts). Sequence diagrams of record: KSPEC-004 §7.1-§7.6. State machines of record: KSPEC-004 §8.

## 3.1 Device registration (administrator)

1. An administrator (DeviceAdmin or SystemAdmin, SR-Z.002) registers a device by entering **only an administrative alias** - no certificate identity is entered manually (UR-001; SR-F-REG.001). The device record is created in status `Pending` (KSPEC-004 §8.1).

2. The gateway issues a **one-time activation code**: shown once in the API/portal response, stored **hashed only**, with an expiry time (optional validity parameter on the request) (SR-F-REG.002; SR-A; KSPEC-005 §10 ICD-ADM.001).

3. The administrator delivers the code to the device over a provisioning channel that is out of scope for the gateway (KSPEC-001 ASM assumptions).

4. Self-service device requests, where enabled, create **pending records only** and require administrator approval before any credential can be issued (SR-F-REG.006); the anonymous request surface is limited to the documented set (SR-Z.008) and must gain abuse controls (SR-F-REG.007 - Missing at baseline, required in TO-BE).

## 3.2 Device activation and initial EST enrollment

1. The device generates its own key pair and builds a PKCS#10 CSR whose subject CN carries its identity; the gateway never generates the device key (KSPEC-004 trust note AS-1; SR-S.011 - device private key non-archival).

2. The device fetches bootstrap trust: `GET /.well-known/est/cacerts` (or `/{label}/cacerts`) returns the profile's CA chain as base64 PKCS#7 certs-only (SR-F-EST.002; ICD-EST.001). Profile resolution is by request host + path prefix; unknown labels are rejected with **404 and never fall back** to a default profile (SR-F-EST.005).

3. The device submits the CSR: `POST /.well-known/est/{label}/simpleenroll` authenticated by **HTTP Basic where the username is the device-record identifier and the password is the activation code**, over TLS only (SR-F-EST.006; ICD-EST.002). Plain-HTTP EST is refused with 426 (SR-F-EST.012). Legacy private activation headers observed in the sample client are **compatibility only and never a requirement** (SR-F-EST.007; SR-F-INT.002; UR-019).

4. Gateway-side validation order (KSPEC-004 §7.1): resolve the enabled EST profile; parse the CSR (raw DER, base64, or PEM; ≤ 64 KiB; signature **always** verified - SR-F-EST.003, ICD-PCR.001); find the pending device by CSR subject CN / activation hash; reject on unknown/expired/replayed code, missing identity, or CN collision; otherwise validate the CSR signature, bind CN + device metadata (manufacturer, model, serial - SR-F-REG.009), and **consume the activation code atomically**.

5. The orchestrator routes issuance to the **profile's bound CA backend** (never the globally active backend - B-3 in KSPEC-004 §5), via the connector factory (SR-F-CAI.002/003). CSR policy (subject-DN rules, key usage, validity) and returned-certificate policy are enforced before delivery (SR-S.002; SR-C.001; THR-004).

6. On success: certificate metadata is persisted, an `Issued` enrollment event is recorded (SR-C.010), the device becomes `Active`, and the EST response returns the leaf + chain as PKCS#7 certs-only (SR-F-EST.004; ICD-PCR.002). On rejection the gateway records a rejected event with reason and requestor IP and dispatches a rejection notification; the CA never sees unapproved requests.

7. If the backend cannot decide synchronously, the gateway returns **202 Accepted with** `Retry-After` and the enrollment event stays `Pending` until the backend outcome is known (SR-F-EST.010; ICD-EST.004). Deterministic per-backend pending semantics are required in TO-BE (SR-F-EST.011 - Missing, TBD matrix).

## 3.3 Renewal (device)

1. Renewal uses `POST /.well-known/est/{label}/simplereenroll` authenticated by the **current certificate presented as a native TLS client certificate** - never the activation code (SR-F-EST.008/009; SR-A.008). Client-certificate validation enforces configured trust anchors, clientAuth EKU, and online revocation checking (KSPEC-006 boundary B-1; SR-F-EST.009).

2. The gateway resolves the device by certificate identity, checks device status and policy, preserves the **approved identity** across renewals, and issues a new certificate for a **new key** (SR-F-CLM.003; UR-021; VERIFIED per IMPLEMENTATION-TRACKER.md).

3. Renewal within the renewal window requires **no new administrator approval** (SR-F-CLM.002; SR-C.004). Revoked or removed devices are denied renewal (SR-F-CLM.009).

4. The device installs the new key and certificate atomically before switching to the new credential and retains the old certificate for overlap (KSPEC-004 §10; docs/development.md). Pending-response retries apply as in §3.2 step 7.

## 3.4 Revocation and retirement (administrator)

1. An administrator with DeviceAdmin+ revokes a certificate: `POST /api/certificates/{id}/revoke` with a valid `RevocationReason` (`RemoveFromCrl` is explicitly rejected) (SR-Z.005; ICD-ADM.004).

2. The gateway verifies the certificate chains to the configured issuer, gathers all revoked serials for that issuer, increments the issuer CRL number, obtains a signed **issuer-scoped CRL** from the connector, and persists the CRL state and certificate status change **transactionally** (SR-F-CLM.007/008; ICD-PCR.003).

3. If the backend does not support remote revocation **and** cannot generate a CRL, revocation **fails closed** (HTTP 501/503; no silent success) (SR-X.001; SR-F-CAI.008; THR-010).

4. Revoked devices are denied enrollment and renewal; revocation denial is distinguishable from enrollment denial (SR-C.009). Revocation propagates via CRL fetch by TLS peers; **no instant mid-association termination is promised** - established sessions end at bounded lifetimes (SR-C.008; UR-010 constraints; KSPEC-002 §16.4).

5. Device removal (soft) blocks all future enrollment/renewal; permanent delete may be rejected to preserve history (SR-F-REG.010). TO-BE requires distinguishing `Untrusted` from `Retired` status semantics (KSPEC-004 §16.2 A-1 - see §10 register).

## 3.5 Administrator bootstrap and account management

1. First-time setup runs through the initial-account wizard (or an environment-seeded initial administrator) and is refused once setup is complete (409) (SR-F-ADM.005; ICD-ADM.007 `/api/auth/setup`). The last active SystemAdmin cannot be deleted or deactivated (SR-F-ADM.003; THR-009 control).

2. Users authenticate to `/api/*` via JWT Bearer (8-hour tokens) or API keys (`X-API-Key`); passwords are BCrypt-hashed (work factor ≥ 12) (SR-A.001/003/009; ICD-ADM.001 preamble). API keys are stored as SHA-256 hashes with a visible

prefix, carry the **generation-time role**, and are shown once at creation (SR-A.003/005; SR-Z.006). Login failures never disclose which factor was wrong (SR-A.010).

### 3.6 CA backend and EST profile administration

1. A SystemAdmin configures CA backends through guided fields or advanced JSON (SR-F-CAI.001; ICD-ADM.002), **tests** reachability before activation (SR-F-CAI.002), and activates **exactly one** backend as the globally active one - understanding that issuance routing is actually **profile → backend** (B-3; SR-F-CAI.004). Deleting a backend in use is rejected (400/409).

2. EST profiles bind devices to a backend plus policy: path prefix, hostnames + match type, certificate template, allowed key usages, validity days, client certificate requirements, trusted client CA thumbprints (KSPEC-004 §9.1 `EST_PROFILE`; SR-C.001). Profile updates are **additive for trust lists** - partial updates preserve omitted trust data (SR-F-ADM.007; PR #47 evidence).

3. Self-signed CA generation (PFX export, thumbprint, NotAfter) is a SystemAdmin operation (ICD-ADM.002 `generate-selfsigned`); CA material persists durably (SR-F-CAI.009).

### 3.7 Monitoring, notifications, and day-2 operations

1. The dashboard summarizes backend state, device counts, enrollment outcomes, and backend evidence (SR-F-ADM.002); a live activity feed and structured, correlation-ID-linked logging support triage (SR-F-ADM.009; SR-U.003).

2. Notification settings (SMTP host/port/TLS mode/auth mode, recipients) are managed via API with passwords stored encrypted and never returned (ICD-ADM.009; ICD-CFG.002). A test-send validates draft settings.

3. The **expiry watcher** (a background hosted service) scans certificates daily, warns 1-365 days ahead (default 14), debounces 7 days per certificate, and skips certificates already renewed (KSPEC-004 §10; SR-F-CLM.004/005). It must be fault tolerant: scan failures are caught and the watcher continues (SR-R.001), but TO-BE requires surfacing repeated scan failure as an alert (KSPEC-007 §5).

4. Non-renewal alerting: certificates approaching expiry without a completed renewal generate alerts (SR-F-CLM.006 - Partial; delivery reliability TBD, SR-R.003). Backup/restore is required in TO-BE with the completeness rule of KSPEC-007 §6.2 (database + CA material + Data Protection key ring + effective configuration).

## 4. Interface contracts

Full normative detail: KSPEC-005 (ICD items). Summary only here.

### 4.1 Interface surface overview (KSPEC-005 §2, ICD items per §1)

#### EST protocol

**Base path:** `/.well-known/est[/{label}]`
**Transport:** HTTPS only (plain HTTP refused, 426)
**Authentication:** TLS client certificate (re-enroll); HTTP Basic one-time activation (initial enroll)
**Audience:** Medical devices / EST clients

#### Admin REST API

**Base path:** `/api/*`
**Transport:** HTTPS
**Authentication:** JWT Bearer or `X-API-Key`
**Audience:** Administrators, portal UI, automation

### CRL distribution

**Base path:** `/api/crl/{issuerFingerprint}.crl`
**Transport:** Dedicated listener; HTTPS in production profile
**Authentication:** None (public by design); GET/HEAD only on the restricted listener
**Audience:** Any peer performing revocation checks

### ACME HTTP-01 challenges

**Base path:** `/.well-known/acme-challenge/{token}`
**Transport:** HTTP(S)
**Authentication:** None (anonymous by ACME design)
**Audience:** ACME servers

### Health/status

**Base path:** `/api/status/health`
**Transport:** HTTPS
**Authentication:** None
**Audience:** Orchestrators, load balancers

## 4.2 EST endpoint semantics (KSPEC-005 §3-§9, ICD-EST.001-006)

| Method | Path | Semantics |
|---|---|---|
| GET | `/.well-known/est/cacerts` | CA chain of profile resolved from Host + `/.well-known/est`; PKCS#7 certs-only, base64 |
| GET | `/.well-known/est/{label}/cacerts` | Same, label-scoped; unknown label → 404, no fallback |
| POST | `/.well-known/est/{label}/simpleenroll` | Initial enrollment; PKCS#10 in, PKCS#7 out; Basic activation bootstrap; 202 + Retry-After supported |
| POST | `/.well-known/est/{label}/simplereenroll` | Renewal; native TLS client certificate required; 202 + Retry-After supported |

Known AS-IS gaps that are TO-BE targets: `/csrattrs`, `/serverkeygen`, `/fullcmc` are not implemented (SR-F-EST.014 requires `/csrattrs`; `/serverkeygen` is a bounded PROPOSED extension - KSPEC-004 §16.3 P-3). Rate limiting applies to EST paths with 429 responses (ICD-EST.006; SR-S.006 - production values TBD). Error bodies and status-code semantics: KSPEC-005 §12 (ICD-ERR.001), including 413 for oversized CSRs and 501 as the fail-closed revocation signal.

## 4.3 Administrative API families (KSPEC-005 §10, ICD-ADM.001-012)

### Devices

**Base path:** `/api/devices`
**Authorization highlights:** DeviceAdmin for mutations; authenticated reads
**Representative operations:** Register, approve, activation code (+reactivate), remove, delete, list certificates/events, demo-enroll

### Device self-requests

**Base path:** `/api/device-requests`
**Authorization highlights:** **Anonymous** (bounded surface, SR-Z.008)
**Representative operations:** Submit approval request → creates pending record only

### CA backends

**Base path:** `/api/cas`
**Authorization highlights:** SystemAdmin for mutations
**Representative operations:** CRUD, test, activate, generate-selfsigned

### EST profiles

**Base path:** `/api/est-profiles`
**Authorization highlights:** SystemAdmin-level management (SR-Z.003)
**Representative operations:** CRUD with additive trust-list updates

### Certificates

**Base path:** `/api/certificates/{id}/revoke`
**Authorization highlights:** DeviceAdmin
**Representative operations:** Revoke with reason; 501/503 fail-closed mapping

### Users

**Base path:** `/api/users`
**Authorization highlights:** SystemAdmin
**Representative operations:** CRUD; last-admin lockout protection

### API keys

**Base path:** `/api/users/{userId}/api-keys`
**Authorization highlights:** Self or SystemAdmin
**Representative operations:** Generate (shown once), list, revoke

### Auth

**Base path:** `/api/auth/*`
**Authorization highlights:** Mixed (setup/login anonymous)
**Representative operations:** status, setup, login, logout, me

### Gateway settings

**Base path:** `/api/settings/gateway`
**Authorization highlights:** SystemAdmin (PUT)
**Representative operations:** Certificate-lifetime bounds

### Notification settings

**Base path:** `/api/settings/notifications*`
**Authorization highlights:** SystemAdmin for mutations
**Representative operations:** SMTP settings, recipients, test send

### Status/health/logs

**Base path:** `/api/status/*`
**Authorization highlights:** Authenticated per KSPEC-005 §10
**Representative operations:** Health, enrollments, log stream

### CRL

**Base path:** `/api/crl/{issuerFingerprint}.crl`
**Authorization highlights:** None (public)
**Representative operations:** Issuer-scoped signed DER CRL

Authoritative machine-readable contracts: the OpenAPI artifacts (`OpenAPI.Admin.yaml`, `OpenAPI.Client.yaml`, `OpenAPI.ESTProfiles.yaml`, `OpenAPI.Schema.yaml`, `OpenAPI.StatusObserve.yaml`). **Baseline caution:** the contract-first files are empty/stale relative to the implemented API (SR-F-INT.003/004 - Missing/Partial). The receiving team must regenerate and then maintain these as the authoritative contract (see §8.3 and Phase 1 exit criteria).

## 4.4 CA connector contract (KSPEC-005 §14, ICD-CAI.001-003)

The connector is the internal abstraction every CA backend implements. The language-neutral contract of record is KSPEC-005 §14; its operations and failure semantics are binding:

| Operation | Contract semantics |
|---|---|
| `Type()` | Backend type discriminator (`SelfSigned`, `Acme`, `Adcs`, `Ejbca`, …) |
| `GetCaCertificatesAsync` | Ordered CA chain for the backend's issuer; empty array (pre-issuance ACME/EJBCA) or exception mapped by the caller to 404/403/503 |
| `IssueCertificateAsync(csr, profile)` | Returns `Successful(leafCert, chain)` or `Failed(message)`; **never throws for backend rejection**; gateway maps to HTTP |
| `RevokeCertificateAsync(serial, reason)` | Native remote-CA revocation only; unsupported backends return `false` and log a warning - **never silent success** |
| `GenerateCrlAsync(request)` | Complete signed CRL for the connector's current issuer; must echo `ExpectedIssuerFingerprint`; default `Unsupported()` |
| `TestConnectionAsync` | Best-effort reachability probe |

The connector factory maps backend type → connector, **caches one instance per backend id (thread-safe)**, and fails closed (`NotSupportedException`) for unimplemented types (Cfssl, HashiCorpVault, Smallstep, OpenXpki exist only as enum values) (SR-F-CAI.003). Per-connector capability matrix (revocation/CRL support differences, fail-closed behavior): KSPEC-005 §14 ICD-CAI.002. New connectors shall be added behind this contract only (SR-O.001).

## 4.5 Database and configuration interfaces

- Persistence: EF Core over SQLite (exercised) and PostgreSQL (schema upgrades implemented, **not exercised** - SR-D.002, TBD-006); additive, idempotent schema upgrades on startup (SR-D.003); conceptual model KSPEC-004 §9.
- Configuration: layered appsettings/environment/secrets per KSPEC-005 §16 (ICD-CFG.001-002), `KRYPTONIAN__*` double-underscore environment names, per-connector JSON config with environment fallbacks, and the secret-handling rules summarized in §5.5 below.

# 5. Security model

Authoritative: KSPEC-006 (THR-nnn catalog, trust boundaries, controls mapping, residual risk). Summary for the receiving team.

## 5.1 Trust boundaries (KSPEC-006 §6)

| Boundary | Statement | Key controls |
|---|---|---|
| B-1 Devices ↔ gateway | EST requires HTTPS; renewal identity is a native client certificate validated against configured CA files, clientAuth EKU required, online revocation, bounded retrieval timeout | `ConfiguredClientCertificateTrust`; SR-F-EST.009 |
| B-2 Proxy ↔ gateway | XFCC forwarded certificate accepted only from configured known proxies, single header, never with a native client certificate | `CertificateForwardingGuard` (VERIFIED spoof rejection); TO-BE: authenticated forwarders (SR-S.005, KSPEC-004 P-2) |
| B-3 Gateway ↔ CA | Each profile resolves its **own** bound backend; the globally active backend is never used for issuance routing | Prevents cross-profile issuer substitution |
| B-4 Gateway ↔ CRL consumers | CRL served anonymously on a dedicated listener that accepts only GET/HEAD on the CRL path | VERIFIED non-CRL denial (SR-B.005) |
| B-5 Admin UI ↔ API | CORS-restricted policy, dual-scheme authentication, 3-role RBAC | SR-A/SR-Z; authorization tests |
| B-6 Gateway ↔ SMTP / ACME | Outbound TLS; credentials from data-protected storage; ACME challenge path public by protocol design | ICD-CFG.002; SR-S.008 |

## 5.2 Authentication and authorization model

• **Admin plane:** dual scheme - JWT Bearer (issuer/audience `kryptonian`, 8-hour lifetime, validated signature) or API keys; the policy scheme selects JWT when an `Authorization` header is present, otherwise the API-key scheme (SR-A.001/002; KSPEC-005 §10). Three roles: **Standard** (read-only), **DeviceAdmin** (device operations, revocation), **SystemAdmin** (system configuration, users, backends) (SR-Z.001-005). Authorization is enforced per mutation with explicit role policies (SR-Z.007 - Partial, TO-BE target).

• **Device plane:** initial enrollment via HTTP Basic bootstrap (activation code), renewal via native TLS client certificate; both fail closed on credential failure (SR-A.007/008; SR-X.005).

• **Forwarded-certificate path (reverse proxy):** the Envoy XFCC format is honored only through boundary B-2 controls; baseline trusts the proxy's identity - closing this with authenticated forwarders is a required TO-BE control (SR-S.005 - Missing).

## 5.3 Activation bootstrap

Activation codes are the **only** bootstrap credential for initial enrollment: one-time, time-limited, stored hashed, consumed on validated bootstrap acceptance before CA issuance, replay rejected (VERIFIED per executed evidence) (SR-F-REG.002; SR-X.005; THR-003). Consumption is race-safe at baseline: `UnitOfWork.TryConsumeActivationCodeAsync` enforces one-time semantics under optimistic concurrency (`DbUpdateConcurrencyException` → rejection), demonstrated by `DeviceActivationConcurrencyTests` (see KSPEC-004 §13, revised per RF-006). The TO-BE implementation must preserve this property, add row-version tokens on hot entities, and verify the crash-scope of consumption versus certificate issuance (KSPEC-004 §17 item 1; P-5 revised).

### 5.4 Revocation and CRL model

Issuer-scoped signed CRLs (RFC 5280) keyed by SHA-256 issuer fingerprint, monotonic CRL numbers, transactional persistence, CDPs on issued certificates, online revocation checking at peers, fail-closed on unsupported backends (SR-C.005/006/007; SR-F-CLM.007/008; SR-X.001). The prototype CRL lifetime is a 60-second demo value - production lifetime and stale-data handling are policy decisions (SR-S.012, SR-C.008 - TBD; THR-010).

### 5.5 Key and secret storage requirements

| Asset | Requirement | Reference |
|---|---|---|
| Device private keys | Generated by the device; **never archived** by the gateway (server-side key generation only as bounded PROPOSED `/serverkeygen`) | SR-S.011; KSPEC-004 A-2 |
| CA private keys (self-signed backend) | Held by gateway by design (TO-BE: evaluate HSM-backed keys, THR-008 PROPOSED controls); persisted durably; included in backup set | SR-F-CAI.009; KSPEC-007 §6.2 |
| SMTP password, ACME keys | Encrypted at rest via the data-protection service; never returned by the API (`hasPassword` boolean only) | ICD-CFG.002; SR-D.008 |
| Activation codes, API keys | Hashed only; raw values shown once | SR-F-REG.002; SR-A.003 |
| Backend `config` JSON | **May contain plaintext PFX passwords at baseline - known finding**; TO-BE requires encryption at rest and a secrets store (SR-F-CAI.010, SR-S.008 - Missing; TBD-005) | KSPEC-005 §16; THR-016 |
| JWT signing secret | Must be provisioned; the hard-coded development fallback must not survive into TO-BE (SR-A.006, SR-S.007 - Missing; THR-007) | KSPEC-006 §9.2 |
| Data Protection key ring | Persisted durably; required to decrypt stored secrets; part of the backup set | SR-D.007; KSPEC-007 §6.2 |
| Passwords | BCrypt work factor ≥ 12 | SR-S.009 |

### 5.6 Threat mitigations the implementation must preserve

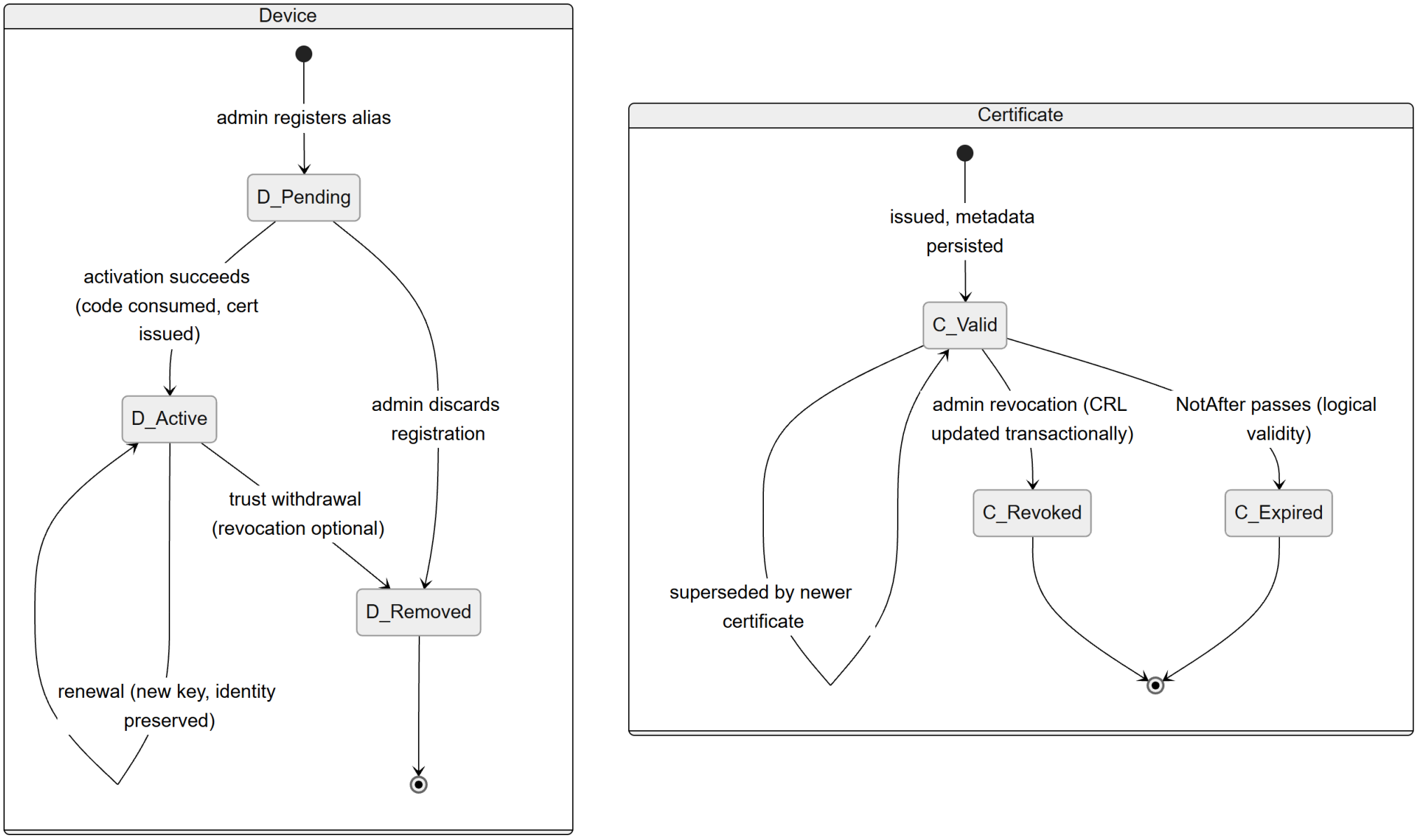
The implementation must preserve every VERIFIED mitigation in KSPEC-006 §9.1 (replay rejection; forwarded-certificate spoof rejection; non-CRL HTTP denial; revocation round-trip to native X509Chain `Revoked`; restart persistence of profiles/issuers/devices; independent curl HTTP-Basic EST over real HTTPS) and close the five dominant residual-risk areas of KSPEC-006 §9.2: dependency deployment blockers (THR-014, the only Critical band), administrative/secret defaults (THR-007/009/016), CRL cadence and freshness (THR-010), audit integrity (THR-015), and unverified institution-CA interoperability (THR-005/008). The full THR-001 - THR-018 catalog and per-threat PROPOSED controls are in KSPEC-006 §7.

## 6. Certificate lifecycle

Authoritative state machines: KSPEC-004 §8 (device status, certificate status, activation code, enrollment event); lifecycle design: KSPEC-004 §10; policy requirements: SR-C.001-010, SR-F-CLM.001-010.

### 6.1 States

## Diagram KSPEC-012-1




Rendered from 12-ENGINEERING-HANDOFF.md. Diagram sheets use larger page sizes to preserve readable labels.

Normative notes (KSPEC-004 §8):

• Baseline device statuses are `Pending`, `Active`, `Removed`; trust withdrawal collapses into `Removed`. TO-BE requires explicit `Untrusted` vs `Retired` semantics (KSPEC-004 §16.2 A-1; decision register §10, DEC-011).

• Certificate status: `Valid`, `Revoked`, `Expired`. Renewal produces a new `Valid` certificate; the old record is retained for audit history. Expiry is checked from NotAfter; no baseline job that persists the Expired enum value was observed.

• Enrollment events: `Issued`, `Pending`, `Rejected`, `Error` - target is one event per attempt (SR-C.010); AS-IS only selected branches persist an event (GAP-038).

• Activation-code lifecycle rides on device fields: issued (hashed) → consumed (replay rejected) / expired / void.

### 6.2 Renewal window and expiry monitoring

• Renewal is certificate-authenticated only; while the presented certificate remains valid and device/profile checks pass, no new approval is needed; the gateway has no time-window restriction on early renewal. The client scheduling policy determines when to request renewal (SR-C.004). The device-side simulator renews at two-thirds of certificate lifetime while the application runs (docs/development.md); **production long-lived/OS-service renewal policy is an open decision** (KSPEC-004 A-7; DEC-009).

• Certificate lifetime defaults come from gateway settings bounded by min/max, with per-profile `ValidityDays` override (SR-C.003). **The production lifetime policy is TBD** (TBD-001; must be chosen from outage tolerance vs. revocation objectives, not an arbitrary demo value).

• The expiry watcher scans daily, warns 1-365 days ahead (default 14), debounces 7 days per certificate, and skips already-renewed certificates (SR-F-CLM.005).

• Notification rules: near-expiry warnings and rejected-enrollment notifications dispatch via SMTP **best-effort**; gateway function never depends on SMTP availability (KSPEC-005 §17 ICD-EXT.001; SR-R.003). TO-BE: notification outbox for delivery reliability (KSPEC-004 P-6), defined trigger set (TBD-002), and non-renewal alerting completed (SR-F-CLM.006).

## 7. Required external integrations

Authoritative: KSPEC-005 §17 (ICD-EXT.001-004), §16 (ICD-CFG.001-002); KSPEC-004 §15. Configuration walkthroughs: docs/ca-backend-configuration.md, docs/admin-setup.md, docs/DEPLOYMENT.md.

### 7.1 CA backends and configuration expectations

#### Self-Signed

**Mechanism:** In-process signing (local CA cert + key, PFX or PEM pair) or harness EST relay
**Configuration expectations:** PFX path/password or cert/key paths; CRL distribution point URL; environment fallbacks `KRYPTONIAN__CA__SELFSIGNED__*`
**Revocation/CRL capability:** Gateway-side signed CRL supported; remote revocation n/a

#### ACME (RFC 8555)

**Mechanism:** Full ACME order flow (Certes-class client); http-01 challenge relay or DNS-01 (DNS-01 is a stub - SR-F-CAI.007 Partial)
**Configuration expectations:** Directory URL, account email, EAB key ID/HMAC, challenge type; gateway must be reachable for HTTP-01 challenges
**Revocation/CRL capability:** No revocation path exercised; fails closed

#### ADCS (Microsoft)

**Mechanism:** SCEP client against NDES: `GET {base}/scep/adcs?operation=GetCACert`, `POST {base}/scep/adcs?operation=PKIOperation`

**Configuration expectations:** SCEP base URL; optional enrollment-agent mTLS credential (PFX path/password or machine-store thumbprint) required under NDES challenge mode; template name in profile

**Revocation/CRL capability:** Remote revocation **not implemented** (returns false); CRL unsupported → fail closed; real-ADCS interoperability **unverified**

#### EJBCA

**Mechanism:** REST client: `POST {base}/ejbca/ejbca-rest-api/v1/certificate/pkcs10enroll`, `PUT .../certificate/{issuerDn}/{serial}/revoke`

**Configuration expectations:** REST base URL; `IssuerDn` required for revocation; REST credentials

**Revocation/CRL capability:** Native remote revocation **supported** when IssuerDn configured; CRL generation unsupported → fail closed

All backends are configured through the admin API/portal (guided fields or advanced JSON) with per-backend `Config` JSON and environment fallbacks (ICD-CFG.001); credentials must move into a secrets store in TO-BE (SR-F-CAI.010; TBD-005).

### 7.2 SMTP

MailKit-based sender; StartTLS/SMTPS/none TLS modes; auth modes; optional `TrustServerCertificate` bypass (off by default). Best-effort dispatch; settings and recipients managed via API; test-send endpoint (ICD-EXT.001; ICD-ADM.009).

### 7.3 Database

SQLite (exercised) and PostgreSQL 16+ (Npgsql path implemented, upgrade SQL additive/idempotent, **not live-exercised** - SR-D.002; TBD-006). Connection pooling per SR-P.004; UTC timestamp discipline per SR-D.005. Production database selection and verification are Phase 0/1 exit criteria (§11).

### 7.4 Reverse proxy / TLS termination

Optional fronting proxy terminates TLS and forwards client certificates using the Envoy XFCC format; the gateway honors it only from configured known proxies, never when a native client certificate is present (KSPEC-005 §7; B-2). Production TLS certificates are provisioned externally (SR-B.003). TO-BE requires authenticated forwarders (SR-S.005). ACME HTTP-01 challenge traffic must reach the gateway through the same fronting path.

## 8. Key architectural decisions and rationale

These decisions are carried into TO-BE as confirmed target design (KSPEC-004 §16.1). The receiving team shall preserve them; changing one requires specification change, not just code change.

### 8.1 Clean architecture (domain → application → infrastructure → host)

Domain entities, enums, and the connector/service interfaces live dependency-free; application services orchestrate use cases (enrollment orchestration, revocation, policy enforcement); infrastructure implements persistence, cryptography, and CA connectors; the API host wires it (KSPEC-004 §3). Rationale: the CA-agnostic product promise (UR-030/038) is only maintainable if CA protocols stay behind the domain interface; it also keeps the demonstration clients out of the product core (KSPEC-000 §3).

### 8.2 Connector abstraction with profile→backend routing

All CA access flows through the connector contract (§4.4) and the factory; issuance routing resolves **profile → bound backend**, never the globally active backend (B-3). Rationale: prevents cross-profile issuer substitution (THR-005), enables per-hospital CA heterogeneity with a single device-facing protocol (UR-016/018), and makes adding backends a contained task (SR-O.001; KSPEC-004 extension points).

### 8.3 Contract-first OpenAPI interface management

The five OpenAPI artifacts are the authoritative machine-readable contracts for admin, client, EST profiles, shared schema, and status surfaces (KSPEC-005 §11; SR-F-INT.003/004). Rationale: an independent team and external integrators must be able to build against stable contracts; the baseline files are stale/empty, so regenerating and keeping them current is a **Phase 1 exit criterion** (§11). A canonical error schema with stable machine-readable codes and correlation IDs is TO-BE (ICD-ERR.001; KSPEC-005 §12).

### 8.4 Fail-closed revocation

Revocation never reports success when the backend cannot enforce or attest it: unsupported remote revocation returns `false` (logged), CRL-incapable backends fail the revocation request (HTTP 501/503), and the CRL document set stays issuer-scoped, signed, and transactionally persisted (SR-X.001; SR-F-CAI.008; THR-010). Rationale: a silently "successful" revocation is worse than a failed one - trust would be withdrawn in the portal but not on the wire.

### 8.5 One-time activation codes as the bootstrap credential

Identity is supplied authoritatively by the device CSR and bound at first use; activation codes are one-time, hashed, expiring, replay-rejected, and consumed atomically (SR-F-REG.002; THR-003). Rationale: eliminates transcription of device identity by administrators (UR-001), limits the bootstrap window, and keeps the gateway out of the device-key-generation business (SR-S.011).

### 8.6 Supporting decisions (carry-forward)

- **Profile-scoped virtual EST servers** (`{label}` path segments) with strict unknown-label rejection - enables multi-policy deployments on one listener (SR-F-EST.005; VERIFIED).
- **Pending-response (202 + Retry-After) enrollment** for slow backends - device retries are first-class (SR-F-EST.010; ICD-EST.004).
- **Target audit completeness** - one persisted record per attempt with outcome and source IP; AS-IS coverage is partial (GAP-038) (SR-C.010; SR-U.001/002).
- **Additive, idempotent schema upgrades** on startup - safe restart/upgrade behavior (SR-D.003).
- **Demonstration components are isolated** (separate projects; not product deliverables) - protects the product boundary and prevents clinical claims (SR-F-INT.006).

## 9. Test and acceptance requirements

Authoritative verification obligations are in KSPEC-008 (VT records) and KSPEC-009 (traceability). This section summarizes them and does not replace their procedures or evidence limitations.

### 9.1 Mandatory verification classes (mapped to executed-evidence patterns)

At minimum, the following behavior classes must have automated tests plus, where noted, live end-to-end demonstration; they mirror the executed evidence patterns of docs/IMPLEMENTATION-TRACKER.md and `artifacts/developer/verify-*/evidence.json`:

| Class | What must be proven | Anchor requirements |
|---|---|---|
| Activation replay | A consumed code reused over EST is rejected; expired/unknown codes rejected | SR-F-REG.002, SR-X.005 |
| Independent-client EST | A standard HTTP-Basic EST enrollment (curl-class client, no private headers) over real HTTPS succeeds end-to-end | SR-F-EST.006, SR-F-INT.001 |

| Class | What must be proven | Anchor requirements |
|---|---|---|
| Renewal integrity | Re-enroll with native TLS client cert; new key generated; approved identity preserved; revoked/removed devices denied | SR-F-CLM.003/009, SR-A.008 |
| Profile routing | Unknown label → 404, no fallback; profile resolves its own backend | SR-F-EST.005, SR-F-CAI.002 |
| Policy enforcement | CSR subject/EKU/key-usage/validity and returned-certificate policy enforced; >64 KiB CSR → 413 | SR-S.002, SR-C.001, SR-F-EST.003 |
| Fail-closed revocation | Unsupported backend revocation → 501/503, no silent success; CRL number monotonic; transactional persistence | SR-X.001, SR-F-CLM.007/008 |
| Peer-side revocation effect | After admin revocation, native online X509Chain validation reports `Revoked` without cache flushing | SR-C.007, THR-010 |
| Forwarding guard | XFCC spoof from non-known proxy rejected; never honored with a native client certificate | SR-S.004 |
| CRL listener restriction | Non-CRL requests on the restricted listener denied | SR-B.005 |
| Restart persistence | Populated database survives restart with profiles, issuers, devices, trust policy intact | SR-V.003, SR-C.002, SR-D.001 |
| RBAC | Each mutation endpoint rejects under-privileged roles; anonymous surface limited to the documented set | SR-Z.001-009 |
| Transport rules | Plain-HTTP EST → 426; Basic-over-HTTP → 403; rate limits → 429 | SR-F-EST.012, SR-S.006 |
| Watcher fault tolerance | Expiry scan failure does not crash the watcher; near-expiry notifications fire per rules | SR-F-CLM.005, SR-R.001 |
| Concurrency | Concurrent activation/renewal does not double-issue or corrupt state | SR-R.004; KSPEC-004 §13 |

## 9.2 Acceptance process requirements

• Every KSPEC-003 requirement must trace to at least one verification activity in KSPEC-008/KSPEC-009 once published; until then, maintain an internal matrix against the Requirements Register (§21 of KSPEC-003).

• Executed-test evidence must be recorded (as the baseline does under `artifacts/developer/verify-*/evidence.json`) - self-reported pass/fail without artifacts is not acceptable.

• A developer end-to-end verifier equivalent to docs/development.md (`verify-dev.ps1`) must exist and pass, including revocation checking mode.

• Hospital-backend interoperability (ADCS/EJBCA) acceptance in Phase 3 (§11) is against **real or harness-backed** instances per docs/admin-setup.md, and results are recorded as evidence, not assumed (THR-005/008).

• No conformity claims (RFC 7030/8555, DICOM, ATNA) may appear in test reports (KSPEC-000 §3; KSPEC-002 §1; assessment belongs to KSPEC-011 when published).

# 10. Decisions register (unresolved items the team needs answered)

Consolidates the TBD/UNKNOWN items recorded across KSPEC-001 §14, KSPEC-002 §13, KSPEC-003 §22, KSPEC-004 §16-§17, and KSPEC-007 §7.2. Owners and needed-by dates are **placeholders for the receiving program to fill** at kickoff; none are fabricated. "Needed by" references roadmap phases in §11.

### DEC-001

**Decision needed:** Production certificate-lifetime policy (outage tolerance vs. revocation objectives)
**Source (authoritative):** KSPEC-002 TBD-001
**Blocking SR/THR:** SR-C.003
**Owner (placeholder):** TBD - PKI policy owner
**Needed by:** Phase 1 exit

### DEC-002

**Decision needed:** Notification trigger set and delivery reliability model (incl. outbox)
**Source (authoritative):** KSPEC-002 TBD-002; KSPEC-004 P-6
**Blocking SR/THR:** SR-F-CLM.006, SR-R.003
**Owner (placeholder):** TBD - operations owner
**Needed by:** Phase 2 entry

### DEC-003

**Decision needed:** Scope of OR.NET white-paper settings (offline sites, legacy devices)
**Source (authoritative):** KSPEC-002 TBD-003
**Blocking SR/THR:** UR-034, UR-036
**Owner (placeholder):** TBD - research liaison
**Needed by:** Phase 3

### DEC-004

**Decision needed:** Location and adoption of shared OR.NET/RT-SEC requirements and test vectors
**Source (authoritative):** KSPEC-002 TBD-004
**Blocking SR/THR:** SR-F-INT.008
**Owner (placeholder):** TBD - research liaison
**Needed by:** Phase 3

### DEC-005

**Decision needed:** Secrets-management mechanism for connector credentials (vault/OS store)
**Source (authoritative):** KSPEC-002 TBD-005
**Blocking SR/THR:** SR-F-CAI.010, SR-S.008
**Owner (placeholder):** TBD - security engineering
**Needed by:** Phase 0 (plan), Phase 4 (implement)

### DEC-006

**Decision needed:** Production database: verify and select PostgreSQL vs SQLite
**Source (authoritative):** KSPEC-002 TBD-006

**Blocking SR/THR:** SR-D.002
**Owner (placeholder):** TBD - platform engineering
**Needed by:** Phase 0/1 exit

### DEC-007

**Decision needed:** EST rate-limit values for production
**Source (authoritative):** KSPEC-003 §22
**Blocking SR/THR:** SR-S.006
**Owner (placeholder):** TBD - security engineering
**Needed by:** Phase 1 exit

### DEC-008

**Decision needed:** Forwarder authentication mechanism (shared secret, allow-list, proxy mTLS)
**Source (authoritative):** KSPEC-004 P-2
**Blocking SR/THR:** SR-S.005
**Owner (placeholder):** TBD - security engineering
**Needed by:** Phase 4

### DEC-009

**Decision needed:** Long-lived renewal operation (OS service vs. running app) and old-certificate retirement policy
**Source (authoritative):** KSPEC-004 A-7; docs/development.md
**Blocking SR/THR:** SR-F-CLM.002, SR-O.003
**Owner (placeholder):** TBD - deployment policy owner
**Needed by:** Phase 2

### DEC-010

**Decision needed:** CRL lifetime and stale-revocation-data policy (replace 60 s prototype value)
**Source (authoritative):** KSPEC-004 A-4/A-5; THR-010
**Blocking SR/THR:** SR-S.012, SR-C.008
**Owner (placeholder):** TBD - PKI policy owner
**Needed by:** Phase 2

### DEC-011

**Decision needed:** Device status model: `Untrusted` vs `Retired` semantics
**Source (authoritative):** KSPEC-004 A-1
**Blocking SR/THR:** SR-F-REG.004
**Owner (placeholder):** TBD - product owner
**Needed by:** Phase 1

### DEC-012

**Decision needed:** Key-archival policy: fate of `EncryptedPrivateKeyPem` field
**Source (authoritative):** KSPEC-004 A-2
**Blocking SR/THR:** SR-S.011, SR-D.008
**Owner (placeholder):** TBD - security engineering
**Needed by:** Phase 1

### DEC-013

**Decision needed:** Enterprise PEN / OID namespace to replace `1.3.6.1.4.1.99999.*`
**Source (authoritative):** KSPEC-004 A-3
**Blocking SR/THR:** SR-C.001 (gateway OID)
**Owner (placeholder):** TBD - external stakeholder
**Needed by:** Phase 2

### DEC-014

**Decision needed:** Anonymous self-service authorization model confirmation
**Source (authoritative):** KSPEC-003 §22
**Blocking SR/THR:** SR-Z.009, SR-F-REG.007
**Owner (placeholder):** TBD - product owner
**Needed by:** Phase 1

### DEC-015

**Decision needed:** Audit export standard (ATNA mapping) and tamper-protection approach
**Source (authoritative):** KSPEC-004 A-6; THR-015
**Blocking SR/THR:** SR-U.005/006
**Owner (placeholder):** TBD - security engineering
**Needed by:** Phase 4

### DEC-016

**Decision needed:** Availability targets, capacity, latency budgets
**Source (authoritative):** KSPEC-003 §22
**Blocking SR/THR:** SR-V.004, SR-P.001/003
**Owner (placeholder):** TBD - operations owner
**Needed by:** Phase 3/4

### DEC-017

**Decision needed:** Backup schedule, retention, RPO/RTO targets
**Source (authoritative):** KSPEC-007 §6.2, §7.2
**Blocking SR/THR:** SR-X.007
**Owner (placeholder):** TBD - operations owner
**Needed by:** Phase 4

### DEC-018

**Decision needed:** Remediation plan for transitive advisories (SQLitePCLRaw.lib.e_sqlite3 2.1.6; System.Security.Cryptography.Xml 8.0.2)
**Source (authoritative):** THR-014; ORK-016
**Blocking SR/THR:** SR-S.014, SR-B
**Owner (placeholder):** TBD - engineering lead
**Needed by:** Phase 0

### DEC-019

**Decision needed:** Metrics format/stack (Prometheus)
**Source (authoritative):** KSPEC-007 §5
**Blocking SR/THR:** SR-O.004

**Owner (placeholder):** TBD - operations owner
**Needed by:** Phase 4

### DEC-020

**Decision needed:** Log/record retention periods
**Source (authoritative):** KSPEC-003 §22
**Blocking SR/THR:** SR-O.002, SR-D.006
**Owner (placeholder):** TBD - compliance owner
**Needed by:** Phase 2

Rule: an implementation may not invent a value for any TBD; it shall implement the mechanism with a clearly marked default and record the pending decision (KSPEC-002 §16.5).

## 11. Phased implementation roadmap

Phases are sequenced so that known blockers are cleared first, then the core protocol, then lifecycle completeness, then hospital interoperability, then operational hardening. Entry/exit criteria are measurable; each phase's exit is a gated acceptance review against the referenced SRs and verification classes (§9.1).

### Phase 0 - Deployment-blocker hardening and baseline hygiene

**Goal:** the system can be deployed without the known blockers, in a hardened configuration.

- **Scope:** remediate the transitive advisories `SQLitePCLRaw.lib.e_sqlite3 2.1.6` and `System.Security.Cryptography.Xml 8.0.2` (THR-014 - the only Critical residual risk; DEC-018); eliminate the hard-coded JWT signing fallback (SR-A.006, SR-S.007) and fail fast on development defaults in Production; disable/retire static legacy API keys or make them explicit opt-in (SR-A.004, THR-007); define the production secret-provisioning story (SR-B.007; DEC-005 plan); establish the upgrade-safety boundary (SR-D.004); exercise and verify the PostgreSQL path (SR-D.002; DEC-006); CI gates for build, tests, UI advisory audit (per docs/development.md "Automated checks").
- **Entry criteria:** baseline reviewed; specification package 000-007 available; test environment (Docker and/or Windows) available.
- **Exit criteria:** zero known high/critical advisories; no default credentials or fallback secrets in a Production-configured deployment; full solution test suite plus UI build pass on Windows CI; restart-persistence test passes on the selected production database; documented run book for configuration/secrets.

### Phase 1 - Core EST, self-signed CA, admin core

**Goal:** a device can be registered, activated, and enrolled through EST against the self-signed backend, administered through the portal and REST API.

- **Scope:** EST endpoint surface with profile-scoped routing (SR-F-EST.001-013, `/cacerts` included); one-time activation bootstrap with race-safe consumption (SR-F-REG.001/002/004/005/009); device inventory and status model (resolve DEC-011/DEC-012/DEC-014); self-signed CA connector per the §4.4 contract (SR-F-CAI.001-004, SR-F-CAI.009); admin core: auth (JWT + API keys), users, API keys, devices, backends, profiles, gateway settings, health/status (SR-F-ADM.001-010 minus notifications depth); regenerate the OpenAPI artifacts and adopt the canonical error schema (SR-F-INT.003/004).
- **Entry criteria:** Phase 0 exit.
- **Exit criteria:** all §9.1 classes except revocation-specific ones pass with recorded evidence; OpenAPI files validate and match implemented routes (automated drift check); profile/unknown-label and replay tests pass; independent curl EST enrollment over real HTTPS demonstrated; last-admin lockout protection tested.

### Phase 2 - Renewal, revocation, notifications, policy lifecycle

**Goal:** full credential lifecycle without manual re-approval, with revocation that actually propagates.

- **Scope:** certificate-authenticated renewal with new key and preserved identity (SR-F-CLM.002/003, SR-C.004); expiry watcher + notification rules with defined trigger set and delivery decoupling/outbox (SR-F-CLM.004/005/006, SR-R.003; DEC-002); issuer-scoped signed CRLs, transactional revocation, fail-closed mapping, CDP population (SR-F-CLM.007-009, SR-C.005-009, SR-S.012; DEC-010); configurable CRL lifetime; `Untrusted`/`Retired` semantics if approved (DEC-011); PEN/OID resolution (DEC-013); enrollment-event audit completeness (SR-C.010, SR-U.001-004).
- **Entry criteria:** Phase 1 exit; DEC-001/DEC-002/DEC-010 decisions recorded.
- **Exit criteria:** full §3 workflow walkthroughs (registration → activation → enrollment → renewal → revocation/retirement) pass end-to-end with evidence; revocation round-trip to native X509Chain `Revoked` demonstrated; CRL staleness and non-renewal alerts fire per configured rules; notification test-send and rejection notifications verified.

### Phase 3 - ADCS/EJBCA hospital interoperability

**Goal:** the gateway enrolls and (where supported) revokes against hospital-class backends.

- **Scope:** ADCS SCEP connector hardening incl. NDES challenge mode and enrollment-agent credential (SR-F-CAI.005; ICD-EXT.003); EJBCA REST connector incl. native revocation with `IssuerDn` (SR-F-CAI.006; ICD-EXT.004); ACME challenge-set completion incl. real DNS-01 (SR-F-CAI.007); interoperability test execution against real or harness-backed instances (docs/admin-setup.md walkthroughs); shared OR.NET/RT-SEC test vectors if agreed (SR-F-INT.008; DEC-003/004).
- **Entry criteria:** Phase 2 exit; access to at least one ADCS/NDES and one EJBCA instance (real or faithful harness) - **a precondition, not guaranteed**; DEC-003/DEC-004 advanced.
- **Exit criteria:** enrollment (and revocation for EJBCA) demonstrated against each backend with recorded evidence and honest capability reporting; fail-closed behavior proven for unsupported operations against each backend; results recorded as the first real interoperability evidence (previously unverified - THR-005/008); no conformity claims introduced.

### Phase 4 - Operational hardening, HA, backup, observability

**Goal:** hospital-grade operability.

- **Scope:** backup/restore implementation per the KSPEC-007 §6.2 completeness rule with restore rehearsals (SR-X.007; DEC-017); secrets-store integration (SR-F-CAI.010, SR-S.008; DEC-005 implementation); authenticated forwarders (SR-S.005; DEC-008); metrics endpoint and alert set (SR-O.004; DEC-019; KSPEC-007 §5); audit tamper protection and export (SR-U.005/006; DEC-015); component-level health (SR-V.002); availability/HA posture per DEC-016; log/record retention per DEC-020; dependency vulnerability process (SR-S.014, SR-O.005).
- **Entry criteria:** Phase 3 exit; DEC-005/DEC-008/DEC-015-DEC-019 decisions recorded.
- **Exit criteria:** documented backup set captured and restored in a rehearsal with all §9.1 classes re-run against the restored instance; metrics endpoint exposes the proposed minimum series; alerts fire in a fault-injection exercise; secrets in database config encrypted at rest; security review of the deployment topology documented (feeds KSPEC-011 re-assessment).

## 12. Definition of done

The handoff is complete - and a delivered system may be declared done - when **all** of the following measurable acceptance criteria hold:

1. **Specification conformance:** every requirement in the KSPEC-003 register (154 SR-*) is implemented or has an approved, recorded deviation; the traceability matrix (KSPEC-009) shows bidirectional SR ↔ verification coverage with no orphan requirements.

2. **Verification coverage:** every verification class in §9.1 (and every KSPEC-008 VT-nnn entry once published) passes with recorded executed evidence; the end-to-end developer verifier passes including revocation mode.

3. **Workflow acceptance:** all §3 walkthroughs complete successfully in a clean environment, from install through retirement, using only documentation - no tribal knowledge required.

4. **Interface conformance:** the regenerated OpenAPI artifacts validate, match the implemented API (automated drift check in CI), and an independent integrator can complete enrollment against the documented contract alone.

5. **Security posture:** all VERIFIED mitigations of KSPEC-006 §9.1 demonstrably hold in the delivered build; the five residual-risk areas of KSPEC-006 §9.2 are either closed or carry approved, tracked compensating controls; no deployment blockers remain (THR-014).

6. **Fail-closed discipline:** no code path reports success on an operation it cannot enforce - specifically revocation on unsupported backends, invalid replacement credentials, and issuer-mismatched CRLs (SR-X.001-005).

7. **Deterministic state:** restart of a populated instance preserves profiles, issuers, devices, trust policy, and CRL state (SR-V.003); schema upgrades are additive and idempotent (SR-D.003); upgrade-safety boundary defined (SR-D.004).

8. **Decisions resolved:** every DEC-nnn in §10 has a recorded decision or an approved owner and date; no unowned TBDs remain.

9. **Operability:** backup/restore rehearsal passed; metrics and the minimum alert set exist; health endpoint reports component state; documented run books for upgrade, restore, and incident response exist.

10. **Boundary integrity:** no clinical capability, no standards-conformity claim, and no regulatory classification appears in delivered artifacts or documentation (KSPEC-000 §3; KSPEC-001 EXC-001 - EXC-008); demonstration components remain clearly labeled as non-product.

11. **Review closure:** this document and the package pass independent review (KSPEC-013) with no unresolved Critical/High findings.

# 13. Traceability and references

## 13.1 Traceability

This document introduces no requirement identifiers of its own; it references UR-* (KSPEC-002), SR-* (KSPEC-003, canonical register §21), ICD-* (KSPEC-005), THR-* (KSPEC-006), and ORK-* (KSPEC-007) by ID only (KSPEC-000 §7). DEC-nnn identifiers are local to this document, are stable, and are inputs to requirement elaboration, not requirements themselves. Verification test identifiers (VT-nnn) belong to KSPEC-008 and are not allocated here.

## 13.2 References

- KSPEC-000 - KSPEC-007 (`docs/formal-specification/`), as cited per section.
- KSPEC-008, KSPEC-009, KSPEC-010, KSPEC-011 - included in this package; consult for authoritative verification, traceability, gap and readiness records.
- Repository operational documents: docs/IMPLEMENTATION-TRACKER.md; docs/development.md; docs/DEPLOYMENT.md; docs/admin-setup.md; docs/ca-backend-configuration.md; docs/device-enrollment.md; docs/user-management.md; docs/email-notifications.md; docs/API-GUIDE.md; docs/ARCHITECTURE.md; docs/flow.md; docs/windows-installation.md; docs/windows-sandbox.md.
- Standards referenced as context only, with no conformity claims: RFC 7030 (EST), RFC 8555 (ACME), RFC 5280 (X.509/CRL).

## 13.3 Provenance summary

This document classifies as **TO-BE** everything it states as required behavior, with AS-IS evidence referenced only to (a) anchor what is already proven (VERIFIED per executed evidence in docs/IMPLEMENTATION-TRACKER.md and `artifacts/developer/verify-*/`), and (b) name what is known Missing/Partial (pulled from KSPEC-003 §22 and KSPEC-004 §16.2). No statement here upgrades a documented-only claim to verified, and no prototype behavior is adopted as normative without specification approval (KSPEC-000 §4, §5, §13).

# Kryptonian Formal Engineering Specification - Independent Review Findings

| Field | Value |
|---|---|
| Document title | Independent Review Findings (RF-nnn) |
| Document ID | KSPEC-013 |
| Version | 0.2 (Draft) |
| Review status | Draft - pending review |
| Created | 2026-10-13 |
| Baseline repository commit | `682f996c8447afec13bc1fce5b7f59e6a06efa25` (branch `feat/windows-sandbox-installer`, "Release Windows gateway and portable enrollment demo 0.1.4") |
| Repository | https://github.com/AAPM-RT-SEC/RTSec.Kryptonian |
| Reviewed material | KSPEC-000 - KSPEC-012 in `docs/formal-specification/` (13 documents) |
| Revision history | 0.1 - 2026-10-13 - Initial independent review of the full package (Author: independent engineering reviewer). |
| Source references | KSPEC-000 (conventions and controls); all reviewed documents; repository evidence (docs/IMPLEMENTATION-TRACKER.md, src/RTSec.Kryptonian.Api/Controllers/, tests/, artifacts/developer/verify-*/, solution file) |
| Author | Name: TBD - Date: TBD - Signature: TBD |
| Reviewer | Name: TBD - Date: TBD - Signature: TBD |
| Approver | Name: TBD - Date: TBD - Signature: TBD |

**Current status:** the original review below is retained as history. All RF-001 through RF-024 documentation findings are dispositioned by revision 0.2; consult the final current-disposition section and KSPEC-016. Implementation gaps and stakeholder approval remain open.

## 1. Review scope and method

All 13 generated documents (00-12) were read in full. Structured checks performed:

- **Header controls**: document ID, version, review status, creation date, baseline commit, revision history, source references, and author/reviewer/approver placeholders present on every document. Baseline commit `682f996c…` is stated consistently across all documents (04/05 abbreviate the header but cite the same SHA).
- **Identifier scheme**: UR (38), SR (154), THR (18), ORK (16), VT (58), GAP (37) populations recounted programmatically against the owning documents.
- **Provenance/status discipline**: no approval is inferred from implementation; all Approval fields are "Review Required"; no FDA/IEC 62304/ISO 14971/medical-device regulatory content found; conformity disclaimers present in 02/03/05/06/08/09/10/11.
- **Repository spot-checks**: 23 cited documentation paths, 10 cited test files (`EstControllerTests.cs`, `EstRouteTests.cs`, `DeviceActivationConcurrencyTests.cs`, `CertificateForwardingGuardTests.cs`, `ConfiguredClientCertificateTrustTests.cs`, `SandboxBootstrapTests.cs`, and others), the controller inventory, the

solution's test-project list, `artifacts/developer/verify-fa867498…/evidence.json`, the rate-limit configuration (100/30/30), the 15-minute default activation-code lifetime, and the 24 h / 7-day / 2-min watcher constants were all verified against the actual repository. **All spot-checked citations were accurate.**

• **Encoding**: every file scanned for double-encoded UTF-8 (mojibake).

Positive observations worth recording: the 09 status distribution (Existing 113 / Partial 20 / Missing 18 / Proposed 3) matches the KSPEC-003 register exactly; the VT→SR edges sampled (VT-011/012/044 etc.) match the KSPEC-008 "Linked requirements" fields; the ORK RPN arithmetic in 07 §4 was recomputed and is correct; THR/ORK/VT/GAP counts match their headers. Evidence fidelity across the package is high and no fabricated evidence, test result, approval, or conformity claim was detected.

The deficiencies found are concentrated in **cross-document reconciliation** (a byproduct of parallel authoring), two **factual miscounts**, and a small number of **wording-discipline** items.

# 2. Findings

## RF-001 - Stale "document does not yet exist" statements and prefix-only requirement references contradict the delivered package

• **Affected**: KSPEC-004 §1.3, §18; KSPEC-005 preamble, §19; KSPEC-007 §2.6; KSPEC-012 header, §1.2, §9, §13.2; inconsistent with KSPEC-003 §22 and KSPEC-008 §8.

• **Severity**: Major

• **Evidence**: 04 §1.3 states "At the time of writing, `03-SOFTWARE-REQUIREMENTS.md` (KSPEC-003) and its requirements register do **not yet exist**"; 05 states the same and restricts itself to prefix-level references (`SR-EST`, `SR-I`…); 07 §2.6 states the register "is not yet present"; 12 states KSPEC-008/009/010/011 were "not yet present" when drafted. Yet KSPEC-003 exists with a canonical 154-SR register and asserts (03 §22) that downstream documents "reference these SRs by ID only", and 09 resolves concrete SR IDs. Simultaneously, 12 cites concrete SR IDs (e.g., SR-F-REG.006, SR-S.011) while declaring 008-011 unpublished, and 07 §7.1 targets an `SR-I` prefix that 03 never allocated (interoperability lives under `SR-F-INT`) - a mismatch 09 §9.4 item 6 already reports but cannot resolve.

• **Impact**: Requirement references in 04/05/07 cannot be machine-traced; 03 §22's downstream-reference claim is false as written; reviewers cannot tell whether prefix-level areas in 04/05/07 map to the register's actual area set (`SR-F-INT` vs `SR-I`).

• **Recommended resolution**: One reconciliation pass: (a) correct 03 §22 to state which documents actually reference by ID and which are prefix-level pending revision; (b) update 04/05/07/12 authoring-time statements to describe the delivered package; (c) resolve the `SR-I` → `SR-F-INT` prefix mismatch (see RF-012); (d) have 09 confirm every prefix intent was resolved.

• **Disposition**: Must-fix before approval.

## RF-002 - KSPEC-009 misstates the verification evidence status of VT-019 and the overall evidence-status statistics of KSPEC-008

• **Affected**: KSPEC-009 §6 VT evidence table (VT-019 row) and §11 summary; contradicts KSPEC-008 §6 (VT-019) and its Evidence Status distribution.

• **Severity**: Critical

• **Evidence**: 08 VT-019 records `Evidence status: Proposed - state-machine traversal test not present as a dedicated AS-IS test; partial coverage via DeviceServiceActivationTests.cs`. 09's VT table row reads "| VT-019 | SR-F-REG.004 | AS-IS automated test (state-machine transitions) |", upgrading a Proposed test to executed AS-IS coverage. Additionally, 09 §11 claims "7 Proposed, 1 partially covered, remainder Covered", while 08 actually contains **12**

**Proposed / 7 Partially covered / 39 Covered** (sum 58, verified by count). 09's own table contains 11 "Proposed" rows - inconsistent both with 08 and with its own §11.

• **Impact**: The traceability matrix - the package's single downstream consumer of VT→SR links per 08 §8 - overstates verification coverage of a lifecycle-behavior test and misreports the package's executed/proposed balance, in tension with 08 §8 rule 2 and the evidence discipline of KSPEC-000 §5 (no upgrade of a class).

• **Recommended resolution**: Recompute 09 §6/§11 from 08's Evidence Status fields verbatim; fix the VT-019 row; state the corrected distribution (39 Covered / 7 Partially covered / 12 Proposed).

• **Disposition**: Must-fix before approval.

## RF-003 - KSPEC-002 §12 status summary does not sum to 38, and the error is propagated into KSPEC-009

• **Affected**: KSPEC-002 §12 (status table); KSPEC-009 §10, §11.

• **Severity**: Major

• **Evidence**: 02 §12 states "Existing 33, Partial 5 (UR-010, UR-012, UR-019, UR-036, UR-037), Missing 1 (UR-013)" - 33+5+1 = **39 ≠ 38**. Counting the actual status column of the 38 UR body records gives **Existing 32, Partial 5, Missing 1** (= 38). 09 §10 quotes "UR statuses quoted from KSPEC-002 (§12: Existing 33, Partial 5, Missing 1)" and §11 repeats it, reproducing the error.

• **Impact**: The stakeholder-requirement coverage summary, one of the first tables a reviewer checks, is arithmetically wrong; 09's identifier-consistency verification (§10) claims to have verified a wrong number.

• **Recommended resolution**: Correct 02 §12 to "Existing 32"; re-derive the status counts from the body records; correct 09 §10/§11 quoting.

• **Disposition**: Must-fix before approval.

## RF-004 - Evidence-map claim of "10 test projects" is factually wrong (8 exist)

• **Affected**: KSPEC-000 §10 (evidence source map); KSPEC-008 header (source references).

• **Severity**: Major

• **Evidence**: `tests/` contains 8 directories and the solution file contains exactly 8 `*.Tests` projects (Domain, Application, Infrastructure, Api, CaHarness, Bridge, Kryptonian.MedicalDevice.Enrollment, DimseTlsProxy). 00 §10 says "tests/ (10 test projects)" and 08's source references repeat it.

• **Impact**: A trivially checkable factual error in the conventions document and the V&V header undermines confidence in the evidence map.

• **Recommended resolution**: Change to 8 in both documents (or state the counting convention if a different basis was intended).

• **Disposition**: Must-fix before approval (trivial).

## RF-005 - GAP-007 cites an incorrect EST rate limit ("5 requests/minute")

• **Affected**: KSPEC-010 §7.2 (GAP-007); inconsistent with KSPEC-005 §8 and `src/RTSec.Kryptonian.Api/appsettings.json`.

• **Severity**: Major

• **Evidence**: appsettings.json and 05 §8 record `*:/.well-known/est/*` = 100/min and 30/min for `simpleenroll`/`simplereenroll`. GAP-007 states "EST endpoints are rate-limited (5 requests/minute)".

• **Impact**: A wrong factual number inside a Critical-priority, Wave-0 deployment-gating finding; the lockout-absence conclusion itself is unaffected and well supported by KSPEC-006 THR-009.

• **Recommended resolution**: Correct the parenthetical to the actual configuration (100/min general; 30/min per enrollment operation) or remove it; keep the finding's substance unchanged.

• **Disposition**: Should-fix (does not alter the Wave-0 conclusion).

## RF-006 - Contradictory statements on activation-code consumption concurrency (TOCTOU closed vs open)

• **Affected**: KSPEC-004 §13 and §16.3 (P-5) vs KSPEC-006 THR-003, KSPEC-008 VT-048, KSPEC-009 (SR-R.004 row), KSPEC-012 §5.3.

• **Severity**: Major

• **Evidence**: 04 §13 states validation and consumption occur in the enrollment path but "no dedicated unique-consumption constraint was observed [INFERRED - potential TOCTOU]" and proposes P-5 (unique consumed index or serializable transaction). 06 THR-003 states codes are "consumed atomically … concurrent activation attempts are serialized (CODE-OBSERVED, `DeviceService` / `EnrollmentOrchestrator.TryConsumeActivationCodeAsync`; tests: `DeviceActivationConcurrencyTests`)" - and that test file exists in `tests/RTSec.Kryptonian.Infrastructure.Tests/Data/`. 08 VT-048 marks the race test "Covered - exactly one consumption"; 12 §5.3 requires race-safe consumption as TO-BE "per KSPEC-004 §13 TOCTOU finding".

• **Impact**: The package simultaneously claims the race is closed (06/08) and open (04/12). One of the two code-level claims is wrong; both 09 SR-R.004 ("Existing") and SR-F-REG.002 traceability inherit the ambiguity. This is security-relevant (duplicate issuance from one code).

• **Recommended resolution**: Re-inspect the baseline code/test against the actual transactional scope; then either (a) correct 04 §13/P-5 (and 12 §5.3) to "serialized, regression-covered" or (b) downgrade 06 THR-003's control and 08 VT-048's evidence status to Proposed and re-rate the residual risk. Record the resolution in 09.

• **Disposition**: Must-fix before approval.

## RF-007 - Encoding corruption (mojibake) in the controls baseline KSPEC-000

• **Affected**: KSPEC-000 (00-SPEC-CONVENTIONS.md) - §1 review sequence, §2 header controls text; 10 double-encoded UTF-8 sequences found (e.g., "000 â†' 001" where "→" is intended; "nameâ€"dateâ€"signature" where "-" is intended).

• **Severity**: Major

• **Evidence**: Character-level scan (U+00E2 / U+20AC / U+00C2 sequences) finds corruption only in 00; all other 12 documents are clean UTF-8.

• **Impact**: Cosmetic but located in the binding conventions document, including the document-control header fields and the mandatory review sequence - the first thing every reviewer reads.

• **Recommended resolution**: Re-save 00 as clean UTF-8 (replace the corrupted sequences with "→" and "-"). Recorded here per instructions; not fixed by this review.

• **Disposition**: Must-fix before approval (trivial, mechanical).

## RF-008 - KSPEC-014 (package index / README) referenced by the review sequence is missing from the package

• **Affected**: Package completeness; KSPEC-000 §1 and §2 (review sequence ends "… 012 → 013 → 014").

• **Severity**: Major

• **Evidence**: `docs/formal-specification/` contains only 00-12; `docs/formal-specification/README.md` does not exist (`Test-Path` = False).

• **Impact**: The document hierarchy defines KSPEC-014 as the package index and review-sequence entry point; the sequence cannot be executed as documented, and approval of the package cannot be declared complete.

• **Recommended resolution**: Author KSPEC-014 (index, review order, status of each document) or amend 00 §1 to defer it explicitly.

• **Disposition**: Must-fix before approval.

## RF-009 - SR-F-CLM.005 requires a "configured re-notification interval" that is hard-coded at baseline

• **Affected**: KSPEC-003 §5 (SR-F-CLM.005); corroborated against `CertificateExpiryWatcher.cs`.

• **Severity**: Minor

• **Evidence**: The requirement says the gateway "shall re-notify about the same certificate no more frequently than the configured re-notification interval", but the code holds `private static readonly TimeSpan RenotifyAfter = TimeSpan.FromDays(7)` - a constant with no configuration key. The requirement's own Evidence field ("24h scan interval, 7-day re-notify") is accurate; the requirement wording overstates AS-IS configurability, in tension with the package's TBD discipline (KSPEC-000 §8; KSPEC-002 §16.5).

• **Recommended resolution**: Either reword to the fixed 7-day interval at AS-IS with a TO-BE note making it configurable, or add the configurability as an explicit TO-BE/PROPOSED element.

• **Disposition**: Should-fix.

## RF-010 - KSPEC-005 §9 uses "Conformant (INFERRED)" labels, in tension with the package's no-conformity-claim discipline

• **Affected**: KSPEC-005 §9 (RFC 7030 conformance points table); cf. KSPEC-003 §16.2 (conformance assessment reserved to KSPEC-011) and KSPEC-011 §1/§8 vocabulary (Supported / Deviating / Untested).

• **Severity**: Minor

• **Evidence**: Rows such as "`/cacerts` … Conformant (INFERRED)" and "Conformant + deviation (lenient)" appear in 05 §9. The section is explicitly disclaimed ("shall not be presented as a standards-conformity claim"), but the label wording reads as a conformity determination and diverges from the vocabulary every other document uses.

• **Recommended resolution**: Replace "Conformant" with 011's vocabulary (e.g., "Aligned (source-inspection)") or "Implemented (inspection)".

• **Disposition**: Should-fix.

## RF-011 - Malformed requirement-area token "SR-C-CLM" in KSPEC-002 traceability notes

• **Affected**: KSPEC-002 (UR-021, UR-025 traceability notes); identifier scheme of KSPEC-000 §7.

• **Severity**: Minor

• **Evidence**: The notes read "SR-C-CLM area"; no such area exists - the correct areas are `SR-F-CLM` (KSPEC-003 §5) and `SR-C` (KSPEC-003 §12).

• **Recommended resolution**: Replace with "SR-F-CLM / SR-C area".

• **Disposition**: Should-fix.

### RF-012 - `SR-I` prefix defined in KSPEC-000 §7 but never allocated by KSPEC-003

• **Affected**: KSPEC-000 §7 (prefix table lists "SR-I - Interoperability requirements - KSPEC-003"); KSPEC-003 §2 (area table has no SR-I; the behavior lives in SR-F-INT); KSPEC-007 §2.6/§7.1 (targets SR-I-*); KSPEC-009 §9.4 item 6.

• **Severity**: Minor

• **Evidence**: The conventions document binds an area the canonical register does not define; 07 still references it. 09 flags the mismatch for 07 but cannot amend 00 or 03.

• **Recommended resolution**: Remove `SR-I` from 00 §7 (or have 03 allocate it) and re-point 07 §7.1/§2.6 at `SR-F-INT` (09 §9.4 item 6 already recommends this).

• **Disposition**: Should-fix.

### RF-013 - KSPEC-011 §11.2 (ASVS V13) overstates OpenAPI file currency

• **Affected**: KSPEC-011 §11.2 (V13 row); inconsistent with KSPEC-005 §11 and KSPEC-003 SR-F-INT.003/004.

• **Severity**: Minor

• **Evidence**: 11 states "OpenAPI files (Admin/StatusObserve current)" while 05 §11 records `OpenAPI.Admin.yaml`/`OpenAPI.ESTProfiles.yaml` as contract-first designs **without security-scheme declarations and missing implemented paths**, `OpenAPI.Schema.yaml` stale, `OpenAPI.Client.yaml` empty (0 bytes), and EST paths absent from all OpenAPI files - gaps 11 itself cites elsewhere (GAP-029, V13 gaps column).

• **Recommended resolution**: Reword the V13 coverage cell to "partial / contract-first; Client empty, Schema stale (GAP-029)".

• **Disposition**: Should-fix.

## 3. Overall review verdict

**Package verdict: technically sound, evidence-faithful Draft - NOT ready for approval in its current form.** Approval is blocked pending the one Critical and seven Major findings (RF-001 - RF-008); the five Minor findings (RF-009 - RF-013) should be corrected in the same revision pass.

The package demonstrates strong engineering discipline and outstanding evidence fidelity: every requirement record carries classification, status, provenance, verification method, and concrete repository evidence; hard-coded threshold values are consistently handled as TBD; no approval is inferred from implementation; the no-conformity / no-medical-device-regulatory boundary is maintained in all 13 documents; and the repository spot-checks (test files, artifacts, controller inventory, configuration constants) confirmed every sampled citation. The principal weakness is the parallel-authoring seam: stale authoring-time statements, the `SR-I` / `SR-F-INT` prefix split, the VT-019 evidence upgrade, and two summary-count errors. None of these undermine the technical substance, and all are mechanically fixable in a single reconciliation pass. Re-review after the must-fix dispositions should suffice; no re-authoring of any document body is required.

Finding counts: **1 Critical (RF-002), 7 Major (RF-001, RF-003 - RF-008), 5 Minor (RF-009 - RF-013); 8 must-fix, 5 should-fix dispositions** (RF-005 is Major with a should-fix disposition).

## 4. Per-document readiness summary

| Document | Readiness | Notes |
|---|---|---|
| KSPEC-000 Conventions | Revise (minor) | RF-007 (mojibake), RF-004 (test-project count), RF-012 (SR-I prefix) |
| KSPEC-001 Product definition | Ready | UC/SCN/ASM/EXC element sets complete and consistently consumed by 02; TBD-001-006 well formed |
| KSPEC-002 User requirements | Near-ready | RF-003 (§12 count), RF-011 (area token); body records and §15 evidence basis otherwise consistent |
| KSPEC-003 Software requirements | Ready for review | Register internally consistent (154 = 154, no duplicates); RF-006 (SR-R.004 vs 04), RF-009 (SR-F-CLM.005 wording), RF-012 |
| KSPEC-004 Software design | Ready pending reconciliation | RF-001 (§1.3/§18 stale), RF-006 (§13/P-5 vs 06/08); architecture, state machines, and design-to-register references otherwise verified |
| KSPEC-005 Interface control | Ready pending reconciliation | RF-001 (preamble/§19), RF-010 ("Conformant" labels); endpoint tables match the controller inventory |
| KSPEC-006 Cybersecurity | Ready | THR count verified (18); all cited test files exist; bands consistent; RF-006 is the only cross-document tension |
| KSPEC-007 Operational risk | Ready pending reconciliation | RF-001 (§2.6), RF-012 (SR-I); FMEA arithmetic recomputed - correct; 16 ORK entries match header |
| KSPEC-008 V&V | Near-ready | RF-004 (header "10 test projects"); 58 VT records verified present and well-formed; evidence discipline exemplary |
| KSPEC-009 Traceability | Needs revision | RF-002 (VT-019 row + §11 statistics), RF-003 (quoting 02's wrong count); matrices otherwise matched the 03/08 registers on all spot-checks |
| KSPEC-010 Gap analysis | Near-ready | RF-005 (GAP-007 rate value); 37 GAP entries verified; Wave ordering internally consistent |
| KSPEC-011 Standards conformance | Ready | Discipline exemplary; RF-013 (V13 wording) only |
| KSPEC-012 Engineering handoff | Ready pending reconciliation | RF-001 (header/§9/§13.2 staleness); concrete SR references verified against the register |
| KSPEC-013 (this document) | Draft | Subject to its own approval cycle |
| KSPEC-014 README | **Missing** | RF-008 |

*End of KSPEC-013, version 0.1 (Draft). This review records findings only; no specification file other than this document was created or modified, and no approval is recorded or inferred.*

## Post-review resolution log (2026-10-13, package integration pass)

The following findings were dispositioned after the independent review. Each disposition was executed by the package integration team (not by the original document authors) and was verified against repository evidence before application.

### RF-001

**Severity:** Major

**Disposition:** Accepted with reconciliation

**Resolution:** Prefix-level SR references in KSPEC-004, 005, 007, 012 are now explicitly resolved via KSPEC-009 §7 binding tables; package index (KSPEC-014 §5) records this rule. No document-body re-authoring performed.

### RF-002

**Severity:** Critical

**Disposition:** Fixed

**Resolution:** KSPEC-009 §6 VT-019 evidence status corrected to Proposed (matching KSPEC-008); §11 VT distribution corrected to 12 Proposed / 7 partially covered / 39 Covered.

### RF-003

**Severity:** Major

**Disposition:** Fixed

**Resolution:** KSPEC-002 §12 status summary corrected to Existing 32 / Partial 5 / Missing 1 (sums to 38); KSPEC-009 §10 quote updated accordingly.

### RF-005

**Severity:** Major

**Disposition:** Fixed

**Resolution:** KSPEC-010 GAP-007 rate-limit figures corrected to the baseline values (100/min general; 30/min per EST enroll endpoint, per docs/ARCHITECTURE.md).

### RF-004

**Severity:** Major

**Disposition:** Fixed

**Resolution:** Test-project count corrected from 10 to 8 across KSPEC-000 §10, KSPEC-003, KSPEC-008, KSPEC-009, KSPEC-010 (tests/ contains 8 test projects at baseline).

### RF-006

**Severity:** Major

**Disposition:** Resolved in favor of race-safe claim

**Resolution:** Adjudicated against source: `UnitOfWork.TryConsumeActivationCodeAsync` enforces one-time consumption under optimistic concurrency (`DbUpdateConcurrencyException` → rejection) and `DeviceActivationConcurrencyTests` proves two contexts cannot both consume. KSPEC-004 §13/P-5 and KSPEC-012 §5.3 corrected; the genuinely open item is the crash-scope of consumption vs issuance (KSPEC-004 §17 item 1).

### RF-007

**Severity:** Major

**Disposition:** Fixed

**Resolution:** Encoding corruption in KSPEC-000 repaired; file verified clean UTF-8.

### RF-008

**Severity:** Major

**Disposition:** Fixed

**Resolution:** KSPEC-014 package index (README.md) created per KSPEC-000 §1.

Remaining findings (should-fix / note) stay open against this Draft package and must be dispositioned during formal review before any document is promoted to Approved.

### RF-009

**Severity:** Minor
**Disposition:** Open
**Notes:** Kept for formal review; see finding detail above.

### RF-010

**Severity:** Minor
**Disposition:** Open
**Notes:** Kept for formal review; see finding detail above.

### RF-011

**Severity:** Minor
**Disposition:** Open
**Notes:** Kept for formal review; see finding detail above.

### RF-012

**Severity:** Minor
**Disposition:** Open
**Notes:** Kept for formal review; see finding detail above.

### RF-013

**Severity:** Minor
**Disposition:** Open
**Notes:** Kept for formal review; see finding detail above.

Note: resolutions applied are documentation corrections only; no application source code was modified at any point (KSPEC-000 §13).

## Current disposition after reconciliation (0.2, 2026-10-13)

The initial findings and verdict above are a historical review of version 0.1. They are not the current package status. The earlier integration log accidentally swapped RF-004 (test-project count) and RF-005 (rate limits); those rows now match the original finding identifiers. The original summary table remains historical evidence.

| Finding | Current disposition | Resolution |
|---|---|---|
| RF-001 | Closed - corrected | Stale sibling-document text removed; canonical register and concrete binding matrix referenced. |
| RF-002 through RF-008 | Closed - documentation corrections | Prior corrections retained; encoding rechecked and residual KSPEC-000 mojibake actually repaired in 0.2. |
| RF-009 | Closed - corrected | SR-F-CLM.005 Partial; fixed AS-IS timing and TO-BE configurable interval separated. |

| Finding | Current disposition | Resolution |
|---|---|---|
| RF-010 | Closed - corrected | Implemented/source-inspection vocabulary replaces Conformant labels. |
| RF-011 | Closed - corrected | Malformed SR-C-CLM area references replaced by allocated SR-F-CLM / SR-C areas. |
| RF-012 | Closed - corrected | Unallocated SR-I prefix removed from current conventions/risk/interface references; interoperability is SR-F-INT. |
| RF-013 | Closed - corrected | ASVS API row describes partial contract-first coverage and known drift. |
| RF-014 through RF-024 | Closed - specification corrections | Detailed source observations/dispositions in KSPEC-016; underlying code gaps remain open. |

The package remains Draft with stakeholder decisions and implementation gaps open. Closing a documentation finding does not approve the product or satisfy an unexecuted test.

# Kryptonian Code and Document Reconciliation

| Field | Value |
|---|---|
| Document ID | KSPEC-016 |
| Title | Code, Documentation and Specification Reconciliation |
| Version | 0.2 (Draft) |
| Status | Draft - technical reconciliation completed; stakeholder approval pending |
| Created | 2026-10-13 |
| Baseline commit | `682f996c8447afec13bc1fce5b7f59e6a06efa25` |
| Revision history | 0.2 - source audit, specification corrections and reproducible PDF publication |
| Source references | Source paths below; KSPEC-003 canonical register; KSPEC-008 verification records; validation files |
| Author | Codex - technical reconciliation, 2026-10-13; no stakeholder signature |
| Reviewer | Unassigned |
| Approver | Unassigned - no approval recorded |

## 1. Assessment and scope

The main EST, profile routing, issuance-policy, renewal, local CRL and device-management flows are consistent with the baseline source. The original specification also contains overstatements of implementation completeness, inferred test coverage and deployment architecture. This revision corrects those claims without changing application code or weakening the target requirements to accommodate defects.

This is a source and documentation audit with selected automated execution. It is not an exhaustive proof of every requirement, a current vulnerability audit, a standards conformity assessment or product approval. Historical developer evidence remains historical. Test definitions alone are CODE-OBSERVED; the fresh run record identifies only what was actually executed in this review.

Markdown in this directory is authoritative editable source. The PDF is a production publication artifact of the Draft specification; publication does not promote any requirement to Approved. The baseline SHA identifies application source. The publication manifest separately hashes all Markdown sources, so uncommitted specification revisions can be identified precisely.

## 2. Reconciliation findings and applied changes

| Finding | Source observation | Specification disposition |
|---|---|---|
| RF-014 - activation timing | `EnrollmentOrchestrator.EnrollAsync` validates bootstrap and CSR signature, then saves activation consumption before resolving the backend, enforcing issuance policy and calling the CA. | UR-002, SR-F-REG.002, VT-015 and handoff corrected. Issuance is not atomic with consumption; failure/pending/crash recovery is GAP-039 and VT-060. |
| RF-015 - issuer routing | `GetCaCertsAsync`, `IssueForDeviceAsync` and `ResolveProfileBackendAsync` use `profile.CaBackendId`; the global active backend is a dashboard concept. | UR-005, SR-F-CAI.002 and VT-040 now specify profile-bound enabled backend routing. |
| RF-016 - audit completeness | Early orchestrator failures return without creating an EnrollmentEvent; controller failures and `CertificateRevocationService` do not uniformly persist lifecycle decision events. | SR-C.010, SR-U.001 and SR-U.002 reclassified Existing to Partial. Target completeness retained; GAP-038 and VT-059 added. |
| RF-017 - performance evidence | `IpRateLimiting.GeneralRules` specifies 100/min general and 30/min for labeled enrollment POST patterns. Configuration is not a throughput benchmark. Unlabeled rule matching has no fresh proof. | SR-P.001 reclassified Partial. Limits, effective-rule testing and client-IP attribution clarified in SR-S.006 and ICD. |
| RF-018 - notification timing | `CertificateExpiryWatcher` uses fixed 24-hour scan, 2-minute startup delay and 7-day repeat interval. Renewal suppression checks a different LastCertificateId after newer issuance. | SR-F-CLM.005 reclassified Partial; fixed timing and successful-issuance suppression documented. VT-029 reverse-matrix evidence corrected; configurable repeat timing remains a target. |
| RF-019 - anonymous surface | Auth status/setup/login/logout, CRL GET, EST, challenge handlers, health map and dashboard assets do not all require framework authorization. EST handlers perform their own credential checks. | SR-Z.008 enumerates the actual surface; anonymous framework routing does not mean unauthenticated enrollment. |
| RF-020 - portal architecture | API `Program.cs` serves React static files from wwwroot/ui or the adjacent UI dist. Web `Program.cs` starts a separate Blazor/MudBlazor portal. | Product definition, conventions, design and summary corrected; React is not embedded in Web. |
| RF-021 - certificate versus device withdrawal | `CertificateRevocationService.RevokeAsync` mutates certificate/CRL state, not Device.Status. Renewal rejects the revoked credential; other valid device credentials are not automatically withdrawn. | SR-F-CLM.007 distinguishes certificate revocation from device removal. |
| RF-022 - incomplete requirement records | SR-F-ADM.005, SR-F-ADM.010, SR-A.004, SR-D.006 and SR-B.005 lacked Evidence and Approval fields. | Mandatory fields added, with CODE-OBSERVED evidence and Review Required approval. |
| **Finding** | **Source observation** | **Specification disposition** |
| RF-023 - identifier and review integration | KSPEC-003 exists, but design/risk/handoff claimed it or later documents were absent; SR-I and | Current integration text corrected; allocated interoperability prefix used; UR-007 bound to SR-F-ADM.003/.005. |

| Finding | Source observation | Specification disposition |
|---|---|---|
| | SR-C-CLM were not allocated prefixes; UR-007 had no upstream edge despite existing setup/last-admin requirements. | Historical review findings retained and current dispositions recorded. |
| RF-024 - standards vocabulary | RFC 7030 uses application/pkcs10 and application/pkcs7-mime. Basic credential provisioning is site-specific; 202 pending is part of EST. | Removed false media-type/Basic/pending deviation implications and Conformant labels. No whole-protocol conformity claim introduced. |

All findings RF-014 through RF-024 are closed as specification corrections. The underlying implementation limitations remain open gaps, not fixed code defects.

Publication inspection also corrected sequence-label punctuation and the handoff's state-diagram grouping syntax. The certificate diagram now identifies expiration as logical validity: NotAfter is checked, but no baseline job writing the Expired enum value was observed. Diagram notes no longer claim complete rejection auditing.

# 3. Source evidence map and important limits

| Area | Inspected evidence | Evidence limit |
|---|---|---|
| API and transport | `src/RTSec.Kryptonian.Api/Program.cs`; all 15 API controllers; `Authentication/ConfiguredClientCertificateTrust.cs`; `Middleware/CertificateForwardingGuard.cs` | Configuration, authorization attributes and pipeline ordering observed; no live deployment/network-capacity claim. |
| Enrollment and renewal | `src/RTSec.Kryptonian.Application/Services/EnrollmentOrchestrator.cs`; `EnrollmentCertificatePolicy.cs`; `DeviceService.cs`; `src/RTSec.Kryptonian.Infrastructure/Data/UnitOfWork.cs` | Ordinary success, failure and concurrency paths inspected; external CA/crash recovery remains unverified. |
| Revocation | `CertificateRevocationService.cs`; `CrlController.cs`; `ICaConnector.cs`; local and remote connectors | Gateway administrative revocation requires GenerateCrlAsync. EJBCA's separate RevokeCertificateAsync method is not invoked by that service; it is not proof of supported gateway revocation. |
| EJBCA chain caching | `EjbcaCaConnector.GetCaCertificatesAsync`; `CaConnectorFactory`; factory registration in API Program.cs | Chain cache is per connector instance. Factory is scoped; a fresh request can see an empty chain even after an earlier issuance. “Empty until first issuance” must not imply durable/global caching. |
| Renewal authorization | `EnrollmentOrchestrator.ReenrollAsync`; device client renewal scheduling | Gateway checks validity, stored certificate, profile, device and identity. It does not enforce a configured early-renewal time window. Client scheduling is a separate policy. |
| Notifications | `CertificateExpiryWatcher.cs`; `NotificationDispatcher.cs`; `MailKitSmtpSender.cs`; existing dispatcher/settings test definitions | Fresh SMTP delivery and watcher fault/timing behavior were not executed. |
| Persistence | EF configurations, schema upgrades, UnitOfWork; test definitions under tests | SQLite historical persistence evidence exists; hospital PostgreSQL exercise remains unverified. |
| Deployment/UI | Both API and Web Program.cs; installer scripts; Docker Compose; README; BUILD; deployment/architecture/device/user docs; implementation tracker | Older docs are historical descriptions where code contradicts them. Default appsettings port keys do not themselves create Kestrel listeners; sandbox explicitly creates loopback listeners. |
| Contracts | `OpenAPI.Admin.yaml`, `OpenAPI.Client.yaml`, `OpenAPI.ESTProfiles.yaml`, `OpenAPI.Schema.yaml`, `OpenAPI.StatusObserve.yaml`; controller inventory | Client file is empty; source/API drift remains GAP-029. PDF publication does not repair machine-readable contracts. |
| Standards terminology | RFC 7030, sections 3.2.3, 4.2.1 and 4.2.3 | Media-type, Basic provisioning and pending-response terminology checked only; no complete standards evaluation. |

Dependency advisories in the original package come from the September implementation tracker. They are historical findings requiring re-audit, not a fresh October security assessment. Likewise, no organizational legal or regulatory classification decision is recorded by this engineering review; the package's nonclinical product scope is retained.

## 4. Verification and publication records

The existing API test project was restored and run after the initial no-restore attempt failed with NETSDK1127 (missing targeting pack): **72 passed, zero failed, zero skipped**. The TRX record is under `validation/test-results/`. Compiler/analyzer warnings were present. This run does not establish SMTP delivery, external CA interoperability, PostgreSQL persistence, production throughput or the new proposed acceptance tests.

The subsequent solution run completed across all eight test assemblies: **337 passed, zero failed, 18 skipped, 355 total**. The 18 existing infrastructure skips remain unverified behaviors. The separate 72-test API run is not added again to those totals. See `validation/verification.json` for per-assembly counts and TRX files.

The broader run, mechanical specification checks, source/PDF hashes and PDF visual-QA results are recorded in `validation/verification.json` and `validation/publication-manifest.json`. Generated test logs and TRX records are local validation outputs and are ignored by version control. Re-run the commands in the package README to reproduce rather than accepting a screenshot as test evidence.

## 5. Approval and implementation follow-up

The 20 decision records remain stakeholder decisions. Performance, availability, retention, CRL cadence, secrets provisioning and partner profile choices are not filled in by inference. Revised Existing/Partial/Missing/Proposed states describe the evidence available here; they do not constitute requirement approval.

Prioritize complete durable audit coverage (GAP-038), consumed-bootstrap recovery (GAP-039), trusted client-IP attribution (GAP-040), and the existing security/operational deployment blockers. Independent verification against the target requirements remains necessary before production deployment.

# Kryptonian Formal Engineering Specification - Final Summary

| Field | Value |
|---|---|
| Document ID | KSPEC-015 |
| Title | Final Package Summary |
| Version | 0.2 (Draft) |
| Status | Draft - pending review |
| Created | 2026-10-13 |
| Baseline commit | `682f996c8447afec13bc1fce5b7f59e6a06efa25` (branch `feat/windows-sandbox-installer`, "Release Windows gateway and portable enrollment demo 0.1.4") |
| Revision history | 0.1 initial draft; 0.2 code/document reconciliation, 2026-10-13 (KSPEC-016) |
| Source references | KSPEC-000 evidence map; KSPEC-016 reconciliation evidence |
| Author | Unassigned - no approval recorded |
| Reviewer | Unassigned - no approval recorded |
| Approver | Unassigned - no approval recorded |

## 1. What was produced

A 17-document formal engineering specification package in `docs/formal-specification/`, reverse-engineered from the repository at the baseline commit. The package covers product definition, stakeholder and software requirements, architecture, interface control, cybersecurity threat model, operational risk, V&V, traceability, gap analysis, standards conformance, engineering handoff, independent review findings, package index, and this summary.

## 2. Requirements extracted

| Measure | Value |
|---|---|
| Stakeholder/user requirements (KSPEC-002) | 38 (UR-001 - UR-038): 11 Critical, 19 High, 7 Medium, 1 Low |
| Software requirements (KSPEC-003) | 154 (SR-F-REG, SR-F-EST, SR-F-CLM, SR-F-CAI, SR-F-ADM, SR-F-INT, SR-S, SR-A, SR-Z, SR-C, SR-D, SR-P, SR-R, SR-V, SR-U, SR-B, SR-O, SR-X) |
| Priority distribution (SR) | 36 Critical, 71 High, 38 Medium, 9 Low |
| Threats cataloged | 18 (THR-001 - THR-018, STRIDE) |
| Operational risks | 16 (ORK-001 - ORK-016, FMEA with RPN bands) |
| Verification tests specified | 60 (VT-001 - VT-060) |
| Gap findings | 40 (GAP-001 - GAP-040) |
| Independent review findings | 24 (RF-001 - RF-024; original review plus reconciliation) |
| Open decisions registered | 20 (DEC-001 - DEC-020 in KSPEC-012 §10) |

## 3. Requirements by implementation status (KSPEC-003 register)

| Status | SR count | UR count |
|---|---|---|
| Existing | 108 | 31 |
| Partial | 25 | 6 |
| Missing | 18 | 1 |
| Proposed | 3 | 0 (recorded at provenance level) |

Traceability: 114 of 154 SRs (74.0%) are VT-linked; 40 have no direct VT link; 38 of 38 URs trace to SRs (UR-007 is linked to initial setup and last-administrator protection); 18 of 18 threats and 16 of 16 operational risks are linked to requirements, with THR-018 lacking a VT; THR-015 links to proposed VT-059.

## 4. Major architecture findings

• Clean-architecture .NET 8 system: ASP.NET Core API (EST + admin) serving the React/TypeScript dashboard, with a separate optional Blazor Server portal, EF Core persistence (SQLite exercised; PostgreSQL implemented but unexercised), four CA connectors (Self-Signed, ACME, ADCS, EJBCA) behind a common connector abstraction, plus demonstration components (WPF EST client, DIMSE-TLS mTLS proxy).

• Strong AS-IS core guarantees (VERIFIED): standard HTTP-Basic EST bootstrap with one-time hashed activation codes and replay rejection; native TLS client-certificate re-enrollment with fresh keys and preserved identity; profile-scoped issuer routing with unknown-label 404 fail-closed behavior; issuer-scoped signed CRLs with transactional revocation failing closed on unsupported backends; race-safe activation consumption; restart persistence of trust policy.

## 5. Important cybersecurity gaps

1. Deployment blockers: unremediated high advisories in `SQLitePCLRaw.lib.e_sqlite3 2.1.6` and `System.Security.Cryptography.Xml 8.0.2` (THR-014, the only Critical residual risk).

2. Hard-coded JWT development fallback secret; legacy static SystemAdmin API keys (THR-007/009/016).

3. No lockout/brute-force throttling on admin authentication; 8-character minimum password policy.

4. XFCC client-certificate forwarding trusted from source IP only (no authenticated forwarder).

5. Hard-coded 60-second prototype CRL lifetime with anonymous CRL endpoint - revocation freshness is cadence-dependent.

6. Audit trail is plain database records without tamper-evidence or export.

7. Connector credentials (PFX passwords) may sit in plaintext configuration.

8. File-based CA key storage: host compromise equals CA compromise.

## 6. Interoperability limitations

• RFC 7030: `/cacerts`, `/simpleenroll`, `/simplereenroll` implemented (conformance judgments marked INFERRED; no conformity claimed). `/csrattrs`, `/serverkeygen`, `/fullcmc` not implemented; `/csrattrs` aligned to RFC 9908 if pursued.

• EST uses RFC 7030 request/response media types (`application/pkcs10`, `application/pkcs7-mime`); additional `text/plain` acceptance is a documented leniency. The device-record GUID is a site-specific Basic username convention, not a Basic wire-format deviation (RFC 7030 §§3.2.3, 4.2.1, 4.2.3).

• ADCS/EJBCA hospital enrollment and revocation interoperability remains UNVERIFIED; remote-CA revocation fails closed. EJBCA `/cacerts` sees an empty chain on a fresh scoped connector; earlier issuance in another request does not persist that cache.

• DICOM TLS (B.12/B.13-related) and OR.NET/IEEE 11073 SDC alignment are research goals only; no certification or adopted-profile claim is made.

• Contract artifacts drift: `OpenAPI.Client.yaml` is empty, `OpenAPI.Schema.yaml` is stale, EST paths exist in no OpenAPI file.

## 7. Outstanding engineering decisions (KSPEC-012 §10)

DEC-001 certificate-lifetime policy; DEC-002 notification triggers/reliability; DEC-003/004 OR.NET white-paper scope and shared test vectors; DEC-005 secrets mechanism; DEC-006 PostgreSQL selection; DEC-007 EST rate limits; DEC-008 forwarder authentication; DEC-009 long-lived renewal/retirement policy; DEC-010 CRL lifetime; DEC-011 device Untrusted vs Retired; DEC-012 key-archival/`EncryptedPrivateKeyPem` fate; DEC-013 enterprise PEN/OID namespace; DEC-014 anonymous self-service model; DEC-015 ATNA audit export/tamper protection; DEC-016 availability/capacity/latency targets; DEC-017 backup RPO/RTO; DEC-018 advisory remediation plan; DEC-019 metrics stack; DEC-020 retention periods.

## 8. Recommended implementation priorities (KSPEC-010 waves; KSPEC-012 roadmap)

• **Wave 0 / Phase 0 (deployment blockers):** dependency advisory remediation (GAP-005), remove JWT fallback secret with fail-closed startup (GAP-006), admin-auth lockout/rate limiting (GAP-007).

• **Phase 1:** core EST + self-signed CA + admin core with regenerated OpenAPI contracts and drift checks.

• **Phase 2:** renewal/revocation/notifications hardening (outbox, CRL policy, trust-withdrawal states).

• **Phase 3:** ADCS/EJBCA hospital interoperability with real evidence (first-time verification of THR-005/008).

• **Phase 4:** operational hardening - backup/restore rehearsals, secrets store, authenticated forwarders, metrics, audit tamper protection, component health.

# 9. Acceptance-criteria status (assignment §11)

1. Independent-engineer comprehension - met via KSPEC-001/003/004/005/012.
2. Mandatory functions as verifiable requirements - met (154 SRs, all with verification methods).
3. External integration contracts - met via KSPEC-005 (EST + admin + connector contracts; OpenAPI fragments embedded; contract-file regeneration is a tracked gap).
4. Security assumptions and trust boundaries - met via KSPEC-004 §5 and KSPEC-006.
5. Certificate lifecycle fully described - met via KSPEC-004 §8/§10 and KSPEC-003 SR-C/SR-F-CLM.
6. Architecture/data-model consistency - met within the package (RF-001 reconciliation recorded).
7. Full traceability - met via KSPEC-009 with empty cells explicitly reported.
8. Measurable acceptance criteria - met via KSPEC-008 VTs and KSPEC-012 definition of done.
9. Material implementation gaps documented - met via KSPEC-010 (40 gaps).
10. Unresolved decisions identified, not guessed - met via TBD/UNKNOWN discipline and DEC register.

**Overall verdict:** the package is a technically sound, evidence-faithful **Draft**. It is not approvable until stakeholder review, target verification and the TBD/DEC decisions are completed; documentation findings are dispositioned in KSPEC-013 and KSPEC-016. No application source code was modified. No fabricated evidence, approvals, or conformity claims exist in the package.

*End of KSPEC-015, version 0.2 (Draft).*